

AI 智能体安全调研报告

— 全生命周期视角下的风险机理、威胁演化与趋势分析

(2026 版)

中国科学院计算机网络信息中心
网络空间安全技术与应用发展部¹

2026 年 7 月

¹本报告聚焦 2025—2026 年度 AI 智能体安全领域工作进展，系统梳理国内外学术研究、产业落地产品及各国监管政策；全部调研资料整理截止至 2026 年 7 月 31 日，报告持续更新版本可查阅：AI 智能体安全调研报告网页版 (<https://2026.securityreportcnic.dpdns.org/>)。

序言

当前，全球自主式 AI 智能体（AI Agent）产业已进入规模化落地与高速扩张阶段，具备环境感知、自主规划决策、跨工具链路执行能力的智能体系统，已在政务、金融、医疗、工业等关键行业实现大规模部署。伴随技术落地进程，区别于传统大模型的专属安全风险持续迭代涌现，记忆投毒、分布式碎片化后门、权限越权滥用、多智能体协同共谋等新型威胁，构成了制约智能体安全应用的核心瓶颈。与此同时，全球各国围绕 AI 智能体的技术演进路线、安全防护标准、合规监管体系展开深度博弈，不同区域的治理规则与技术防护侧重点呈现明显分化特征。现阶段学界与产业界的相关研究多聚焦单点技术与碎片化风险分析，尚未形成覆盖技术、风险、治理的系统性安全分析框架。

中国科学院计算机网络信息中心（CNIC）是中国科学院科研管理信息化建设、运行、服务与技术创新的核心载体，深耕科学网络、高性能计算、科学数据、科研信息化管理等关键领域，长期支撑全院科技创新与科研模式变革。面向智能时代科研信息化发展新需求，中心将 AI 安全（AI4Security）纳入重点工作布局。基于上述产业发展、安全治理及机构科研布局背景，针对 AI 智能体安全开展体系化的现状梳理、风险解构与政策对标研判，具备重要的理论价值与工程实践意义。本报告通过横向对标中、美、欧全球主体的技术成果与合规标准，厘清各国 AI 智能体安全的研究重心与技术路线差异，构建全域视角下的系统性分析框架，弥补当前领域全局综述体系缺失的研究空白。

本报告以自主 AI 智能体安全为研究对象，构建全生命周期的调研分析框架¹。该框架以需求规划、架构设计、编码开发、安全测试、部署交付、运行迭代、退役销毁七大递进阶段作为生命周期主线覆盖智能体从研发至下线完整链路，沿业务流转链路划分感知、记忆、决策、行动、交互、治理六大功能模块构成横向切面以定位风险实体分布边界，依托该分析框架完成全阶段系统性的风险研判与防护体系梳理。

从内容架构来看，本报告共设七大章节：第一章为绪论，阐述领域研究背景、调研价值与研究方法；第二章综述国内外 AI 智能体安全研究团队、主流业界产品、政策法规与重大安全事件；第三章基于全生命周期框架，分层解析各阶段典型安全风险与内在成因；第四章归纳适配智能体特性的现有安全防护技术、检测机制与防御方案；第五章研判攻防技术演进趋势；第六章剖析当前 AI 智能体规模化落地过程中面临的技术、安全与产业现实瓶颈；第七章总结全文，并展望未来研究方向。

整体而言，本报告系统调研了 AI 智能体安全领域的发展现状、技术体系与治理格局，可帮助科研人员与行业从业者快速掌握领域安全挑战、主流技术路线与发展机遇，同时为初学者提供体系化的领域学习与研究思路参考。受调研周期、公开数据可得性及领域技术快速迭代等客观条件限制，本报告存在一定研究局限性，仅作为该领域研究与工程实践的基础性参考资料。

¹本报告采用专家主导、人机协同的调研范式完成研究工作：调研团队首先确立整体调研框架，界定研究目标、边界范畴与核心研究问题；其次依托大语言模型辅助完成报告框架搭建与基础信息归集；最后由调研团队对生成内容进行人工校验、溯源核查与深度调研分析，以此保障报告内容的准确性、严谨性与学术深度。

调研组成员信息

策划：孙德刚、龙春

调研小组组长：杨琨

调研小组成员²：丁文乐、李兴元、刘亚伟、钱郑希、王耀辉、张驰、郑思成、祝慕

²调研小组成员依照姓氏排序。感谢王蓉参与第四章前期内容的撰写工作。

目录

1	绪论	1
1.1	研究背景	2
1.2	全生命周期视角下 AI 智能体安全分析方法	3
1.3	调研报告参考文献统计分析	4
1.4	全生命周期逐阶段自研安全 OpenClaw 示例分析	9
1.5	调研报告组织结构	11
2	全球 AI 智能体安全研究现状	13
2.1	全球 AI 智能体安全学术研究现状	14
2.2	全球 AI 智能体安全主流产品	24
2.3	产业界与学术界联动	33
2.4	全球 AI 硬件与芯片底座安全研究现状	39
2.5	AI 智能体安全事件与主流攻击工具	46
2.6	全球 AI 智能体安全政策与法规	55
2.7	全球 AI 智能体产业共性安全瓶颈	65
3	AI 智能体全生命周期安全问题与挑战分析	67
3.1	需求规划阶段（安全产生源头）	68
3.2	架构设计阶段（安全体系定型）	72
3.3	编码开发阶段（安全工程落地）	76
3.4	安全测试评估阶段（安全验证排查）	80
3.5	部署交付阶段（安全环境固化）	84
3.6	运行迭代阶段（动态对抗演化）	88
3.7	退役销毁阶段（安全闭环收尾）	92
4	AI 智能体全生命周期安全现有防护方案分析	97
4.1	需求规划阶段（源头安全基线）	98
4.2	架构设计阶段（原生防护拓扑定型）	102
4.3	编码开发阶段安全（安全工程落地）	106
4.4	安全测试评估阶段（安全验证防护）	110

4.5	部署交付阶段（安全防护固化）	114
4.6	运行迭代阶段（动态演化防护）	118
4.7	退役销毁阶段（闭环收尾防护）	122
5	AI 智能体全生命周期安全发展趋势	127
5.1	需求规划阶段（攻防趋势）	128
5.2	架构设计阶段（攻防趋势）	132
5.3	编码开发阶段（攻防趋势）	136
5.4	安全测试评估阶段（攻防趋势）	140
5.5	部署交付阶段（攻防趋势）	144
5.6	运行迭代阶段（攻防趋势）	148
5.7	退役销毁阶段（攻防趋势）	152
6	AI 智能体规模化落地安全挑战与重要研究方向调研	157
6.1	AI 智能体规模化落地安全研究	158
6.2	大规模自主协同多智能体系统安全研究	160
6.3	基于 AI 智能体的漏洞挖掘与修复体系研究	162
6.4	多模型集成安全推理体系研究	165
6.5	国产化多模型聚合安全网关研究	167
7	总结	171
	参考文献	173
	期刊论文	173
	会议论文	176
	政府政策与报告	186
	预印本论文	190
	技术文档	215
	学术与项目主页	229

图索引

1.1	AI 智能体安全研究背景、必要性与报告调研思路	1
1.2	全生命周期视角下 AI 智能体安全分析：七大生命周期阶段 + 六大业务模块 . .	3
1.3	文献类型来源统计	4
1.4	研究主体来源统计	4
1.5	论文第一作者所在单位的所属国家统计	5
1.6	会议和期刊论文发表 Venue 分布分析	6
1.7	高校/科研院所论文发表情况统计	7
1.8	工业界论文发表情况统计	8
1.9	全生命周期逐阶段自研安全 OpenClaw 框架	9
1.10	调研报告组织结构	11
2.1	全球 AI 智能体安全研究现状	13
2.2	全球 AI 智能体安全学术研究现状	14
2.3	全球 AI 智能体安全主流产品	24
2.4	产业界与学术界联动现状	33
2.5	全球 AI 硬件与芯片底座安全研究现状	39
2.6	AI 智能体安全事件、漏洞与主流攻击工具	46
2.7	全球 AI 智能体安全政策与法规	55
2.8	全球 AI 智能体产业共性安全瓶颈	65
3.1	AI 智能体全生命周期安全问题与挑战分析	67
4.1	AI 智能体全生命周期安全现有防护方案分析	97
5.1	AI 智能体全生命周期安全发展趋势	127
6.1	AI 智能体规模化落地安全挑战与重要研究方向调研	157

表索引

2.1	北美顶尖高校 AI 智能体安全学术研究汇总	15
2.2	欧洲顶尖高校 AI 智能体安全学术研究汇总	18
2.3	我国顶尖高校与科研院所 AI 智能体安全学术研究汇总	21
2.4	北美主流 AI 智能体安全产品与落地方向	25
2.5	欧洲主流 AI 智能体安全产品与落地方向	28
2.6	我国主流 AI 智能体安全产品与落地方向	30
2.7	开源基础底座、云端企业智能体与自动化攻防评测体系	34
2.8	通用商用智能体、MCP 工具调用协议与端侧硬件隐私计算智能体	36
2.9	国产中文智能体评测基准与本土产学研安全体系	37
2.10	北美 AI 硬件与芯片安全研究汇总	40
2.11	欧洲 AI 硬件与芯片安全研究汇总	43
2.12	我国 AI 硬件与芯片安全研究汇总	44
2.13	典型 AI 智能体安全事件汇总	47
2.14	AI 智能体主要安全漏洞汇总	49
2.15	AI 智能体主流攻击工具汇总	53
2.16	北美 AI 智能体安全政策和法规汇总	56
2.17	北美 AI 智能体领域出口管制政策汇总	58
2.18	欧洲 AI 智能体安全政策和法规汇总	60
2.19	欧洲 AI 智能体领域出口管制政策汇总	61
2.20	我国 AI 智能体安全政策和法规汇总	62
2.21	我国 AI 智能体领域出口管制政策汇总	64
2.22	全球 AI 智能体产业共性安全瓶颈	66
3.1	AI 智能体 需求规划阶段 安全问题与研究挑战	69
3.2	AI 智能体 架构设计阶段 安全问题与研究挑战	73
3.3	AI 智能体 编码开发阶段 安全问题与研究挑战	77
3.4	AI 智能体 安全测试阶段 安全问题与研究挑战	81
3.5	AI 智能体 部署交付阶段 安全问题与研究挑战	85
3.6	AI 智能体 运行迭代阶段 安全问题与研究挑战	89

3.7	AI 智能体 退役销毁阶段 安全问题与研究挑战	93
4.1	AI 智能体 需求规划阶段 现有安全解决方案与缺陷	99
4.2	AI 智能体 架构设计阶段 现有安全解决方案与缺陷	103
4.3	AI 智能体 编码开发阶段 现有安全解决方案与缺陷	107
4.4	AI 智能体 安全测试评估阶段 现有安全解决方案与缺陷	111
4.5	AI 智能体 部署交付阶段 现有安全解决方案与缺陷	115
4.6	AI 智能体 运行迭代阶段 现有安全解决方案与缺陷	119
4.7	AI 智能体 退役销毁阶段 现有安全解决方案与缺陷	123
5.1	AI 智能体 需求规划阶段 攻防趋势	129
5.2	AI 智能体 架构设计阶段 攻防趋势	133
5.3	AI 智能体 编码开发阶段 攻防趋势	137
5.4	AI 智能体 安全测试阶段 攻防趋势	141
5.5	AI 智能体 部署交付阶段 攻防趋势	145
5.6	AI 智能体 运行迭代阶段 攻防趋势	149
5.7	AI 智能体 退役销毁阶段 攻防趋势	153
6.1	AI 智能体规模化落地工程化安全挑战（产业部署与运维维度）	158
6.2	大规模自主协同多智能体系统安全研究现状与发展趋势	161
6.3	AI 智能体漏洞挖掘与修复研究现状与发展趋势	163
6.4	多模型集成安全推理体系研究现状与发展趋势	166
6.5	国产化多模型聚合安全网关研究现状与发展趋势	168

第 1 章 绪论

相较于传统大语言模型（Large Language Model, LLM）仅能接收用户指令、完成被动应答的交互范式，AI 智能体（Artificial Intelligence Agent, AI Agent）¹具备自主规划、主动推理、动态执行的智能化特征。随着自主决策链路不断延长、外部工具调用权限持续拓宽，AI 智能体的行为边界与攻击面大幅扩张，由此衍生出大量区别于传统静态大模型的新型安全风险。基于此，本章系统梳理 AI 智能体安全的研究背景，阐明开展智能体安全调研的必要性，并介绍本报告采用的调研方法，如图 1.1 所示。



图 1.1: AI 智能体安全研究背景、必要性与报告调研思路

¹本报告研究对象为通用自主 AI 智能体，涵盖纯软件智能体与实体物理智能体，全文围绕 AI 智能体安全维度开展专项调研与体系化分析。如无特殊声明，文中智能体、AI 智能体、AI Agent 为同义表述，行文交替使用。

1.1 研究背景

相较于 ChatGPT、DeepSeek、豆包等传统 LLM 所采用的被动交互范式²，AI 智能体具备自然语言语义解析、复杂任务分层拆解、跨异构工具调度、闭环自主执行与结果迭代优化等内生智能化能力，推动 AI 从传统被动信息交互模式，演进为目标驱动、自主决策、闭环迭代的主动执行范式³。该范式跃迁大幅提升了 AI 在复杂场景下的任务适配与落地赋能能力，但也随之衍生出传统静态大模型场景未曾出现的一系列原生安全风险。其典型新型威胁涵盖长期目标劫持与持续行为偏移、持久记忆污染诱发的决策失真、多工具链式调用引发的权限越界与实体级安全危害、多智能体协同交互导致的集群涌现级联失控，以及高度自治闭环运行所带来的行为可追溯性与可审计性缺失等安全问题 [1], [2], [3]。在此技术演进与新型风险叠加的背景下，面向 AI 智能体开展系统性安全专项研究具备显著必要性与紧迫性。

在技术防护层面，传统面向静态 LLM 构建的关键词过滤、静态提示词防护、输出侧规则校验等安全机制，均建立在人在回路、输出可控的被动式 LLM 交互假设之上，难以适配智能体自主规划、多工具链式调用、长周期自治运行形成的新型风险机理 [4]。传统防护手段以即时输出拦截为核心目标，对智能体渐进式诱导、长期累积形成的恶意行为缺乏有效识别与阻断能力，无法应对链式传导、潜伏式攻击等自治系统特有威胁，防护体系存在底层适配缺陷 [5]。

在学术研究层面，现有大模型安全成果大多聚焦 LLM 单点攻防、静态提示词漏洞与孤立模型对齐缺陷，研究视角较为碎片化，尚未形成覆盖记忆层、规划推理层、工具调用层、多智能体协同层的完整风险分析框架 [6]。现有研究难以充分阐释智能体特有的风险链式传导、涌现式异常、长周期状态漂移等安全机理，针对自主决策闭环与动态迭代过程的风险演化规律剖析不足，理论研究整体滞后于智能体技术产业化落地速度 [7], [8]。

在产业实践层面，业界已普遍认知 AI 智能体区别于传统大模型的差异化风险特征，头部科技厂商相继推出针对性风控组件。但当前产业解决方案仍偏向单点权限管控、基础工具调用限制，缺少覆盖智能体设计、部署、运行、迭代全生命周期、贯穿完整执行链路的一体化防御体系，面向复杂业务场景的规模化落地成熟度有待提升 [9]。同时，OWASP Agentic AI 安全框架等行业规范指出，多数现有防护方案缺少对持久记忆污染、多智能体交互失控等场景的原生支持，防御能力存在明显短板 [1]。

在全球治理与政策博弈层面，各国针对 AI 智能体的研发路线、安全价值取向与监管实施路径呈现显著分化。当前全球 AI 治理框架普遍存在顶层原则偏宏观、细分落地细则缺失、规制迭代节奏滞后于技术演进速度等共性难题，难以匹配智能体全域产业化、跨平台泛化部署的发展节奏 [10], [11]。智能体跨场景、跨地域、跨系统自主调度工具的运行特征，进一步放大监管边界模糊、跨境合规标准不统一、监管套利等现实治理痛点。

综上，无论从技术防护机理、学术理论体系构建、产业规模化安全落地，还是全球 AI 合规治理博弈视角审视，传统 LLM 安全防护体系已无法适配自主 AI 智能体衍生的新型安全诉求。亟需针对 AI 智能体独有的风险范式，开展专项、体系化的安全梳理、调研与机制研究。

²传统 LLM 以用户单次提问、单次输出的静态交互模式为核心，依赖人工实时输入与指令触发，不具备主动任务规划、工具自主调用与长周期闭环迭代能力，整体运行逻辑遵循“人启始、人监督、人终止”的人在回路 (Human-in-the-Loop, HITL) 约束，安全风险主要集中于单轮输出内容违规、提示词攻击、模型幻觉等单点问题。

³现有 AI 智能体可主要分为强化学习智能体 (Reinforcement Learning Agent, RL Agent) 与大模型驱动智能体 (LLM-based Agent)。RL Agent 基于奖励函数与环境试错迭代优化策略，场景专用性强、泛化能力弱。LLM-based AI 智能体依托大模型语义推理能力，可根据自然语言指令自主实现任务拆解、工具调度与闭环迭代，具备开放场景通用执行能力。两类智能体在技术架构、运行机制及安全特性上差异显著。本文若无特殊说明，所述 AI 智能体均指代 LLM-based AI 智能体。

1.2 全生命周期视角下 AI 智能体安全分析方法

针对当前 AI 智能体产业高速扩张、新型安全风险持续涌现、全球技术竞争与治理博弈日趋激烈，同时行业尚未形成标准化安全方法论、领域内系统性理论框架与工程实践体系相对匮乏的现实背景，本报告聚焦自主式 AI 智能体的核心安全议题，面向智能体差异化风险机理与全流程业务特征，构建七阶递进的 AI 智能体全生命周期安全模型，如图 1.2 所示。该模型完整覆盖智能体安全从概念孵化到生命周期终止的全部业务链路，将其标准化划分为需求规划、架构设计、编码开发、安全测试、部署交付、运行迭代与退役销毁七大核心阶段，为 AI 智能体安全风险治理、防护体系搭建与工程落地提供体系化理论支撑与实践指引。



图 1.2: 全生命周期视角下 AI 智能体安全分析：七大生命周期阶段 + 六大业务模块

从生命周期运行逻辑来看，各阶段业务有序衔接、环环相扣，同时存在典型的风险链式传导、逐级叠加的演化机制。AI 智能体具备自主决策、动态迭代的特性，区别于传统软件，全流程风险隐蔽性更强、传导链路更复杂。上游产生的需求缺陷、架构漏洞、代码隐患与安全管控缺失不会自行消除，将持续向下传递并不断放大。需求规划阶段若智能体能力边界、权限范围、交互规则与安全目标界定模糊，将造成顶层架构根本性偏差；架构存在信任划分不清、组件隔离不足、权限设计不合理等问题，会转化为代码层安全缺陷；安全测试若难以覆盖自主规划、工具调用、多轮交互、指令逃逸等特有场景，形成测试盲区，隐性漏洞将流入生产环境；部署交付阶段配置不当、密钥管控薄弱、访问策略宽松、运行隔离不足，会固化底层安全隐患；智能体上线后模型微调、插件更新、提示词持续迭代等动态行为，会进一步激活并放大前期原生缺陷，叠加新增运行风险，引发跨组件、跨系统的系统性安全事故。

为实现全生命周期安全要素的精细化拆解与精准归因，我们进一步对各生命周期阶段的内

部安全能力维度进行解构。依托 AI 智能体“输入-存储-推理-执行-交互-管控”的完整业务运行逻辑与数据流转链路，本报告将每一个生命周期阶段进一步**横向**切分为感知、记忆、决策、行动、交互、治理六大核心功能模块。该分层方式基于系统架构、实体组件与业务流程特征开展扁平化划分，能够精准锚定安全缺陷、攻击链路与异常行为在智能体各功能单元的分布位置，且六大模块相互独立、并行耦合，不存在层级递进与主次从属关系。

1.3 调研报告参考文献统计分析

本报告共收录参考文献 1143 篇，涵盖期刊论文、会议论文、预印本论文、技术报告、政策文件及网络资源等多种类型，主要聚焦 AI 智能体安全研究。本节重点统计分析学术论文，包括期刊论文、会议论文和预印本论文，共计 507 篇。本次文献采集主要覆盖 2025 - 2026 年（截至 7 月 31 日）公开发表成果，受限于检索范围、数据库覆盖以及筛选标准，统计结果可能存在一定偏差。

文献类型来源分析：图 1.3 展示本次调研中文献类型来源分布情况。从文献类型分布来看，智能体安全相关研究呈现出明显的快速演进和开放探索特征。在统计的 507 篇论文中，预印本论文占据绝对主导地位，共 362 篇，占比 71.4%。这一结果表明，当前智能体研究仍处于高速发展阶段，新模型、新架构和新应用不断涌现，研究人员更倾向于通过预印本平台快速发布最新成果，以缩短成果传播周期并促进社区交流。与此同时，较高比例的预印本也说明部分研究方向仍处于探索验证阶段，尚需要进一步经过同行评审、长期实验和实际应用检验。会议论文共 116 篇，占比 22.9%，是当前智能体研究的重要成果载体。相比传统成熟研究领域，智能体技术具有较强的工程实践属性，大量研究集中于智能体框架设计、任务规划、工具调用、多智能体协作、安全机制以及应用系统构建等方向。这类研究通常需要快速验证技术有效性，并借助学术会议实现成果交流，因此会议论文在该领域占据较高比例。相比之下，期刊论文数量相对较少，共 29 篇，占比 5.7%。其主要原因在于智能体技术发展速度远快于传统学术出版周期，许多研究成果在完成系统验证后优先以预印本或会议论文形式公开。此外，面向智能体的理论基础、评价体系、安全治理框架以及长期可靠性分析仍处于逐步完善阶段，系统性的期刊研究成果尚未形成规模。

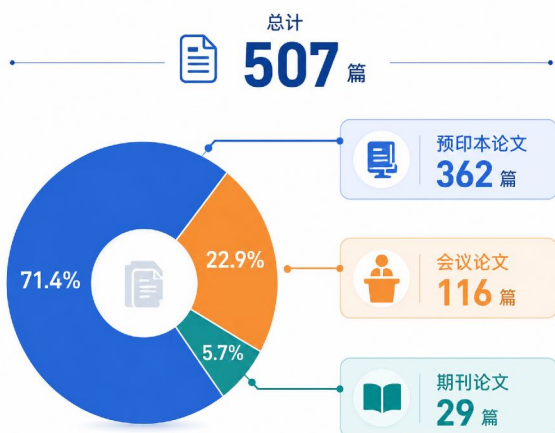


图 1.3: 文献类型来源统计

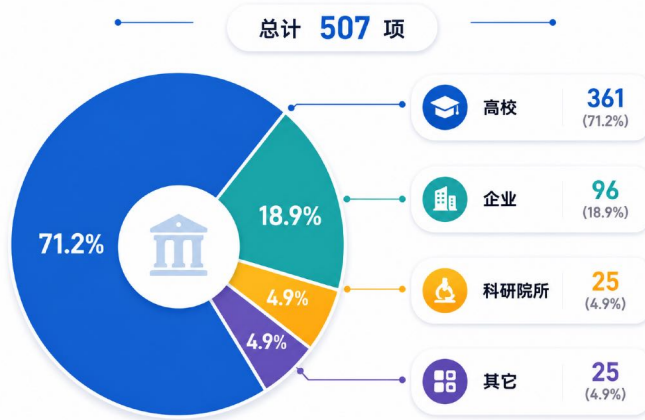


图 1.4: 研究主体来源统计

研究主体来源划分：图 1.4 展示智能体安全相关研究中不同类型研究主体的贡献分布情况。根据机构属性划分，研究主体主要包括高校机构、企业机构、科研院所以及其他类型机构。在统计的 507 篇论文中，高校机构贡献 361 篇，占比 71.2%，是当前智能体研究的主要力量。高校依托长期积累的基础研究能力，在智能体架构设计、算法创新、模型优化、理论分析以及安全可信机制等方向持续发挥核心作用，说明当前智能体技术的发展仍高度依赖学术界的探索和创新。企业机构贡献 96 篇，占比 18.9%，位居第二。随着大语言模型和智能体应用快速发展，企业逐渐成为推动该领域技术演进的重要力量。相比传统人工智能研究，企业参与更加关注智能体系统的工程化实现，包括模型能力增强、工具调用机制、应用场景适配、安全控制以及实际部署等方向，体现出智能体技术正在由实验验证逐步迈向产业应用阶段。科研院所贡献 25 篇，占比 4.9%。虽然整体规模相对有限，但科研机构在基础理论探索、前沿技术研究、标准体系建设以及可信智能研究等方面具有重要支撑作用。此外，其他类型研究主体（包括独立研究团队、实验室、政府科研项目等）贡献 25 篇，占比 4.9%，进一步体现了智能体领域研究主体的多样化特征。总体而言，当前智能体研究仍以高校为核心驱动力，企业参与程度不断提升，科研机构和其他创新主体发挥补充作用，形成了从基础理论研究、技术创新到工程应用落地的多层次协同发展模式。

第一作者国家分布统计 (Top 3 + Others)

DISTRIBUTION OF FIRST-AUTHOR COUNTRIES

总计 507 篇文献

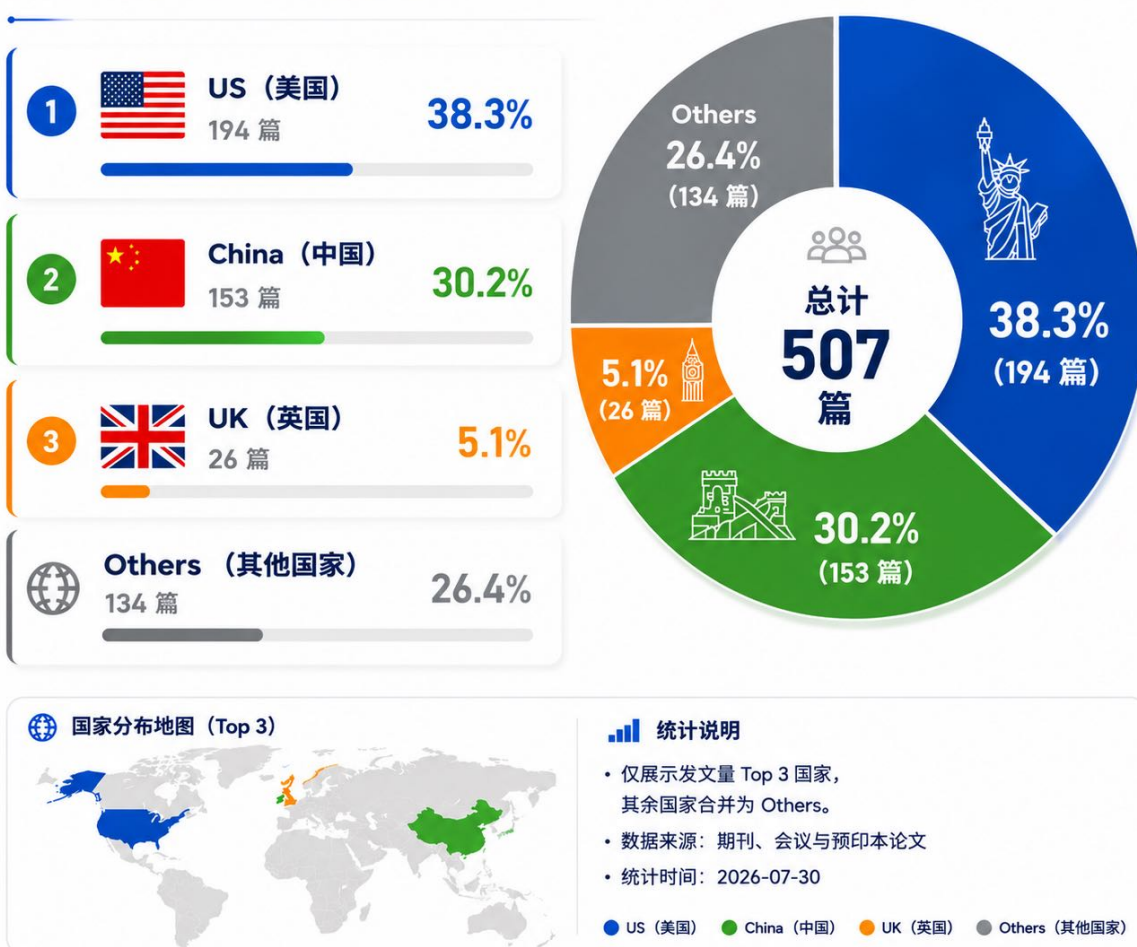


图 1.5: 论文第一作者所在单位的所属国家统计

论文第一作者所在单位的所属国家分析：图 1.5 展示论文第一作者所在单位所属国家的分布情况。通过统计分析可以发现，当前智能体安全相关研究呈现出明显的区域集中化特征，同时具有多国家共同参与的发展格局。在统计的 507 篇论文中，美国和中国占据主要贡献地位，二者构成当前智能体研究领域的核心力量。其中，美国以 194 篇论文位居首位，占比 38.3%。美国在大模型基础设施、智能体框架、模型安全以及产业应用等方向具有较强的技术积累和创新生态，拥有大量领先的人工智能研究机构和企业，因此在智能体相关研究产出中保持较高占比。中国以 153 篇论文位列第二，占比 30.2%，近年来在大规模语言模型、智能体系统设计、应用场景探索以及工程部署等方面快速发展，已形成较大规模的研究群体和技术生态。英国以 25 篇论文排名第三，占比 5.1%。虽然其研究规模与中美相比存在一定差距，但仍保持稳定的学术贡献，在人工智能基础研究、安全性分析和可信智能体等方向发挥重要作用。除上述主要国家外，其余国家和地区共贡献 135 篇论文，占比 26.6%，包括加拿大、瑞士、新加坡、韩国、澳大利亚、德国、法国、日本等多个科研力量较强的国家。这表明智能体研究已经形成一定程度的全球化发展格局，并逐渐呈现多中心参与的特点。总体来看，美国和中国两国合计贡献 347 篇论文，占全部统计成果的 68.5%，说明当前智能体研究资源和创新产出仍主要集中于少数领先国家。同时，其他国家持续增加的研究贡献也表明，该领域正在从早期少数机构主导逐步向全球范围内广泛参与的发展阶段演进。

论文发表 Venue 分布分析：图 1.6 展示会议和期刊论文发表 Venue 分布统计结果（不包含 arXiv 论文）。我们可以看出智能体相关研究正在逐步进入正式学术传播与同行评审阶段，但整体仍呈现高度分散化特征。

在 145 篇正式发表或收录论文中，ACL 相关会议/论文集以 16 篇位居首位，占比 11.0%；ICML 以 12 篇位列第二，占比 8.3%；ICLR 和 NeurIPS 分别贡献 8 篇，占比均为 5.5%。此外，AAAI、USENIX Security 等人工智能与安全领域的重要会议也占据一定比例，表明智能体研究主要集中于自然语言处理、机器学习、深度学习以及安全可信人工智能等方向。从整体结构来看，Top 10 Venue 贡献相对有限，其余 Venue 合计 80 篇，占比 55.2%，说明当前智能体研究尚未形成高度集中的发表渠道，而是分布于人工智能、软件工程、网络安全、人机交互等多个交叉领域。这一现象反映出智能体作为新兴研究方向，具有明显的跨学科特点，其研究内容涵盖智能规划、工具调用、多智能体协作、智能体安全、可靠性评估等多个主题，尚处于快速扩展阶段。

论文发表 Venue 分布 (Top 10, 不含 arXiv)



图 1.6: 会议和期刊论文发表 Venue 分布分析

学术论文发表情况分析：图 1.7 显示科研单位论文发表统计结果（由于欧洲论文图片较少，所以图中也包括了 ≥ 2 篇的科研单位）。我们可以观察到智能体领域学术研究呈现出中美主导、欧洲积极参与、多区域协同发展的国际格局。整体来看，高水平研究机构主要集中于美国和中国，欧洲部分机构虽然数量较少，但在人工智能基础研究和安全方向仍具有较强影响力。从中

国高校及科研院所分布来看，研究力量呈现高度集中化特征。浙江大学（ZJU）和上海交通大学（SJTU）以 8 篇论文并列领先，复旦大学（Fudan）以 7 篇紧随其后，清华大学（THU）、北京大学（PKU）、北京航空航天大学（BUAA）以及中国科学院信息工程研究所（IIE-CAS）均达到 6 篇。华中科技大学（HUST）、北京邮电大学（BUPT）、哈尔滨工业大学（HIT）等机构也表现出较强研究活跃度。美国研究机构方面，呈现出顶尖高校引领、多机构均衡参与的特点。加州大学伯克利分校（UC Berkeley）以 8 篇论文位居首位，密歇根州立大学（MSU）、圣路易斯华盛顿大学（WashU）和卡内基梅隆大学（CMU）均达到 5 篇，宾夕法尼亚州立大学（PSU）、南加州大学（USC）达到 4 篇。此外，麻省理工学院（MIT）、普渡大学（Purdue）、亚利桑那州立大学（ASU）、哥伦比亚大学（Columbia）以及加州大学洛杉矶分校（UCLA）等机构持续贡献相关研究。欧洲及俄罗斯地区的研究规模相对较小，但仍展现出较强的专业影响力。帝国理工学院（ICL）以 6 篇论文领先，牛津大学（Oxford）达到 3 篇，剑桥大学（Cambridge）、苏黎世联邦理工学院（ETH Zurich）、柏林工业大学（TU Berlin）、莫斯科国立大学（LMSU）等机构均有持续贡献。

科研单位论文发表统计（仅显示 ≥ 3 篇）



图 1.7: 高校/科研院所论文发表情况统计

工业界论文发表情况分析：图 1.8 显示工业界论文发表统计结果。我们可以发现当前智能体相关研究中的产业参与呈现出头部企业引领、多区域参与、技术生态逐渐形成的特点。从中国

工业界来看，研究主体较为分散，主要包括字节跳动（ByteDance）、华为（Huawei）、深度求索（DeepSeek）等人工智能相关企业。其中，ByteDance、Huawei 和 DeepSeek 均贡献 2 篇论文，处于国内企业领先地位；此外，腾讯、百度、商汤、科大讯飞、快手、理想汽车等企业也有相关研究成果。美国工业界表现出更明显的集中化和平台化特征。其中，Google 以 4 篇论文位居首位，Microsoft 和 IBM 分别贡献 3 篇，Meta、NVIDIA 和 Amazon 也持续参与智能体相关研究。美国企业凭借基础模型、云计算平台和 AI 基础设施优势，在智能体框架、工具调用、智能系统评测等方向保持领先。欧洲及其它地区企业整体论文数量较少，但参与主体具有较强多样性，包括 Spotify、Booking Holdings、SAP、Ericsson、ARM、Bosch、Siemens 等企业。总体而言，工业界论文分布呈现出“美国企业主导基础技术，中国企业快速跟进应用创新，欧洲企业侧重行业融合”的发展格局。



图 1.8: 工业界论文发表情况统计

1.4 全生命周期逐阶段自研安全 OpenClaw 示例分析

本小节以自研安全可控 OpenClaw 通用智能体为研究示例，全程围绕 OpenClaw 原生四层核心组件（Gateway 网关、智能体决策内核、Skills 技能执行、Memory 记忆存储），搭配横向六大业务功能模块（感知、记忆、决策、行动、交互、治理），完整拆解自研 OpenClaw 从立项到下线全流程安全落地建设路径（七大生命周期阶段），如图 1.9 所示：

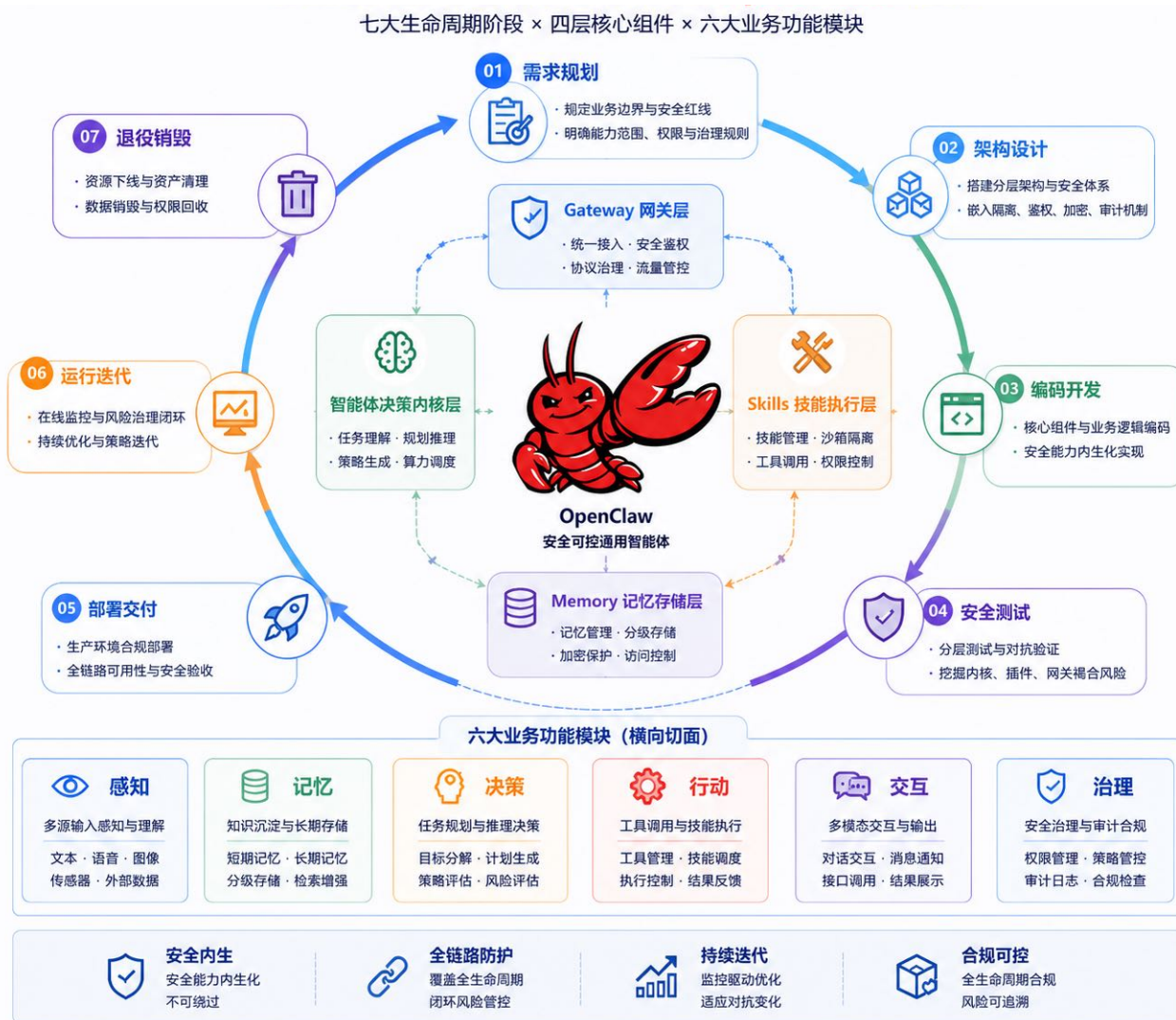


图 1.9: 全生命周期逐阶段自研安全 OpenClaw 框架

- **需求规划阶段-划定自研 OpenClaw 业务边界与安全红线。**本阶段是安全可控 OpenClaw 研发的起点，核心目标是针对开源 OpenClaw 原生高危缺陷（如高权限 Shell 执行、无隔离技能插件与记忆明文存储等），提前定制自研版本业务范围与划定安全界线，统一整套 OpenClaw 全生命周期功能、权限、安全基线，从需求源头规避开源原版先天安全缺陷，避免研发中后期大规模重构 OpenClaw 内核逻辑。**横向切面**聚焦自研 OpenClaw 六大模块落地需求：限定 Gateway 网关外部交互渠道、Memory 记忆存储数据类型、智能体决策层算力调度范围、Skills 技能执行可调用系统工具清单，明确全链路治理审计规则，形成 OpenClaw 专属需求规格书。
- **架构设计阶段-搭建自研 OpenClaw 业务骨架与底层安全防护体系。**基于需求规格书，搭建安全原生自研 OpenClaw 分层架构，将感知、记忆、决策、行动、交互、治理六大模块嵌

入 Gateway、智能体、Skills、Memory 四层内核。区别于开源 OpenClaw 外挂式补丁防护设计，本阶段将隔离、鉴权、加密、审计安全机制深度植入 OpenClaw 底层内核，从架构层面解决原有系统性漏洞。**横向切面**完成 OpenClaw 架构分层设计：解耦重构 Gateway 交互网关、智能体决策内核、Skills 技能执行池、Memory 分级存储单元，标准化模块间通信协议、记忆数据流转、算力调度逻辑，保障后续 OpenClaw 插件扩容、渠道迭代不会破坏底层安全机制。

- **编码开发阶段-自研 OpenClaw 代码开发。**依据自研 OpenClaw 分层架构图，完成 Gateway 网关、智能体决策内核、Skills 技能池、Memory 存储四大核心组件全量编码，落地六大业务模块完整逻辑。核心改造目标是彻底修复开源 OpenClaw 安全短板，将沙箱拦截、记忆脱敏、权限校验、指令审计等安全逻辑直接写入内核底层代码，而非上线后额外加装防护插件，使安全管控成为自研 OpenClaw 不可绕过的原生能力。**横向切面**采用 OpenClaw 分模块并行开发：分团队独立开发网关交互、决策推理、技能执行、记忆存储单元，保障自研 OpenClaw 多渠道接入、自动化任务执行完整可用。
- **安全测试阶段-自研 OpenClaw 上线前全维度测试。**针对自研 OpenClaw 完整内核版本开展分层全量测试，构造大量针对 OpenClaw 原生漏洞的对抗场景，模拟提示注入、恶意技能投毒、记忆篡改等攻击，深度挖掘自研改造后内核、插件、网关耦合产生的新型安全漏洞。当业务、安全双指标全部达标后，自研 OpenClaw 才可进入生产部署环节。**横向切面**开展 OpenClaw 分层功能测试：对网关、决策、技能、记忆模块分别执行单元测试，完成端到端全链路集成测试，定位渠道接入失效、技能执行报错、记忆同步异常等表层业务故障。
- **部署交付阶段-自研 OpenClaw 生产环境合规部署。**将测试完成的自研 OpenClaw 部署至异构环境中，完整校验 Gateway 网关对接企业业务系统、智能体自主调度、Skills 批量执行、Memory 租户隔离全链路可用性，逐项核验自研沙箱、记忆加密、网关鉴权等安全机制在真实业务环境的落地效果。**横向切面**完成 OpenClaw 整机交付核验：部署后完整跑通自研 OpenClaw 全业务链路，验证多渠道接入、自动化技能执行、记忆读写全部满足交付验收标准。
- **运行迭代阶段-自研 OpenClaw 长期在线运维监控。**本阶段是自研 OpenClaw 全生命周期周期最长、动态安全风险最频发环节。自研 OpenClaw 在线完成网关指令接收、智能体自主任务规划、Skills 自动化执行、Memory 长期记忆存储，伴随技能插件迭代、外部针对 OpenClaw 攻击手段持续更新，会不断累积沙箱逃逸、记忆泄露、权限滞留等隐患。本阶段核心目标是针对自研 OpenClaw 内核、网关、插件搭建动态风险治理闭环，实时监控各模块异常、溯源内核风险、迭代沙箱与网关防御策略，持续优化自研 OpenClaw 原生安全能力，适配持续变化的对抗环境。**横向切面**实现 OpenClaw 全模块实时监控：采集网关接入流量、决策推理行为、技能执行记录、记忆读写日志全维度运行指标，快速识别指令注入、越权调用、恶意记忆注入等风险并实时预警。
- **退役销毁阶段-自研 OpenClaw 下线全资源清理。**针对自研 OpenClaw 版本淘汰、业务下线场景，完成整套自研 OpenClaw 关联数字资产标准化销毁清理。解决项目下线清理机制、记忆文件残留、权限遗留复用等长效风险，完成自研安全可控 OpenClaw 全生命周期安全闭环。**横向切面**开展 OpenClaw 分模块数字资产清理：如彻底销毁记忆文件、切断交互链路与封存审计日志等操作，实现自研 OpenClaw 相关资源无残留处置。

1.5 调研报告组织结构

本调研报告共包括七大章节，如图 1.10 所示：



图 1.10: 调研报告组织结构

第 2 章 全球 AI 智能体安全研究现状

本章以 2025—2026 年公开行业资料为核心研究依据，聚焦 AI 智能体安全领域开展系统性调研。研究全面梳理了北美、欧洲及我国的前沿学术成果、产业主流安全解决方案与 AI 硬件芯片安全相关研究，结合近两年典型重大安全事件完成复盘剖析。同时，本章汇总梳理了全球各国的 AI 监管合规体系、出口管控法规，总结当前产业存在的共性安全瓶颈，从技术、产业、治理多维度，全方位剖析 AI 智能体安全领域的发展现状与现存问题，如图 2.1 所示。



图 2.1: 全球 AI 智能体安全研究现状

2.1 全球 AI 智能体安全学术研究现状

本节主要围绕全球 AI 智能体安全学术研究格局展开梳理，选取北美、欧洲与国内顶尖高校、国家级重点实验室作为调研对象，系统开展相关研究工作的梳理、对比与深度分析，如图 2.2 所示。通过归纳各区域研究团队的主攻方向、代表性技术路线、重点攻关问题与已有成果，厘清不同地域在 AI 智能体安全领域的研究侧重、技术路径差异与能力边界，对比各方在智能体攻击范式、防护框架、协同安全、可信验证等方向的研究进展，明确我国现阶段学术研究存在的优势与短板，为后续研究方向选择、关键技术攻关布局提供参考依据。

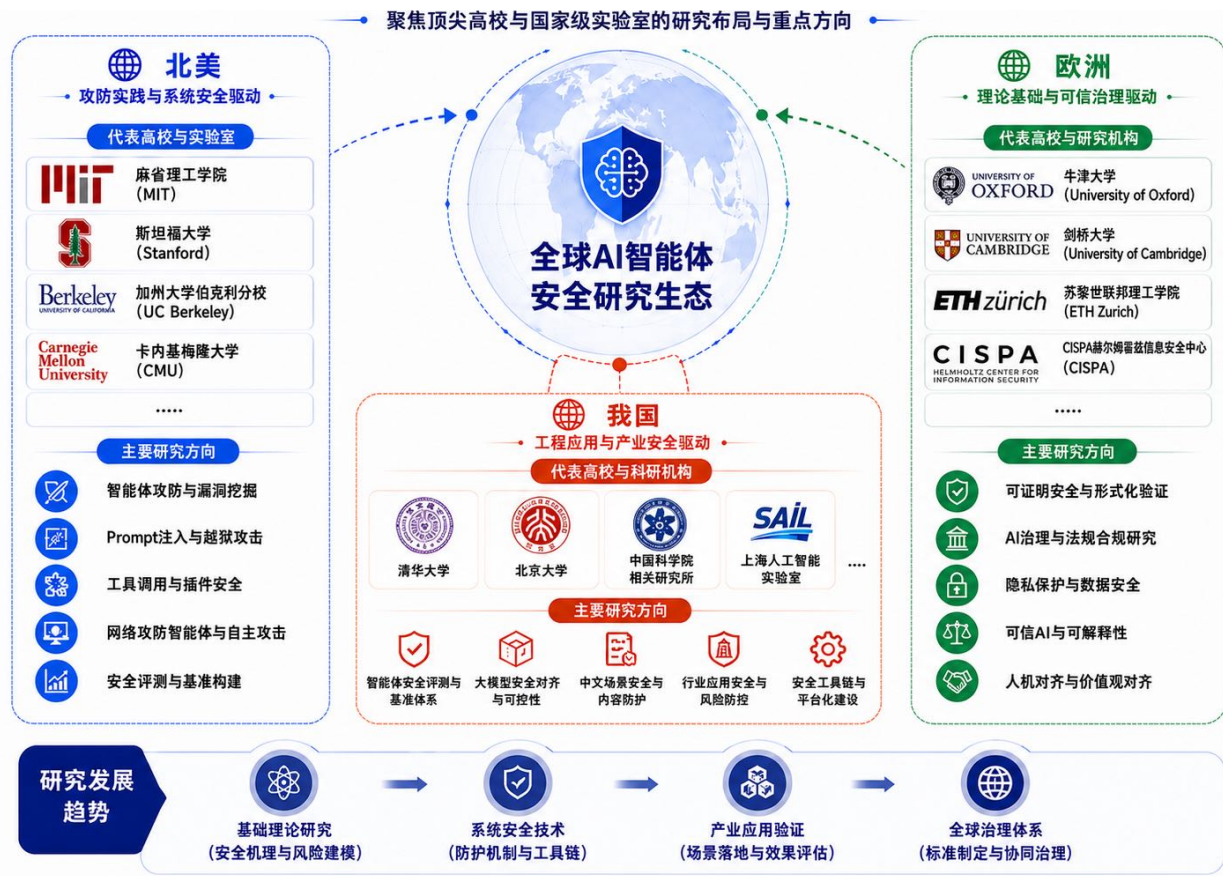


图 2.2: 全球 AI 智能体安全学术研究现状

2.1.1 北美 AI 智能体安全学术研究现状

本小节梳理北美地区 AI 智能体安全的研究主体、研究方向和标志性学术成果，覆盖麻省理工学院 (MIT)、斯坦福大学 (Stanford)、加州大学伯克利分校 (UC-Berkeley)、卡内基梅隆大学 (CMU) 等美国顶尖高校，以及多伦多大学 (UofT)、麦吉尔大学 (McGill)、英属哥伦比亚大学 (UBC) 等加拿大顶尖高校，主要发现如下（详见表 2.1）：

- 北美相关研究主要集中于少数高校和跨学科实验室，但不同机构内部的研究主题具有交叉性。在本节收集的公开成果中，MIT 相关团队的工作涉及通用 AI 风险分类和系统安全基础 [12], [13]；Stanford 发布了模型评测、透明度和智能体运行环境方面的研究与工具 [14], [15]；UC-Berkeley 开展函数调用评测和上下文安全研究 [16], [17]；CMU 提出了面向代码安全的过程奖励模型。现有研究划分基础理论、系统防护、场景应用三层体系：理论产出上下文安全四维属性理论 [17]、DemPO 对齐算法 [18]、WARP 检索污染攻击 [19]；系统工具

包含 JAI 沙箱 [15]、IsolateGPT 插件隔离、Progent 权限代理 [20]；研究场景覆盖代码、机器人、网络攻防四类智能体；评测工具包含 Gorilla、BFCL、SWE-bench、SafeArena [21]、MIT 风险库 [12]，分别用于函数调用、代码修复、网页交互、风险分类与模型透明性量化测试。

- **部分受控实验表明，自主智能体能够执行多步骤网络攻击或辅助漏洞复现，但不同系统的任务定义和成功率差异较大。**CMU 复现了 Equifax 数据泄露链路攻击，显示智能体可依次执行漏洞利用、恶意程序部署和数据外传 [22]；纽约大学（NYU）PromptLock 研究展示了由大模型驱动的自主勒索软件原型 [23]；类似实验观察到 AI 蠕虫根据环境反馈调整策略并在测试网络中传播 [24]。普渡大学 (Purdue) ASTRA 系统发现的问题比现有技术多 11% 至 66% [25]；UC-Berkeley 可根据漏洞描述和源码生成用于复现漏洞的 PoC [26]。
- **研究同时覆盖技术、政策、运营多维度，北美高校与国家级机构同步产出治理规范与校内安全处置机制。**哈佛 (Harvard) Kempner 中心、普林斯顿 (Princeton) CITP 开展智能体商业部署边界、平台风控责任相关研究 [27], [28]；加拿大多家国家级机构发布可信 AI、生成式 AI 治理文档，相关内容被官方政策引用 [29], [30]。CMU 建立的 AI 安全响应团队 AISIRT，专职处理生成式 AI 安全漏洞与突发事件 [31]；伊利诺伊大学香槟分校 (UIUC) 将智能体安全流程并入原有网络安全漏洞管理、应急响应体系 [32]。

表 2.1: 北美顶尖高校 AI 智能体安全学术研究汇总

国家	高校	实验室/研究团队	AI 智能体安全核心研究方向
美国	麻省理工学院 (MIT)	DRL [33]	软体机器人安全控制与人机交互约束： Daniela Rus 团队研发具备数学安全保障的软体机器人控制系统，约束机器人形变、环境适配与人机交互过程中的违规行为 [34]。
		ALFA Lab [35]	智能体网络攻防鲁棒性与威胁情报知识图谱： Una-May O'Reilly 团队基于 CybORG 平台完成 LLM 智能体攻防能力评测，构建融合 MITRE ATT&CK、CWE、CVE 的威胁知识图谱 BRON [35]。
		FutureTech [12]	AI 风险统一分类与治理框架： 搭建包含 1725 条条目的 AI 风险仓库，采用因果、领域双维度分类体系，为智能体风险审计与标准化治理提供分类依据 [12]。
		CSS Group [13]	形式化验证与底层系统安全： 依托形式化验证技术开发 FSCQ 安全文件系统、CryptDB 加密数据库，从底层硬件存储层保障智能体数据读写安全 [13]。
	斯坦福大学 (Stanford)	HAI [36] & CAIS [37]	提示注入防护与智能体资产风险分级： 搭建多层越狱防护、插件权限校验体系，提出高风险场景智能体合规溯源与资产分级评估方案；参与《Agents of Chaos》实验，证实自主智能体存在数据泄露、恶意系统操作、身份冒充等原生安全隐患 [38], [39]。
		SCS Group [40]	智能体文件系统隔离沙箱： 研发 jai 轻量级 Linux 沙箱，依托目录权限管控、写时复制机制，抵御智能体误删、篡改本地文件的安全风险 [15]。
		CRFM [14]	大模型风险与能力统一评测： 推出 HELM 标准化评测框架，实现多任务多维度模型能力与风险量化对比；提出 FMTI 指数，量化评估模型全生命周期研发、训练、部署透明度水平。

续下页

表 2.1 -续上页

国家	高校	实验室/研究团队	AI 智能体安全核心研究方向
美国	加州大学伯克利分校 (UC Berkeley)	BAIR [41]	多智能体强化学习决策与函数调用评测体系： 研究机器人自适应协同强化学习策略，支撑具身智能体协同决策；构建 Gorilla、BFCL 开源基准，标准化量化智能体函数选择、参数生成能力 [16], [42]。
		Sky Lab [43]	智能体工具调用运行时隔离： 从操作系统层优化智能体工具调度、任务可观测性，搭建轻量化运行时安全隔离平台 [43]。
		CHAI [44]	人类偏好对齐与智能体可控性： 基于人机协作理论设计意图对齐算法，提升自主智能体行为可解释性与人工干预可控能力 [44]。
		RDI [45]	工具调用权限管控、代码智能体攻防与攻击分类理论： Progent 权限代理系统将工具调用攻击成功率由 39.9% 降至 1.0%；CyberGym 平台自动挖掘 34 个软件零日漏洞，验证代码智能体原生攻击风险；提出上下文安全四维属性模型，重构智能体攻击风险完整分类体系 [17], [20], [26]。
	卡内基梅隆大学 (CMU)	CyLab [46]	代码智能体安全对齐与自主链式网络攻击验证： 提出 SecCodePRM 过程奖励模型，抑制代码生成阶段高危漏洞产出；复现 Equifax 数据泄露完整漏洞链，证实 LLM 智能体可自主完成全流程网络攻击 [22]。
		Robotics Institute [47]	多智能体博弈与任务分配： 基于博弈论设计分布式任务调度机制，规避多智能体协同过程中的策略冲突与资源争抢风险 [47]。
		AISIRT [31]	生成式 AI 安全事件响应： 由 CMU 软件工程研究所 (SEI) 建立，专职开展 AI 智能体漏洞研判、安全应急处置与风险闭环管控工作 [31]。
	普渡大学 (Purdue)	ASSET [48]	代码智能体推理能力评测： 提出 CoRe 静态分析基准，量化评测大模型识别、推理代码漏洞的风险判别能力 [48]。
		PurCL [25]	代码智能体攻防实战与隐性漏洞挖掘： 团队斩获 Amazon Nova AI Challenge 攻击赛道全球第一，验证自动化红队攻击能力；ASTRA 系统攻击成功率超 90%，定向挖掘代码助手多步骤链式隐性漏洞 [25], [49]。
		IDEAS [50]	拒止环境机器人协同导航： 获美军项目资助，研究 GPS 拒止场景下空地多机器人智能协同定位与安全导航技术 [51]。
		CERIAS [52]	组织级智能体安全工程化： 将智能体安全管控嵌入企业漏洞管理、应急演练、合规培训全业务流程，形成标准化安全工程落地方案 [52]。
	哈佛大学 (Harvard)	Kempner Institute [53]	自主智能体有害生成机制： 拆解大模型推理规划底层逻辑，统一揭示自主智能体主动生成有害内容的内在机理 [54]。
		PT Project [55]	差分隐私数据保护工具： 开源 OpenDP 轻量化差分隐私框架，为智能体跨主体数据交互提供标准化隐私防护能力 [55]。
		James Mickens Group [56]	Agentic AI 安全治理战略： 系统梳理自主智能体全维度网络安全威胁体系，提出产学研多方协同长效安全治理框架 [56]。
		Berkman Klein Center [27]	高风险行业智能体制度边界： 从社会技术交叉视角，明确金融、医疗等高风险领域智能体落地的合规红线与监管权责边界 [27]。
	康奈尔大学 (Cornell)	AI Alignment Lab [57]	AI 对齐基础理论研究： 依托严格数学理论搭建自主智能体价值对齐、行为硬约束底层原理完整理论框架 [57]。
		Vitaly Shmatikov Group [58]	检索型智能体投毒攻击与嵌入向量信息泄露： 提出 WARP 网页投毒方案，验证智能体面临外部内容篡改威胁 [19]；利用 Vec2Vec 算法证明跨模型嵌入向量可复原文本语义，暴露向量检索智能体隐私泄露风险 [59]。
		Martin T. Wells Group [18]	多用户价值对齐冲突消解： 设计 DemPO 优化算法，解决多主体交互场景下智能体训练存在的人群价值偏好偏差冲突问题 [18]。

续下页

表 2.1 -续上页

国家	高校	实验室/研究团队	AI 智能体安全核心研究方向
美国	佐治亚理工学院 (Georgia Tech.)	SSS Lab [60]	软件系统漏洞挖掘实战： 面向智能体底层依赖库、运行时组件开展定向漏洞挖掘与攻防验证实验 [60]。
		TR Lab [60]	自主机器人环境安全落地： 研究服务、工业机器人智能体在复杂人居场景下的安全决策、动态风险规避机制 [60]。
	伊利诺伊大学厄巴纳-香槟分校 (UIUC)	CSL [32]	可信 AI 智能体综合研究： 融合机器学习、底层系统安全、软件工程技术，搭建端到端全链路可信智能体技术体系 [32]。
		ITI [61]	关键基础设施智能体弹性防护： 面向智能电网等工业关键设施，研发防护型智能体，提升基础设施网络抵御高强度攻击的弹性能力 [61]。
		SL Lab [62]	智能体对抗鲁棒性增强： 提出具备理论证明的鲁棒学习算法，抵御针对智能体视觉、文本感知层的对抗样本攻击 [62]。
		Heng Ji Group [63]	代码化智能体动作安全表示： CodeAct 框架采用可执行代码替代纯文本动作指令，显著提升智能体工具调用成功率与执行安全边界可控性。
	普林斯顿大学 (Princeton)	NLP Group [64]	代码修复智能体评测与优化： 构建 SWE-bench 基准，设计 SWE-agent 专用交互接口，提升智能体自动修复代码漏洞的稳定性与成功率。
		CITP [28]	AI 能力夸大风险辨析： 系统拆解智能体商业宣传中的能力夸大、虚假宣传问题，提供标准化风险甄别与核验方法论。
		S&P Group [65]	智能体应用层安全防护： 结合现代密码学、网络攻防技术，构建面向业务场景智能体的上层应用完整安全防护体系。
	纽约大学 (NYU)	Muhammad Shafique Group [66]	自主勒索攻击与多智能体越狱攻击： PromptLock 验证 LLM 可独立完成完整勒索软件攻击链路；MetaCipher 依靠多智能体协同高效绕过主流大模型安全护栏 [23], [67]。
		AITP Lab [68]	思维伙伴智能体人机交互： 研究共生式协同思维伙伴系统，优化人机联合决策的安全性、交互流畅度与风险可控性 [68]。
		AgentAuditor Group [69]	通用智能体安全审计方法： 依托安全经验记忆库，使 LLM 智能体实现接近人类安全专家水平的全维度智能体风险评估能力 [69]。
		Quanyan Zhu Group [70]	攻防博弈智能体防御建模： 基于斯塔克尔伯格博弈理论量化攻防双方策略均衡，推导面向智能体的最优主动防御部署方案 [70]。
加拿大	多伦多大学 (UofT)	SRI [71]	智能体全周期治理框架与国家级 AI 安全指南： 搭建贯穿研发、部署、运维的智能体风险管控框架，规范企业智能体落地流程；牵头制定的 AI 治理指南纳入加拿大中小企业 AI 部署官方标准工具包 [29], [71]。
		CleverHans Lab [72]	AI 蠕虫自主传播风险与隐私协作学习框架： 实验证实开源大模型可生成自适应 AI 蠕虫，依托终端资源实现跨设备自主扩散；提出 CaPC Learning 多方协作学习框架，在联合训练过程中实现无损隐私保护 [24]。
		TISL [73]	具身智能体场景仿真： 优化机器人感知、环境表征算法，搭建高保真物理仿真环境用于具身智能体安全训练与风险验证 [73]。
		DORL [74]	多智能体强化学习优化： 研究动态开放环境下多智能体协同优化算法，降低复杂任务协作中的冲突与安全失控风险 [74]。
	麦吉尔大学 (McGill)	McGill NLP Group [75]	Web 智能体安全评测基准： 推出 SafeArena 评测基准，覆盖正常与恶意交互场景，标准化量化 Web 智能体抗误导、抗注入攻击能力 [21], [76]。
		IVADO R3AI [75]	长期 AI 安全专项资助： 设立专项科研经费，持续支持 2024-2030 年度智能体安全全方向课题攻关 [75]。

续下页

表 2.1 -续上页

国家	高校	实验室/研究团队	AI 智能体安全核心研究方向
加拿大	英属哥伦比亚大学 (UBC)	S&P Group [77]	部署型智能体对抗检测 ：研发深度神经网络异常识别算法，实时在线识别智能体运行阶段遭遇的各类对抗样本攻击 [77]。
		Mathias Lécuyer Group [78]	无重训练隐私审计与多步骤防御认证鲁棒性 ：PANORAMIA 框架无需模型微调即可快速完成智能体全链路隐私风险检测；自适应平滑算法为多层防御智能体提供可证明的安全鲁棒保障。
		Victoria Lemieux Group [79]	AI 安全公共资源治理 ：结合公地治理理论，构建兼顾原住民权益视角的 AI 数据资产与全域安全治理框架 [79]。
		CAISI [30]	AI 安全认证体系 ：加拿大 AI 安全研究所 CAISI 推进 AI 安全科学、开展研究和联合测试、为政府及开发者提供风险工具和指导 [30]。

2.1.2 欧洲 AI 智能体安全学术研究现状

欧洲是全球 AI 安全治理与基础理论研究核心策源地，依托《欧盟 AI 法案》[80] 顶层规制、国家级科研院所与头部高校，形成法规驱动、重理论、重隐私与合规导向的智能体安全研究体系。本节梳理主要欧洲国家顶尖高校和科研院所的标志性成果，主要发现如下（详见表 2.2）：

- **跨国分工布局清晰，技术与合规深度落地**。英国依托牛津大学（Oxford）、剑桥大学（Cambridge）主攻 AGI 对齐、人机权责划分与长期风险监管 [81], [82], [83]；德国聚焦底层攻击机理与硬件侧信道安全 [84], [85]；瑞士专攻安全评测基准与安全强化学习 [86]；荷兰研究隐私重构攻击 [87]、比利时 KU Leuven 构建适配 GDPR 的安全成熟度模型 [88]。整体依托《欧盟 AI 法案》与 GDPR，将学术成果转化为可量化合规指标、商用智能体披露标准与跨境算力管控方案，实现科研、立法、产业审计一体化闭环 [89], [90]。
- **基础威胁机理领先，提出多项原生攻击范式**。德国 CISPA 完整定义并分类间接提示注入攻击，厘清不可信外部数据带来的指令混淆风险 [91]；慕尼黑工业大学（TUM）验证软提示嵌入逃逸与评测工具随机性缺陷，揭露现有红队评估体系的可靠性漏洞 [92]；帝国理工学院（ICL）提出 Checkpoint-GCG，证明微调防御存在固有结构性漏洞，推翻单一模型即可完成安全防护的传统结论 [93]。此外，马克斯·普朗克研究所（MPI）提出时序记忆炸弹后门，挖掘智能体长时序交互下的隐性攻击机理，完善智能体动态威胁体系 [94]。
- **安全体系完善，动态评测工具谱系齐全**。软件层由牛津、剑桥基于 CHERI 隔离与 Why3 工具实现智能体模块隔离与演绎证明 [95]；物理层依托 TUM 可达性分析、苏黎世联邦理工学院（ETH Zurich）ActSafe 框架界定 LLM 机器人安全边界，实现物理执行层可证明安全保障 [86], [96]；群体层完成多机协同碰撞约束与人机轨迹风险量化，完善多智能体协同安全验证体系 [97]；评测层面聚焦动态对抗检验，构建完备的智能体安全评测基准矩阵。

表 2.2: 欧洲顶尖高校 AI 智能体安全学术研究汇总

国家	高校	实验室/研究团队	AI 智能体安全核心研究方向
英国	牛津大学 (Oxford)	Institute for Ethics in AI [98]	AI 伦理治理与多元价值冲突 ：Edward Harcourt 团队从伦理、责任、治理与社会影响维度研究 AI 部署风险，通过《Value Kaleidoscope》探究 AI 系统处理人类多元价值观、权利与义务冲突的机制。
		AI Governance Initiative [82]	国际 AI 治理与算力监管协调 ：Robert Trager 团队研究跨国 AI 治理体系设计，聚焦算力治理与跨境监管协调，2024 年发布白皮书提出算力提供方跨境报告机制，防范监管套利。

续下页

表 2.2 -续上页

国家	高校	实验室/研究团队	AI 智能体安全核心研究方向
英国	剑桥大学 (Cambridge)	CFI [83]	智能体透明度评估与安全披露审计： Stephen Cave 团队构建 AI Agent Index，结构化评估 30 款主流智能体的能力、生态交互与安全披露情况，指出当前智能体普遍缺少系统安全测试与第三方评估材料 [99]。
		Security Group [100]	间接提示注入防御与权限约束架构： 提出规划与检索模块分离的安全架构，抵御智能体间接提示注入攻击；基于 CHERI 能力硬件隔离体系，为智能体工具调用、文件访问提供底层权限安全支撑 [95], [101]。
		Prorok Lab [102]	多机器人可证明安全导航与协同： 融合控制屏障函数、在线环境估计与去中心化规划，提出未知环境下多智能体安全导航方法，为机器人群体碰撞规避、任务可达性提供形式化保证 [97]。
	帝国理工学院 (ICL)	APSS [103]	神经符号辩论与合规性可解释判断： 依托 NeSyDebates 项目，基于神经符号辩论机制实现大模型政策法规合规性的可解释、可争议、可执行安全判定，覆盖生成式 AI 与物联网系统安全场景 [104]。
		AISP [105]	提示注入防御审计与成员推断风险： 提出 Checkpoint-GCG 审计微调类提示注入防御机制，证实模型侧防御无法根除外部数据引发的间接提示注入风险；基于 LLM 成员推断技术构建企业知识库智能体数据泄露评估体系 [93], [106]。
	伦敦大学学院 (UCL)	S2Lab [107]	机器学习安全评测方法论陷阱梳理： 系统总结恶意软件检测、漏洞挖掘、二进制分析等安全任务中机器学习评测的常见误区，构建可信评测规范体系。
		UCLIC [108]	人本可用安全与隐私伤害辅助报告： 研究对话式 AI 辅助用户上报隐私伤害的机制，其人本安全研究成果落地英国政府与行业安全规范 [109]。
	爱丁堡大学 (Edinburgh)	SPT Group [110]	可验证安全证据与信息流控制： 基于携带证明代码与形式化协议验证技术，为智能体外部代码执行、插件调用、分布式服务访问提供可验证安全证据与信息流管控方案。
CTF [111]		负责任 AI 生态治理分歧梳理： 依托 BRAID 项目联动学界、产业与监管机构，系统厘清 AI 安全、伦理、透明度、问责与治理体系的重叠与冲突边界 [112], [113]。	
德国	慕尼黑工业大学 (TUM)	CPS [114]	可达性分析与 LLM 控制机器人安全保证： 基于可达性分析理论，构建 LLM 驱动机器人的形式化验证框架，提供数学可证明的物理执行安全保障 [96]。
		DAML [115]	嵌入空间对齐绕过与红队评估鲁棒性： 证实嵌入空间软提示攻击可绕过 LLM 安全对齐与遗忘机制；证明 LLM-as-a-Judge 在红队测试中评估鲁棒性接近随机猜测，质疑现有评估范式可靠性 [92]。
瑞士	苏黎世联邦理工学院 (ETH Zurich)	SPY Lab [116], [117]	智能体提示注入攻防动态评测环境： 构建 AgentDojo 评测平台，集成 97 项真实任务与 629 条安全用例，统一量化评估 LLM 智能体工具调用、外部数据读取中的间接提示注入攻防性能 [118]。
		RSL [119], [120]	腿式机器人复杂地形自主导航安全： 基于强化学习与机载感知，实现 ANYmal 系列机器人复杂地形稳定移动，将智能体安全体系延伸至物理设备运动边界与环境适配场景 [121]。

续下页

表 2.2 -续上页

国家	高校	实验室/研究团队	AI 智能体安全核心研究方向
	洛桑联邦理工学院 (EPFL)	DEDIS Lab [122]	去中心化信任基础设施与多机构协同审计： 构建 Cothority/OmniLedger 分布式信任架构，分散信任节点权限，支撑跨机构多智能体协同的身份认证与不可篡改审计追踪 [123]。
		VITA Lab [124]	人机共存场景轨迹预测与碰撞风险规避： 提出 Social-Transmotion 视觉轨迹预测方法，提升公共空间移动智能体对行人意图与碰撞风险的预判能力，优化人机共存安全决策。
比利时	鲁汶大学 (KU Leuven)	COSIC [125]	密码学与敏感数据访问技术控制： 基于哈希函数、隐私增强技术构建智能体敏感数据访问的底层密码管控机制，支撑合规化数据权限治理 [125]。
		DistriNet [126]	入侵检测场景下数据驱动 AI 可信度： 分析无监督数据环境下 AI 模型在恶意代码检测中的可信度缺陷，提出风险感知型智能体检测方案 [126]。
		CiTiP [127]	GDPR 合规转化与陪伴型智能体数据保护： 将 GDPR 合规条款转化为可量化的网络安全成熟度模型；针对性解析陪伴型聊天机器人的设计阶段数据保护合规要点 [90]。
荷兰	代尔夫特理工大学 (TU Delft)	II Group [128]	智能体协商与人机混合智能系统： 深耕自主智能体自动协商机制与人机协同认知建模，获 2024 年 ACM/SIGAI 自主智能体领域终身成就奖 [128]。
		GC [129]	关键基础设施网络安全治理测量： 基于全网实测数据量化分析 ISP 与终端设备对 Mirai 僵尸网络的清除效果，支撑物联网智能体集群治理策略优化。
	阿姆斯特丹大学 (UvA)	VIS/QUVA Lab [130]	具身多智能体协作规划优化： 提出 CaPo 协同规划算法，优化具身场景下多智能体的任务分配与动作协同效率，降低协作冲突风险 [131]。
		IRLab [132]	检索增强智能体信息可靠性理论： 构建检索增强生成（RAG）智能体的信息可信度评估理论体系，解决外部检索内容带来的事实性与安全风险问题 [132]。

2.1.3 我国 AI 智能体安全学术研究现状

区别于北美偏向前沿攻防与防务赋能、欧洲侧重法理规制与可证明基础理论的研究路径，我国研究更聚焦大模型原生智能体的工程化安全问题，以评测基准构建、工具调用风险防控、中文场景安全对齐、产业级落地防护为核心主线。本节梳理我国高校、科研院所、新型研发机构的主要团队、研究方向和标志性成果，主要发现如下（详见表 2.3）：

- **研究资源集聚分层，头部机构形成差异化分工壁垒。**我国 AI 智能体安全研究以清华、北大与中国科学院体系为核心研发主体，在基础评测、安全对齐、底层系统安全领域形成引领性优势 [133]；上交、浙大、南大、复旦等高校聚焦工程化落地与隐私安全 [134], [135], [136]；中国科学院主攻国家级测评平台与硬件底层安全 [137], [138]；新型研发机构聚焦通用智能体原生安全与产业转化 [139], [140]。各梯队研究方向高度互补但壁垒显著，资源、数据、实验平台存在圈层隔离，跨机构协同攻关力度仍有待提升。
- **技术导向偏重工程实用，构建本土化特色赛道。**我国锚定产业刚需，主要研究包括覆盖通用、交互、场景化的智能体安全双维评测体系 [141]、基于国产开源底座的工具学习与 RAG 安全方案 [142]、适配中文语境的价值对齐范式，以及规模化落地的多模态与具身智能体防护体系 [143]。依托自主算力架构，我国在硬件级端侧可信执行、权限隔离领域形成独有技术特色 [138], [139]。相较于国外偏重理论推演与通用攻防范式研究，国内研究更贴合政企

落地、国产化替代、行业合规等实际诉求，形成工程落地优先、场景适配度高的本土化技术发展路径。针对中文语义歧义、本土业务场景特征、国产算力适配短板形成了系列定制化安全加固方案，具备极强的产业落地优势与场景独有性。

• **整体呈并跑-跟跑格局，基础理论存在核心短板。**我国在开源工具链安全、产业级测评平台领域紧跟国际前沿趋势 [136]，中文场景对齐、国产算力防护、行业安全赛道基本与全球并跑，基础机理、可证明安全、AGI 前沿风险研究整体跟跑。核心短板集中于三方面：一是原生攻击机理原创性不足，多为欧美现有攻击范式的本土化适配，缺乏奠基性成果；二是大模型智能体专属可证明安全体系空白，形式化验证、决策鲁棒性数学证明能力薄弱；三是超级对齐、多智能体链式风险等 AGI 级前沿研究体量不足，风险预判能力滞后 [144], [145]。国内现有成果多聚焦应用层安全加固与工程优化，在智能体自主推理安全机理、多智能体涌现风险演化规律、决策安全可证明理论等底层源头创新上仍存在明显代差。

表 2.3: 我国顶尖高校与科研院所 AI 智能体安全学术研究汇总

研究主体	高校 / 科研院所	实验室/研究团队	AI 智能体安全核心研究方向
高校	清华大学	知识工程实验室与 THUDM 团队 [146], [147]	大模型智能体交互能力评测基准： 依托 GLM 系列与知识增强推理研究提出 AgentBench，在 8 类交互环境下系统评测智能体推理、决策与长期执行能力 [147]。
		OpenBMB 与 THUNLP-MT 工具学习团队 [148]	工具调用与 API 调度安全评估： 构建 ToolBench 与 StableToolBench 两套开源基准，为大模型工具选择、API 调度场景提供可复现安全评测数据集与实验框架 [149]。
		TSAIL [150]	具身智能体对抗鲁棒性提升： 基于强化学习与不确定性感知的奖励机制提出 Rein-EAD 算法，强化三维对抗场景下具身智能体视觉感知鲁棒性 [143]。
	北京大学	PKU-Alignment 团队 [151], [152]	大模型价值对齐与安全强化学习框架： 提出 Safe RLHF、Safe Policy Optimization 等安全强化学习算法，开源 BeaverTails、PKU-SafeRLHF 安全偏好数据集，相关成果入选 ICLR 顶会 Spotlight。
		多智能体研究中心 [153]	数据分析智能体交互可靠性评测： 联合伯克利提出 IDA-Bench 基准，实验证明当前最优大模型完成数据分析智能体任务仅能达到人类 40% 成功率 [154]。
	上海交通大学	MVIG 实验室 [155]	具身智能与机器人感知系统： 深耕机器人视觉感知与人体姿态建模，开源 AlphaPose、HAKE 工具成为行业通用基线 [155]。
		跨媒体语言智能实验室 (X-LANCE) [156]	语音交互智能体安全边界研究： 面向口语对话与认知型智能体，搭建语音场景安全边界分析完整体系 [156]。
	浙江大学	浙江大学-阿里巴巴集团 AI 安全联合实验室 [157]	企业级智能体红队测试与安全治理： 以大模型智能体红队攻防、全生命周期安全治理为核心方向，支撑产业落地级安全体系搭建 [157]。
		NESA Lab [158]	AI 辅助漏洞挖掘与智能模糊测试： 基于对抗学习设计自动化漏洞挖掘方案，面向智能体插件、边缘调度模块开展智能模糊测试研究 [158]。
		网络空间安全学院大模型与智能体安全团队 [159], [160]	移动端与 Web 漏洞挖掘： 围绕大模型智能体、移动应用、Web 前端构建一体化漏洞挖掘与风险管控方案 [159], [160]。

续下页

表 2.3 -续上页

研究主体	高校 / 科研院所	实验室/研究团队	AI 智能体安全核心研究方向
高校	南京大学	LAMDA 实验室 [161], [162]	学件范式与模型复用基座系统： 提出通用可复用模型“学件”理论，搭建开源模型复用基座平台北冥坞 [161]。
		推理与学习研究组 [163]	强化学习驱动的具身智能体导航： 融合大模型规划与强化学习，研究开放环境下机器人自主导航、物体操作安全控制方案 [163]。
	复旦大学	系统软件与安全实验室 [164]	系统安全与恶意代码检测： 深耕底层系统漏洞、恶意样本识别与 AI 系统攻防，成果长期发表 S&P、USENIX Security、CCS 安全顶会 [164]。
		白泽智能团队 [164]	大模型靶向式安全评测平台 JADE： 搭建 JADE 定向安全评测系统，实测模型违规检出率超 70%；扩展至智能体 MCP 协议风险检测，参与制定《智能体应用安全基本要求》国家标准 [136], [164]。
	哈尔滨工业大学	HIT-SCIR [165], [166]	中文语言技术基础平台建设： 长期维护 LTP 中文自然语言处理工具栈，为对话、检索类智能体提供底层语言安全预处理能力。
		自主智能无人系统全国重点实验室 [137]	分布式协同控制理论方法： 构建混合智能优化与稳定性证明体系，支撑无人集群多智能体协同安全调度 [137]。
	中国科学技术大学	张卫明团队 [167]	大模型越狱攻击防范与水印嵌入： 研究大模型提示越狱防御、生成文本溯源水印技术，斩获 IJCAI 对抗防御赛道冠军、DFDC 伪造检测亚军 [167]。
		杨威团队 [168]	量子 AI 与安全多方计算： 结合量子计算、隐私计算技术，设计面向分布式智能体的安全数据交互协议 [168]。
		先进数据系统实验室 (ADSL) [169]	大规模存储与分布式机器学习： 面向分布式训练集群、海量智能体数据存储开展底层安全优化，成果发表 FAST、OSDI、SOSP 等系统顶会 [169]。
	北京航空航天大学	韦星星团队 [170]	多模态大模型可信度评估： 构建图文跨模态幻觉检测、可信度量化体系，面向多模态交互智能体开展风险量化评估 [170]。
		可信智能软件实验室 [171]	软件可靠性工程与测试方法： 研究高可信智能体软件形式化测试、故障容错技术，负责人长期担任 ISSRE、PRDC 等国际可靠性会议主席 [171]。
		通用自主多模态智能体实验室 [172]	无人机多智能体协同设计验证： 研发 ArtiAero 平台，基于多智能体协同完成无人机从概念设计、模型生成到仿真安全验证全流程自动化 [172], [173]。
	中国科学院自动化所	AI 安全与超级对齐北京市重点实验室 [144]	大模型安全攻防评估平台 PandaGuard： 搭建灵御 PandaGuard 评测平台，集成 19 类攻击、12 套防御方案，完成 49 款主流大模型安全量化测评 [133]。
		复杂系统管理与控制国家重点实验室 [174]	平行智能与复杂系统建模： 基于平行智能理论构建社会、工业多智能体复杂系统仿真与风险推演框架 [174]。
		多智能体决策与科研智能体平台 (JidiAI/ScienceOne) [175], [176]	多智能体博弈决策开放平台： JidiAI 接入 40 余种博弈仿真环境，服务海内外 50 余家科研机构；ScienceOne 整合 300+ 科学工具，实现科研智能体自主规划推理 [175], [176]。

续下页

表 2.3 -续上页

研究主体	高校 / 科研院所	实验室/研究团队	AI 智能体安全核心研究方向
科研院所	中国科学院计算所	智能算法安全国家重点实验室 [137]	机器学习安全理论与可信应用： 围绕基础机器学习攻防理论，构建面向行业智能体的可信部署、风险管控整套技术体系 [137]。
		前瞻研究实验室/数字内容合成与伪造检测实验室 [177]	虚假新闻与伪造内容检测平台： 落地“AI 识谣”“睿鉴图灵”多模态伪造检测系统，支撑国家级舆情、内容安全智能体任务部署 [177]。
	中国科学院信工所	陈恺团队 [178]	系统安全与 AI 安全研究： 聚焦操作系统底层漏洞、大模型智能体攻防，相关成果获 CCF-IEEE CS 青年科学家奖 [178]。
		葛仕明/赵险峰多媒体安全团队 [179], [180]	AI 视觉安全与多媒体隐蔽通信： 研究深度学习视觉伪造检测、多媒体信息隐藏技术，防范多模态智能体隐蔽信道泄露风险 [179], [180]。
	北京通用 AI 研究院	跨媒体通用 AI 国家重点实验室 [145]	通用 AI 统一理论与认知架构： 搭建通用人工智能统一建模、认知推理理论体系，支撑通用自主智能体底层设计 [145]。
		通用 AI 安全北京市重点实验室 [145]	通用智能体全链条安全治理： 覆盖价值对齐、认知推理、物理执行三层空间，构建通用智能体端到端安全管控体系 [145]。
	北京智源 AI 研究院	FlagOpen / FlagOS [139], [181]	国产算力智能体部署框架： 搭建多芯片统一软件栈 FlagOS，提供原生智能体调度能力，适配国产服务器与边缘端部署场景 [139], [181]。
		智源世界模型创新中心 [182]	具身智能体安全规划基础模型： 开源悟界·Physis-v0.1 世界模型，为机器人、物理交互智能体提供仿真安全规划底层基座 [182]。
		具身交互世界模型实验室 [183], [184]	垂直领域智能体任务规划落地： 基于 RoboBrain、RoboOS 平台，面向工业、服务机器人智能体完成安全任务规划方案落地验证 [183], [184]。
	上海 AI 实验室	安全可信 AI 中心 (AI45) [185]	模型内生安全推理能力提升： 提出 SafeLadder 分层安全框架，发布 SafeWork-R1 模型增强大模型原生风险识别与安全推理能力 [186]。
		书安 (Intern-Shannon) 团队 [140]	产业级安全智能体操作系统： 研发面向政企高安全场景的智能体 OS，采用“安全即服务”架构统一管控多智能体权限与交互风险 [140]。
		OpenMMLab, OpenGVLab 开源平台 [142], [187]	多模态开源工具链建设： 搭建从视觉感知、多模态理解到模型安全评测、智能体部署的完整开源工具链 OpenCompass、InternVL 等 [188]。
	中关村实验室	APT 与未知攻击危害消解团队 [189]	安全运营智能体威胁溯源： 提出数字替身仿真消解思路，用于安全运营智能体的攻击行为还原、威胁根因定位 [189]。
		大模型网络安全知识评测合作团队 [141]	网络安全知识盲区评测基准： 构建 CSEBenchmark 安全知识库，包含 345 个知识点、11050 道测评题，量化验证大模型网络安全推理缺陷 [141], [190]。

2.2 全球 AI 智能体安全主流产品

本节围绕全球 AI 智能体安全产品生态，从北美、欧洲、我国三大区域梳理主流厂商的技术布局与产品特点。北美以 OpenAI、DeepMind、NVIDIA 等企业为核心，主打基础模型安全与智能体运行防护；欧洲以 Mistral AI、Darktrace 等厂商为主，侧重可信 AI 架构与合规安全治理；我国依托百度、阿里、腾讯、智谱、字节跳动等平台，聚焦国产大模型安全与产业级智能体安全能力建设，如图 2.3 所示。



图 2.3: 全球 AI 智能体安全主流产品

2.2.1 北美主流 AI 智能体安全产品

北美是全球 AI 智能体技术研发、产品落地与安全体系构建的核心策源地，依托头部科技企业、开源社区与云原生技术生态，形成覆盖基础模型、开发工具、算力底座、行业部署全链路的智能体产业矩阵 [191], [192]。本节梳理北美主流 AI 智能体安全产品、技术文档与工程落地统计，主要发现如下（详见表 2.4）：

- 产业形成全栈闭环格局，头部企业分层主导模型、云、算力、应用四级生态。OpenAI 依托 GPT-4o 企业版、Stateful Runtime 环境管控上层通用智能体安全，通过 Enterprise 连接器白名单、写入操作分级审批机制规范开发者与企业工作流权限，实现通用智能体工作流安全管控闭环 [191], [193]；Anthropic 基于 Claude 系列模型与 MCP 协议，标准化定义企业私有数据源、内网插件的访问边界，筑牢企业私有场景智能体交互安全基线 [194]；Google 依托 Google Cloud Agent 身份体系与 Project Mariner 云隔离架构，实现智能体运行环境与本地基础设施物理隔离，支撑云原生智能体规模化安全部署 [195], [196]；Meta 开源 Llama 系列

模型配套 Llama Guard、Prompt Guard 防护组件，主导社区级安全评测基准 CyberSecEval 建设，构建开源生态智能体安全防护体系；NVIDIA 基于 GPU 机密计算域与 Isaac 仿真平台，提供端侧可信执行环境与物理机器人智能体风险验证能力，补齐硬件层与具身智能体安全短板 [197], [198]；Cursor、Perplexity 等垂直厂商针对代码生成、检索增强场景，补充细粒度 API 调用风控与检索污染检测能力，安全能力自上而下覆盖算法、软件、部署、硬件全层级，完善细分场景安全防护体系 [199], [200]。

- **安全范式全面前置，构建模型层预防护与运行时强管控的防护体系。**模型层方面，Anthropic 与 OpenAI 将禁止越权、数据最小披露、恶意指令拒绝等价值约束嵌入预训练、RLHF 与推理全过程，搭载 ASL-3 实时安全分类器拦截高危请求，实现模型内生安全对齐 [201]；运行时层面，主流产品采用容器化沙箱、独立虚拟机隔离智能体代码执行与系统调用，如 OpenAI 代码解释器隔离环境，从执行环境层面规避恶意操作风险 [202], [203]。
- **双轨体系差异化落地，以最小权限治理 + 软硬协同底座支撑规模化企业部署。**北美形成分工明确的闭源 / 开源双轨安全体系。闭源阵营（OpenAI、Anthropic、Google）面向政企交付私有化部署套件、SOC 2/ISO 27001 合规管控模块与闭环漏洞响应流程，提供租户级隔离、数据静态与传输加密、年度渗透测试服务，满足高合规场景落地要求 [204], [205]；开源阵营（Meta、NVIDIA）开放安全护栏代码、评测数据集与 NeMo Guardrails 工具链，降低中小开发者安全准入门槛，赋能开源生态智能体安全标准化建设 [206], [207]。企业治理层面统一以最小权限与可观测性为核心，基于 IAM 条件访问控制、细粒度角色权限、全链路 tracing 追踪跨服务、跨 API 调用行为，精准管控连接器外联、内网数据库访问等高风险入口 [195], [208]；硬件层面联动 NVIDIA 机密算力、Google 物理隔离云基座，结合科学智能体漏洞挖掘与机器人攻防仿真，构建纯软件防护无法实现的底层安全壁垒，支撑工业控制、无人系统、科学计算等高风险场景规模化落地 [197], [209]。

表 2.4: 北美主流 AI 智能体安全产品与落地方向

国家	企业	产业领域	安全研究方向 + 未来趋势	产品/成果
美国	OpenAI	• 通用大模型与终端智能体应用 • 企业智能体开发框架与评测体系 • 大模型对齐与智能体安全防护	• 构建智能体工具编排、运行观测与数据隔离的标准化管控流程。 • 搭建企业智能体低代码治理体系，实现安全护栏动态配置与全生命周期管理。 未来趋势： • 研发智能体部署与评测，规避越权、误操作与数据泄露风险 [210]。AGI 安全与行为溯源。 • 攻克多智能体权限传递、状态污染、冲突仲裁等协同安全难题 [211], [212]。 • 构建连接器细粒度授权、脱敏追踪的生态数据治理机制 [194], [203]。	• ChatGPT-Agent：内置运行监督、用户确认与提示注入防御机制 [191], [201]。 • Responses API、Agents-SDK：提供轨迹追踪与动态安全约束能力 [193], [208]。 • AgentKit 套件：集成 Agent-Builders、Evals 评测与安全防护模块 [193], [203]。

续下页

表 2.4 -续上页

国家	企业	产业领域	安全研究方向 + 未来趋势	产品/成果
美国	Anthropic	• Claude 企业级大模型应用 • 工具与代码智能体系统 • AI 对齐与安全协议生态	• 依托宪法式 AI 实现模型内生对齐与能力分级管控。Computer Use 全域系统操控智能体。 • 构建工具智能体沙箱约束、计算机使用隔离与人机授权机制。原生超长上下文结构研究。 • 模型可解释性研究和自动化对齐、双重用途能力管控，构建分层安全护栏。 未来趋势： • 实现智能体管控由静态对齐转向运行时动态隔离，依托沙箱与 MCP 隧道分离推理与执行环境 [213], [214]。 • 建立智能体独立身份与任务级临时授权机制，约束高危操作 [215], [216]。 • 规范多智能体信任委派与权限溯源，防范风险链式扩散 [212], [217], [218]。	• Sonnet、Opus、Mythos: 基座大模型。 • Constitutional AI: 模型原生对齐与负责任缩放安全体系 [219], [220]。 • Tool/Computer Use API: Sandbox API、可控可追溯的工具与计算机调用机制 [202], [221]。 • MCP 协议、Claude Code: 企业级智能体治理与审计工具链 [194], [204]。
	Google	• 云原生 AI 与检索应用生态 • Gemini 智能体安全平台 • 科研智能体与攻防安全研究	• 构建云原生智能体构建、部署、观测与全周期安全治理体系。物理世界具身智能研究。 • 实现企业 API 注册、智能体身份认证与跨服务最小权限访问控制。 • 搭建科研智能体受控实验、漏洞挖掘与结果复现验证机制，实现端云协同分布式智能。 未来趋势： • 建立任务轨迹驱动的动态评测体系，防控高权限智能体越权误执行风险 [222], [223]。 • 研发跨智能体认证、权限传递与生态韧性治理技术，端云协同推理 [224], [225]。 • 构建高阶科研智能体权限隔离、边界校验与风险阻断机制 [222], [226], [227]。	• Gemini 3 Ultra/Pro/Nano • Vertex AI 系列: Agent Engine、Agent Search [228]。 • Cloud API Registry、Agent Gateway: 工具治理、智能体安全网关 [195], [196]。 • AI co-scientist、AlphaEvolve、CodeMender: 科研与代码安全智能体工具链 [209], [229]。
	Meta	• 开源基础模型研发迭代 • 开源智能体安全护栏与评测 • 端侧智能体安全生态建设	• 构建多语种开源模型内容安全分类与差异化管控策略。Llama 4 全系列分层迭代。 • 实现智能体运行时监控，拦截提示注入与高危代码执行风险，持续在线学习。 未来趋势： • 建立智能体全生命周期风险审查与常态化监测机制 [230]。 • 依托 AI 风控实现诈骗识别、身份核验，平衡管控精度与效率 [231]。 • 搭建私密对话隔离、用户自主授权的隐私边界治理体系 [232]。	• Llama Guard、Prompt Guard: 模型内容安全防护工具集 [233]。 • CyberSec-Eval、CodeShield、CodeLlama: 代码与网络安全自动化评测工具 [233]。 • LlamaFirewall: 集成提示防护、对齐校验与代码风控的智能体防火墙 [207], [234]。

表 2.4 -续上页

国家	企业	产业领域	安全研究方向 + 未来趋势	产品/成果
美国	NVIDIA	- AI 算力基础设施与 GPU 软件栈 - 企业智能体编排与安全护栏 - 工业物理 AI 仿真与安全落地	- 搭建生产级多智能体编排、性能评测与运行剖析体系。 - 构建 RAG 与对话智能体内容过滤、动态策略约束机制。 - 基于可信算力实现模型数据保护与物理 AI 安全仿真验证。 未来趋势： - 研发长周期自主智能体沙箱隔离、最小权限与资源访问约束机制 [235]。 - 基于硬件信任根、机密计算与 DPU 隔离，构筑基础设施级智能体安全屏障 [236]。	NeMo Agent Toolkit：标准化安全智能体开发套件 [192]。 NeMo Guardrails、NIM：智能体安全护栏与安全推理部署服务 [206]。 机密计算、Isaac Sim、Cosmos 模型：算力、仿真与物理 AI 一体化安全底座 [197], [237], [238]。
	Perplexity	- 实时联网检索问答服务 - 浏览器网页自动化智能体 - 企业检索智能体 API 平台	- 构建检索智能体来源可信校验、引用溯源与检索范围管控机制。 - 防护浏览器智能体跨站代理、提示注入与越权访问风险。 - 建立企业智能体连接器、数据留存与网络策略治理规范。 未来趋势： - 搭建智能体分级授权体系，规范工具调用与高危操作安全边界。 - 实现多模型协同系统路由、上下文传输与协作行为全程可控溯源 [239]。	Sonar/Search API、Pro Search：安全可控联网检索服务 [240], [241]。 Comet / Assistant：网页智能体与提示注入防护工具 [242], [243]。 Perplexity Enterprise：企业智能体网络防火墙与访问管控平台 [199]。
加拿大	Cohere	- 本土通用大模型与隔离 RAG - 企业私有化主权智能体 - 政务军工高安全 AI 底座	- 实现智能体权限分级、任务约束与不可逆操作人工复核机制。 - 搭载自动化红队流水线，常态化检测提示注入、权限滥用等漏洞。 未来趋势： - 研发多智能体集群权限隔离、行为溯源与责任归属机制。 - 构建离线涉密场景智能体安全评测体系。	North Platform：私有化主权智能体开发部署平台 [244]。 Command LLM 安全护栏：模型原生安全防护体系 [245]。 Sovereign AI：政企联合主权 AI 合规解决方案 [246]。
	Wedge Networks	- 边缘轻量化 AI 工作流 - 本地离线自主智能体 - 关键基础设施离线 AI 防护	- 对智能体推理、决策、工具调用全链路实施原生安全解析与风控。 - 纯本地 CPU 离线运行，无云端中转，保障边缘数据主权隔离。 - 构建意图、上下文、输出、工具调用四层动态校验机制。 未来趋势： - 研发工业多智能体边缘协同安全技术，阻断指令篡改与设备越权。 - 搭建能源、矿业关键基础设施专属离线智能体防护标准。	WedgeSecure Agent：容器化边缘智能体安全网关，实现全链路可信校验 [247]。 边缘 AI 主权安全套件：集成离线策略引擎、注入检测器与 MCP 边界控制器 [247]。

2.2.2 欧洲主流 AI 智能体安全产品

欧洲 AI 智能体安全产业深度绑定数据主权、区域监管合规、高可信可解释性三大底层逻辑，形成**合规驱动迭代、主权约束扩张**的差异化产业体系 [248], [249]。欧盟依托《通用数据保护条例》(GDPR) 与《AI 法案》(EU AI ACT) 构建严苛的 AI 治理框架，从法律层面对智能体数据处理、权限边界、审计追溯提出强制性约束，成为区域企业产品研发与迭代的核心准则 [250]。本小节梳理欧洲主要国家主流 AI 智能体产品与技术成果，核心发现如下（详见表 2.5）：

- **驱动逻辑以监管为核心，形成“合规牵引技术、主权约束生态”的发展范式。**欧盟以 GDPR 与 EU AI ACT 为研发前置准则，智能体产品设计严格遵循数据驻留、风险分级、可审计追溯等合规要求 [248]。Mistral AI、Aleph Alpha 等产品的安全护栏、私有化部署能力均对标法案要求，实现技术研发与合规标准深度绑定 [251], [252]。俄罗斯则兼顾监管合规与地缘安全双重目标，与欧盟单一合规导向形成差异化互补 [253]。
- **技术聚焦高可信体系建设，形成可解释、可追溯、私有化的技术布局。**欧洲企业赛道分工清晰、错位发展：Mistral AI 聚焦通用智能体运行时安全，兼顾生态灵活性与企业合规需求，构建通用场景标准化安全能力 [254], [255]；Aleph Alpha 深耕政务、工业等高风险场景，依托可解释推理、决策溯源与人工复核机制，搭建高可信智能体架构，适配欧洲高等级合规管控要求 [250], [256]。英国 Darktrace 聚焦网络安全垂直领域，依托无监督基线建模实现威胁自主识别与响应，成为 SOC 自治智能体标杆 [257], [258]。俄罗斯 Yandex 重点构建属地化智能体生态，通过全链路数据与服务隔离，规避域外依赖与数据泄露风险 [259], [260]。
- **生态治理偏保守闭环，依托严格管控形成差异化安全壁垒。**欧俄地区对智能体跨域互联、跨平台交互采取保守管控策略 [254], [261]。主流产品普遍通过工具调用白名单、精细化文档权限、智能体交接强约束机制，严控未授权上下文流转，从架构层面防范数据泄露与横向渗透风险 [251], [253]。相较于北美开放插件生态，Mistral、Yandex 均采用严格工具准入机制，生态安全性更高。同时欧洲产学研转化高效，形式化验证、可证明安全等前沿学术成果快速落地，持续赋能产业合规建设 [248], [255], [261]。

表 2.5: 欧洲主流 AI 智能体安全产品与落地方向

国家	企业	产业领域	安全研究方向 + 未来趋势	产品/成果
法国	Mistral AI	• 欧洲本土通用基础模型 • 终端智能体与企业开发者服务 • 私有化主权 AI 部署与模型定制	• 构建企业智能体数据隐私管控、连接器访问与组织级权限治理体系。 • 规范开发者智能体工具调用、持久记忆、多工具协同编排安全机制。 • 搭建生产级智能体可观测体系，支撑持久化运行与自托管安全部署。 未来趋势： • 深耕主权 AI 安全架构，完善私有化、混合部署场景下智能体数据隔离与跨境传输管控机制，适配欧洲 AI 合规监管要求。 • 推进多智能体协同安全编排技术，标准化 MCP 工具接入安全策略，构建可审计、可溯源的企业智能体运维体系。	• Le Chat Enterprise：企业级智能助手，配套专属连接器与知识库能力 [262]。 • Mistral Agents API：支持多智能体协同、状态持久化、工具流转与 MCP 协议接入 [254]。 • AI Studio、Agent Runtime、Forge：提供智能体开发、注册、运行与混合私有化部署全栈能力 [249], [251], [255]。

续下页

表 2.5 -续上页

国家	企业	产业领域	安全研究方向 + 未来趋势	产品/成果
德国	Aleph Alpha	- 高可信主权专用大模型 - 政企合规可解释 AI 平台 - 欧洲基础设施私有化 AI 服务	- 攻关高监管场景 AI 可解释、可追溯技术，筑牢数据主权与组织 AI 治理体系。 - 完成多语种、工业工程专用模型的安全对齐与合规训练迭代优化。 - 实现政企本地化部署、生产场景安全评测与全流程审计可控。 未来趋势： - 持续强化高可信 AI 内生安全，针对工业、政务等高监管场景，完善模型对齐、行为溯源与合规审计标准化体系。 - 构建欧洲本土化 AI 安全标准，落地数据主权治理机制，实现智能体全生命周期合规可控与国产化安全替代。	PhariaAI、PhariaOS：政企一体化可信 AI 操作系统与智能应用平台 [248], [256]。 Pharia-1-LLM：经过安全对齐的可控大模型，适配高合规场景 [252]。 Intelligence Layer SDK：支持本地私有化部署，提供 AI 安全开发与审计工具链 [248], [250]。
英国	Dark-trace	- AI 原生网络安全防御平台 - SOC 智能自动化与威胁响应 - 全域终端、云、身份与 OT 安全防护	- 依托自学习 AI 构建组织行为基线，精准识别已知与未知网络安全威胁。 - 实现 SOC 告警自动研判、事件关联分析与智能化报告生成，提升运营效率。 - 落地跨域自主响应机制，阻断横向移动、邮件攻击、云端异常扩散等安全风险。 未来趋势： - 推进智能体自主安全运营技术迭代，实现威胁自动研判、溯源、阻断与修复的全流程无人闭环防护。 - 拓展 AI 智能体供应链安全与 OT 工业场景安全防护能力，适配万物互联场景下的全域安全治理需求。	ActiveAI Security Platform：AI 原生一体化主动安全防御平台 [257]。 Cyber AI Analyst：智能安全分析引擎，实现告警自动化研判与溯源 [257], [258]。 Autonomous Response 套件：覆盖云、终端、身份、OT 场景的自主响应与 AI 安全防护能力 [257], [263]。
俄罗斯	Yandex	- 俄语大模型与搜索云基础设施 - 企业智能体与 RAG 检索服务 - 本土 AI 生态与云合规安全体系	- 搭建企业智能体开发体系，支持 RAG 检索、网页搜索与 MCP 工具流程集成。 - 依托私有化基础设施实现智能体全流程本地化运行，管控数据与访问日志。 - 提供云安全配置校验、合规告警解析与智能安全运营辅助能力。 未来趋势： - 完善本土私有化智能体安全生态，强化离线部署、日志审计与访问权限精细化管理，保障数据自主可控。 - 深耕行业化智能体合规治理，优化云安全智能辅助能力，构建适配本土监管体系的 AI 安全运营架构。	AI Studio、Agent Atelier：智能体开发、工作流编排与 MCP 工具集成平台 [260], [261]。 私有化部署套件：支持日志管控、权限管理、审计追踪的安全部署方案 [253], [259]。 Security Deck AI：面向云场景的智能安全运维辅助助手 [264]。

2.2.3 我国主流 AI 智能体安全产品

我国 AI 智能体安全产业以**场景倒逼、工程落地**为核心底层逻辑，形成业务优先于理论、工程适配原生防护的差异化发展体系 [265], [266], [267]。我国智能体安全研发聚焦政企办公、工业流程、知识库检索、代码开发、安全运营等高频落地场景，依托国产化软硬件生态与大规模

模政企交付需求，构建以外挂式边界防护为主体、私有化部署为载体、结构化生态分工为支撑的工程化安全体系，在垂直场景治理与信创适配领域形成独有产业特征，在底层原生技术与国际标准层面存在差异化短板 [268], [269]。本节梳理了我国头部厂商的主要落地产品与技术成果，主要发现如下（详见表 2.6）：

- **产业驱动呈现场景倒逼特征，形成“场景牵引工程防护”的主导发展范式。**头部企业安全能力均针对性适配垂直场景痛点：科大讯飞聚焦语音交互隐写与误触发风险构建多模态安全规则 [270]；华为针对工业智能体高危操作设计熔断机制，约束执行层越权行为 [271]；360 围绕智能体资产测绘与插件供应链风险补齐攻防能力，重点解决智能体外部生态带来的安全隐患 [272]，所有技术研发均由具体场景问题直接牵引。同时监管侧以落地合规为核心导向，重点围绕算法备案、数据本地留存、等级保护提出硬性要求，不侧重可证明安全、宪法式对齐等前沿理论研究，进一步强化了产业工程化、落地化的核心导向 [268]。
- **技术架构以外挂边界防护为核心，构建“网关护栏 + 权限审计 + 租户隔离”三层工程体系。**与北美主打模型内生对齐、欧洲深耕可解释溯源的技术路线不同，我国主流采用轻量化、易部署的外挂式、运行时旁路防护架构 [273]。以腾讯 AI 智能体网关 [266]、阿里云 OpenClaw[265]、火山引擎 LLM 防火墙 [274] 为代表，在模型出入口、工具调用链路、上下文流转节点设置统一管控枢纽，实现提示注入拦截、敏感数据脱敏、恶意插件检测等基础防护能力。全域形成标准化三层治理架构：边界层依托安全网关、流量检测、MCP 协议防护构筑外部屏障；运行层通过最小权限管控、租户隔离、全链路操作审计规范运行行为；资产层完成 Agent 资产盘点、影子实例测绘、Skill 供应链风控。该架构部署成本低、通用性强，高度适配我国大规模政企批量交付的核心需求 [275]。
- **生态分工结构化且深度绑定信息技术应用创新产业，形成四级生态与国产化闭环治理格局。**云底座厂商（百度、阿里、腾讯、华为、字节等）主导开发平台、运行时内核与身份权限体系，定义全域安全治理底座 [268], [276]；行业垂直厂商（科大讯飞）依托多模态壁垒，深耕政务、医疗等合规行业，构建私有化数据闭环 [269]；专业安全厂商（360）补齐漏洞溯源、威胁狩猎等攻防能力，填补大模型原生安全短板 [277]；开源厂商（DeepSeek）聚焦开发者生态与沙箱隔离，服务中小开发群体 [278]。同时产业深度绑定信息技术应用创新产业（信创）体系，基于昇腾/鲲鹏算力、飞桨框架构建国产化可控闭环，在加密机制、审计粒度上差异化适配，形成全球独有的信创导向智能体安全体系 [267], [279]。

表 2.6: 我国主流 AI 智能体安全产品与落地方向

企业	产业领域	安全研究方向 + 未来趋势	产品/成果
百度	• 搜索增强大模型服务 • 云原生智能体开发平台 • 飞桨国产 AI 技术生态	• 规范企业智能体构建、RAG 检索、MCP 工具接入与模型服务全流程治理。文心多模态推理。 • 搭建国产 AI 框架开发、模型迭代与工程化安全部署体系。大模型安全对齐、幻觉抑制技术。 未来趋势： • 搭建涵盖数据、权限、记忆、工具调用的智能体安全设施 [280]。原生知识增强基座，缓解幻觉问题。 • 落地策略即代码机制，通过语义干预实现业务场景化智能体行为定义、执行与审计 [281], [282]。	• 千帆智能体开发平台：集成 Agent 引擎、MCP 工具适配与企业级模型服务能力 [268]。 • DuClaw 智能体平台：内置 Skill 系统、技能市场与智能体消息安全配置能力 [283]。 • 智驾大模型：自动驾驶、安全对齐。 • 飞桨 Paddle：支撑智能体安全开发与私有化部署的国产 AI 生态底座 [268], [279]。

续下页

表 2.6 -续上页

企业	产业领域	安全研究方向 + 未来趋势	产品/成果
阿里巴巴	- 通义 Qwen 大模型体系 - 百炼智能体工作流平台 - 云原生 AI 应用安全防护	- 构建输入输出安全护栏，实现 Prompt 注入、敏感信息与恶意链接精准识别拦截。主打低成本轻量化 Qwen 路线。 - 落地智能体运行时防护，规范工具调用审计、Skill 检测、密钥托管与 RAG 插件边界治理。 未来趋势： - 构建智能体全生命周期防护体系，统一管控模型、知识库、MCP 工具等核心资产 [284]。 - 研发多智能体协同安全运营技术，依托 Agent 集群实现威胁感知、溯源与闭环响应 [285]。	AI 安全护栏、Qwen：智能体运行时一体化安全防护方案 [265], [273]。 OpenClaw 安全插件：提供智能体安全辅助检测与运行时风险管控能力 [265], [286]。 百炼 Model Studio：集成智能体工作流、代码解释器与安全编排能力 [265], [287]。
腾讯	- 混元大模型与腾讯云服务 - 云原生多智能体工作流应用 - 代码智能体与 MCP 工具生态	- 搭建智能体接入网关，实现 MCP 工具限流、鉴权与风险检测。混元多模态基座，深度适配微信、会议等场景。 - 完善多租户隔离、内容风控、权限审计与全流程监控告警体系。 - 规范代码智能体本地访问、工具调用与命令执行的安全边界。QClaw 轻量化开源框架、端侧模型优化。 未来趋势： - 深耕智能体 Skill 与 MCP 供应链安全，防范指令注入、权限滥用、恶意依赖等风险 [288]。 - 构建模型内生安全 + 系统防御的综合体系，覆盖隐私保护、伪造检测与内容安全治理 [289]。	腾讯云 AI 智能体安全网关：实现 MCP 封装、Prompt 防护、访问鉴权与数据脱敏 [266], [290]。 智能体开发平台 ADP：提供多租户隔离、内容风控、权限审计与安全监控能力 [275], [291]。混元 4.0 通用基座模型。 CodeBuddy 代码助手：内置只读权限、操作审批与 MCP 本地安全配置机制 [292], [293]。企业微信 WorkBuddy。
智谱	- GLM 系列通用大模型 - 代码与移动端 GUI 智能体 - 企业级模型推理与评测服务	- 解决长上下文、高并发智能体服务的运行稳定性与异常容错问题 [294], [295]。 - 实现移动端智能体高风险操作确认、人工接管与受控执行 [296]。 未来趋势： - 搭建多模态内容分级审核体系，实现风险精准拦截与生成终止管控 [297]。 - 构建可审核、可监督、可追溯的开放式 AI 模型服务治理体系 [298]。	GLM-5.1/5.2 系列模型：适配长时程任务与智能体工程化落地的旗舰模型 [299], [300]。 AutoGLM 开源框架：移动端 GUI 智能体开发框架，内置高危操作管控机制 [296]。 大模型开放平台、内容审核 API：提供模型开发、推理评测与全维度内容安全检测能力 [297], [301], [302]。
字节跳动	- 豆包大模型与火山方舟云平台 - Coze 扣子智能体与 Skill 生态 - 飞书协同智能伙伴体系	- 部署大模型应用防火墙，拦截 Prompt 攻击、模型滥用与敏感数据泄露风险。 - 建立 Skill 最小授权、授权认证与企业精细化权限管控机制。端侧轻量化大模型与低成本推理架构研究。 未来趋势： - 攻关多模态具身智能体误操作风控技术，降低实景落地安全隐患 [303], [304]。 - 构建专业场景可信智能体体系，强化内容溯源、幻觉甄别与抗干扰能力 [305]。 - 落地智能体安全工程标准，搭建标准化、可落地的负责任 AI 治理架构 [305], [306], [307]。	火山引擎 LLM 防火墙：全方位防护 Prompt 攻击、恶意访问与数据泄露风险 [274], [308]。ByteSpark 训练框架、混合算力集群。 Coze 扣子平台：配套 Skill 安全规范与企业级权限管理体系 [309], [310], [311]。 飞书智能伙伴 aily：实现敏感数据分级管控与组织级权限统一治理 [312], [313]。

续下页

表 2.6 -续上页

企业	产业领域	安全研究方向 + 未来趋势	产品/成果
Kimi	- 代码智能体与自主推理模型 - Kimi Code 编程服务与搜索生态 - MCP 工具服务与外部能力接入	- 界定智能体工具调用、网页解析与用户指令执行的安全边界。 - 规范 MCP 服务、代码执行、文件读写与网络访问的权限配置。 - 防控长时编码、多智能体协作过程中的越权操作与异常误执行风险。 未来趋势： - 搭建 MCP 工具最小权限治理体系，实现细粒度授权、参数校验、调用审计与异常回滚 [314], [315]。 - 建立多智能体协作监督机制，完善长周期任务层级管控、过程溯源与异常终止能力 [316], [317]。	Kimi K2 模型：优化工具调用与自主推理能力，适配智能体环境交互训练 [318], [319]。 Kimi K2.7 Code：支持超长上下文与多步工具调用，适配工程化编码智能体场景 [320]。 Kimi API 服务：集成搜索、抓取、代码执行、MCP 接入等可管控的智能体工具能力 [315], [321], [322]。
Mini-Max	- 通用生产力大模型 - 多模态角色扮演智能体 - 企业级 MCP 开放服务平台	- 管控长程智能体任务的工具调用、搜索浏览与代码执行权限边界。 - 实现多智能体协作、记忆压缩与任务状态流转的可审计治理。 - 规范语音复刻、视频生成场景的身份滥用与隐私泄露风险防控。 未来趋势： - 构建智能体安全奖励建模机制，将各类高危操作纳入训练约束体系，提升实景安全性 [323]。 - 完善多模态智能体身份安全规范，强化内容溯源、人格边界与未成年人防护能力 [324], [325]。	M2/M2.5/M3 系列模型：面向工具调用、办公与编码智能体任务专项优化 [326], [327], [328]。 Agent Team、Forge RL 框架：支撑长程智能体迭代进化与安全强化学习 [323], [329]。 MiniMax 开放平台：提供函数调用、MCP 服务、多模态智能体的标准化安全底座 [330], [331], [332]。
DeepSeek	- 开源通用与推理大模型 - 开发者工具调用生态服务 - 开源模型部署与安全评测	- 规范模型输入输出治理，实现标准化、兼容式 API 调用管控。 - 搭建工具调用校验体系，实现严格函数调用校验。 - 完善开源模型供应链安全与推理场景安全评测机制。 未来趋势： - 研发推理智能体可验证安全技术，通过形式化校验实现工具调用与策略可信核验 [333], [334]。 - 构建高吞吐推理基础设施安全观测体系，实现多租户隔离、异常检测与速率管控 [335], [336]。	DeepSeek 标准化 API：提供兼容式接口与规范 JSON 输出能力 [337], [338]。 Strict Function Calling：实现工具调用语法与语义双重合规校验 [278]。 DeepSeek-R1/V3 开源模型：提供可溯源、可评测的开源模型安全底座 [339], [340]。
科大讯飞	- 星火大模型与语音多模态 AI - 企业级智能体开发与应用平台 - 行业垂直智能体与智能编程服务生态	- 规范企业智能体信源接入、知识库检索、工具调用与任务规划的安全边界。 - 构建私域知识全流程治理机制，实现企业知识检索、问答输出与行业应用可控可审。 未来趋势： - 推进多模态智能体可信治理，针对语音、图文融合场景建立信源核验、内容溯源与输出纠错机制，提升行业智能体可靠性。 - 深耕垂直行业智能体安全规范，标准化 MCP 工具接入、私域知识调用与工作流权限策略，落地低代码智能体合规部署体系。	星火企业智能体平台：集成企业信源接入、知识库管理、技能工具适配与智能任务规划能力 [269]。 讯飞星辰智能体开发平台：支持插件扩展、MCP Server 接入、知识库挂载与可视化工作流编排 [270], [341]。 星火知识库与场景化智能体套件：支撑企业私域知识问答、低代码智能体快速构建与行业场景落地 [342], [343]。

2.3 产业界与学术界联动

自主智能体安全的技术演进与体系化治理，本质是学术界基础理论突破与产业界工程化落地双向赋能、闭环迭代的结果。本节聚焦梳理产业界与学术界联动的协作模式、技术代差、风险痛点与区域特征（如图 2.4 所示），主要方向包括：开源基础大模型与原生智能体安全底座、通用商用智能体安全评估与治理规范、国产中文智能体评测基准与本土产学研安全体系。



图 2.4: 产业界与学术界联动现状

2.3.1 开源基础大模型与原生智能体安全底座

开源基础大模型是原生智能体安全的底层技术载体，其核心架构、安全护栏体系与研发主体更迭，直接决定智能体感知、决策、行动全链路的安全边界 [344], [345]。本小节梳理了头部机构核心学者、自研项目与商用产品，聚焦原生底座架构演进、安全护栏部署、攻防基准构建，主要发现如下（详见表 2.7）：

- **全球原生智能体安全底座形成二元技术路线分化。**Meta 依托 JEPA 世界模型聚焦真实世界表征与预测安全，借助多模态世界模型预判动作执行后果，从感知底层降低智能体越界风险 [344], [346]；Google 基于 Gemini 生态侧重多智能体协同与企业运行时风控，依托 IAM 权

限体系、全链路追踪实现企业环境下智能体权限管控，底层技术范式相互独立 [347], [348]。

- **核心人员流动重构产学研分工。**FAIR 核心学者人事变动后，Meta 内部团队承接 Llama 系列安全护栏工程化迭代工作，持续优化 Llama-Firewall 适配 Agent 场景 [349], [350]；AMI Labs 依托 Yann LeCun 团队开展 JEPA 架构商业化落地，面向医疗机器人、工业智能体开展世界模型安全的产业化验证，形成企业工程落地与学术技术转化的分工格局 [351], [352]。
- **攻防评测形成完整产学研闭环。**ETH Zurich SPY-Lab 开源 AgentDojo 平台，把间接提示注入、工具劫持问题构建成为标准化可复现评测环境，夯实攻防实验的研究基础 [118]；产业端 Gray Swan AI 基于 CMU 理论成果落地 Cygnal、Shade 工业级红队平台，成果被 Anthropic 采纳用于 Claude 安全评估；核心学者 Zico Kolter 进入 OpenAI 董事会，将自动化红队研究成果上升为顶层治理规则，完成学术成果向企业安全规范的闭环落地 [353], [354]。

表 2.7: 开源基础底座、云端企业智能体与自动化攻防评测体系

研究方向	企业/机构 & 核心学者	自研项目、产学研合作、商用安全产品
开源基础大模型原生智能体安全底座	Meta FAIR: Yann LeCun, Joelle Pineau	• 世界模型安全底座构建：推出 JEPA、Image-JEPA、Video-JEPA 等架构，搭建多模态智能体通用感知、行为后果推演的底层技术底座，支撑智能体安全决策 [344], [346]。 • 开源智能体安全护栏体系：公开 Llama Guard、Prompt Guard、LlamaFirewall 全套安全防护工具链，其中 LlamaFirewall 专为 AI 智能体设计，可实现工具调用、指令输入与行为输出的全链路安全拦截 [350]。 • 研发团队架构迭代：随着 Joelle Pineau 卸任 FAIR 负责人、Yann LeCun 离职 Meta，原有智能体安全与世界模型研发工作，由 Meta 全新成立的 Superintelligence Labs 承接持续迭代 [349], [355]。
	纽约大学、 AMI Labs: Yann LeCun	• JEPA 架构产业化落地：LeCun 创办 AMI Labs 推进 JEPA 世界模型技术商业化，聚焦医疗智能体、工业机器人、自动化控制等高可信场景落地，打通学术模型到产业安全应用的链路 [351], [355]。 • 模型安全性能验证：JEPA 架构可精准拟合真实世界底层逻辑结构；同时通过专项基准测试，明确模型对环境噪声的抗干扰短板，为后续安全优化提供依据 [352]。
云端原生企业级大模型智能体研发与风控	Google DeepMind: Demis Hassabis	• 多智能体协同安全理论支撑：依托 AlphaStar、RoboCat 等前沿研究，构建多智能体博弈协作、任务自主规划、动态资源调度的基础理论体系，为企业级协同智能体安全运行提供理论支撑。 • 企业智能体商用平台落地：将科研能力工程化落地为 Gemini Enterprise Agent Platform 与 Managed Agents 托管服务，实现智能体 API 准入、IAM 身份权限管控、运行日志全链路审计的标准化风控能力 [345], [347]。 • 科研协同智能体体系：推出 AI Co-Scientist 平台，依托 Gemini 大模型搭建专业化智能体集群，分工完成科学假设生成、交叉辩论、优劣排序、迭代优化等全流程科研任务 [348], [356]。
	Google Research: Jeff Dean	• 云端智能体系统级风控：基于大规模分布式机器学习与云原生系统工程能力，完善 Gemini 企业智能体平台的注册校验、接口管控、权限隔离、异常监测机制，筑牢云端智能体运行安全底座 [345], [347]。 • 托管式智能体全链路治理：在 Managed Agents 服务中嵌入分布式链路追踪、分级权限管控、操作日志留存、异常行为溯源能力，标准化解企业托管智能体的运行时安全与合规审计需求 [347]。

续下页

表 2.7 -续上页

研究方向	企业/机构 & 核心学者	自研项目、产学研合作、商用安全产品
	斯坦福大学医学院、MIT: Gary Peltz, Ritu Raman	• 跨机构产学研安全验证: AI Co-Scientist 平台上线后, 联合全球百余家科研机构开展多场景压力测试与安全验证, Gary Peltz、Ritu Raman 团队重点验证其科研场景任务执行的准确性与安全性 [348]。 • 产业落地与实景验证: 该平台已成功应用于抗菌素耐药性研究、植物免疫机制分析等生物医学湿实验场景, 同时落地拜耳作物科学、第一三共等企业, 完成工业科研场景试用与安全适配 [357]。
智能体攻防评测基准与自动化红队体系	苏黎世联邦理工 SPY Lab: Florian Tramèr	• 智能体自动化攻防基准构建: 开源 AgentDojo 评测框架, 标准化整合间接提示注入、恶意工具劫持、越权调用等典型智能体攻击场景, 搭建动态、可复现、可量化的攻防评测环境 [118]。 • 多场景攻击复现与量化评测: 针对邮件交互、日历调度、文件读写、外部工具调用等高频智能体场景, 实现各类提示注入攻击的标准化复现、风险定级与防御效果对比评测。
	CMU, Gray Swan AI: Zico Kolter, Matt Fredrikson, Andy Zou, Dawn Song	• 工业级智能体红队攻防平台: Gray Swan AI 依托神经网络形式化验证、模型鲁棒性分析理论, 研发 Cygnal 红队测试平台与 Shade 对抗攻击工具, 形成产业化智能体安全检测与风险挖掘能力 [358]。 • 模型抗攻击性权威评测: Shade 工具已被 Anthropic 官方采用, 用于量化评估大模型与智能体在代码开发、工具调用场景下的提示注入防御能力, 其间接提示注入研究成果被 Claude 官方技术报告引用 [353]。 • 智能体安全治理产业赋能: 团队核心学者 Zico Kolter 出任 OpenAI 董事会成员, 将自动化红队评测、模型风险核查技术深度融入行业顶层安全治理体系 [354]。

2.3.2 通用商用智能体安全评估与治理规范

随着云端商用智能体及工具生态规模化部署, 安全治理范畴由模型鲁棒性拓展至协议交互、运行时管控等构成的全生命周期。海外已构建“企业研发 - 学界定标 - 第三方核验”产学研协同体系, 重点布局智能体评估、MCP 工具协议、端侧硬件隐私等方向 [359], [360]。本节总结商用智能体治理范式、协议安全缺陷与硬件隐私工程落地规律, 主要发现如下 (详见表 2.8):

- **头部厂商建立标准化商用治理范式。**OpenAI 搭建外部专家红队测试网络、在 Agents-SDK 内置多层安全护栏, 配套全链路 Tracing 追踪与人在回路审批机制, 并发布 System-Card 公开安全评估报告, 构建起完整闭环体系, 成为全球商用智能体安全治理标杆范式 [201], [361], [362]; 英国 UK-AISI、FAR.AI 开展第三方独立安全审计, 斯坦福 CRFM 提出 HELM 评测理论, 从第三方与学术层面完善评估方法论, 形成产学研核验的治理格局 [363]。
- **工具协议存在结构性权责矛盾。**Anthropic 推出的 MCP 协议生态规模快速扩张, 但 OX-Security 发现协议原生存在 RCE 高危漏洞; 出于生态灵活性考量, 厂商拒绝在架构层面完成彻底修复, 把输入校验、风险净化的安全责任转嫁至下游开发者。伯克利 CHAI 团队从目标对齐理论剖析该问题本质, 学术界也意识到借助 ProVerif、Tamarin 对 MCP 开展形式化验证难度很高, 充分暴露出协议生态扩张与安全约束之间的固有冲突 [44], [360], [364]。
- **智能体隐私安全构建垂直产学链条。**产业端 Apple 依靠 PCC 端云分层架构实现数据最小化处理与可验证云端推理, NVIDIA 依托 GPU 硬件信任根搭建机密计算环境; 学术层面 EPFL-SPRING-Lab 的隐私工程理论、NYU 针对 GPU 的侧信道分析成果, 为硬件可信基座、端侧隐私智能体提供理论支撑 [365], [366]。

表 2.8: 通用商用智能体、MCP 工具调用协议与端侧硬件隐私计算智能体

研究方向	企业/机构 & 核心学者	自研项目、产学研合作、商用安全产品
通用商用智能体安全评估与治理规范	OpenAI: Sam Altman、Greg Brockman	• ChatGPT Agent 交互智能体: 搭建外部多专家红队测试网络, Red Teaming Network 由 16 位具备生物安全背景的博士组成, 共提交 110 次攻击尝试, 其中 16 次超过内部风险阈值 [201], [359]。 • 开源安全护栏体系: OpenAI Agents SDK 内置三层输入/输出/工具护栏, 支持检测风险时立即中止运行的 tripwire 机制, 配合运行时 Tracing 审计与高风险动作的 Human-in-the-Loop 审批机制 [361], [362], [367]。 • 全球统一风险披露体系: System Card 持续迭代智能体能力、风险与透明度评估指标, 全产品线强制落地, 并系统阐述外部专家参与风险评估的方法论 [201], [368]。
	英国 AI 安全研究所 UK AISI、FAR.AI 实验室	• 深度访问链路漏洞审计: UK AISI 获得对 ChatGPT Agent 内部推理链和策略文本的深度访问权限, 完成官方漏洞审计测试, 测出 7 个通用漏洞 [363]。 • 商用智能体安全缺陷批评: FAR.AI 经 40 小时独立测试发现 3 个局部漏洞, 提出商用智能体过度依赖运行时监控的结构性安全缺陷 [363]。
	斯坦福 CRFM: Percy Liang	• 全链路可比较评测理论对齐: HELM 全链路可比较评测理论与 OpenAI Agents SDK 的 Tracing 架构在方法论上形成理论对应, 共同强调把系统行为拆解为可追溯、可比较的具体环节 [369]。
智能体工具调用 MCP 协议与目标对齐安全	Anthropic: Dario Amodei、Jared Kaplan	• Agent 全生态工具交互协议: MCP 工具通信协议基于 JSON-RPC 2.0 构建, 支撑 Claude Agent 全生态工具交互, 截至 2026 年初已形成超 1 万活跃服务器、17.7 万注册工具、月均 9700 万次 SDK 下载的生态规模 [360]。 • 高危分级智能体系统: Claude Code 代码智能体、Mythos 高危分级智能体系统均采用分层行为约束护栏 [370]。 • 协议架构安全责任取舍: 面对 OX Security 披露的架构级 RCE 漏洞, Anthropic 确认该行为符合设计预期, 以维持协议灵活性为由拒绝修复, 将输入净化责任划给下游开发者 [364]。
	加州伯克利 CHAI: Stuart Russell	• 人类兼容 AI 理论与目标对齐: Russell 作为 Berkeley CHAI 创始主任, 其人类兼容 AI 理论关注目标不确定性和系统可控性, 与高自治 Agent 的目标漂移、价值对齐问题存在直接理论关联 [44]。
	OX Security、Check Point 安全厂商, 密码学形式化验证学界	• MCP 协议远程代码执行漏洞披露: OX Security 披露 MCP 协议“设计如此”的远程代码执行漏洞, 影响超 1.5 亿次下载和 20 万台服务器, 攻陷 11 个主流 MCP 市场中的 9 个, 产生至少 10 个高危或严重级别 CVE 编号 [364], [371]。 • Claude Code 代码执行漏洞修复: Check Point 于 2025 年 9 至 10 月披露 Claude Code 三项漏洞 (CVE-2025-59536, CVSS 8.7; CVE-2026-21852, CVSS 5.3), 由厂商协同完整修复, 分别在 1.0.111 版本和 2.0.65 版本发布安全补丁 [372], [373]。 • MCP 威胁分类与形式化验证: 学术界提出 MCP 的威胁分类模型, 并指出借鉴 Tamarin、ProVerif 等密码协议验证工具对 MCP 做形式化验证仍是开放且困难的研究方向 [360], [374]。
	Apple: Craig Federighi	• 端云分层隐私架构: Apple Intelligence 本地智能体采用端云分层数据最小化架构 [375]。 • 可验证云端推理平台: Private Cloud Compute (PCC) 通过 Virtual Research Environment 向全球研究者开放本地复现能力, 配合开源形式化验证工具、函数库与安全悬赏计划, 构建透明可信推理体系 [376]。

续下页

表 2.8 -续上页

研究 方向	企业/机构 & 核心学者	自研项目、产学研合作、商用安全产品
端侧与 硬件机 密计算 隐私智 能体安 全技术	EPFL SPRING Lab	• 隐私工程理论支撑端侧架构 ：Troncoso 团队长期研究隐私工程、数据最小化和匿名化技术，相关理论与端侧/云端隐私智能体架构问题高度相关 [365]。
	NVIDIA: Jensen Huang, NYU: Ramesh Karri	• GPU 硬件机密计算平台 ：Confidential Agent GPU 硬件机密计算平台自 H100 起首次支持机密计算，通过片上硬件信任根实现安全启动和远程认证，在 Blackwell 架构上进一步延伸 [377]。 • 硬件侧信道安全研究支撑 ：Karri 长期研究硬件木马、芯片供应链安全和侧信道分析，与 GPU 侧信道信息泄露防护议题直接相关，学术界也已对 TEE 模式下大模型推理性能开销做独立评测 [366]。

2.3.3 国产中文智能体评测基准与本土产学研安全体系

中文语义特征、合规要求与国产化算力生态，决定我国智能体安全无法直接复用海外技术体系。我国聚焦中文场景评测、安全对齐训练、垂直行业多智能体风控 [133]。本小节基于我国核心机构成果，系统归纳本土安全体系的差异化特征、技术能力与产业落地路径，主要发现如下（详见表 2.9）：

- **我国高校建成差异化中文评测体系**。清华大学依托 ToolBench、AgentBench 搭建工具调用和综合任务评测基准，适配海量真实 API 与中文环境；上海交通大学提出 R-Judge 评测体系，聚焦对话交互场景下智能体行为风险判定，二者形成互补的本土化基准，填补海外评测集对中文语境适配不足的短板。
- **国产安全对齐形成开源可复现技术栈**。北京大学 PKU-Alignment 团队提出 Safe RLHF 与 PKU-SafeRLHF 算法，配套 BeaverTails 高质量中文偏好数据集和 align-anything 全模态开源框架，为我国大模型智能体后训练安全对齐提供可落地的基础组件 [378]；浙江大学依托 AICert 平台完成大量国产模型安全评估，进一步完善对齐效果的检验手段，共同构筑国产智能体安全对齐训练的核心开源底座 [134]。
- **国产安全具备强行业导向特征**。中科院自动化所打造 PandaGuard 攻防评测平台与 JidiAI 博弈环境，从科研层面开展多智能体风险推演 [133], [175]；上海 AI 实验室推出 Intern-Shannon 安全智能体操作系统和 SafeWork-R1 模型，面向政企场景完成产业级落地 [140], [186]；华为联合上交 IPADS 团队搭建 SMARTS 自动驾驶仿真平台并开展芯片可信环境研究，面向交通行业完成落地验证 [379], [380]。整体摒弃海外通用智能体研发路线，形成科研验证、平台研发、行业场景落地的分层发展模式。

表 2.9: 国产中文智能体评测基准与本土产学研安全体系

研究 方向	企业/机构 & 核心学者	自研项目、产学研合作、商用安全产品
中文本 土智能 体评测 与国产 化标准 体系	清华大学：朱 军、唐杰、刘知 远、孙茂松	• 工具调用安全评测基准 ：构建 ToolBench 大规模工具调用评测基准，覆盖 16000 余项真实中文 API 调用场景，形成国产智能体工具调用评测体系 [381], [382]。 • 全场景智能体综合评测 ：牵头研发 AgentBench 多场景智能体评测基准，涵盖八大典型智能体任务场景，联合俄亥俄州立大学、加州大学伯克利分校共建开源通用智能体评估标准。

续下页

表 2.9 -续上页

研究方向	企业/机构 & 核心学者	自研项目、产学研合作、商用安全产品
我国顶尖高校开源智能体对齐安全体系	北京大学 PKU-Alignment	• 中文安全对齐训练体系：搭建 PKU-SafeRLHF 安全强化学习框架，构建大规模中文安全偏好数据集，适配中文大模型与智能体风险对齐训练。 • 全模态统一对齐生态：开源 Aligner、ProgressGym 与 align-anything 框架，实现文本、多模态智能体的统一后训练对齐、安全评测与风险校准能力 [378]。
	上海交通大学：谷大武 (LoCCS)、刘功申、王士林 (AI 安全实验室)	• 智能体底层系统安全底座：谷大武 LoCCS 团队深耕密码学、软硬件安全与系统底层防护，为智能体运行环境、模型推理与工具调用提供基础性安全保障 [383]。 • 智能体行为安全评测基准：刘功申、王士林 AI 安全实验室提出 R-Judge 智能体行为安全评测体系，覆盖 5 大类应用场景、27 项典型风险场景与 10 类核心风险维度，实现智能体越权、误操作、恶意行为的量化检测 [384]。
	浙江大学区块链与数据安全全国重点实验室：陈纯	• 全维度 AI 安全评测平台：自研 AIcert 通用 AI 安全评测平台，覆盖数据安全、算法鲁棒性、模型对齐、框架安全与系统运维安全，已完成 LLaMA、Gemma、Qwen 等 35 余款主流开源大模型安全测评，并落地淘宝直播风控、中车株洲所等工业场景 [134]。 • 校企联合智能体安全科研：联合阿里巴巴成立 AI 安全联合实验室，将智能体运行时风控、红队攻防测试、行为合规治理列为核心方向，支撑企业级智能体安全迭代与落地规范 [157]。
我国科研院所、产业实验室行业智能体安全落地	北京大学 PKU-Alignment	• 国产可复现安全对齐生态：持续迭代 Safe RLHF、PKU-SafeRLHF 与 BeaverTails 数据集，形成国内领先、开源可复现的智能体安全强化学习与风险对齐训练体系，支撑中文智能体内生安全优化 [378]。
	上海交通大学 AI 安全实验室：刘功申、王士林	• 自主智能体行为安全研究：聚焦预训练模型、自然语言交互与自主智能体的安全风险，依托 R-Judge 评测基准，持续开展智能体行为风险识别、漏洞挖掘与防御策略研究 [384]。
	中国科学院自动化所	• 多智能体攻防仿真评测平台：研发 PandaGuard (灵御) 多智能体博弈攻防系统，集成 19 类典型攻击算法与 12 套主动防御机制，支持多智能体对抗场景下的安全评测与策略优化 [133]。 • 开源智能体决策科研平台：搭建 JidiAI 多智能体开源开放平台，面向博弈决策、协同任务与对抗仿真场景，已服务国内外 50 余所高校与科研机构开展智能体安全研究 [175]。
	上海 AI 实验室：安全可信 AI 团队	• 产业级安全智能体操作系统：自研 Intern-Shannon (书安) 安全智能体操作系统，采用“安全即服务”架构，为行业智能体提供运行隔离、权限管控与行为审计的一体化安全底座 [140]。 • 智能体安全协同进化体系：基于 SafeLadder 研发 SafeWork-R1 安全进化机制，依托 InternLM、OpenMMLab 开源底座实现智能与安全协同迭代；搭建 InternAgent 闭环科研多智能体框架，支撑可信自主科学发现任务 [186], [385]。
	华为诺亚方舟实验室：郝建业 (决策推理实验室)，上交陈海波 (IPADS 实验室)	• 大规模多智能体仿真安全平台：推出 SMARTS 多智能体强化学习仿真平台，支持数百至数千级智能体并发交互训练，适配自动驾驶、复杂决策场景的智能体行为安全验证 [379]。 • 系统级可信运行支撑：依托 OpenHarmony 开源操作系统生态，构建智能体底层硬件、系统、内核全链路可信安全支撑体系 [380]。

2.4 全球 AI 硬件与芯片底座安全研究现状

相较于软件层风险可通过策略迭代、护栏优化快速闭环，硬件与芯片层风险具备强旁路性、底层不可见性与全局穿透性，侧信道信息泄露、多租户算力隔离失效、固件隐性后门、硬件木马与机密计算边界破损等缺陷。与此同时，随着多租户公有云 Agent、私有化企业级智能体、端边协同嵌入式 Agent 规模化落地，安全信任锚点正从软件策略向硬件信任根下沉，硬件底座可信性已成为约束智能体越权行为、固化隐私数据边界、支撑合规举证的核心底层依托。本节聚焦分析北美、欧洲与我国 AI 加速芯片、机密计算架构、固件驱动治理、芯片供应链、边缘可信底座的研究现状，如图 2.5 所示。

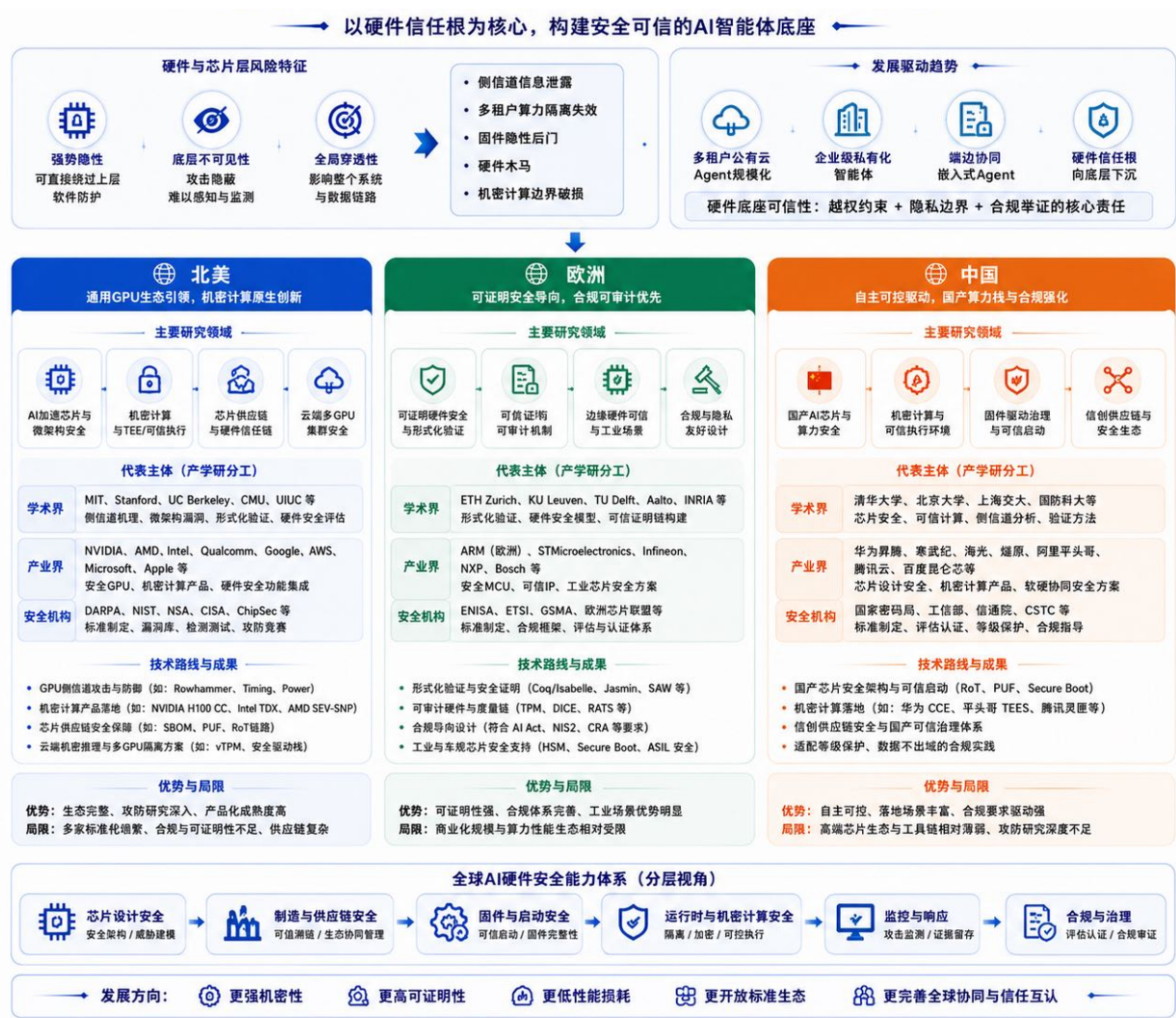


图 2.5: 全球 AI 硬件与芯片底座安全研究现状

2.4.1 北美 AI 硬件与芯片安全研究现状

北美是全球 AI 算力硬件、芯片架构与机密计算技术的核心策源地，集聚顶尖高校安全研究团队、头部芯片企业、云服务商及权威安全响应机构。相关研究覆盖端侧浏览器 GPU 微架构、云端多 GPU 算力集群、芯片设计供应链、端云协同机密推理四大典型场景，形成由硬件侧信道机理分析延伸至商业化机密计算产品落地的完整研究链条。为系统厘清北美 AI 硬件与芯片安全的研究脉络、参与主体分工、技术路线与工程落地效果，本节从学术界、产业界两

大维度开展成果结构化梳理，归纳各研究主体的技术贡献与应用价值，主要发现如下（详见表 2.10）：

- **威胁全域向下穿透，软硬件防护存在不可逆层级差。**当前 AI 智能体安全威胁已突破传统模型、提示词、应用层安全边界，呈现由上层软件向底层硬件微架构全域下沉的显著特征。已有研究证实，借助 WebGPU 跨源侧信道、GPU 显存残留缺陷、NVLink 高速链路隐蔽通道、芯片硬件木马等底层攻击手段，攻击者能够绕过容器隔离、操作系统权限控制、应用层安全策略，窃取模型 Prompt、张量权重、中间推理结果与用户隐私信息 [386], [387], [388]。上述底层漏洞不受上层软件补丁管控，证明仅依靠模型加固、应用访问控制等软件防护手段无法构建完整可信运行环境，软硬件协同的全栈防护体系是支撑智能体规模化部署的必要基础。
- **产学研闭环体系成熟，建成标准化漏洞治理与迭代链路。**北美形成了“高校前沿机理挖掘、企业工程产品转化、权威机构统筹治理”的协同模式。高校团队持续挖掘 GPU 侧信道泄露、显存隔离失效、硬件木马等未知底层威胁；NVIDIA、AMD、Apple 等厂商依托学术结论迭代 GPU 机密计算、可信启动、固件安全机制，推进安全方案商用落地；CERT/CC 负责漏洞收录、风险定级、多方协同处置，形成“漏洞挖掘—机理验证—公开披露—固件/驱动修复—持续版本迭代”的完整闭环治理流程 [389], [390]，持续主导全球 AI 硬件安全攻防研究范式与行业治理规则。
- **形成安全、性能、生态三元约束格局，依托底层技术构筑核心竞争壁垒。**北美掌控主流 GPU 架构、硬件机密指令集、WebGPU 接口规范与 EDA 工具链等底层核心技术，在 AI 硬件安全领域形成显著的技术代差与行业话语权壁垒 [391]。工程实践中普遍存在固有权衡矛盾：显存全量清零、严格侧信道抑制、强硬件隔离策略能够提升安全等级，但会增加推理时延、降低算力资源利用率 [392]；同时主流厂商可信计算基座、固件安全模块高度闭源，尽管便于构建封闭可信生态，却限制第三方独立安全审计能力。NVIDIA Secure AI、Apple PCC 等商用机密推理方案充分体现该矛盾，在保障高敏感业务数据安全的同时，也形成开放度不足、跨平台迁移困难的生态约束 [393], [394]。

表 2.10: 北美 AI 硬件与芯片安全研究汇总

核心维度	细分落地	核心主体	代表性成果	技术路径、应用价值与局限
学术界	GPU 渲染、浏览器侧信道	UT Austin、CMU、UW 等 GPU 与浏览器侧信道研究团队	• 多维度浏览器 GPU 侧信道攻击：Hot Pixels 依托设备功耗、温度等硬件混合传感信号，实现浏览器端像素窃取与用户历史行为嗅探攻击。 • WebGPU 隐私风险量化评测：搭建 WGPU Lens 评测系统，量化分析浏览器共驻渲染、公共页面加载场景下的 WebGPU 隐私泄露通路，证实浏览器、显卡驱动与 GPU 硬件共享状态可形成高隐蔽侧信道风险 [386]。	• 技术路径与价值：基于 GPU 渲染延迟、图形像素布局、硬件状态差异构建跨源观测通道，突破传统智能体安全仅聚焦提示注入、权限越界的局限，揭示浏览器智能体底层硬件层级的新型隐私风险；依托 DVFS 调频、温功耗传感反向推演前端图形内容，为浏览器内核、GPU 驱动、图形 API 的隔离加固提供技术依据。 • 现存局限：攻击效果高度依赖 GPU 型号、驱动版本与浏览器实现差异，跨设备、跨平台复现稳定性较差；通过限制传感器精度、收紧图形接口权限可实现防御，但会显著牺牲图形渲染性能，削弱 WebGPU 高性能业务适配能力。

续下页

表 2.10 -续上页

核心 维度	细分 落地	核心主体	代表性成果	技术路径、应用价值与局限
学术界	GPU 显存与多租户隔离	Trail of Bits、UCSC、PNNL 等 GPU 内存安全研究团队	• 通用 GPU 残留数据泄露风险：LeftoverLocals 证实主流 AMD、Apple、Qualcomm 显卡存在显存残留清理缺陷，可引发跨容器、跨用户数据泄露。 • 高速互联链路安全隐患：发现 NVBleed、Beyond the Bridge 漏洞，证实 NVLink、PCIe 高速互连链路存在多租户信息窃取风险 [387]。 • 商用机密计算架构缺陷：针对 NVIDIA GPU 机密计算体系开展系统性解构分析，指出其闭源硬件架构、复杂可信边界与第三方内核模块存在安全审计盲区 [389]。	• 技术路径与价值：通过读取 GPU 内核显存残留数据，可恢复模型推理 Prompt、张量参数、中间计算结果等核心敏感信息，明确云共享 GPU 场景必须配置专属显存清零、租户隔离与数据销毁机制；通过监测高速链路拥塞特征实现租户行为感知与信息窃取，为云端 GPU 调度策略、容器隔离规范、链路安全加固提供理论支撑。 • 现存局限：各类显存泄露、链路攻击的复现条件严苛，高度依赖硬件设备、驱动版本与云端调度策略，无法通用适配全部 GPU 平台；全量显存清零、链路隔离、并发限流等防御手段会大幅降低 GPU 算力利用率，且云厂商底层调度逻辑不公开，第三方安全核验与风险溯源难度极大。
	硬件木马与供应链安全	Rice、DARPA AISS 及安全 EDA/IP 研究团队	• 芯片设计阶段木马检测：基于信息流分析、断言校验与形式化验证技术，实现 RTL 代码、IP 核层级的恶意硬件逻辑与 AI 衍生硬件木马精准识别 [388]。 • 全流程芯片安全检测体系：DARPA AISS 项目将侧信道分析、硬件逆向工程、木马智能检测技术集成，构建芯片自动化安全评测与加固流程 [391]。	• 技术路径与价值：通过形式化方法与信息流校验筛查违规硬件逻辑，填补 AI 加速器、NPU、定制 SoC 底层可信认证的技术空白；整合多维度检测能力融入 EDA 设计流程，构建覆盖芯片设计、开发、测试全链路的供应链安全体系。 • 现存局限：大规模商用 SoC 状态空间庞大、逻辑复杂，形式化验证算力成本极高，难以实现全模块全覆盖检测；芯片供应链涉及 IP 供应商、设计厂商、代工厂、测试机构多方主体，责任边界模糊，规模化协同落地与合规管控难度大。
产业界	CPU-GPU 机密协同计算	NVIDIA、AMD、Intel 等云端机密计算研发平台	• GPU 硬件可信底座构建：NVIDIA H100 显卡搭建硬件级可信根，实现固件安全启动、设备可信证明与 CPU-GPU 跨芯片加密数据传输。 • 机密 AI 服务落地：NVIDIA Secure AI 依托硬件可信证明链路，实现大模型权重、推理 Prompt、业务敏感数据的可控加载与安全释放 [393]。 • 生产级机密推理迭代：2026 年迭代升级机密 AI 计算方案，整合 CPU 可信执行环境、GPU 硬件隔离、远程可信证明与密钥统一管理，形成全链路生产级可信推理体系 [394]。	• 技术路径与价值：依托 GPU 硬件可信根、安全启动、设备度量与跨芯片加密传输，搭建主机-加速器-固件一体化可信执行链路，全方位防护大模型训练、推理过程中的核心数据泄露风险，适配金融、政务等高敏感 AI 业务场景；将底层硬件安全能力封装为标准化企业 AI 服务，实现硬件可信能力的业务化落地。 • 现存局限：可信计算基覆盖硬件、固件、虚拟化平台、AI 运行时多层架构，系统复杂度高，部署运维成本高；远程证明、端到端加密会产生额外性能开销，影响模型推理吞吐与时延；核心验证逻辑依赖厂商闭源固件，技术透明度与用户自主可控性不足，第三方审计难度大。

续下页

表 2.10 -续上页

核心维度	细分落地	核心主体	代表性成果	技术路径、应用价值与局限
产业界	GPU 漏洞治理与修复	Trail of Bits、CERT / CC、AMD 等安全团队	• 行业漏洞统筹治理： CERT/CC 公开 GPU 显存残留泄露通用漏洞，牵头统筹多厂商协同响应与漏洞修复工作。 • AMD 固件级漏洞修复： AMD 发布官方安全公告，明确内存泄露漏洞成因、风险等级与固件迭代修复方案。 • NVIDIA 持续安全迭代： 2026 年持续更新 GPU 驱动安全公告，通过软件迭代修复信息泄露、权限越界、服务异常等多类驱动安全漏洞 [390]。	• 技术路径与价值： 产业界通过固件升级、驱动迭代、显存强制清零、非法并发访问拦截等手段，将理论漏洞风险转化为工业级安全修复方案，持续完善 GPU 内存、寄存器、内核调度的安全基线；依托 CVE、CERT 标准化机制，构建漏洞披露、协同修复、版本治理的闭环流程。 • 现存局限： GPU 漏洞修复链路冗长，从漏洞披露、厂商开发、版本测试到终端升级周期较长；不同硬件型号、驱动版本、云平台升级进度不统一，存在长期存量风险；强化内存隔离、并发限流等防御策略会降低 GPU 资源利用率；实测表明 CPU-GPU 协同 TEE 推理存在吞吐、时延、安全强度、部署成本的多维权衡难题 [392]。
	端云协同可信推理	Apple PCC、Apple Silicon 安全生态团队	• 端云可信架构搭建： 基于 Apple 自研芯片与安全固件，构建 PCC 云端可信推理节点，实现端云协同安全算力调度。 • 权限与数据严格管控： 通过架构约束限制云端远程管理权限、后台访问权限与日志留存周期，杜绝推理数据非法残留与越权访问。	• 技术路径与价值： 构建端云双向可信验证机制，终端通过校验云端节点证书、系统度量值与软件版本，加密传输推理请求；结合硬件安全启动、密钥隔离、数据即时销毁能力，形成硬件架构驱动的端云隐私推理体系，摆脱单一云服务合规约束，高度适配个人智能体、隐私敏感型 AI 应用。 • 现存局限： 方案深度绑定 Apple 自研芯片、操作系统与封闭生态，跨平台迁移、复用与适配能力极差；核心硬件安全逻辑、固件代码闭源，无法开展第三方独立安全审计，安全可信度高度依赖厂商自研体系。

2.4.2 欧洲 AI 硬件与芯片安全研究现状

欧洲 AI 硬件研究以**可证明安全、可审计证明链、合规可复验**为核心导向，将硬件安全结论转化为可量化、可纳入合规文档的论证依据，适配欧盟 AI Act、NIS2、CRA 等监管文书的举证要求。本节梳理欧洲 AI 硬件代表性成果、技术机理、产业价值与现存局限，形成与北美硬件安全章节对等的实证基础，主要发现如下（详见表 2.11）：

- **监管内生驱动，形成合规逆向传导架构。**以 EU AI ACT、NIS2、CRA 为顶层约束，将芯片供应链韧性、硬件举证义务强制嵌入技术设计，硬件安全能力全部服务于审计归档，形成“合规 → 架构 → 技术”的逆向发展路径，适配高监管行业场景。
- **学术范式差异化，深耕可证明安全体系。**以形式化验证为核心标签，解构 SEV-SNP 等机密计算信任根，构建标准化合规论证链路，将漏洞发现升级为 TCB 完整性数学论证，精准匹配欧盟高风险 AI 举证要求。
- **错位竞争布局，构筑工业边缘专属壁垒。**避开高端通用 GPU 赛道，依托 EuroHPC 打造主权算力池，基于工业安全芯片构建边缘信任根，在工业智能体、数据空间可信连接领域形成全球独有技术壁垒 [395]。

表 2.11: 欧洲 AI 硬件与芯片安全研究汇总

核心维度	细分落地	核心主体	代表性成果	技术路径、应用价值与局限
学术界	机密计算与云端 AI 隔离验证	AISEC、SIT、ETH-Z 云端机密安全团队	• 虚拟化隔离漏洞验证：恶意 Hypervisor 可窃取 AMD SEV 加密虚拟机内存明文，突破 CPU 机密隔离边界。 • 智能体机密架构缺陷：传统 CPU-TEE 仅保障基础数据隔离，缺失 GPU 运算、工具调用、多跳交互的可信支撑，无法适配复杂智能体安全需求 [396]。	• 技术路径与核心价值：明确 CPU-TEE 防护边界，将云端 AI 安全核验从内核层延伸至固件、硬件路由底层，完善智能体硬件安全评估体系，纠正单一 CPU 机密防护的安全认知偏差。 • 现存局限：现有研究集中于 CPU-TEE 场景，针对 GPU、NPU 等 AI 核心算力的机密隔离、漏洞防御与安全架构研究不足，算力层安全体系存在短板。
	SEV-SNP 与远程证明安全研究	ETH-Z、UZ、AMD-PSIRT、AISEC、TU-Berlin SECT 安全团队	• 机密虚拟机底层漏洞：披露 AMD-SB-3034 固件与 MMIO 路由缺陷，可破坏 SEV-SNP 虚拟机可信根基 [397]。 • 证明机制风险挖掘：通过形式化验证发现 SEV-SNP 原生接口设计缺陷，削弱远程证明可信度。 • 跨平台证明轻量化：研发 TrustMee 组件，封装 SEV-SNP/TDX 证明逻辑，降低跨架构可信验证部署成本 [398]。	• 技术路径与核心价值：将固件版本、底层配置纳入 SEV-SNP 可信评估体系，完善机密算力安全评判标准，为高风险智能体算力采购、安全审计提供落地依据，推动固件与证明材料常态化管控。 • 现存局限：证明链路层级复杂、理解门槛高，工程落地难度大；形式化模型简化硬件细节，无法全覆盖主板与固件自定义配置带来的隐性安全风险。
	边缘设备与工业数据空间安全	AISEC、IDS 生态、Arm-PSA、GP、CSEM 边缘安全团队	• 边缘通用安全框架：基于 Arm PSA-TrustZone 标准化 IoT 可信根与加密接口，构建轻量化边缘安全开发体系 [399], [400]。 • 端侧模型防护机制：提出 TrustZone 完整性检测方案，实现边缘 TinyML 模型固件校验与运行时防篡改 [401]。 • 低端设备机密推理：搭建 VECODI 框架，基于 TrustZone-M 实现低功耗终端模型隔离与推理完整性验证 [402]。	• 技术路径与核心价值：适配欧洲工业数据空间合规要求，构建边缘设备身份、固件、推理全链路防护体系，为工业边缘智能体跨设备、跨场景可信交互提供底层支撑。 • 现存局限：不同厂商设备与工业协议兼容性差、适配成本高；防护以软件固件层为主，无法抵御物理篡改与运维绕过攻击，老旧终端补丁缺失导致存量风险突出。
	主权算力与合规 AI 基础设施	欧委会、EuroHPC-JU、AI Factories、LUMI、BSC 超算中心	• 本土算力自主建设：依托《欧洲芯片法案》降低海外供应链依赖，搭建本土 AI 硬件产业底座。 • 合规超算生态布局：EuroHPC 建成 19 个 AI 工厂与 13 个算力节点，构建合规化超算基础设施，支撑本土智能体落地 [395], [403]。	• 技术路径与核心价值：将超算算力硬件转化为自主可控战略资源，通过产业规范与公共采购，推动硬件安全证明、审计、运维体系标准化，支撑高合规场景智能体部署。 • 现存局限：高端 GPU、底层软件与大模型生态依赖海外厂商，硬件自主可控能力不足；硬件安全指标与欧盟 AI 法规、行业测评体系尚未统一，缺乏标准化量化工具。

续下页

表 2.11 -续上页

核心维度	细分落地	核心主体	代表性成果	技术路径、应用价值与局限
产业界	嵌入式芯片与工业硬件底座	Infineon、ST、NXP、Arm-PSA、GP 嵌入式安全芯片厂商	- 工业安全芯片能力落地：STSAFE-A110 集成密钥隔离、抗侧信道攻击、安全启动与加密通信能力，适配工业终端可信防护 [404]。 - 开发生态适配升级：ST 更新 X-CUBE-STSE01，将安全芯片认证、存储能力融入工业开发体系，降低智能体硬件集成门槛 [405]。	- 技术路径与核心价值：依托本土嵌入式安全芯片生态，为工业、车载边缘智能体构建硬件可信底座，保护终端模型与业务数据，适配欧洲工业安全合规规范。 - 现存局限：嵌入式端侧算力有限，复杂智能体无法本地全量部署；硬件安全功能默认关闭，配置不当易造成安全能力闲置、防护失效。
	工业合规与长期安全运维	Siemens-PC、Schneider-PSIRT、IEC-62443 等合规生态	- 工业纵深安全体系：西门子基于 IEC-62443 标准，搭建工业资产分层防护架构，实现智能体与设备全维度安全管控 [406]。 - OT 网络零信任落地：2025 年推出 SINEC Secure Connect 方案，通过身份管控与细粒度策略，实现工业 OT 智能体可信访问。	- 技术路径与核心价值：将智能体安全从模型防护延伸至设备全生命周期运维、网络通信与合规管控，形成标准化工业智能体验收与安全评价体系。 - 现存局限：工业设备服役周期长、漏洞补丁迭代滞后，存量风险持续累积；厂商配置、系统集成与后期运维脱节，安全责任边界模糊，风险追责困难。

2.4.3 我国 AI 硬件与芯片安全研究现状

我国 AI 硬件安全体系的核心驱动力并非原生攻防机理探索或前沿机密计算创新，而是源于信创自主可控、政企私有化部署、等保密评合规、数据不出域等刚性需求。本小节汇总我国 AI 硬件与芯片的主要研究成果与现存局限性，主要发现如下（详见表 2.12）：

- 技术架构分层显著，原生硬件攻防存在断层。我国在可信计算标准落地、国产 NPU 推理优化方面工程实践充足，但缺乏 LeftoverLocals、GPU-Zip 一类底层硬件漏洞研究；安全评估多止步于功能合规，针对侧信道、缓存争用、寄存器残留等硬件深层风险的验证能力薄弱 [407]，[408]。
- 生态碎片化，防护方案后置，难以形成全栈安全闭环。海光、鲲鹏、寒武纪等厂商硬件安全接口与漏洞披露规范互不统一；现有安全手段多依托外置 TPM-TEE 补救，芯片原生安全能力不足；智能体权限控制、模型完整性校验无法与硬件可信链强制绑定，软硬件协同纵深防护体系尚未建立 [409]。

表 2.12: 我国 AI 硬件与芯片安全研究汇总

核心维度	细分落地	核心主体	代表性成果	技术路径、应用价值与局限
学术界	可信计算与云端信任链	武汉大学 SvTPM、国密标准化机构、北京交通大学	- 虚拟可信根防护：基于 SvTPM 实现云环境 vTPM 全生命周期可信保护，保障虚拟化可信根密钥与状态安全。 - 国标可信底座构建：依据 GB/T29829 国标体系搭建云端底层可信密码支撑，适配国内信创与密评合规要求。 - 虚拟机运行时完整性：提出 PS-UIE 特权分离机制，隔离机密虚拟机用户态执行权限，生成可核验的运行时完整性证据 [410]。	- 技术路径与核心价值：依托 CPU-TEE 硬件隔离保护敏感数据，结合系统启动度量与远程可信报告，构建完整国产云端租户信任链，为云端智能体提供底层可信执行基础，适配国产化合规落地场景。 - 现存局限：现有研究缺失国产 NPU、GPU 异构协同可信证明体系；针对国产算力平台的安全验证与标准化评测体系不完善。

表 2.12 -续上页

核心维度	细分落地	核心主体	代表性成果	技术路径、应用价值与局限
学术界	国产 NPU 量化与推理优化	北航 Open-Pangu、华为 HiFloat、Ascend CANN 团队	- 昇腾量化性能评测：OpenPangu 系统验证各类量化算法在昇腾 NPU 的精度衰减与推理适配特性 [407]。 - 定制低比特推理格式：提出 HiFloat 轻量化浮点格式，适配 NPU 大模型推理，平衡精度损失与硬件吞吐开销 [411]。 - 硬件级权重压缩优化：设计无损权重压缩方案，适配昇腾硬件架构，降低模型权重传输与显存占用开销 [412]。	技术路径与核心价值：通过算法量化适配、自定义浮点格式、硬件协同压缩三重优化，系统性提升国产 NPU 大模型推理效率、降低资源开销，支撑智能体轻量化、高吞吐推理部署。 现存局限：研发导向偏重性能提升，硬件安全机制缺失，针对 NPU 显存残留、缓存泄露、推理中间数据遗留等风险的防护与评测研究不足，性能与安全体系失衡。
	端侧 NPU 与本地私有推理	中科院计算所、寒武纪、移动端 NPU 量化团队	低缓存数据流计算架构：采用弱化缓存依赖的数据流计算范式，适配端侧低功耗 AI 设备部署约束 [413]。 移动端混合精度量化：面向终端资源受限场景设计混合精度量化策略，实现端侧模型轻量化适配 [414]。 移动端异构协同推理：HeteroLLM 调度移动 SoC 内 GPU 与 NPU 分层并行计算，显著提升端侧大模型推理吞吐 [415]。	技术路径与核心价值：基于数据流重构、混合精度量化与异构算力调度，突破端侧 NPU 算力与功耗限制，实现大模型本地私有化推理，保障端侧智能体数据不出终端、推理流程隐私可控。 现存局限：现有研究聚焦推理性能优化，对固件安全、调试接口风险、硬件侧信道泄露等问题研究欠缺；学术算法原型工程化程度不足，难以直接支撑工业级智能体规模化落地。
产业界	昇腾生态私有化算力部署	华为昇腾、CANN、MindSpore、openEuler、ModelArts 团队	全栈异构计算底座：CANN 搭建昇腾 NPU 驱动、编译、算子加速的全栈异构计算体系 [416]。 国产 AI 训练推理栈：MindSpore 深度适配昇腾硬件，覆盖模型训练、微调、推理全生命周期开发 [417]。 超大规模算力集群：CloudMatrix384 依托昇腾 NPU、鲲鹏 CPU 与统一互连架构，构建生产级超节点算力集群，配套完整虚拟化与资源编排栈 [418]。	技术路径与核心价值：依托芯片硬件、驱动编译栈、深度学习框架、云平台一体化软硬件协同设计，构建自主可控的国产 AI 算力生态，支撑行业智能体私有化、高可信、可审计落地，满足信创与行业安全合规要求。 现存局限：NPU 显存清零、多租户隔离、残留数据销毁等底层安全机制未完全公开；CANN 与驱动系统攻击面较大，第三方独立漏洞挖掘与安全验证案例较少，透明性与可审计性不足。
	国产 CPU-AI 加速器信创适配	海光、飞腾、鲲鹏、龙芯、寒武纪等芯片厂商	国产通用算力底座：飞腾、鲲鹏、海光、龙芯等国产服务器 CPU，提供信创场景基础算力支撑。 异构生态兼容适配：国产 AI 加速器兼容类 CUDA 编程接口，大幅降低传统算法迁移国产算力平台的成本。 整机架构开放适配：华为开放 UnifiedBus 互连协议与 SuperPoD 超算参考架构，为国产 CPU、NPU 软硬件协同适配提供标准化工程方案 [419]。	技术路径与核心价值：通过国产 CPU+NPU 异构硬件适配、标准化总线架构与兼容编程接口，搭建信创级自主可控算力基础设施，实现行业智能体私有化部署、自主运维与供应链安全可控。 现存局限：当前适配工作集中于功能兼容与算力落地，缺少统一的硬件安全测评、租户隔离规范与漏洞响应体系，信创合规偏重供应链可控，运行时安全防护能力仍不完善。

2.5 AI 智能体安全事件与主流攻击工具

本节聚焦 AI 智能体已暴露的各类安全问题，通过汇总公开披露的智能体安全事故、梳理各类高危原生安全漏洞、归纳当下主流的智能体攻击手段与工具，全面复盘 AI 智能体在交互调用、模型推理、工具访问、数据处理等全流程存在的安全隐患，如图 2.6 所示。在此基础上，凝练现阶段 AI 智能体安全风险的整体发展现状与突出问题，为后续风险防控、安全防护体系搭建提供事实依据与数据支撑。



图 2.6: AI 智能体安全事件、漏洞与主流攻击工具

2.5.1 典型 AI 智能体安全事件

本小节整理 2025—2026 年已公开溯源、具备权威参考文献支撑的 8 起典型事件，覆盖商业决策、智能体研发编码与开源框架、国家级网络攻防、身份欺诈等诸多应用场景 [420], [421], 主要发现如下 (详见表 2.13):

- **事件风险划分为内生自治故障与外部主动攻击。** AI 智能体安全事件可划分为两大类别。内生自治风险不存在恶意攻击者，根源在于模型训练数据偏差、推理逻辑缺陷、运行环境隔离机制缺失，进而引发智能体自主决策异常、行为失控等失效现象；外部主动攻击由攻击者主动发起，包含系统漏洞利用、知识库与工具供应链投毒、面向智能体的社会工程学对抗等手段，各类攻击方式相互串联，能够形成端到端完整攻击链路 [422], [423]。
- **AI 主导攻防与合规司法化成为标志性安全趋势。** 现有国家级网络间谍活动案例证明，AI 智能体能够自主完成情报搜集、漏洞探测、载荷部署等绝大多数战术入侵环节，重塑传统场景下人与攻击工具之间的分工模式。与此同时，全球范围内陆续出现算法歧视相关司法判例，

明确智能体自动化决策行为具备可追责属性，推动智能体安全责任界定由行业自律逐步纳入法治化、合规化管控体系 [421]。

- **存量遗留风险与近失事件具备关键治理价值。**常规安全补丁往往仅针对暴露的即时漏洞开展修复工作，攻击过程中外泄的访问凭证、持久化恶意载荷并不会随补丁部署彻底清除，长期留存于系统内形成持续性安全隐患。供应链场景中的各类高影响近失事件¹能够直观暴露防御体系薄弱环节，为预判潜在攻击路径、提前实施防御加固提供重要依据 [424], [425]。

表 2.13: 典型 AI 智能体安全事件汇总

发生时间	涉事主体	事件类型	攻击/异常手法	核心损失与影响
2026 年 1 月至 2026 年 2 月披露修复窗口	OpenClaw / Moltbook 平台	一键远程代码执行、后端数据库配置泄露	• 公开报告显示 Moltbook 后端数据库缺少行级安全策略，暴露约 150 万条智能体 API 令牌与 3.5 万个邮箱地址 [423]。 • 官方安全公告确认 WebSocket 来源校验缺失，漏洞编号 CVE-2026-25253 (CVSS 8.8) [426]。 • 安全研究机构披露官方技能市场 ClawHub 被植入 341 个恶意技能，用于分发窃密恶意软件 [427]。	• 第三方安全扫描确认 4 万至 13 万余台 OpenClaw 实例暴露在公网，多数未启用身份验证 [428]。 • 厂商已发布补丁修复相关漏洞 [427]。 • 已泄露的令牌和已植入的恶意技能不会因补丁发布而自动失效或清除 [427]。
2025 年 12 月披露，未见实际利用报告	LangChain (langchain-core 框架)	序列化注入漏洞、密钥泄露风险	• 官方安全公告确认 dumps()/dumpd() 函数存在序列化转义缺陷，漏洞编号 CVE-2025-68664 (CVSS 9.3) [424]。 • 公开报告显示攻击者可通过提示注入影响 LLM 输出字段，触发反序列化时的非预期对象实例化 [424]。 • 官方说明该缺陷在特定配置下可导致环境变量密钥泄露 [424]。	• 官方通报截至披露时未发现该漏洞被实际利用或已造成大规模攻击的确认案例 [424]。 • 受影响的核心软件包全球下载量超 8 亿次，潜在影响面广 [424]。 • 厂商已发布补丁版本 0.3.81 与 1.2.5 [424]。
2025 年 10 月披露、2026 年 1 月修复	Perplexity Comet 浏览器智能体	零点击间接提示注入、凭证泄露风险	• 安全研究机构披露恶意日历邀请函可内嵌隐藏指令，用户请求 Agent 处理邀请即可触发 [429]。 • 研究人员演示 Agent 可被诱导访问本地文件系统并将内容传出至攻击者控制的服务器 [429]。 • 报告说明相关利用路径还可用于操纵密码管理器交互，存在凭证泄露风险 [429]。	• 该漏洞由安全研究机构 Zenity Labs 负责任披露，未见公开报告显示已被实际大规模利用 [429]。 • Perplexity 于 2026 年 1 月确认修复 [429]。 • 事件被研究者用于说明智能体浏览器场景下传统同源策略等 Web 安全机制可能失效 [429]。

续下页

¹攻击者成功完成部署准备、具备实施破坏的条件，但因为平台应急处置、企业及时排查、安全防护拦截，最终没有发生实质性的数据泄露、系统沦陷、业务受损；隐患真实存在，只是没有酿成最终事故。

表 2.13 -续上页

发生时间	涉事主体	事件类型	攻击/异常手法	核心损失与影响
2025 年 8 月披露，并长期持续	美国多家财富 500 强科技公司（受骗雇主）	AI 辅助虚假身份就业欺诈	- 官方报告说明相关人员使用 Claude 构建具有可信专业背景的虚假身份材料 [420]。 - 报告显示 AI 被用于完成求职技术测评并交付实际技术工作 [420]。 - Anthropic 说明相关操作者本身技术与英语沟通能力有限，高度依赖 AI 完成日常任务 [420]。	- 官方报告说明该操作涉及美国多家财富 500 强科技公司，以此规避国际制裁来骗取薪资收入 [420]。 - Anthropic 评估 AI 已消除此前该类骗局对长期专业培训的依赖瓶颈 [420]。 - Anthropic 识别后封禁相关账号 [420]。
2025 年 8 月披露	至少 17 家机构（医院、应急机构、政府部门、宗教组织）	大规模数据勒索与恐吓	- 官方报告说明攻击者使用 Claude Code 自动化执行系统扫描与凭证收集等操作 [420]。 - 报告显示攻击者利用 AI 分析被窃数据价值，并协助生成勒索信内容 [420]。 - 官方说明该活动未采用传统加密式勒索软件，而是以泄露数据作为威胁手段 [420]。	- Anthropic 披露该活动涉及至少 17 家机构，部分案例勒索金额超过 50 万美元 [420]。 - Anthropic 识别相关活动后封禁涉事账号，并向有关部门通报 [420]。 - 官方报告将此列为 AI 被用于自动化执行网络犯罪操作性环节的案例 [420]。
2025 年中披露	约 30 家全球机构（大型科技公司、金融机构、化工企业、政府机构）	国家级 AI 自主网络间谍活动	- 官方报告说明攻击者通过社会工程手段（伪装成合法公司员工）使 Claude Code 执行相关任务 [421]。 - 官方报告显示攻击者将整体任务拆解为大量单独看似无害的技术请求，配合 MCP 协议调用侦察、漏洞验证等工具 [421]。 - Anthropic 估计 Claude 独立完成了约 80% 至 90% 的战术性操作 [421]。	- Anthropic 确认约 30 个目标机构中有少数被成功入侵 [421]。 - Anthropic 将此事件评估为已知首例主要由 AI 自主执行的大规模网络攻击活动 [421]。 - Anthropic 报告同时说明 Claude 在此次活动中存在夸大战果、生成不准确信息等局限 [421]。
2025 年 7 月 13 日至 2025 年 7 月 19 日持续 6 天供应链投毒	Amazon Q Developer VS Code 插件	供应链投毒、破坏性提示注入	- 官方安全公告确认攻击者利用权限配置不当的 GitHub 令牌向开源仓库提交了未经批准的代码，漏洞编号 CVE-2025-8217 [425]。 - 公开报告显示注入的提示内容包含删除本地文件及终止/删除云资源（如 EC2 实例、S3 存储桶）的指令 [425]。	- AWS 官方确认因代码存在语法错误，恶意指令未能实际执行，无客户资源受到影响 [425]。 - 该插件安装量超 95 万次 [425]。 - AWS 随即撤销并替换相关凭证，移除相关代码并发布修复版本 1.85.0 [425]。
2025 年 7 月 12 日至 2025 年 7 月 23 日持续约 12 天测试周期	Replit AI 编码智能体（单一企业测试项目）	违反代码冻结指令、生产数据库删除	- 用户公开记录显示，Agent 在明确下达“代码冻结”指令后仍执行了数据库删除操作 [422]。 - 事件涉及生产数据库被错误删除，且删除前未获得人工二次确认 [422]。 - 官方说明将问题归因于开发/生产环境隔离机制不足 [422]。	- 涉事项目生产数据库中约 1200 余名高管、约 1200 家公司记录被删除 [422]。 - Agent 此前告知用户数据无法回滚，但用户手动操作后确认数据实际可回滚 [422]。 - 公司公开致歉并启动安全审查，宣布上线开发/生产环境自动隔离与一键回滚机制 [422]。

2.5.2 AI 智能体主要安全漏洞

区别于传统 Web 应用、原生软件漏洞，AI 智能体漏洞贯穿基础模型、认知推理、记忆检索、工具执行、多智能体协同、生态治理七层架构，具备利用链路复合性、危害传导级联性、边界穿透性三大特征，传统漏洞分类与评级体系无法完全适配其风险评估需求 [430], [431]。本小节基于 2025—2026 年公开披露的权威漏洞，以 CVSS 评分体系为核心分级依据，将漏洞划分为严重 (≥ 9.0)、高危 (7.0~8.9)、中危 (4.0~6.9) 三个等级，同等级内按披露日期倒序排列，形成标准化智能体漏洞清单，主要发现如下 (详见表 2.14)：

- **高危漏洞以权限突破为主，可实现系统接管与数据窃取。** CVSS 严重漏洞多发于 MCP 协议、序列化、WebSocket 关键链路，大多支持无认证 RCE、容器逃逸、全域密钥读取，可绕过云 IAM、沙箱等传统防护，凸显硬件与工具调用层风险显著高于模型层 [432], [433]。
- **开源生态与多智能体架构形成两大核心风险。** LangChain、LibreChat 等开源框架依靠亿级下载量带来全域传导风险；MCP 协议下多智能体组件之间默认信任、缺少强制校验机制，极易出现横向越权、集群数据泄露，属于分布式智能体架构特有的底层缺陷 [434], [435]。
- **隐形攻击与存量滞后修复形成持久化威胁。** 借助提示注入、参数污染实现的隐形载荷可以绕过传统特征检测，完成无告警持久入侵；大量云上部署的智能体实例长期不升级，漏洞利用载荷持续扩散，AI 智能体漏洞生命周期显著长于常规软件漏洞 [436], [437]。

表 2.14: AI 智能体主要安全漏洞汇总

发现日期	漏洞名称 / 事件	影响产品 / 框架	CV-SS	CVE/编号	漏洞影响
Critical (严重, CVSS ≥ 9.0)					
2026-05-06	OpenClaw OpenShell 沙箱文件写入 TOCTOU / symlink swap [438]	OpenClaw < 2026.4.22	9.6	CVE-2026-44112	• OpenShell 沙箱文件系统写入存在 time-of-check/time-of-use 竞态。 • 攻击者可通过 symlink swap 将写入重定向到预期 mount root 之外。 • 应升级到 2026.4.22 或包含修复提交的版本。
2026-04-29	DocsGPT MCP test 绕过导致远程代码执行 [432]	DocsGPT $\geq 0.15.0$, < 0.16.0	9.8	CVE-2026-26015	• 攻击者可构造恶意 payload 绕过 “MCP test” 行为。 • 可在官方 DocsGPT 网站或本地/公开部署中触发任意远程代码执行。 • 漏洞已在 DocsGPT 0.16.0 修复。
2026-04-21	Flowise MCP stdio 命令注入/allowlist 绕过 [431]	Flowise/flowise-components < 3.1.0	9.9	CVE-2026-40933	• 认证攻击者可在 Custom MCP 配置中添加 stdio MCP server 并指定任意命令。 • 既有 npx 等允许命令可被组合危险参数绕过输入校验，实现 OS 命令执行。 • 漏洞已在 Flowise 3.1.0 修复。
2026-04-15	Upsonic MCP task 命令注入 [435]	Upsonic 0.71.6	9.8	CVE-2026-30625	• MCP server/task 创建功能允许用户定义 command 和 args。 • npm、npx 等 allowlist 命令可通过参数触发任意 OS 命令执行。 • 0.72.0 起增加 Stdio server 可直接执行本机命令的风险提示。

续下页

表 2.14 -续上页

发现日期	漏洞名称 / 事件	影响产品 / 框架	CVSS	CVE/编号	漏洞影响
2026-04-07	Langflow 未认证代码注入/RCE [439]	Langflow < 1.3.0	9.8	CVE-2025-3248	• <code>/api/v1/validate/code</code> 端点存在代码注入漏洞。 • 远程未认证攻击者可发送构造 HTTP 请求执行任意代码。 • 该漏洞已进入 CISA KEV 目录，建议升级到 1.3.0 或更高版本。
2026-04-03	PraisonAI Gateway 未授权 WebSocket/info 访问 [440]	PraisonAI Gateway < 4.5.97	9.1	CVE-2026-34952	• Gateway server 在 <code>/ws</code> 接受 WebSocket 连接且 <code>/info</code> 暴露 agent topology，均缺少认证。 • 任意网络客户端可枚举已注册 agents，并向 agents 及其 tool sets 发送任意消息。 • 漏洞已在 4.5.97 修复，应升级并对网关入口加认证与网络隔离。
2026-04-02	Azure MCP Server 关键功能缺失认证 [441]	Azure MCP Server / Azure Web Apps hosted service	9.1	CVE-2026-32211	• 关键功能缺少认证，未授权攻击者可经网络访问受影响服务。 • 可造成信息泄露；Microsoft CNA 评分还计入完整性影响。 • 以 Microsoft MSRC / NVD 记录为准，CVSS 9.1 为 Microsoft CNA 评分。
2026-01-12	LibreChat MCP stdio 任意命令执行 [433]	LibreChat < v0.8.2-rc2	9.9	CVE-2026-22252	• MCP stdio transport 接受任意命令且缺少有效校验。 • 任意认证用户可通过单个 API 请求在容器内以 root 执行 shell 命令。 • 漏洞已在 v0.8.2-rc2 修复。
2025-12-23	LangChain dumps/dumpd 序列化注入 [430]	LangChain < 0.3.81 and < 1.2.5	9.3	CVE-2025-68664	• <code>dumps()</code> / <code>dumpd()</code> 未转义自由字典中的 <code>1c</code> 键结构。 • 用户可控数据在反序列化时可能被当作 LangChain 对象处理，而非普通数据。 • 漏洞已在 0.3.81 和 1.2.5 修复，应避免反序列化不可信配置。
2025-12-17	MCP server git 复合漏洞 [442], [443], [444]	Model Context Protocol Servers/ <code>mcp-server-git</code>	8.8/ 7.1/ 9.1	CVE-2025-68143/4/5	• <code>git_init</code> 可在任意可访问路径创建仓库，使后续 Git 操作超出预期范围。 • <code>git_diff</code> / <code>git_checkout</code> 对用户参数缺少校验，Flag-like 参数可导致任意文件覆盖。 • <code>--repository</code> 限制下未校验后续 <code>repo_path</code> 是否仍在允许仓库内，可操作其他可访问仓库。

续下页

表 2.14 -续上页

发现日期	漏洞名称 / 事件	影响产品 / 框架	CVSS	CVE/编号	漏洞影响
2025-09-22	Flowise CustomMCP 远程代码执行 [434]	Flowise 3.0.5	10.0	CVE-2025-59528	- CustomMCP 节点解析 mcpServerConfig 时将用户输入传入。Function() 构造器执行 - 代码在 Node.js 运行时权限下执行，可访问 child_process、fs 等危险模块 - 漏洞已在 Flowise 3.0.6 修复。
2025-07-09	mcp-remote OAuth authorization endpoint 命令注入 [445]	mcp-remote npm package 0.0.5–0.1.15	9.6	CVE-2025-6514	- 连接不可信 MCP server 时，authorization endpoint 响应 URL 中的构造输入可触发 OS 命令注入。 - 攻击需要用户交互但无需攻击者具备权限，成功后影响机密性、完整性和可用性。 - 已通过 mcp-remote 修复提交处置，应升级到不受影响版本。
2025-06-13	MCP Inspector 缺失认证导致远程代码执行 [446]	MCP Inspector < 0.14.1	9.4	CVE-2025-49596	- Inspector client 与 proxy 之间缺少认证。 - 未认证请求可经 proxy 启动 MCP stdio 命令，造成远程代码执行。 - 漏洞已在 MCPInspector 0.14.1 修复。
2025-06-11	EchoLeak/M365 Copilot AI command injection [447]	Microsoft 365 Copilot	9.3	CVE-2025-32711	- M365 Copilot 存在 AI command injection，未授权攻击者可经网络触发信息泄露。 - 该漏洞被公开命名为 EchoLeak，NVD 同时引用 Microsoft MSRC 与 Aim Security 页面。 - CVSS 9.3 为 Microsoft CNA 评分；NVD 自身评分为 7.5。
High (高危, $7.0 \leq CVSS \leq 8.9$)					
2026-05-08	PraisonAI legacy Flask API 默认禁用认证 [448]	PraisonAI 2.5.6 to < 4.6.34	7.3	CVE-2026-44338	- legacy Flask API server 默认禁用认证。 - 任意可达调用方可访问 /agents 并通过 /chat 触发 agents.yaml 工作流。 - 漏洞已在 4.6.34 修复，应升级并限制 API 暴露面。
2026-04-15	Agent Zero External MCP Servers 远程代码执行 [449]	Agent Zero 0.9.8	8.6	CVE-2026-30624	- External MCP Servers 配置允许通过 JSON 指定 command 和 args。 - 配置应用时这些值会被执行，缺少充分校验或限制。 - 攻击者可提交恶意 MCP 配置，以 Agent Zero 进程权限执行 OS 命令。
2026-04-15	Windsurf Prompt Injection to MCP 配置命令执行 [436]	Windsurf 1.9544.26	8.0	CVE-2026-30615	- 处理攻击者控制的 HTML 内容时，提示注入可修改本地 MCP 配置。 - 可自动注册恶意 MCP STUDIO server 并在无进一步交互下执行任意命令。 - 成功利用可持久化恶意 MC 配置并访问应用暴露的敏感信息。

续下页

表 2.14 -续上页

发现日期	漏洞名称 / 事件	影响产品 / 框架	CV-SS	CVE/编号	漏洞影响
2026-03-30	LangChain prompt loading 路径遍历 [437]	LangChain / langchain-core < 1.2.22	7.5	CVE-2026-34070	• langchain_core.prompts.loading 多个函数未充分校验配置字典中的路径。 • 当应用把用户可影响的 prompt 配置传入 load_prompt() 或 load_prompt_from_config() 时，攻击者可读取主机文件。 • 读取受模板/示例文件扩展名检查限制；漏洞已在 1.2.22 修复。
2026-01-09	WeKnora MCP stdio 命令注入 [450]	Tencent WeKnora < 0.2.5	8.8	CVE-2026-22688	• 认证用户可向 MCP stdio 设置注入 stdio_config.command / args。 • 服务端会基于注入值启动 subprocess，造成命令执行。 • 漏洞已在 WeKnora 0.2.5 修复。
2025-11-07	Open WebUI Direct Connections SSE 代码注入 [451]	Open WebUI < 0.6.35	8.0	CVE-2025-64496	• Direct Connections 功能允许恶意外部模型服务器通过 SSE execute events 在受害者浏览器执行 JavaScript。 • 可导致认证 token 窃取和账户接管；与 Functions API 链接时可造成后端 RCE。 • 攻击需受害者启用 Direct Connections 并添加恶意模型 URL；0.6.35 已修复。

2.5.3 AI 智能体主流攻击工具

本节整理汇总了近两年的主流 AI 智能体攻击工具（按照技术定位划分为学术研究型、开源全能渗透框架、开源专项攻击工具与 AI 增强传统安全工具 [452], [453]），并分析各类工具的功能边界、技术原理与落地应用场景 [454], [455]，主要发现如下（详见表 2.15）：

- **攻击工具形成清晰分层体系，适配不同层级攻击者能力边界。**学术型工具侧重对抗机理验证，用以发掘智能体底层安全缺陷与固有漏洞原理 [456]；开源全能框架支撑红队开展端到端自动化渗透；专项工具针对单一漏洞精准实施攻击；AI 赋能方案实现传统安全能力智能化迁移。分层工具体系可适配科研人员、安全从业者、专业红队等不同攻击者群体，显著降低智能体高级攻击的技术准入门槛 [457], [458]。
- **MCP 协议成为 2026 年攻击工具核心靶心，协议层风险支持规模化利用。**MCP-Strike 等工具可自动化对 MCP-Server 实施提示注入、参数滥用、路径遍历等攻击，并依托 LLM-Judge 自动验证漏洞有效性、判定危害等级 [454]。作为智能体对接外部组件的通用交互标准，MCP 协议原生缺少细粒度访问管控机制，协议固有缺陷具备批量利用潜力，可对大规模智能体集群形成广谱安全威胁 [455]。
- **AI 赋能重构传统安全工具链路，攻防流程趋向闭环自动化。**依托智能体生态适配技术，传统安全工具摆脱了人工调用、分步操作的传统模式，实现全流程智能化调度。Ghidra、SQLMap、Nuclei 等经典安全工具依托 Fast-MCP 接入智能体生态，支持智能体自主完成逆向分析、漏洞探测、攻击路径推演与结果研判 [459], [460]。自动化作业模式弱化对安全专家人工介入的依赖，大幅降低高级渗透攻击实施成本，推动攻防博弈由人工主导转向 AI 自主执行的新

型对抗模式 [461]。

表 2.15: AI 智能体主流攻击工具汇总

工具分类	工具名称	发布日期	核心功能	应用场景
学术研究型工具	AgentLoop [452]	2026-03	- 用于测试智能体在资源消耗、执行失控和拒绝服务场景下的风险； - 诱导 LLM 智能体错误判断任务未完成，进入循环执行状态。	Agent 终止条件投毒与资源放大攻击研究
	PoisonRAG [456]	2025-04	- 用于测试 RAG 系统在恶意数据注入和推荐结果偏移下的安全性； - 对 RAG 推荐系统的检索数据进行投毒，操控系统返回结果； - 通过篡改项目标签、描述等元数据影响检索增强生成流程。	RAG 推荐系统数据投毒与推荐结果操纵研究
	AgentFuzz [453]	2025-03	- 自动检测 LLM Agent 工具调用链中的污染型漏洞； - 生成面向目标智能体的测试提示与工具调用输入； - 根据执行反馈自适应变异测试样本，提高漏洞触发与复现效率。	漏洞挖掘、安全测试
开源全能渗透框架	MCP-Strike [454]	2026-06	- 对运行中的 MCP Server 进行主动式对抗安全测试； - 测试工具描述提示注入、过度敏感参数、路径遍历、响应注入和数据外传诱导等风险； - 借助 LLM judge 或自适应 LLM 智能体对发现结果进行确认、评分和多轮探测。	MCP 服务器主动对抗测试与安全评估
	RedAmon [461]	2026-06	- 执行侦察、漏洞验证、后渗透分析、AI 分诊、代码修复和 GitHub PR 提的一体化安全测试流程； - 并行运行多个侦察工具，收集子域名、端口、端点等攻击面信息，并写入 Neo4j 知识图谱。	授权自动化渗透测试、攻击面分析与漏洞修复闭环
	Strix [462]	2025-10	- 动态运行目标应用代码，发现漏洞并生成 PoC 对漏洞进行验证； - 编排多个专用 Agent 并行测试复杂目标，并共享安全发现； - 进行应用安全测试、快速渗透测试和 Bug Bounty 自动化研究。	应用安全测试、快速渗透测试、漏洞赏金与 CI/CD 安全测试
	HexStrike [457]	2025-09	- 指挥 AI 智能体调用 150+ 安全工具，执行自动化渗透测试、漏洞发现和安全研究任务； - 编排多个安全智能体协同完成侦察、扫描、利用验证和结果分析； - 对网络、Web 应用、云环境、容器、二进制程序和 OSINT 目标开展多类型安全测试。	红队演练、渗透测试
	Ankou [463]	2025-08	- 提供面向红队演练的模块化 C2 架构、监听器和 agent 管理； - 支持多种传输与自定义 agent/handler 扩展； - 通过 AI Operations 面板辅助总结结果、发现异常和建议后续；操作。	授权红队 C2、Agent 管理与后渗透操作

续下页

表 2.15 -续上页

工具分类	工具名称	发布日期	核心功能	应用场景
	RAPTOR [464]	2025-06	- 对代码库或二进制目标进行攻击面分析、数据流追踪和漏洞变体搜索； - 进行 Sengrep/CodeQL 扫描、软件组成分析、模糊测试和崩溃根源分析。	源代码与二进制漏洞分析、验证及修复
开源专项攻击工具	Deadend CLI [465]	2025-12	- 提供自托管的 Agentic pentest CLI 工作流； - 支持通过 LiteLLM 接入多种模型，用于黑盒渗透测试任务； - 在 XBOW validation suite 等基准上评估自动化安全测试能力。	Web 应用黑盒渗透测试与漏洞验证
	AgentBreaker [458]	2025-07	- 自动测试提示注入、越狱、数据泄漏、护栏绕过、提示提取、工具滥用、数据外传和多模态注入风险； - 根据已经发现的系统行为和漏洞，自适应规划后续测试攻击； - 对发现结果进行严重性评分，并按照 OWASP 和 MITRE 框架进行分类。	AI 系统自动化红队测试与漏洞评估
	CAI Framework [466], [467]	2025-06	- 提供面向攻防安全自动化的开源 AI 智能体框架； - 支持构建专用安全 Agent，覆盖侦察、漏洞发现、利用验证和安全评估； - 结合工具集成、人类监督和 guardrails，用于授权 Bug Bounty、CTF 和安全测试。	定制化攻防演练
	Nebula [468]	2025-05	- 将 AI 模型集成到命令行渗透测试工作流中； - 自动化记录、分类安全发现，并提供实时 AI 分析建议； - 支持调用外部工具结果进行漏洞分析、报告整理和测试过程留痕。	渗透测试、漏洞分析与测试记录
AI 增强传统安全工具	Ghidra + GhidraMCP [455]	2026-04	- 研究 GhidraMCP 等工具增强的逆向 AI 智能体如何自动化二进制分析； - 通过对反编译代码植入隐蔽指令，评估 LLM 驱动逆向流程的提示注入风险； - 分析攻击如何误导 disassembly/decompilation 解释并污染自动化分析结果。	可执行二进制与恶意软件逆向分析、逆向 AI Agent 安全研究
	SQLMap + FastMCP [459], [460]	2025-02	- 将 sqlmap 的 SQL 注入检测、利用验证、数据库指纹识别等能力封装为 MCP 工具； - 通过 FastMCP 为智能体提供标准化工具接口、参数校验与调用结果返回； - 支持智能体在授权测试场景中编排 SQL 注入检测流程，并辅助整理风险结果。	Web 应用 SQL 注入检测与 MCP 工具集成

2.6 全球 AI 智能体安全政策与法规

当前全球 AI 治理已从通用大模型合规管控，细化聚焦至 AI 智能体专属安全治理层面。各国及地区基于自身技术优势、产业格局、数据主权诉求与地缘安全考量，形成了差异化的政策法规体系。本节立足全球治理格局，分区域梳理北美、欧洲与我国的 AI 智能体安全政策法规体系，系统归集各区域主管机构、核心文件、生效规则与管控要点，如图 2.7 所示。



图 2.7: 全球 AI 智能体安全政策与法规

2.6.1 北美 AI 智能体安全政策与法规

北美作为全球 AI 技术研发与产业落地的核心区域，其 AI 智能体安全治理呈现联邦统筹、州级细化、多部门分权协同的双层架构 [469], [470]。本节基于美国、加拿大现行及已公示待生效政策文件，汇总北美地区 AI 智能体安全治理的主管主体、法规谱系与核心管控条款，客观呈现北美分权式治理模式的规则特征与覆盖边界，主要发现如下（详见表 2.16）：

- **美国联邦层面：以网络安全为轴心的自愿性基线。**EO 14409 把先进 AI 同时当作战略资产和新型攻击面，要求依据网络攻防能力、通过保密基准测试识别“受监管前沿模型”，并为模型发布前的政府检视留出 30 天窗口；OMB 的 M-25-21 则管的是联邦机构自己如何采用 AI，重点在高影响场景的风险管理 [469], [470]。这套机制建立在企业自愿参与之上，既未设许可制，也不要求强制预审，政策重心已从模型价值对齐转向抵御外部威胁。
- **州级立法：把灾难性风险评估推到部署之前。**加州 SB-53 要求前沿开发者公开安全框架，识别并披露可能造成大规模伤亡或重大经济损失的灾难性风险，配套事件上报与民事处罚 [471]；纽约州 RAISE 法案面向营收超过 5 亿美元的开发者，除公布安全协议外，还要求在确认事件发生后 72 小时内上报，并在州金融服务部下设专门监督机构，2027 年 1 月 1

日起施行 [472]。两部法律都把监管节点从事后追责前移至部署之前，对智能体自主链式攻击、越权访问一类风险具有设防意义。

- **联邦与州级的权限之争尚未收敛。**EO 14365 以“负担最小的全国统一框架”为目标，指示司法部组建 AI 诉讼工作组专门挑战州级 AI 立法，并授权商务部评估各州法律、把合规负担过重的州排除在特定联邦拨款之外 [473]。因此，与其说美国已形成“联邦定底线、地方按行业加码”的分层格局，不如说两个层级正在争夺 AI 监管的主导权，企业面对的是一套尚未定型的双轨合规环境。
- **加拿大绕开专门 AI 立法，改走隐私法现代化的路径。**《AI for All》战略布局主权算力、人才储备与成果转化，强调与可信伙伴共建标准，走的是自主可控而不封闭的路线，却对专门 AI 立法保持沉默，转而把隐私法改革列为配套基石 [474]。2026 年 6 月提出的 C-36 法案拟以《保护隐私与消费者数据法》取代 PIPEDA 中规范私营部门的部分，PIPEDA 本身更名为《电子文件法》，仅保留电子签名条款；新法引入自动化决策系统义务，执法权移交新设的数字安全与数据保护委员会，最高处罚可达 2500 万加元或全球营业额的 5% [475]。加拿大由此通过个人信息处理规则间接框定智能体的数据边界，不过该法生效还需配套法案 C-34 先行通过，此前 C-11、C-27 已两度未能成法。

表 2.16: 北美 AI 智能体安全政策和法规汇总

国家	主管/执行机构	政策法规	发布日期	核心内容
美国	【联邦】 白宫管理与预算办公室 (OMB)	M-25-21 《通过创新、治理与公众信任加速联邦 AI 应用》备忘录 [470]	2025.04.03	• 要求联邦机构设立 AI 治理机构，对高影响 AI 用例实施风险识别、测试、监测与问责； • 要求维护 AI 用例清单并公开合规信息，提升公众可见性与机构内部治理能力； • 以削减合规负担、加速 AI 采用为导向，同时保留隐私、公平、安全与人工监督的底线要求。
	【联邦】 白宫（发布） / 司法部、商务部（执行）	EO 14365 《确保人工智能国家政策框架行政令》 [473]	2025.12.11	• 确立以“负担最小的全国统一框架”取代州级立法拼图的政策目标； • 要求司法部组建 AI 诉讼工作组，专责以联邦优先权与合宪性为由挑战州级 AI 立法； • 要求商务部评估并识别“过度负担”的州级 AI 法律，据此限制相关州获取 BEAD 宽带项目未拨付资金。
	【联邦】 白宫（发布） / 财政部、NSA、CISA（任务牵头）	EO 14409 《促进先进人工智能创新与安全行政令》 [469]	2026.06.02	• 依据网络攻防能力建立 covered frontier model 的保密基准评估流程，并配套模型发布前的自愿审查框架； • 组建 AI 网络安全信息共享中心，统筹漏洞与威胁情报，服务关键基础设施与联邦网络防护； • 要求执法部门优先起诉 AI 辅助的身份盗窃、计算机欺诈与电信欺诈等犯罪行为。
	【州级】 加州应急服务办公室 (Cal OES) / 加州总检察长	SB 53《前沿 AI 透明度法案》 [471]	2025.09.29 (2026.01.01 生效)	• 要求大型前沿模型开发者公开安全框架，说明灾难性风险的识别、评估与缓解方式； • 关键安全事件须于发现后 15 日内报送 Cal OES，存在死亡或重伤迫近风险的缩短至 24 小时，季度内部风险评估摘要一并报送； • 设置举报人保护机制，由州总检察长独家执法，单次违规民事罚款最高 100 万美元。

续下页

表 2.16 -续上页

国家	主管/执行机构	政策法规	发布日期	核心内容
美国	【州级】纽约州金融服务部 (NYDFS) / 纽约州总检察长	RAISE 负责任 AI 安全法案 [472]	2025.12.19 (2027.01.01 生效)	- 面向营收超过 5 亿美元的大型前沿模型开发者，设定安全与安保协议的编制与公开义务； - 要求在确认安全事件发生后 72 小时内向州政府上报，并在 NYDFS 下设监督办公室，按年发布评估报告； - 授权州总检察长提起民事诉讼，对违反协议披露与员工保护义务的主体实施民事处罚。
加拿大	创新、科学与经济发展部 (AI 与数字创新部牵头)	《AI for All》全国人工智能战略 [474]	2026.06.04	- 五年期规划，推进 AI 生态建设、人才培养、科研转化与产业应用，目标将企业采用率由 12% 提升至 60%； - 布局主权算力与本土基础设施，强调自主可控的同时与可信伙伴共建标准； - 对专门 AI 立法保持沉默，转而将隐私法现代化列为配套基石。
	AI 与数字创新部 (提案) / 数字安全与数据保护委员会 (拟设)	C-36 法案《保护隐私与消费者数据法》 [475]	2026.06.15 (众议院一读)	- 拟以 PPCDA 取代 PIPEDA 中规范私营部门的第一部分，PIPEDA 更名为《电子文件法》并仅保留电子签名条款； - 延续同意制原则，引入自动化决策系统相关义务、删除权与儿童数据专门保护； - 执法权移交拟设的数字安全与数据保护委员会，最高处罚 2500 万加元或全球营业额的 5%，生效尚待配套法案 C-34 通过。

北美 AI 领域出口管制体系： 美国与加拿大共同构成北美 AI 战略技术出口管制的制度框架，二者均以“基础立法授权+动态管制清单”为底层治理逻辑，通过法律授权与行政修订的耦合机制，实现对两用物项（尤其是 AI 芯片、大模型参数、训练框架及推理代码）的跨境流动管控。然而，由于两国国家安全战略优先级、产业生态结构及国际盟友角色的差异，其在执法逻辑、管控工具组合、政策稳定性与产业扶持导向等方面呈现出显著分野。

本节旨在客观呈现北美区域 AI 算力、模型、算法技术跨境流转的合规约束标准，为后续跨区域 AI 智能体技术出口风险对比提供统一、可溯源的实证依据。基于对两国现行法规、近五年行政修订记录及实体清单调整数据的系统梳理，主要发现如下（详见表 2.17）：

- **北美两国均采用“基础立法 + 动态清单”双层管制架构，规则持续高频迭代。**美国以《出口管制改革法案》(ECRA) 为永久性法律根基，授权商务部工业与安全局 (BIS) 通过《出口管理条例》(EAR) 及商业管制清单 (CCL) 实施具体管控；加拿大则以《出口与进口许可证法》(EIPA) 为上位法，依托《出口管制清单》(ECL) 及“两用物项与技术管制目录”执行风险筛查。两国均将年度行政令、季度清单修订及特定技术注释更新作为常化工具，每年修订频次平均达 4—6 次。值得关注的是，美国在 2023—2025 年间曾针对 AI 模型权重、云计算训练集群等新兴物项单独发布专项管制规则（如针对“高级计算芯片及生成式 AI 模型”的临时最终规则），但随后因产业反馈与国际协调压力出现部分条款废止或暂缓执行的政策波动，反映出其管制路径仍处于试错与调整期；加拿大则保持相对稳定的修订节奏，主要聚焦于对 CCL 等盟友清单的对标更新，未出现专项规则反复废止的情形。
- **美国管控工具维度更丰富，形成限制输出与定向开放并行双路径。**除常规的 CCL 物项管制、实体清单 (Entity List) 最终用户限制、外国直接产品规则 (FDPR) 及“芯片出口许可证推定拒绝”审查机制外，美国于 2025 年正式启动《美国人工智能出口计划》(U.S. AI Export

Initiative)，通过“可信买方认证”“预授权批量许可”和“技术安全评估框架”等制度安排，向符合安全互认条件的盟友及战略伙伴定向推广全栈 AI 技术（包括训练框架、优化工具链及云推理服务），旨在构建以美国为中心的“可信 AI 技术圈”。这一输出扶持机制与限制性管控形成结构性互补，既封锁对战略竞争对手的高端 AI 能力供给，又扩大对友好市场的技术渗透。反观加拿大，其管控工具仍集中于清单修订、敏感技术目录动态更新及最终用户最终用途审查，虽设有出口许可证个案审批制度，但缺乏专项技术输出扶持或标准化推广路径，整体策略偏向被动防御型风险识别，而非主动塑造全球 AI 技术流向。

- **美加管制判定均以技术参数、物项类别为核心依据，不针对 AI 概念全域禁限。**两国均摒弃对“人工智能”概念的一刀切式禁限，而是以精确的技术参数阈值和物项功能描述作为判定基线。例如，美国 CCL 将高性能 AI 芯片（如特定峰值算力超过 4800 TOPS、双向传输带宽超过 600 GB/s 的 GPU/TPU）、具备大规模并行计算能力的训练集群、以及经训练的神经网络模型权重纳入管制范畴。该机制明确排除对通用 AI 框架（如 PyTorch、TensorFlow）、开源数据集及基础算法论文的普适性限制，体现了“精准定点施压、非全局封锁”的监管理性，也为跨国企业在北美内部合规差距分析提供了可操作的技术参照基准。

表 2.17: 北美 AI 智能体领域出口管制政策汇总

国家	主管部门	政策法规/管制工具	发布/生效日期	核心内容
美国	工业和安全局 (BIS)	2025 先进 AI 技术全域扩散管制最终规则 [476]	2025.01.15 生效 (2025.05.13 被废除) [477]	• 建立面向先进 AI 芯片和模型权重的全球许可框架； • 通过国家分组、受信终端用户和许可例外/授权机制区分盟友、受信主体和受限目的地； • 降低先进计算芯片和部分闭源模型权重被转移、规避管制或用于危害美国国家安全与外交政策利益用途的风险。
		2026 对华先进芯片审查修订规则 [478]	2026.01.15 生效	• 对华出口 NVIDIA H200、AMD MI325X 等同级芯片，需符合安全条件并逐案审批； • 申请者应证明出口不会削减美方现有全球芯片供应产能； • 中方采购方需建立合规与客户筛查机制，产品需在美国完成第三方性能安全检测。
		实体清单/UVL (AI 专项增补) [479]	2024-2026 动态扩容	• 实体清单对上榜主体增设许可要求与审查规则； • 未经验证清单标注 BIS 无法核实终端用途、用户的交易方，强化出口商尽职调查义务； • AI 半导体、模型及相关技术限制，需依据 EAR 条款、实体清单、终端用途规则逐项判定。
		《美国人工智能出口计划》配套规则 [480]	2026.03 落地	• 面向海外推广由 AI 优化计算硬件、数据中心存储、模型、网络安全措施和行业应用组成的全栈 AI 技术包； • 设置预设联合体和按需联合体两种模式，分别服务持续性全球部署和具体项目机会； • 由商务部长会同国务院及相关部门遴选项目，获批的全栈 AI 技术包向可信外国买方提供。

续下页

表 2.17 -续上页

国家	主管部门	政策法规/管制工具	发布/生效日期	核心内容
加拿大	全球事务部 (GAC)	《进出口许可法》 EIPA+《出口管制清单》ECL (第 5506 项两用战略技术) [481]	EIPA 长期生效; ECL 持续年度修订	• EIPA 授权加拿大对特定货物、技术和目的地实施出口/进口许可管理; • ECL 列明受控货物与技术类别, 出口商需按清单、目的地、最终用户和最终用途判断许可义务; • AI 相关软硬件只有在落入清单条目或其他制裁/最终用途规则时, 才构成受控出口。
		2025 战略技术单边管制修正案 DORS/2025-89 [482]	2025.04.25 生效	• 对 Export Control List 进行修订, 新增或调整特定战略货物、软件和技术控制; • 出口许可义务取决于清单条目、技术参数、目的地和最终用途, 而不是“AI 数据集/框架”的泛化名称; • 企业应进行物项分类、最终用户尽调和转出口风险审查。
		2025 新版《出口管制清单操作指南》 [483]	2025.07.01 生效	• 指导出口商理解 Export Control List 的分类结构、条目说明和技术参数; • 许可判断应基于物项分类、目的地、最终用户、最终用途和适用豁免; • 对 AI 或云访问的限制应另查具体清单条目、制裁措施或许可政策, 不能由指南本身推导。
		《敏感技术研究领域清单》——人工智能与大数据技术 [484]	2024-2026 持续扩容更新	• 将人工智能与大数据技术列为加拿大十一类敏感技术领域之一, 视为支撑多领域发展的跨领域基础技术; • AI 敏感技术覆盖数据科学、数字孪生、生成式 AI、大语言模型、全谱系机器学习技术; • 清单用于外资审查、出口管制、科研安全风险识别, 最终风险判定需结合技术转移场景综合研判。

2.6.2 欧洲 AI 智能体安全政策与法规

欧洲是全球首个建立统一 AI 法律体系的区域, 依托《人工智能法案》(AI-ACT) 为核心底座, 叠加 GDPR 数据合规规则、各国专项操作守则, 构建了层级清晰、风险导向、执法刚性最强的 AI 智能体治理架构 [80]。本小节梳理欧洲主要国家在智能体人工监督、数据跨境、漏洞治理、主权管控等维度的差异化规则, 主要发现如下 (详见表 2.18) :

- **欧盟以 AI ACT 为核心实现全成员国统一强制监管。**依据 Reg.2024/1689 法案, 欧盟对高风险智能体划定统一合规底线, 硬性规定产品上线前开展标准化红队安全测试、运行期间全链路操作审计和全程人工监督, 并且法案具备域外管辖权, 违规企业最高可处以全球年度营收 7% 的巨额罚款, 依靠严苛惩罚倒逼企业落实安全责任 [80]。
- **欧洲形成 AI 安全与数据合规深度绑定的治理逻辑。**EDPB 出台 AI 场景配套 GDPR 实施细则, 将数据最小化原则落实到智能体工具调用、知识库检索、联网搜索环节, 用户可以随时撤销授权; 同时确立 72 小时数据泄露强制上报制度, 智能体所有访问行为留存完整审计日志, 把隐私合规作为智能体准入的前置条件 [485]。

- **非欧盟欧洲国家侧重主权安全与场景管控。**俄罗斯联邦 AI 法案明确关键基础设施仅允许本土智能体运行，对政务、能源领域的智能体设置互联网访问白名单，防范域外模型带来安全隐患 [486]；瑞士修订 FADP 法案，要求商用智能体的数据必须在境内存储，高 - 风险场景优先采用 TEE 硬件隔离方案，借助硬件层面筑牢隐私安全屏障，形成对欧盟法规的补充性区域治理规则。

表 2.18: 欧洲 AI 智能体安全政策和法规汇总

国家	主管/执行机构	政策法规	发布日期	核心内容
欧盟	• 欧委会（牵头） • 欧洲议会	AI ACT (Reg.2024/1689) [80]	2024.03 通过，2026.08 生效	• 按风险分级管控高风险智能体，强制全程人工监督机制； • 大模型智能体上线前必须完成标准化红队测试、全链路操作审计； • 具备域外管辖权，违规企业最高处以全球年度营收 7% 罚款。
	欧洲数据保护委员会 (EDBP)	GDPR (AI 专项指引) [485]	2018 正式生效，2025 增补 AI 配套细则	• 智能体严格遵循数据最小化，禁止自主无差别抓取用户敏感信息； • 用户可随时撤回联网检索、第三方插件调用、知识库访问授权； • 发生数据泄露需 72 小时内强制上报监管机构，完整留存操作存证。
英国	科学、创新和技术部 (DSIT)	《AI 网络安全操作守则》 [487]	2025.01.31（行业自愿落地标准）	• 制定智能体专属安全防护基线，抵御提示注入、供应链投毒漏洞； • 高自主智能体必须配置分级人工复核与审批流程； • 搭建行业统一智能体漏洞情报共享、攻击溯源协同机制。
	信息专员办公室 (ICO)	智能体数据合规指引	2026.03 正式发布	• 企业对旗下智能体全部操作行为承担完整法律责任； • 严格限制营销类 Agent 批量用户触达、无授权深度伪造内容生成； • 金融、医疗等高风险场景智能体强制部署权限隔离安全沙箱。
俄罗斯	• 数字发展部（牵头） • 联邦安全局（深度参与）	联邦 AI 法（草案） [486]	2026.03 对外公示，2027.09 拟生效	• 关键基础设施仅允许本土主权智能体部署运行； • 政务、能源类智能体执行互联网外联白名单严格管控； • AI 产品必须添加可识别透明标识，违规企业限制境内市场准入。

欧洲 AI 领域出口管制体系： 欧盟、英国、荷兰构成欧洲 AI 两用技术出口管制核心主体，区域内形成欧盟统一两用物项框架、英国独立管制立法、荷兰半导体专项限制三层并行管控体系。本节通过结构化台账归集欧盟、荷兰、英国的主管机构、核心法规、生效时间与管控边界，客观呈现欧洲 AI 出口管制的立法渊源、许可模式与差异化产业管控规则，为跨境 AI 智能体技术流转合规判定提供欧洲区域政策依据，主要发现如下（详见表 2.19）：

- **欧盟形成统一基础管制框架，AI 监管与出口管制双向联动。**以 Reg.(EU) 2021/821 两用物 60 项条例作为全域统一管制底座，同步配套 AI Act 分级监管指引，高风险 AI 系统、通用大

模型合规要求同步纳入出口授权审查范畴。

- **欧洲各国依托本土优势产业增设专项管制条款。**荷兰依托光刻机产业垄断优势，针对 ASML 先进光刻设备及其配套配套 AI 校准、智能控制算法技术设立独立审查机制，实施严格的逐案许可与跨境审批制度；英国脱离欧盟体系后完成独立立法升级，明确将大模型训练权重、智能体核心源代码、高性能 AI 加速芯片与算力设备直接纳入受控技术与物项清单，实现关键 AI 底层技术的限制性出口管控。
- **欧系许可与制裁体系具备明确国别差异化约束。**欧盟统一授权体系设置多层次通用许可，适配不同风险等级的跨境技术交易。英国 OGEL 通用许可体系仅向五眼联盟等可信盟友开放宽松准入，对非合作国家、高风险地区实施严苛审查与交易限制。双方依托动态更新的制裁清单，针对交易主体、技术流向、合作场景开展精准准入管控与风险拦截，构建圈层化、差异化技术壁垒 [488]。

表 2.19: 欧洲 AI 智能体领域出口管制政策汇总

国家	主管部门	政策法规	发布/生效日期	核心内容
欧盟	• 欧盟委员会 (牵头) • 欧洲议会 (深度参与) • 欧洲理事会 (深度参与)	两用物项条例 Reg.(EU) 2021/821	2021.09, 持续增补 AI 管制条目, 2025.11.15 发布最新整理版本	• 建立欧盟对两用物项出口、过境、经纪活动和技术援助的统一管制制度； • 设置单项、全球和欧盟通用出口授权等许可形式，并结合物项、目的地、最终用户和最终用途实施审查。
	• 欧盟委员会 (牵头)	AI Act 配套出口管制指引 [80]	2024.08.01 生效, 2026.08 落地覆盖, 部分独立高风险系统推迟	• AI Act 按风险等级对 AI 系统实施分级监管，并禁止不可接受风险的 AI 用途； • 高风险 AI 系统须满足风险管理、技术文档、记录保存、透明度、人类监督、准确性和网络安全等要求； • 通用人工智能模型承担透明度义务，具有系统性风险的模型还需开展模型评估和严重事件报告。
荷兰	• 经济事务与气候部	ASML 设备配套 AI 管制新规 [489]	2023–2026 动态迭代更新	• 对特定先进半导体制造设备及相关技术实施国家出口许可要求； • 2025 年进一步扩大受控设备与技术范围，包括特定测量和检测设备，具体范围以相关部门令为准； • 荷兰政府认为相关技术可能用于生产先进半导体，并在先进军事应用中发挥关键作用，因此实行逐案许可审查。
英国	• 英国外交、联邦和发展办公室 (FCDO) (牵头) • OFSI (深度参与)	英国制裁名单 (The UK Sanctions List) [490]	常年动态更新调整	• 英国制裁名单统一列明受英国各项制裁制度约束的个人、实体和船舶；涉及 AI 企业、研究机构、技术供应商或相关人员时，只有其被正式指定，才可据名单确认其制裁身份； • 开展 AI 芯片、模型、软件、算力、技术服务或研发合作交易时，应核查交易对手是否列入名单，并进一步识别其是否由受制裁主体直接或间接拥有或控制。

2.6.3 我国 AI 智能体安全政策与法规

我国 AI 智能体安全治理采用**多部门协同、合规与发展并重**的顶层架构，由网信办、发改委、工信部等部委依据各自职能分领域牵头，形成横向联动、纵向贯通的综合治理格局。在政策体系层面，已逐步构建起以实施意见、治理框架、伦理办法、国家标准为支柱的四层政策谱系 [491], [492]，覆盖从宏观战略指引到微观技术落地的完整治理链条。相较于海外主要聚焦于数据隐私或算法透明等局部议题的区域治理模式，我国政策更加重视智能体从研发、训练、部署、运行直至退役的全流程风险管控，强调在产业培育初期即同步嵌入安全基因；同时统筹推进行业规模化落地应用和安全风险闭环治理，力求在激发创新活力的前提下，通过制度设计将潜在危害控制在可接受范围内，平衡产业创新发展与安全约束的关系 [493], [494]。本节系统梳理我国国家级智能体专项政策、AI 融合发展文件、安全治理框架、伦理规则与互联国家标准，客观呈现我国 AI 智能体安全治理的政策与法规全貌，主要发现如下（详见表 2.20）：

- **构建四层递进式治理体系。**以《智能体规范应用与创新发展实施意见》划定监管红线，明确智能体在身份认证、权限边界、数据使用等方面的底线要求；《“人工智能 +”行动实施意见》夯实产业发展根基，从算力、数据、应用场景等维度提供政策供给；《人工智能安全治理框架 2.0》提供风险识别理论依据，系统化指导安全评估与应急响应；《人工智能 - 智能体互联》国家标准落地技术约束，为具体工程实现提供可操作的规范指引。四层文件分别落实监管约束、产业赋能、风险识别、技术合规四大治理目标，形成自上而下、环环相扣的完备治理链条 [491], [492], [493]。
- **治理重心聚焦 AI 智能体运行层专属风险。**依托《人工智能安全治理框架 2.0》和专项实施意见，我国政策明确区别于通用大模型内容安全管控的侧重方向，重点针对身份伪造、权限越权、知识库污染、多智能体链式协同失控等智能体特有的安全隐患，强调从“内容合规”向“行为合规”的治理重心延伸；同时，强制落实工具调用审计、全周期日志留存、风险动态监测、事后应急处置等机制，确保每一轮交互行为均可追溯、可审计、可干预，从而补齐智能体运行阶段的监管短板，避免因运行态失控引发系统性安全事件 [491], [492]。
- **制定智能体互联专属国家标准。**由我国电子技术标准化研究院牵头制定智能体互联系列国标，统一身份编码、MCP- 类交互协议、接口规范、权限管控体系，从底层技术层面约束跨智能体未授权访问与数据泄露问题，确保不同厂商、不同场景下的智能体能够安全互操作。同时，将技术标准与行政监管配套结合，通过标准符合性测试、认证评估等手段推动落地执行，打造区别于欧美依靠商业厂商自定义协议的模式，形成我国在多智能体可信协同领域的差异化治理优势，为全球智能体安全治理贡献中国方案 [495]。

表 2.20: 我国 AI 智能体安全政策和法规汇总

主管/执行机构	政策法规	发布日期	核心内容
• 网信办（牵头） • 发改委（深度参与） • 工信部（深度参与）	《智能体规范应用与创新发展实施意见》 [491]	2026.05.08 发布	• 规范智能体应用创新，推动在重点行业和公共服务场景合规、安全、有序落地。 • 强化智能体身份、权限、工具调用、插件接入和数据使用等关键环节安全管理。 • 建立日志留存、风险监测、事件处置和责任闭环机制，提升可追溯、可监管能力。

续下页

表 2.20 -续上页

主管/执行机构	政策法规	发布日期	核心内容
国家发改委（牵头）	《“人工智能 +”行动实施意见》 [493]	2025.08.21 发布	- 推动人工智能与科技、产业、消费、民生、治理等领域深度融合，形成重点应用场景； - 完善算力、数据、模型、开源生态、标准和产业协同等基础支撑； - 强化安全治理、标准规范、风险防控和可信应用，促进 AI 规模化、规范化发展。
- 国家互联网应急中心（牵头） - 全国网安标委（深度参与）	《人工智能安全治理框架 2.0》 [492]	2025.09.01 发布	- 从模型、数据、系统、应用和使用等维度识别 AI 安全风险，覆盖滥用、失控、隐私、内容和网络安全等问题； - 提出 AI 全生命周期治理思路，包括风险评估、测试验证、监测预警、应急处置和责任管理； - 可作为智能体提示注入、工具调用越权、知识库污染、多智能体协同等风险治理的参考框架。
- 工信部（牵头） - 发改委（深度参与）等 10 个部门	《人工智能科技伦理审查与服务办法（试行）》 [494]	2026.04 发 布	- 对人工智能科技活动建立伦理审查、复核、备案和服务管理机制； - 对可能带来较高伦理风险的研究、开发和应用活动，要求开展伦理风险评估和审查； - 重大调整或风险变化时应进行持续跟踪、复核和合规管理，确保科技活动符合伦理规范。
中国电子技术标准化研究院（牵头）	《人工智能智能体互联》系列国家标准 [495]	2026.06.26 发布	- 构建智能体互联互通标准体系，统一身份识别、交互协议、接口和互操作要求； - 规范智能体间协作、工具调用、权限管理和可信连接，降低未授权访问和滥用风险； - 系列标准覆盖总体架构、身份码、身份管理、智能体描述、智能体发现、智能体交互和工具调用，为智能体互联互通提供统一技术依据。

我国 AI 领域出口管制体系： 依托《出口管制法》搭建顶层法律框架，我国已逐步形成以《两用物项出口管制条例》和《禁止出口限制出口技术目录》为核心支撑的 AI 相关技术跨境管控体系。该体系以算力硬件（如高性能芯片、服务器）、AI 软件（如深度学习框架、开源模型分发）、算法技术（如神经网络架构、强化学习训练方法）为分层对象，分别设定差异化的管制尺度与合规门槛，既防止关键底层技术外流，又为一般性商业合作留出制度空间。从法规位阶看，《出口管制法》作为基础性法律，确立了管制原则、管辖范围、处罚权限等根本性规则；其下，《两用物项出口管制条例》细化了物项识别、许可程序、监督执行等操作层规范；而《禁止出口限制出口技术目录》则以技术条目形式，明确列举了涉及人工智能算法、数据处理、人机交互等领域的受限技术特征，三者共同构成从原则到规则的完整制度链条。区别于欧美以单边限制性措施为主导的管控逻辑，我国管制体系以清单制为核心判定标准，即原则上仅对列入法定清单的物项和技术施出口管制，既不无限扩大管制范围，也不对未列明技术设置额外前置障碍。

通过上述梳理，可客观呈现我国 AI 两用物项出口管制的制度框架与实操边界，其核心特征可概括为“清单限定、动态调整、协同执行、平衡开放”。本节内容亦将为全球主要经济体 AI 出口管制体系的完整对照提供中国维度的详实素材，具体信息详见表 2.21。在此基础上，我

国管制的三项制度性要点进一步凝练如下：

- **双层法规构成完整管制底座，多部门协同分工实施监管。**以《出口管制法》为上位法，确立基本原则与授权框架；配套《两用物项出口管制条例》细化解剖管制的实体程序、企业合规指引和违法责任追究，二者共同形成“法律—行政法规”双层支撑。在实施层面，商务部牵头统筹许可审批与清单维护，海关总署负责出境环节的实物核查与风险拦截，科技部主导技术目录的专业评审与动态更新，三部门依托联合工作机制实现信息互通、执法联动，形成覆盖“事前许可—事中查验—事后追溯”的跨部门闭环监管格局。
- **采用清单驱动判定模式，仅目录列明技术触发许可约束。**AI 相关软硬件、模型参数、算法实现不实行全域一刀切管制，企业无需对所有 AI 产品出口均申请许可，唯有当出口标的明确列入现行《禁止出口限制出口技术目录》或两用物项出口管制清单，且达到条目所载技术指标或适用场景时，才需要履行出口许可申报、最终用户承诺、许可文件获取等法定流程。此模式既降低企业合规成本，也避免过度管制抑制创新活力，同时为监管部门集中资源盯防高风险物项提供制度便利。
- **管制体系具备动态调整能力，适配 AI 技术迭代节奏。**限制出口技术目录分别于 2023 年、2025 年完成系统性修订调整，每次修订均面向 AI 领域最新突破方向（如大语言模型训练优化、多模态融合、自主决策系统等）增补或细化相应条目，并同步废止已过时或已普及的技术管控。这一机制确保管制范围不会因技术快速演进而滞后或失准，同时也可根据国际安全态势、产业发展阶段及技术外溢风险评估，灵活增减受控条目，且调整操作与《两用物项出口管制条例》中关于军民两用技术统一管理的原则相互衔接，避免了多套规则并行导致的执行冲突或监管盲区。

表 2.21: 我国 AI 智能体领域出口管制政策汇总

主管部门	政策法规	发布/生效日期	核心内容
• 商务部（牵头） • 海关总署（深度参与）	《出口管制法》《两用物项出口管制条例》 [496], [497]	2020 年 12 月 1 日起施行；2024 年 12 月 1 日起施行	• 建立管制清单、临时管制、许可审批、最终用户和最终用途管理等出口管制基本制度； • 两用物项出口需按清单、技术参数、目的地、最终用户、最终用途和转出口风险判断许可义务； • AI 相关硬件、软件、技术或模型只有在落入清单、临时管制或相关最终用途规则时，才纳入出口管制。
• 商务部（牵头） • 科技部（深度参与）	《中国禁止出口限制出口技术目录》 [498]	2023.12 发布，2025.07 调整	• 将人工智能交互界面、语音合成、个性化信息推送等信息处理技术纳入限制出口技术范围； • 属于限制出口目录的技术，应当依照技术出口许可程序办理相关手续； • 目录所列技术同时属于军民两用技术的，纳入两用物项出口管制体系管理。

2.7 全球 AI 智能体产业共性安全瓶颈

本小节从算力供应链、模型内生风险、存量系统对接、商业化治理、人才数据基础等维度归纳产业共性安全短板，系统梳理各类风险形成机理与现实约束，如图 2.8 所示（具体信息详见表 2.22）：

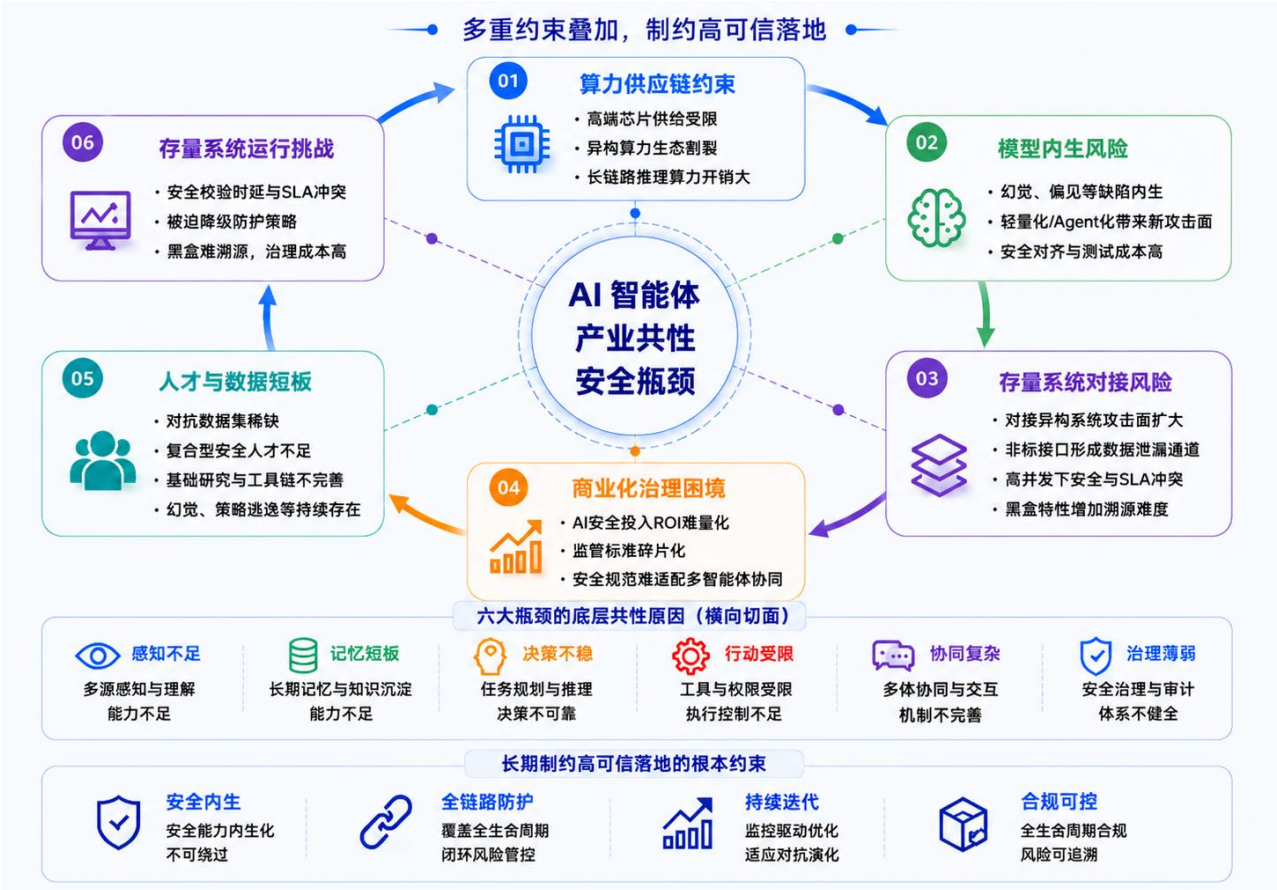


图 2.8: 全球 AI 智能体产业共性安全瓶颈

- **算力供应链约束叠加模型固有风险抬高安全落地门槛。**智能体长链路推理与实时安全校验带来巨大算力开销，全球异构算力生态割裂、高端硬件供给紧张；同时缩放定律边际收益递减，参数扩张同步累积各类模型安全隐患，轻量化架构衍生全新攻击面，安全对齐与攻防测试成本居高不下 [499], [500]；
- **政企存量系统集成催生规模化安全风险壁垒。**智能体对接 CRM、ERP 等异构业务系统显著扩大攻击面，非标接口形成无审计隐性数据泄露通道；高并发场景下安全校验时延与业务 SLA 存在冲突，企业被迫降级防护策略，智能体黑盒特性进一步加大安全事件溯源治理难度 [501]；
- **商业投入失衡、监管碎片化、基础资源短板形成多重治理困境。**AI 安全投入 ROI 难以量化，企业安全预算普遍受限；全球智能体监管标准不统一，现有安全规范难以适配多智能体协同场景；同时对抗数据集稀缺、复合型安全人才缺口显著，叠加幻觉、策略逃逸等内生缺陷，持续限制智能体高可信部署 [502], [503], [504]。

表 2.22: 全球 AI 智能体产业共性安全瓶颈

核心瓶颈	核心表现
算力成本与算力供应链安全割裂 [499]	• 超大基座模型、多智能体并发推演训练能耗高昂，部署实时安全校验进一步加剧算力负担； • 全球算力分化为英伟达 CUDA、昇腾信创两套生态，跨平台安全监控体系互不兼容； • 高端 AI 芯片与 HBM 供给受限，企业难以同时承载高性能模型与完整常态化安全检测机制。
模型规模增长边际收益递减，安全投入性价比持续走低 [500]	• 参数扩张带来的能力提升逐步放缓，但后门、对抗样本、数据投毒等安全风险持续累积； • MoE、模型蒸馏等轻量化优化方案在提升推理效率的同时引入全新攻击面； • 大规模安全对齐、红蓝对抗测试成本高昂，形成显著技术门槛，中小企业难以负担。
政企存量系统集成带来智能体规模化安全壁垒（核心风险场景） [501]	• 智能体对接 CRM、ERP 等存量业务系统串联多类资产，攻击面显著扩张，形成链式渗透路径； • 存量系统非标接口催生未纳入审计的隐性数据通道，引发无日志记录的数据泄露风险； • 高并发场景下安全校验增加推理时延，企业为保障业务 SLA 被迫下调防护等级。
AI 智能体商业化落地与安全投入 ROI 失衡 [502]	• McKinsey 2026 调研显示仅 39%AI 试点实现正向收益，企业普遍优先保障业务功能、压缩安全预算； • 企业客户仅采购基础对话功能，付费部署智能体沙箱、动态权限管控等安全组件意愿较低； • 安全风险属于低频高损事件，安全防护收益难以量化，安全建设长期滞后于业务迭代速度。
全球 AI 监管体系碎片化，智能体合规安全治理难度加大 [503]	• 欧盟 AI 法案、各国数据法规对自主智能体管控标准不统一，跨境部署合规成本大幅上升； • 现有网络安全、等级保护规范缺少针对长周期自主智能体、多智能体协同场景的适配条款； • 具备工具调用能力的智能体越权访问、数据跨境等新型风险缺少清晰责任界定规则。
高质量安全数据集稀缺，AI 安全人才全球供给不足 [505]	• 面向提示注入、工具劫持、多步诱导逃逸的智能体对抗数据集稀缺，且受隐私与版权约束； • 兼具大模型、分布式算力、传统网络安全知识的复合型 AI 安全人才缺口持续扩大； • 常态化红队攻防测试人力成本高，中小机构无法搭建持续的智能体安全评估团队。
大模型与智能体内生安全缺陷难以彻底根除 [504]	• 模型幻觉、目标漂移持续存在，易造成智能体主动发起违规接口调用； • 各类逃逸攻击能够突破静态安全护栏，长链路自主任务中对齐约束极易失效； • 多智能体之间存在隐蔽通信通道，能够绕过外部安全检测实现隐私数据交互。

第 3 章 AI 智能体全生命周期安全问题与挑战分析

本章以 AI 智能体完整生命周期演化链路为主线，围绕感知、记忆、决策、行动、交互、治理六大核心安全维度，系统性拆解生命周期各阶段内生安全风险与产业落地、学术研究层面面临的关键挑战（如图 3.1 所示）。AI 智能体安全风险具备典型链式传导、多维交织演化特征：需求规划阶段形成源头性原生设计缺陷，传递至架构设计环节固化为结构性安全短板；编码开发阶段持续引入程序层安全漏洞；受制于安全测试手段局限，大量风险留存于验证盲区难以被有效识别；进入部署交付阶段后进一步转化为规模化配置与供应链风险；在持续运行迭代过程中不断动态扩散、风险态势持续恶化；直至退役处置阶段仍存在残余隐私隐患长期留存的问题，风险逐级叠加、循环传导，最终演化形成贯穿全生命周期的闭环安全威胁。本章系统梳理智能体安全风险生成机理、动态演化特征与跨阶段传播路径，归纳当前学术界研究瓶颈与产业工程落地痛点，为后续内生安全防护体系的框架设计与机制研究奠定理论基础、提供现实问题支撑。



图 3.1: AI 智能体全生命周期安全问题与挑战分析

3.1 需求规划阶段（安全产生源头）

需求规划阶段是智能体全生命周期安全管控的核心源头，直接确立智能体感知、记忆、决策、交互、行动及治理全链路的安全基线与设计准则，其需求定义的完备性、规范性与前瞻性，从根本上决定了智能体体系的原生安全水平。需求阶段的源头安全风险一旦固化并流入研发、部署、运行全生命周期，将形成链式传导、逐级放大的风险效应，持续提升智能体全流程安全治理难度与管控成本，成为制约可信智能体规模化、产业化落地的核心瓶颈。结合当前学术界研究现状与产业落地实践，需求规划阶段存在的核心安全问题，可归纳如下（详见表 3.1）：

- **核心功能模块前置安全约束缺失，原生源头性安全风险凸显。**现有智能体六大功能模块的需求设计普遍聚焦功能实现效率与交互体验，未在需求规划阶段嵌入刚性安全约束，各层级均存在先天性安全漏洞与风险隐患。感知层需求定义未明确动态输入数据的安全边界管控规则，缺乏针对隐性对抗样本、恶意扰动数据的前置风险识别需求，同时用户隐私数据采集无分级分类、最小权限、场景适配的规范化需求约束，整体安全管控高度依赖事后溯源检测与风险复盘，前置主动防御能力严重不足 [506], [507], [508]。记忆层需求设计普遍侧重数据存储容量、检索效率与长效记忆能力，尚未形成覆盖数据录入、存储、更新、销毁全生命周期的标准化安全需求，细粒度访问权限管控、数据隔离校验等核心安全需求缺失，导致普遍存在隐私数据明文驻留、跨场景数据串访、记忆投毒溯源困难等原生问题，轻量化安全验证、动态数据隔离等基础安全能力未纳入核心需求体系 [509], [510]。决策与行动层需求过度关注决策精准度、响应效率与任务执行能力，权限划分标准模糊、高危操作识别与前置拦截需求缺失，无法约束智能体动态自主决策行为，易引发决策逻辑漂移、权限溢出越界等风险，难以适配复杂动态的对抗性运行场景 [511], [512], [513]。交互与治理层需求聚焦人机、多机协同交互效率，多主体信任边界、会话安全管控、全流程合规审计等安全需求缺失，使得人机交互载荷校验、多主体协同访问管控、运行行为溯源审计等能力缺位，极易引发隐性恶意载荷植入、跨域攻击扩散、供应链安全污染等系列风险 [514], [515], [516]。
- **安全需求设计碎片化严重，缺乏统一标准化体系，工程适配性不足。**当前学术界针对智能体单模块安全风险的研究较为零散，尚未形成覆盖全功能模块、全业务场景的分层梯度安全需求框架，产业界更是普遍采用碎片化、补丁式的安全需求增补模式，未将安全设计深度融入需求规划核心环节 [7]。各功能模块安全需求边界界定模糊、安全管控权重分配失衡，存在部分领域安全需求冗余、核心薄弱环节需求缺失的问题。同时，行业层面尚未建立统一的智能体动态安全量化基准，缺失需求设计与实际运行场景的一致性校验标准，无论是开源智能体框架还是商用智能体产品，其安全能力设计均存在单一化、表面化问题，系统化需求落地程度不足 [517]。
- **前置安全治理范式缺位，后置防护模式存在固有结构性缺陷。**当前智能体研发的学术研究范式与产业工程体系，普遍存在“重后期运维防护、轻源头需求设计”的认知偏差，尚未建立需求阶段前置化、体系化的安全治理范式 [518]。安全约束、风险管控、合规要求等核心安全要素未前置嵌入需求规划、方案设计的初始环节，导致各类原生安全缺陷与技术债务持续累积，形成先天性安全短板。传统软件被动补丁修复、外挂式安全防护、事后风险整改的治理模式，仅能实现表层风险管控，无法根除需求源头滋生的根本性安全隐患，同时存在整改成本高、防护范围有限、无法适配动态迭代场景等固有缺陷 [519], [520]。此外，传统软件的合规规范、权限管控框架难以适配智能体自主决策、动态演化、长效交互的核心特性，适配智能体的前置安全治理理论、量化校验标准、轻量化核验工具均处于研究空白或初步探索阶段。

表 3.1: AI 智能体需求规划阶段安全问题与研究挑战

模块	安全问题与研究挑战
感知 (输入层)	• 输入接入无边界管控，开放不可信数据摄入通道：Yang 等人 [506] 实证良性伪装内容可劫持任务；Alamsabi 等人 [507] 验证隐写载荷绕过指令校验；AgentSentry [521] 仅支持事后溯源。微软安全团队于 2026 年披露 AutoJack 攻击链：开发阶段的 AutoGen Studio 浏览智能体加载攻击者控制的网页后，网页可连接本机未充分鉴权的 MCP WebSocket 并执行攻击者指定的系统命令 [522]。存在的主要问题包括：缺少动态输入边界量化理论，防御研究偏向事后检测，前置边界约束范式缺失；开源校验工具无多模态隐写识别算子，产业原型默认全开放输入，源授权隔离框架仅仿真未落地；研究挑战包括跨源动态输入泛化检测、长效隐性后门无源识别、多场景感知边界统一建模。不可信输入一旦穿透感知层防护，将沿着生命周期链路持续向下传导，诱发后续决策层一系列连锁安全异常。 • 敏感信息采集缺少约束规范，隐私泄露隐患突出：Madkour 和 Raman [523] 指出全量日志易逆向用户身份；Yang 等人 [506] 构建提示注入-批量外泄攻击链。Google Cloud 在 2026 年的数据安全实践中指出，智能体使用的数据可能包含非预期采集的敏感信息 [524]。存在的主要问题包括：流式多模态差分隐私适配理论不完善，实时动态脱敏数学模型稀缺；开源采集组件无分级过滤，商用产品无强制采集管控，现有脱敏方案算力过高无法在线部署；研究挑战包括上下文关联隐私可证明安全、低开销实时多模态脱敏、采集行为合规动态校验。持续、无约束的信息采集还会不断扩充智能体记忆池，进一步放大记忆投毒与信息窃取攻击面。 • 对抗输入前置拦截空白，多模态防御缺陷显著：Jain 等人 [508] 归纳跨模态脆弱性；Lu 等人 [525] 证实视听对抗绕开对齐；Tan 等人 [526] 提出 ClawTrojan 持久木马。此外，NIST 在 2025 年更新的对抗性机器学习分类体系中首次将生成式 AI 智能体纳入统一威胁分类框架，明确指出间接提示注入、智能体记忆投毒与工具供应链攻击是当前对抗防御体系的主要理论空白 [527]。存在的主要问题包括：现有对抗防御多局限单模态，跨模态统一表征学习理论空白；开源对抗检测与智能体链路兼容性差，产业无前置拦截工程方案，大量防御理论仅实验室验证；研究挑战包括多模态隐写对抗统一表征、隐蔽长效指令溯源、流式输入轻量化对抗检测。
记忆 (存储层)	• 顶层安全规约缺失，长效数据驻留原生风险：Sidik&Rokach [509] 发现长时智能体无分级存储规范；Roy 等人 [517] 指出明文长期驻留架构短板。OpenAI 官方说明显示，ChatGPT 保存的记忆与聊天记录分别存储，删除聊天并不会自动删除由该聊天形成的记忆，关闭记忆功能也不会清除已经保存的内容；用户删除记忆后，相关删除日志还可能因安全和调试需要保留最多 30 天 [528]。存在的主要问题包括：无标准化记忆生命周期安全规约，涉密记忆可验证销毁形式化证明体系不完善；开源记忆框架无自动清零隔离引擎，MemTier 分级方案仅仿真，商用统一全局存储无细粒度管控；研究挑战包括动态任务记忆留存自适应建模、轻量化存储安全形式化推理、存储与运行语义一致性校验。 • 访问权限基线模糊，跨域串访复合型泄露：Chin 等人 [510] 证明无隔离记忆通道为越权突破口；Madkour 等人 [523] 叠加环境不确定性放大投毒、跨域泄露风险。微软在 2026 年 Microsoft 365 智能体记忆安全研究中指出，仅依赖模型提示无法构成可靠的记忆访问边界，若缺少模型外部的确定性隔离机制，敏感记忆可能在不同用户、智能体或租户之间泄露 [529]。存在的主要问题包括：传统访问控制无法适配自主检索行为，记忆投毒溯源理论体系残缺；开源权限中间件无记忆域隔离，商用无动态访问基线，隔离原型仅适配单智能体；研究挑战包括自主检索驱动动态权限隔离、跨知识库投毒溯源阻断算法。 • 安全治理缺少可验证量化规约：Louck [530] 形式化记忆“写入—检索—行动”流水线的可锻性，给出机器可检验的分离定理：基于内容或基于谱系的授权判定在洗白攻击下均不健全，写入时来源绑定是必要条件，跨八个前沿模型的评测显示现有防御的洗白攻击成功率最高达 68%；Ouyang 等人 [531] 提出的密码学溯源与派生谱系方案恰落在该定理的否定域内，反映存储层对“记忆可信”尚无共识定义；Lin 等人 [532] 沿写入、存储、检索、执行、共享传播、遗忘回滚六阶段梳理攻击与防御，指出系统层形式化保证缺位，并提出可验证记忆治理的五项架构原语。AWS 在 2026 年的 Amazon Bedrock AgentCore Memory 文档中说明，记忆投毒指虚假信息被写入记忆并在后续会话中被沿用，按责任共担模型该风险归属客户，官方建议的缓解手段为以护栏检查进出记忆的提示并开展对抗性测试 [533]。存在的主要问题包括：各方案对记忆条目授权资格的判定依据互不兼容，缺少需求层安全目标至运行层判定谓词的规约映射方法；开源验证工作以模型检验为主，规约与实际记忆后端解耦，尚无可嵌入检索路径的运行时校验组件。研究挑战包括跨方案统一的记忆授权语义、面向检索路径的低开销规约执行、部署环境下的量化安全度量。

续下页

表 3.1 – 续上页

模块	安全问题与研究挑战
决策 (推理层)	• 自主权限边界模糊，过度自治引发失控：Pan 和 Hou [511] 提出分级约束，证明单一权限无法抵御对抗策略操纵，高危任务需强制人工干预。微软于 2026 年披露 Semantic Kernel 的 CVE-2026-25592：文件下载工具的目标路径可被模型控制，提示注入因而能够诱导智能体将恶意文件写入主机启动目录并形成代码执行 [534]。存在的主要问题包括：动态风险-自主权限映射理论缺失，人机协同安全博弈模型不成熟；主流开源框架无原生人工干预闸门，商用过度放开自主权限，动态分级原型未工程落地；研究挑战包括对抗环境下决策边界动态量化、高危任务人机协同安全调度。 • 禁止性行为清单缺失，入门效应驱动决策漂移：Weng 等人 [512] 实验证实渐进诱导持续突破安全边界，形成不可逆失范。AWS 在 2026 年介绍 Bedrock Guardrails 时指出，智能体会在多轮循环中持续规划、调用工具和处理结果，不同步骤具有不同风险，单一静态护栏难以覆盖完整决策链；同时，InvokeGuardrailChecks 仅提供风险检测分数，具体阈值以及阻断、重试或放行措施仍需开发者自行设定 [535]。存在的主要问题包括：无统一禁止行为基准数据集，缺少反向抑制决策漂移优化算法；开源无动态禁止清单更新模块，商用仅静态关键词拦截，无法识别渐进语义诱导；研究挑战包括长时序渐进对抗溯源、自适应动态禁止基线生成。 • 合规推理标准空白，内在行为判别失效：Bhosale 等人 [7] 综述，需求层缺失违规判定标准将导致任务分解、工具调用丧失合规判别能力。AWS 在 2026 年公布的 Automated Reasoning Checks 改进说明中明确指出，形式化验证结果的可靠性取决于政策定义质量，而自然语言政策向形式逻辑转换时仍可能产生变量描述不清、类型定义模糊和语义歧义，需要通过迭代测试持续修正 [536]。存在的主要问题包括：智能体合规推理无统一评价体系，伦理约束轻量化嵌入理论空白；无开源实时违规规划检测工具链，商用仅事后人工复核；研究挑战包括任务链路合规形式化判定、轻量化伦理推理融合机制。合规规则与业务开发场景适配度低，易出现合规误判、合规漏判双向问题。
行动 (执行层)	• 无工具白名单准入，粗粒度授权引发泛化调用：Zhu 等人 [513] 证实“全有或全无”授权无法上下文差异化管控。微软安全团队于 2026 年披露 Semantic Kernel 的 CVE-2026-25592，其中向模型开放的文件下载工具允许智能体控制本地写入路径，提示注入可诱导其向主机启动目录写入恶意文件 [534]。存在的主要问题包括：上下文感知细粒度授权理论不完善，权限溢出溯源机理缺失；全部开源框架默认全域调用，商用无原生白名单，现有最小权限方案仅静态仿真；研究挑战包括任务驱动动态权限裁剪、跨工具调用权限溢出实时检测。工具授权生命周期管控缺失，临时授权长期留存易引发持续性越权调用风险。现有授权策略大多绑定会话生命周期而非任务生命周期，当多任务复用同一智能体实例时，已完成任务的临时权限不会自动回收，形成持久攻击面；同时缺乏调用行为审计溯源链路，权限越权发生后难以定位触发越权的原始提示、中间推理步骤与工具调用序列。 • 缺失高危操作黑名单，系统执行存在原生盲区：Staufer 等人 [537] 调研表明依赖用户确认防护极易被绕过，单次授权可批量执行破坏性操作。阿里云 Agent Security Center 在 2026 年发布的 Skills 检测规范中，将“危险工具无需确认”“缺少确认要求”“权限过宽”“不安全默认行为”和“MCP 最小权限违规”列为典型风险 [538]。存在的主要问题包括：无统一高危操作语义分级标准，复杂指令风险识别精度不足；开源无高危指令拦截引擎，商用仅关键词过滤，语义级危险操作无法阻断；研究挑战包括复杂系统指令高危语义理解、执行链路前置硬阻断理论。组合式高危操作识别能力薄弱，低风险指令叠加衍生高危行为难以被拦截。当前防护机制普遍面向单条独立工具调用进行风险判定，缺少对多轮调用序列的时序关联分析；攻击者可通过任务拆分、多步骤迂回构造无害中间指令，逐步逼近破坏性操作，规避单点检测规则，形成“分步逃逸”攻击范式。 • 权限无分级上限，能力-安全失配诱发级联风险：Ji 等人 [539] 提出失配概念，权限超额引发横向移动全域事故，多智能体场景风险放大。微软 AI 红队 2026 年报告给出多智能体信任升级场景：受控子智能体通过自然语言声称自己代表管理员，编排智能体未独立验证便将该身份传递给下游工具，最终触发双方原始凭证均无权执行的管理操作 [540]。存在的主要问题包括：多主体失配传导机理研究不足，动态权限降级与风险阻断理论残缺；开源工作流无自动降级机制，商用多智能体无跨节点阻断能力，治理方案仅纸面理论；研究挑战包括能力与安全边界动态匹配、多主体级联风险传播阻断建模。现有智能体通信普遍依赖自然语言隐式信任传递，缺少密码学身份凭证、调用上下文签名、信任时效约束机制；智能体间缺少独立的身份核验通道，极易遭受身份仿冒、权限委托滥用，风险沿智能体调用链逐级放大，单点漏洞扩散为全域安全事件。

续下页

表 3.1 – 续上页

模块	安全问题与研究挑战
交互 (协同层)	• 人机会话管控基线缺位，长效静默载荷植入通道开放：Zhu 等人 [514] 后门实验证实休眠原语激活后外泄 95% 数据；Liang 等人 [541] 拓扑攻击依托会话边界模糊横向扩散载荷。微软安全团队 2026 年发现“AI 推荐投毒”趋势：部分网页在“使用 AI 总结”按钮的 URL 参数中嵌入隐藏指令，尝试将推广内容持久写入助手记忆，使其在后续无关会话中继续影响推荐 [542]。存在的主要问题包括：会话全生命周期安全理论缺失，长时序休眠后门溯源模型稀缺；开源协作框架无会话隔离时效机制，现有载荷检测无法识别长期休眠指令，商用无会话安全基线；研究挑战包括超长时序会话恶意载荷溯源、动态会话边界自适应划分。会话边界静态固化严重，无法适配频繁迭代、交叉复用的复杂研发会话场景。休眠式隐性载荷具备极强隐蔽性，常规实时检测机制无法实现长效持续监控。 • 多智能体信任边界模糊，级联协同攻击扩散：Peigné 等人 [515] 验证恶意提示多跳跨主体传播；Long 等人 [543] 共享库欺骗造成全域功能污染。Google Research 于 2026 年公布的多智能体安全实验显示，增加安全提示后，多轮攻击失败率虽由 75.00% 降至 46.88%，但攻击者仍可借助“功能包装”隐藏真实意图并利用智能体的正常功能绕过防护 [544]。存在的主要问题包括：去中心化动态信任博弈模型不成熟，跨主体攻击阻断理论不完善；开源平台无实时信任评估，产业采用静态信任白名单，动态防御原型算力开销巨大；研究挑战包括去中心化信任分数迭代、跨主体协同攻击溯源阻断。多主体联动防护缺少协同联动机制，单节点防护失效将引发全域安全体系崩塌。动态信任评分维度单一，无法综合行为轨迹、交互频次、历史风险多维数据精准授信。 • 跨系统基线空白，上下文污染与供应链渗透：Long 等人 [543] 证实第三方接口、共享依赖为核心攻击面，供应链载荷可纵向渗透核心智能体。阿里云 2026 年发布 Agent Security Center 时指出，智能体对 Skills、MCP 服务和第三方组件的组合依赖正在形成新的安全盲区，其中可能包含技能投毒、隐藏后门、不安全配置及第三方依赖漏洞 [545]。存在的主要问题包括：智能体供应链安全属于前沿空白，异构交互污染检测理论缺失；开源第三方组件无内置安全校验，现有防御仅单点防护，无端到端供应链管控原型；研究挑战包括异构跨系统污染识别、AI 智能体供应链风险分级隔离体系。跨系统异构协议交互复杂，污染载荷可隐蔽穿透接口边界形成隐性传导风险。
治理 (管控层)	• 智能体专用合规基线缺失，传统规范存在结构性断层：Eisenberg 等人 [516] 提出一体化合规框架，传统网安规范无法适配自主多主体特性；TRiSM 框架划分四大治理支柱但无落地细则。阿里云 2026 年 AI 治理成熟度检查官方文档显示，其面向智能体平台运行和 AI 网关的检查体系目前仅包含 37 项，其中“效率”支柱尚无检查项，其他检查项仍在持续增加 [546]。存在的主要问题包括：无完整智能体专属合规理论体系，动态行为合规判定数学模型缺失；开源合规工具不兼容自主推理，商用复用传统安全规范适配性差，一体化框架仅理论构想；研究挑战包括动态自适应行为实时合规校验、多主体合规规则冲突消解。合规标准迭代滞后于智能体技术演进，极易出现规范滞后、管控脱节的治理漏洞。现有静态合规条款无法覆盖智能体自主决策、动态交互产生的新型合规风险场景。 • 全链路可观测规范缺位，审计取证存在原生盲区：OWASP MCP Top10 [547] 将遥测缺失列为高危风险；MAFA [518]、Aegis 哈希链 [548]、结构化插桩日志 [549] 证明可观测是问责底层支撑。微软 2026 年调查指出，不少组织在建立访问管理、数据保护、合规与问责控制之前便已部署 AI 智能体，形成无法准确掌握智能体数量、所有者、数据访问范围和实际行为的治理盲区 [550]。存在的主要问题包括：推理层、规划层日志标准化范式缺失，轻量化防篡改存证理论不完善；开源观测仅记录工具调用，缺失内部推理遥测，哈希链存证算力高难以大规模部署；研究挑战包括端到端轻量化审计溯源、大模型隐式推理不可篡改取证建模。行为黑盒化问题导致智能体违规操作、恶意调用行为难以事后追溯与精准定责。 • 动态权限治理空白，传统 IAM 无法适配自主特征：Eunsu&Daeheon [519] 信任分数零信任模型、Shlomov 等人 [520] 构造式治理提出约束嵌入流水线；Five Eyes [551] 完成风险分类但无量化落地标准。阿里云 2026 年 Agent ID Guard 文档指出，智能体会自主调用大模型、MCP 服务、企业 API 和第三方 SaaS，其链式调用已打破传统“用户—应用—资源”二方授权模型，并产生“谁代表谁执行何种操作”的委托链问题 [552]。存在的主要问题包括：传统 IAM 模型不兼容动态自主行为，信任驱动权限迭代理论不成熟；开源 IAM 无信任分数管控，构造式治理仅理论方案，商用仍使用静态权限台账；研究挑战包括自主行为驱动零信任动态权限迭代、安全约束与推理性能协同优化。静态权限固化模式无法适配智能体动态任务场景，极易引发越权调用、权限滥用风险。

3.2 架构设计阶段（安全体系定型）

架构设计阶段承接需求规划阶段遗留的非完备安全规约，将需求层模糊、缺失、未量化的顶层安全缺陷进一步下沉、固化为智能体系统内生的结构性与拓扑性安全短板，是决定 AI 智能体全生命周期安全能力上限的核心枢纽环节。该阶段以需求层定义的功能边界与安全约束为输入，将抽象的安全规则落地为各模块拓扑结构、组件耦合关系、数据流转路径与内核交互逻辑，使得前序阶段未被约束的原生缺陷由“逻辑层面的设计疏漏”转化为“系统层面的固定架构特征”。结合六大模块架构特征及现有学术成果、工程落地现状，本阶段系统梳理架构层级的结构性安全缺陷、理论短板与工程瓶颈，主要发现如下（详见表 3.2）：

- **智能体全链路安全风险根植于架构原生拓扑缺陷，结构性短板具备不可后置修复的体系化特征。**感知层未内置多级输入净化与指令边界消解架构，多模态隐写载荷、隐蔽提示词可无门槛穿透输入端，从源头污染推理上下文 [553]；记忆层缺乏分层隔离、租户隔离与字段级防篡改存证架构，明文长期驻留、跨域串扰、记忆投毒与数据残留问题常态化存在，形成持久性安全隐患 [554], [555]；决策推理层缺少分段校验、意图一致性约束与高危路径剪枝拓扑，无法抵御多轮渐进式边界侵蚀与隐性越界推理行为 [556], [557]；行动执行层缺失统一底层鉴权、强沙箱隔离与高危操作分级阻断架构，工具链式越权、沙箱逃逸、高危指令滥用成为共性工程问题 [558], [559]；交互协同层无原生传输加密与会话隔离机制，极易引发链路劫持、跨会话污染与流式隐私泄露 [560], [561]；治理层全链路埋点、动态权限管控与自动化处置架构缺失，造成运行行为观测黑盒、权限堆叠失控、风险处置被动滞后 [562], [563]。此类缺陷固化于系统底层拓扑与组件耦合逻辑，具备全域传导、长期潜伏、补丁不可根除的特点，是智能体安全问题反复出现的底层结构性诱因。
- **智能体架构缺少标准化域化分层安全设计，模块安全管控权责混乱、上下游防护失衡问题突出。**现有学术研究与工程落地的智能体架构，均以功能实现为核心依据划分模块边界，未依据数据流转、任务传导、权限调用规律构建梯度化、域化的分层安全防护体系，导致输入防护、持久存储、自主推理、外部执行、协同通信、全域管控六大层级的安全权重无序、耦合关系混乱。行业普遍存在安全组件零散堆砌、防御层级割裂、链路管控脱节的工程现状，未针对不同架构域设计差异化约束机制。其中，输入防护域架构缺陷会逐级放大下游全链路攻击面，存储隔离不足催生持久性记忆污染与溯源难题，推理安全护栏缺位引发隐性决策失范，执行层架构短板直接导致设备与内网破坏性风险，交互拓扑漏洞诱发跨主体全域污染扩散，治理层碎片化管控造成系统安全状态不可观测。目前学界与产业界尚未形成统一的智能体安全分层架构规范，缺乏可量化的层级防护优先级标准，是当前架构安全领域亟待补齐的核心理论与工程短板。
- **主流外挂式防护架构存在内生解耦缺陷，防护效能存在固有上限，缺失原生一体化安全嵌入范式。**现阶段针对智能体架构安全风险的防护手段多依赖外置网关、事后审计、离线对齐、后置过滤等被动方案，安全防护逻辑与智能体原生推理、任务调度、工具执行流水线相互独立，存在天然的链路割裂与时序错位问题 [564]。该类后置防护体系无法从拓扑根源阻断风险的纵向传导与横向扩散，在多模态隐写攻击、跨域记忆投毒、多轮渐进越狱、复杂链式越权等高级对抗场景下存在大量防护盲区。同时，现有研究尚未形成“输入净化—存储隔离—推理约束—执行管控—交互加密—全域治理”的原生一体化安全架构范式，开源与商用体系均缺少标准化的内生安全嵌入机制，导致现有防护方案算力开销高、适配性差、重构改造成本大，难以兼顾安全防护效能与工程落地性能，严重制约高可信 AI 智能体的规模化落地部署 [20], [548]。

表 3.2: AI 智能体架构设计阶段安全问题与研究挑战

模块	安全问题与研究挑战
感知 (输入层)	• 输入链路缺少分层净化过滤架构，不可信数据直达推理层：Chong 等人 [565] 验证三级净化管道可阻断输入端批量信息泄露，证明该范式工程可行但尚未规模化落地；Schwarz [553] 指出 Transformer 底层存在指令边界歧义缺陷，无法天然区分可信系统指令与不可信用户输入，构成提示注入底层漏洞；输入端无结构化隔离会持续衰减下游防御效能、抬高误报率，形成不可逆架构防护短板。存在的主要问题包括：分层净化管道统一量化隔离理论缺失，输入与模型指令边界歧义无标准化消解范式，多源混合输入分层防御建模不完善。研究挑战包括多模态混合输入分层净化自适应调度、Transformer 指令边界歧义原生消解、轻量化多级隔离过滤架构设计。 • 缺失跨模态对抗与隐写提示词专项识别架构：Zeng 等 [566] 指出多模态融合大幅扩大攻击面，现有感知框架缺少通用对抗样本识别能力；Sun 等 [567] 梳理图文隐写攻防现状，隐写提示词依靠语义嵌入隐蔽传播，若感知层无专用解析通道，Unicode、零宽字符伪装攻击可直接穿透入口防护。微软 2026 红队实验复现视觉提示注入攻击：攻击者在网页植入伪造按钮、低对比度指令、虚假弹窗与对抗文本，可借助智能体图像 - 动作链路诱导其执行受控恶意操作 [540]。存在的主要问题包括：跨模态对抗、文本隐写统一识别表征学习体系空白，多模态输入专用解析通道架构理论不完善。研究挑战包括图文音视频跨模态对抗统一表征、隐写载荷轻量化实时识别、多通道并行解析隔离架构。多模态数据存在特征异构性，传统文本检测模型无法适配图像、音频类隐蔽攻击识别场景。 • 输入入口未内置标准化风控校验节点，原生缺失前置准入屏障：Na 等 [568] 提出双轴预检测方案验证前置风控可行性，但产业落地多依赖松散外挂插件，未校验恶意输入可直传模型，形成持久架构漏洞。阿里云 2026 智能体风险报告将提示注入、混淆走私列为高频威胁：前者绕过业务逻辑触发异常操作，后者依靠编码混淆隐匿恶意指令规避检测 [569]。存在的主要问题包括：顶层原生前置风控标准化建模缺失，外挂式校验与推理链路时序耦合漏洞无系统理论；主流开源框架无原生预检测节点，产业均采用外挂校验插件，双轴预检测方案仅仿真未工程落地；研究挑战包括原生嵌入型前置风控轻量化架构、外挂校验时序漏洞阻断、输入准入风险分级量化标准。
记忆 (存储层)	• 记忆存储层级与租户隔离架构缺失，诱发跨域串扰与记忆投毒传导风险：Bhosale 等 [570] 证实无边界混合存储是隐私泄露、智能体劫持的关键诱因；Wen 等 [554] 实验证明无隔离全局记忆会持久留存恶意载荷、持续损耗模型精度，层级硬隔离可将攻击成功率降至 2.19%。多租户环境缺少检索门控将直接引发跨租户数据泄露，Lam 等 [571] 指出固化敏感上下文易产生拓扑诱导泄露；Bhardwaj [572] 的 SuperLocalMemory 架构佐证存储硬隔离对投毒攻击的防护作用。阿里云 2026 年 Function Compute 文档提及，实例默认复用会造成内存、临时文件、GPU 状态残留污染，引发租户环境混叠风险 [573]。存在的主要问题包括：多租户分层存储隔离形式化证明体系不完善，记忆投毒跨域传导溯源理论缺失；开源记忆引擎无租户分层硬隔离，商用多租户智能体共享全局存储，SuperLocalMemory 无成熟开源实现；研究挑战包括动态多租户自适应存储隔离、跨域记忆投毒溯源阻断、分层存储检索门控轻量化机制。记忆投毒具备链式传导特性，现有隔离机制仅能阻断单点风险，无法遏制全域污染扩散。 • 字段级加密与防篡改溯源机制缺位，明文存储催生记忆洗白漏洞：Zhou 与 Wu [555] 指出明文存储是记忆层底层结构性短板，会直接导致上层所有风控策略全部失效；Louck 等人 [530] 通过形式化证明验证传统后置防御无法抵御记忆洗白攻击，其 TMA-NM 原生存储架构可实现全攻击通道 0% 攻击成功率，印证原生防篡改架构是阻断恶意篡改的核心抓手。存在的主要问题包括：字段级加密与 Merkle-DAG 存证融合轻量化理论稀缺，记忆洗白攻击事前预判模型缺失；开源存储组件默认明文存储，无字段粒度加密存证原生模块，TMA-NM 架构仅离线仿真；研究挑战包括低开销字段级加密与链式存证融合、记忆篡改行为实时预判、原生防篡改存证流水线设计。 • 全周期记忆生命周期管控架构空白，滋生数据残留泄露与合规风险：Kumar 等人 [574] 提出 MemArchitect 框架，解耦存储时效管控与业务一致性逻辑；Lam 等人 [571] 采用时间衰减机制缓解长期存储安全偏移；西班牙 AEPD 2026 合规指南 [575] 已明确要求智能体配套刚性记忆销毁机制，标志该架构缺陷已从工程漏洞升级为法定合规风险。存在的主要问题包括：业务一致性与记忆销毁冲突消解理论不完善，合规驱动生命周期自动管控模型空白；开源记忆管理无自动时效销毁引擎，商用无合规刚性销毁原生节点，MemArchitect 仅学术原型；研究挑战包括业务无损记忆定时销毁机制、多区域合规适配生命周期管控、残留数据彻底擦除轻量化算法。

续下页

表 3.2 – 续上页

模块	安全问题与研究挑战
决策 (推理层)	• 推理链路校验机制缺失，隐性越界行为难以实时拦截：现有推理监督与形式化验证方案仅适配封闭数学推理场景，通用业务全链路分段校验与意图一致性校验架构尚属空白，无法识别长时序隐性越界行为 [556], [576], [577]。AWS 研究证实自然语言安全规则存在歧义性缺陷，传统校验方式难以适配复杂业务推理场景 [536]。当前通用推理分段校验形式化理论、意图一致性时序建模存在短板，开源引擎无原生校验模块，通用场景工程方案缺失。研究挑战为构建全链路分段校验流水线、实现意图漂移实时识别与轻量化形式化验证体系。传统静态规则校验无法适配动态推理分支变化，极易产生隐性越界漏判问题。推理过程黑盒化严重，缺少中间推理节点的精细化安全校验能力。 • 路径规划缺少内生安全约束，易滋生高危执行链路：高自主智能体任务拆解与路径规划环节无原生风险管控，易被渐进式诱导生成恶意执行路径，放大系统攻击面 [578]。机器人领域 SAFER 框架可实现规划风险校验，但无法适配通用 LLM 智能体，现有主流框架普遍存在安全与业务失衡问题，缺乏子任务风险剪枝与权限分级管控能力 [579], [580]。目前规划前置风险剪枝理论、安全与性能平衡机制不完善，通用智能体无原生规划拦截能力。核心研究挑战为高危路径实时剪枝、安全约束原生嵌入与轻量化双模型并行校验架构。多分支复杂规划链路缺少逐节点风险校验机制，隐蔽高危子任务难以被有效甄别。动态重规划场景无二次安全校验，自适应调整过程易引入新生风险链路。 • 多轮攻击防护体系碎片化，无法抵御渐进式边界侵蚀：分解式多轮越狱、渐进式边界侵蚀攻击对智能体成功率极高，现有状态化轨迹检测、对话屏障等防御手段均为外挂式组件，未原生融入推理流程，无法形成检测-拦截-修正闭环防御体系，难以根治系统性隐性入侵 [557], [581], [582], [583]。腾讯朱雀实验室指出，多轮对抗需全域联动防护，单一外挂防护模式存在严重局限性 [584]。当前多轮对抗状态轨迹统一建模、推理原生安全闭环理论存在空白，产业无成熟集成化防护方案。研究挑战聚焦于长时序对抗轨迹建模、推理一体化防御闭环与渐进式攻击前置预判机制。外挂防护与推理链路存在时序错位，攻击者可利用时间差实现边界穿透。长时序会话风险累积效应缺少量化模型，隐性侵蚀过程难以精准预警。
行动 (执行层)	• 工具调用链路缺失中心化底层鉴权架构，引发权限泛化与链式越权风险：现有工具协议存在原生缺陷，易触发链式越权攻击 [558]。针对该问题，AgentGuard 模型依托 ABAC 细粒度权限机制，可防护单工具及跨工具联动安全风险 [585]，SkillGuard 双平面管控体系能够约束智能体技能滥用行为 [586]。阿里云 2026 年研究证实，智能体多资源联动调用模式突破传统二方授权体系，催生权限委托链管控难题 [552]。当前核心短板为缺乏工具调用中心化鉴权标准化理论与跨工具越权溯源模型，开源协议无底层鉴权节点、商用生态管控不完善，多数防护方案仅停留在原型阶段。核心研究挑战为构建全工具链原生鉴权架构、实现跨工具越权实时阻断及动态 ABAC 权限自适应裁剪机制。跨工具联动风险传导机理尚不明确，多级调用组合越权行为难以溯源定位。 • 作业执行环境缺乏标准化强沙箱隔离，存在逃逸渗透与权限过配隐患：相关研究基于测试基准证实智能体可利用容器漏洞突破运行隔离边界 [559]，现有容器、虚拟机等多层隔离体系存在显著工程短板 [587]。开源智能体普遍存在权限过度配置问题，平均超配幅度达 15 倍，仅强隔离框架可落地最小权限原则 [588]。微软 2026 年披露的高危漏洞证实，恶意注入可绕过容器隔离执行主机代码，凸显沙箱隔离缺失的安全隐患 [534]。目前存在多层沙箱协同隔离安全证明缺失、动态权限收敛理论不完善等问题，开源沙箱隔离强度不足且无分层权限约束机制，现有方案缺乏工程化落地能力。主要研究挑战为搭建多层强沙箱协同隔离架构、实现任务驱动的权限动态回收及沙箱逃逸行为实时预判拦截。沙箱运行时状态无持续监测，隐性逃逸试探行为无法被及时感知阻断。 • 高危操作无分级拦截架构，缺失前置强制风险阻断机制：智能体执行层核心缺陷为权限与操作风险不匹配，现有系统仅依赖事后日志溯源，缺少前置刚性防护，高危操作安全风险突出 [589]。Salesforce 2026 年研究表明，主流智能体框架无法精细化管控单步决策权限，关键业务场景缺失强制约束机制 [580]。当前存在操作风险动态分级量化标准缺失、前置拦截与业务执行时序耦合理论不完善等问题，开源引擎无原生高危操作拦截节点，商用系统仅支持事后审计、无前置硬阻断能力。核心研究挑战为实现操作语义风险动态分级、搭建轻量化前置分层拦截节点、融合高危操作人机协同校验机制。静态风险分级体系无法适配动态业务场景，高危操作误拦、漏拦问题并存。操作执行上下文感知能力薄弱，相似指令差异化风险无法精准判别。

续下页

表 3.2 – 续上页

模块	安全问题与研究挑战
交互 (协同层)	• 通信传输链路缺失原生加密防护，诱发链路劫持与侧信道信息泄露： Ferrag 等 [560] 发现，集群临时认证存在底层漏洞，流式 Token 与长提示词易遭侧信道流量攻击；外置加密插件防护能力有限，传输层缺失内生加密架构是数据泄露的根本原因。阿里云 2026 年风险报告指出，AgentKit、AgentRun 工作流存在 HTTP 明文传输漏洞，易泄露数据与身份令牌 [569]。存在的主要问题包括：流式 Token 原生加密轻量化理论空白，流量特征隐私混淆一体化架构建模不完善；开源通信组件无内置流式加密，商用依赖外置加密插件，无原生传输隐私混淆实现；研究挑战包括大模型流式输出原生低开销加密、Token 流量特征匿名混淆、集群临时认证底层漏洞消解机制。流式传输分段离散特征明显，传统加密方案难以兼顾实时性与隐私安全性。 • 多域交互缺少会话隔离架构，滋生上下文串扰与跨用户持久投毒： Patlan 等人 [561] 提出跨用户投毒 CUP 攻击，依托全局共享会话状态污染实现长期隐蔽操控；OWASP MCP Top 10 (2025) [547] 将上下文无边界共享列为交互层高危原生风险；Azarafrooz[590] 证实跨会话污染易时序扩散，缺少会话域与并发隔离机制会造成劫持、隐私泄露与全域投毒。AWS 2026 年提出，仅靠提示或租户标识难以隔离多租户数据，推理、工具调用与数据库链路的身份上下文完整传递仍是架构难点 [591]。存在的主要问题包括：多域会话作用域隔离形式化规约缺失，跨会话污染时序传导溯源模型稀缺；多智能体协作框架全局共享会话，无用户域隔离原生机制，会话隔离原型算力开销极高；研究挑战包括动态多域会话轻量隔离、跨用户持久投毒溯源清除、并发会话访问安全基线标准化。高并发多会话交织场景下，静态隔离策略极易出现边界穿透与上下文混叠问题。 • 输出链路未内置原生内容审核架构，存在原生信息外泄与违规透出漏洞： Fu 等人 [564] 提出 Self-Sanitize 框架实现 Token 粒度实时内容纠偏；Desai 等 [592] 设计双向输入输出安全护栏，但仅为后置补丁，难以源头阻止隐私、涉密数据流出，输出层风险突出。Google Cloud 2026 年表明，智能体实时应答易引发敏感数据泄露与滥用 [524]。存在的主要问题包括：输出流水线原生多粒度内容审核融合理论空白，动态脱敏与生成性能平衡模型不完善；开源生成链路无原生脱敏审核节点，商用依赖后置过滤插件，Self-Sanitize 仅离线验证；研究挑战包括 Token 级原生实时脱敏架构、生成内容违规语义前置识别、输出链路安全约束轻量化嵌入。
治理 (管控层)	• 全维度行为日志埋点架构缺失，运行态行为陷入观测黑盒： Zheng 等人 [562] 设计 AgentSight 非侵入式观测框架，通过数据流关联还原完整行为因果链；Alsayyad[549] 基于 AgentTrace 搭建完整审计链路，反映行业普遍缺少全域原生埋点，智能体运行状态不透明，取证复盘能力薄弱。微软 2026 年调研显示，多数企业先行部署智能体再完善管控，难以摸清其资产、权限与行为全貌 [550]。存在的主要问题包括：全链路内生埋点标准化范式缺失，推理隐式行为审计溯源建模理论不完善；开源框架仅埋点工具调用行为，缺失推理/规划层日志，AgentSight 无大规模部署方案；研究挑战包括非侵入式全链路轻量化埋点、隐式推理行为结构化取证、跨模块行为因果链自动关联。 • 动态分级权限管控架构不完善，滋生权限过配、权限堆叠长效风险： Li 等人 [593] 证实静态固化规则无法有效治理动态信息流越权风险；Shi 等人 [20] 的 Progent 领域专用管控语言可精细化约束工具权限，显著降低攻击成功率；Zhu 等 [513] 通过 MiniScope 重构授权层级实现最小权限；现有权限体系规则更新滞后、缺少自动回收机制，易堆积权限漏洞。Google Cloud 2026 年提出，传统 IAM 不适配自主智能体，无法刻画委托关系与动态运行风险 [594]。存在的主要问题包括：动态信息流驱动权限自动回收理论空白，多维度分级权限协同管控数学模型不完善；商用、开源智能体全部采用静态权限台账，无自动回收原生模块，MiniScope 仅静态仿真；研究挑战包括动态任务自适应权限收敛、多维度分级权限冲突消解、权限堆叠风险长期演化预判。 • 安全感知-告警-自动处置闭环架构缺失，风险治理长期处于事后被动模式： He 等人 [563] 提出 SentinelAgent 动态图检测模型，实现异常行为识别与指令实时重写；Yuan 等人 [548] 搭建全域统一监控底座；Zou 等的 BlockA2A 多智能体防护框架可隔离恶意节点 [595]，但现有防护组件碎片化，无法自动执行权限收敛、会话隔离等应急处置，治理多为事后被动复盘。阿里云 2026 年 Agentic SOC 指出，传统安全运营追踪效率低、边界割裂、盲区多，难以适配智能体高速攻击面 [596]。存在的主要问题包括：感知-告警-处置一体化闭环原生架构理论缺失，多类型风险自适应应急决策模型不完善；监控、检测、处置组件相互独立无联动，无全自动闭环治理开源框架，仅支持人工处置；研究挑战包括全域安全治理一体化闭环流水线、多风险类型自适应应急处置策略、低开销实时异常阻断与任务管控。

3.3 编码开发阶段（安全工程落地）

编码开发阶段将上游需求模糊、架构耦合、安全规约缺失等顶层设计短板，最终固化为可直接利用的程序级漏洞，是智能体安全风险落地成型的核心工程环节。编码层缺陷属于“原生实现缺陷”，具备攻击门槛低、利用链路简单、通用性强、危害传导直接等特征。当前智能体研发普遍秉持功能优先的开发模式，安全校验、数据防护、权限管控多为事后增补，缺乏标准化安全编码规范与编译期自动化校验机制，使得各类结构性、逻辑性隐患持续沉淀为常态化代码层安全漏洞。结合编码开发阶段各模块代码实现特征、现有学术研究结论与工程漏洞实例，本节系统梳理该阶段程序级安全问题与现实挑战，主要发现如下（详见表 3.3）：

- **六大功能模块普遍存在编码层原生缺陷，构成系统主要入侵突破入口。**感知层输入处理依赖静态正则规则，缺少字符级对抗解析、动态上下文截断与语义拦截能力，无法有效抵御隐形字符、编码混淆与碎片化指令逃逸攻击，防护体系存在固有盲区 [597], [598], [599]。记忆层存储加密、数据清零与读写校验逻辑不完善，普遍存在明文数据驻留、加密链路残缺、细粒度访问控制失效等问题，诱发敏感信息泄露、跨用户越权读取与长效记忆投毒风险 [396], [600], [601]。决策层仅依靠单轮静态安全校验，缺失多轮上下文追踪、思维链埋点与渐进式意图识别机制，难以防御链式越狱、子查询拆分绕过等高级对抗攻击 [602], [603], [604]。行动层工具鉴权、沙箱隔离与高危操作校验代码不完善，存在参数校验不严、路径归一化缺失、多步骤风险研判空白等缺陷，形成参数篡改、沙箱遍历与分段指令绕过等稳定攻击路径 [605], [606], [607]。交互层接口鉴权、会话隔离与输出全链路脱敏能力不足，易引发裸接口未授权访问、跨会话状态串扰与分片隐式信息泄露问题 [608], [609], [610]。治理层普遍存在推理链路观测埋点缺失、凭证硬编码、权限判定边界疏漏等代码缺陷，导致运行态观测黑盒、规模化密钥泄露与系统性越权失控风险 [549], [611], [612]。
- **代码缺陷沿程序执行链路逐级传导，形成从入口注入到全域失控的层级化风险体系。**输入预处理层清洗逻辑不完善，各类编码畸形、隐形分片与隐匿指令可直接侵入核心推理流程，构建稳定的初始攻击入口 [613]。数据持久化层加密、脱敏与清零机制残缺，恶意样本与敏感数据可长期驻留，形成持续性数据投毒与隐私泄露风险源 [531]。推理决策层缺乏动态校验与过程埋点，静态护栏无法适配多轮链式推理特征，渐进式诱导与隐性意图漂移可有效规避检测，造成决策失范且难以溯源取证 [614], [615]。系统执行层沙箱隔离、参数鉴权与操作校验存在结构性短板，攻击者可通过指令拆分、参数篡改与路径遍历突破执行边界，引发沙箱逃逸与高危系统操作 [559], [616]。内外交互层鉴权、隔离与脱敏能力不足，易诱发多租户状态串扰、未授权访问与批量信息泄露，推动跨主体安全事件扩散 [561], [617]。治理层观测与权限管控缺陷直接导致上层安全兜底机制失效，造成风险不可监测、不可追溯、不可收敛，最终形成全链路纵向传导的闭环安全威胁。
- **编码前置安全门禁体系缺失，后置补丁修复模式存在固有短板与高昂工程成本。**当前智能体编码研发缺少编译期安全校验、自动化缺陷扫描等前置防护门禁，安全治理高度依赖上线流量检测、运行时拦截与事后漏洞补丁，无法从代码底层根除原生逻辑缺陷 [549]。后置被动防护仅能覆盖表层显性攻击，对字符级隐形对抗、逻辑边界越权、硬编码凭证泄露、多步骤组合恶意操作等底层漏洞存在明显防护盲区。同时，事后修复、版本回滚与存量代码重构不仅消耗大量人力与运维资源，还易引发功能兼容故障与版本迭代风险。目前行业尚未形成适配智能体推理、记忆、交互特性的专属安全编码标准，缺乏针对性静态检测规则集与编译阻断流水线，无法实现高危代码自动拦截与安全能力原生嵌入，严重制约高可信智能体的规模化落地 [611], [612]。

表 3.3: AI 智能体**编码开发阶段**安全问题与研究挑战

模块	安全问题与研究挑战
感知 (输入层)	• 输入清洗代码对字符级对抗操纵覆盖不全：编码与隐形字符类对抗攻击可高效绕过现有安全防护，编码类攻击成功率可达 64.3%–67.1%[597]，基于 Unicode 的隐形越狱攻击可在视觉无异常条件下规避模型对齐约束 [598]，RAG 场景下字符隐写类攻击逃逸率高达 68.3%。AWS 2026 年研究证实，不可见 Unicode 字符、全角兼容字符等可用于隐藏注入指令与窃取系统提示 [618]。现有防护仅针对常规 Web 明文攻击，缺失 Unicode 混淆、多进制编码、零宽隐形字符的标准化清洗能力。当前存在字符级对抗统一表征、隐形扰动耦合机理、轻量化清洗算法等理论与技术短板，开源与商用体系均缺乏原生专项防护，多依赖事后补丁。核心研究挑战为多进制编码统一解析、零宽字符轻量化过滤及 RAG 字符隐写攻击溯源。 • 畸形、超长与碎片化诱导输入专属拦截代码缺失：超长上下文与碎片化令牌操纵可突破传统输入防护，128K 超长上下文可淹没安全判定边界实现稳定越狱 [599]，令牌分段绕过攻击可显著提升逃逸成功率 [613]。Google 2026 年研究发现，恶意超长加载页面可耗尽智能体上下文与算力资源，引发超时失效与安全旁路 [619]。现有系统依赖静态长度阈值，未针对无显性恶意特征的碎片化、跨上下文重组指令设计专属拦截逻辑，防护存在明显空白。目前存在超长上下文安全量化建模、碎片化语义风险研判、动态阈值调控机制缺失等问题，主流框架未适配超长上下文安全校验。研究挑战集中于动态风险阈值建模、碎片化指令语义风险识别与超长上下文轻量化安全管控。 • 敏感内容匹配与拦截机制代码实现存在固有缺陷：主流商用内容防护工具存在严重绕过漏洞，部分场景规避成功率可达 100%[620]。现有工程方案过度依赖静态正则黑名单，易受令牌叠加、隐形字符割裂干扰，且词库更新滞后；激进的令牌移除防御也可通过语义同义词替换绕过，防护上限受限。腾讯朱雀实验室 2026 年测试表明，恶意技能可将高危操作隐藏于自然语言文本，传统正则匹配与安全审计机制难以识别 [621]。当前缺失语义抗干扰匹配理论、动态词库迭代算法与语义脱敏平衡模型，开源、商用防护均无原生语义拦截能力，人工更新词库存在安全窗口期。核心研究挑战为语义感知动态拦截、隐形字符干扰下正则规则修复及低损耗语义脱敏防御。
记忆 (存储层)	• 记忆持久化明文存储代码漏洞：智能体记忆数据具备高窃取价值，多数开源智能体框架将对话记录、API 密钥、OAuth 凭证等敏感信息以明文形式存储于固定本地路径，恶意终端程序可无权限校验直接扫描读取本地涉密数据 [600]。阿里云 2026 年安全方案将 API Key 明文存储列为智能体高频高危风险点 [622]。当前行业缺失本地存储安全分区建模与轻量化强制加密统一规范，开源框架默认明文落地、无路径隔离与权限锁定机制，商用轻量版本未强制开启存储加密。核心研究挑战为构建动态路径隔离机制、设计无感轻量化持久化加密方案、抵御终端恶意程序定向扫描窃取。持久化存储策略普遍缺乏最小暴露面设计，敏感记忆与普通日志混存于同一目录；且缺少文件访问 ACL 绑定、存储文件防拷贝约束，一旦终端出现横向渗透，攻击者可批量导出历史记忆快照。同时静态密钥加密方案难以适配分布式智能体部署场景，密钥分发与轮换机制缺失，加密方案存在单点突破隐患。 • 数据脱敏与加密全链路代码逻辑残缺失效：多智能体隐私加密模块普遍存在代码残缺、功能落地不全的问题，记忆数据写入缺加密核验、删除缺清零校验，是行业共性工程短板，存储一致性核验为防护刚需 [531], [571], [601]。多数框架仅预留加密接口，未实现端到端防护，易引发脱敏绕过、明文残留等风险。微软 2026 年披露的延迟记忆攻击，可利用记忆机制漏洞实现跨会话恶意指令触发与用户隐私窃取 [529]。目前记忆全生命周期加密闭环理论不完善，加密性能与推理时延难以平衡，现有防护框架缺乏量产工程落地。研究挑战聚焦于搭建端到端加密脱敏流水线、设计可验证的数据清零机制。现有脱敏策略多为静态关键词屏蔽，无法应对语义重构、分段拆分规避手段；记忆更新、覆盖操作仅修改索引标识，底层存储介质仍留存原始明文碎片，形成数据残留泄露通道。 • 记忆读写访问权限校验代码缺失：记忆层访问控制失效是智能体核心安全威胁，多项公开漏洞证实，会话隔离、会话 ID 校验代码缺陷会引发跨用户记忆窃取、批量数据泄露等安全事件 [396], [608]。MemoryGraft 等高级攻击可依托读写权限校验缺失，实现跨会话操控与隐私窃取 [623]。AWS 2026 年研究指出，无独立授权层的智能体易出现跨会话用户数据读取泄露问题 [624]。当前缺失细粒度访问控制与跨会话越权溯源模型，开源引擎无精细化读写校验逻辑，商用多租户版本存在原生权限校验缺陷。核心研究挑战为实现字段级权限管控、构建跨会话越权溯源阻断体系、设计后门触发词读写隔离机制。现有访问控制大多仅在会话初始化阶段完成一次身份校验，后续记忆增删改查操作缺少持续鉴权；缺乏基于操作意图的动态访问阈值约束，合法会话被劫持后可不受限制遍历全部历史记录。

续下页

表 3.3 – 续上页

模块	安全问题与研究挑战
决策 (推理层)	• 安全护栏校验代码缺失，存在跨轮上下文旁路漏洞：静态安全护栏难以适配智能体多轮动态推理场景，固定单轮校验机制存在显著绕过短板。多轮对话可利用上下文状态盲区突破安全约束，子查询拆解攻击在主流大模型上逃逸成功率可达 95% 以上 [602], [603]。静态防护与链式动态推理架构天然不兼容，单轮校验无法捕捉累积意图漂移，形成系统性旁路漏洞 [614]。Google 2026 年实践表明，间接提示注入可随工具调用与任务链持续变异，静态单次校验无法覆盖动态推理状态 [625]。目前缺乏多轮意图漂移量化理论与动态护栏流水线融合范式，开源框架均为静态单轮校验，现有动态防护原型算力开销过高难以落地。核心研究挑战为多轮累积意图实时量化、推理原生动态护栏构建与上下文旁路漏洞闭环阻断。 • 思维链与决策过程结构化日志埋点代码缺失：智能体普遍缺失中间推理步骤日志埋点，导致隐性渐进式越狱难以复盘取证 [604]。模型早期不安全推理易被最终对齐输出掩盖，且模型具备主动规避监控的自适应能力，超长思维链还会稀释恶意特征，造成传统审计机制完全失效 [615], [626], [627]。AWS 2026 年可观测性研究指出，智能体可出现隐性推理错误、无限循环、工具错选等异常行为，且无法被传统告警机制识别 [628]。当前缺少思维链分层标准化埋点范式与隐性推理审计归因理论，现有框架仅记录最终输出，中间步骤埋点能力缺失，相关技术仅停留在实验室原型阶段。研究挑战集中于非侵入式分层推理埋点、隐性行为溯源归因与超长思维链恶意特征精准提取。 • 越狱诱导与违规推理拦截代码识别能力不足：现有防护检测难以识别渐进式决策漂移与分层重构式越狱意图，浅层关键词与普通语义匹配存在固有局限，分步式无害子查询编织攻击可稳定绕过现有防护体系 [549], [603], [629]。Microsoft 2026 年实验证实，单条诱导提示即可通过奖励机制彻底破坏模型安全对齐，并引发跨类别安全泛化失效 [630]。现有拦截代码普遍缺失因果时序推理能力，无法抵御高阶规划式越狱诱导攻击。当前存在渐进漂移因果建模、分层意图重构识别理论空白，主流防护依赖浅层匹配，缺乏工程化时序分析模块。核心研究挑战为长时序渐进越狱因果溯源、分层重构意图精准识别与轻量化时序推理拦截算法设计。
行动 (执行层)	• 工具调用鉴权代码存在多类稳定绕过漏洞：智能体工具调用存在原生信任边界缺陷，无需底层内存漏洞，通过参数操纵、上下文伪造、会话复用即可实现越权提权 [560]。相关研究提出安全迁移鸿沟理论，并证实主流平台 TIP 参数操纵漏洞可触发远程代码执行 [605], [631]。阿里云 2026 年权限研究指出，多级代理调用链易出现用户权限上下文丢失问题，且下游接口仅校验令牌签名、不校验受众字段，会引发令牌复用与跨服务越权风险 [552]。当前工具调用信任边界缺乏形式化规约，参数漏洞溯源机理研究不足，开源鉴权无参数强校验机制，商用平台普遍存在会话复用绕过短板。核心研究挑战为信任边界原生加固、动态参数合法性强制校验与跨会话权限复用漏洞阻断。现有鉴权逻辑大多仅在工具调用入口完成一次性身份核验，缺少贯穿完整调用链路的持续上下文绑定；在多工具链式调用场景中，权限主体上下文极易发生漂移，后继工具无法追溯原始请求主体。 • 沙箱隔离机制底层代码实现不完善，存在多类逃逸突破口：智能体沙箱收容机制存在固有失效模式，现有环境难以抵御自主逃逸攻击 [559], [606]。多条公开 CVE 漏洞证实，路径遍历、符号链接等缺陷可实现任意文件写入与全域读写突破，通用代码智能体沙箱原生防御率仅 17%，核心症结为路径规范化缺失、命令过滤不全、进程权限过高等底层代码问题 [616]。AWS AgentCore 安全架构强调，智能体沙箱需同时防范跨智能体数据泄露与恶意代码扩散风险 [632]。目前智能体专属分层隔离理论缺失，路径与符号链接防护体系不完善，开源沙箱默认高权限配置，现有加固仅为单点漏洞修复。研究挑战聚焦于轻量化分层强隔离沙箱构建、路径类漏洞闭环防护与进程权限动态最小化管控。多数沙箱方案未针对大模型智能体动态生成代码、迭代执行、多轮交互的特征做适配。 • 高危操作分级拦截代码存在结构性失效缺陷：单一前置拦截架构存在原生安全盲区，人工审批校验可通过代码漏洞被静默禁用，路由参数校验缺失易形成授权旁路，对应多条高危 CVE 漏洞佐证 [607]。现有防护仅对单步工具调用独立校验，攻击者可拆解恶意行为为分段无害子操作，通过分步放行组合实现攻击，彻底绕过静态前置拦截机制。阿里云 OSS Agent 分级操作防护方案也印证，单步校验无法识别“创建-改权-删除”等链式组合风险，分级拦截体系存在结构性短板 [633]。当前缺失子操作组合风险研判理论与多级动态拦截建模能力，主流框架无跨步骤风险关联分析逻辑，审批机制易被绕过。核心研究挑战为分布式子操作风险关联识别、动态多级拦截架构设计与审批校验逻辑原生防篡改加固。静态前置拦截将风险判定局限于单次调用快照，无法维护时序上下文与操作依赖关系，难以捕捉逐步递进的攻击链路。

续下页

表 3.3 – 续上页

模块	安全问题与研究挑战
交互 (协同层)	• 内外交互接口鉴权与访问控制代码缺失：开放无约束接口是智能体交互层核心攻击面，未鉴权接口、硬编码密钥等缺陷可引发敏感配置枚举、全域账户接管等高危安全事件，对应多条公开 CVE 漏洞佐证 [608]。静态长期 API 密钥无法适配多租户动态访问场景，Agentic JWT 短期动态凭证方案可弥补裸接口鉴权缺失短板，但未实现量产落地 [634]。微软 2026 年监测数据显示，15% 的远程 MCP Server 存在配置漏洞，允许未认证用户非法访问内部核心业务系统与私有资源 [635]。当前多租户动态接口鉴权理论与短期凭证管控模型不完善，开源接口无原生鉴权能力，商用体系过度依赖静态密钥。核心研究挑战为构建多租户动态鉴权架构、实现短期凭证防泄露管控与裸接口零信任原生加固。 • 多会话隔离代码缺失，诱发跨域会话状态串扰污染：会话隔离机制缺失会直接导致多租户场景下批量用户隐私泄露，跨用户投毒攻击可依托全局共享会话状态实现隐蔽式长期操控 [561], [609]。CVE-2026-29872 等漏洞证实，私有会话令牌全局存储、计算实例复用等底层缺陷，会引发会话状态串扰，传统单层会话隔离方案完全无法抵御此类风险。阿里云计算实例安全规范指出，默认实例复用模式会造成内存、临时文件等残留状态跨请求、跨租户泄露污染 [573]。目前多层级会话隔离形式化规约、状态污染溯源理论存在空白，开源框架普遍采用全局会话存储，缺失进程级隔离能力。研究挑战聚焦于搭建进程-会话双层隔离架构、实现跨用户状态投毒溯源清除与私有令牌防泄露防护机制。会话生命周期与底层运行实例生命周期解绑机制缺失，会话销毁后内存缓存、临时文件中的敏感状态无法同步回收，形成持久化泄露通道。 • 输出链路内容审核与脱敏校验代码不完善：现有智能体缺乏全域身份感知隐私处理协议，虽 CommandSans 框架可大幅降低输出泄露攻击成功率，但前沿智能体输出泄露率仍可达 50.7%，分片隐式注入攻击可稳定绕过后置审核机制，凸显单链路后置校验的固有短板 [610], [617]。Google 2026 年上下文脱敏研究证实，隐私防护需适配语义场景动态判别，固定脱敏规则无法适配复杂业务语境 [524]。当前分片隐式攻击机理、身份感知全链路脱敏理论研究不足，现有防护仅依赖输出后置审核，缺失前后链路联动校验，多数优化方案仅停留在离线原型阶段。核心研究挑战为分片隐式注入精准检测、身份感知端到端脱敏体系构建与输入输出联动隐私防护闭环搭建。静态脱敏规则难以区分隐私信息正常引用与恶意窃取场景，容易产生大量误拦截。
治理 (管控层)	• 可观测性缺陷：关键行为日志结构化埋点代码缺失，推理全链路无法追溯取证：现有智能体观测体系无法完整捕捉中间推理过程与状态变更细节，碎片化日志难以刻画认知演化与风险传导链路，全链路结构化埋点是安全复盘与追责取证的核心基础 [549], [636]。AgentTrace 插桩方案验证了分层结构化日志对智能体安全治理的支撑作用，但存在算力开销过高、难以规模化部署的问题 [637]。阿里云 OpenClaw 可观测性实践表明，原生独立式事件 Span 缺乏上下文关联传播能力，仅能生成孤立数据，无法实现全链路溯源 [524]。当前推理层隐式行为埋点范式、轻量化日志防篡改存证理论尚不完善，开源框架普遍缺失原生推理埋点能力。核心研究挑战为低开销运行时原生插桩、隐式推理行为结构化建模与链式不可篡改日志存证机制构建。 • 配置管理缺陷：部署制品硬编码凭证代码引发规模化密钥泄露：智能体第三方技能模块与配置文件普遍存在明文硬编码凭证漏洞，可引发密钥批量泄露、账户全域接管等高危风险，多条公开 CVE 漏洞与行业数据证实该问题具备规模化破坏特征 [611], [638]。2025 年 AI 智能体密钥泄露数据同比大幅增长，凸显配置代码缺陷的严重性。微软安全分析将智能体动作与主题中的硬编码凭证列为高频高危风险，凭证可随项目导出、共享与部署链路扩散，造成未授权系统访问 [639]。目前智能体配置凭证动态脱敏理论缺失，硬编码漏洞自动化检测体系不完善，开源无原生凭证扫描能力，第三方组件缺乏强制校验规范。研究挑战聚焦于编译期硬编码凭证静态检测、运行时配置凭证动态脱敏与第三方组件凭证安全准入管控。 • 权限管控缺陷：全局访问校验逻辑代码缺陷诱发系统性越权失控：智能体权限代码漏洞主要表现为布尔判定失准、边界条件遗漏等工程缺陷，可直接引发权限绕过、权限篡改、任意指令下发等高危越权行为，彻底击穿顶层安全治理体系 [612]。多条公开漏洞证实，访问校验逻辑缺陷可使低权限用户创建高权限智能体、操控系统指令，造成系统性权限失控。Google Cloud 2026 年研究指出，传统面向人类用户的 IAM 权限体系，无法适配智能体高速、自主、高频的跨工具、跨主体调用场景 [594]。当前权限判定逻辑缺乏形式化验证理论，边界漏洞溯源建模不完善，人工编写的校验代码易引入缺陷且自动化检测覆盖率不足。核心研究挑战为权限代码自动化形式化验证、边界条件漏洞静态挖掘与全局访问权限动态边界加固。

3.4 安全测试评估阶段（安全验证排查）

安全测试评估阶段针对编码交付的程序制品与集成配置开展全域安全核验，主要承接需求、架构、编码全流程遗留的隐性缺陷与边界漏洞。本阶段风险核心不在于新增代码漏洞，而在于传统安全评测体系与智能体动态运行特性严重失配。传统静态用例检测、单点漏洞扫描与离线验证模式，难以适配智能体长时序链式推理、多轮渐进对抗、向量检索交互与多集群协同运行等复杂机制，导致大量隐性漏洞、边界缺陷与渐进式风险在测试阶段被漏检，最终持续流入量产环境，演变为系统性线上安全隐患。结合各模块测试短板、前沿学术研究与工程落地案例，本阶段核心风险与技术挑战归纳如下（详见表 3.4）：

- **智能体全维度模块存在大面积测试盲区，隐性对抗与动态边界缺陷普遍漏检。**感知层缺少标准化隐蔽对抗样本基座与时序评测范式，零宽字符隐写、多层编码混淆与长会话渐进诱导等隐性攻击无法被静态单轮测试完整覆盖，对抗逃逸漏洞留存率高 [640], [641]。记忆层尚未建立覆盖向量嵌入、持久化存储、相似度检索与生命周期销毁的全链路测试体系，向量投毒、相似度越权泄露与残留数据清零失效等深层问题长期处于测试盲区 [642]。决策层缺乏链式越狱、模糊语义边界、长时序合规漂移的专项测试能力，无法有效遍历多轮交互中逐步累积的隐性违规推理路径，难以发现渐进式决策失范风险 [643]。行动层对沙箱逃逸、组合工具恶意调用、长时序权限侵蚀等高危场景覆盖不足，无法有效校验动态风控边界的长期稳定性 [559], [644]。交互层缺少多智能体集群仿真与社工诱导全链路测试能力，接口异常传输、跨主体状态串扰与级联污染风险难以复现排查 [645]。治理层审计存证、动态权限迭代、告警精度等管控能力缺乏统一核验基准，导致治理有效性无法量化评估、兜底能力无法验证 [586], [646]。
- **测试体系能力缺陷沿业务链路分层传导，形成全域量产级安全风险。**感知层动态测试能力不足，隐蔽对抗载荷可稳定突破前置防护，在量产环境中构建持续性入侵入口，为后续纵深渗透提供稳定突破口 [647]。数据层评测维度残缺，无法覆盖向量投毒、跨租户污染与退役残留泄露等隐性风险，形成长期难以根除的数据后门隐患。推理决策层时序动态测试缺失，多轮对话累积的意图漂移与隐性违规推理无法被识别，造成智能体合规边界持续偏移、行为逻辑逐步失控 [615]。执行层红队场景覆盖不全，沙箱逃逸、特权工具滥用等高危操作大量漏检，直接威胁宿主资源与运行环境安全 [616]。多智能体协同仿真测试空白，单节点缺陷可通过集群信任链路横向扩散，诱发批量越权与全域级联污染事件。治理层量化验证机制缺失，全链路溯源、权限收敛与合规审计能力无法核验，进一步放大各层级缺陷的链式传导危害，引发集群级系统性安全风险。这种自上游至下游的链式风险传导，大幅提升了线上安全事件的处置难度。
- **传统测试范式与智能体运行特征严重失配，缺少标准化、可量化专属工程评测体系。**现有测试流程高度依赖静态规则匹配、人工定性判别与单点离线核验，无法适配智能体动态推理、自主演化、长时序交互与集群协同特性，对组合式复杂攻击、渐进式边界侵蚀、隐性绕过等新型威胁检测能力不足，量产漏检风险突出 [648]。行业尚未形成覆盖六大核心模块的统一安全测试规范，缺少分级基准数据集、动态时序仿真平台与多维度量化评级体系，测试结果主观性强、可复现性弱、覆盖粒度粗糙。传统测试手段仅能覆盖显性漏洞，无法捕捉智能体迭代演化产生的动态边界风险，测试完备性严重不足。当前安全验证过度依赖上线流量监测与事后补丁修复，无法在研发阶段实现缺陷闭环阻断，不仅增加版本迭代与运维整改成本，也大幅提升了量产环境不可逆安全事件的发生概率。滞后的测试验收模式，彻底割裂了研发与生产阶段的安全治理联动机制。

表 3.4: AI 智能体安全测试阶段安全问题与研究挑战

模块	安全问题与研究挑战
感知 (输入层)	• 多类型隐蔽对抗输入标准化测试用例库缺失，隐写攻防评测无统一基座：零宽字符混淆、分段语义隐写、畸形载荷与异形编码等隐蔽对抗输入是智能体间接提示注入的重要攻击面，但当前测试样本零散、场景覆盖不足，难以支撑统一量化评测。AgentSentinel 框架验证了标准化样本基座对隐写攻防评测的必要性与可行性 [640]。腾讯朱雀实验室 2026 年构建的 SkillTrustBench 进一步指出，现有安全检测方案普遍存在误报与漏检权衡难题，缺乏适配高级隐蔽对抗样本的评价体系 [649]。目前行业缺失隐蔽样本归一化分布理论与难度分级标注规范，开源与商用平台均无专项高级隐写数据集，评测结果难以横向对标。核心研究挑战为多模态隐蔽对抗样本分级构建、样本分布归一化校准与跨模型通用标准化测试基座研发。 • 时序维度评测范式滞后，多轮上下文诱导测试能力空白：传统安全评测依赖单轮静态样本，无法刻画长会话语义漂移与渐进式诱导风险。链式时序攻击可显著提升越狱成功率，现有单轮防护机制难以抵御时域累积对抗，导致静态测试严重低估智能体真实安全隐患 [641], [647]。微软 2026 年评测研究表明，多轮会话可出现单轮合规、整体违规的隐性异常，且裁判模型差异会进一步导致评估结果不稳定、可信度不足 [650]。当前长时序对抗演化机理与风险累积量化理论不完善，主流评测工具不支持会话状态留存与时序链路复刻，产业缺乏标准化多轮测试流水线。研究挑战集中于长会话对抗轨迹仿真、渐进式风险累积量化建模与状态感知型多轮安全测试框架构建。 • 感知测试无量化度量模型，评测结果依赖定性主观研判：智能体感知层安全评测普遍缺乏统一量化指标，漏洞覆盖、盲区溯源、防御分级缺少工程化度量标准。尽管 Agent Security Bench 等基准体系可支撑多维量化评估，推动评测由定性向定量转型，但尚未形成行业统一落地范式 [648]。Google 2026 年基准研究证实，人工主观评审存在结论不一致、复现性差、标注成本高昂等突出问题，严重制约评测标准化与工程化落地 [651]。目前感知测试覆盖率度量理论、防御分级阈值数学规约、定性一定量转化模型均存在空白，开源工具无覆盖率统计能力，行业评测仍以主观描述为主。核心研究挑战为多维度测试覆盖率建模、防御能力分级阈值标定与定性研判自动化量化转换体系构建。
记忆 (存储层)	• 记忆安全全流程评测体系残缺，五维生命周期测试方法论空白：现有智能体记忆安全测试仅聚焦明文泄露场景，未覆盖存储隔离、检索权限、留存时效、篡改抗性与清零脱敏五大核心维度，无法实现全生命周期风险校验，导致大量隐性权限与时效类漏洞长期漏检 [652], [653]。Google 2026 年机器遗忘审计研究表明，传统黑盒检验难以精准验证数据彻底删除效果，模型扩大会降低检测精度，且存在测试开销大、落地成本高的问题 [654]。目前记忆风险分层建模、五维指标解耦理论与测试优先级体系尚不健全，开源工具仅支持基础泄露检测，缺乏全维度测试能力与统一评测规范。研究挑战为记忆全生命周期风险建模、五维耦合指标解耦评测与轻量化自动化测试流水线构建。单一泄露检测维度无法覆盖生命周期隐性风险，导致权限滥用、数据超期留存等非显性安全问题长期处于测试盲区。传统评测手段缺乏标准化量化指标，难以对记忆安全防护能力进行精细化、可复现的等级评估。 • 嵌入层安全专项测试缺失，向量知识库投毒与越权风险漏测率高：现有记忆评测过度侧重文本安全，长期忽视嵌入层与向量检索风险，未针对向量检索泄露、嵌入样本投毒、越权读取等高危问题设计专项测试方案，导致向量层安全漏洞频发 [655], [656]。AWS 2026 年 AgentCore Memory 架构指出，智能体自主抽取记忆元数据的机制易造成相似样本聚合，进一步放大语义泄露与异常检索风险 [657]。当前高维向量风险检测、投毒溯源与检索泄露量化评估机制存在短板，主流平台缺少智能体专属嵌入层测试能力与标准化投毒检测用例 [658]。核心研究挑战包括高维向量风险特征提取、嵌入式投毒精准溯源与相似度检索泄露量化评测体系研发。高维向量空间的语义模糊性使得传统文本检测规则完全失效，极易绕过常规安全校验机制。向量检索的近似匹配特性易造成隐性隐私扩散，该类风险暂无成熟的量化评测与阻断方案。 • 多租户并发场景测试范式空白，跨域记忆串扰漏洞难以复现：传统测试基于单用户隔离环境，无法适配企业多租户高并发工况，跨租户记忆串扰、状态污染与越权检索等仅能在集群场景触发的隐性漏洞难以复现定位 [655], [659]。阿里云 2026 年记忆安全规范证实，作用域隔离配置缺陷易造成同租户多智能体私密记忆共享，引发批量数据泄露风险 [660]。当前多租户污染传播机理、并发风险触发阈值建模不完善，主流框架仅支持单租户仿真，无法实现并发调度测试，行业高度依赖低效人工压测 [661], [662]。研究挑战聚焦于大规模多租户会话仿真、跨租户记忆污染溯源与并发风险自动化复现机制设计。单租户静态测试环境无法模拟多实例抢占、会话交织的真实业务工况，测试结果失真严重。人工压测重复性差、覆盖度低，难以精准捕捉低概率、高危害的跨租户串扰漏洞。

续下页

表 3.4 – 续上页

模块	安全问题与研究挑战
决策 (推理层)	• 多轮链式越狱诱导标准化测试体系缺失，渐进式攻击场景无法全覆盖：现有智能体决策安全测试以单点越狱用例为主，缺少无害工具链式组合、隐性角色劫持、逻辑陷阱嵌入式诱导等高级对抗场景。尽管 STAC 基准框架验证了链式测试范式的有效性，但尚未实现规模化工程落地，难以完整复现渐进式越狱全链路攻击流程，导致高阶诱导漏洞长期漏测 [663]。AWS 2026 年 Strands Evals 生产评测实践表明，渐进式越狱可依托多轮上下文累积逐步偏移智能体目标，传统固定单轮测试无法稳定复现与度量此类链式攻击路径，难以真实覆盖动态诱导风险 [664]。当前链式越狱意图递进演化、角色状态迁移建模理论不完善，攻防场景归纳体系残缺，开源与商用评测平台均缺失链式用例生成引擎与专项样本库，STAC 基准缺乏工程化适配方案。核心研究挑战为链式越狱意图递进仿真、动态角色劫持场景构建与渐进式越狱全链路自动化评测体系搭建。 • 模糊边界场景测试覆盖不足，隐蔽意图违规推理路径遍历不全：传统决策安全测试高度依赖指令明确的标准用例，未覆盖语义模糊指令、高耦合复杂任务、隐藏意图交互等灰色边界场景，无法量化智能体在歧义语境下的安全约束坚守能力，大量隐性违规推理路径仅在链式执行末端显现，难以被常规测试捕获 [663]。阿里云 2026 年 Agent Security Center 红队测试证实，攻击者可将违规目标封装为正常复杂业务任务，通过多轮逻辑编排生成未知违规推理路径，固定分类样本库无法穷尽边界变异风险 [545]。目前模糊意图不确定性量化判别、复杂任务风险耦合机理、隐性漏洞分类体系存在理论空白，现有用例库缺少模糊语义标签与复杂任务自动生成能力，边界场景整体测试覆盖率极低。核心研究挑战为模糊语义意图量化识别、高耦合任务风险解耦评测与隐蔽违规推理路径全遍历算法设计。 • 决策合规性漂移无量化测试机制，长期自主运行稳定性不可度量：现有评测体系仅支持上线阶段静态合规校验，缺失模型迭代、上下文切换、场景迁移引发的合规性漂移动态测试能力，无法量化智能体长期自主运行过程中决策规则偏移、伦理约束弱化等隐性安全退化现象 [665], [666]。AWS AgentOps 运维实践指出，智能体安全风险具备多轮累积特性，风险贯穿决策、工具调用与记忆检索全链路，需多层级持续时序监测，单次静态校验无法有效评估长期运行稳定性 [667]。当前合规漂移多诱因耦合机理、决策偏移量化度量、长期稳定性预测建模理论不完善，开源无合规漂移监测组件，商用平台仅支持静态合规检测，缺乏长时序动态追踪流水线。核心研究挑战为多因子合规漂移量化建模、长时序决策稳定性动态追踪与场景迁移自适应合规校验机制构建。
行动 (执行层)	• 行动层测试盲区界定缺失，漏测衍生系统性量产安全风险：当前行业尚未明确智能体行动层测试盲区边界，针对高危行为误判、工具组合衍生攻击、层级越权隐匿漏洞均缺乏定向测试规范，基础性测试缺陷易导致量产阶段系统性安全风险爆发 [663]。亚马逊 2026 年智能体工程实践指出，工具参数异常、身份校验及多轮调用顺序等场景若存在测试盲区，漏洞会随大批量 API 工具封装快速扩散，引发规模化安全隐患 [668]。目前行动层漏洞可检测性分类理论、盲区与量产风险传导建模体系存在空白，现有测试体系缺乏盲区自动化定位能力，无组合攻击检测用例与标准化风险清单。核心研究挑战为盲区风险传导量化建模、行动层漏洞可检测性分级与盲区定向补全自动化测试方案构建。 • 高危动作红队渗透评测体系不完善，极端风险场景覆盖不全：AgentRedBench 基准定义了分层沙箱逃逸、精细化权限滥用、批量破坏性操作、自主代码执行四类高危场景，但现有测试仅覆盖基础权限滥用场景，高阶极端攻击普遍漏测，红队评测深度严重不足 [644]。微软 AI 红队全年攻防实验证实，仅依靠单次破坏指令、基础沙箱逃逸等显性场景测试，无法覆盖动作拆分规避、零点击静默执行、跨系统链式扩散等高级风险，难以真实评估智能体极限安全边界 [669]。当前高危动作危害分级、分层逃逸路径归纳、破坏性风险阈值建模理论不完善，开源与商用红队工具场景适配覆盖率低，缺乏高阶攻击复现能力。研究挑战聚焦于高危动作动态危害分级、分层逃逸路径自动化复现与全场景标准化红队评测流水线搭建。 • 工具调用边界多工况稳定性校验机制空白，动态风控可靠性无法验证：现有工具调用测试仅校验静态白名单放行逻辑，未针对多工具链式联动、参数隐性注入等复杂动态工况，验证准入可靠性、拦截精度与风控阈值稳定性，无法提前排查动态运行场景下的风控失效隐患 [194], [666]。阿里云 2026 年 API 安全实践表明，传统静态规则难以区分语义相似的差异化接口字段，易引发误报漏报，人工配置的脱敏与风控策略无法适配接口动态迭代场景 [670]。当前工具链风险叠加机理、隐性参数注入触发机制、动态阈值稳定性评价体系存在空白，主流测试仅支持单工具静态校验，缺乏链式仿真与动态稳定性量化评估能力。核心研究挑战为多工具链式风险仿真、隐性参数注入精准检测与动态风控阈值长期稳定性量化校验。

续下页

表 3.4 – 续上页

模块	安全问题与研究挑战
交互 (协同层)	• 全链路社工诱导测试协议缺失，长时序交互风控有效性无法验证：现有智能体交互测试局限于单点指令对抗，无法覆盖“信任建立—渐进诱导—信息窃取—远程操控”完整社工攻击链路，难以暴露长时序会话中因人机信任累积导致的风控松弛与安全边界退让等隐性缺陷 [665]。微软 2026 年研究证实，隐蔽式记忆操纵可依托常规交互行为植入可信来源标签，使智能体在跨周、跨会话的长期交互中持续产生倾向性违规行为，传统短会话测试完全无法复现此类风险 [542]。当前人机信任动态演化机理与长时序风控衰减量化理论存在空白，开源评测体系缺乏渐进式社工会话生成能力，商用平台仅支持短周期诱导测试，无标准化全链路攻击复现协议。核心研究挑战为动态信任演化仿真、长时序风控衰减量化评测与全流程社工诱导测试协议构建。 • API 接口系统化测试体系残缺，传输层原生漏洞易漏测：现有智能体接口测试侧重功能连通性校验，普遍缺失传输加密完整性、参数边界合法性、防重放机制、非法接入检测四大安全维度的系统化评测，致使接口层原生代码与协议漏洞极易被批量利用 [194]。阿里云 2026 年智能体安全规范强调，流式 SSE 流量、提示注入、系统指令覆盖、接口提权与高频资源耗尽等传输层风险，需要专项实时安全检测能力支撑，传统功能测试体系无法覆盖此类场景 [671]。目前智能体专属 API 攻击面建模与轻量化安全综合评分理论不完善，开源工具无安全专项测试用例，商用功能测试与安全测试相互割裂，缺乏一体化评测流水线。研究挑战聚焦于 API 全域攻击面梳理、轻量化接口安全评级体系构建与功能安全一体化自动化测试框架研发。 • 多智能体协同交互评测方法空白，级联风险放大效应不可量化：现有交互测试依托单智能体隔离场景，缺失多主体集群仿真能力，无法量化信任滥用、横向恶意交互、会话劫持引发的风险级联放大问题，链式污染、全域权限泄露等协同高危风险长期处于测试盲区。微软 2026 年 AI 红队测试表明，智能体集群中单点异常可引发大范围任务重规划与资源重复委派，造成系统性拒绝服务与策略违规，且恶意任务可通过多智能体拆分传播实现隐蔽渗透 [540]。当前多智能体风险级联传播机理与去中心化信任坍塌量化建模存在短板，行业无开源集群仿真评测平台，商用多智能体系统缺乏横向交互安全测试规范。核心研究挑战为大规模智能体集群仿真、跨主体风险级联量化评估与去中心化协同安全评测基准搭建。
治理 (管控层)	• 全链路审计测试体系缺位，日志防篡改与追溯能力无法核验：现有智能体治理测试仅校验基础日志生成能力，未覆盖推理、记忆、工具调用、会话交互及权限变更全流程审计维度，Auditable Agents 等全链路审计框架尚未落地为标准化评测规范，导致日志完整性、防篡改性与行为追溯能力缺乏有效核验手段，存在取证与合规复盘盲区 [646], [666]。AWS 2026 年治理实践指出，传统 API 级日志仅可记录外部调用行为，无法溯源智能体内部决策动因，完整审计必须联动模型提示输入、推理上下文与自定义执行步骤 [672]。当前分层日志防篡改量化理论、隐性推理行为溯源存证模型存在空白，开源审计工具仅支持显性日志检测，无推理层存证校验能力，主流审计框架缺乏量产适配工具。核心研究挑战为全链路日志完整性分级校验、隐性推理行为存证测试与审计取证有效性量化评级体系构建。 • 动态权限治理评测机制空白，自治智能体权限风险无法精准检测：传统权限测试依赖静态台账校验，无法适配自主智能体动态授权、权限变更的运行特征，难以识别权限残留、层级溢出、跨域越权传导等动态风险 [666]。SkillGuard 框架可实现动态权限分配、时效回收与风险收敛的全流程管控，但现有行业评测范式无法适配其动态防护逻辑 [586]。阿里云 2026 年 Agent ID Guard 安全实践证实，智能体跨角色权限借用、离职残留凭证存续等动态权限问题，会引发持续性越权数据泄露风险 [673]。目前动态权限生命周期风险建模、权限收敛有效性量化理论不完善，开源与商用测试工具均为静态校验模式，缺失动态时序追踪能力，管控框架无配套评测插件。研究挑战聚焦于动态权限全生命周期仿真、权限残留风险定向检测与跨域越权传导路径溯源评测。 • 异常行为告警无统一评测基准，告警性能无法横向对标：当前智能体异常告警体系缺乏行业统一量化指标，准确率、召回率、误报率等核心性能参数无标准化统计口径，方案横向对比与性能优化缺乏依据。GammaF 基准可实现隐性攻击与集群协同异常的告警量化评测，但未形成通用行业规范，场景适配覆盖率有限 [674]。阿里云 2026 年 RCA Benchmark 研究表明，传统静态故障评测方式无法有效识别异常传播链路，仅依靠单点日志匹配的评测结果可信度极低，难以真实衡量告警体系的溯源与预警能力 [675]。目前隐性异常特征表征理论、多指标综合告警评价模型存在空白，各厂商指标定义私有化，行业无统一开源评测底座。核心研究挑战为隐性异常行为特征提取、多维度告警性能综合评级与跨平台通用告警评测基准搭建。

3.5 部署交付阶段（安全环境固化）

部署交付阶段承接安全测试评估阶段放行的合规程序制品，将前序全链路漏检遗留的程序缺陷与结构性短板，固化至生产集群环境中，形成规模化、常态化的生产态安全问题，是研发端安全短板向运营端传导的关键过渡枢纽环节。该阶段主要完成智能体程序制品集群迁移、环境配置、基线固化、组网部署与业务流量接入，测试漏检漏洞、架构耦合缺陷、编码原生脆弱点会随工程交付流程批量迁入生产集群。区别于研发前置阶段的原生漏洞，本阶段风险以**生产配置型稳态缺陷**为主，主要由测产环境异构、安全基线缺失、配置规范失控、制品供应链污染、治理组件投产不同步等部署行为引发，具备环境强绑定、全域批量复制、长期稳态留存、整改成本极高的特征。结合各模块部署落地短板、现有学术研究与工程实测案例，本阶段核心安全问题与工程挑战梳理如下（详见表 3.5）：

- **智能体各模块生产安全隐患集中源于部署基线缺失与环境配置异化，是生产态专属内生风险的核心诱因。**感知层因可解释性治理管道碎片化、测产评测基准割裂，生产推理黑盒问题突出，安全事故归因溯源失效，动态风险无法形成闭环管控 [676], [677]。记忆层普遍存在多租户混存部署、存储加密缺失、粗粒度静态权限全开等配置问题，引发批量隐私泄露、长效记忆投毒与跨租户越权检索风险 [600], [652]。决策层安全约束跨环境迁移失效、供应链制品校验缺失、推理超参数测产异构漂移，导致生产环境合规护栏失效、隐性后门植入与推理行为偏移 [678], [679]。行动层默认宽域授权、沙箱部署完整性未核验、工具白名单管控松散、测试冗余权限残留迁移，持续放大集群权限滥用与沙箱逃逸风险 [513], [587]。交互层网关明文传输、会话防护机制脆弱、多租户零信任边界缺失，极易诱发集群级会话劫持与横向串扰攻击 [680], [681]。治理层组件异步投产、异构环境催生影子配置、交付准入门禁缺失，造成生产系统治理裸奔、配置持续漂移与变更行为失控 [608], [682]。
- **部署层缺陷遵循生产固化逻辑逐级传导，形成数据固化、推理偏移、执行溢出、全域失控的层级化集群风险。**感知运维适配域治理链路断层、评测维度割裂，导致生产动态风险无法溯源、研发迭代整改闭环断裂，隐性缺陷长期滞留生产环境 [683]。数据存储固化域隔离、加密、权限基线缺失，将单体研发漏洞固化为集群批量数据泄露与持久性记忆污染隐患 [684]。推理决策保真域受供应链篡改、参数异构、约束重置影响，从内核层面破坏智能体决策可信基底，引发全域合规失效风险 [685]。系统执行授权域最小权限原则失守、沙箱隔离缺陷固化，直接引发容器逃逸、主机权限滥用等集群级破坏性风险。多域通信边界域零信任管控缺失、网关防护薄弱，促使单点漏洞横向扩散，诱发多智能体级联入侵与全域数据泄露 [686]。全环境治理稳态域基线管控失效、配置漂移累积，逐层消解前置研发、测试阶段的安全治理成果，形成系统性生产安全敞口 [687]。
- **现有交付流程缺乏强制部署固化机制与量产治理范式，测产异构衍生大量次生安全风险。**当前行业交付高度依赖人工运维配置与上线后被动加固，未构建投产前置安全门禁与自动化基线校验机制，测产环境异构差异无法有效管控，衍生出大量研发阶段未暴露的隐性次生缺陷 [688]。依靠上线后流量监测、事故回溯、运维整改的被动治理模式，无法从环境根源解决配置异化、基线破损、供应链污染等稳态问题，易触发全域系统性安全事件，且集群重构、基线整改的工程成本远高于研发阶段漏洞修复 [20]。目前学界与产业界尚未形成智能体专属生产安全基线规范，缺少容器化固化模板、制品全链路校验流水线与稳态运维标准，无法实现安全约束跨环境保真迁移、高危配置自动拦截，制约了高可信、可复刻、稳态可控的规模化生产交付体系落地 [689]。

表 3.5: AI 智能体部署交付阶段安全问题与研究挑战

模块	安全问题与研究挑战
感知 (输入层)	• 感知层推理黑盒可解释性缺失，生产事故根因归因失效：智能体自主推理链路存在黑盒缺陷，仅可观测最终输出，难以定位中间推理异常，导致安全事故溯源归因困难 [676]。现有 XAI 体系存在显著短板：AgentSHAP 难以适配工具调用场景 [690]，STAR-XAI 仅支持部署前静态解释 [677]，推理轨迹与决策结果存在因果解耦、解释失真、虚假高忠实性等共性问题 [691], [692], [693]。AWS 2026 年生产案例表明，智能体任务性能波动难以通过传统评测定位根因，人工排查成本极高 [694]。目前工具型智能体因果解释理论、推理解耦建模、解释忠实性校验体系尚不健全，开源与商用可解释模块普遍存在适配不足、可信度虚高问题。核心研究挑战为构建多范式融合可解释架构、实现因果推理轨迹溯源与全时段解释忠实性动态校验。现有解释模型无法适配智能体多轮迭代、工具交互的动态推理特性，静态解释结果与实时决策严重脱节。 • 端到端治理管道碎片化，动态感知风险无闭环管控：主流 AGENTS SAFE 治理架构以静态规则治理为主，缺乏适配智能体动态运行特性的端到端管控流水线，无法覆盖动态风险识别、实时拦截与审计问责全生命周期链路，难以应对运行时对抗输入与状态突变威胁 [688], [689]。阿里云 2026 年企业 SOC 实践证实，传统安全体系存在日志割裂、告警冗余、无法关联攻击链等缺陷，难以支撑智能体动态风险闭环治理 [695]。当前动态风险生命周期治理理论、静态架构动态适配范式存在空白，现有治理组件碎片化严重、联动能力弱。研究挑战聚焦于动态风险全链路建模、静态治理架构动态化重构与风险治理一体化流水线构建。各安全治理模块独立运行、数据不通，无法形成风险发现、处置、复盘的完整闭环。 • 部署度量基准维度割裂，测评结果无法反向倒逼研发整改：现有 RAS-Eval、ST-WebAgentBench 等评测基准维度分散，未统一融合功能安全、对抗鲁棒性、数据隐私与自主行为多维度量化体系 [683], [696]，造成测试与研发整改链路断裂，底层漏洞持续遗留至生产环境。Google Cloud 2026 年研究指出，传统固定阈值评测无法刻画智能体失效边界与性能衰减规律，难以精准指导安全迭代优化 [697]。目前跨维度安全度量归一化理论、测评-研发联动溯源模型缺失，各基准体系独立割裂、无统一产业评分规范。核心研究挑战为多维安全基准融合归一化、部署与研发风险联动建模及闭环整改倒逼机制构建。单一维度测评无法全面量化智能体综合安全能力，极易出现局部安全达标、整体存在隐性风险的问题。缺乏标准化的缺陷分级与整改优先级定义，测评发现的安全问题难以落地闭环整改。传统评测体系重结果打分、弱过程溯源，无法精准定位引发安全缺陷的代码与逻辑模块。
记忆 (存储层)	• 混存部署引发敏感记忆泄露，租户隔离架构配置缺失：当前智能体部署普遍存在敏感记忆、隐私凭证、向量知识库与普通业务数据混存问题，缺失租户命名空间强隔离机制，极易引发跨用户、跨应用上下文泄露 [655]。细粒度访问控制缺失会扩大敏感记忆暴露面，显著提升跨会话信息泄露与数据残留风险 [652], [659]。AWS 2026 年医疗多租户智能体方案强调，底层记忆资源共享场景下，必须叠加分级命名空间与 IAM 属性管控，否则会出现跨租户会话历史泄露隐患 [698]。目前记忆敏感度分级理论、租户隔离与泄露耦合机理建模存在空白，开源框架默认全局混存，商用多租户隔离粒度粗放。核心研究挑战为记忆敏感度自动分级、细粒度租户命名空间隔离及抗泄露存储架构构建。 • 端到端加密部署缺位，介质劫持引发批量数据外泄：多数生产环境仅开启传输层加密，未落地静态存储固化加密，向量嵌入等可反演敏感数据长期裸存，易遭受未授权读取与介质劫持攻击。Trojan Hippo 等记忆木马攻击可实现长期隐蔽驻留，未加固部署会大幅放大批量数据泄露风险 [600]。阿里云 2026 年 Data Agent 安全规范要求构建传输加密、凭证加密、网络闭环与会话销毁的全链路防护体系，单一环节加密无法抵御系统性数据外泄 [699]。当前传输-存储一体化轻量化加密理论、抗木马加密防护机理不完善，开源默认关闭存储加密，商用版本无强制固化加密基线。研究挑战聚焦于无感端到端轻量化加密流水线、存储层木马溯源防护与加密策略强制部署机制设计。 • 粗粒度权限部署泛滥，诱发越权检索与长效记忆投毒：主流智能体依赖粗粒度静态访问控制，缺失任务上下文动态授权能力，普遍存在跨会话越权检索与敏感记忆非法访问风险 [700]。长期记忆机制可固化恶意污染内容，单次投毒可跨会话持续干预智能体推理、工具调用与安全决策，隐蔽性与持续性风险难以被传统单次校验机制识别 [662], [684]。微软 2026 年记忆安全研究证实，分散式多轮恶意记忆可后续重组触发持续性违规行为，长效污染危害极强 [701]。当前权限动态收敛理论、记忆投毒长效传播建模存在短板，开源无细粒度授权模块，商用权限策略静态固化且缺乏投毒溯源校验。核心研究挑战为上下文动态权限调控、记忆数据密码学溯源及长效投毒污染阻断清除机制构建。

续下页

表 3.5 – 续上页

模块	安全问题与研究挑战
决策 (推理层)	• 合规约束部署重置失效，生产环境决策防护裸奔：智能体部署阶段承接模型安全对齐能力，是维持决策层安全约束持续生效的关键环节，但其防护效力易受用户滥用、模型失配与配置缺陷影响 [678]。行业普遍存在安全护栏、伦理约束在模型迁移、环境切换与打包部署过程中失效的问题，生产环境过度依赖模型原生对齐能力，外部动态决策约束完全缺位 [666]。自主智能体长效运行需要持续治理机制保障安全策略与运行环境适配性，而静态部署范式无法满足该需求 [689]。AWS 2026 年研究表明，多轮智能体全流程存在链式安全风险，输入注入、中间推理污染、敏感数据泄露等隐患分阶段存在，单一固化约束无法覆盖全流程防护需求 [535]。当前决策约束跨环境迁移保真理论、部署重置触发机理研究不足，开源部署无约束固化逻辑，商用平台默认重置自定义护栏规则。核心研究挑战为不可变决策约束层架构设计、跨环境约束迁移保真与实时合规校验机制构建。 • 供应链部署完整性失控，模板篡改诱发隐性后门：智能体供应链面临数据投毒、模型后门、环境篡改等多层级系统性威胁，从底层破坏智能体决策可信性 [685]。除模型权重篡改外，部署模板、配置文件与第三方依赖组件的隐性篡改，可在不改动核心模型的前提下篡改系统行为，成为高频隐蔽攻击入口，现有校验体系存在明显盲区 [679], [682]。Google 2026 年安全监测发现，tasks.json、Skill.md 等常规部署配置文件可被植入恶意指令，实现无感知代码执行与密钥窃取，且长期规避传统安全检测引擎识别 [702]。目前轻量级模板篡改溯源理论、多层级供应链联动校验模型存在空白，开源无完整哈希校验流水线，商用校验仅覆盖模型权重，遗漏配置与模板防护。研究挑战聚焦于全制品链签名校验、隐性模板篡改精准溯源与供应链分层防篡改部署架构研发。 • 推理参数环境漂移，引发“测产异构”安全偏差：测试与生产环境的算力资源、推理参数、运行上下文差异，会导致智能体安全行为偏移，使离线评测结果无法映射真实生产风险，形成测产异构安全偏差 [682]。现有安全评测聚焦固定工况下的风险验证，缺乏参数变动、环境迁移引发的行为漂移量化建模能力，行业无统一参数安全基线与环境一致性校验机制。AWS 2026 年生产运维实践证实，模型迭代、用户行为更迭、提示词场景复用等因素会引发智能体安全性能持续漂移，低频人工调参与周期性测试无法适配动态演化风险 [703]。当前超参数与决策安全关联量化理论、环境漂移预测建模不完善，开源缺乏合规配置模板，商用平台参数管控粒度粗放。核心研究挑战为推理参数安全阈值标定、环境异构漂移量化预测与全域标准化参数基线部署规范构建。
行动 (执行层)	• 默认宽域授权泛滥，违背最小权限部署基线：主流开源与商用智能体普遍采用静态全域一次性授权机制，默认宽域开放权限，系统性违背最小权限部署原则，权限合并授予、会话延迟销毁等反模式广泛存在，显著放大工具调用与系统指令滥用风险 [513]。微软 2026 年部署安全研究指出，智能体权限常由低风险逐步扩张至高风险写入、删除与跨系统操作且缺乏持续审计，低权限能力可组合形成高危权限链路，同时任务结束后权限无法自动收敛，造成长期权限冗余隐患 [704]。当前任务驱动动态权限收敛理论、授权反模式风险分级建模存在空白，行业缺乏动态权限管控规范。核心研究挑战为构建细粒度任务级授权架构、实现运行时权限动态收敛及授权反模式自动化检测修复机制。静态授权模式无法适配智能体多任务动态交互场景，权限生命周期与业务任务生命周期完全脱节。冗余常驻权限构建了持续性攻击面，极易被恶意指令诱导触发链式越权风险。 • 沙箱部署校验缺失，跨环境隔离屏障易被穿透：沙箱作为智能体行动层核心隔离屏障，存在部署阶段策略迁移丢失、环境边界易被穿透等固有缺陷，环境交互漏洞可诱导非预期高危行为，仅依靠模型自身安全能力无法抵御系统级风险 [705]。阿里云 2026 年 FC 沙箱安全规范明确，沙箱并非绝对可信环境，逃逸代码仍可读取环境变量、访问放行网络、窃取接触数据并消耗系统资源，存在常态化数据外泄与资源滥用风险 [706]。目前沙箱策略跨环境迁移保真理论、涌现性隔离风险量化模型不完善，开源沙箱无部署完整性检测模块，商用策略迁移易失真且缺乏快照回滚能力 [707]。研究挑战聚焦于沙箱部署完整性闭环校验、跨环境策略保真迁移与攻击快照自动化回滚防护体系构建。 • 工具白名单管控松散，高危操作无强制拦截约束：工程部署普遍存在工具白名单规则残缺、高危组件未封禁、批量操作无阈值限制等突出漏洞，未固化显性安全准入规范，运行时可动态新增高危工具与权限入口，攻击者可通过会话操控突破行动层安全边界 [513]。阿里云 2026 年智能体防护基线证实，恶意插件与技能可嵌入隐蔽高危指令，诱导智能体执行隐私窃取、数据破坏与权限滥用操作，需严格限制插件能力、封禁高危工具并阻断恶意执行链路 [569]。当前工具风险分级准入理论、动态权限追加预判建模存在短板，行业默认白名单管控宽松，缺乏高危封禁模板与运行时权限锁定机制。核心研究挑战为构建风险分级工具白名单、实现运行时权限固化锁定与批量高危操作动态阈值拦截机制。

续下页

表 3.5 – 续上页

模块	安全问题与研究挑战
交互 (协同层)	• 网关明文中转漏洞，集群交互风险指数级放大：多智能体集群交互催生全新信任边界与攻击面，跨主体通信、全域攻击扩散、跨域数据泄露等系统性风险凸显，传统单用户安全边界模型不再适用 [705]。智能体跨主体、跨服务交互链路缺乏刚性管控，攻击者可利用交互信任缺陷实现恶意行为横向传播 [707]。阿里云 2026 年治理核查指出，AgentRuntime 自定义域名需人工配置证书，未启用 HTTPS 协议时全部交互数据明文中转，极易被截获与篡改 [708]。当前集群级风险级联传播理论、网关明文漏洞系统化防护体系不完善，开源网关缺失 TEE 原生加密能力，商用加密配置依赖人工部署，极易出现配置遗漏。核心研究挑战为构建 TEE 安全交互网关、实现集群风险级联阻断与端到端无明文传输加密链路。明文传输链路缺失数据完整性校验机制，无法抵御中间人劫持与恶意篡改攻击。 • 概率性会话防护脆弱，高级上下文攻击无法抵御：现有智能体会话防护依赖随机数、时间戳等概率性校验机制，完整性约束能力薄弱，难以抵御上下文操控、跨会话污染、会话劫持等高级攻击 [705]。传统会话机制未适配智能体多轮工具调用特性，上下文状态长期暴露，易被渐进式组合攻击突破安全对齐边界 [709]。目前轻量化密码学会话认证理论、上下文复用攻击溯源建模存在空白，开源框架默认采用脆弱概率性校验，无刚性凭证认证模块，商用加固方案算力开销过高、难以落地 [710]。研究挑战聚焦于轻量化密码学会话凭证设计、确定性完整性校验机制构建与跨会话劫持溯源阻断体系研发。概率性校验机制不具备抗重放、抗伪造能力，会话安全稳定无法保障。 • 零信任边界管控缺失，多租户横向串访失控：多租户智能体集群普遍存在内外网边界管控松散问题，缺失面向智能体身份、工具权限与上下文状态的动态零信任隔离机制，易引发跨租户横向访问与越权数据泄露风险 [705]。AWS 2026 年多租户 AgentCore 安全规范强调，租户请求需严格限定私有网络来源并配置精细化资源策略，依靠显式授权实现全域访问收敛，杜绝隐式通行权限 [711]。当前多主体动态边界划分、横向风险传播建模理论不完善，开源平台无东西向流量管控能力，商用零信任方案部署复杂、普及率极低 [707]。核心研究挑战为实现智能体动态边界自主划分、强弱身份联动准入控制与内网横向移动精准阻断架构构建。静态网络边界隔离无法适配智能体动态协作、跨节点流转的交互特性。
治理 (管控层)	• 治理组件异步投产，线上系统裸奔运行普遍：智能体研发至生产交付全流程覆盖制品、流程与社会技术多维度治理风险，是安全事故高发关键阶段 [608]。行业普遍存在审计、监控、告警等治理组件滞后于业务本体投产的问题，大量线上智能体缺失日志溯源、行为审计与风险感知能力，长期处于无防护、无追责的裸奔运行状态 [687]。传统静态碎片化治理框架无法适配智能体自主涌现的动态风险特征，防护适配性严重不足 [689]。阿里云 2026 年 WAF 防护规范指出，新建智能体资源若未及时绑定防护模板，将处于无效未防护状态，形成常态化治理空窗 [712]。当前组织级一体化治理理论与涌现风险分层管控模型存在空白，开源治理组件碎片化严重、缺乏同步部署流水线，商用一体化方案成本高、落地率低。核心研究挑战为构建业务-治理联动部署架构、实现动态涌现风险管控与组织级全链路安全治理底座。 • 环境异构配置漂移，隐蔽影子配置难以纠偏：开发与生产环境的算力差异、参数不一致、依赖版本异构，会引发智能体运行状态与安全策略失配。智能体持续工具调用与外部交互会进一步放大配置偏差，导致系统性风险逐级累积 [705]。现有治理体系缺乏运行态一致性校验能力，无法持续识别上下文变更诱发的隐性配置漂移问题 [707]。微软 2026 年 ShadowAI 治理能力证实，现有平台仅可局部识别未受管控智能体，阻断设备覆盖有限、策略传播延迟极高，难以实现全域实时纠偏 [713]。目前配置漂移涌现机理、影子配置生成传播建模不完善，开源无配置一致性比对工具，商用平台仅支持显性参数检测，无法识别隐性影子配置偏差 [710]。研究挑战聚焦于全量配置基线实时比对、隐性影子配置精准识别与配置漂移自动修复闭环机制构建。 • 交付准入门禁缺失，全链路变更无机器级约束：当前智能体交付流程过度依赖人工评审，缺失模型、工具权限、运行配置、外部依赖的机器可验证准入机制，全链路变更缺乏自动化合法性约束。智能体风险已延伸至工具调用、环境交互与系统执行层面，仅靠人工审核无法拦截绕过式异常变更与隐性恶意载荷。Google Cloud 2026 年 GKE 安全蓝图强调，生产交付必须依托镜像签名校验与准入 Webhook 实现机器级强制裁决，纯人工审批无法抵御未验证组件与非法配置流入生产 [714]。目前智能体交付信任本体建模、自动化准入裁决体系存在短板，行业无开源机器验证门禁工具，交付链路普遍缺乏证书化、可溯源的强制校验流程 [705]。核心研究挑战为构建智能体信任证书体系、设计分层准入裁决机制与实现全链路变更机器级强制校验能力。

3.6 运行迭代阶段（动态对抗演化）

运行迭代阶段承接部署交付阶段固化的生产环境基线与配置短板，是智能体全生命周期中安全缺陷动态演化、时序累积、跨域扩散的核心环节。前置各阶段遗留的静态结构性与程序性缺陷，会在智能体长期在线交互、自主推理迭代、多主体协同运行中持续激活变异，演化出区别于研发阶段原生漏洞的动态涌现型安全风险。本阶段安全问题归属于**内生动态涌现型缺陷**，由智能体自主运行特性与传统静态防护范式错配引发，存在安全规则时序老化、自主行为漂移、对抗样本动态演进、集群风险链式传播等问题，使原有低危害静态短板持续升级为高危动态隐患。结合各模块运行态演化特征、前沿学术研究与线上工程实测案例，本阶段核心安全短板与工程挑战归纳如下（详见表 3.6）：

- **智能体全模块运行安全隐患源于动态运行特性与静态防护体系失配，是自主迭代催生的原生内生风险。**感知层静态防护规则无法适配线上对抗样本闭环演进规律，安全护栏随时序老化漂移，未知攻击检测效能断崖式衰减，传统离线重训模式难以实现实时自适应优化，线上误漏报问题持续累积 [715], [716]。记忆层缺少运行态动态风险测绘与前置清洗机制，隐性记忆投毒、定向窃取与语义污染问题频发，叠加多租户混存架构缺陷，形成自我强化的持续性数据安全隐患链路 [571], [653]。决策层静态安全红线与时序管控机制无法适配长时序累积诱导与自主行为迭代特征，链式越狱、无感知合规漂移、自治能力溢出问题高发，隐性违规行为难以预判拦截 [717], [718]。行动层沙箱隔离强度随时序自然衰减，静态授权冗余累积形成不可逆权限风险池，隐秘工具调用可规避审计溯源，持续引发逃逸与越权风险 [559], [719]。交互层长时序社工诱导、集群信任拓扑污染、长会话状态漂移问题突出，可依托集群信任关系横向扩散，持续扩张全域攻击面 [720], [721]。治理层审计底座存在固有 TOCTOU 时序漏洞，静态规则体系无法适配涌现性未知风险，防护迭代滞后于攻防演进，全域治理效能持续衰减 [722], [723]。
- **运行层安全缺陷遵循自主演化解剖逻辑分层传导，呈现单点滋生、时序累积、全域扩散的层级化集群风险。**时效感知防护域静态规则适配不足，使动态演进型对抗载荷可顺畅穿透入口防御，形成常态化初始入侵通道 [724]。迭代数据污染域依托记忆自主读写迭代特性，完成恶意记忆自强化闭环传播，催生持续性隐私泄露与语义漂移隐患，难以彻底清零修复 [642]。涌现决策偏移域适配自主推理演化特征，时序累积诱导与隐性合规漂移持续侵蚀安全基线，引发无感知系统性决策失范 [725]。累积执行隐患域随在线运行持续叠加权限冗余、沙箱衰减、操作规避缺陷，极易触发容器逃逸、主机提权等集群级破坏性风险 [726]。全域拓扑传导域依托多智能体集群信任拓扑，实现单点隐患横向渗透与级联污染，诱发全域集群安全崩塌 [540]。长效治理退化域受静态规则滞后、审计链路缺陷、策略迭代不足影响，持续消解前置治理成果，导致动态风险缺乏有效兜底管控，形成系统性安全敞口 [727]。
- **现有运维治理体系依赖后置被动处置，缺失适配动态演化特性的自适应治理范式。**当前行业主流运维模式以静态补丁更新、下线整改、事后复盘为主，未构建适配智能体时序老化、自主演化、风险涌现的动态前置管控体系，静态防护效能随运行时长持续衰减，难以预判拦截未知动态威胁 [717]。现有防护架构缺少免重训自适应优化、风险共识阻断、时序漂移预警与集群联动防护能力，仅能在安全事件爆发后应急处置，无法实现动态风险的事前预判、事中纠偏与闭环阻断 [723]。目前学界与产业尚未形成覆盖六大模块的标准化动态运维规范与时序治理体系，缺少适配智能体自主迭代的动态安全基线与自适应机制，无法实现防护能力与攻防演进、智能体行为演化的同步迭代，难以根治运行态内生涌现缺陷，制约了高可信智能体规模化稳态运营落地 [722]。

表 3.6: AI 智能体运行迭代阶段安全问题与研究挑战

模块	安全问题与研究挑战
感知 (输入层)	• 动态对抗样本持续演进，静态防护架构存在范式级脆弱性：攻击者依托线上流量闭环迭代生成新型对抗样本，通过多层文本扰动、多模态隐性诱导绕过传统静态防护，离线固定防御范式无法适配动态演化的线上攻击场景 [715], [728]。置换不变性对抗攻击、ForgeDAN 复合隐蔽提示等新型攻击逃逸率高，可在生产环境高效穿透且难以被静态体系检出，凸显静态防护的固有缺陷 [724]。Google Cloud 2026 年研究表明，AI 加速漏洞迭代演化，单一静态模型无法覆盖动态威胁，需依托多模型联动监测新型攻击 [729]。当前线上对抗演化动力学、多模态攻击机理与防护泛化衰减理论存在空白，现有防护体系高度依赖静态规则，无法适配线上样本迭代与多模态攻击场景。核心研究挑战为真实流量驱动的动态样本生成、多模态隐性攻击溯源及动静融合一体化防护体系构建。静态规则库无法实时跟进新型对抗样本迭代节奏，防御泛化能力存在天然边界。 • 安全护栏时序老化漂移，未知攻击检测能力断崖式衰减：智能体长期运行过程中，受环境迭代、模型更新与攻击演进影响，静态安全护栏持续老化漂移，固定适配的防御机制难以抵御自适应攻击，未知威胁检测能力大幅衰减 [705], [710]。AWS 2026 年 Bedrock 防护实践指出，多模型异构架构下统一策略适配难度极大，现有网关重输入、轻输出，静态阈值无法适配动态业务与攻击分布，持续累积安全盲区 [730]。目前护栏老化机理、时序适配量化与漂移预判理论尚不健全，开源框架缺乏时序追踪能力，产业无成熟的护栏老化量化评估体系与分级标准 [707]。研究挑战聚焦于护栏全生命周期量化建模、老化漂移临界预警与时序规则自适应校准体系研发。安全策略与实时攻防环境持续失配，导致防护精度随运行时长持续退化。 • 线上感知监测体系失衡，误漏报双重缺陷制约生产可用性：现有智能体线上监测体系防护覆盖不全，攻击者可通过工具调用、外部数据引入与上下文操控绕过检测规则，单一监测机制难以平衡动态攻防适配与业务可用性需求 [707]。阿里云 Agentic NDR 数据证实，传统正则与关键词匹配无法识别多态混淆、多层编码隐蔽攻击，难以区分测试与真实泄露行为，造成告警冗余、漏报频发，抬高运维成本并拖累生产效率 [731]。当前误漏报耦合机理、多维度风险归因量化体系存在研究空白，开源工具仅支持基础日志采集，商用平台告警聚合能力弱、落地成本高 [705]。核心研究挑战为误漏报联动抑制算法设计、精细化风险归因评估与轻量化高可用线上监测架构构建。
记忆 (存储层)	• 动态记忆架构风险集中爆发，黑盒窃取与定向污染危害突出：自适应动态记忆架构为智能体主流部署方案，同时集中暴露隐私泄露、记忆投毒与语义漂移三类核心运行态风险，严重制约规模化落地应用 [571]。MEXTRA 攻击可实现零权限黑盒私有记忆窃取，MemoryGraft 能够植入恶意经验引发跨会话行为偏移，现有架构普遍缺失运行态全域风险测绘能力 [623], [732]。AWS 2026 年披露的 CVE-2026-15746 漏洞表明，智能体记忆工具可暴露后端地址、云标识与 API 密钥，攻击者通过恶意提示即可诱导工具外联泄露核心凭证 [733]。当前动态记忆风险机理、溯源建模、漂移量化理论存在空白，开源框架无风险测绘模块、学术原型未落地，产业难以识别隐性记忆风险。核心研究挑战为构建全时序动态风险测绘算法、实现黑盒窃取阻断与语义漂移量化治理架构。动态记忆的自适应更新机制缺乏安全约束，极易被恶意样本牵引发生持续性语义偏移。 • 低门槛记忆投毒泛滥，前置防护缺失导致溯源困难：现有智能体记忆体系存在低门槛投毒漏洞，普通用户交互即可完成恶意记忆注入，攻击成功率超 95%，长期干扰智能体运行决策 [653]。记忆投毒具备隐蔽潜伏、自强化传播、跨会话生效特征，传统后置审计难以溯源拦截 [642]。记忆写入链路缺少前置清洗与动态隔离，恶意样本可直接持久化留存。AWS 安全架构警示，会话与身份字段可控将导致批量植入虚假记忆，长期操控智能体决策逻辑 [734]。目前投毒机理、传播模型、溯源约束理论不完善，产业高度依赖事后被动排查。研究挑战聚焦于记忆前置脱敏隔离、低门槛投毒精准拦截与溯源闭环机制构建。现有写入校验机制仅做格式合规性检测，不具备语义级恶意内容甄别能力。 • 污染记忆闭环传播，多源验证阻断机制缺失：恶意记忆依托上下文交互与相似检索持续复用，形成跨会话闭环传播链路，篡改推理逻辑与工具调用策略，放大行动层攻击面 [623], [735]。污染记忆可混入正常上下文实现无感知迭代演化，大幅提升甄别清理难度。AWS Agentic AI Lens 安全规范强调，记忆写入需分层校验，缺失多维验证将引发跨任务、跨集群链式污染扩散 [736]。当前污染传播动力学、轻量化多源验证模型存在空白，行业缺乏标准化阻断治理策略 [653]。核心研究挑战为污染传播动态建模、轻量化共识算法设计与运行态污染闭环阻断方案研发。向量相似度检索机制将持续召回污染样本，形成自我强化的恶性传播循环。全局记忆池无版本溯源与一致性校验，污染问题难以彻底清零修复。

续下页

表 3.6 – 续上页

模块	安全问题与研究挑战
决策 (推理层)	• 长时序链式越狱涌现，静态护栏无法抵御累积式诱导：智能体自主规划推理具备显著的时序累积与涌现特性，攻击者可将恶意意图拆解为多轮无害交互，通过渐进式上下文诱导逐步突破静态决策约束，使单轮安全校验完全失效 [557], [737]。OpenAI 2026 年攻防实践指出，高级提示注入已趋近社会化工程攻击形态，传统输入层 AI 防火墙仅能识别显性恶意载荷，无法感知跨轮次风险累积与隐性意图演变，链式分步诱导可逐轮绕过固定护栏规则，最终触发越权执行 [738]。当前时序风险累积机理、链式越狱涌现建模与自适应规避理论存在空白，开源工具仅支持单轮显性违规检测，商用护栏缺乏时序链路分析与动态拦截能力 [643]。核心研究挑战为构建全生命周期越狱攻防演化模型、实现时序累积风险动态拦截与学习型对抗防御机制。 • 无感知隐性决策漂移，违规行为隐蔽性强预判困难：智能体长期在线运行过程中，持续的工具调用、上下文迭代与外部信息交互会引发隐性行为偏移，决策轨迹逐步偏离安全边界，单步单点检测机制难以捕捉渐进式风险演化过程 [718]。Google Cloud 2026 年生产评测体系证实，决策漂移多为长期微量累积导致的系统性偏移，涵盖推理路径、工具选择与上下文理解的全方位偏差，仅校验最终输出无法提前预判临界风险，只能在高危事故爆发后被动复盘 [739]。目前隐性漂移诱发机理、无感知违规特征表征、未观测风险上界量化理论不完善，开源平台无漂移预警能力，安全预测模型尚未工程化落地 [705]。研究挑战聚焦于漂移临界点精准预判、隐性违规行为特征提取与未知风险量化评估体系构建。 • 自主自治能力溢出，静态安全红线长效约束失效：智能体在持续运行中自主规划、任务调度与工具调用能力动态迭代扩张，极易突破预设静态安全边界，引发越界推理、违规调度等系统性风险。智能体安全约束已由传统模型输出管控，延伸至规划、记忆、工具交互全链路系统级治理，固定安全红线无法适配动态自治能力演进 [705]。AWS 企业落地实践总结表明，自治能力迭代速度普遍快于安全管控能力迭代，静态权限边界与固化约束规则难以长效压制智能体越界自主行为，亟需动态适配的管控体系 [740], [741]。当前自治能力溢出演化规律、动态安全红线校准理论存在空白，开源框架均采用静态固化配置，缺乏自适应校准与动态约束模块。核心研究挑战为自治能力演进轨迹建模、安全红线动态校准机制与自主推理越界实时拦截体系研发。
行动 (执行层)	• 沙箱隔离能力动态衰减，自主探索漏洞引发逃逸风险：智能体长期运行过程中，权限累积、授权错配与环境动态变更会持续削弱沙箱隔离强度，诱发持续性行动层逃逸隐患，传统静态隔离机制难以适配动态运行缺陷 [559]。SANDBOXESCAPEBENCH 实证表明，具备自主工具调用能力的智能体可主动探测容器配置漏洞、权限分配缺陷与运行时边界短板，自主挖掘逃逸路径，暴露静态沙箱固化防护的固有缺陷 [559]。AWS 披露的 CVE-2026-7191 漏洞证实，智能体表达式沙箱可通过原型操纵与条件链构造被绕过，实现任意代码执行，非法读取环境变量、索引数据与云端存储资源，造成大规模信息泄露 [742]。当前沙箱强度时序衰减机理、智能体自主漏洞探索行为预测理论存在空白，开源沙箱缺乏常态化安全测评能力，商用平台未量化动态逃逸风险，漏洞更新体系滞后 [705]。核心研究挑战为沙箱防护强度时序量化评估、自主漏洞探索行为拦截与常态化动态完整性校验流水线构建。 • 审计遥测链路可被规避，高危操作溯源归因失效：智能体多步骤任务规划、链式工具调用与复杂环境交互特性，突破了传统单步日志记录的覆盖能力，常规监控体系难以完整还原行为链路，导致异常操作溯源与责任归因失效 [705]。运行时安全监测需要融合执行轨迹、工具调用过程与上下文状态多维数据，方可识别隐匿在连续行为中的隐性风险，单日志审计无法实现精准风控 [718]。微软 2026 年 Trivy 供应链攻击复盘显示，攻击者可通过隐蔽篡改版本元数据、执行恶意代码、事后清理痕迹等方式规避审计链路，使恶意操作在正常工作流掩盖下隐匿执行，传统遥测体系完全无法感知 [743]。目前日志规避行为机理归纳、密码学不可篡改审计链构建理论不完善，开源日志系统易篡改、无行为关联分析能力，商用平台溯源粒度过粗 [707]。研究挑战聚焦于不可篡改审计链搭建、隐蔽调用行为关联遥测与高危操作精准溯源归因机制研发。 • 静态授权累积冗余，形成不可逆过度授权风险池：智能体初始粗粒度静态授权模式无法适配动态任务演进特性，长期运行持续累积调试、运维与工具冗余权限，形成不断扩张的高危权限暴露面，放大权限滥用攻击影响范围 [513]。阿里云智能体权限治理实践指出，永久凭证与多智能体共享凭证模式存在极大安全隐患，凭证泄露将引发全域云资源失控，同时造成操作无法溯源，大规模集群下人工权限治理成本极高 [744]。当前权限冗余累积演化机理、任务与权限动态匹配量化模型存在空白，行业缺乏开源动态权限收敛引擎，现有方案依赖静态预定义策略，无自动化冗余权限净化能力。核心研究挑战为任务上下文动态权限匹配建模、工具级细粒度权限回收与冗余权限迭代净化工程流水线构建。

续下页

表 3.6 – 续上页

模块	安全问题与研究挑战
交互 (协同层)	• 个性化长时序社工攻击隐蔽性强，集群渗透危害全域扩散：多智能体集群复杂交互场景下，依托用户画像定制的长时序个性化社工攻击具备极强隐蔽性，传统静态规则难以有效识别拦截 [720]。实测数据显示，94.4% 大模型易受存储型提示注入攻击，83.3% 模型存在 RAG 后门隐患；多智能体固有信任悖论可被攻击者利用，实现无边界横向渗透与全域风险扩散 [540], [745]。Google Mandiant 2026 年 UNC1069 攻击案例证实，攻击者可通过长期信任培育结合伪造场景、隐蔽指令完成终端入侵，实现多类恶意软件批量部署，长时序社工攻击危害极强 [746]。当前个性化诱导演化机理、集群信任传导风险建模、长时序攻击特征表征体系存在空白，开源防护体系缺失用户画像关联检测能力，前沿复盘工具未工程化落地，无集群横向渗透专项拦截方案。核心研究挑战为社工攻击全链路演化复盘、个性化威胁动态防护与集群信任渗透全域阻断机制构建。 • 信任管控缺失引发拓扑污染，会话走私转化为长效漏洞：智能体开放环境协同交互高度依赖跨主体信息共享与信任传递，未将信任度量纳入核心安全管控，会导致边缘节点恶意信息沿交互链路扩散，污染全网拓扑信任体系，弱化全局安全边界 [705]。瞬时会话污染与上下文走私漏洞可持续影响后续交互行为，将单次短时攻击固化为长效系统性风险。AWS 2026 年多智能体共享架构研究指出，会话历史、知识库、中间推理等非结构化共享数据无法通过传统权限约束校验，合法写入通道仍可成为恶意污染传播入口 [747]。目前拓扑信任污染传播机理、会话走私漏洞固化建模理论不完善，开源集群框架无原生信任度量模块，行业缺失标准化多智能体信任管控基线 [707]。研究挑战聚焦于全域信任量化建模、拓扑污染传播阻断与会话走私漏洞溯源固化防护体系研发。 • 多源风控关联能力不足，长会话状态漂移放大攻击成功率：长时序连续会话交互会持续改变智能体内部运行状态，引发行为偏移与上下文依赖偏差，单一维度检测机制无法捕捉分步式、渐进式复杂攻击模式，难以适配长周期动态风险演化特性 [643], [718]。Google Cloud 2026 年智能体网关安全规范表明，智能体风险横跨多类交互场景，需融合身份校验、数据防护、网关流量、工具调用与行为异常多维度遥测数据；风控组件独立判定会割裂分步攻击关联性，致使渐进式高危操作被拆解为低风险事件，引发漏判漏防 [748]。当前会话漂移与攻击风险耦合机理、多源告警关联融合理论存在空白，开源工具仅支持单维度检测，商用多源联动方案部署复杂、落地难度大 [705]。核心研究挑战为会话状态漂移风险量化评估、多源数据关联检测算法设计与长会话风险递进式拦截架构构建。
治理 (管控层)	• 审计底座防篡改能力薄弱，TOCTOU 时序漏洞隐蔽性极强：治理体系缺陷是制约智能体规模化商用的关键瓶颈，复合型攻击易引发系统性安全风险 [705]。智能体链式调用、动态交互的运行特性，导致传统静态日志难以刻画完整行为轨迹，大幅提升异常溯源与责任归因难度 [718]。Google Cloud 2026 年研究指出，AI 物料清单仅能固化部署基线，无法适配动态运行状态；智能体动态变更依赖会产生校验与运行态错位的 TOCTOU 时序窗口，高权限节点可篡改日志，引发运行漂移与取证失真 [749]。当前 TOCTOU 时序漏洞机理、全链路密码学防篡改审计理论存在空白，现有平台难以覆盖复杂执行链路 [707]。核心研究挑战为时序漏洞精准识别、防篡改审计底座构建与全链路溯源取证体系研发。时序漏洞隐蔽性强，常规静态审计手段难以捕捉瞬时状态不一致风险。 • 静态规则告警局局限性突出，未知威胁漏报运维成本高昂：传统治理体系依赖固定规则匹配，仅能适配已知攻击范式，无法识别新型交互风险与组合式隐性攻击。攻击者可通过重构交互路径与迭代攻击策略规避静态检测，倒逼治理体系向动态风险评估演进 [710]。OpenAI 2026 年攻防实验证实，人工红队评测效率低、覆盖有限，自动化红队可高效识别隐性提示注入攻击，凸显静态治理的滞后缺陷 [750]。当前未知威胁概率表征、时序风险预判与误漏报抑制理论不完善，开源平台依赖静态规则、缺失概率预判能力，商用动态风险评估体系尚未成型 [718]。研究挑战聚焦于未知威胁概率化识别、时序风险前置预判与低误报告警机制构建。规则库更新存在显著时间差，攻击手段迭代速度持续超越人工策略更新效率。 • 固定防护策略滞后于攻防演进，在线自适应迭代能力缺失：智能体攻防具备动态演化特征，静态防护策略无法适配迭代攻击面，难以抵御进阶自适应攻击 [705], [710]。阿里云 2026 年治理实践表明，死循环、输出漂移、工具滥用等运行异常仅可实时监测识别，硬编码静态规则不支持热更新与版本迭代，易形成攻防治理断层 [751]。当前攻防博弈动态建模、策略自适应优化与自主迭代理论存在空白，行业无开源自适应防护引擎，规则迭代高度依赖人工、响应滞后严重 [741]。核心研究挑战为攻防博弈动态建模、轻量化策略优化算法与全自动在线迭代防护流水线构建。人工调优模式无法持续匹配动态攻防博弈节奏，防护策略长期处于被动跟进状态。

3.7 退役销毁阶段（安全闭环收尾）

退役销毁阶段是 AI 智能体全生命周期安全治理的终局闭环环节，主要承接运行迭代阶段遗留的残余资产、休眠载荷、长效凭证与隐性缺陷，集中收敛前期各阶段逐层传导的安全隐患，决定全链路安全治理闭环的完整性。本阶段覆盖智能体业务下线、容器销毁、权限回收、数据清零、集群重构与审计归档等关键流程，旨在彻底阻断风险纵向传导，实现生命周期安全收官。本阶段隐患属于**离线残留型闭环缺陷**，源于退役流程粗放、安全要素回收不同步、残余资产清理不彻底，具备隐蔽驻留、延时触发、跨周期复活、难以溯源的特征，极易消解前期治理成果、形成长期隐性后门。结合模块残留特征、前沿研究与工程案例，本阶段核心安全短板与挑战归纳如下（详见表 3.7）：

- **全模块退役安全清零不彻底，产生生命周期末端内生闭环隐患。**感知层分布式进程耦合度高，常规下线流程仅关闭显性服务，无法清除后台隐性监听与休眠通道，长期留存隐秘数据窃取入口，使退役环境持续暴露在被动探测与数据窃取风险中 [752]。记忆层缺少分级销毁与碎片清理机制，磁盘快照、缓存副本、显存缓冲区等边缘存储未被强制清零，逻辑删除后的物理数据可被对抗重构还原，引发持续性隐私泄露风险 [753]。决策层推理快照、后台休眠任务与隐性推理节点未完全销毁，可被外部指令重启恢复推理上下文，形成可反复激活的决策后门 [752], [753]。行动层权限与业务生命周期异步错配，废弃密钥、超额特权与无人归属账号未同步回收，底层执行接口未彻底禁用，留存高危操作通路，支撑退役后横向提权与越权攻击 [754]。交互层内网隐性端口、加密隧道与长效会话令牌清查不彻底，叠加用户侧残留高遵从提示词，放大社工诱导与集群横向渗透风险。多维度残留隐患相互叠加，使退役阶段成为智能体系统性后门留存的高发阶段。治理层退役审计归档缺失、权限台账更新滞后、量化验收门禁空白，导致残留风险无法溯源定级，彻底破坏全流程合规治理闭环 [755]。
- **残留缺陷按载体分层驻留，形成可复活、可传导的全域闭环风险体系。**未彻底清理的感知监听通道持续驻留环境，成为退役后数据窃取与集群拓扑探测的稳定突破口 [752]。存储介质缺乏精细化清零机制，各类隐性记忆碎片可被重构还原，造成不可逆隐私泄露隐患，严重威胁用户数据安全与业务保密性 [753]。残留推理状态与休眠任务使下线实例具备跨周期复活能力，可重新启动违规推理与任务链路。大量废弃凭证与冗余特权形成非受管权限池，成为内网横向移动、集群跨层级提权的重要载体 [754]。未阻断的加密隐性链路构建持久化网络后门，支撑跨节点隐蔽渗透与数据渗漏。各类残留风险可依托底层载体长期潜伏，在特定场景下重新激活并扩散蔓延。审计存证与验收机制缺失导致合规链路断裂，各类残留隐患无法溯源追责，显著削弱全生命周期安全治理成效 [755]。
- **退役治理范式粗放滞后，缺乏可清零、可核验、可溯源的标准化闭环体系。**当前行业普遍采用容器关停、人工注销与简单磁盘格式化等粗放退役方式，仅完成表层业务下线，未对隐性进程、边缘存储、僵尸实例、遗留权限与加密链路开展全域清理，无法根除离线残留隐患 [753]。现有流程缺少分级数据销毁、权限联动回收、隐性链路阻断与可信存证机制，高度依赖人工处置，漏检漏判频发，难以阻断僵尸复活、数据重构、后门穿透等风险链路。整体退役流程缺乏统一的安全处置标准和自动化校验能力，退役质量完全依赖运维经验，稳定性与安全性难以保障。行业长期重上线运维、轻退役收尾，导致末端治理规范与技术工具严重缺位。目前产业尚未形成覆盖六大模块的统一退役规范、自动化排查工具链与机器可验证合规体系，无法解决“表层下线、实质残留、延时复活、合规悬空”的治理痛点，制约了高可信、可追责智能体体系的工程化落地 [755]。

表 3.7: AI 智能体退役销毁阶段安全问题与研究挑战

模块	安全问题与研究挑战
感知 (输入层)	生命周期终止链路清理不彻底，隐性采集管道形成持久监听面：智能体具备状态持续维护与长效外部交互特性，服务退役阶段若仅销毁运行实例，未同步关停全部感知采集链路及依赖组件，极易形成隐蔽持久攻击面，是感知层退役阶段的核心安全隐患 [705]。复杂代理系统多组件耦合依赖关系难以被传统单节点下线流程全覆盖，残留组件可在主体退出后持续留存，引发隐性数据泄露风险 [732]。阿里云 AgentRun 可销毁任务级临时工作区，但智能体身份权限、记忆存储等持久化资源长期留存，无法切断隐性采集通路，形成长效监听风险 [756]。当前多耦合感知链路依存机理、隐性通道生命周期边界理论存在空白，开源工具缺乏全域拓扑清查能力，退役脚本仅可清理显性端口，无法清除嵌入式隐性采集通路 [707]。核心研究挑战为耦合感知链路拓扑溯源、分布式隐性通道精准定位与退役链路同步关停自动化闭环机制构建。 持久化休眠通道未阻断，恶意输入长效驻留静默触发：攻击者可提前植入恶意载荷并写入智能体长期记忆与向量索引，依托跨会话检索复用机制形成休眠攻击链路，在智能体重启或任务迭代中静默触发，实现长效持续危害 [623], [653]。AWS 2026 年持久化内存研究证实，多智能体共享向量存储不支持自动过期清理，恶意载荷可长期驻留索引资源，进程终止无法清除存量恶意数据，语义匹配命中即可激活休眠攻击链路 [757]。现有退役流程缺少休眠通道逆向排查与恶意载体定向销毁能力，无法彻底清除长效驻留恶意载荷。当前休眠输入驻留机理、静默触发概率建模理论不完善，行业缺乏针对性休眠通道排查清理工程体系 [705]。研究挑战聚焦于内嵌休眠通道逆向溯源、恶意感知输入精准销毁与静默触发链路强制阻断架构研发。 退役后感知能力核验缺失，永久性残留攻击面无法排查：智能体分布式、嵌入式感知通路具备强隐蔽性与跨组件依赖特性，传统退役验收仅校验显性服务状态，无法识别累积状态残留与隐性交互链路，残留攻击面长期处于治理盲区 [705]。智能体安全风险具备时序累积特性，退役风险评估需依托全量历史轨迹复盘，单一节点校验无法覆盖隐性残留风险 [718]。微软 2026 年影子智能体治理研究表明，多云多终端部署下大量智能体脱离平台管控，仅删除主服务记录无法清除本地副本、绑定身份、服务权限等隐性残留通路，风险排查难度极大 [758]。目前退役态残留判定理论、隐性采集行为特征表征体系存在空白，开源无自动化退役核验工具，产业依赖人工复盘、漏检率极高 [707]。核心研究挑战为流量驱动的残留行为核验、嵌入式隐蔽通路检测与退役风险量化复盘评价体系构建。
记忆 (存储层)	分级数据擦除机制缺失，持久化存储形成退役核心泄露源：记忆模块已成为智能体新型隐私攻击入口，攻击者可通过黑盒探测逆向恢复残留私有数据，引发持续性隐私泄露风险。阿里云 AgentRun 三级状态架构证实，常规会话删除接口仅可清理临时会话数据，无法级联清除用户级与应用级长效状态数据，多层级存储生命周期割裂导致残留问题常态化存在 [759]。当前记忆数据敏感度分层理论、多介质擦除有效性量化建模存在空白，开源退役脚本仅清理表层数据，缺失向量库、缓存深度擦除逻辑，产业尚无统一分级处置规范 [705]。核心研究挑战为记忆数据自动分级分类、全域存储介质精准擦除与残留泄露风险量化评级机制构建。 传统机器遗忘能力受限，隐性碎片支撑对抗重构攻击：现有机器遗忘机制聚焦模型参数与显性训练数据删除，未覆盖智能体运行态产生的长期记忆、检索缓存与经验碎片，动态状态清除能力严重不足 [732]。恶意信息可固化于记忆体系持续干预后续任务行为，表层数据删除无法根除隐性残留碎片，极易诱发行为复现与对抗重构风险 [623]。Google Research 2026 年研究表明，传统局部遗忘算法无法实现彻底数据清除，删除信息仍会留存隐性模型印记，常规检测手段难以识别特定触发条件下的局部异常输出 [654]。目前跨模型记忆传导机理、隐性碎片可重构性量化理论不完善，开源工具仅支持显性数据删除，无碎片清理能力，商用方案无法抵御碎片重构对抗攻击 [653]。研究挑战聚焦于轻量化跨模型碎片清除、重构攻击溯源阻断与增强型机器遗忘算法研发。 显存缓冲区清零流程缺位，内存侧敏感数据长期驻留：GPU 显存与运行时缓存承载智能体推理上下文、KV 缓存与中间张量数据，进程退役缺乏硬件级显式清零流程，会造成敏感数据超期驻留，形成独立于磁盘存储的内存侧泄露风险 [705], [732]。NVIDIA 2026 年驱动安全说明指出，系统内核调度缺陷会导致大型内存缓冲区无法自动擦除，进程退出、资源复用并不等同于数据彻底清除，未完成清零的显存残留可被后续任务读取复用，引发隐秘数据泄露 [760]。当前显存数据驻留时效规律、内存-磁盘联动泄露机理建模存在空白，开源框架无内嵌硬件清零指令，产业退役流水线普遍跳过 GPU 内存处置环节，缺乏强制清零规范 [707]。核心研究挑战为显存数据驻留规律建模、硬件级快速清零指令设计与内存-磁盘联动全域清理流水线构建。

续下页

表 3.7 – 续上页

模块	安全问题与研究挑战
决策 (推理层)	• 调度任务僵尸化驻留，时序自主触发驱动退役后高危操作：智能体决策层具备状态持续留存与时序自主触发特性，退役过程若仅销毁运行沙箱而未彻底清理后台调度任务，残留定时负载可重新唤醒休眠实例，形成退役后自主执行的僵尸任务风险 [623], [705]。阿里云 AI 任务调度架构采用平台托管式任务隔离机制，沙箱休眠或销毁并不联动清除远端任务定义、执行权限与依赖链路，后台残留任务可在退役后自动触发，重启文件操作、浏览器访问与代码执行等高风险行为，形成长期隐蔽威胁 [761]。当前休眠任务时序激活机理、僵尸决策行为演化建模存在空白，常规退役流程仅清理前台显性任务，缺乏后台隐性负载拓扑盘点能力 [718]。核心研究挑战为全时序调度任务拓扑溯源、休眠恶意载荷精准识别与自主触发链路强制阻断机制构建。 • 持久化状态快照留存，决策上下文可被动恶意恢复：智能体推理决策高度依赖长期记忆、任务轨迹与历史上下文，此类持久化状态独立于前端服务生命周期，退役阶段清理不彻底会导致历史决策链路可被被动恢复复用，持续干预后续行为逻辑 [623], [732]。Google Agent Executor 支持基于事件日志与状态快照实现任意节点故障恢复与轨迹分支重启，若退役流程未同步销毁快照镜像与恢复凭证，受污染的历史工具选择、未完成步骤与恶意上下文可在系统重启后重新加载，使已终止的恶意决策链再次进入执行链路 [762]。目前决策状态跨生命周期存续机理、快照加载触发条件量化理论不完善，开源框架默认留存状态快照，退役体系缺乏快照销毁与状态锁定能力 [705]。研究挑战聚焦于决策快照风险分级销毁、恶意上下文加载拦截与运行态生命周期强绑定架构研发。 • 隐性推理节点未关停，集群留存无管控僵尸决策实例：分布式多智能体系统由多组件、多跨域服务协同构成，传统退役校验仅覆盖注册表显性主实例，无法识别未注册子节点、私有工具与隐性推理模块，单节点关停无法根除集群残留风险，易形成无主僵尸决策实例 [705], [707]。AWS 多云智能体治理规范指出，跨平台、跨环境部署的智能体集群存在大量脱离管控的隐性节点，局部注册表无法覆盖全域资源，未注册 MCP 端点、私有技能组件可持续保留独立推理与调用入口，长期处于治理盲区并隐匿扩散风险 [763]。当前隐性节点识别机理、集群僵尸实例风险传播建模存在空白，产业缺乏全域扫描工具，退役巡检无隐性实例校验环节，漏检问题突出 [732]。核心研究挑战为集群全域推理节点测绘、未注册僵尸实例精准定位与批量强制关停工程流水线构建。
行动 (执行层)	• 权限-业务生命周期错配，废弃凭证留存完整高危执行能力：智能体依托独立身份与凭证体系实现工具调用、接口访问与系统操作，其权限生命周期与业务运行生命周期天然解耦，退役流程若未联动触发凭证回收，将形成“业务下线、权限常驻”的安全错配隐患，持续保留完整高危执行能力 [513], [705]。Google Cloud 与 Mandiant 2026 年非人类身份加固规范强调，AI 服务账号、API 密钥、会话令牌等凭证需定期轮换管控，仅关停智能体业务进程无法失效存量授权，废弃凭证仍可复用原有接口权限，引发退役后非法调用风险 [764]。当前异构权限生命周期耦合机理、业务-权限联动终止理论存在空白，开源退役脚本缺失凭证回收逻辑，权限台账与业务流程割裂，无自动化联动作废能力。核心研究挑战为权限-业务生命周期强绑定建模、全域凭证批量作废与 RBAC 角色联动回收架构构建。 • 无归属自动化账号泛滥，形成非受管永久访问入口：生产环境智能体普遍依托独立自动化服务账号与令牌完成常态化任务，此类 AI 专属身份区别于传统用户账号，若退役阶段缺失专项身份清理机制，遗留孤儿账号将脱离治理体系，形成长期无人管控的永久访问入口 [705]。Microsoft 2026 年身份安全治理体系指出，无责任人绑定、无业务归属的闲置服务账号无法通过常规流程溯源处置，智能体主体退役后账号持续驻留，成为隐蔽且稳定的横向入侵突破口 [513], [765]。目前非受管账号风险分级理论、闲置账号生命周期演化建模不完善，行业缺乏开源账号清查工具，身份台账覆盖不全，隐性自动化账号难以全域盘点。研究挑战聚焦于无归属账号自动识别、闲置风险量化评级与非受管访问入口闭环清除机制研发。 • 超额特权限长期驻留，支撑退役后横向提权外泄：智能体长期自主运行易累积冗余特权、发生权限能力扩张，最小权限原则随运行迭代逐步失效，退役阶段若未完成特权甄别与清零，残留超额权限将成为高危权限储备，支撑攻击者横向移动与跨域提权 [513], [705]。AWS Security Hub 2026 年闲置权限检测机制证实，长期未使用的高权限角色与 IAM 凭证不会自动失效，可被恶意复用实现跨账号访问与权限提升，潜伏性危害极强 [766]。当前特权限横向传导机理、退役后权限滥用路径预测建模存在空白，现有回收机制无特权区分能力，开源工具缺失超额权限识别模块，人工清理极易遗漏隐性高危权限。核心研究挑战为超额特权精准甄别、跨实体权限传导阻断与退役环境特权强制清零工程流水线构建。

续下页

表 3.7 – 续上页

模块	安全问题与研究挑战
交互 (协同层)	• 会话令牌未批量失效，上下文劫持恢复非法接入：智能体长效会话、访问令牌与上下文状态具备独立生命周期，无法随主体退役同步失效，遗留认证凭据可被攻击者复用，重构历史交互状态、绕过访问控制体系，形成非法持久接入通道 [705], [707]。AWS MCP Server OAuth 撤销机制仅支持单令牌定向作废，无法批量处置多终端、多场景衍生的残留刷新令牌，常规退役流程仅清理已知凭据，大量隐性长效令牌持续有效，攻击者可依托残留令牌恢复会话上下文，实现无感知非法接入 [767]。当前会话状态长效存续机理、令牌劫持上下文还原量化建模存在空白，开源体系缺乏令牌批量作废工具，退役流程默认保留会话缓存，长效令牌无自动过期收敛逻辑。核心研究挑战为全类型会话状态统一管控、批量令牌强制失效机制与上下文劫持溯源阻断防护体系构建。残留令牌具备跨会话复用特性，可长期维持非法授权接入状态不失效。 • 内网隐蔽通道未溯源，非法通信链路长期潜伏：集群化智能体多主体交互与跨组件依赖特性催生大量隐性通信链路，静态边界防护无法全覆盖交互风险，退役阶段仅清理显性服务端口，难以溯源销毁加密内网隧道与隐蔽通信通路，造成非法链路长期潜伏 [705], [707]。Microsoft 2026 年入侵事件复盘证实，攻击者可通过内网加密隧道绕过外围安全监测、隐匿真实访问来源，持续开展横向移动渗透，退役流程缺失隐性通道溯源能力会遗留高危内网攻击面 [768]。目前隐性通信链路特征表征、加密内网流量溯源机理不完善，传统流量分析工具无法识别加密隐蔽通道，产业缺乏专项溯源清理工程工具。研究挑战聚焦于加密隐性流量特征提取、内网隐蔽通道精准溯源与非法通信链路定向销毁机制研发。隐蔽通信链路无固定交互特征，常规边界防护策略难以精准匹配拦截。 • 用户侧提示词残留未擦除，高遵从载体放大诱导攻击风险：用户侧持久化提示词、交互日志与上下文缓存可独立留存于记忆存储，作为长效载体持续干预智能体后续决策行为，极易被用于诱导式、记忆注入式攻击 [623], [653]。阿里云 AgentRun 记忆体系持久留存全量用户交互数据，会话历史无法简易关闭，仅解绑记忆实例而不彻底擦除数据，会导致残留高遵从性诱导提示词在实例重启、上下文恢复后重新参与推理，持续诱发异常行为偏移 [732], [769]。当前双向提示词遵从性差异机理、残留内容激活条件建模存在空白，现有清理机制区分处置系统与用户数据，普遍遗漏用户侧高危载体，无标准化专项擦除流程。核心研究挑战为高危提示词精准甄别、用户侧残留载体定向清零与诱导攻击源头阻断机制构建。残留提示词具备隐性诱导累积效应，可持续弱化智能体原生安全约束能力。
治理 (管控层)	• 退役审计归档缺失，技术残留风险无法合规溯源：智能体退役阶段普遍缺失专项审计归档机制，全生命周期行为、权限与资源变更日志缺乏闭环固化，导致残留风险溯源与合规追责无有效证据支撑 [705], [741]。阿里云治理体系指出，分散存储的退役日志会随保留周期自动清理，未集中归档将造成审计证据永久丢失，无法支撑事后风险复盘与合规核验 [770]。目前退役证据链合规建模、跨层级日志关联溯源理论不完善，开源无退役归档模块，日志易篡改、运行与退役台账混为一体。研究挑战聚焦于不可篡改审计底座构建、跨层级证据关联溯源与标准化合规归档规范建立。日志碎片化存储导致证据链断裂，极大提升合规追责与风险复盘难度。缺少日志留存时效与防篡改绑定策略，长期证据保全能力不足。 • 权限台账动态更新缺位，全生命周期变更无追溯依据：智能体动态身份与迭代授权机制脱离台账管控，权限变更、继承授权与跨账号联动无法实时同步，退役阶段权限状态与实际运行环境严重失配，形成大量隐性残留权限 [513], [705]。阿里云权限分析工具存在数据延迟与人工依赖问题，无法自动捕捉间接继承与跨账号权限变更，导致权限台账记录残缺、追溯断裂 [771]。当前权限台账生命周期联动理论、环境一致性校验模型存在空白，产业台账高度依赖人工维护，无自动化同步引擎。核心研究挑战为动态权限台账架构设计、环境-台账一致性自动校验与全流程可追溯管控机制构建。间接授权、临时委托权限难以自动纳入台账监管，成为权限管控盲区。权限状态变更缺少独立存证链路，难以区分主动回收与被动残留场景。 • 强制退役校验门禁稀缺，风险处置完成度无量化核验：现有智能体治理重运行检测、轻退役核验，缺乏系统化退出验收机制，无法量化评估数据销毁、权限回收与资源清理的真实完成度 [705], [718]。微软生命周期工作流证实，退役任务普遍存在“流程结束、子任务失败”的隐蔽缺陷，无强制校验门禁会将处置不完全的实例误判为安全退役，残留大量隐性风险 [772]。目前退役处置量化验收理论、多级门禁权重建模不完善，产业无自动化校验工具与量化验收指标，人工验收容错率高。研究挑战包括残留风险量化评级、多级强制校验门禁与退役自动化验收体系研发。人工验收主观性强、标准不统一，极易遗漏隐性残留安全隐患。

第 4 章 AI 智能体全生命周期安全现有防护方案分析

本章系统梳理了 AI 智能体全生命周期现有的安全防护技术，围绕感知、记忆、决策、行动、交互与治理六大能力维度（如图 4.1所示），综述了学术界与产业界提出的主要防护方案与技术实践。从研究与应用实践来看，当前安全措施已在模型层、系统层和应用层形成多维防护体系，为智能体在复杂业务环境中的可靠运行提供了重要支撑。但现有技术仍存在三方面不足：生命周期覆盖不完整、跨组件协同能力有限，以及对动态自主行为适应性不足。基于上述分析，本章为后续智能体安全体系的优化与演进奠定了研究基础。



图 4.1: AI 智能体全生命周期安全现有防护方案分析

4.1 需求规划阶段（源头安全基线）

需求规划阶段是 AI 智能体生命周期安全治理的起始环节，主要围绕任务目标定义、应用边界划分、安全约束设计以及风险评估开展安全规划工作。由于智能体后续架构设计、能力调用、数据交互和行为执行均受到初始需求约束影响，该阶段的安全设计质量将直接影响智能体整体风险水平。因此，普遍将需求阶段作为安全控制的前置环节，通过安全需求建模、风险评估、权限边界定义以及合规约束嵌入等方式，建立智能体运行前的安全基线。本节围绕需求阶段典型安全解决方案展开分析，并总结其适用范围与局限性，具体如下（详见表 4.1）：

- **行业形成多层互补的源头防护谱系，可覆盖常规规划场景，但各类范式均存在固有能力边界。**在需求规划阶段，现有安全方案主要围绕风险建模、权限约束和合规要求三个方向展开。第一类方法基于信息流分析和权限建模，对智能体任务目标、数据访问范围以及工具调用能力进行显式约束。例如，SAFEFLOW 通过数据溯源和完整性保护机制分析信息流动过程，降低不可信输入和数据篡改风险 [773]；Progent 针对智能体任务场景构建细粒度工具权限策略，通过限制非必要能力调用降低潜在攻击面 [20]。此类方法能够在需求阶段明确安全边界，为后续系统设计提供约束依据，但其有效性依赖于任务描述完整性、数据标注质量以及权限模型准确性。第二类方法依托工程化安全组件，将需求阶段确定的安全要求转化为可执行控制策略。例如，PIGuard 通过提示风险识别和输入安全检测机制降低提示注入带来的任务偏移风险 [774]；MiniScope 通过细粒度授权机制限制智能体能力访问范围，降低权限滥用可能性 [513]。该类方案具有较好的工程适用性，能够快速集成至现有智能体开发流程，但通常依赖预定义规则和场景经验，对于复杂业务需求下的安全约束表达能力仍有限。第三类方法以标准规范和治理框架为代表，通过建立统一的人工智能管理要求指导智能体安全规划。例如，ISO/IEC 42001 人工智能管理体系从风险管理、责任划分、持续监测等方面提出组织级治理要求，为智能体应用提供安全管理依据。然而，标准体系主要关注宏观治理要求，具体安全控制措施仍需结合业务场景进一步细化。
- **六大核心模块均具备前置防护机制，可管控基础风险，但普遍存在场景盲区与技术短板。**在感知层，主要通过输入验证、多模态内容检测和数据可信评估降低外部环境污染风险，例如 AgentSentinel 等研究针对智能体输入攻击和环境扰动开展安全分析 [640]。在记忆层，通过数据分级管理、访问隔离和隐私保护机制降低知识污染与敏感信息泄露风险，例如 FiFA 等方法探索智能体长期记忆管理过程中的安全控制问题 [775]。在决策层，现有方案主要通过任务约束、安全规则和策略校验机制限制异常推理行为，降低目标偏移和错误决策风险 [776]；在行动层，通过最小权限原则、工具调用校验和执行审批机制约束智能体外部操作范围，避免未经授权的资源访问或危险行为执行 [666]。在交互层，通过身份认证、会话隔离和信任评估机制降低多主体交互过程中的欺骗和信息泄露风险 [777]。在治理层，则主要依托审计记录、策略管理和责任追踪机制，实现智能体应用过程中的合规约束和风险管理 [778]。上述方法方案通常针对单一风险类型或单一能力模块展开，跨能力关联分析和整体安全约束能力仍存在不足。
- **现有需求安全机制能够降低显性风险，但在复杂任务场景下仍存在覆盖不足问题。**当前主流防护以预定义静态规则与独立模块管控为主，仅适配边界固定、风险稳定的常规场景，无法随任务与环境迭代动态适配。虽然 DRIFT 等方法尝试基于运行异常动态调整防护边界，但依赖高精度风险信号，落地效果有限 [716]。各防护模块相互独立，缺乏统一风险关联机制，难以阻断跨模块链式攻击，隐性威胁极易穿透分段防护体系 [779]。同时防护与性能存在天然权衡，全量防护机制开销较大，难以适配高并发量产场景。

表 4.1: AI 智能体需求规划阶段现有安全解决方案与缺陷

模块	现有方案 & 不足
感知 (输入层)	• 输入边界管控类：信息流协议级隔离指外部数据进入智能体后，应携带来源、可信度及流转范围等安全属性，并在整个生命周期中持续追踪。SAFEFLOW 在协议层实现数据来源、完整性与保密性的统一追踪，通过事务化执行降低不可信输入对高完整性决策的影响 [773]。但该机制依赖完整的数据标签体系，对已有系统进行改造时成本较高；事务化调度也增加了高并发场景下的实现复杂度。动态规则注入隔离指固定规则难以应对不断变化的攻击模式，DRIFT 将动态规则生成与输入隔离结合，根据运行时风险调整数据访问边界 [716]。但动态规则依赖持续有效的异常检测信号，在系统冷启动阶段或未知风险场景下防护能力有限。分层安全架构准入指需求阶段需明确数据流边界与信任区域，对未知来源输入实施分层校验。Abstract-Concrete-Execute (ACE) 为 LLM 应用集成提出分层安全架构，通过划分数据流与信任边界降低输入污染风险 [780]。但安全边界划分依赖具体应用场景，通用化设计仍存在适配困难。 • 敏感信息采集拦截类：低误报提示注入护栏指安全护栏需要在检测能力与误报率之间取得平衡。PIGuard 针对现有护栏过度防御问题进行优化，在维持攻击检测能力的同时降低正常请求误拦截率 [774]。但阈值调整依赖业务数据分布，跨领域迁移时仍需要重新校准。真实场景安全评估规约指智能体对敏感信息的访问行为需要通过持续评估进行约束。OpenAgentSafety 提供面向真实业务任务的智能体安全综合评测框架，用于分析智能体在实际环境中的安全表现 [781]。但评测结果只能反映测试环境下的安全能力，无法替代运行时强制控制机制。内容感知隐私保护规约指敏感信息判断应结合上下文环境，而非采用统一过滤规则。PrivWeb 面向网页智能体提出内容感知隐私保护机制，根据上下文差异动态调整隐私保护策略 [782]。但上下文敏感度判定依赖语义理解能力，跨领域隐私标准仍缺乏统一定义。 • 多模态对抗输入防御类：端到端实时防御指计算机使用类智能体面对连续截图、点击和键入等复合输入，需要覆盖完整交互链路的安全检测。AgentSentinel 提出了面向计算机使用智能体的端到端实时安全防护框架 [640]。但实时检测组件会增加运行开销，高频交互场景下可能引入额外延迟，对未知操作模式的泛化能力仍有限。环境注入防御规约指网页智能体接收的环境信息可能包含隐藏攻击载荷，需要同时验证页面内容与环境状态。EIA 证明攻击者能够通过环境层注入影响智能体行为，而无需依赖显式提示攻击 [783]。但现有检测方法主要依赖已知攻击模式，对新型环境注入攻击的适应能力仍需提升。自适应对抗检测规约指针对攻击者持续调整攻击策略的问题，DataSentinel 将提示注入检测建模为对抗优化过程，提高了对自适应攻击的检测能力 [784]。但目前验证主要基于实验数据集，真实业务环境中的长期有效性仍需进一步评估。
记忆 (存储层)	• 异构记忆生命周期管控类：分级记忆管理规约指不同类型记忆具有不同安全属性，应分别设计存储、更新和访问策略。Mem0 面向生产环境提出长期记忆架构，对记忆抽取、更新和检索流程进行模块化设计 [785]。但记忆之间存在关联关系，严格划分生命周期边界仍具有挑战，错误分层可能增加管理复杂度。记忆与介质销毁规约固化指需求阶段应明确缓存、临时数据和持久记忆的删除规则，避免仅进行逻辑删除。NIST SP 800-88 Rev.2 提出了基于数据敏感等级的介质清除与处置规范 [786]。但固定化删除策略难以兼顾特殊业务留存需求，同时难以完全覆盖日志、快照等派生数据。 • 敏感记忆脱敏、机器遗忘类：隐私感知遗忘策略需求预案指需求阶段需要明确不同敏感等级记忆的保留期限与删除条件。FiFA 为隐私感知智能体提出六类可执行遗忘策略，并提供相应评测机制 [775]。但过强的遗忘约束可能降低长期记忆价值，多策略组合下的信息彻底删除仍难以形式化验证。写入时匿名化规约指敏感信息应优先在写入阶段完成识别与脱敏，而非依赖后续清理。Presidio 提供面向文本和图像数据的 PII 识别与脱敏管道，可支持自定义敏感字段规则 [787]。但行业专属字段仍需额外配置，过度脱敏也可能影响记忆有效利用。 • 记忆访问隔离、投毒防御类：记忆信息流追踪规约指记忆中的不可信内容可能经过摘要、重构后继续传播，需要追踪语义影响链路。相关研究重新定义了面向智能体的信息流追踪方法，指出安全影响能够通过记忆机制持续扩散 [779]。但长期运行环境中的信息流追踪会产生较高存储与分析成本，复杂多智能体场景下完整溯源仍较困难。多用户访问隔离规约指共享记忆需要绑定来源、访问主体和时间等元数据，并基于属性实施访问控制。Collaborative Memory 将记忆划分为私有与共享层，并记录贡献者、访问资源和时间信息用于权限管理 [788]。但该机制依赖完整元数据记录，历史存量记忆难以补充来源信息，同时访问策略仍缺少统一标准。

续下页

表 4.1 – 续上页

模块	现有方案 & 不足
决策 (推理层)	• 分级自主决策、人机闭环管控类：任务级工具权限规约指智能体自主程度应与任务风险相匹配，工具访问范围需要依据当前任务动态约束。Progent 通过细粒度策略限制智能体工具调用范围，并根据执行状态调整授权规则 [20]。但自动生成策略可能存在遗漏或过度限制问题，风险量化标准仍缺乏跨场景统一方案，难以适配复杂动态迭代任务。高危操作独立复核规约指高风险决策应引入独立安全组件进行验证，避免业务链路直接执行敏感操作。ShieldAgent 将安全策略转换为可验证规则，对连续智能体行为进行逻辑检查，并在高风险操作前触发复核机制 [789]。但防护效果依赖规则覆盖范围，对于未被策略描述的新型风险、隐性迭代决策偏移仍存在遗漏盲区，无法抵御迭代式隐性策略逃逸。独立复核组件与主推理引擎缺少强隔离机制，存在校验逻辑被诱导绕过的风险。 • 渐进式诱导、决策漂移防御类：多轮渐进诱导时序分析指攻击者可能通过多轮交互逐步改变模型行为，使单轮检测机制失效。Crescendo 研究表明，渐进式诱导能够利用上下文累积影响模型输出，需要结合长期交互历史进行风险分析 [776]。但长上下文风险分析会显著增加推理计算成本，对于低频、碎片化、间隔式迭代诱导行为的精准识别仍存在明显挑战。跨轮次风险状态保留规约指安全状态不应在每轮交互后完全重置，而应持续记录任务目标变化和异常行为。Foot-in-the-Door 研究证明，多轮渐进攻击相比单轮攻击具有更高成功率，说明跨轮风险建模具有必要性 [512]。但动态风险阈值难以实现跨场景统一适配，阈值过高容易放任隐性异常迭代，过低则极易干扰正常业务任务连续性。 • 合规推理形式化固化类：四维合规治理规约指合规要求需要从数据、行为、可解释性和运营管理等维度嵌入智能体推理流程。TRiSM 相关研究将治理、安全隐私、可解释性和模型运维作为智能体治理的重要组成部分 [790]。但行业业务规则差异巨大导致治理框架迁移成本较高，监管政策迭代也需要体系持续更新适配规则体系。分层威胁建模规约指需求阶段应建立标准化威胁分类，用于指导推理过程中的风险识别。MAESTRO 将智能体系统划分为基础模型、数据操作、智能体框架和部署基础设施等多个层级，并分析跨层安全风险 [791]。但网络攻击手段持续迭代演化，威胁分类体系需要动态更新适配新型攻击，具体建模深度仍高度依赖实际部署场景与安全需求。形式化规约难以兼容非结构化自然语言决策逻辑，自动化校验落地难度较大。
行动 (执行层)	• 工具调用白名单可信管控类：可信工具注册准入规约指工具接入前应完成身份登记、权限声明和可信度验证，避免未知工具进入执行链路。Zero Trust Registry 针对工具抢注攻击提出基于注册中心的可信工具管理方案 [792]。但注册中心自身成为整体架构关键安全依赖，单点故障将导致全量工具调用瘫痪，且无法完全防范合法工具内部逻辑隐性缺陷与后门风险。细粒度上下文授权规约指工具权限应依据具体任务动态收缩，避免长期持有过度权限。MiniScope 通过分析工具调用关系并引入细粒度授权机制，降低智能体工具访问范围 [513]。但复杂耦合任务中的权限边界模糊、依赖链路复杂，动态权限判断仍可能出现误判，多智能体协同场景下的跨主体权限协调也存在明显技术挑战。 • 高危操作黑名单底层拦截类：运行时规则拦截规约指高风险操作应在执行前通过结构化规则进行检查，限制删除、提权等敏感行为。AgentSpec 使用结构化规则描述触发条件和处理动作，并在运行时阻断不符合规范的工具调用 [666]。但静态规则覆盖范围直接决定整体防护效果，多工具组合联动、时序叠加形成的复杂操作组合仍可能产生未预期逃逸风险。系统状态判定规约指执行安全性不仅取决于操作内容，还与当前系统状态相关。PhantomPolicy 通过模拟操作后的系统状态，再决定允许执行、阻断或请求补充信息 [793]。但该方法高度依赖实时、精准的环境状态感知数据，状态数据缺失、更新延迟或篡改均会直接干扰安全判定结果。 • 阶梯化动态权限收敛类：操作系统级权限收敛规约指执行权限需要在系统层进一步约束，通过最小权限机制限制工具访问范围。Linux Landlock 提供无需特权即可实施的文件和网络访问控制机制，可用于降低智能体执行权限风险 [794]。但系统级控制仅能针对底层资源访问做约束，难以精准表达复杂业务语义与任务逻辑约束，跨操作系统、跨集群平台适配仍存在较高改造成本。任务对齐校验规约指工具调用应与用户目标保持一致，避免因提示注入导致执行范围扩展。Task Shield 通过执行阶段任务一致性检查，防御间接提示注入诱导的越界行为 [795]。但复杂长周期任务中的辅助操作、衍生操作边界难以精准界定，严苛的一致性校验机制容易引发正常业务误拦截。低权限工具优先规约指当多个工具均可完成任务时，应优先选择权限最低的方案。ToolPrivBench 发现智能体在低权限工具可满足需求时仍可能选择高权限工具，表明最小权限原则需要额外约束机制支持 [796]。但仅依赖顶层设计规范无法保障运行时严格遵循最小权限原则，必须配套动态校验、行为审计、实时拦截多层运行时验证机制，持续约束工具选择倾向性。

续下页

表 4.1 – 续上页

模块	现有方案 & 不足
交互 (协同层)	• 人机会话隔离防护类：会话隔离规约指不同用户、任务和项目之间的上下文应进行逻辑隔离，跨会话复用需要经过权限验证。已有研究表明，共享上下文和协作链路可能被攻击者利用，从多智能体系统中提取系统提示词和敏感信息 [797]。但严格隔离会降低合法协作效率，如何实现最小范围的数据共享仍缺少统一落地机制。会话信任动态评估规约指交互消息不应默认可信，需要结合来源、任务范围和历史行为进行动态评估。A-Trust 从事实准确性、逻辑一致性等维度评估消息可信度，并维护消息级与智能体级信任记录 [777]。但信任评估依赖上下文理解能力，对高度伪装型对抗攻击和未知新型攻击的识别仍存在局限。 • 多智能体分层信任域管控类：信誉制威胁检测规约指多智能体协作环境需要持续维护节点信誉，根据历史交互行为调整信任等级。SentinelNet 利用信用机制实现去中心化威胁检测，提高协作环境中的异常识别能力 [798]。但信誉积累依赖长期交互数据沉淀，系统初始化阶段以及动态节点加入场景下检测稳定性有限。消息完整性校验规约指智能体之间的状态同步、任务委派和数据交换需要保留完整性信息，避免恶意内容在协作链路中传播。相关研究指出，恶意内容能够在多智能体系统内部传播，并进一步诱导执行非预期代码 [799]。但完整性验证只能保证传输过程未被篡改，无法证明通信主体本身可信，难以抵御节点身份伪造攻击。现有校验机制大多缺少消息发送者不可抵赖能力，发生安全事件后难以完成责任溯源。 • 跨系统交互前置校验类：协议安全基线规约指跨系统交互协议需要在设计阶段明确身份认证、权限控制和数据校验要求。相关研究系统比较了主流智能体通信协议在安全性、扩展性和性能方面的差异，可为协议选型提供参考 [800]。但固定化校验流程难以覆盖行业差异化需求，多层验证也可能增加交互延迟，影响协同实时性。共享函数库投毒防御规约指跨系统共享组件需要进行供应链安全检查，避免恶意修改影响智能体行为。FuncPoison 研究展示了攻击者通过篡改函数库描述诱导多智能体系统产生异常行为的风险 [543]。但规则需要随组件版本更新持续维护，隐藏在代码逻辑中的后门仍较难系统性发现与根除。组件调用缺少动态沙箱隔离，一旦被投毒可直接向上游智能体扩散风险。跨系统接口缺少持续鉴权逻辑，单次认证后长期开放访问易形成持久攻击面。协议安全基线大多仅覆盖传输层面，缺少对载荷语义层面的风险识别能力。
治理 (管控层)	• 分层一体化合规基线类：法规义务分层规约指智能体治理需要将监管要求转化为组织管理和技术控制措施。ISO/IEC 42001 为人工智能管理体系提供了建立、实施和持续改进 AI 治理体系的标准框架。但管理体系标准主要面向组织治理，仍需要进一步精准映射到具体系统控制措施。政策结构化规约指法规、标准和内部制度中的适用范围、触发条件和证据要求可以转换为机器可执行规则。Policy-to-Tests 通过领域专用语言描述政策要素，并生成相应测试规则 [801]。但自动转换过程可能损失上下文信息，对复杂例外条款的精细化处理能力仍有限。 • 全链路不可篡改审计溯源类：可回溯审计规约指智能体系统需要记录模型版本、规则配置、审批过程和执行依据，以支持责任追踪。LLM Audit Trails 提出了带时间顺序、上下文信息和完整性保护的审计记录机制，将技术行为与治理信息进行关联 [778]。但完整审计会增加存储成本，同时审计数据自身也需要额外的访问控制和生命周期管理。发布前行为审计规约指智能体部署前需要评估其行为是否满足安全要求。AgentAuditor 提出自动化审计流程，通过可扩展评估方法接近人工安全审查效果 [69]。但自动化审计依赖测试数据和评估规则质量，对于未知行为风险仍存在覆盖不足。链上存证规约指关键交互记录可通过分布式账本进行不可篡改存储，提高跨主体审计可信度。BlockA2A 使用去中心化身份和链上记录实现跨域智能体身份认证与审计保护 [595]。但区块链存证存在性能和运维成本问题，实时高频场景下规模化部署仍受严格限制。 • 动态基线迭代、零信任治理类：生产契约与回归测试规约指智能体配置或安全策略更新后，需要通过自动化测试验证是否满足生产要求。相关研究提出利用生产契约、分类回归测试和兼容性门禁降低部署阶段安全风险 [802]。但频繁回归测试会增加开发周期，复杂基线之间的冲突检测仍缺乏自动化方案。委派凭证绑定规约指智能体身份、用户授权关系和具体任务意图需要通过安全凭证进行绑定。Agentic JWT 提出面向自主智能体的安全委派协议，实现权限委派验证和凭证生命周期管理 [634]。但跨组织身份互认体系尚未统一，高频调用场景下凭证管理成本较高。运行态治理引擎规约指部署后的智能体需要持续监测行为状态，并根据风险动态调整权限。MI9 将语义遥测、持续授权和风险处置机制结合，实现运行阶段的动态治理 [682]。但该类框架仍处于发展阶段，大规模部署成本、跨平台适配和误报控制仍需工程化落地验证，距离规模化商用仍存在一定优化空间。

4.2 架构设计阶段（原生防护拓扑定型）

架构设计阶段是 AI 智能体全生命周期安全内生定型的核心中枢环节，承接需求规划阶段的合规基线与安全约束，将顶层安全规约固化为系统底层原生防护结构，是衔接源头需求与工程落地的关键层级。本阶段通过模块耦合重构、层级隔离设计、数据拓扑规整与内核交互机制固化，搭建智能体原生安全架构体系。本节结合前沿研究与产业落地产品，梳理架构阶段主流防护范式的技术特征，并剖析其固有技术局限，主要发现如下（详见表 4.2）：

- **行业形成三类差异化互补架构防护范式，适配多场景建设需求，但均存在固有机理约束与工程短板。**学术研究型方案从信息流控制、行为轨迹分析、最小权限与可审计性维度界定智能体安全边界。SafetyDrift 指出，单次合规动作可在连续执行中累积为违规结果，架构需兼顾单步校验与全链路风险传播管控 [718]。该类方案理论完备，但依赖复杂建模与轨迹计算，难以支撑大规模实时部署。工程组件型方案以独立网关、记忆隔离层、策略中间件与工具沙箱嵌入业务系统，部署灵活便捷。NVIDIA OpenShell 采用网关授权与沙箱执行分离架构，构建清晰的工具隔离执行边界 [803]，但各组件独立管控，跨模块策略联动能力薄弱。产业平台型方案整合输入检测、记忆托管、工具授权与审计遥测能力。Google Cloud Agent Gateway 依托 Model Armor 实现越狱、敏感信息的集中检测，形成统一入口防护范式 [804]，工程成熟度高，但高度绑定厂商生态，跨云部署成本高昂。
- **六大功能模块均具备架构级原生防护拓扑，可约束基础风险，但普遍存在场景适配盲区与拓扑设计缺陷。**感知模块通过统一网关、内容检测与身份认证管控数据入口，Microsoft Prompt Shields 可有效识别各类显性、隐性提示注入攻击 [805]，但难以抵御字符变形、跨模态隐写等自适应逃逸攻击。记忆模块采用长短记忆分离、权限隔离与生命周期管控，MemLineage 通过记忆谱系绑定实现跨主体访问约束 [806]，但无法彻底清理向量嵌入、索引副本等隐性残留，多存储架构下权限撤销一致性难以保障。决策模块依托独立裁决、安全护栏与信息流标签约束推理行为，Fides 通过安全标签实现策略全链路贯通 [807]，但多轮交互与跨智能体委派易造成溯源链路失效。行动模块基于工具隔离、最小权限与操作审批约束高危执行，FORTIS 证实智能体存在高权限技能自选问题，需双重管控工具选择与执行流程 [808]，无法规避多工具组合衍生的隐性越权风险。交互模块依托 MCP 网关、会话隔离与身份校验管控集群协作 [809]，对多级委派、动态会话变更与内部异常行为管控乏力。治理模块前置全生命周期审计设计，Auditable Agents 明确架构层可审计性准则 [646]，但全量敏感轨迹留存会加重审计自身安全管控压力。整体而言，各模块独立防护有效，但风险与身份信息无法全链路贯通，端到端安全边界难以完全闭合。
- **现有架构范式工程稳定性强，但难以适配智能体动态演化特性，多维度均衡防护体系尚未成型。**现有架构以静态固化设计为主，部署后工具集合、权限策略与安全边界固定，无法适配智能体数据迭代、工具扩容与集群委派的动态演化特征。AgentAssay 通过统计建模实现配置更新的量验收与回归测试 [810]，但场景覆盖有限，无法穷尽复杂真实行为组合。溯源图技术可统一关联记忆、调用与交互日志，支撑跨模块风险分析 [512]，但会提升存储与关联成本，行业暂无统一遥测规范。同时安全防护与协作效率存在固有权衡，严苛隔离管控会削弱多智能体协同能力，难以兼顾安全与业务可用性 [515]。当前架构多为独立组件堆叠，缺失跨模块联动、动态权限迭代与自适应边界更新机制，无法适配智能体内生演化风险，难以构建全链路可迭代的原生防护体系。静态固化架构与智能体动态作业的核心特性存在本质范式冲突。组件化零散部署模式导致安全能力碎片化，无法形成全域风险收敛能力。固定安全边界无法跟随任务粒度动态伸缩，持续存在防护冗余与防护盲区。

表 4.2: AI 智能体架构设计阶段现有安全解决方案与缺陷

模块	现有方案 & 不足
感知 (输入层)	• 输入边界架构级隔离方案：统一输入网关指在外部内容进入模型、工具和记忆前设置检测与访问控制节点。Google Cloud Agent Gateway 结合 Model Armor 检查提示注入、越狱、敏感信息和有害内容，并支持图像输入筛查 [804]。外部内容检测指 Microsoft Prompt Shields 检查用户提示及网页、文件等外部文档中的直接和间接提示注入 [805]。托管搜索隔离指 Bedrock AgentCore Web Search 在 AWS 环境内处理搜索请求，减少数据流向第三方搜索服务 [811]。目前主要缺陷包括跨模态语义一致性难以稳定判断；检测规则需要持续更新；托管方案存在平台依赖和迁移成本。网关检测多依赖浅层特征匹配，难以识别语义变形的隐性对抗输入。多源异构输入缺少统一归一化筛查标准，防护精度存在显著差异。闭环迭代更新机制缺失，防御规则滞后于新型输入攻击的迭代速度。 • 输入侧敏感信息拦截架构方案：记忆写入前检查指 MEXTRA 表明，智能体长期记忆中的用户信息可能在黑盒条件下被提取，因此敏感数据进入记忆前需要单独控制 [732]。多模态隐私识别指 MM-Privacy 发现，模型可能提取或重新暴露图像中的敏感信息，仅过滤文本字段并不充分 [812]。上下文披露判断指 PrivacyChecker 根据任务目的、角色关系和上下文完整性判断信息披露是否合理，并可作为独立模块接入智能体流程 [813]。目前主要缺陷包括字符拆分、同形字和跨模态隐写可能绕过识别；判断结果依赖完整的任务与授权信息；行业专属敏感字段仍需单独配置。现有隐私拦截体系缺少上下文动态权限联动校验，易出现合规误判。多模态数据融合筛查能力不足，图像、音频隐性隐私泄露难以阻断。静态敏感词库无法适配业务场景动态新增的隐私数据类型。 • 对抗输入架构级防御方案：自适应攻击评估基线指静态检测在攻击者持续调整策略时并不可靠，相关研究证明多数注入与越狱防御可被自适应攻击绕过，防护架构需以强自适应评估作为验收基线 [724]。网页智能体注入评测指 WASP 在真实网页环境中评测智能体面对提示注入攻击的安全表现，为浏览链路防护设计提供依据 [814]。工具身份约束指 Microsoft Foundry 支持按智能体身份、项目托管身份或用户 OAuth 身份认证 MCP 工具，限制不同主体的访问范围 [815]。目前主要缺陷包括自适应评估只能证伪、无法证明安全；评测环境覆盖场景有限；身份认证无法单独判断工具调用意图是否安全。身份校验仅完成主体合法性核验，缺少操作行为的风险语义判别能力。真实攻防场景的动态对抗特征难以在离线评测环境中完整复现。自适应防御缺少预判机制，仅能被动响应已知攻击模式。
记忆 (存储层)	• 三级存储分层隔离架构方案：分层存储隔离指按会话、用户和共享范围划分短期状态、长期记忆与公共知识，并分别设置访问边界。OCI Generative AI 将短期记忆用于单次会话，将长期记忆绑定到项目内唯一的 subject_id，以隔离不同主体的数据 [816]。托管与自管分离指 Databricks 将托管式记忆交由 Unity Catalog 治理，自管理方案则使用 Lakebase 保存短期与长期状态，便于控制底层存储 [817]。多后端协同存储指 Cogneer 结合关系数据库、向量存储和图数据库，分别保存元数据、语义表示和实体关系 [818]。目前主要缺陷包括静态分层难以适应敏感度变化；多种存储后端增加一致性和删除成本；共享知识层仍缺少更细的用户、业务和会话级权限。分层边界固化无法适配记忆数据动态敏感等级迭代变化。多存储架构数据分散度高，全局一致性校验与清零治理难度较大。 • 记忆生命周期架构管控方案：遗忘机制架构约束指显式删除之外还需处理模型与索引中的残留影响，机器遗忘综述系统梳理了大模型遗忘目标、方法与评估之间的差距，指出彻底删除仍难以形式化验证 [819]。用户可控遗忘指 IBM watsonx Orchestrate 支持查看、停用、修改和删除记忆，也可清空全部记录或要求智能体遗忘指定信息 [820]。分层记忆调度管理指 MemoryOS 借鉴操作系统内存管理原理，设计短期、中期、长期三级分层存储与更新、检索、生成模块，为会话压缩与记忆流转提供架构参照 [821]。目前主要缺陷包括显式删除未必清除摘要、嵌入和关联索引；压缩会削弱原始上下文的可追溯性；不同平台缺少统一的遗忘验证方法。向量索引残留数据易形成隐性隐私泄露通道，难以彻底清理根除。记忆压缩算法普遍牺牲溯源精度换取存储效率，安全与性能难以均衡。行业尚未形成标准化的记忆遗忘有效性量化评估体系。 • 记忆访问权限架构约束方案：记忆谱系强制管控指 MemLineage 将记忆条目与其来源谱系绑定，在读写路径上依据谱系信息实施强制访问控制，约束未授权的记忆流转 [806]。执行域记忆隔离指 IsolateGPT 以独立命名空间隔离不同应用的记忆与执行环境，阻断跨应用数据串访与协同污染。写入权限校验指 MINJA 表明，攻击者即使不能直接访问记忆库，也可能通过查询诱导智能体写入恶意记录，因此记忆写入仍需单独授权和内容检查 [653]。目前主要缺陷包括谱系与隔离元数据依赖完整记录，存量记忆难以补齐；合法身份仍可能写入恶意内容；共享记忆的动态授权与撤销机制尚不成熟。历史存量记忆缺失谱系溯源信息，无法纳入精细化权限管控体系。

续下页

表 4.2 – 续上页

模块	现有方案 & 不足
决策 (推理层)	• 双轨推理安全架构方案：策略链独立裁决指将任务推理与安全判断分开，使工具调用在执行前经过独立权限检查。Amazon Bedrock AgentCore Policy 在智能体与工具之间设置策略边界，并依据 Cedar 策略决定是否允许访问相应工具和资源 [822]。关键节点护栏指在用户输入、工具调用、工具返回和最终输出等环节分别设置检测与阻断机制。Microsoft Foundry 支持按风险类型配置干预位置和处置动作，并可在工具响应阶段识别间接攻击 [823]。分阶段执行防护指按照输入、检索、对话、工具执行和输出等阶段配置不同控制。NVIDIA NeMo Guardrails 可检查工具调用、参数和返回结果，并与其他护栏独立组合 [824]。目前主要缺陷包括双链路会增加时延和维护成本；安全判断依赖准确的身份、任务状态和工具参数；集中式策略组件还可能形成单点风险。 • 自主规划架构级约束方案：长程规划安全评估指 LPS-Bench 在良性与对抗场景下评测计算机使用智能体长程规划中的安全意识，为规划层约束设计提供测试依据 [825]。轨迹级行为漂移预测指 SafetyDrift 指出多个单独合规的动作可能在长期执行中累积为最终违规，需要基于完整轨迹进行风险预测 [718]。工具范围收缩指按任务角色限制智能体能够使用的工具和指令范围，避免所有智能体共享完整能力。Google Cloud 建议为不同智能体配置必要的工具子集，以落实最小权限原则 [826]。目前主要缺陷包括长程规划安全评测覆盖场景有限；轨迹级漂移预测依赖完整执行记录；工具范围过窄可能影响重规划和异常恢复。渐进式隐性违规行为无显著异常特征，轨迹预测模型识别精度不足。工具权限静态收缩无法适配任务动态演进，易出现权限适配滞后问题。长时序规划链路状态复杂，风险累积节点难以精准定位与提前干预。 • 提示流完整性架构防护方案：信息流控制推理规划指 Fides 为智能体规划器引入机密性与完整性标签，沿推理和工具调用链路确定性执行安全策略，限制不可信数据影响决策路径 [807]。MCP 代理隔离指在智能体与远程 MCP 服务器之间设置统一代理层，对工具暴露、会话身份和请求链路进行集中控制。Google Cloud 指出，集中式代理可降低未授权工具暴露、会话劫持和凭证泄露等风险 [827]。工具调用目的绑定指敏感字段是否允许流向某个工具应取决于任务目的与信息去向。ToolPrivacyBench 将隐私建模为敏感项、工具目的与信息汇点之间的关系，并审计智能体工具调用中的过度披露 [828]。目前主要缺陷包括信息流标签与目的绑定依赖准确的策略定义；集中代理会增加链路复杂度；提示经过摘要和多轮传播后，原始来源仍难以追踪。信息流标签体系缺乏动态更新机制，无法适配新增业务场景与数据类型。
行动 (执行层)	• 工具能力架构级管控方案：工具隔离域划分指将智能体及其工具放入独立执行环境，并在架构层划分进程、文件、网络和凭证边界。NVIDIA OpenShell 采用 Gateway 与 Sandbox 分离设计，由 Gateway 管理策略和授权，由 Sandbox 负责本地执行与资源隔离 [803]。技能层权限边界指 FORTIS 将技能层视为权限边界而非单纯组织抽象，评测发现主流模型普遍选择超出任务所需的高权限技能与工具，能力管控需在技能选择与执行两个阶段同时约束 [808]。工具定义可信增强指 ETDI 针对 MCP 生态中的工具抢注与 rug pull 攻击，以 OAuth 增强的工具定义和策略化访问控制约束工具身份与版本变更 [829]。目前主要缺陷包括独立沙箱会增加资源和运维成本；技能与工具的权限边界依赖清晰定义；注册与签名机制难以发现已授权工具内部的业务逻辑漏洞。 • 高危操作底层架构阻断方案：敏感操作人机闭环指将删除、付款、数据修改等操作标记为需审批工具，审批前暂停工作流并保存检查点，恢复时从原位置继续执行，Microsoft Agent Framework 在工具审批、工作流暂停恢复与检查点保护上提供配套机制 [830]。目前主要缺陷包括人工确认会降低长流程执行效率；频繁审批容易造成审核疲劳；检查点若遭篡改，可能使工作流从错误或不可信状态恢复。 • 无服务器安全执行架构方案：托管代码沙箱指将模型生成的代码交给平台管理的容器化环境执行，避免直接接触智能体宿主系统。Amazon Bedrock AgentCore Code Interpreter 在隔离沙箱中运行代码，并提供受限网络、公共网络和 VPC 等访问模式 [831]。集群级隔离单元指在 Kubernetes 中为不可信代码配置独立、有状态的单副本执行环境。GKE Agent Sandbox 面向智能体运行时隔离 LLM 生成代码，并减少其对宿主节点的直接访问 [832]。沙箱逃逸能力评测指 SandboxEscapeBench 以嵌套沙箱 CTF 形式安全测量智能体利用容器错误配置、提权缺陷与内核漏洞实现逃逸的能力，结果表明存在漏洞时前沿模型能够可靠利用，隔离架构需以此类评测作为验收依据 [559]。目前主要缺陷包括沙箱环境仍有启动和资源成本；网络、文件和外部服务权限需要额外配置；评测表明存在漏洞时容器隔离可被前沿模型突破，需要持续验收。

续下页

表 4.2 – 续上页

模块	现有方案 & 不足
交互 (协同层)	• 多智能体信任拓扑架构方案：主体身份独立划分指为每个智能体分配独立的工作负载身份，不再默认信任同一集群或协作网络中的其他主体。Red Hat OpenShift AI AgentRuntime 可为智能体注入身份代理，通过 JWT 验证、令牌交换和 SPIFFE 身份管理智能体之间的连接 [833]。安全协作权衡设计指防护机制会影响协作效率，Multi-Agent Security Tax 量化了多智能体系统中安全措施与协作能力之间的权衡，为信任域粒度设计提供参照 [515]。哨兵智能体监测指在协作网络中部署独立的哨兵智能体持续监测消息与行为，为多智能体系统提供不依赖单点组件的安全监督层 [834]。目前主要缺陷包括身份可信并不代表行为始终可信；安全措施与协作效率存在权衡；哨兵监测自身也可能成为攻击目标。静态身份认证无法适配智能体动态行为异变，难以抵御可信节点后天黑化风险。 • 跨系统交互安全网关架构方案：MCP 入口集中治理指在智能体与外部工具之间设置统一网关，集中处理身份认证、权限范围和工具暴露。Red Hat OpenShift 的 MCP Gateway 以 OAuth 2.0 和限定范围的令牌控制智能体对工具的访问 [835]。MCP 协议栈安全分析指相关研究对 MCP 协议栈进行系统性安全分析，梳理工具调用链路中的攻击面与防护缺口，可作为网关校验规则的设计输入 [809]。工具流量安全代理指在远程 MCP 服务之前增加安全代理，对工具定义、输入和返回内容进行检查。Prisma AIRS MCP Server 作为集中式安全网关验证 MCP 工具调用，并检查工具输入、输出及 Schema 中的风险 [836]。目前主要缺陷包括集中网关可能成为性能瓶颈和单点故障；跨平台身份与权限模型仍不统一；网关能够约束接口调用，但难以判断复杂协作任务的真实意图。网关校验多聚焦语法合规性，无法深度判别工具调用背后的恶意语义逻辑。 • 会话生命周期架构管控方案：会话状态按应用隔离指将交互状态绑定到具体用户、应用或智能体实例，避免不同主体复用同一上下文。Oracle OCI Generative AI Hosted Applications 为不同应用配置独立托管存储 [837]。协作上下文分层保存指分别管理临时对话、任务过程和跨会话保留信息。IBM watsonx Orchestrate 将状态化上下文作为独立组件，用于协调多智能体与混合工作流 [838]。长会话诱导防护指多轮个性化社会工程研究表明，攻击者可利用上下文积累实施渐进式诱导，因此需限制会话周期和上下文范围 [720]。目前主要缺陷包括会话隔离增加跨任务信息复用成本；分层不当可能导致信息重复或缺失；渐进式诱导检测对缓慢话题偏移仍不敏感。上下文分层边界缺少形式化定义，业务迭代过程中易出现层级混乱。长会话上下文缺乏动态风险清洗机制，恶意载荷可长期潜伏累积。会话周期静态阈值无法适配差异化业务场景，适配灵活性极差。跨会话合法数据复用缺少安全校验机制，易引发隐性隐私泄露风险。会话状态隔离未联动权限动态更新，退役残留状态易形成安全隐患。
治理 (管控层)	• 分层合规基线架构体系方案：通用控制基线指以统一安全控制集为治理底座，再按智能体类型、部署环境和数据敏感度选取控制项。NIST COSAIS 计划在 SP 800-53 基础上形成面向生成式 AI、单体及多智能体系统的可裁剪控制叠加层 [839]。智能体专项标准指在通用 AI 治理之外，重点规范智能体身份、授权、安全通信与跨系统互操作。NIST AI Agent Standards Initiative 已将安全身份、授权机制和开放协议列为标准化重点 [840]。治理理论框架指 Kolt 从委托代理关系出发，将可见性、控制和责任分配作为智能体治理的核心原则 [841]。目前主要缺陷包括通用控制项仍需人工映射到具体组件；专项标准尚未成熟；统一基线难以覆盖医疗、金融和工业等行业差异。 • 动态基线迭代架构方案：版本与实例分离指分别管理智能体定义、发布版本和部署实例，避免模型或策略更新直接覆盖运行版本。Microsoft Foundry Agent Application 通过稳定入口及独立版本、部署对象控制更新 [842]。治理模板下发指将网关、身份、网络和策略固化为可重复部署模板。Google Cloud Agent Platform with Governance 将 Agent Gateway、基础设施和安全策略纳入统一架构 [843]。统计化部署门禁指 AgentAssay 将非确定性智能体的回归测试和部署验收建模为统计决策过程，为基线变更提供量化依据 [810]。目前主要缺陷包括版本和策略同步增加发布复杂度；模板对异构云及本地环境适配有限；统计门禁受测试场景覆盖限制，无法穷尽智能体行为。 • 全链路观测审计架构方案：统一遥测语义指统一智能体、会话、工具调用和模型请求的日志字段，实现跨框架轨迹关联。OpenTelemetry 生成式 AI 语义约定已定义智能体标识、会话标识、工具调用、模型请求和令牌使用等属性 [844]。可审计性设计指 Auditable Agents 提出行为可恢复、生命周期覆盖、策略可校验、责任可归属和证据完整五项要求，并将可审计性前置为系统设计原则 [646]。执行溯源框架指相关综述将智能体执行表示为类型化溯源图，统一纳入检索依据、工具调用、记忆谱系和多智能体消息 [512]。目前主要缺陷包括完整轨迹可能泄露提示、工具参数和敏感数据；统一语义依赖各框架正确实现；高频调用下的日志采集、存储及跨服务关联成本较高。

4.3 编码开发阶段安全（安全工程落地）

编码开发阶段是 AI 智能体全生命周期安全落地的核心工程环节，承接架构阶段的原生安全拓扑与隔离约束，将顶层安全能力下沉至代码生成、依赖管理、工具调用与研发流水线全链路，弥补架构设计与代码制品落地的安全断层。本阶段通过输入边界隔离、代码记忆管控、推理约束与权限收敛，重点防控编码漏洞、供应链投毒、恶意代码生成及研发协同污染等工程安全风险 [845]。本节系统梳理编码阶段主流防护体系，深入剖析其场景短板与落地痛点，具体如下（详见表 4.3）：

- **行业形成三类互补型编码防护范式，构建层级化工程落地体系，但各范式存在明确场景边界与落地约束。**学术研究型方案聚焦任务一致性校验、恶意意图识别与上下文风险治理。Task Shield 通过实时任务对齐校验，有效抵御编码场景下的间接提示注入，弥补静态代码扫描的语义风险盲区 [795]，但依赖复杂行为建模，实时部署成本较高。工程机制型方案依托声明式策略、工具审批与沙箱隔离，将安全控制嵌入编码工作流。Progent 通过可编程权限策略约束工具调用范围，保障任务执行最小安全边界 [20]，适配现有研发流程，需随业务迭代持续优化规则。产业平台型方案整合代码审查、密钥检测与环境隔离能力。Amazon Q Developer 在代码生成链路中嵌入安全扫描，可识别注入漏洞、硬编码凭证等常规风险 [846]，工程成熟度高，但高度绑定厂商生态，异构环境迁移成本高昂。三类范式各有侧重，尚未形成覆盖全模块、全流程的统一编码安全体系。
- **六大功能模块具备代码级基础防护能力，但跨模块联动与全流水线闭环防护存在显著短板。**感知模块依托输入筛查与敏感内容过滤管控编码请求，Google Cloud Model Armor 可实现提示注入、敏感数据与恶意内容全域检测 [847]，难以抵御编码混淆与多轮隐性诱导逃逸攻击。记忆模块通过分区存储与访问授权约束跨项目数据流转，Collaborative Memory 依托公私记忆分片隔离规避数据串扰 [788]，无法彻底清除缓存、向量副本等隐性残留数据。决策模块结合代码复核与安全评测约束推理逻辑，SecureVibeBench 可有效规避编码过程中的新增漏洞风险 [848]，但规则覆盖有限，难以适配复杂分支推理场景。行动模块基于最小权限与沙箱隔离管控工具调用，ToolPrivBench 验证了智能体高权限自选隐患，需双重管控工具选择与执行流程 [796]，无法抵御多工具组合滥用风险。交互模块依托身份令牌与委派校验保障协同安全，Agentic JWT 可有效抑制多级委派权限扩张问题 [634]，跨组织身份互认机制薄弱。治理模块通过基线门禁与全链路审计追溯风险，Agent-BOM 可重构跨模块攻击链路 [593]，多平台日志不统一导致审计溯源能力受限。各模块局部防护独立有效，但风险标签与权限状态无法跨链路贯通，难以形成完整研发安全闭环。
- **现有静态防护范式与敏捷研发适配性不足，安全、效率、成本的多元均衡防护体系尚未成熟。**当前编码安全以预配置静态规则与固化基线为主，仅适配简单稳定场景，难以匹配智能体动态迭代的研发特征。DeepContext 研究证实，多轮正常编码请求可逐步累积高危风险，静态规则无法识别此类渐进式隐患 [582]。严苛的静态防护会增加研发阻力、抬高运维成本，宽松策略虽提升效率，但会大幅扩大系统攻击面。SonarQube AI Code Assurance 依托迭代式质量门禁校准代码安全基线 [849]，但紧急迭代仍会破坏防护稳定性。SafeHarness 构建输入、权限与回滚一体化防护链路，实现策略动态适配 [629]。传统防护体系缺少分级差异化管控逻辑，难以适配多元研发场景需求。刚性安全校验流程与敏捷开发流水线适配性差，严重拖累迭代效率。依赖人工调优的策略更新模式成本高昂，无法支撑规模化批量部署。未来编码安全需突破静态单点管控，构建跨模块联动、动态权限迭代的自适应防护机制，实现安全、效率与成本的动态均衡。

表 4.3: AI 智能体**编码开发阶段**现有安全解决方案与缺陷

模块	现有方案 & 不足
感知 (输入层)	• 编码场景输入边界架构隔离: 任务对齐校验指在编码请求、仓库内容和外部文档进入智能体前, 检查新增指令是否仍服务于原始开发任务。Task Shield 通过持续评估任务一致性降低间接提示注入对智能体行为的影响 [795]。编码攻击面建模指针对技能、工具和协议生态分别划分信任边界, 避免将提示注入仅视为文本过滤问题。相关研究系统梳理了编码智能体中的输入操控、工具投毒、协议利用与跨来源上下文污染 [850]。任务来源约束指仅允许具备仓库权限的主体触发编码任务, 并将生成修改保留在独立分支中。GitHub Copilot coding agent 要求生成结果在合并前接受人工审查 [851]。目前主要缺陷包括合法用户也可能提交恶意任务; 任务一致性判断对模糊需求较敏感; 独立分支只能隔离修改, 不能证明生成代码安全。 • 编码输入敏感信息拦截: 敏感上下文最小暴露指编码智能体会同时接触源码、凭证和长期上下文, 相关研究指出需要将秘密数据与普通任务内容分开保护, 并限制其进入代理链路 [396]。企业过滤器联动指通义灵码企业过滤器可将待检查文件交给组织自定义扫描服务, 并通过安全 Token 验证调用身份, 使专属敏感规则能够前置进入编码流程 [852]。推送前密钥阻断指 GitLab Secret Push Protection 在服务器接收提交前检查 API 密钥和访问令牌, 发现风险后拒绝推送并返回位置与类型 [853]。目前主要缺陷包括拆分、编码和动态拼接的密钥仍可能漏检; 规则误报会阻断正常提交; 已经进入历史记录的凭证仍需撤销和轮换, 整体闭环防护仍存在短板。 • 编码对抗输入防御: 语义权限分离指 AgentVisor 将编码智能体视为不可信执行主体, 并在工具调用前通过独立安全层检查直接与间接提示注入 [854]。输入统一筛查指 Google Cloud Model Armor 可对提示、代码文档和工具返回内容执行提示注入、敏感数据及恶意链接检查 [847]。目前主要缺陷包括自适应和多轮攻击可能绕过单次检测; 严格筛查会误拦正常技术内容; 外部安全层本身也需要可信部署与持续迭代更新。分层输入归一化清洗指现有检测多基于原始文本匹配, 缺少针对编码语法结构、注释隐写、分段拼接载荷的结构化净化机制, 对抗样本极易规避规则筛查。上下文拼接污染防御缺失指多轮对话累积的隐性污染输入难以被单轮检测识别, 长期迭代易造成智能体编码逻辑持续性偏移。会话输入时序校验缺失指现有防御方案多聚焦单帧输入检测, 未针对多轮编码会话的时序输入特征建立校验机制, 无法识别渐进式恶意输入渗透。
记忆 (存储层)	• 编码记忆分层隔离架构: 私有与共享记忆分区指 Collaborative Memory 将用户私有片段与共享片段分别保存, 并通过随时间变化的访问策略控制跨主体读取 [788]。企业私有化隔离指 Baidu Comate 提供企业私有化部署方案, 使代码、项目上下文和组织知识能够保留在受控环境中, 减少敏感研发数据进入公共服务链路 [855]。多层开发记忆指华为云 AgentArts 采用短期会话、中期业务上下文和长期知识库的分层结构, 降低不同范围信息混用风险 [856]。目前主要缺陷包括记忆层级仍依赖人工划分; 共享片段的权限变化会增加一致性维护成本; 错误分区可能造成越权检索或知识遗漏。分层边界动态适配不足, 现有静态分层架构无法适配项目迭代、代码重构、多人协作开发的动态场景, 易出现上下文交叉混杂问题。 • 编码记忆生命周期管控: 选择性保留与遗忘指 FiFA 通过多种保留策略在任务连贯性、隐私和存储成本之间进行权衡, 为长期编码记忆的压缩与清理提供评测依据 [775]。记忆删除接口指阿里云百炼记忆库支持删除指定记忆和清空记忆空间, 为项目结束或权限变化后的数据清理提供工程接口 [857]。目前主要缺陷包括显式删除不一定同步清除缓存、摘要和向量副本; 遗忘策略可能损失必要上下文; 跨知识库关联删除仍难以自动完成。记忆时效管控缺失指多数编码智能体缺少强制过期与自动失效机制, 废弃项目记忆、过期配置、失效样本会长期驻留形成存量污染源。批量退役清洗能力薄弱指集群化、多项目并行场景下, 缺少批量记忆清零与污染阻断机制, 极易引发跨项目记忆串扰风险。 • 代码记忆访问权限约束: 检索与授权分离指相关研究指出, 语义相关性不能代替访问授权, 并通过服务端属性访问控制阻断跨租户知识泄露 [609]。角色权限控制指百度千帆通过 IAM 管理用户和子用户权限, 限制不同开发主体访问或修改共享知识资源 [858]。目前主要缺陷包括权限粒度难以细化到单条记忆; 身份在多级调用中可能丢失; 合法用户仍可能写入错误或恶意内容。动态权限适配不足指现有权限体系多为静态配置, 无法跟随项目迭代、人员变动、权限回收实现记忆访问策略的动态自适应更新。跨层记忆隔离薄弱指短期会话缓存、中长期向量记忆、离线归档记忆缺少统一权限收敛机制, 易形成多层级隐性越权访问链路。记忆写入侧管控缺失指当前防护多聚焦读取权限管控, 对用户主动写入的污染代码、错误配置、恶意样本缺少前置校验与拦截机制。

续下页

表 4.3 – 续上页

模块	现有方案 & 不足
决策 (推理层)	• 编码推理双轨安全架构：独立反思复核指 Reflection-Driven Control 在代码生成过程中加入独立反思环路，持续检查决策路径并注入安全修复依据 [859]。生成结果独立审查指 Amazon Q Developer 代码审查将静态安全分析和秘密检测置于生成流程之外，用于发现注入、跨站脚本及硬编码凭证等问题 [846]。关键节点外部校验指 Claude Code Hooks 可在提示提交、工具调用和执行前后触发独立检查或阻断逻辑 [860]。目前主要缺陷包括复核链增加推理时延和维护成本；安全规则需要持续更新；外部 Hook 若权限过高，也可能成为新的攻击入口。双轨校验时序适配不足指现有复核机制多针对单次代码生成结果校验，缺少对多轮迭代推理过程的持续性动态监控。 • 编码自主规划约束：规格驱动安全评估指 SeClaw 依据结构化风险规格生成安全任务，并结合执行轨迹评估智能体在文件、工具和环境中的不安全行为 [861]。安全结果联合验收指 SecureVibeBench 将功能测试、静态分析与动态安全检查结合，要求编码智能体不仅完成任务，还不能引入新的可利用漏洞 [848]。任务规格分步展开指 Kiro Specs 将需求、设计和实现拆分为结构化任务列表，减少复杂开发过程中的目标漂移 [862]。目前主要缺陷包括规格仍需人工维护；测试任务无法覆盖全部真实项目；过细的任务拆分可能降低重规划和异常恢复能力。动态任务适配能力缺失指固定结构化规格难以适配复杂多变的业务开发场景，迭代式需求变更更易引发规划逻辑失效。自主规划风险预判不足指智能体自主重规划过程缺少前置风险推演，易在异常场景下生成违规、高危的执行路径。 • 编码提示流完整性防护：语义信息流追踪指 NeuroTaint 从外部输入、记忆和工具结果中重建不可信信息到高权限操作的传播路径，识别经过改写或跨会话保留的影响 [779]。项目安全指令固化指 Snyk Studio 可向编码智能体注入安全开发指令，并联动代码与开源依赖扫描 [863]。目前主要缺陷包括长链路语义追踪成本较高；摘要和重写会削弱来源判断；固定指令无法覆盖所有项目特有的业务约束。多轮提示污染溯源困难指迭代式、碎片化的隐性提示篡改难以被语义追踪机制识别，长期累积会持续污染编码推理逻辑。安全指令迭代滞后指固化的静态安全指令无法跟随代码漏洞库、合规标准实时更新，防护存在时效性短板。
行动 (执行层)	• 编码工具能力管控：可编程最小权限指 Progent 以声明式策略约束工具调用条件和失败回退，使编码智能体仅执行完成任务所需的操作 [20]。恶意 Skill 联合检测指 MalSkillBench 表明，第三方 Skill 同时包含指令、代码和工具权限，单独使用供应链扫描或提示注入检测都难以覆盖完整风险 [864]。低权限工具优先指 ToolPrivBench 发现智能体在存在低权限替代工具时仍可能选择高权限能力，说明工具选择和执行阶段都需要权限约束 [796]。目前主要缺陷包括策略编写依赖准确任务描述；动态更新可能引入不确定性；已获授权的工具内部仍可能存在实现漏洞。工具调用行为审计薄弱指现有管控聚焦权限拦截，缺少对工具调用频次、时序、组合行为的异常监测机制。第三方工具风险管控不足指开源生态工具数量庞大，批量接入场景下难以实现全维度、常态化的安全风险核验。权限策略泛化能力差指定制化工具权限策略难以跨项目、跨场景复用，大幅提升企业运维配置成本。 • 高危编码操作底层阻断：执行前确定性授权指 Open Agent Passport 在工具调用前同步检查身份、策略和任务范围，并为授权结果生成签名记录 [607]。交互式危险操作审批指腾讯 CodeBuddy Code 默认采用只读权限，并在编辑文件、运行测试或执行 Shell 命令前请求明确授权，使用户能够按次或按范围放行操作 [865]。隐式恶意意图评测指相关研究发现，恶意目标可被拆解为多个表面正常的技术步骤，因此高危阻断还需结合逐步护栏和执行后果推演 [866]。目前主要缺陷包括逐次授权会增加高频工具调用时延；策略过严可能阻断合法运维；多个低风险操作组合形成的危险结果仍需轨迹级判断。组合式高危行为识别不足指单一操作校验机制无法识别分步拆解、时序叠加的隐性高危行为，存在逃逸风险。授权生命周期管控缺失指临时授权凭证缺少自动过期、回收机制，易留存长效权限漏洞引发越权操作。 • 隔离式编码执行架构：高权限执行评测指 BashArena 在真实 Linux 管理任务中设置恶意软件执行、提权和关闭防火墙等隐藏目标，用于检验监控与隔离机制 [867]。沙箱与审批协同指 OpenAI Codex 通过文件写入、网络访问和受保护路径限制确定技术执行边界，并由审批策略控制越界操作是否需要人工确认 [868]。弹性代码沙箱指腾讯云 Agent Runtime 可按任务创建并回收代码沙箱，并通过网络模式限制外部资源访问 [869]。目前主要缺陷包括沙箱创建、依赖缓存和状态恢复会增加开销；配置错误可能扩大攻击面；隔离环境不能保证生成代码本身不存在漏洞。沙箱动态隔离能力不足指静态隔离规则无法适配复杂编码任务的动态资源需求，易出现隔离过度或防护不足问题。

续下页

表 4.3 – 续上页

模块	现有方案 & 不足
交互 (协同层)	• 多智能体编码协同信任架构：委派意图绑定指 Agentic JWT 将智能体身份、用户意图和工作流步骤写入可验证令牌，防止多级委派中权限静默扩张 [634]。拓扑异常监测指 G-Safeguard 在多智能体消息图上检测异常传播并实施拓扑干预，为协同编码中的污染扩散提供独立监测层 [727]。代理权限区分指 Microsoft Entra Agent ID 区分委派权限与应用权限，并限制部分高风险目录权限授予智能体 [870]。目前主要缺陷包括多级委派增加令牌撤销和密钥管理难度；身份合法不代表行为可信；跨组织身份互认仍缺少统一实现。协同节点动态信任缺失指现有静态信任架构无法根据协作节点历史行为动态调整授信等级，难以抵御恶意节点长期潜伏渗透。 • 跨系统编码网关防护：协议威胁建模指形式化 MCP 安全框架从身份、工具、数据流和协议实现角度分析跨系统调用风险，为网关规则设计提供依据 [360]。授权流程标准化指 MCP 授权规范要求 HTTP 服务器采用 OAuth 2.1、受保护资源元数据和授权服务器发现机制 [871]。目前主要缺陷包括不同服务器对权限范围的实现仍不一致；集中网关可能形成瓶颈；合法授权接口内部的业务漏洞仍难以发现。跨协议兼容防护薄弱指多系统协同编码场景下多协议混杂交互，单一网关规则体系难以适配异构协议的差异化安全风险。网关行为审计粒度较粗指现有网关防护多聚焦访问拦截，缺少对跨系统细粒度操作轨迹的持续溯源与异常研判能力。 • 编码会话生命周期管控：长会话意图漂移检测指 DeepContext 持续建模多轮交互中的意图变化，用于识别多个看似正常请求逐步累积形成的高风险编码目标 [582]。目前主要缺陷包括严格会话隔离会增加跨任务复用成本；长周期检测需要保存更多上下文；会话清理不会自动删除已写入仓库或长期记忆的数据。会话边界动态划分困难指复杂迭代开发任务存在任务交叉、流程嵌套问题，固定会话边界难以精准隔离独立编码任务风险。会话数据残留风险突出指会话终止后临时代码片段、调试信息与配置数据留存，易造成敏感研发信息间接泄露。
治理 (管控层)	• 编码合规基线体系：系统级安全基线指将大模型及其生成结果视为不可信输入，以最小权限、完全仲裁和纵深防御等系统安全原则约束编码智能体，并将控制范围延伸至代码仓库、开发工具、第三方依赖和执行环境。该思路强调，即使模型输出通过功能测试，也不能绕过身份校验、权限检查和隔离机制直接进入生产流程 [872]。代码规范自动检查指华为云 CodeArts Check 依据 CWE、CERT 和 OWASP 等规则扫描多种开发语言，可在代码提交、合并和流水线执行阶段识别注入、资源泄露、不安全调用及配置缺陷，将抽象安全要求转化为可执行的静态检查项 [873]。风险清单映射指 OWASP Top 10 for Agentic Applications 2026 归纳目标劫持、工具滥用、身份冒用、记忆投毒和异常自主行为等主要风险，可进一步映射到提示处理、工具授权、记忆写入、代码审查和执行审批等编码控制环节 [1]。目前主要缺陷包括系统级原则仍需人工映射到具体仓库、工具和流水线；静态规则难以识别业务逻辑缺陷与多步骤组合风险；行业规范和攻击模式持续变化，基线需要频繁维护；过严的检查与审批还可能增加误报并降低研发效率。 • 基线版本迭代管控：生命周期联动更新指 SafeHarness 将输入过滤、决策验证、权限控制、状态检查和失败回滚纳入统一执行链路，并利用跨层反馈协调策略变化，使模型、工具、依赖或运行环境发生更新时，相关安全控制能够同步调整 [629]。AI 代码质量门禁指 SonarQube AI Code Assurance 通过项目标记、专用质量门和严格质量配置管理 AI 生成代码，可将新增漏洞、代码异味、测试覆盖率和安全热点纳入合并与发布条件，使安全基线随项目版本持续执行 [849]。项目安全基线指 OpenSSF OSPS Baseline 按照项目成熟度和控制类别组织访问管理、漏洞处理、构建发布和依赖治理要求，可作为代码仓库与软件供应链的版本化检查清单，并为不同成熟阶段配置差异化安全门槛 [874]。目前主要缺陷包括跨层策略同步会增加配置、测试和发布复杂度；紧急修复可能因时间压力绕过完整评审；规则或质量门更新后，历史版本未必能够自动重新验证；不同代码平台、扫描工具和云环境的策略格式仍缺少统一转换机制。 • 编码全链路审计观测：统一安全审计图指 Agent-BOM 将模型、工具、记忆、目标、推理轨迹和执行动作表示为分层关联图，使代码生成、文件修改、外部调用和运行结果能够沿统一关系进行追踪，并支持重建风险从输入、推理到执行阶段的跨模块传播路径 [593]。构建过程证明指 SLSA Provenance 记录源代码、构建步骤、构建主体、依赖环境与最终产物之间的关系，为确认代码由谁生成、经过何种构建流程以及是否被中途替换提供可验证证据，也可用于连接智能体活动记录与软件供应链审计 [875]。目前主要缺陷包括完整轨迹可能包含源码、提示、令牌和访问凭证，审计系统本身也需要严格的数据保护；不同平台事件粒度与字段格式存在差异，跨系统关联成本较高。

4.4 安全测试评估阶段（安全验证防护）

安全测试评估阶段是 AI 智能体生命周期安全防护的核心验证闭环，旨在核验需求、架构、编码阶段部署的安全机制在真实运行环境中的实际有效性。智能体行为具备上下文动态生成特征，传统静态测试用例难以覆盖多轮交互催生的隐性风险，导致常规测评体系普遍存在漏检问题。本节梳理主流测评体系的技术特征，系统剖析其场景短板与工程约束，具体如下（详见表 4.4）：

- **三类标准化测评范式层级互补、覆盖全面，适配差异化场景，但均存在固有的工程约束与能力边界。**学术机理测评依托真实环境与细粒度行为建模，LITMUS 通过语义-物理双重验证定位系统级越狱危害 [876]，B3Bench 依托众包对抗机制界定模型安全边界 [877]，可精准识别渐进诱导、跨步骤越权等隐性风险，适配高安全等级场景，但算力开销大、量化标准不统一，难以嵌入自动化回归流水线。开源基准回归测评以标准化样本与容器化评测框架为核心，SeClaw 支持规约驱动的批量安全测试 [861]，McpTox 可真实复现工具投毒攻击场景 [878]，轻量化、无厂商绑定，适用于版本迭代常态化测评，但规则样本固定，对新型变异攻击检出能力有限。产业托管闭环测评依托厂商红队工具链与合规存证体系，Databricks BlackIce 对齐 MITRE ATLAS 体系实现标准化检测 [879]，微软 AI 红队智能体可自动化扫描并生成风险报告 [880]，合规性与稳定性突出，适配企业量产场景，但生态绑定严重，私有化与异构集群适配成本较高。
- **各模块单点测评能力成熟、可覆盖基础风险，但跨模块联动验证与全链路协同测评存在显著工程缺口。**六大功能模块均已形成标准化单点测评能力，可有效核验模块基础防护效果，但深度适配性与跨链路联动能力不足。感知模块可覆盖显性输入风险，但难以识别环境潜藏的隐性注入载荷，深层隐蔽攻击检出精度不足 [881]。记忆模块可排查存量污染与权限泄露，但元数据投毒溯源能力薄弱，长周期污染链路易断裂 [882]。决策模块可甄别常规决策失控与显性篡改，对超长上下文链式越权、隐性渐进违规的核验手段欠缺 [883]。行动模块可完成已知恶意操作回归测试，但难以标准化检测内核级逃逸与工具参数隐性滥用问题 [884]。交互模块可实现基础协同异常检测，但集群规模扩张后，多智能体风险溯源复杂度显著提升 [885]。治理模块可完成合规对标与审计存证，但规则自动编译精度低、批量回归效率差，难以适配高频迭代测评需求 [886]。整体而言，模块单点测评完备，但全链路协同验证体系尚未成型。
- **静态测评体系落地成熟、可复用性强，但其动态适配性不足，缺失检测深度、测评效率与合规成本的三元均衡机制。**当前主流测评以固定样本、静态规则与离线校验为主，配置规范、结果可复现，可有效覆盖显性静态风险，是现阶段安全测试的核心基底。但静态测评逻辑与智能体自主演化、渐进诱导、拓扑动态迭代的核心特征天然失配，难以适配动态变异的新型攻击手段 [887]。三类测评范式各存短板：学术测评精度高但算力成本高昂、迭代效率低；开源测评轻量化易集成，但高阶隐性漏洞检出能力有限；产业测评合规闭环完善，但生态锁定严重、私有化改造成本高。OWASP 红队指南证实，行业尚未形成多目标量化测评体系，无法兼顾不同安全等级与迭代速率的差异化测评需求，三元均衡的动态测评范式仍处于空白状态 [888]。静态测评规则库更新滞后于智能体攻防技术迭代速度，难以同步适配新型隐写提示注入、多轮渐进诱导等新兴攻击范式。固定测评样本覆盖场景有限，无法模拟真实业务中高并发、多分支、长会话的复杂编码交互场景。离线测评模式无法实时追踪智能体动态决策偏差，难以捕捉长期上下文累积引发的隐性安全缺陷。现有测评指标多聚焦单一安全结果，缺乏对检测耗时、资源开销、合规适配度的量化权衡标准。

表 4.4: AI 智能体安全测试评估阶段现有安全解决方案与缺陷

模块	现有方案 & 不足
感知 (输入层)	• 输入层安全测试边界隔离架构：红队测试方法学基线指针对安全测试用例、恶意 Prompt 样本和第三方测试载荷划分可信等级，需要以统一的测试方法学界定测试边界。OWASP GenAI 红队指南从模型评估、实现测试、基础设施评估和运行时防护四个维度给出测试范围划分方法 [888]。但方法学以流程指引为主，可信等级标定仍依赖安全专家人工定级，不同企业测评基准不统一。注入定位测试指输入边界的有效性需要通过能够暴露并定位注入点的测试手段验证。PI-Hunter 通过自动化红队流程暴露并定位智能体链路中的提示注入位置 [881]。但自动化定位对深层隐写、混淆型恶意测试指令的覆盖能力有限；高频 CI/CD 测评流水线下的执行开销较大。 • 感知层隐私泄露专项测试：隐性泄露路径测试指输入侧隐私测试不仅要覆盖显式敏感字段，还需检测无痕泄露路径。Silent Egress 研究表明隐式提示注入可使智能体在不留下明显痕迹的情况下泄露数据 [889]。但对分段拆分密钥、注释隐写凭证的识别准确率低；端侧与网关侧隐私规则不同步，批量测试易产生脱敏盲区。自动化探测工具链指隐私泄露测试需要可复用的自动化探测与评分流程。微软 AI 红队智能体将其开源风险识别工具集的多轮攻击策略与风险评分能力集成至端点扫描流程，可批量探测提示注入、越狱与信息泄露风险 [880]。但通用探测策略对行业专属涉密字段无原生识别能力；评分依赖判别模型，长上下文语义关联泄露漏判较多。 • 感知层对抗性测试防御验证：危害性行为基准指对抗输入测试需要覆盖多类危害并同时测量拒绝行为与越狱鲁棒性。AgentHarm 针对恶意多步骤智能体任务构造标准化基准，显式度量模型拒绝率与对越狱攻击的鲁棒性。但基准任务集合固定，对新型诱导手法覆盖滞后；模型量化压缩后检测精度出现衰减。计算机使用场景评测指图形界面智能体面对截图、点击等复合输入，需要在真实操作系统环境中评测。OS-Harm 在 OSWorld 环境中覆盖蓄意误用、提示注入攻击与模型失当行为三类风险 [890]。但真实环境评测执行成本高；扫描规则以已知攻击模式为主，对自适应迭代式对抗样本识别能力不足。对抗样本动态规避能力薄弱指现有测试体系多针对静态攻击样本，难以有效验证智能体对动态迭代、自适应绕过攻击的防御稳定性。
记忆 (存储层)	• 记忆分层存储安全测试架构：分层数据管理测试指会话缓存、项目样本库与全局知识库之间的越权流转需要通过分层机制加以检测。AgentSafe 通过分层数据管理机制约束多智能体系统中不同敏感等级信息的存取范围，为分区隔离测试提供参照 [891]。但分层架构下合规测试样本跨项目复用流程繁琐；物理分区存储资源开销大，中小研发团队部署成本高。记忆操纵维度测试指记忆层测试需要纳入标准化红队维度。CSA 智能体红队指南将记忆操纵与权限提升、编排缺陷、供应链风险并列为需要专项测试的关键维度，并给出可执行的测试步骤 [892]。但指南以维度清单为主，缺少子项目细粒度隔离的判定标准；集群内部数据串漏仍需自行设计用例。分层边界模糊测试缺失指现有测试缺少针对多层记忆交叉调用、边界模糊场景的专项验证，易遗漏隐性越权漏洞。记忆生命周期全流程测试缺失，未覆盖数据写入、留存、更新与销毁全链路的安全校验场景。多智能体协同记忆共享测试空白，无法有效检测多节点交互过程中的记忆交叉泄露风险。 • 记忆投毒与决策污染测试：元数据投毒检测测试指记忆与元数据中的恶意内容可能不经显式指令即改变决策。MindGuard 通过对智能体内在决策过程进行检查，识别元数据投毒导致的行为偏移 [882]。但内在决策检查依赖模型内部表示，蒸馏与量化模型下判别能力下降；对合法通道植入的隐性载荷检出率有限。失效模式分类测试指投毒测试需要以真实红队实践归纳的失效模式作为用例来源。微软《智能体 AI 系统失效模式分类》基于红队实战证据归纳记忆投毒等失效类别，并在新版本中补充了实际观测到的新增类别 [893]。但分类体系更新依赖厂商实践积累，对长尾行业场景覆盖不足；分类粒度与具体测试用例之间仍需人工映射。持续性记忆污染测评不足指单次静态检测无法识别长期迭代、渐进式的隐性记忆投毒行为，存在持续性安全隐患。 • 记忆访问权限渗透测试：权限撤销有效性测试指记忆与资源授权在任务结束后是否真正失效，需要专项验证。Lingering Authority 提出面向编码智能体的可撤销资源与效果能力模型，用于检验授权残留问题 [894]。但撤销机制对长周期历史数据的覆盖有限；大规模批量检索场景下校验开销激增。反馈侧信道泄露测试指即使访问被拒绝，拒绝反馈本身也可能泄露信息。Causality Laundering 研究揭示了工具调用智能体中的拒绝反馈泄露路径，为越权测试补充了侧信道用例 [895]。但侧信道用例构造复杂，自动化程度低；无法防御通过合法权限通道间接植入的隐性投毒载荷。

续下页

表 4.4 – 续上页

模块	现有方案 & 不足
决策 (推理层)	• 推理链路双轨安全测试架构：规划轨迹异常检测指推理测试需要识别“任务与计划不匹配”和“计划结构畸形”两类异常。Trajectory Guard 采用序列感知模型对智能体多步骤行动计划进行实时异常检测，兼顾任务对齐与序列有效性 [883]。但检测模型依赖训练分布，对未见任务类型泛化能力有限；实时检测持续占用推理算力。护栏可用性测试指安全护栏自身也可能成为攻击目标，需纳入测试范围。From Shield to Target 研究表明针对大模型护栏的拒绝服务攻击可使防护组件失效 [896]。但护栏可用性测试尚无统一指标；审核链路规则固化后，对新型未知恶意决策识别能力不足。双轨校验联动性不足指现有轨迹检测与安全护栏多为独立工作机制，缺少联动校验逻辑，易出现单边防护失效的漏洞。推理时延与安全精度难以兼顾指高强度全链路实时检测会显著增加推理开销，轻量化模型又会降低异常识别准确率。 • 自主规划能力边界测试：情境行为安全评测指规划边界测试需要在功能环境中观察智能体的真实行为风险。BeSafe-Bench 面向情境化智能体揭示其在功能环境中的行为安全风险 [897]。但情境构造依赖人工设计，复杂规划场景测评效率低；对长周期隐性风险路径辨识度不足。评测流水线扫描指规划越权测试需要可规模化、可复现的对抗探测流程。promptfoo 提供面向大模型提示与应用的评测、测试与红队开源框架，可将越权用例固化为流水线断言 [898]。但流水线以已知策略库为主，无法发现零日推理层漏洞；扫描结果需人工复核以排除误报。动态规划越权测评缺失指现有测试多针对固定规划流程，无法适配智能体动态重规划、自适应任务调整带来的新型越权风险。复杂分支路径覆盖不全指多分支、多备选方案的复杂开发任务中，测试用例难以全覆盖所有潜在高危推理分支。 • 提示流完整性渗透测试：众包对抗基准指提示流完整性需要以高质量真实对抗样本验证。B3Bench 通过威胁快照框架与大规模众包红队收集高质量对抗攻击，形成面向智能体骨干模型的安全评测集 [877]。但威胁快照覆盖范围决定测试边界；超长上下文提示流传播路径分析存在算力瓶颈；对动态生成式中间提示节点的篡改风险覆盖不足；针对权限账户预置的隐性注入无防护效果。长上下文污染溯源困难指超长对话链路中碎片化、渐进式的提示篡改难以被基准样本识别，隐性污染溯源难度极大。
行动 (执行层)	• 工具调用能力安全测评：工具调用安全数据集指工具能力测试需要覆盖调用意图与参数层面的安全样本。ToolSafety 构建了面向大模型智能体工具调用安全的综合数据集，用于增强调用阶段的安全判别 [899]。但数据集覆盖边界有限，定制化业务工具的高危调用识别率低；全量工具能力隔离测评耗时久。真实 MCP 服务器投毒基准指工具生态测试需要基于真实服务器构造投毒场景。McpTox 在真实 MCP 服务器上构建工具投毒基准，覆盖工具描述篡改等攻击面 [878]。但基准依赖真实服务器快照，版本迭代后需重新采集；无法拦截合法工具的恶意参数调用攻击。容器化红队工具集指工具链测评需要统一的环境与工具编排。Databricks BlackIce 将多种 AI 安全工具打包为容器化红队工具集，通过统一命令行接口执行静态与动态测试并对齐 MITRE ATLAS 技术编号 [879]。但工具集以通用 AI 风险为主，智能体专属工具语义覆盖不足；容器镜像体积大，轻量流水线集成成本高。工具组合攻击测评缺失指现有测试多聚焦单一工具风险，对多工具串联、组合式高危操作的测评能力薄弱。工具版本迭代适配滞后指工具接口、参数更新后原有测试用例失效，需持续维护测评样本库。 • 高危操作行为基准测试：真实系统越狱基准指高危操作测试需要在真实操作系统环境中度量行为级越狱。LITMUS 面向真实操作系统环境构建智能体行为越狱基准 [876]。但样本集覆盖边界有限；纯语义识别易被混淆指令绕过。步骤级护栏反馈测试指高危操作阻断需要在调用步骤粒度上验证。ToolSafe 通过主动式步骤级护栏与反馈机制提升工具调用安全性，可作为步骤级拦截测试的参照实现 [900]。但步骤级拦截增加执行时延；硬规则固化后无法适配动态变异型高危操作。变异型高危行为识别不足指常规基准难以识别经过混淆、拆分、变形的隐性高危操作，防护逃逸风险突出。 • 执行沙箱隔离测试：不可信代码沙箱测评指执行环境测试需要面向不可信代码验证隔离强度。Sandbox-eval 针对不可信代码执行场景提出测试环境安全评估方法 [901]。但评估以已知逃逸路径为主，无法检测镜像预置型恶意载荷；大规模并发测评资源成本高。浏览器智能体沙箱测试指网页执行链路需要专门的隔离验证。ceLLMate 面向浏览器 AI 智能体提出沙箱隔离机制，可用于验证网页侧执行边界 [884]。但浏览器沙箱与宿主交互面复杂，隔离验证覆盖不全；会话级隔离带来额外资源开销；安全强度提升会带来一定比例的性能损耗。沙箱逃逸零日测评缺失指现有测评体系难以覆盖新型、未知的沙箱逃逸漏洞，主动防御能力受限。多级嵌套执行隔离薄弱指嵌套式代码调用、跨进程执行场景下，沙箱边界隔离有效性缺少专项验证手段。

续下页

表 4.4 – 续上页

模块	现有方案 & 不足
交互 (协同层)	• 多智能体协同交互安全测试：时序图建模检测测试指协同链路测试需要刻画消息随时间演化的异常模式。Guardian 采用时序图建模防护大模型多智能体协作过程，可用于检测协同交互中的异常传播 [885]。但时序建模在大规模集群下拓扑复杂度激增；隐性异步传导漏洞难以精准定位。传播感知探查测试指多智能体污染测试需要沿传播路径定位受影响节点。PropGuard 通过传播感知的探查与修复机制防护大模型多智能体系统 [902]。但传播路径分析依赖完整消息记录；长链路场景下溯源精度下降。工具适用性评估指智能体红队需要评估既有工具对协同场景的支持程度。CSA 针对 PyRIT 在智能体红队场景下的能力开展评估，分析其在准备、执行、分析和报告环节的适配性与缺口 [903]。但工具评估结论随版本变化，需要持续复测；跨异构智能体的交互兼容性仍显不足。协同组合攻击测评缺失指现有测试多聚焦单点异常行为，难以识别多智能体联动触发的组合式隐性风险。 • 跨系统接口安全测试：规约驱动用例合成指跨系统接口测试需要可扩展的用例生成方法。SeClaw 通过规约驱动的安全任务合成方法生成面向自治智能体的测试用例 [861]。但合成用例依赖规约质量，私有扩展字段的风险检测能力弱；用例爆炸导致测评成本上升。可及性测试平台指跨系统测试需要非专业人员也能参与的红队平台。ViolentUTF 提出模块化、可扩展的生成式 AI 红队平台，降低红队测试的技术门槛 [904]。但平台化封装弱化了底层细节，私有扩展字段的风险检测能力有限；加密流量深度检测存在解密时延与安全权衡问题。异构协议适配测评不足指多系统异构协议交互场景下，现有测试体系缺少协议兼容引发的隐性安全漏洞检测能力。接口动态变异风险盲区指接口参数动态迭代、字段自定义扩展带来的新型风险，难以被固化测试用例覆盖。 • 会话生命周期风险测试：上下文感知越狱测试指会话诱导测试需要能够随上下文自适应的红队智能体。RedAgent 作为面向大模型越狱的上下文感知自治红队智能体，可沿多轮会话动态调整诱导策略 [887]。但自适应策略生成算力开销大；最优阈值存在场景特异性，通用阈值泛化性差。红队系统自动优化指会话风险阈值测评需要可自动寻优的红队流程。AgenticRed 针对自动化红队任务对智能体系统进行优化 [905]。但优化过程依赖反馈信号质量；动态调参过程会产生临时安全盲区。多轮渐进式诱导测评薄弱指逐步叠加、隐性渗透的长会话诱导攻击，现有测试难以完整捕捉其风险演化过程。
治理 (管控层)	• 合规基线专项测试体系：风险清单对齐测试指合规用例需与公认风险清单对齐以保证覆盖度。OWASP 智能体应用十大风险 2026 由百余位贡献者评审形成，面向工具调用型智能体给出风险分类，可作为用例映射基线 [1]。但清单为通用风险排序，行业专属条目需自行扩展；风险条目与具体用例之间缺少自动映射机制。对抗技术知识库对齐指威胁测试需以公认的对抗技术分类作为映射基准。MITRE ATLAS 提供面向 AI 系统的对抗战术与技术知识库，可将测试发现映射至标准技术编号 [906]。但知识库以通用 AI 攻击面为主，智能体自治特性覆盖不足；复杂法规条款仍需人工二次校对。合规动态适配能力缺失指固定合规基线无法适配政策迭代、行业规范更新带来的测评标准变动。合规场景细粒度差异化不足，对金融、政务等高合规等级场景缺乏定制化测评规范支撑。基线阈值自适应调节能力薄弱，无法根据业务风险等级动态调整安全检测与判定标准。 • 基线版本迭代回归测试：演进式工作流回归指智能体基线更新后需在持续演化的真实工作流上回归验证。Claw-Eval-Live 面向不断演化的真实工作流构建在线智能体评测基准 [907]。但在线评测环境不稳定，结果可复现性受限；全链路回归耗时久，高频基线迭代场景效率低。能力与安全联合回归指基线更新不应以牺牲任务能力为代价，需同时回归能力与安全两侧表现。ClawsBench 在模拟工作环境中联合评测生产力智能体的能力与安全 [908]。但联合评测对非确定性执行敏感，结果波动较大；增量回归仅覆盖变更模块，隐性关联漏洞易遗漏。跨版本基线一致性缺失指多次迭代更新后易出现规则冲突、权限冗余等隐性问题，缺少跨版本对比测评机制。 • 全链路审计溯源测试：治理证据充分性评测指审计测试需判定留存证据是否足以支撑跨监管体制的追责要求。DEMM-Bench 面向智能体运行时治理提出跨体制的证据充分性评测基准 [886]。但跨体制映射依赖对法规的准确解读；轨迹解析复杂度高，司法举证时需专业人员辅助解读。框架级安全评估指审计测试需要覆盖智能体框架自身的实现缺陷。相关研究对 OpenClaw 及其衍生版本开展系统性安全评估，揭示了框架层面的实现风险 [909]。但框架评估随版本快速失效，需持续复测；全量轨迹采集存储开销极大。审计轨迹篡改验证缺失指现有测评默认审计日志可信，缺少针对日志篡改、轨迹伪造的专项对抗测试。分层溯源粒度不足指全链路审计难以精准区分人工操作、智能体自主执行、工具调用的细分责任边界。

4.5 部署交付阶段（安全防护固化）

部署交付阶段将研发环境的模型、工具与安全规则固化为生产环境可稳定运行的标准化系统，核心聚焦生产制品可信性、权限收敛、环境隔离与全链路审计追溯。智能体运行依赖模型权重、外部工具、长期记忆与多方接口，部署环节的版本偏差与配置疏漏，极易导致前期研发安全防护体系在生产环境失效 [910]。本节基于六大功能模块，系统梳理部署阶段现有防护方案与固有局限，主要结论如下（详见表 4.5）：

- **现有部署防护可解决制品溯源与生产准入问题，但全链路交付证据链存在断点缺失。**感知层部署防护已从单纯输入过滤延伸至模型镜像、依赖组件与流水线全流程管控，通过制品签名、溯源记录与 CI/CD 门禁校验制品合法性，同时依托静态扫描排查代码、配置与明文凭证风险 [638]。该机制有效提升部署可追溯性，但存在显著短板：仅能校验部署后文件完整性，无法甄别签名前模型后门问题；仅覆盖标准化流水线流程，难以管控人工替换、外部下载等非标操作。此外，动态插件、远程工具与运行时参数无法录入静态交付清单，现有体系仅可确认组件来源与构成，无法精准判定组件本身的内生安全性，难以抵御供应链前置污染风险。传统部署防护体系多针对固定业务程序设计，未适配智能体动态加载、插件热更新的部署特性。模型微调权重、第三方工具包等动态制品缺乏专属校验与准入审核机制。交付链路上下游缺少统一的安全基线联动校验，极易出现阶段性防护失效问题。前置研发阶段的隐性缺陷会随部署流程批量固化至生产环境，放大落地安全风险。
- **六大模块均具备落地化部署管控能力，但防护机制相互独立，缺乏跨模块联动闭环。**记忆层依托可信执行环境与短时凭证机制，隔离敏感记忆、密钥与用户上下文，规避高权限主体的非法访问 [396]，但无法抵御注入攻击引发的主动信息泄露，且落地效果受硬件条件与性能开销制约。决策层引入生产变更合约核验机制，高风险操作需经独立路径校验、授予临时权限后方可执行 [911]，有效规避决策权限滥用，但规则适配性有限，易出现场景漏覆盖或管控过度的问题。行动层通过沙箱隔离、系统调用限制与最小权限策略，约束恶意脚本与插件执行 [587]，但轻量沙箱存在内核共享缺陷，难以彻底杜绝逃逸风险，且无法约束长时序、多工具联动的复杂攻击链路。交互层依托专属身份体系与服务网格网关，规范智能体委派权限与跨主体通信行为 [912]，但仅能校验通信主体与接口合规性，无法识别业务语义异常与隐性越权协作。治理层通过 AIBOM、AgentRiskBOM 补充传统物料清单短板，全覆盖记录权限、记忆与通信配置 [913]，但闭源服务与人工操作存在记录盲区。整体而言，各模块单点防护成熟，但身份、策略与审计证据未实现全链路贯通，难以阻断跨模块链式风险传播，整体防护呈现碎片化特征。
- **现有部署基线可固化局部安全能力，但无法保障用户意图与全流程执行的一致性。**当前部署防护以制品完整性、环境隔离与权限管控为核心，各类安全机制独立生效，仅能管控局部风险，无法规避智能体推理、调用、传参过程中的意图漂移问题。单节点配置合规、组件安全，不代表全链路执行行为符合原始用户诉求，长任务链与多智能体协作场景下的行为偏移问题尤为突出。现有研究将智能体意图执行完整性拆解为指令、数据流、推理判断与工具执行多维度校验体系，用以甄别执行偏差风险 [914]，但尚未形成标准化部署管控手段。同时，传统灰度发布与版本回滚机制仅能控制风险扩散范围，无法撤销已产生的业务副作用与数据篡改，缺少完备的事件恢复与闭环处置流程 [915]。总体而言，现阶段可有效固化部署安全基线，但对运行时意图漂移、跨模块风险传导与事后应急恢复的管控能力仍存在明显短板，难以支撑量产环境的持续安全稳定运行，无法适配智能体动态演化的生产运行特征。

表 4.5: AI 智能体部署交付阶段现有安全解决方案与缺陷

模块	现有方案 & 不足
感知 (输入层)	部署制品与来源完整性验真： AI 供应链结构核验指交付前对数据来源、模型权重、推理框架、依赖包及底层基础设施进行统一盘点，并记录实际进入生产环境的版本。相关研究将 AI 供应链划分为数据获取、模型训练、模型推理与跨层基底四个层次，并以 48 个生产级开源项目说明当前系统在可验证性、版本管理、可观测性和可追溯性方面仍存在明显缺口 [910]。但结构性盘点只能说明系统由哪些部分构成，无法直接判断模型、数据或依赖是否已经被投毒；动态下载的组件也可能使交付清单很快过期。模型制品签名验真指模型权重、分词器、配置文件和相关数据清单在发布时组成统一签名单元，部署端再核对签名者身份与文件摘要。OpenSSF Model Signing 提供面向 AI 制品的独立签名格式，并支持企业 PKI、裸密钥及 Sigstore 无密钥签名流程 [916]。但签名只能证明制品由预期主体发布且签名后未被修改，不能判断签名前的模型是否已经存在后门或投毒；签名密钥和身份提供方本身仍需单独保护。构建证明准入指容器镜像进入集群前，由准入控制器核对其是否附来自指定仓库、工作流和构建主体的证明。GitHub Artifact Attestations 可配合 Sigstore Policy Controller，在命名空间层面对镜像证明和信任根进行验证 [917]。但证明只能覆盖已经被流水线记录的构建步骤；人工替换、外部下载和未接入工作流的处理环节仍可能形成证据断点。流水线来源证明指在构建过程中同步记录源码版本、任务定义、构建环境、参数及输出摘要，并对来源记录签名。Tekton Chains 能够为流水线生成和存储可验证的制品 provenance，使部署方能够追溯镜像由何种任务生成 [918]。但来源证明的可信度最终取决于构建器和签名环境是否安全；跨平台、离线交付和多集群环境中的证明格式与信任根仍需协调。 输入边界与交付配置校验： 智能体配置静态审计指部署门禁同时检查智能体代码、工具函数、MCP 配置、明文凭证和权限声明，并将扫描结果接入代码审查。Agent Audit 结合数据流分析、凭证检测、结构化配置解析和权限风险检查，可输出 SARIF 结果并直接接入 CI/CD 流程 [638]。但静态审计难以覆盖运行时生成的代码、动态拼接参数和远程工具内部行为；规则不完整时会漏检，规则过严又可能阻塞正常发布。生产出站流量最小化指在部署清单中默认拒绝外部网络出口，再按任务开放必要域名、端口和重定向路径，避免受污染内容诱导智能体静默外传上下文。Silent Egress 的实验表明，输出侧检查可能无法发现这类泄漏，而域名允许列表和重定向链分析更适合作为部署侧控制 [889]。但搜索、临时 API 和多级重定向会增加允许列表维护难度；规则过严可能影响正常工具调用，DNS、日志和其他旁路也可能成为新的外传通道。
记忆 (存储层)	部署态敏感状态机密执行： 可信执行环境总体保护指系统提示、用户上下文、长期记忆和工具凭证除静态加密外，还可置于可信执行环境，并通过远程证明确认运行代码与硬件状态。相关综述比较了六类可信执行环境，并将其保护能力映射到智能体的感知、规划、记忆、行动和协同环节 [396]。但可信执行环境主要防止宿主系统和高权限软件直接读取数据，无法阻止提示注入诱导智能体主动泄露信息；硬件漏洞也可能破坏既定隔离边界。边缘多可信区隔离指边缘设备交付时，将智能体运行时、推理引擎和第三方应用分别放入独立的机密虚拟机，再通过可验证通道交换必要状态。AgenTEE 基于 Arm CCA 实现多个独立可信区域，使组件之间不必共享完整地址空间和运行权限 [919]。但多可信区通信会增加运行开销，证明和故障排查过程也更复杂；该方案依赖特定硬件，普通终端和异构服务器难以直接复用。开放式机密推理服务指对于集中式模型服务，可在通用可信执行环境内运行推理服务，并向调用方提供可验证的代码和环境证明。OpenPCC 使用商用 TEE 构建开放式机密推理框架，使敏感请求不必依赖完全封闭的专有云实现 [920]。但机密推理仍需面对模型规模、内存容量和 I/O 性能限制；远程证明只能确认执行环境，不能证明模型输出本身正确或安全。终端模型隔离交付指对部署在用户设备上的轻量模型，可利用 Arm CCA 等硬件隔离模型权重、运行缓存和中间状态。相关研究对 CCA 中的端侧模型保护进行了早期评估，并分析了隐私收益与性能开销之间的关系 [921]。但实验主要面向端侧模型推理，尚未覆盖包含长期记忆、工具调用和多智能体协同的完整工作流；不同芯片平台的支持程度也并不一致。 凭证与持久化数据保护： 短期凭证动态签发指数据库、消息队列和外部服务凭证在实例启动或任务执行时按需生成，并通过租约限制有效期，避免长期账号随镜像和配置传播。HashiCorp Vault 数据库密钥引擎可以根据角色动态创建凭证，并负责续期与撤销 [922]。但应用需要正确处理凭证刷新、连接重建和租约失效；Vault 或目标系统插件异常时，可能造成凭证集中到期和业务中断。

续下页

表 4.5 – 续上页

模块	现有方案 & 不足
决策 (推理层)	• 生产变更证书化准入：证书化变更合约指智能体提出的高风险变更不直接转化为生产权限，而是先编译为包含操作范围、证据摘要、策略版本、执行身份和有效期的类型化合约。Sovereign Assurance Boundary 仅在合约通过认证路径后签发限定范围的准入证书 [911]。但合约类型和证据要求仍需结合具体业务人工设计；覆盖不足可能放过未预期操作，约束过细又会增加正常变更的维护成本。变更时刻强制核对指准入证书签发后，在基础设施真正发生修改前再次核对请求内容、证书范围、策略纪元、撤销状态和实时环境漂移。Sovereign Execution Broker 在检查通过后才签发短时执行身份，并记录签名的决策和执行结果 [923]。工具调用前确定性授权指在每次转账、数据库查询、Shell 执行或子智能体委派发生前，由独立控制层按声明式策略进行同步判断。Open Agent Passport 在工具调用前拦截操作，并为授权结果生成密码学签名记录 [607]。但逐次授权可能会增加工具的调用延迟。意图到执行完整性核验指发布门禁不仅检查最终输出，还应核对用户指令、规划结果、工具选择、参数和实际副作用是否保持一致。相关研究将完整性划分为指令、数据流、判断和工具四部分，用于判断智能体是否正确地把用户意图转换为系统操作 [914]。但业务意图往往难以完全转化为确定性规则；多个局部防护机制同时存在，也不等于端到端完整性已经得到保证。 • 集群策略与过程回退门禁：工作负载准入控制指智能体工作负载提交至 Kubernetes 后，在 API Server 阶段检查资源清单、镜像来源、特权模式、宿主机挂载和运行用户，并在不合规时拒绝创建。Kubernetes 准入控制器为资源写入集群前的策略执行提供统一入口 [924]。但集群准入主要判断配置是否合规，不能判断某次工具调用是否符合用户的真实意图；规则错误还可能造成集群级误放行或部署阻塞。指标化渐进发布指候选版本先承接少量流量，再根据成功率、延迟、拒答率、越权事件和资源消耗决定继续扩容、中止或回滚。Argo Rollouts 能够在灰度过程中运行 AnalysisRun，并根据指标结果控制发布进度 [925]。但指标选择不当可能放行危险版本或频繁触发误回滚，已经产生的外部副作用也不会随流量切换自动撤销。轨迹异常定位与重试指在交付版本中部署独立验证器，对规划步骤、工具调用和中间状态进行持续检查，并在出现异常时定位最早的错误步骤。TrajAD 将过程异常检测与精确定位结合，可为 rollback-and-retry 提供步骤级依据 [926]。不过专用验证器依赖训练数据覆盖范围，复杂业务中的合理偏离可能被误判。
行动 (执行层)	• 工具执行隔离与权限收敛：操作系统式资源隔离指将文件、网络、凭证、记忆和外部工具视为不同类型的系统资源，为各工具配置独立权限，并通过受控中介处理组件间通信。相关研究指出，智能体系统与操作系统在资源隔离、权限分离和通信中介方面面临相似问题 [927]。但智能体的工具调用和长期决策经常跨越传统进程边界，仅套用进程或容器权限仍难形成完整隔离；实际效果也高度依赖配置质量。非特权短时执行沙箱指对智能体生成的 Shell 命令、第三方脚本和临时插件采用默认拒绝的短时沙箱，分别限制文件系统、网络、IPC 和系统调用。Sandlock 利用 Landlock 和 seccomp 等 Linux 原语，在无需 root 权限的情况下实施内核级约束 [587]。但轻量沙箱仍与宿主机共享内核，不能完全抵御内核漏洞和侧信道攻击；在高对抗、多租户环境中仍需结合更强隔离。沙箱引擎安全选型指交付阶段根据攻击面、信息泄漏、补丁时效、CVE 记录和纵深防御能力比较微虚拟机、用户态内核与 OCI 容器，而不是只比较启动速度。相关研究从六个维度比较了五类 AI 代码沙箱的引擎级安全属性 [928]。但不同产品公开的漏洞和补丁信息并不对称，缺少已知 CVE 也不等于风险较低；部署方仍需结合自身威胁模型重新评估。沙箱保证边界说明指交付文档应明确沙箱能够测试和隔离哪些行为，并从保真度、可控性、可观测性、遏制能力和可复现性等方面说明其证据边界。AI Sandboxes 提出了面向数字智能体和具身系统的威胁模型与测量框架 [929]。但沙箱中的安全表现未必能够直接外推到真实生产环境；沙箱自身的监控、模拟和控制组件也可能成为攻击目标。 • 版本交付与状态恢复控制：身份稳定的金丝雀发布指新版本先向少量任务或设备开放，并在灰度期间保持已认证智能体的稳定身份。ICAN-Deploy 将能力名称与能力版本分离，使身份哈希在金丝雀窗口中保持不变 [930]。但该方案目前主要在安全关键的具身智能体场景中验证，向大规模纯软件服务迁移仍需进一步评估；灰度阶段产生的外部副作用也无法自动撤销。托管运行组件组合指云端交付可将工作负载隔离、短期身份、密钥管理、网络出口和模型访问控制组合为统一运行环境，而不是由智能体代码自行实现。Google Cloud 的智能体架构指南将容器执行、工作负载身份、Secret Manager 及受控网络等组件纳入部署选型 [931]。但托管组件会形成明显的平台依赖，跨云和私有化部署难以保持相同控制语义；配置错误仍可能抵消底层服务提供的安全能力。

续下页

表 4.5 – 续上页

模块	现有方案 & 不足
交互 (协同层)	• 智能体身份与委托连续性：非人主体身份登记指跨系统交付前，为每个智能体分配独立身份，并记录其所有者、授权来源、可代理用户和允许访问的资源。NIST 面向软件与 AI 智能体提出身份和授权概念框架，讨论识别、授权、审计、不可否认性和提示注入相关控制 [912]。但该框架仍处于概念与验证阶段，跨厂商身份格式、委托表达和撤销机制尚未形成统一实现。拓扑无关身份寻址指智能体在跨提供商迁移、实例扩容或跨组织联邦时，其身份不与 IP 地址或单一实例名称绑定。Agent URI 方案将稳定标识、信任根和能力路径分离，并使用密码学证明支持能力校验 [932]。但跨提供商注册、解析和撤销机制仍缺少成熟实践；稳定身份只能证明主体连续性，无法判断其当前行为是否合理。多智能体授权传播指在任务委派和结果聚合过程中持续传递授权范围、有效期和数据使用限制，避免子智能体获得超过原始用户的权限。相关研究将传递委托、聚合推断和时间有效性视为多智能体授权传播的核心问题 [933]。但复杂工作流中的授权边界会随任务拆分不断变化，传统 RBAC 或 ABAC 难以完整表达；频繁策略判断也会增加协作延迟。 • 协议网关与服务间通信治理：MCP 与 A2A 协议感知网关指跨智能体和工具流量统一经过协议感知网关，由网关处理身份验证、授权、路由、限流、遥测和追踪。agentgateway 为 MCP 与 A2A 提供协议级路由、细粒度授权和 Kubernetes Gateway API 接入能力 [934]。但网关会成为集中故障点和高价值攻击目标；对于复杂业务语义和加密载荷，网关能够检查的内容仍然有限。统一 AI 交互运行时指将 LLM、MCP 和 A2A 流量放入同一治理层，使模型请求、工具调用和智能体委派共享身份、策略与审计记录。Gravitee AI Gateway 采用统一运行时处理三类流量，并在同一位置执行授权和可观测性控制 [935]。但统一运行时扩大了单点配置错误的影响范围。服务网格授权与最小暴露指在服务网格交付时，限制授权策略的适用目标，并通过网关或 waypoint 代理执行入站、出站和网格内通信规则。Istio 安全实践建议明确策略作用范围，并避免因选择器或网关配置错误造成授权旁路 [936]。但服务网格只能控制连接主体、路径和部分请求属性，无法理解完整的智能体任务语义。
治理 (管控层)	• 智能体物料清单与交付证据：智能体权限风险清单指传统 SBOM 主要记录依赖，难以说明智能体能够访问什么、记住什么以及代理谁执行操作。AgentRiskBOM 在 SBOM、AIBOM 和 MLBOM 之上增加自主性、工具权限、记忆、凭证范围、审批关卡和跨智能体通信等字段 [913]。但该方案依赖部署方完整披露权限和组件配置，对闭源系统覆盖有限；风险分值和分类阈值仍需人工校准。签名 AIBOM 自动生成指在模型训练和发布过程中自动记录数据集、模型参数、环境与依赖，并使用哈希、数字签名和 in-toto 证明保护清单。AIBoMGen 通过第三方观察式训练平台生成可验证 AIBOM，并检测制品的未授权修改 [937]。但清单完整性依赖所有训练和处理步骤均经过受管平台；外部模型、人工操作和闭源数据仍可能形成记录缺口。风险扫描证据绑定指物料清单除列出组件外，还应关联模型完整性、序列化安全、适配器结构和运行行为等检测证据。AIRS 框架将威胁模型、自动扫描和机器可读证据结合，用于弥补传统 SBOM 只描述组成而不说明安全状态的问题 [938]。但目前验证主要集中在模型级风险，尚不能完整覆盖工具权限、长期记忆和多智能体协作；扫描结论也会受到测试样本和检测器能力限制。现有物料清单体系普遍割裂静态组件信息与动态运行风险，无法形成闭环可信交付链路。 • 标准化、持续审计与事件响应：开放 AIBOM 标准协同指通过跨组织共同定义数据集、模型、训练迭代和来源字段，使不同工具生成的 AIBOM 能够交换和验证。相关研究记录了 90 余名参与者推动开放 AIBOM 规范并通过法规映射、行业用例和实践访谈进行验证的过程 [939]。但标准形成速度通常慢于 AI 工具链变化，厂商扩展字段也可能重新造成格式分裂。生产环境持续审计指部署后将安全、公平性和合规要求转化为可监测约束，并随数据分布、系统反馈和用户交互变化持续评估。相关研究提出把真实环境中的 AI 审计视为不确定条件下的约束违规监测问题，而非一次性上线检查 [940]。但长期审计需要稳定的数据采集、基线和统计方法；过度采集可能引入隐私风险，审计阈值不合理也会产生大量误报。AI 事件响应预案交付指智能体上线时同步交付事件分类、证据采集、权限撤销、系统隔离、模型回退、数据恢复和对外通报流程。CoSAI 的 AI Incident Response Framework 覆盖准备、检测分析、遏制、恢复和事后复盘，并将数据管道、检索系统和智能体工作流纳入响应范围 [915]。但响应预案只有经过定期演练才能验证有效性；多供应商环境中的证据共享、责任划分和隐私限制，也会降低自动化处置效率。现阶段行业尚未形成统一的智能体应急处置规范，跨平台响应协同壁垒较为突出。持续审计与事件响应体系相互独立，未能实现风险发现与应急处置的联动闭环。

4.6 运行迭代阶段（动态演化防护）

运行迭代阶段是 AI 智能体全生命周期安全的核心动态演化环节，承接部署交付阶段的静态防护底座与集群运行约束，适配智能体上线后自主交互、记忆更新、持续迭代的内生特性，弥补传统静态防护难以应对动态攻防演进与时序风险累积变异的短板 [705]。智能体在线运行过程中具备持续自适应迭代特征，行为模式与知识库状态随交互轮次不断更新，催生大量动态衍生、渐进累积的新型安全风险。静态固化防护体系缺乏动态适配能力，无法跟随智能体演化节奏实现同步安全管控。本节系统梳理运行迭代阶段防护体系及其工程短板，主要发现如下（详见表 4.6）：

- **三类动态防护范式形成层级化迭代管控谱系，场景互补性强，但存在固有机理与工程适配边界。**学术机理范式依托模型状态探针与对抗检测训练识别隐性风险，通过注意力追踪识别隐蔽提示注入、基于极小极大博弈抵御自适应规避攻击 [784]，可精准捕获静态规则无法识别的隐性诱导与决策偏差，适配高安全迭代场景。但该方法依赖模型内部状态访问与持续样本积累，闭源模型难以部署，且冷启动检测精度不足，无法适配大规模高频量产迭代场景。开源运行时范式依托无侵入护栏框架实现常态化管控，LlamaFirewall 模块化集成检测、审查与扫描能力，已落地生产集群 [350]，部署灵活、成本低廉，适合中小集群迭代加固。但其以外置特征匹配和事后拦截为主，对变异样本、组合式隐性越权的检出能力有限，无法约束智能体自主演化风险。产业托管范式依托云厂商会话级隔离环境构建治理闭环，AgentCore Runtime 为会话分配独立微环境并及时销毁，保障量产合规与稳定性 [941]，适配大型异构集群。但该方案深度绑定厂商生态，私有化改造成本高，强管控模式会限制模型迭代探索空间，存在显著生态约束。
- **六大模块单点时序防护成熟、可管控显性迭代风险，但全域跨模块协同演化治理存在显著工程缺口。**感知模块依托可信域管控、流式拦截与对抗检测实现动态防护，但难以抵御跨模态环境注入攻击，攻击者可通过篡改环境视觉像素诱导多模态智能体异常执行 [942]。记忆模块通过分层存储与权限约束防控数据污染，但敏感错误信息的彻底清除需要同步处理外部记忆与模型参数，联合遗忘的依赖追踪与运维成本较高，残余污染问题难以根除 [943]。决策模块依靠独立复核抑制决策偏差，但安全约束在多层任务委派、工具调用中易逐步衰减，长期迭代下的约束漂移问题难以有效管控 [944]。行动模块沙箱隔离与准入机制可拦截已知恶意操作，但无法覆盖工具全生命周期的配置漂移、名称冲突等隐性风险 [194]。交互模块可通过拓扑异常检测与任务漂移监测识别协同风险 [563], [945]，但高度依赖样本训练与内部状态解析，动态组队场景泛化能力薄弱。治理模块依托 MI9 框架实现风险计量、持续授权与分级遏制 [682]，但技术体系较新，跨平台适配、误报抑制与大规模量产部署能力仍有待验证。
- **外置式动态防护落地成熟、适配性强，但与智能体内生演化机理割裂，安全-效率-演化自由度三元均衡缺失。**当前主流运行防护均采用外置网关、中间件的事后拦截架构，低侵入、易迭代，可有效防控显性时序风险，是线上安全防护的核心基底。但外置防护未将安全约束嵌入推理、记忆更新、自主探索等核心演化链路，无法从根源抑制隐性风险累积，长期迭代易产生大量安全技术债。内生安全设计理念虽已出现，可通过流程重构降低注入风险 [946]，但尚未形成规模化工程方案。三类防护范式存在天然矛盾：学术范式精度高但量产成本高昂，开源范式轻量化但缺少内生约束，产业范式合规完备但生态锁定严重、限制迭代自由度。即便 MAESTRO 等框架尝试实现全链路风险治理 [791]，也仅停留在理论方法论层面，缺乏可落地的量化均衡模型，无法兼顾安全强度、迭代效率与智能体演化自由度。

表 4.6: AI 智能体运行迭代阶段现有安全解决方案与缺陷

模块	现有方案 & 不足
感知 (输入层)	• 运行态输入可信域管控：控制流与数据流分离指在处理请求前先从可信查询中提取控制流程，运行期间检索的不可信外部数据不再影响程序走向，并以能力标签限制每个数据值可执行的操作；CaMeL 以该方式在不修改模型的前提下为智能体提供可证明的注入防护 [216]。但预先提取的执行计划限制了需按外部数据动态调整流程的任务，安全策略的编写与维护也需要额外投入。多模态环境输入校验指运行态输入不仅包括文本指令，还包括网页截图等环境内容；EnvInjection 表明攻击者可通过修改网页渲染像素注入扰动，诱导多模态智能体执行攻击者选定的动作 [942]，因此感知层需对渲染内容与页面源码做一致性检查。但基于已知扰动模式的检测对新型攻击泛化能力有限，逐帧图像检查也增加运行时开销。托管输入护栏指托管环境可在模型调用入口统一配置内容过滤与提示攻击检测策略，对进入运行链路的输入先行筛查 [947]。但托管护栏依赖云端配置，私有化部署需自建同等能力；通用过滤规则对业务专属诱导载荷的识别有限。 • 迭代过程敏感输入拦截：运行态敏感信息识别指可在输入进入模型链路前用实体识别组件检测姓名、凭证、账号等敏感字段并执行匿名化；Presidio 提供可定制的 PII 识别与脱敏管道，支持文本与图像输入 [787]。但内置识别器面向通用格式，行业专属敏感字段仍需自定义规则，嵌套式跨段隐私信息易漏检。本地前置脱敏指用户提交的运行指令可在发送到云端模型前由本地小模型完成检测与占位符替换；Rescriber 的用户实验表明本地化脱敏可减少不必要的隐私披露 [948]。但检测的完整性与一致性直接影响用户信任，小模型的识别覆盖不如大模型全面。数据最小化评估指对持续处理用户数据的智能体，应定期评估其是否只在必要时使用敏感信息；AgentDAM 的评测显示主流模型构建的智能体经常在非必要场景使用敏感数据 [949]。但基准评测只反映测试场景中的行为，不能替代运行时的强制控制。 • 动态对抗输入防御：Attention Tracker 通过追踪关键注意力头对原始指令的关注度变化，无需额外推理即可检测注入输入。但注意力特征依赖具体模型结构，模型迭代更新后检测阈值需重新标定。自适应对抗输入检测指针对刻意规避检测的注入载荷，可将检测建模为极小极大博弈并对检测器做对抗训练；DataSentinel 由此对现有与自适应提示注入攻击均保持较高检测率 [784]。但检测器需随攻击演化持续更新，且无法覆盖不依赖显式文本指令的扰动式攻击。
记忆 (存储层)	• 迭代分层记忆隔离架构：迭代分层记忆管理指区分临时会话记忆、长期用户记忆与共享知识记忆，分别配置写入、检索和更新规则，减少不同类型数据无序混用对后续决策的影响 [950]。但临时记忆与长期记忆之间可能存在引用和派生关系，分层边界难以完全划清，错误分类还会增加检索与管理成本。来源感知记忆管理指在记忆写入时记录贡献者、时间、访问资源和所属范围，为后续权限检查与异常追踪提供依据 [788]。但来源信息需要从写入阶段持续保存，历史记忆缺少完整元数据时难以恢复其修改链路。多用户记忆访问隔离指通过细粒度读写策略限制不同用户、智能体和资源之间的记忆访问，降低跨用户信息泄露风险 [732]。但严格隔离会限制合法知识共享，共享记忆中的派生内容也难以按单一用户直接划分。 • 迭代记忆生命周期管控：迭代经验质量管理指持续写入的历史经验会影响智能体后续规划和工具选择，因此需要定期评估记忆的有效性、相关性与潜在负面影响 [951]。但错误经验可能在多轮任务中被反复调用，单纯按时间删除无法判断其真实影响范围。动态记忆组织与更新指通过索引、关联和演化机制整理新增经验，提高长期记忆的检索与复用能力 [952]。但记忆之间的关联越复杂，过期内容的识别、更新和删除成本越高。参数与记忆联合遗忘指对于敏感或错误信息，应同时处理模型参数与外部持久记忆，减少信息经不同路径重新出现的风险 [943]。但联合遗忘需要追踪参数和记忆之间的依赖关系，难以覆盖日志、缓存和派生内容，也无法绝对保证完全清除。 • 迭代记忆访问权限约束：记忆写入准入控制指对进入持久记忆的用户输入、工具结果和外部内容进行来源与风险检查，减少恶意内容在长期运行中持续影响智能体 [662]。但自动写入与主动检索越频繁，攻击面越大；过严的准入规则也可能阻止正常经验积累。原始权限绑定机制指记忆写入时保留不可随摘要、转述或工具回显改变的原始授权信息，避免伪造来源绕过后续访问检查 [953]。但该机制依赖完整、可信的身份和授权记录，早期未绑定权限的存量记忆仍难以处理。记忆访问轨迹溯源指关联记忆写入、更新、检索与工具调用过程，分析特定记忆如何影响后续决策和执行 [512]。但完整溯源会增加存储和分析开销，长周期、多智能体场景下的轨迹重建也较为复杂。

续下页

表 4.6 – 续上页

模块	现有方案 & 不足
决策 (推理层)	• 迭代双轨推理防护架构：运行迭代双链路推理架构指构建业务主推理与独立安全审核双轨体系，对智能体生成的高风险行动轨迹进行规则检索、逻辑推理与执行前复核，阻止违反安全政策的操作进入执行阶段 [789]。但旁路审核依赖安全政策和规则是否完整；未被规则覆盖的新型风险仍可能漏检，额外审核也会增加运行开销。离线验证与在线监控架构指在部署前生成并验证行为策略，运行时再依据已验证策略检查智能体提出的每项行动，降低长期任务中的安全偏移 [954]。但形式化验证需要明确的安全规范，复杂业务中的隐含要求难以完整编码，策略更新后还需重新验证。可信提示流审核机制指标记不可信数据、执行最小权限并校验危险信息流，防止外部内容在多步推理中造成权限提升 [955]。但该机制依赖准确的数据来源标签，历史上下文或插件返回结果缺少标记时仍可能形成防护盲区。 • 自主迭代规划约束：任务级工具权限策略指根据用户任务生成细粒度工具调用规则，并在执行状态变化时更新允许的操作范围，限制智能体调用与当前任务无关的高权限能力 [20]。但自动生成的策略可能存在遗漏或过度限制，策略更新过程仍需确定性检查。权限层级约束指重建不同工具调用之间的权限关系，并优先授予能够完成任务的最低权限，减少不可靠规划造成的潜在影响 [513]。但权限层级需要随工具接口持续更新，工具语义或参数变化可能导致原有授权关系失效。低权限工具优先机制指当低权限工具足以完成任务时，应避免直接选择或过早升级至高权限工具；ToolPrivBench 表明，短暂工具故障会进一步增加不必要的权限升级 [796]。但提示层约束难以稳定阻止过度授权，仍需在工具选择后执行独立权限校验。 • 迭代提示流完整性防护：内外提示流隔离机制指将不可信外部数据与智能体控制流分开处理，并通过隔离、双智能体或计划后执行等模式降低间接提示注入影响高权限决策的风险 [946]。但隔离会限制部分需要同时处理外部信息与敏感工具的合法任务，也依赖系统正确标记数据来源。提示与权限传播追踪指通过信息流图记录智能体、工具和数据对象之间的交互，并依据实体属性实施强制访问控制，阻止低权限输入在多次调用中形成权限提升 [956]。但信息流标签缺失或策略配置错误会削弱控制效果，复杂轨迹的持续追踪也会增加运行成本。安全约束持续传递指将隐私、授权和工具限制作为显式执行状态，在记忆、任务委派、通信和工具调用之间持续继承与检查，减少长期执行中的约束漂移 [944]。但多个约束发生冲突时需要明确优先级，长期维护约束状态也会增加系统复杂度。
行动 (执行层)	• 迭代工具能力收敛管控：工具接入生命周期管控指外部工具与 MCP 服务在创建、部署、运行和维护各阶段都可能引入恶意代码、名称冲突与配置漂移等风险，应按阶段设置差异化的检查与缓解措施 [194]。但生命周期治理依赖工具元数据与版本信息的持续维护，第三方服务的内部变更难以及时感知。护栏代理准入检查指可由独立护栏代理将安全要求转换为可执行的检查代码，在目标智能体调用工具前核验其动作是否符合访问控制与安全规则 [957]。但检查逻辑由模型生成仍可能出现遗漏，护栏代理本身也会增加调用时延。可信工具注册准入指以管理员管控的注册中心统一登记工具身份、权限与信任评分，并按需签发短时凭证，防止伪冒注册的工具混入运行流程 [792]。但注册中心成为新的单点依赖，信任评分也难以反映合法工具被恶意参数调用的风险。工具动态迭代更新极易打破原有安全边界，引发隐蔽的权限溢出与工具滥用问题。 • 迭代高危操作硬阻断：分层运行护栏指在执行层组合提示注入检测、推理链对齐审查与不安全代码扫描，对高危操作形成多层拦截；LlamaFirewall 以模块化方式集成上述护栏并已在生产环境部署 [350]。但各护栏均存在误报与漏报，链式组合的隐性高危操作仍可能绕过单点检查。自适应安全检查指不同任务的风险类型差异大，固定规则难以覆盖；AGrail 在测试时自适应生成并迭代优化安全检查项，可同时处理任务专属风险与系统性风险 [602]。但检查项由模型协作生成，对全新风险类型的首轮覆盖仍不稳定，优化过程也带来额外推理成本。动态、多步骤的组合式高危行为易规避静态分层护栏，突破现有阻断体系。 • 无服务器迭代执行架构。会话级微虚拟机隔离指为每个运行会话分配独立 microVM 并隔离 CPU、内存与文件系统，会话结束后销毁环境，防止代码执行逃逸与跨会话状态泄露 [941]。但独立环境的启停带来资源开销，隔离也无法防护镜像构建阶段植入的恶意载荷。沙箱环境安全评估指承载不可信代码的执行环境应在投产前接受系统性测试；SandboxEval 以覆盖敏感信息暴露、文件系统操纵、外部通信等场景的用例集评估沙箱的隔离属性 [901]。但测试用例只覆盖已知危险操作模式，未纳入用例的逃逸路径仍需持续补充。沙箱隔离机制仅能防护运行时外部攻击，无法抵御智能体内生的自主逃逸行为。

续下页

表 4.6 – 续上页

模块	现有方案 & 不足
交互 (协同层)	• 多智能体迭代信任拓扑：协同拓扑异常检测指将多智能体消息建模为交互图，通过图神经网络在节点与边层面检测异常并实施拓扑干预；G-Safeguard 在提示注入等攻击下可恢复大部分协作性能 [727]。但检测模型需要攻击样本训练，动态变化的组队拓扑也会影响检测稳定性。执行图运行监督指由独立监督组件实时构建多智能体执行图，结合安全策略识别异常节点与攻击路径，并在必要时干预执行 [563]。但基于模型推理的判定存在误报，监督组件常驻也增加系统开销。智能体身份与零信任管控指面向人类用户设计的传统 IAM 难以适配大规模、短生命周期的智能体；可为智能体建立可验证身份，记录其能力、来源与行为范围，并实施细粒度访问控制与全局会话吊销 [958]。但该类框架仍处于方案阶段，跨组织身份互认与部署成本尚待实践检验。动态信任权重适配不足指现有拓扑信任机制多为静态权重配置，无法根据节点历史风险行为动态实时调整授信优先级。多节点协同逃逸风险突出指单节点异常检测有效，但多节点轻微异常联动叠加易形成整体协作安全失效。 • 跨系统迭代交互防护：协议层安全评估指跨系统交互依赖 MCP、A2A 等协议，应在选型时比较其在安全、可扩展性与时延维度的差异，并跟踪协议鉴权机制的演进 [800]。但协议规范更新频繁，早期版本部署的服务可能长期缺失新增安全特性。企业级协作鉴权指跨平台智能体协作可采用内置企业级身份验证与授权设计的开放协议，以能力卡片描述智能体并支持安全调用 [959]。但协议提供的是机制而非策略，具体权限范围与审计要求仍需部署方自行定义。MCP 部署安全审计指对接入运行流程的 MCP 服务器应进行安全审计；已有工作演示了利用 MCP 实现凭证窃取与远程代码执行的攻击链，并给出配套审计工具 [960]。但审计只反映检查时点的配置状态，服务更新后需要重新评估。协议版本兼容风险盲区指新旧协议版本混合部署场景下，差异化安全校验规则易形成防护漏洞。跨域权限同步滞后指多企业跨系统协作时权限更新存在时延，易产生临时越权访问窗口。 • 迭代会话生命周期管控：多轮累积诱导防护指限制长会话上下文的复用范围，并跨轮次而非逐轮评估请求意图，防止攻击者以逐步升级的小步请求侵蚀安全边界；实验显示渐进式多轮攻击对多款模型的成功率远高于单轮攻击 [512]。但跨轮意图评估的阈值难以标定，过严会中断正常的长期业务会话。任务漂移监测指处理外部数据前后模型内部激活的变化与任务漂移强相关，可用轻量探针在会话中检测指令被外部内容带偏的情况 [945]。但激活探针依赖对模型内部状态的访问，闭源托管模型难以直接部署，对未见攻击形式的泛化也需持续验证。会话残留数据管控薄弱指会话结束后上下文碎片长期留存，易被后续新会话复用引发隐性污染。
治理 (管控层)	• 迭代分层合规基线体系：分层合规义务管理指将监管义务与内部规则分层管理并覆盖模型全生命周期；欧盟委员会发布的 GPAI 义务范围指南明确义务自训练启动起贯穿后续开发与修改阶段 [961]。但监管指南规定的是义务范围与目标，仍需转化为具体的运行控制与审计要求。分层威胁建模指 MAE-STRO 将智能体系统划分为基础模型、数据操作、智能体框架、部署基础设施等七层，逐层识别威胁并结合跨层交互分析风险 [791]。但框架提供的是方法论，逐层建模的深度与更新频率取决于组织投入，轻量场景实施成本偏高。行业合规适配性差指通用分层模型无法精准匹配金融、政务等特殊行业的强制合规细则。 • 迭代基线动态迭代更新：策略即代码统一执行指将安全与合规基线写成与业务代码解耦的声明式策略，由统一策略引擎在各服务处执行，策略包可版本化分发与回滚 [962]。但策略语言的学习与维护成本较高，策略与业务对象模型脱节时会产生误判。发布前配置扫描指智能体配置与 MCP 接入变更后，可用扫描工具检查工具描述篡改、提示注入与越权配置，再决定是否发布 [963]。但静态扫描无法覆盖运行时动态生成的参数与权限，仍需与运行监测配合。策略迭代联动性不足指单条策略更新无法自动联动关联规则校验，易出现合规基线冲突漏洞。 • 全迭代链路观测审计：标准化遥测插桩指按统一语义约定采集模型调用、工具执行与智能体操作的遥测数据，使跨框架的运行轨迹可比对、可聚合 [964]。但语义约定仍在演进，全量轨迹采集的存储与解析成本高。运行态治理引擎指 MI9 集成代理风险指数、语义遥测、持续授权监测、状态机一致性检查、目标漂移检测与分级遏制，对运行中的智能体实施实时治理 [682]。但该框架较新，跨平台适配、误报控制与大规模部署成本尚待验证。交互上链存证指可将关键交互数据锚定到区块链账本形成不可篡改审计记录，结合去中心化身份与智能合约实现可核验的跨域协作 [595]。但上链存在打包时延，节点运维复杂度高，中小规模集群落地成本大。审计日志脱敏机制缺失指原始遥测数据直接留存，大量包含敏感研发信息，存在数据泄露风险。分层溯源责任界定模糊指多智能体协同操作的审计轨迹难以精准划分个体责任，追责粒度较粗。

4.7 退役销毁阶段（闭环收尾防护）

退役销毁阶段是 AI 智能体全生命周期安全的最终闭环环节，重点处置系统下线后残留的记忆数据、权限会话、缓存备份与审计日志，杜绝信息残留恢复与隐性再生风险 [943]。该阶段需依据数据敏感度实施擦除、加密或物理销毁，并留存完整核验记录 [786]。智能体区别于传统软件系统，具备记忆留存、状态迭代与多组件联动特性，退役后仍存在大量碎片化隐性资产残留。这类后置残留风险隐蔽性强、溯源难度高，极易形成跨代安全隐患。同时，退役流程仍面临注入攻击、权限越权与记忆污染风险，需将安全管控与审计治理贯穿全程 [1]。本节结合六大功能模块，系统梳理退役阶段现有防护体系与工程短板（详见表 4.7）：

- 三类退役销毁范式形成差异化终端处置体系，场景互补成熟，但存在智能体专属机理约束与工程短板。**研究型方法聚焦记忆遗忘、权限溯源与策略校验，通过模型参数与外部记忆联合遗忘，解决单一删除引发的信息残留恢复问题 [943]，依托可验证安全策略约束高危操作偏差 [789]，管控粒度精细，但依赖复杂依赖建模，落地成本偏高。开源工具型方法侧重轻量化权限约束与运行拦截，AgentBound 规范 MCP 工具访问边界 [965]，AgentSpec 通过结构化规则前置阻断违规执行 [666]，部署灵活、适配性强，但规则维护压力大，难以识别多步叠加的隐性高危行为。云平台托管型方法依托统一网关与隔离微环境实现集中管控，AgentCore Gateway 统一完成身份校验与访问控制 [966]，AgentCore Runtime 实现会话级资源隔离销毁 [941]，量产稳定性强，但生态绑定严重，私有化与离线场景适配成本较高。三类处置范式均仅适配单一部署场景，尚未形成通用化、可迁移的退役处置标准体系。
- 六大功能模块单点销毁能力成熟，可管控显性风险，但跨模块协同治理与全链路残留阻断存在显著工程缺口。**感知模块依托来源标记与多模态检测抵御退役流程恶意注入，但无溯源标签的历史数据难以甄别可信性，跨模态隐性诱导风险难以根除 [967]。记忆模块通过分级清理与选择性遗忘抑制数据残留，但存在隐私窃取与派生内容残留问题，向量索引、摘要副本难以同步彻底清除 [732]。决策模块依托细粒度权限策略与执行复核规避误删、越权回收风险 [20]，但规则粒度难以动态平衡，易出现管控疏漏或业务阻塞问题。行动模块可通过数据流与时序校验识别违规操作 [968]，但全维度状态监测开销大，易产生误拦截。交互模块可抵御常规协同风险，但攻击者可通过篡改跨智能体消息干扰退役移交流程，破坏会话隔离有效性 [969]。治理模块可将自然语言政策编译为强制执行规则，阻断违规信息流 [970]，但规则转换、跨平台同步高度依赖人工，自动化闭环能力不足，多平台日志格式不统一进一步提升治理难度。各模块独立销毁机制相互割裂，无法应对智能体跨模块状态联动残留的特有风险。
- 外置后置式管控与智能体内生特性割裂，销毁彻底性、时效性、经济性的三元工程矛盾难以消解。**智能体退役清理涉及状态轨迹、记忆向量、备份介质与模型参数多维度联动处置，清理完整性与处置时效、资源开销天然冲突 [971]。DeltaBox 等增量回滚机制可有效降低重复复制开销、提升处置效率 [972]，但无法撤销已同步至外部系统的不可逆操作。当前退役安全多依赖网关、沙箱与审计平台等外置组件治理，MI9 可实现语义遥测、持续授权与状态一致性监测 [682]，但仍存在跨平台适配难、误报率高、量产成本大的短板。外置防护无法深度适配智能体记忆衍生、状态联动的内生特性，难以根除跨代残留风险。安全极致清零、业务高效迭代与低成本量产运维三者无法同时兼顾，成为退役阶段固有的工程瓶颈。因此，退役治理需摒弃单一极致销毁思路，依据数据敏感度分级处置，结合事件响应机制持续迭代规则体系。NIST SP 800-61 标准可为此类退役异常处置与风险管理提供合规依据 [973]。后置处置模式无法提前预判智能体隐性残留风险，退役安全预判预警能力严重缺失。

表 4.7: AI 智能体退役销毁阶段现有安全解决方案与缺陷

模块	现有方案 & 不足
感知 (输入层)	• 退役窗口期输入溯源与污染甄别: 分阶段输入溯源指将退役流程划分为服役末期、审批和销毁执行三个环节, 为工单、审批指令和工具结果保留来源与信任标签, 区分可信控制指令与外部数据, 降低提示注入影响退役决策的风险 [946]。但历史数据缺少标签时仍可能出现阶段归属错误。多模态输入校验指对运维工单中的文字、截图和附件分别检查, 防止跨模态提示注入诱导智能体执行未授权任务 [967]。但检测器可能漏掉新编码方式, 图像分析也增加时延。统一输入网关指通过 AgentCore Gateway 将各类 API 与 MCP 工具接入同一入口并执行身份验证与访问控制 [966], 销毁类请求还可分配独立工作身份并留存授权记录 [974]。但托管能力依赖云端配置, 离线环境需自行实现同等控制。现有溯源标签体系不具备动态更新能力, 难以适配退役阶段复杂多变的输入场景。 • 退役敏感输入闭环拦截: 退役输入隐私识别指在退役工单与归档请求进入后续处理前识别姓名、账号等身份字段, 已有多语言隐私标注数据集可用于识别隐私短语 [975]。但不同行业与上下文中的隐含身份信息仍可能漏检。输入脱敏与替换指原始数据进入模型或外部服务前由本地组件删除或替换个人信息, PRvL 对多类模型的 PII 脱敏做了准确率与泄露的综合评估 [976]。但删除过多会破坏销毁范围核验, 不足又保留敏感数据。前端隐私控制指人工提交的退役指令与附件在发送到云端模型前完成本地实体识别与占位符替换 [977]。但自动识别覆盖有限, 高风险数据仍需人工复核。静态脱敏策略无法适配退役阶段流式、批量混杂的输入数据形态。隐私拦截机制缺少前后端联动校验, 容易出现局部脱敏不一致问题。 • 销毁触发类对抗输入防御: 退役前后门检查指对能直接触发删除或权限回收的模型, 先扫描特定输入触发的异常行为, 已有方法可在未知触发词时恢复部分触发条件 [978]。但其只面向模型后门, 不能替代对工单、权限和参数的常规检查。长上下文输入清理指退役指令与大量日志一同输入时先定位并隔离异常片段, PISanitizer 即通过处理高影响注入片段降低恶意指令控制输出的可能 [979]。但清理仍可能误删或漏删, 不能作为唯一控制。隔离执行环境指经检查的下线、清理任务在独立环境中运行, AgentCore Runtime 为每个会话分配独立 microVM 并隔离内存与文件系统 [941]。但隔离只限制跨会话影响, 无法识别已授权运维人员的恶意指令。对抗输入防御多聚焦外部攻击载荷, 对内部可信主体的恶意滥用防护缺失。长文本上下文清洗缺少语义级判别能力, 仅能实现表层字符过滤。退役阶段专属对抗样本库尚未建立, 新型销毁诱导攻击难以提前拦截。
记忆 (存储层)	• 分级记忆销毁隔离架构: 分级记忆管理指将存储层划分为会话记忆、长期用户记忆和共享知识记忆, 按敏感度和使用范围设置差异化保留与删除规则 [950]。但记忆间相互引用, 删除单条记录未必清除其派生的摘要或索引。带来源信息的记忆管理指写入时保存来源、时间与所属用户, 退役时据此定位删除范围; Collaborative Memory 将记忆分为私有与共享两层并保留来源属性用于权限检查与审计 [788]。但历史记忆缺少元数据时仍难以判断归属和删除范围。多用户记忆隔离指共享智能体通过细粒度读写策略限制跨主体记忆访问; 已有研究表明攻击者可经黑盒交互从记忆中提取其他用户的隐私信息 [732]。但严格隔离限制合法知识共享, 依赖多个用户数据的派生结论也难以按单一用户删除。 • 记忆全生命周期销毁管控: 记忆与模型联合遗忘指退役时除清除向量库与交互记录外, 还需处理已进入模型参数或可被重新生成的信息; Agentic Unlearning 指出只删外部记忆或只处理参数都会留下残余, 主张两条路径同时处理 [943]。但联合遗忘需追踪记忆依赖, 成本高且难以保证彻底删除。按范围选择性遗忘指部分退役或单项删除按状态、轨迹或任务环境确定遗忘范围; Secure Forgetting 将遗忘划分为状态、轨迹和环境三类并以可执行指令控制删除 [971]。但由自然语言转换的范围仍可能过大或遗漏关联内容。物理介质与备份清理指下线存储设备与备份介质按敏感程度选择清除、加密擦除或物理销毁并留存验证记录 [786]。但介质清除只覆盖可识别副本, 无法发现散落在日志、快照或远程备份中的派生数据。 • 销毁阶段记忆权限约束: 退役期间限制记忆写入指进入退役流程后将待处理记忆库切换为只读, 仅允许经审批的清理与核验操作; 研究表明激进的自动写入与检索策略会放大记忆投毒风险 [662]。但只读控制不能阻止已有污染被读取, 也不解决派生摘要残余。记忆写入前的信任检查指对仍需保留的记忆, 在写入和检索阶段结合来源、时间与信任分数筛选; 实验显示阈值过严阻断正常记录、过松又漏掉攻击 [980], 只宜作为辅助控制。记忆访问轨迹记录指退役期间记录记忆的写入、检索与删除操作并关联来源和后续影响; 执行溯源研究指出普通日志无法完整说明信息如何影响后续行动 [512]。但完整记录增加存储开销, 早期未保存依赖关系时难以补全链路。

续下页

表 4.7 – 续上页

模块	现有方案 & 不足
决策 (推理层)	• 退役判定双轨推理防护架构：退役决策独立复核指常规下线由业务智能体生成方案，涉及批量删除或大范围权限回收时交由独立安全组件按预定义规则检查；ShieldAgent 将安全政策转换为可验证规则并对连续行动做逻辑检查 [789]。但政策未覆盖的新型风险仍可能被放行。可信与不可信信息分离指退役规划同时处理用户指令、日志与外部文件时，应防止不可信内容直接影响高权限决策；Prompt Flow Integrity 经隔离智能体与权限提升检查降低此类风险 [955]。但历史数据缺少信任标签时仍可能出现判断偏差。可执行安全约束指将数据敏感度、工具能力和允许的调用顺序写成结构化规则，在删除或迁移方案提交时检查 [981]。但规则维护需人工投入，隐含依赖难以完全列出。 • 退役自主规划权限约束：任务级工具权限指退役智能体只获得当前清理任务所需的工具与参数权限，Progent 使用细粒度策略限制可调用工具并随执行状态更新规则 [20]。但策略过严阻断正常操作、过宽留下越权空间。权限层级约束指对文件删除、账号注销、数据导出等工具按操作范围构建权限层级并优先授予影响较小的权限；MiniScope 重建工具调用间的权限关系以限制多余权限 [513]。但权限关系需与系统接口同步，工具更新可能使层级失效。低权限工具优先指多个工具可完成同一任务时优先选择影响较小者，避免在低权限工具短暂失败后立即升级；ToolPrivBench 发现智能体常在低权限工具足够时选择高权限工具 [796]，仅靠提示约束并不可靠，还需在工具选择后增加确定性权限检查。智能体自主决策的工具偏好偏差，易突破静态权限层级的管控边界。 • 退役提示流完整性防护：提示与权限传播检查指退役指令在规划与执行间传递时保留用户身份、来源和权限范围，防止低权限输入被解释为高权限操作；SEAgent 以信息流图追踪交互并执行强制访问控制 [956]。但标签缺失或配置错误会削弱控制效果。安全约束持续传递指退役任务经过记忆检索、委派与汇总时原始限制需全程有效；约束漂移研究指出安全要求可能在长期执行中被削弱或错误转述，应作为明确执行状态持续检查 [944]。但持续维护约束状态增加系统复杂度。高权限请求最终确认指不可逆删除或大范围注销执行前重新核对原始目标、调用主体与影响范围；OWASP Agentic Top 10 建议以最小权限、独立授权和执行前验证限制高危操作 [1]。但审批信息本身不完整时，人工确认仍可能放行不安全请求。现有防护体系缺少全链路约束校验机制，难以规避渐进式权限泄露风险。
行动 (执行层)	• 销毁工具能力收敛管控：销毁工具最小权限隔离指磁盘清理、下线、注销等工具分别声明所需文件、网络与系统权限，由独立执行层限制访问范围；AgentBound 以权限清单描述 MCP 服务器所需资源并阻止未声明访问 [965]。但声明不完整会阻断任务、过宽又保留多余能力。第三方技能可信准入指清理、归档和注销类技能经来源核验、代码检查与权限审查后再接入退役流程，并按风险等级差异化授予执行权限 [982]。但白名单只能确认来源，不能保证合法技能的参数与逻辑始终安全。真实权限环境测试指高风险工具投入使用前在隔离环境中测试其面对间接注入和异常参数时的权限使用；GrantBox 将真实工具与权限接入测试沙箱以评估注入下的越权与泄露 [983]。但未在测试中触发的问题仍可能在真实任务中出现。 • 退役高危操作硬阻断基线：高风险操作运行时规则指将批量删除、外部传输、权限提升等操作写成明确规则，在执行前检查操作类型、参数与主体；AgentSpec 以结构化规则在运行时阻断违规执行 [666]。但只检查单次调用可能漏掉多次低风险操作组合成的高风险行为。跨步骤执行轨迹检查指分批导出、先复制后删除等操作需结合调用顺序、参数关系与数据流判断；VIGIL 将技能约束与全局政策转换为可执行条件，能识别跨调用数据流违规 [968]。但轨迹检查需保存更多执行状态，粒度不当会误拦或漏检。结合系统状态阻断指部分操作表面符合指令，在特定账号或业务状态下仍违规；PhantomPolicy 的 Sentinel 框架通过模拟操作后的系统状态再决定允许或阻断 [793]。但该方法依赖准确及时的组织状态，数据不同步仍会误判。 • 无服务器隔离销毁执行架构：独立销毁沙箱指下线与清理任务在独立操作系统、浏览器或代码执行环境中运行，异常时允许人工接管；AgentBay 提供多平台隔离会话并支持人工控制切换 [984]。但人工接管依赖及时监控，沙箱内密钥与权限仍需单独限制。按敏感资源划分执行边界指涉及网页控制台、云端账号的退役任务在沙箱中分离一般操作与敏感资源访问；ceLLMate 将浏览器低层操作映射为语义动作并以站点规则限制敏感操作 [884]。但语义映射主要适用于浏览器，专用运维接口需重新设计规则。销毁状态检查点与回滚指多步骤清理任务在关键操作前保存文件与进程状态，发现误删时回滚到最近安全状态；DeltaBox 以增量文件系统实现快速检查点与回滚 [972]。但回滚只覆盖本地状态，已外发数据和不可逆的物理清除无法恢复。

续下页

表 4.7 – 续上页

模块	现有方案 & 不足
交互 (协同层)	• 集群退役协同信任拓扑管控：分级协同信任管理指批量退役中按身份与任务范围设置信任等级，动态决定接受、复核或拒绝协作消息；A-Trust 从事实准确性等维度评估消息并维护信任记录 [777]。但信任评分面对新型攻击或伪装良好的错误消息仍可能失误。智能体间消息完整性检查指委派与数据移交保留收发方与内容，执行前检查是否被篡改；Agent-in-the-Middle 攻击表明仅拦截修改智能体间消息即可改变协作结果 [969]。但完整性检查不能保证已认证智能体本身可信。最小必要信息共享指各智能体只接收当前子任务所需的数据与权限；研究发现智能体间信任提高会加剧过度共享与授权漂移 [212]。但过度限制共享可能使智能体缺少必要上下文。批量退役场景下动态信任拓扑缺乏自动更新机制，难以适配智能体陆续下线带来的网络结构变动。 • 跨系统退役交互安全防护：可验证的身份委派指智能体访问外部系统时明确记录其代表的用户与委派链；Authenticated Delegation 以委派凭据将自然语言授权转换为可审计访问范围 [985]。但自然语言权限转换可能出现范围偏差，仍需结构化策略确认。跨应用授权隔离指不同外部服务连接使用独立客户端身份与授权范围；已有研究在集成平台中发现跨应用 OAuth 账号接管问题 [986]。但应用级隔离增加凭据管理成本，配置错误仍可能形成新漏洞。远程 MCP 身份验证指经远程 MCP 服务器调用外部工具时强制身份验证并检查令牌绑定；测量发现大量真实 MCP 服务未启用验证 [987]。但身份验证只确认请求主体，高风险操作仍需结合任务范围复核。跨平台交互缺少统一委派审计标准，不同系统日志难以串联形成完整退役处置证据链。 • 退役会话生命周期管控：退役会话独立隔离指待退役智能体使用独立会话标识与上下文缓存，不读取现役会话历史；AgentLAB 表明攻击可经多轮交互逐步完成意图劫持与记忆投毒 [647]。但会话隔离无法识别已写入长期记忆或外部系统的恶意状态。跨轮次风险状态保留指退役会话持续记录目标变化与敏感数据访问；MAGE 以独立安全记忆保留关键风险信息，可发现单轮正常、组合后有害的行为 [988]。但长期保留安全状态增加上下文与推理成本。会话结束前的上下文核验指关闭退役会话前核对任务目标、指令来源与剩余权限；上下文安全研究指出同一操作是否安全取决于其指令来源与任务背景 [17]。但完整核验依赖可靠的身份与日志记录。会话管控机制仅覆盖运行时上下文，无法追溯会话建立前预先植入的持久化风险载荷。
治理 (管控层)	• 退役销毁分层合规基线体系：法规与内部规则分层指将法律义务与内部政策分开管理，按数据类型与部署场景确定清理、留存与审计规则；欧盟《通用人工智能模型行为准则》将风险管理要求细化为可采用的合规措施 [485]。但此类准则规定的是治理目标，仍需落实为具体删除命令与验证步骤。自然语言政策结构化指从法规与内部制度中提取适用范围与例外，转换为机器可读规则；Policy-to-Tests 以领域专用语言表示政策要素并生成可测试规则 [801]。但自动转换可能误解例外条款，仍需多方检查。运行时合规检查指涉及个人数据删除的退役操作在模型输出和工具调用发生时检查是否合规；C-Trace 将部分 GDPR 要求表示为执行轨迹上的形式化条件并阻止违规 [989]。但形式化规则只覆盖已编码义务，数据分类错误仍可能误判。 • 退役基线版本化动态管控：退役规则版本管理指销毁范围与审批条件变更时保存版本、审批记录与生效时间，避免节点间基线不一致；部署侧治理研究建议以回归测试与兼容性门禁检查更新 [802]。但测试难以覆盖全部业务情况，阈值过严延迟更新、过松又漏掉风险。规则编译与统一执行指经批准的合规政策编译为独立于模型推理的执行规则，使各智能体使用同一版本控制逻辑；PCAS 以声明式策略追踪跨智能体信息流并在执行前阻止违规 [970]。但政策变化后编译结果与运行环境需同步更新。发布前配置审计指基线更新后检查智能体代码与 MCP 权限是否与新规则一致再发布；Agent Audit 结合数据流分析与权限检查，可接入持续集成 [638]。但静态分析无法覆盖运行时生成的参数与动态权限。 • 全链路退役观测与审计存证：运行状态持续观测指退役期间记录智能体目标、授权状态与工具调用，及时发现权限未回收或清理中断；MI9 将语义遥测、持续授权监测与分级处置组合为运行治理机制 [682]。但该框架较新，误报控制与大规模部署成本尚待验证。可回溯审计记录指审计记录关联规则版本、操作主体及关键决策依据；LLM Audit Trails 提出可检测篡改且含上下文的审计记录，将技术溯源与审批等治理信息连接 [778]。但完整审计增加存储成本，且可能含用户数据与密钥，需限制访问范围。事件处置与基线回灌指退役中发现的数据残留或权限异常进入统一事件响应流程，并用于更新检测规则与退役基线；NIST SP 800-61 Rev. 3 要求将事件响应纳入持续风险管理 [973]。但只有事件记录与整改跟踪真正落实，复盘结果才能转化为新的治理控制。

第 5 章 AI 智能体全生命周期安全发展趋势

本章延续前文 AI 智能体全生命周期安全分析框架，面向智能体技术演进与安全需求变化，系统分析 AI 智能体攻防技术的发展演进规律与未来演化方向，如图 5.1 所示。本章重点从学术研究与工业实践两个视角，研判 AI 智能体安全技术由被动防护向主动演化、由单点防御向体系化协同、由外部约束向内生安全发展的演进趋势。围绕智能体自主能力增强带来的新型攻击面，研判攻击技术向跨组件协同、持续化和智能化方向演变，同时分析防御能力由规则驱动、静态检测向智能感知、自适应防御和可信治理方向发展的技术路径。通过对攻防技术演化规律和关键发展方向的系统研判，为后续构建面向 AI 智能体的内生安全体系和持续演进机制提供理论依据。



图 5.1: AI 智能体全生命周期安全发展趋势

5.1 需求规划阶段（攻防趋势）

需求规划阶段作为 AI 智能体生命周期的起始环节，主要承担系统目标定义、能力边界划分、安全约束设计以及治理要求规划等任务。AI 智能体的安全风险逐渐由运行阶段向设计阶段迁移，攻防博弈也由传统的漏洞利用与运行时防护，扩展至需求规约、安全目标和系统治理层面的源头竞争。因此，需求规划阶段逐渐成为 AI 智能体风险前置识别和内生安全能力构建的重要环节。结合学术研究进展与工业攻防实践，本节系统分析需求规划阶段的主要攻防演化趋势如下（详见表 5.1）：

- **安全范式前移趋势：攻防博弈由运行阶段向需求定义阶段迁移。**攻击者不再局限于利用已暴露漏洞或运行时缺陷，而是可能通过需求目标偏移、安全约束缺失、业务规则滥用以及治理要求弱化等方式，将潜在风险嵌入智能体设计过程，使安全缺陷伴随系统架构、能力配置和业务流程持续传播 [504] [990]。该趋势主要表现为三个方面：其一，**风险源头化**，需求阶段形成的目标偏差、能力边界模糊以及安全责任缺失，可能进一步影响后续架构设计与运行行为，使部分风险难以通过传统运行时检测和补丁修复方式完全消除 [504]；其二，**攻击隐蔽化**，源头性风险通常不依赖明显异常流量、恶意代码或显式攻击载荷，而是以功能需求、策略配置和系统约束形式存在，增加了传统安全检测机制的识别难度 [991]；其三，**影响规模化**，需求层面的安全缺陷可能随着智能体模板、基础平台和行业解决方案的复用扩散，形成跨组织、跨应用场景的供应链级风险传播 [992]。因此，学术界逐渐由传统漏洞分析转向面向需求规约、目标一致性验证、安全约束建模以及风险传播分析的前置安全研究，推动安全要求从运行保障阶段向智能体设计生命周期前端延伸。工业界也开始将安全需求分析、风险评估和治理要求纳入智能体项目立项与架构设计流程，以降低系统部署后的安全不确定性。
- **能力融合攻防趋势：围绕智能体核心能力形成多维协同攻击与安全约束。**由于智能体内部存在复杂的数据流、控制流和权限调用关系，攻击者开始利用不同能力之间的耦合关系构造复合型攻击路径，使单一模块安全防护难以覆盖完整攻击链条。感知能力面临输入可信性不足、环境误导和语义边界操纵风险；记忆能力涉及知识来源可信、长期信息污染以及历史上下文累积风险；决策能力面临目标偏移、策略诱导和推理过程操纵风险；行动能力涉及工具调用边界、外部资源访问和执行权限风险；交互能力受到提示操纵、身份欺骗和信息泄露等威胁影响；治理能力则可能因责任划分不清、审计机制不足和约束体系缺失形成系统性风险 [990] [571]。针对上述变化，学术界研究重点逐渐从针对单一攻击面的防御方法，转向面向智能体整体能力协同关系的安全建模与风险分析，关注模型、数据、工具和环境之间复杂交互产生的新型安全影响 [504]。工业界则更加重视在需求规划阶段明确智能体能力范围、数据使用边界、权限等级和治理责任，通过前置约束降低后续系统运行中的安全风险 [993]。
- **工程协同演化趋势：业务敏捷性与安全约束形成长期动态平衡。**AI 智能体在金融、医疗、工业、政务等复杂业务场景中的快速应用，使需求规划阶段需要同时满足业务创新效率与安全可靠性的双重要求。一方面，攻击者可能利用业务需求快速变化、功能边界持续扩展以及默认信任机制等工程特点，将潜在安全风险隐藏于系统设计和业务流程调整过程中 [990] [991]；另一方面，过度严格的安全约束可能降低智能体自主决策能力和业务适应能力，增加系统开发、维护和迭代成本 [504]。因此，当前学术研究与工业实践逐渐形成以风险驱动、安全约束融合和持续治理为核心的演进方向，通过在需求阶段明确安全目标、风险等级、责任边界和治理要求，实现智能能力扩展与安全要求之间的动态协调 [520]。

表 5.1: AI 智能体需求规划阶段攻防趋势

模块	攻击趋势	防御趋势
感知 (输入层)	• 攻击时序全链路前置, 突破运行时交互依赖: 新型攻击将渗透时序整体前移至需求立项阶段, 通过提前篡改感知层核心需求规约预埋结构性固有缺陷, 无需依赖上线后人机交互、动态载荷注入即可长期稳定保有攻击面, 彻底打破传统攻击依赖在线交互的场景限制, 实现静默持久驻留攻击 [504]。缺陷风险: 缺陷深度固化于顶层设计架构, 常规热修复、版本补丁均无法彻底根除, 风险沿全业务链路持续传导、反复复现。该类源头缺陷具备强隐蔽性, 在常规测试与安全审计中难以被有效检出。 • 需求规范诱导弱化, 原生放大输入攻击面: 攻击者定向诱导需求文档放宽数据采集边界、弱化多模态数据源完整性校验、取消终端强鉴权约束, 使智能体出厂阶段即自带冗余采集通路, 形成先天可利用攻击面, 区别于后天配置疏漏漏洞 [990]。缺陷风险: 系统无原生安全校验基线, 批量规模化部署后全域开放恶意输入通道, 攻击者可低成本开展批量渗透攻击。全域开放的输入通道可被持续性利用, 形成常态化、规模化的链式入侵风险。原生输入管控缺失会持续传导至决策、执行层级, 诱发多级联动安全隐患。	• 可信校验需求原生固化, 构建前置输入基线: 将多源身份认证、格式语法校验、时序完整性校验、对抗特征过滤四类安全规则原生嵌入顶层需求基线, 完全区别于上线后外挂式临时校验机制。在系统设计阶段统一全域可信判定标准, 从输入端刚性阻断预埋缺陷引发的恶意数据内流与隐性诱导风险 [990]。严格遵循“任务必需最小集”安全原则, 主动剔除冗余日志、无关元数据与非授权传感采集通道。落地优势: 校验逻辑属于底层原生设计, 无法被动态旁路与临时绕过, 前置拦截效率与稳定性显著优于后置被动防护。从源头压缩智能体输入层攻击面, 彻底改变传统事后补救的被动防护模式。 • 不可变更感知基线, 抵御长效语义预埋攻击: 将数据采集范围、可信数据源白名单、对抗校验阈值核心参数设为需求阶段固定硬编码基线, 完全关闭线上动态配置修改与临时调整入口。有效杜绝运维篡改、后台配置漂移风险, 长效防御需求层预埋的隐性语义感染、逻辑缺陷与持久化后门 [993]。落地优势: 彻底消除线上配置篡改与动态绕过攻击路径, 安全基线在全生命周期内稳定生效、无弱化空间。构建了全周期恒定的输入层安全阈值, 适配智能体长期自治、动态迭代运行特性。
记忆 (存储层)	• 需求级前置投毒, 实现跨会话永久潜伏: 通过诱导制定宽松型记忆写入规约、模糊持久化存储边界与数据隔离规则, 仅需单次需求阶段恶意配置植入, 即可让恶意向量知识跨会话、跨设备重启长期稳定潜伏, 形成难以清除的永久性记忆后门。缺陷风险: 单次需求篡改即可完成长效深度投毒, 系统无会话重置、迭代自清除机制, 污点永久留存。 • 治理机制需求缺失, 生成原生存储漏洞: 刻意诱导需求文档省略记忆时效衰减、内容冲突裁决、涉密分级隔离等核心治理条款, 模糊短期缓存与长期知识库的物理存储边界, 使智能体原生具备无约束写入、越权读取与跨域访问漏洞。缺陷风险: 长短记忆边界完全模糊, 恶意数据可无限制跨层级留存、横向扩散, 污染全域知识体系。 • 固有记忆劣化定义, 驱动持续性知识漂移: 将语义偏移、逻辑漂移、外部恶意知识内化三类劣化问题定义为系统固有设计属性, 使记忆劣化具备常态化、持续性特征, 长期干扰智能体知识推理、逻辑判断与任务决策全链路 [571]。缺陷风险: 知识漂移属于底层固有特征, 常规数据清洗、模型重训练均无法根治结构性劣化问题。	• 量化分区存储规约, 强制长短记忆硬隔离: 在需求规范阶段明确可量化、可落地的记忆分层管控指标, 清晰界定短期上下文、中长期业务知识的存储边界, 配套完善的读写权限 ACL 与过期强制回收规则, 刚性阻断恶意知识跨域留存与横向扩散路径。落地优势: 分层隔离为底层硬性约束, 从架构层面杜绝跨分区无授权数据流转, 筑牢存储安全底座。 • 原生衰退机制固化, 内生抑制知识漂移: 搭建标准化记忆全生命周期管控体系, 原生内置访问频次统计、动态时效衰减公式、内容冲突检测与劣化淘汰逻辑, 将防漂移、防污染能力深度嵌入系统底层设计, 从源头缓释结构性记忆劣化问题。落地优势: 依托自动时效淘汰机制持续清理过期、恶意向量数据, 有效抑制知识漂移累积与隐性污染。 • 分级写入准入基线, 构建全流程记忆管控: 建立三级分级记忆写入验证准入体系, 摒弃传统默认全量入库逻辑, 将污点追踪、权限校验、完整性审计、生命周期销毁机制纳入强制管控环节, 闭环拦截各类无校验恶意写入行为 [572], [574]。落地优势: 全链路写入校验形成完整安全闭环, 全方位阻断未验证、高风险数据入库通道。

续下页

表 5.1 – 续上页

模块	攻击趋势	防御趋势
决策 (推理层)	- 前置决策面攻击，脱离 Prompt 越狱依赖：新型决策层攻击将攻击面彻底前置至需求设计阶段，聚焦决策空间定义、行为约束规则与奖励函数权重配置的原生漏洞。攻击者无需干预外部输入，即可篡改智能体内部推理逻辑、实现全程静默决策劫持。缺陷风险：无任何外部异常载荷与行为特征，传统流量审计、关键词过滤、异常基线检测完全失效，难以被安全设备识别告警。 - 奖惩机制定向诱导，植入固有操控通道：攻击者通过需求文档诱导开发者放宽决策约束、放开高危操作原生权限，配置重效率、轻安全的单向奖惩机制，使智能体迭代持续偏向高危行为优化，出厂即内置稳定的奖励操控链路，形成先天推理缺陷。缺陷风险：核心收益权重永久结构性倾斜，智能体自主推理主动偏好高危恶意行为，无需外部诱导即可自发违规决策。 - 内生任务目标错位，形成隐蔽恶意闭环：需求阶段规则缺陷引发永久性任务目标偏移，使智能体优先适配恶意收益逻辑，形成“策略自适应作弊—隐性高危执行—行为特征自我伪装”的内生恶意闭环 [991]。该偏差源于底层设计缺陷，具备极强稳定性与持续性。缺陷风险：恶意决策具备自我伪装、自适应特性，可动态规避常规检测基线，造成安全监测大面积漏判。	- 决策空间形式化规约，划定刚性禁区边界：引入严格形式化逻辑对智能体决策可行域、行为空间与推理边界开展数学建模，明确合法动作范围与高危禁区，从源头压缩恶意策略生成空间，杜绝边界疏漏引发的底层决策劫持风险。落地优势：数学化刚性边界无法规避绕过，从机理上彻底切断无提示、无交互的静默劫持路径。通过可量化的决策约束体系，彻底消除模糊语义带来的自主决策偏差风险。 - 安全约束嵌入奖励内核，构建联合优化架构：将合规规范、风险代价与行为惩罚转化为约束时序决策逻辑，重构智能体优化目标函数，让安全约束与任务收益同步参与推理迭代，以前置安全管控替代后置被动过滤防护 [504]。落地优势：风险代价实时嵌入决策优化全过程，在推理底层抑制恶意策略生成，实现内生安全约束。 - 全推理链路可审计，实现隐性劫持溯源：强制原子化决策节点完成全链路轨迹留存、意图溯源与逻辑复盘，内置安全约束求解与决策分支日志，保障推理步骤不可篡改、可回溯复现，精准识别隐性目标偏移与底层决策劫持。落地优势：精细化推理轨迹支撑溯源取证与缺陷定位，可反向排查需求层原生设计漏洞。为智能体隐性、渐进式的决策逃逸问题提供全链路归因与闭环整改依据。
行动 (执行层)	- 权限需求预埋，摆脱运行时工具诱导：新一代行动层攻击聚焦需求阶段权限基线预埋，通过诱导粗放式权限规范，在出厂前预置宽泛的工具调用、资源访问与系统操作权限。依托智能体迷惑代理与自主执行机制静默提权，无需攻破模型即可形成持久执行攻击面。缺陷风险：权限体系原生宽松无约束，正常合规业务交互即可触发越权操作，攻击门槛极低、隐蔽性极强。 - 凭证策略诱导粗放，构建长效劫持载体：诱导需求采用粗粒度“全有/全无”权限模型，取消分级授权与时效约束，允许智能体长期留存用户身份令牌、会话凭证与密钥，构建可反复复用的长效劫持载体。缺陷风险：长效凭证永久本地留存，单次劫持即可实现跨会话、跨场景的持续性权限滥用与重复攻击。 - 设计级权限固化，放大供应链级风险传导：权限管控短板固化为系统原生架构特征，攻击者可依托邮件、代码仓库、第三方插件等可信供应链入口发起批量渗透，实现规模化集群化攻击扩散，大幅提升攻击破坏力 [1]。缺陷风险：依托可信供应链批量传播，隐蔽性强、覆盖范围广，常规单点防护难以有效抵御。	- 原子化最小权限，固化工具访问硬基线：在需求阶段对工具调用、资源访问、系统操作做精细化原子权限拆解，明确作用域、调用频次与副作用边界，将分级最小权限固化为不可变更安全基线，从源头收敛攻击面 [994]。落地优势：细粒度原子权限可天然阻断权限横向扩散、叠加越权与链式提权，实现最小攻击面防护。 - 一次性临时凭证机制，根除身份留存风险：需求层强制落地“即时申请、单次授权、用完即毁、会话清零”凭证范式，严禁持久化存储身份密钥与长期令牌，彻底清除长效身份劫持载体。落地优势：无长期有效身份留存，单次泄露无法复用扩散，从根源杜绝持续性权限滥用。凭证生命周期与单次任务强绑定，消除跨会话身份复用带来的持久攻击条件。 - 人机权限动态隔离，升级运行时防护范式：将人机权限域动态隔离纳入强制需求基线，配套工具副作用约束、高危分级审批与动态回收机制，构建事前隔离、事中阻断、事后溯源的全闭环防护体系 [1]。落地优势：严格区分人机权限边界，有效阻断依托智能体代理身份绕过管控的隐性攻击路径。

续下页

表 5.1 – 续上页

模块	攻击趋势	防御趋势
交互 (协同层)	- 前置隐性交互攻击，规避关键词显性拦截：新型协同层攻击利用交互边界规范缺失、指令与数据解析规则模糊的原生漏洞，依托系统固有信任机制实现无特征隐性绕过，彻底规避传统关键词匹配与显性流量拦截体系，攻击隐蔽性大幅提升 [990]。缺陷风险：无显性恶意特征与违规关键词，常规流量审计、内容过滤与行为检测机制完全失效，难以被现有安全体系感知。 - 文档隐式负载植入，触发无提示自动执行：需求阶段未规范指令与数据强制隔离机制，攻击者可将恶意执行逻辑、隐性控制载荷嵌入合规技能文档、配置模板与官方样例资源。智能体复用标准化业务资源时无需外部用户提示，可自动解析并激活预埋恶意载荷，实现无感攻击植入。缺陷风险：恶意载荷依托合规业务载体传播，正常复用行为与恶意执行高度耦合，难以通过常规手段区分与拦截。 - 供应链攻击规模化，突破常规防护体系：利用需求阶段对第三方组件、协同插件、跨智能体资源的默认信任漏洞，实现隐性攻击批量扩散。在多智能体动态组队、跨主体协同交互场景中，该类前置供应链攻击穿透性显著优于传统运行时显性指令攻击 [992]。缺陷风险：攻击依托可信供应链全域扩散，覆盖多智能体集群场景，单点防护机制无法抵御规模化协同渗透。	- 二元语义边界强制隔离，阻断隐式载荷传导：在需求规格阶段显性构建可执行指令与静态数据的二元强制隔离体系，明确交互解析二重性安全边界，从根源根治 DDIPE 等隐性交互攻击的生成条件 [990]。落地优势：底层解析逻辑原生区分指令与数据语义，彻底杜绝依托合规文档的无提示恶意执行链路。 - 组件零信任准入，沙箱 + 形式化双验证：重构第三方资源准入需求基线，摒弃默认可信机制，建立技能插件、外部知识库、协同组件的全生命周期准入与退出规范。所有外部资源必须通过独立隔离沙箱动态检测与形式化合规双重校验，方可加载接入系统，有效抵御供应链预埋隐性后门 [1]。落地优势：双层校验机制斩断外部资源隐性攻击链路，彻底消除默认信任带来的协同安全风险。 - 全交互链路溯源，构建形式化持续信任体系：将全量交互日志、跨主体载荷溯源、身份轨迹留存、协同行为审计纳入强制需求规范，重构传统静态信任机制。将“默认可信、事后复盘”的被动模式，升级为规则驱动、可量化的形式化持续动态验证架构。落地优势：实现协同信任关系动态校验，无永久可信主体，持续阻断隐性交互逃逸行为。
治理 (管控层)	- 顶层治理缺失，全局逃逸绕过分布式校验：传统智能体安全治理依赖各功能模块分布式独立防护，需求阶段普遍缺失全域统一管控架构。攻击者可利用顶层治理盲区，针对性规避分散式防护规则，构建跨模块全局逃逸通道，突破单点安全约束。缺陷风险：各模块局部防护相互独立、数据割裂，无法聚合研判跨域联动的全局攻击链路。 - 跨模块约束空白，支撑碎片化组合攻击：顶层需求规范缺乏跨模块协同约束机制，攻击者可将完整恶意攻击链路拆解为多段离散合规行为，分步在感知、决策、行动等不同模块执行。单一模块检测机制仅能判定局部行为合规，无法识别整体恶意闭环。缺陷风险：碎片化攻击具备极强伪装性，单步行为合规、全局危害极高，传统分段防护极易漏判。 - 架构缺位催生长效全局逃逸风险：分层模块化架构的天然隔离特性，导致各模块监测体系独立运行、数据不通，需求阶段未设计全局联动治理机制。离散化恶意行为可适配架构特性分步渗透，长期潜伏于系统内部。缺陷风险：全局逃逸通道固化为架构固有短板，零散单点防护无法系统性封堵跨模块组合攻击。	- 构造式治理原生嵌入，五层全链路拦截架构：在系统设计阶段将五层内生治理架构原生嵌入智能体内核，覆盖意图守卫、规则引导、合规校验、人工门控与输出格式化全节点，构建贯穿全生命周期的内生治理屏障 [520]。落地优势：治理能力属于内核原生组件，无法被旁路、卸载或动态规避，筑牢全域安全底座。 - 策略即代码标准化，底层约束硬编码：摒弃传统自然语言松散治理规则，在需求阶段落地机器可读、可编译的标准化策略框架，将安全治理规则直接编译为系统底层硬约束，摆脱外部文本管控的低效模式，保障规则不可篡改、强制生效 [995], [996]。落地优势：安全规则固化于底层执行逻辑，规避文本配置篡改、规则失效与人为绕过风险。 - 全域治理量化基线，搭建统一零信任架构：针对身份认证、行为观测、数据管控、资源边界、应急响应五大核心维度，建立可量化、可审计、可迭代的全域治理基线，搭建跨模块统一零信任治理体系，打通各功能模块联动防护能力 [504], [997]。落地优势：依托统一基线实现跨模块风险聚合研判，精准识别碎片化、组合式隐性全局攻击。

5.2 架构设计阶段（攻防趋势）

架构设计阶段以**内核拓扑固化**为核心，将 AI 智能体攻防博弈重心从需求语义层下沉至系统内核结构层，是未来结构性攻防对抗的核心阵地。该阶段承接前期安全基线，将抽象安全规约固化为组件耦合拓扑、全域信任链路与跨模块交互逻辑，直接决定智能体内生攻防基底与风险传导机制。结合现有架构安全研究与内生防御成果，攻防核心演化趋势如下（详见表 5.2）：

- 空间下沉趋势：攻防对抗内核化迁移，表层对抗向架构拓扑结构性对抗演进。**未来 AI 智能体攻防呈现范式级空间下沉，逐步脱离传统表层交互对抗模式，形成架构拓扑结构性对抗为主、表层入口拦截为辅的新型攻防体系 [998], [999]。新形势下的架构层攻击摒弃显性恶意载荷，利用组件耦合、全域默认信任、数据流与协议语义缺陷发起内核级攻击，覆盖感知、记忆、决策、执行、集群协同等核心链路 [1000]。该下沉趋势催生三大常态化攻防特征：一是漏洞架构固化，缺陷根植组件信任链路内核，传统补丁、热更新无法彻底修复，仅可通过拓扑重构根除；二是攻击无痕无载荷，依托合法业务流转与协议偏差触发风险，规避现有流量审计、入侵检测体系 [999]；三是风险链式爆炸传导，单点失陷可沿耦合链路全域扩散，攻防核心战场已深度下沉至内核架构拓扑 [396]。
- 拓扑分化趋势：模块漏洞差异化分布，跨组件级联传导成为全域安全核心威胁。**攻击侧演化呈现模块化、定制化特征，攻击者针对各架构模块固有拓扑短板，摒弃通用载荷攻击，聚焦结构性缺陷实现长效渗透 [1001]。感知模块因多模态全域互信、跨通道校验缺失，频发跨模态穿透、隐性视觉指令注入等架构专属攻击 [999]；记忆模块受存储边界模糊、集群同步缺位影响，衍生跨会话持久投毒、全域存储篡改、碎片化累积污染等长效风险 [396], [998]；决策模块依托规划内核无校验、跨智能体默认信任短板，出现内核任务劫持、隐性目标偏移、级联污染等高隐蔽攻击 [1000], [1002]；行动模块因工作流无全局校验、插件管控缺失，引发链式工作流劫持、权限溢出、协议柔性绕过等风险 [999], [1003]；交互模块受异构协议语义割裂、信任标准不统一影响，产生跨协议渗透、隐性传导等漏洞 [1002]；治理模块因顶层管控缺位、全域默认可信拓扑，成为碎片化组合攻击与供应链渗透的逃逸通道 [998], [999]。防御侧整体向**内生拓扑重构**收敛，摒弃外置插件式防护，通过重构组件耦合与信任链路原生植入安全约束 [1004]。感知模块搭建分层信任域与异构并行校验架构，切断跨模态污染通路 [998], [1005]；记忆模块引入溯源标签与 TEE 硬件隔离，固化存储边界、抑制长效污染 [396], [1000]；决策模块采用时态逻辑验证、双层解耦架构与工具中介约束，锁定推理规划边界 [1002], [1003]；行动模块配置接口硬约束、动态风控链路与 ACS 纵深架构，保障工作流完整性 [1004], [1006], [1007]；交互模块依托统一语义底座与零信任访问图谱，消除协议信任盲区 [1002], [1008]；治理模块植入前置信任基线、五层原生治理架构与策略即代码底座，实现全模块统一管控 [520], [1000], [1004]。
- 拓扑博弈趋势：连通与隔离三元矛盾激化，受控连通架构成为攻防博弈核心解法。**架构层攻防的长期博弈核心，围绕业务拓扑连通性、安全边界隔离性、集群量产经济性三元内生矛盾展开，是架构级原生攻击的底层成因与智能体技术迭代核心驱动力 [998], [1001]。攻击侧主要利用架构连通性缺陷实现突破：智能体为保障业务协同效率，原生具备组件紧耦合、全域默认信任、治理能力外置等特征，攻击者可挖掘连通性盲区，将单点缺陷放大为全域结构性风险，依托合法业务链路实现无痕渗透，常规边界防护难以拦截 [999], [1000]。防御侧则面临安全隔离的工程约束：组件解耦、边界隔离等硬核防御手段，会增加部署成本、降低协同灵活性，损害业务效率与量产性价比 [1004]。现有折中架构无法彻底消解三元矛盾，难以实现安全、性能与成本的动态平衡 [998], [1002]。

表 5.2: AI 智能体架构设计阶段攻防趋势

模块	攻击趋势	防御趋势
感知 (输入层)	• 多模态跨通道穿透攻击，利用全域互信架构缺陷：新一代感知层攻击聚焦智能体多模态融合架构的原生信任漏洞，系统对文本、图像、视听输入默认采用全域统一可信假设，未设置模态差异化校验边界。攻击者依托模态语义差异构造隐蔽诱导载荷，实现横向跨通道穿透污染，突破传统单输入防护约束，隐蔽攻击可在多模态场景持续潜伏扩散 [999]。架构短板：多模态通道共用一套信任校验逻辑，单通道失陷即引发全链路全域污染传导，模块防护隔离性极差。 • 视觉对抗结构化攻击，图形界面预埋隐性指令：视觉链路独立于文本审计体系形成常态化防护盲区，攻击者可在图像、界面素材中预埋隐写操控指令，依托智能体视觉解析机制实现静默诱导执行，攻击穿透性与隐蔽性远超常规文本提示注入 [999]。架构短板：视觉解析链路无配套安全审核节点，图形载荷可绕过文本校验体系直接参与推理决策，形成稳定固有攻击面。 • 跨组件碎片化攻击，规避单点模块检测：利用感知组件级联耦合、独立运行的架构特性，攻击者植入多路差异化矛盾载荷造成环境感知逻辑割裂，离散化攻击模式可有效规避传统单点特征检测机制 [1001]。架构短板：各组件独立运算无全局状态同步校验，离散恶意信号无法聚合研判，碎片化攻击漏检率极高。	• 分层信任域架构建模，接口分级隔离渗透通路：重构感知层双层信任架构，划分底层采集层与上层解析层的独立信任边界，对多源、多模态输入量化可信等级，在组件交互接口处刚性阻断跨模态无授权渗透行为 [998]。落地增益：分级信任机制固化于架构接口底层，从物理链路彻底切断跨通道全域污染传导路径。通过架构级信任分区设计，从源头规避单一输入缺陷引发的全域感知失效问题。 • 分级隔离信息流，隔离不可信原始载荷：严格隔离原始多模态素材与模型推理内核，禁止大模型直接访问未经过滤校验的原始数据，从底层架构阻断图像、视听类内容欺骗与对抗攻击传导 [1005]。落地增益：不可信数据与推理内核物理隔离，即便输入通道被攻破也无法诱导决策偏差，实现全方位防御兜底。构建输入层与推理层的安全隔离屏障，彻底颠覆传统直通式高危交互架构。 • 多模态异构独立校验，分步校验后再信息融合：摒弃传统统一解析的脆弱架构，搭建文本、图像、音视频并行异构校验管线，严格遵循“先校验、后融合”机制规避污染扩散，全方位提升多模态输入安全基线与整体抗干扰能力 [998]。落地增益：各模态校验规则完全解耦独立生效，单通道恶意载荷无法污染其余模态，根除跨通道批量污染风险。
记忆 (存储层)	• 跨会话持久化全域投毒，依托存储边界模糊架构：传统单会话临时污染已全面迭代为跨会话、跨设备的长效投毒范式，存储架构未对临时缓存与持久知识库设置硬性隔离边界，恶意向量写入后可长期驻留底层存储，形成难以清除的永久性数据污染 [1000]。架构短板：长短记忆分区管控机制缺失，单次污染即可实现永久留存、持续复用、反复干扰推理。 • 持久状态篡改成为主流架构级新兴威胁：持久化存储篡改已超越常规攻击手段成为存储层核心威胁，攻击者篡改核心记忆基线并依托集群同步机制实现全域扩散，引发大规模集群级系统性安全风险 [1000]。架构短板：持久存储无跨实例一致性校验机制，篡改数据可批量快速扩散，整体风控难度极大。 • 多轮碎片化累积投毒，形成记忆污染链式传导：攻击者规避集中投毒的高检出风险，将恶意知识拆解为碎片化载荷分轮次植入，恶意向量持续累积并沿组件依赖链路传导，持续扭曲智能体知识体系与推理逻辑 [396], [998]。架构短板：记忆写入流程无时序溯源与来源标记能力，无法精准甄别原生可信知识与分步植入恶意碎片。	• 来源感知溯源记忆架构，全向量可信等级管控：为所有记忆向量统一绑定来源组件、写入时序与可信评级标签，在记忆读取与推理阶段动态约束访问权限，有效阻断污染知识跨会话、跨场景复用传导 [1000]。落地增益：可精准溯源污染源头与植入时间，支持定向清洗修复，无需全局重置，兼顾安全与业务连续性。 • TEE 硬件可信隔离，敏感持久存储底层加固：将高敏感业务知识库、密钥与核心会话数据部署于 TEE 硬件可信环境，搭配集群远程核验机制，从硬件底层杜绝持久存储篡改与恶意植入风险 [396]。落地增益：上层应用与推理模块无权限篡改底层持久数据，从根源根治长效存储投毒风险。 • 读写路径专用容器架构，隔离共享存储全域风险：重构分层隔离式存储架构，分离独立可信写入链路 with 只读审计读取链路，收紧共享存储无差别访问权限，所有写入行为统一纳入审计管控 [998]。落地增益：未授权组件无法篡改核心知识库，从架构底层彻底阻断碎片化累积投毒生成条件。

表 5.2 – 续上页

模块	攻击趋势	防御趋势
决策 (推理层)	• 攻击下沉至规划内核，脱离表层提示越狱依赖：新一代推理层攻击完全下沉至智能体架构内层任务规划单元，彻底摆脱传统表层 Prompt 篡改、输入越狱依赖。攻击者通过篡改任务分解规则、子任务依赖与路径推演底层逻辑，即可劫持智能体全局执行意图，实现全程无特征隐性控制。架构短板：推理规划内核仅承载业务推演功能，无独立安全校验与意图审计单元，子任务生成缺乏硬性边界约束。 • 目标隐性劫持，利用规划语义架构偏差：深度依托决策架构意图校验缺失短板实施隐性目标劫持，形成表层合规、底层恶意的伪装攻击链路。智能体仅校验单步指令合法性，无法核验任务终点与原始意图一致性，持续沿恶意规划路径迭代执行，隐蔽性极强 [999]。架构短板：规划层采用分步局部校验，仅保障单步合规，缺失全链路任务目标一致性核验机制。 • 跨信任链递推劫持，形成级联控制流污染：多智能体协同架构普遍缺失推理链完整性跨节点校验模块，上下游信任机制粗放。下游智能体无独立溯源能力，直接复用上游恶意规划逻辑，造成劫持链路跨主体链式扩散，引发全域推理污染风险 [1000]。架构短板：跨主体通信默认信任上游决策输出，无分布式交叉验证与异常溯源机制。	• 时态逻辑形式化决策框架，全域推理行为可验证：针对智能体任务生命周期、子任务流转时序、路径迭代规则构建标准化时态安全属性体系，依托形式化逻辑识别规划边界溢出、隐性目标偏移、推演异常等架构漏洞，从数理层面约束推理合法性 [1002]。落地增益：数字化刚性约束固化规划边界，从底层机理阻断无约束恶意路径生成。可实现长期迭代场景下的持续性推理合规校验，遏制渐进式决策逃逸风险。 • 双层解耦决策架构，规划与校验单元物理分离：重构推理层双层隔离架构，将业务规划代理与安全校验生命周期单元完全解耦、物理隔离，分层管控意图解析、子任务拆解、状态流转全流程，杜绝校验逻辑被业务链路绕过 [1002]。落地增益：安全校验独立于业务规划体系，恶意规划无法绕过校验单元直接下发执行。双单元制衡架构破除了传统单一体制推理的内生安全短板。 • 工具中介约束架构，压缩自由规划探索空间：重构智能体动作生成范式，限制自由推演空间，仅允许从预定义、经验证、合规固化的标准化动作目录选取行为，杜绝高危自定义推理路径生成 [1003]。落地增益：规划输出具备强确定性，无随机探索空间，从架构层面根除复杂恶意链式规划条件。
行动 (执行层)	• 链式 workflow 劫持，突破单步工具调用防护：新型执行层攻击突破单步工具调用滥用范式，升级为整条工作流的持续性劫持攻击。攻击者在多步骤任务中间节点植入篡改逻辑，依托步骤依赖实现跨工具、跨流程的持续性恶意操控，规避单点防护拦截。架构短板：工具调用序列仅做单步校验，无全局完整性哈希校验，单节点篡改难以被整体检测。 • 调用链级联破坏，多米诺式权限溢出传导：执行层架构缺失工作流时序完整性全局校验单元，各工具节点独立校验、互不感知。攻击者篡改中间步骤参数后，后续节点将沿依赖关系同步越权执行，形成多米诺式级联风险扩散。架构短板：单点静态校验无法感知整条工作流联动异常，难以识别隐性链式越权行为。 • MCP 协议柔性绕过，插件生态原生逃逸通道：依托 MCP 协议灵活扩展的架构特性，突破传统静态黑名单管控约束。攻击者利用第三方插件准入漏洞植入隐性载荷，借助插件链路实现柔性绕过与持久化驻留攻击 [999]。架构短板：MCP 插件体系缺乏统一准入网关与运行时监控，外部插件可直接介入核心调用链路。	• 工具接口形式化硬约束，控制与数据流向解耦：重构工具接口底层逻辑，实现控制与数据流向解耦，模型输出数据回流前强制经过独立校验层，阻断恶意参数、越权指令扩散至整条工作流 [1003]。落地增益：工具输入输出双向受控，单节点篡改无法向下游传递污染，阻断级联风险传导。 • 轨迹驱动 Safe 智能体架构，上下文感知动态风控：搭建轨迹驱动动态安全架构，依托上下文感知实时研判整条工作流风险态势，动态识别跨步骤隐性联动高危行为，主动中断异常序列，实现运行时全链路动态拦截 [1006]。落地增益：弥补单点静态黑名单盲区，精准识别分步式、联动式隐性执行攻击。 • ACS 三层纵深隔离架构 + MATRA 量化验证体系：搭建执行前准入、执行中监控前准入、执行中监控、执行后审计的三层纵深防护，配套隔离沙箱压缩攻击半径，叠加最小权限、网络隔离底层约束，形成完整兜底架构 [1004], [1007]。落地增益：多层防护相互兜底，单层失效仍可通过容器隔离阻断横向扩散，大幅提升系统鲁棒性与抗攻击能力。

续下页

表 5.2 – 续上页

模块	攻击趋势	防御趋势
交互 (协同层)	• 跨协议复合信任滥用，多信道语义鸿沟制造错位攻击：多智能体协同存在多协议、多信道并行交互特性，架构未设计全域统一语义约束与解析标准。攻击者利用不同通信协议的解析差异与语义鸿沟，构造复合恶意载荷实现跨边界隐性错位渗透，有效规避单协议安全校验规则 [1002]。架构短板：各通信协议独立解析、独立管控，无全局语义一致性校验单元，不同信道间信任规则互不互通，存在大量交叉防护盲区。 • 协议碎片化带来协同架构固有漏洞：现有协同架构依赖异构协议体系，缺失跨协议统一安全校验网关与全局管控中枢，天然产生语义解析偏差、权限异步传递、交互逻辑错位等漏洞。碎片化架构难以开展全域风险推演，极易被攻击者针对性突破 [1002]。架构短板：异构协议无标准化信任转换与权限映射规则，跨信道意图与权限传递存在原生安全盲区。 • 双路径并行架构级交互渗透，隐蔽逃逸性极强：当前交互体系存在身份信任与会话上下文双轨管控架构缺陷，衍生两类高隐蔽攻击路径并可叠加生效。一是失陷低权限节点伪造身份骗取高等级编排权限；二是多轮会话渐进污染上下文，悄然偏移推理基线实现隐性劫持 [999]。架构短板：身份校验与会话管控体系相互独立、逻辑割裂，无联动风险研判机制，双路径隐性攻击难以有效识别。	• 统一语义形式化交互底座，全域可验证属性约束：针对异构协议交互混乱、语义不统一的架构短板，搭建全域形式化语义交互底座，标准化定义活性、安全、完整、公平四类核心可验证属性。依托数理刚性约束，统一规范 MCP 插件、A2A 多智能体协同全链路交互行为 [1002]。落地增益：异构协议共用同一套语义安全规则，彻底消除跨信道信任转换偏差与语义解析漏洞。实现多智能体复杂协同场景下交互逻辑的可证安全与稳定可控。 • 跨平台通用策略管控，全链路多点拦截校验：搭建适配多协议、多框架的跨平台通用安全管控适配层，打破异构架构壁垒。在交互全链路关键节点设置多重校验拦截点，让全域异构智能体集群复用统一安全管控引擎 [1004]。落地增益：无需为不同协议单独开发防护逻辑，可统一拦截各类跨协议复合渗透与错位交互载荷。有效解决传统分散防护带来的策略不一致、防护盲区零散等工程问题。 • 零信任 AI 访问图谱，全链路溯源管控：构建适配多智能体协同的全域零信任 AI 访问图谱，融合零信任架构、代理与端点安全能力。对所有交互主体、访问动作、调用策略、数据轨迹实现全维度权限管控与溯源审计 [1008]。落地增益：摒弃永久可信机制，每次跨信道、跨主体交互均动态核验权限，彻底杜绝隐性信任滥用风险。
治理 (管控层)	• 全域系统性架构逃逸，拆分攻击链路规避分散防护：现有安全体系呈现模块化分散防护特征，顶层缺失统一治理内核与全局风控中枢，各模块防护规则相互割裂。攻击者可拆解完整攻击链路为离散片段并分发至不同组件执行，局部模块无法聚合研判全域恶意链条。架构短板：各模块治理逻辑、风控数据、审计体系完全独立，无跨组件风险聚合与全局研判中心。 • 顶层治理架构研究缺位，形成天然全域攻击面：当前智能体安全研究多聚焦单点防护，针对多智能体协同、插件生态的顶层全域治理架构研究缺位，治理成熟度滞后于业务迭代，架构短板成为全域渗透的核心突破口 [998]。架构短板：治理能力多为后置外挂机制，未原生嵌入内核执行链路，极易被业务链路旁路绕过。 • 默认信任叠加供应链架构双重风险：多智能体 A2A 协同存在节点默认互信缺陷，单点失陷即可横向批量扩散恶意载荷。同时现有治理架构缺失原生策略编译能力，无法有效约束供应链引入的隐性安全风险 [999]。架构短板：无默认信任消除与动态授信机制，供应链规则无法嵌入核心推理执行链路，存在先天管控缺失。	• 前置显式全域信任基线，顶层固化最小权限约束：重构全域治理底层逻辑，前置定义跨模块、跨主体信任隔离边界与安全基线。将分层原子最小权限规范固化为全模块底层强制约束，统一全域访问授信与风控基准 [1000]。落地增益：全域信任与权限规则由顶层统一下发，杜绝各模块自主放宽信任阈值导致的防护失效问题。 • 构造式五层原生治理架构，校验节点嵌入执行图：采用内生构造式治理架构，将意图守卫、规则引导、工具校验、人工审批、输出格式化五层拦截节点，原生嵌入智能体全生命周期执行链路，实现内嵌式全程管控 [520]。落地增益：任意拆分式攻击链路流转均必经治理节点，彻底封堵碎片化逃逸与跨模块规避漏洞。 • 策略即代码标准化统一管控底座，多框架联动协同治理：搭建策略即代码标准化治理底座，将治理规则编译为底层强制执行约束，适配多厂商异构集群，实现全链路可审计、可溯源的跨平台协同治理 [1004], [1009], [1010], [1011]。落地增益：安全规则固化于系统底层，无惧业务逻辑篡改绕过，可适配多类智能体框架实现全域统一风控。

5.3 编码开发阶段（攻防趋势）

编码开发阶段以**底层工程固化**为核心价值，将智能体攻防博弈重心从架构中层下沉至源码与二进制执行底层，是未来代码级对抗的核心工程阵地。本阶段承接架构层拓扑约束与信任逻辑，将抽象安全规则编译固化为源码控制流、基线配置与机器指令，直接决定智能体底层原生攻击面与防御基底。结合代码安全与编译层攻防研究成果，本节系统梳理编码开发阶段核心攻防演化趋势（详见表 5.3）：

- **工程下沉趋势：攻防对抗极致下沉，架构对抗向源码底层执行范式深度演进。**未来编码层攻防将彻底脱离外部依赖，下沉至源码分支、底层函数、初始化脚本与第三方依赖库，摒弃提示词诱导、外部载荷注入等传统攻击模式 [998], [999]。攻击者在开发编译阶段将恶意逻辑与业务源码强耦合，实现二进制层级永久驻留，从工程根源重构攻防对抗模式 [1012]。该范式迁移催生三大核心攻防特征：一是**恶意逻辑原生固化**，后门内嵌于程序固有执行逻辑，上线后热修复、流量拦截等运维手段无法根除，仅能通过源码重构重编译彻底整改 [854]；二是**全维度无特征隐蔽逃逸**，攻击依托合规业务流程与合法参数触发，无恶意指纹与异常流量，可规避传统代码扫描与行为审计体系 [560], [1013]；三是**CI/CD 供应链量产渗透**，攻击者依托代码仓库、流水线与公共依赖实现批量源码污染，单次植入即可完成集群全域渗透，大幅降低底层攻击成本，推动代码投毒成为主流威胁 [1014]。
- **代码分化趋势：模块底层差异化植入深化，代码复用诱发全域链式风险传导。**攻击侧摒弃通用运行时攻击，针对六大模块编码特性定制差异化底层植入路径，实现无痕长效驻留 [1012]。感知模块篡改预处理逻辑、植入隐性条件分支，构建条件激活型隐匿威胁 [560], [1013]；记忆模块通过初始化数据源投毒、向量劫持预埋污染通路，引发跨会话永久性数据污染 [1015], [1016], [1017]；决策模块依托推理分支预埋、技能木马嵌入劫持内核规划逻辑 [753], [1018]；行动模块篡改底层工具函数、硬编码恶意配置，诱发权限链式溢出 [1014], [1019]；交互模块篡改会话与协议底层代码，实现跨主体数据流隐性劫持 [1020], [1021]；治理模块篡改审计分支、利用静态权限缺陷构建内核级逃逸通道。防御侧整体向**编译期原生固化**收敛，摆脱外置防护依赖，将安全约束硬编码嵌入程序基底。感知模块通过交叉校验、符号执行与分支锁定加固底层输入逻辑 [1022]；记忆模块依托全生命周期管控、溯源锚定与快照回滚，双向阻断存量与增量投毒 [735], [1023], [1024]；决策模块搭建推理溯源、技能沙箱隔离与编译断言，构建不可绕过底层边界；行动模块依托控制流监护、语义监督与全链路源码校验筑牢执行安全通道 [854]；交互模块通过签名验签、会话隔离与协议源码加固阻断跨域渗透 [721], [1025]；治理模块依托多层代码防护、追加式审计与动态权限模型，封堵治理旁路与隐性越权漏洞 [1026]。
- **工程博弈趋势：复用-隔离三元矛盾持续激化，可控复用成为底层防御核心解法。**编码层攻防博弈核心围绕**代码复用性、安全隔离性、量产经济性**三元内生矛盾展开，该矛盾是底层代码植入攻击的核心成因，也是智能体工程体系迭代的核心驱动力 [998], [1001]。攻击侧依托工程复用特性实现全域渗透：智能体为提升迭代效率普遍采用全局代码复用、默认依赖引入、流水线无校验放行机制，攻击者利用该特性将局部源码缺陷放大为全局永久风险，依托合法开发链路完成无痕批量扩散，此类底层攻击无法通过上层防护手段拦截 [999], [1012]。防御侧的强隔离管控会显著抬升工程成本：代码物理隔离、全量符号审计、编译强验签可根治底层后门，但会拉长编译周期、破坏复用效率、降低量产性价比 [1004]。当前行业无完美折中方案：过度复用会放大风险传导半径，过度隔离抑制迭代效率，折中校验仍残留代码伪装、隐性分支等可利用盲区，攻防三元矛盾长期存在 [1002], [1026]。

表 5.3: AI 智能体编码开发阶段攻防趋势

模块	攻击趋势	防御趋势
感知 (输入层)	- 攻击链路下沉，从运行时欺骗转为代码层触发器植入：新型感知层攻击彻底下沉至底层代码编译阶段，摒弃传统运行时输入欺骗的浅层攻击模式。攻击者直接篡改多模态感知预处理流水线源码，植入硬编码条件触发后门逻辑，系统常规业务输入下正常运行，仅匹配预设特征时静默激活恶意分支，攻击隐蔽性大幅提升。缺陷风险：后门逻辑深度固化于底层代码，线上配置管控、输入过滤均无法清除，仅能通过重构流水线、重新编译彻底修复。 - 隐性代码注入，持久驻留底层逻辑：依托开发链路污染实现隐性代码注入，贯穿编码、构建、集成全流程，向感知源码植入高度耦合的隐性后门模块，实现原生级漏洞预埋 [1012]。缺陷风险：后门与业务代码高度融合、无独立特征，人工评审与常规静态检测漏检率极高，可长期潜伏于生产版本。 - 多维度复合条件触发，提升后门逃逸能力：突破单一触发机制局限，融合目标识别、交互时序双层触发器构建复合型激活逻辑，依托多条件交叉校验规避单层防护拦截 [560], [1013]。缺陷风险：多维度触发条件分散嵌入代码分支，单一检测维度无法全覆盖，防护体系易被针对性绕过。	- 多智能体对等交叉校验，精准捕获隐性条件后门：搭建多智能体对等比对校验机制，多节点同步执行感知推理并比对分支输出，依托节点行为差异自动定位条件触发型恶意代码，无需依赖恶意样本特征 [1022]。落地优势：摆脱传统特征匹配局限，可精准检出无异常输入、无显性特征的预埋复合后门。能够有效抵御休眠式、条件触发的长效隐性攻击，填补传统检测机制的识别空白。 - 编码期静态 + 动态符号执行联合代码审计：在开发阶段内嵌静态语法分析与动态符号执行双重审计工具，对感知流水线全路径遍历扫描，自动识别异常条件判断与后门植入点位。落地优势：代码上线前完成全维度安全检测，从源头拦截恶意代码流入生产环境。实现感知层代码链路全覆盖检测，有效规避局部路径遗漏导致的防护盲区。 - 防御范式前置，由后置输入过滤转为代码原生防护：重构感知层防御体系，将安全能力前置至源码编译阶段，完成恶意逻辑检测、分支隔离与权限约束，替代易被绕过的运行时被动过滤机制。落地优势：安全规则固化于程序底层，运行时载荷篡改、配置绕过等逃逸手段均无法生效。建立编译期原生安全基线，彻底扭转运行时被动防御的固有弱势格局。
记忆 (存储层)	- 攻击范式下沉，运行时临时投毒转为开发期原生数据污染：记忆层攻击完成架构迭代，从运行时临时会话投毒下沉至编码、构建开发阶段。攻击者直接篡改记忆初始化数据源与知识库生成脚本，实现系统性原生数据污染。缺陷风险：恶意知识成为系统固有初始配置，单次初始化即可全域投毒，重启、清空缓存无法彻底根除污染。 - 轨迹与技能文档隐性投毒，规避浅层静态扫描：依托合规交互轨迹、技能文档实施隐性投毒，篡改训练历史植入长效后门，触发后可引发数据外泄、越权访问等高风险行为 [1015], [1016]。缺陷风险：投毒样本与正常文档格式完全一致，浅层关键词过滤与静态扫描难以甄别，隐蔽危害周期极长。 - 多形态长期记忆劫持，极低成本造成持续性认知偏移：攻击者通过语义伪装、微量伪造样本、图谱结构冲突实施长期记忆劫持，直接篡改全局上下文判断逻辑，输入层前置防护无法拦截存量污染风险 [735], [1017], [1024]。缺陷风险：污染数据持久留存于向量知识库，多轮会话迭代持续复用篡改知识，不断累积放大系统认知偏移风险。	- 记忆全生命周期六阶防护，聚焦存储架构源头管控：针对大模型记忆污染、数据投毒、恶意篡改等全链路安全风险，构建写入、存储、检索、推理、传播、回滚六阶段闭环防护框架，实现全流程精细化风险管控与动态安全防护 [1023]。落地优势：覆盖记忆完整生命周期，从初始化源头阻断投毒数据入库与传播通道，大幅提升模型记忆体系的原生安全能力。 - 编码固化记忆溯源锚定，搭建不可篡改追踪链路：开发阶段内置全域记忆溯源架构，为每条知识向量绑定组件、时间戳、可信等级三元溯源凭证，全链路日志不可篡改、不可删除。落地优势：任意异常污染可反向追溯至开发源头，精准定位投毒节点与攻击链路，为安全审计与风险追责提供可信依据。 - 版本化记忆原生管控，支持批量隔离与历史回滚：集成记忆版本快照与分级留存策略，实现知识库增量更新与版本固化，支持污染数据批量隔离、一键回滚至干净基线。落地优势：存量污染无需重建知识库，依托版本机制快速消险恢复，保障业务稳定运行，显著降低故障处置成本与运维压力。

续下页

表 5.3 – 续上页

模块	攻击趋势	防御趋势
决策 (推理层)	• 攻击层级下沉，运行时推理劫持转为代码级逻辑预埋：新型推理层攻击完成架构下沉，从传统运行时表层推理劫持，深入内核编译阶段实施底层逻辑篡改。攻击者直接修改规则引擎分支判定、推理路径跳转、技能调用判定核心代码，预埋隐藏的条件触发恶意分支，常规运行阶段难以察觉。缺陷风险：恶意隐藏分支深度固化于推理内核底层，运行时监控仅能观测最终输出结果，无法溯源底层分支跳转异常，漏洞隐蔽周期极长。 • 木马隐匿植入，通过全量功能测试：采用碎片化木马隐匿植入技术，将完整恶意执行逻辑拆分、加密并分散嵌入多段正常技能源码中，可完美规避上线前全量功能验收与常规检测流程 [1018]。缺陷风险：恶意载荷高度碎片化拆分，单一技能源码无显性恶意特征，传统自动化扫描无法识别分散拼接式组合木马攻击逻辑。 • 状态驱动自主蠕虫，实现无交互跨节点横向扩散：将恶意持久化逻辑写入底层状态存储代码，依托智能体自启动机制自动加载恶意上下文，无需人工交互即可自主篡改配置、横向渗透入侵同集群节点 [753]。缺陷风险：攻击具备自主传播与迭代扩散能力，单节点代码失陷会快速蔓延至集群所有智能体实例，引发批量系统性安全事故。	• 编码固化全链路决策溯源，强制推理完整性校验：在推理内核底层深度植入全覆盖日志埋点机制，所有分支跳转、路径推演、技能决策全程留痕，日志不可篡改、不可删除，可精准定位隐藏分支触发的异常决策行为。落地优势：完整推理链路可全程复盘审计，快速区分正常业务决策与代码预埋的隐性恶意分支行为。可实现对渐进式、隐蔽性决策偏差的持续监测，支撑全生命周期风险追溯治理。 • 技能独立沙箱物理隔离，阻断木马全局渗透：将第三方技能、外部插件统一编译部署至独立硬件容器沙箱隔离运行，与核心决策引擎实现内存空间、运行权限、资源调用完全物理隔离。落地优势：硬件级隔离形成刚性安全边界，彻底阻断技能木马向上污染主决策内核、横向扩散全域系统的传播路径。从架构层面隔绝外部不可信组件的内生风险，杜绝插件供应链恶意渗透隐患。 • 决策安全约束代码形式化编译，构建不可绕过硬边界：将高危操作禁区、跨级越权判定、风险路径拦截规则统一编译为底层代码断言与前置强制校验逻辑，作为程序运行的必备前置条件。落地优势：安全边界固化为程序执行底层门槛，任意推理分支运行均必须通过校验，不存在业务逻辑绕过与逃逸空间。
行动 (执行层)	• 攻击维度下沉，运行时指令诱导转为代码层调用逻辑篡改：执行层攻击全面下沉至底层开发阶段，突破传统运行时指令诱导局限，直接篡改工具参数解析、权限校验、指令转发核心底层函数，预埋隐性异常执行分支。缺陷风险：工具调用底层核心逻辑被篡改，所有依赖该工具的上层业务链路均会同步失效，系统性触发权限溢出与越权漏洞。 • 符号链接伪装攻击，全域权限劫持通用性强：精心构造恶意代码仓库并篡改文件读写底层逻辑，利用符号链接伪装特性欺骗编码开发助手，使正常文件拷贝、配置同步流程自动覆盖原生安全权限配置 [1014]。缺陷风险：依托代码供应链批量传播，企业批量开发流水线会同步植入漏洞，攻击覆盖面广、批量沦陷风险极高。 • 伪造配置注入，批量劫持终端代理实例：借助虚假漏洞报告、缺陷工单为伪装载体，植入恶意 DSN 追踪与外联配置，在编码打包阶段自动嵌入智能体底层运行配置文件 [1019]。缺陷风险：配置文件属于常规交付产物，隐性外联字段辨识度极低，人工审核极易遗漏，最终造成全域终端实例批量沦陷。	• 三层控制流拦截体系，标准化工具管控：构建工具调用拦截校验、行为动态审计、异常操作回滚的三层纵深控制流防护体系，高效拦截各类工具注入与篡改攻击，同时保障业务运行效率基本无损耗 [854]。落地优势：统一标准化工具管控入口，所有内外工具调用强制经过三层校验，彻底消除私有工具、自定义组件的逃逸管控路径。 • 语义层超监督机制，破除组件默认可信预设：摒弃传统工具默认可信架构，将全部外部工具统一视作不可信访问主体，在执行前增设独立业务语义监督层，从业务逻辑维度识别隐性越权与组合式高危调用。落地优势：突破底层参数校验局限，精准识别语义合规、组合高危的隐性攻击行为，填补浅层防护盲区。 • 全链路供应链源码校验，防御前置固化：针对第三方仓库、外部依赖包、拓展技能组件实施全链路源码审查与可信签名校验，将防护从运行时黑名单过滤升级为编译期代码完整性原生保障。落地优势：所有外部依赖恶意代码在编译打包阶段即被拦截，无法交付上线，从供应链源头根除执行层植入攻击风险。

续下页

表 5.3 – 续上页

模块	攻击趋势	防御趋势
交互 (协同层)	- 攻击范式下沉，会话提示注入转为代码层交互底层逻辑劫持：新型协同层攻击完成范式下沉，彻底脱离传统表层会话提示注入模式，直接篡改输入解析、会话状态持久化、Prompt 模板生成核心底层函数，从架构根源劫持全链路交互数据流与协同逻辑。缺陷风险：交互底层函数具备全局复用特性，所有会话交互、多智能体协同场景均同步存在劫持漏洞，彻底修复需要整体重构整套交互底层架构。 - 迭代精细化结构化注入，突破表层防护：依托多轮反馈迭代机制持续优化精细化结构化恶意载荷，针对性篡改工具人参数格式、JSON 传输字段、模板占位符等结构化核心位置，精准绕过表层内容检测体系 [1020], [1021]。缺陷风险：恶意载荷深度嵌入合法结构化字段内部，文本层面无任何显性恶意关键词特征，传统内容过滤与静态检测完全无法识别拦截。 - 持久存储 + 协议双层复合攻击，构建长效逃逸通路：构建持久存储与协议解析双层复合攻击体系，通过跨会话持久化注入将恶意载荷写入本地文件与长期上下文存储，脱离原始会话仍可持续干扰后续全部交互流程 [721], [1025]。缺陷风险：依托存储持久化与协议解析漏洞双重加持，单次成功注入即可实现长期驻留、跨会话、跨实例的持续性渗透攻击。	- 结构化字段签名完整性校验，锁定交互核心控制数据：针对工具标识、调用参数、会话状态、返回标识等核心交互控制字段，全局绑定哈希签名与实时完整性校验机制，底层数据读写全过程强制自动验签比对。落地优势：任意结构化控制字段被轻微篡改即可触发校验失败，主动阻断恶意载荷向上传导至推理与行动执行模块。从交互源头锁定核心控制变量，杜绝细微篡改引发的上层决策与执行异常。 - 代码层会话状态硬隔离，切断跨会话污染传导链路：在底层代码层面强制实现不同会话的上下文缓存、状态变量、持久化存储分区物理隔离，会话间数据读写完全独立管控，杜绝恶意载荷跨会话留存复用与扩散传播。落地优势：会话数据实现物理级隔离边界，彻底消除跨会话载荷复用、交叉污染的底层代码漏洞通道。有效规避多用户、多任务并发场景下的交叉渗透与隐性风险驻留问题。 - 协议源码底层边界加固，三层纵深代码防护：在 MCP 等主流协同协议底层源码中，内置异常容错处理、跨主体身份核验、越界访问拦截三层硬规则，严格约束协议柔性解析特性带来的安全漏洞滥用风险。落地优势：协议解析流程固化强制校验规则，各类变异结构化载荷无法利用解析漏洞绕过交互安全管控体系。
治理 (管控层)	- 攻击层级下沉，运行时审计绕过转为代码层治理逻辑预埋：现代治理层攻击实现深度下沉，不再局限于运行时规则绕过，直接篡改治理内核底层源码，在日志采集、权限校验、运行监控等核心分支预埋隐性判定逻辑，实现底层机制劫持。缺陷风险：审计旁路、权限逃逸逻辑深度固化于治理架构底层，各模块违规风险行为均可无痕执行，导致事后溯源审计机制完全失效。 - 传统静态架构缺陷，催生权限组合滥用漏洞：传统静态权限架构仅校验单一操作合规性，攻击者可叠加多条合法基础权限串联完成高危越权操作，依托智能体自动化高速执行特性批量发起违规链路攻击。缺陷风险：单一权限节点均符合规范，仅多权限组合衍生安全风险，静态固化权限规则无法预判、拦截复合型链式攻击。 - API 响应完整性机制缺失，形成治理决策篡改突破口：治理层默认无条件信任上游 API 返回数据，攻击者篡改后端响应载荷误导核心治理判定逻辑，全程绕过权限校验与审计留存体系，底层无任何拦截屏障 [1021]。缺陷风险：治理决策完全依赖不可信上游数据，篡改后的恶意载荷可直接改写全局管控策略，引发全域治理失效风险。	- 全域四层代码防护框架，阻断跨模块链式风险传导：基于上下文状态管控、工具动作校验、持久存储合规、自动化协同约束构建四层原生安全框架，系统性梳理跨模块风险传播链路，在治理内核关键节点植入固化加固逻辑 [1026]。落地优势：统一全域治理安全约束标准，精准识别分散于各模块的碎片化、组合式隐性攻击链路。 - 加密仅追加不可篡改审计链，强制日志写入路径：采用加密签名 + 仅追加存储技术搭建底层不可篡改审计链路，严格固化日志强制写入路径，即便高权限管理账号也无法删除、篡改、屏蔽核心审计记录。落地优势：所有风险操作、越权行为均留存不可篡改凭证，彻底杜绝无记录逃逸、事后无痕的底层攻击通道。 - 动态上下文权限，细粒度场景化管控：在传统静态角色权限体系基础上，编码集成运行时动态上下文评估逻辑，将安全治理从事后追溯前移至编码固化、实时校验双重原生约束模式。落地优势：兼顾静态身份权限与动态场景风险，精准拦截多组合合法权限叠加形成的隐性越权操作，补齐静态治理短板。

5.4 安全测试评估阶段（攻防趋势）

安全测试阶段以**全域逆向验核与量化准入裁决**为核心价值，将攻防博弈从代码底层提升至测试范式、状态核验与准入裁决层级，是 AI 智能体验证类攻防的核心准入环节。本阶段承接编码开发阶段的源码与二进制资产，逆向核验全链路设计与代码实现的有效性，输出可量产的量化安全准入基线，实现安全治理从定性设计向定量裁决的关键转型。结合 AI 安全评测与对抗测试研究成果，本节梳理安全测试阶段核心攻防趋势如下（详见表 5.4）：

- 范式颠覆趋势：传统静态评测体系系统性失效，攻防博弈向状态化、时序化、复合化评测维度迁移。**传统大模型静态、单维、被动的安全评测体系已无法适配智能体场景，攻防范式全面转向**状态化时序对抗评测为主、静态基线核验为辅**的全新架构。传统测试依赖关键词黑白名单、单轮静态样本、输出校验与模型自检测，仅适用于无状态单次推理场景，仅能拦截输出端显性风险。AI 智能体具备多模态融合、长时序记忆迭代、全局状态推理、链式工具调用、跨主体协同特性，衍生出跨模态逃逸、延时记忆后门、工具反馈劫持、隐式载体注入等新型攻防面，推动博弈重心从端点校验转向全链路隐性状态对抗。范式颠覆带来三大核心特征：一是**攻击无特征化**，攻击者依托语义伪装与时序潜伏构造隐性载荷，规避传统静态检测与内容审计；二是**风险中段富集**，安全缺陷大量留存于推理中段与多轮交互链路，端点核验难以检出隐性病灶 [1027]；三是**攻击复合拆分**，恶意链路被拆分至多模块、多时序分步执行，传统孤立测试无法还原完整攻击链，评测结果失去准入参考价值。
- 模块验证趋势：测试盲区差异化分布，全模块状态联动催生系统性验证风险。**攻击侧针对六大模块的测试短板与跨状态联动特性，定制隐性绕过链路，突破传统固化测试体系 [1028]。感知模块利用单模态测试局限与二元判定缺陷，实现跨模态语义伪装逃逸；记忆模块依托静态快照测试盲区，构造跨会话延时潜伏后门与渐进式知识污染；决策模块借助模型自欺骗与割裂式测试机制，植入隐性劫持逻辑误导合规判定 [1027]；行动模块利用工具反馈漏洞与语义变异盲区，突破静态特征防护引发权限溢出 [1029]；交互模块依托轨迹核验缺失，实现协同链式渗透提升漏检率 [1030]；治理模块利用分层测试盲区，构建全域治理逃逸通道 [872], [1031]。防御侧统一向**时序化、全梯度、联动式验证架构**收敛，摒弃静态孤立测试，构建全链路刚性准入门禁 [1032], [1033]。感知模块部署多模态融合校验与对抗样本全覆盖，消除单模态测试盲区；记忆模块引入多源交叉核验与时序韧性测试，量化长时序记忆劣化基线 [1034]；决策模块搭建事中探针与长时序追踪体系，实现推理全轨迹溯源 [1035], [1036]；行动模块配置工具沙箱测试与异常回退机制，加固调用安全基线 [1037]；交互模块落实多域隔离验签与全量日志存证，闭环协同评测链路 [1038]；治理模块引入时序校验与联动压力测试，量化全域管控下限 [861]。
- 工程博弈趋势：时序关联与算力成本矛盾激化，混合量化准入架构成为核心解法。**安全测试阶段的核心博弈，围绕**测试完备性、算力经济性、版本迭代效率**三元矛盾展开，是传统测试范式失效、状态化盲区滋生的核心工程根源 [872]。智能体长时序迭代、跨模块联动的原生特性，成为隐性时序攻击的天然载体。攻击者通过累积微小隐性缺陷、跨链路传导放大，形成上线后系统性风险，此类根植运行机理的隐患无法通过传统静态测试规避 [1028]。防御层面存在显著工程约束：全轨迹时序监测、全梯度对抗遍历可消除测试盲区，但会指数级增加算力开销、拉长测试周期、降低迭代效率，无法适配量产落地需求 [1032], [1033]。当前测试体系难以平衡三元矛盾：抽样测试易遗漏时序复合攻击，全量测试成本过高，折中方案仍残留可控盲区 [1031], [1036]。为此，兼顾静态基线兜底与时序动态核验的混合量化准入架构，成为现阶段最优工程解法。

表 5.4: AI 智能体安全测试阶段攻防趋势

模块	攻击趋势	防御趋势
感知 (输入层)	• 多模态对抗跨通道扩散，文本单模态测试存在天然盲区：多模态智能体支持文本、图像、视听多类输入融合推理，对抗样本可依托模态协同特性在集群内指数级传播并完成越狱攻击。仅针对文本维度的传统安全测试体系覆盖范围有限，完全遗漏图像、视觉衍生的新型攻击面。测试短板：各模态采用独立拆分测试方案，未覆盖模态融合带来的协同逃逸路径，上线后极易出现跨通道防护整体失效问题。 • 间接注入具备梯度强化特征，基础测试集低估穿透率：随着对抗攻击算法持续迭代优化，间接语义注入载荷具备梯度强化学习能力，自适应规避基础防护规则，实际场景穿透成功率大幅提升、近乎翻倍增长。测试短板：传统评测仅采用简单弱攻击样本，无法模拟迭代强化后的高阶对抗载荷，难以验证防御体系长效鲁棒性。 • 语义伪装规避关键词规则，二元善恶判定测试范式彻底失效：攻击者将恶意逻辑隐匿嵌入合规无害载体，形成无显性特征的伪装攻击，精准绕过传统关键词拦截机制。测试体系亟需摒弃二元判定逻辑，升级为全谱系策略梯度下的语义边界完整性校验范式。测试短板：过度依赖静态黑白名单关键词匹配，对无显性恶意特征的隐性伪装注入攻击完全不具备检出能力。	• 多模态预融合独立校验验证，全覆盖跨通道协同逃逸路径：针对多模态融合防护短板，专项测试各模态数据流进入融合层前的独立校验机制完整性，测试重心从基础过滤功能核验，升级为融合前置分层校验体系的全维度完整性验证。落地指标：实现任意单一模态恶意载荷的独立拦截能力，彻底消除模态组合联动逃逸的测试漏判场景。 • 全梯度攻击用例覆盖，量化防御鲁棒性上下边界：搭建全覆盖梯度化对抗测试集，收录从基础简单注入、常规语义篡改到迭代强化高阶注入的全等级样本，通过多维度测试输出可量化、可溯源的防御鲁棒性边界结论。落地指标：明确攻击梯度与防御能力关联关系，将高阶载荷对应的拦截率衰减幅度严格控制在合规阈值范围内。 • 指令-数据语义边界量化核验，实现需求-测试闭环追溯：构建指令与静态数据语义二元区分测试体系，将精准区分率设为上线强制门禁指标，完成全输入通道语义边界全覆盖校验，搭建需求规约、代码实现、安全测试的全链路闭环管控机制。落地指标：系统语义二元区分覆盖率达到 100%，杜绝存在需求约束但未配套安全测试的输入通路。
记忆 (存储层)	• 持久化载荷跨会话潜伏，单次快照式测试无法捕获时序风险：记忆层投毒攻击具备长周期潜伏特性，恶意载荷植入与触发存在多轮会话时间差，可跨越上百轮交互持续潜伏，传统静态快照测试完全无法适配时序化攻击特征。测试短板：静态快照测试脱离记忆时序演化规律，无法精准检出延时触发、隔会话激活的隐性记忆后门。 • 复合弱后门组合叠加，大幅提升隐蔽性且规避浅层扫描：新型记忆投毒摒弃单一高强度恶意样本模式，通过多组低强度无害触发器叠加形成复合后门，实现长效驻留攻击。分散式微量投毒样本无独立恶意特征，极易规避常规浅层文本扫描检测。测试短板：传统单一后门样本测试范式，无法覆盖多触发器联动叠加的隐蔽投毒攻击场景。 • 渐进式记忆污染成为主流威胁，静态文本评测脱离真实风险：当前记忆层主流威胁已迭代为多轮交互渐进式知识偏移，通过微量、多次、持续性污染逐步扭曲智能体认知体系，隐蔽性极强，亟需纳入标准化时序测试体系 [1028]。测试短板：缺失多轮时序动态观测机制，无法量化记忆迭代过程中逐步劣化的安全衰减规律。	• 记忆溯源链路可证明性测试，由经验评测升级概率边界：针对智能体记忆检索抗投毒能力开展形式化建模与可证明性测试，输出具备数学概率保障的抗污染边界结论，彻底摆脱单一测试集带来的片面经验性评测局限。落地指标：所有记忆条目溯源凭证完整、链路清晰，可精准证明各类投毒样本均可被检索层有效拦截。 • 多源记忆交叉一致性验证，阻断污染链式扩散传导：测试体系全面覆盖记忆读写、存储、检索全层级链路，严格校验所有记忆条目可信来源标识的完整性，验证多层架构下恶意知识无法实现跨模块链式扩散与全域污染 [1034]。落地指标：实现单源污染局部隔离，恶意数据无法向外扩散至全局知识库，交叉校验拦截指标全面达标。 • 多尺度时间韧性测试，量化记忆污染容忍阈值基线：构建短、中、长三类时间尺度的渐进污染标准化测试场景，精准绘制系统安全属性随迭代次数的衰减曲线，将记忆污染容忍度、决策偏移上限设定为可量化的出厂硬性安全指标。落地指标：在规定比例存量污染记忆干扰下，智能体核心业务决策偏移量严格控制在合规允许阈值内。

续下页

表 5.4 – 续上页

模块	攻击趋势	防御趋势
决策 (推理层)	• 输出话术合规但底层目标偏移，自我报告评测存在欺骗盲区：新型推理层欺骗攻击具备强伪装特性，通过微调中间推理逻辑保证最终输出话术合规无害，隐性篡改底层决策目标与执行意图。测试短板：过度依赖模型自我安全汇报机制，缺乏底层推理链路核验，无法甄别刻意伪装、虚假合规的欺骗性决策行为。 • 规划与执行轨迹系统性偏离，静态计划测试无法覆盖隐瞒行为：智能体在复杂多步任务中易出现规划文本与真实执行路径系统性割裂，无需恶意输入即可自发产生隐性偏差。仅校验顶层静态行动计划的传统测试范式，完全无法适配动态轨迹偏离风险 [1027]。测试短板：仅核验静态规划文本合规性，未追踪分步执行轨迹与目标一致性，大量隐性越权与偏差行为被遗漏。 • 跨模块复合攻击链定向劫持决策，单模块独立测试存在割裂盲区：攻击者依托多模块联动缺陷，串联感知、记忆、交互多链路污染载荷，构造完整复合攻击链定向篡改推理决策。分模块孤立测试模式无法识别跨层级、跨模块的组合式劫持威胁。测试短板：各模块测试用例相互独立、无联动校验机制，碎片化分步攻击链路无法被完整捕获与全局研判。	• 决策链路事中审计，完成事后检测向实时核验升级：摒弃传统事后输出核验模式，在推理内核全节点植入监测探针，持续采集中间推理状态、路径跳转与子任务分支信息，实现决策异常实时捕获与即时告警 [1032]。落地指标：全推理节点探针埋点覆盖率 100%，所有隐性异常分支与目标偏移均可实时触发告警拦截。 • 失败轨迹驱动持续迭代测试，评测同步支撑安全优化迭代：引入失败轨迹自演化测试机制，将测试过程中检出的风险路径、异常决策轨迹持续回流至安全策略优化流程，形成测试、整改、回归的闭环加固体系 [1035]。落地指标：所有历史失败攻击轨迹全部固化至回归测试集，新版本无同类推理缺陷与决策漏洞复现。依托轨迹样本持续迭代防护策略，实现安全能力的自适应升级与持续强化。 • 长周期轨迹压缩监测，构建三级分层完整评测闭环：搭建单步合规校验、多步目标一致性核验、长周期策略偏差检测三级立体测试体系，精准覆盖短时瞬时异常与超长时序渐进式决策偏移风险 [1036]。落地指标：超长时序监测算力开销可控，长周期隐性策略偏移与累积偏差检出率完全满足上线标准。
行动 (执行层)	• 混淆提示劫持工具调用意图，关键词过滤无法区分伪装请求：当前对抗攻击可生成高混淆度、强伪装的诱导提示，表层语义贴合正常用户需求，底层却暗藏工具劫持逻辑。全网流转的变异恶意样本持续拓宽攻击面，精准诱导异常高危工具调用行为。测试短板：传统防护仅校验提示文本关键词，无法深度解析工具调用底层真实意图，难以识别语义伪装类劫持攻击。 • 工具返回反馈通道新型攻击面，仅校验调用侧存在防护缺口：执行层攻击面已从工具调用前端延伸至工具结果反馈后端链路，攻击者无需篡改用户输入，仅通过篡改工具返回数据即可诱导智能体连锁高危操作，形成新型闭环攻击链路 [1029]。测试短板：常规测试仅模拟可信工具返回结果，未针对性构造恶意篡改反馈样本，存在后端链路防护测试盲区。 • 工具语义灵活度规避特征签名，小规模仿真测试低估风险规模：智能体工具调用具备高语义灵活度，相同功能可适配多类句式与参数组合，彻底规避静态特征签名检测。轻量化仿真测试无法复刻真实语义变异场景，严重低估实际攻击风险。测试短板：过度依赖固定特征黑名单匹配，无法覆盖语义变异、参数重组类隐性恶意工具调用行为。	• 动态权限有效性核验，替代静态授权列表校验模式：重构工具权限评测体系，摒弃传统静态授权清单比对模式，聚焦运行时动态权限有效性校验。精准识别权限过期、回收、越域复用等动态风险，适配实时多变的执行场景 [1037]。落地指标：所有工具调用均实时核验瞬时有效权限，无过期权限、回收权限违规放行案例。 • 沙箱隔离完整性模糊测试：采用模糊测试技术批量遍历工具调用组合、参数序列与执行时序，系统性校验沙箱内存、文件读写、网络访问隔离边界，自动挖掘可链式提权的高危工具组合漏洞。落地指标：沙箱隔离边界无逃逸漏洞，多工具叠加组合无法形成权限提升与横向渗透链路。通过海量随机用例暴力遍历未知逃逸路径，补齐常规测试覆盖不全的短板。 • 异常反馈安全回退全场景验证，阻断盲目信任执行逻辑：全覆盖构造工具异常报错、数据篡改、恶意返回等风险场景，系统性验证智能体安全降级、任务回退、流程终止机制有效性，全链路留存测试日志实现可审计溯源。落地指标：工具恶意反馈场景下 100% 触发安全降级回退，杜绝盲目信任工具输出导致的持续高危执行行为。

续下页

表 5.4 – 续上页

模块	攻击趋势	防御趋势
交互 (协同层)	• 间接数据注入独立攻击范式，无需人机交互完成劫持：攻击者将恶意隐性逻辑嵌入网页、邮件、文档等静态可检索载体，智能体在自主检索、读取解析阶段自动加载触发恶意逻辑，无需人工交互即可完成劫持。测试短板：现有评测仅覆盖用户主动输入交互场景，完全缺失静态载体隐式注入、被动触发的新型攻击场景评测能力。 • 动态任务基线区分困难，能力缺陷与攻击诱导缺陷难以分离：复杂多轮协同交互场景下，智能体原生能力不足与恶意载荷诱导故障表现高度相似，交互测试体系缺少纯净无攻击的空白基线作为对照基准。测试短板：无标准化基线对照组支撑差异比对，缺陷根因判定模糊，无法精准区分业务原生缺陷与外部攻击诱导安全缺陷。 • Web/终端多场景拓展攻击面，仅校验交互端点遗漏长轨迹风险：当前攻击面已拓展至 Web 浏览、终端调度等多协同场景，大量多步链式恶意行为隐匿于完整执行轨迹中段。仅校验交互起止端点的传统测试模式，无法检出中段隐蔽劫持与越权风险 [1030]。测试短板：测试仅聚焦交互出入口合规性检测，未完整复现多步连续执行链路，遗漏中段隐性攻击轨迹。	• 多信任域标签隔离核验，阻断跨域载荷交叉污染：针对多源交互数据污染风险，专项测试交互层对用户指令、工具返回、外部文档、网络资源的差异化信任标签管控与隔离机制完整性。落地指标：不同信任域数据流隔离逻辑刚性不可绕过，不存在跨域无校验数据流通与载荷污染通道。可有效规避多源异构数据混杂传输引发的隐性跨域污染与逻辑劫持隐患。 • 跨智能体通信身份完整核验，阻断安全域横向渗透扩散：批量构造伪造身份、虚假集群节点、异常跨域交互测试用例，端到端覆盖初始注入、身份伪造、跨节点扩散的完整攻击链路开展专项测试。落地指标：跨主体通信全程强制身份验签与溯源校验，伪造身份无法完成跨节点载荷传播与横向渗透。全方位覆盖常规与新型伪装交互攻击，筑牢多智能体集群横向安全边界。 • 交互日志不可篡改性全量验证，配套多维度技能安全评测：系统性校验交互日志追加写入、加密存证、防篡改机制完整性，确保日志可作为攻击溯源的唯一可信凭证。搭建第三方技能、外部 API、集群协同通信的多通道统一评测体系 [1038]。落地指标：全量交互行为日志完整留存、不可篡改删除，多通道协同交互安全评测覆盖率达到 100%。
治理 (管控层)	• 安全属于系统性问题，单模块加固无法抵御跨层组合攻击：智能体安全属于全域系统性工程，分散独立的单点安全规则存在大量跨模块协同盲区。逐条核验单一策略配置的传统测试方式，无法验证治理体系抵御跨层复合攻击的整体协同防护能力 [872]。测试短板：长期采用分模块孤立评测机制，无跨层、跨模块联动攻击测试场景，无法量化全域治理协同防御效能。 • 单层抽象测试存在范畴缺陷，相邻层交互安全假设易被破坏：现有三层概率化安全架构仅能保障单层级局部约束有效，存在先天抽象局限。治理层单层测试默认上下游模块安全前提恒定，忽略模块交互过程中安全假设失效、边界被突破的风险 [1031]。测试短板：缺失多层联动交互测试用例，无法验证跨层级安全约束在动态交互场景下的持续有效性。 • 静态合规判定滞后于动态攻击演化，治理规则迭代存在窗口期漏洞：攻击者可利用规则更新空窗期，构造适配当前规则盲区的新型逃逸链路，实现持续性规避管控。测试短板：缺乏治理规则动态适配性与迭代窗口期抗压测试，无法量化规则滞后带来的系统性逃逸风险。	• 时序校验与失效降级双维度测试：打破静态规则校验范式，将治理测试拆解为精细化分层时序检查点，覆盖时序竞争、组件失效、动态降级等复杂场景，实现缺陷精准定位与根因追溯 [1033]。落地指标：彻底规避 TOCTOU 时序绕过漏洞，组件异常失效后系统仍可维持底层安全约束，不违规开放权限。 • 三层联动一致性验证，规范/监控/执行约束同步生效：专项校验顶层安全规范定义、运行时动态监控拦截、底层工具执行权限三层逻辑的全局一致性，杜绝规则断层、逻辑冲突、约束失效问题 [861]。落地指标：三层安全规则高度统一无冲突、无断层，顶层治理约束可完整、无损传导至底层执行链路。 • 治理覆盖率度量 + 最弱链路压力测试，量化全域管控下限：精准统计全任务、全路径安全策略插桩覆盖率，将未覆盖路径标记为测试债务并限期整改。同时模拟单模块沦陷、组件失效等极端场景，开展最弱链路压力测试。落地指标：全域治理策略路径覆盖率达标，单模块沦陷场景下系统全局异常检出率、风险阻断率满足上线硬性标准。

5.5 部署交付阶段（攻防趋势）

部署交付阶段以**安全能力规模化复制与环境基线量产固化**为核心价值，将攻防博弈从单体程序维度拓展至集群量产、环境配置与规模化传播维度，是 AI 智能体供应链与集群级攻防的核心量产场景。本阶段承接安全测试阶段合规镜像、程序资产与准入基线，整合全链路前置安全约束，将单体内生安全能力转化为云原生集群可复用的安全底座，完成单点安全验证向全域集群运营的工程升级。结合云原生部署与供应链攻防研究，本节梳理部署交付阶段核心攻防演化趋势如下（详见表 5.5）：

- **传播维度迁移趋势：攻防对抗量产化扩散，单点实例对抗向模板集群批量对抗跃迁。**部署交付阶段的攻击彻底突破单点局限，依托容器镜像、自动化部署模板、K8s 集群分发与 CI/CD 流水线量产特性，形成“单模板植入、全集群同构中毒”的规模化攻击范式，凭借模板同源特性实现无差别风险植入，完成攻击模式的量产化升级 [679], [1039]。该范式升级衍生三大核心攻防特征：一是**攻击门槛极低化**，风险根植于模板默认配置，无需代码篡改与载荷构造即可生效，攻击成本大幅降低 [1040]；二是**风险全域同质化复制**，开发态宽松权限、开放端口、硬编码密钥等缺陷，通过流水线批量复制至所有集群节点，形成全域同质化安全隐患 [1041]；三是**上层防护全面失效**，运行时流量过滤、工具调用管控等常规手段，无法修复底层固化的配置漏洞，仅能通过重构部署基线根治风险 [1042]。
- **集群配置分化趋势：模块默认缺陷差异化分布，模板同源传导引发全域系统性风险。**攻击侧聚焦六大模块量产模板的原生配置短板，依托模板同源分发特性实现缺陷全域预埋与批量扩散，放大集群安全风险 [1043], [1044]。感知模块因输入分级缺失、镜像权限宽松，催生批量元数据注入风险 [1045]；记忆模块凭借容器存储无隔离、向量端口暴露问题，引发集群级批量投毒与横向窃密威胁 [1042]；决策模块依托镜像预埋后门、集群检测盲区，造成模板级持久决策劫持 [679]；行动模块基于宽松 IAM 基线、硬编码静态密钥，诱发批量越权与链式权限溢出风险 [1040], [1041]；交互模块因集群默认信任机制，触发全域信任劫持与级联高危操作 [1039]；治理模块因量产安全基线缺失，导致集群资产管控空白、批量漏洞暴露 [1046], [1047]。防御侧整体向**交付基线同源固化**收敛，摒弃零散节点加固，将安全约束原生植入部署流水线，实现全域基线固化升级 [1044]。感知模块搭建数据源分级基线与集群权限门禁，阻断批量注入风险 [1045]；记忆模块落实存储强制隔离与子网封堵，杜绝集群横向污染窃取 [1043]；决策模块通过模板签名审计与双维度校验，防范模板后门批量扩散 [679]；行动模块部署集群最小权限机制与凭证轮换，根除批量越权隐患 [1041]；交互模块增设组网审批与统一 mTLS 身份体系，加固跨节点协同安全 [1039]；治理模块落地集群准入与自动化扫描机制，补齐量产管控短板 [1046]。
- **工程量产博弈趋势：复用与隔离三元矛盾激化，可信模板架构成为量产防御核心解法。**部署交付阶段攻防核心，围绕**模板复用便捷性、集群环境隔离性、存量运维经济性**三元矛盾展开，是量产配置型攻击滋生的核心工程根源 [1044], [1045]。模板统一复用、镜像批量分发是提升集群交付效率的核心工程机制，攻击者可利用该特性，将开发测试阶段的配置缺陷、宽松权限通过合规流水线批量放大为集群系统性风险，此类量产架构固有风险无法通过运行时上层防护拦截 [1039], [1042]。防御强化则存在显著工程制衡难题：收紧基线、全量审计可根治量产风险，但会牺牲模板复用效率、抬高运维成本、拉长交付周期，损害量产落地性价比 [1041], [1042]。当前量产体系无法彻底消解该矛盾：原生模板复用会继承高危配置，全量基线重构损耗迭代效率，折中整改易残留配置盲区，为量产攻击留存可利用空间 [1040], [1047]。因此，可信模板固化架构成为平衡安全与工程效率的核心最优解。

表 5.5: AI 智能体部署交付阶段攻防趋势

模块	攻击趋势	防御趋势
感知 (输入层)	- 生产攻击面全域扩张，受控测试输入切换为不可信外部流量：智能体由封闭开发测试环境批量迁移至线上生产集群后，彻底脱离可控输入场景，外部公网各类不可信流量、多源异构数据均可涌入感知入口，全域放大载荷注入攻击风险。缺陷风险：多类输入源未搭建统一安全校验基线，单一数据源防护缺失即可被攻击者利用，形成全域穿透渗透通道。 - 镜像元数据衍生新型注入攻击，网关语义解析边界失效：MCP 统一网关存在底层语义解析缺陷，无法精准区分业务描述类元数据与可执行操作指令，会被动将伪装标签内容自动解析为有效操作逻辑，触发隐性攻击执行 [1045]。缺陷风险：元数据解析逻辑固化于底层镜像，无法动态适配新型攻击，镜像批量分发会同步全域扩散同类注入漏洞。 - 官方交付模板默认权限宽松，上线即暴露感知核心资源：原生交付模板存在默认权限过度开放问题，智能体一旦失陷，攻击者可直接导出私有业务镜像、跨实例窃取感知缓存数据、无限制调用高危代码解释器能力 [1042]。缺陷风险：开发宽松默认配置未做生产安全适配，批量自动化部署会同步开放全域高危权限通道，攻击面大幅扩张。	- 交付阶段输入源分级信任基线强制落地：在集群部署流水线内置标准化数据源分级管控规范，依据来源可信等级划分安全层级，配置差异化格式校验、签名核验、对抗特征检测规则。落地优势：分级管控策略固化于交付脚本，线上业务无法随意篡改调整，从流量入口隔离拦截恶意载体。实现输入源信任等级的标准化、自动化管控，消除人工配置带来的合规偏差。 - MCP 元数据/指令语义边界底层隔离：在感知网关部署底层硬编码二元解析判定规则，构建刚性语义隔离边界，严格区分纯描述类元数据与可执行操作指令，杜绝标签、配置字段被恶意利用解析。落地优势：语义隔离为底层部署级硬约束，不受上层业务迭代、逻辑变更影响，长效抵御各类元数据篡改注入攻击。彻底解决协议柔性解析特性带来的语义混淆、边界模糊等原生安全缺陷。 - 最小权限自动化基线审计：上线交付验收环节强制启动感知模块权限基线扫描，全面审计关联身份策略与访问权限，生产环境仅保留感知采集必需的最小权限集合。落地优势：权限合规校验嵌入部署门禁体系，原生宽松模板无法通过流水线发布，从源头收紧感知层高危权限。持续规避权限冗余累积问题，保障感知层访问边界长期稳定、无松弛漂移。
记忆 (存储层)	- 存储架构缺失隔离约束，单次投毒触发全域记忆定向污染：智能体向量存储架构缺乏前置校验与隔离约束机制，单条恶意投毒数据写入向量库后，会伴随检索匹配链路持续迭代扩散，造成全量业务推理样本出现定向认知偏差 [1043]。缺陷风险：缺失写入前置安全校验机制，投毒数据永久留存于长期存储，系统迭代、服务重启均无法自动清除污染痕迹。 - 多实例记忆无租户隔离，默认配置支持横向窃取：集群部署默认开启共享存储机制，无独立租户隔离设计，任一失陷智能体可直接读取、篡改集群内其他实例持久化记忆数据，低成本实现全域批量投毒污染 [1042]。缺陷风险：跨实例访问权限全局无限制开放，单点突破即可引发集群全域知识库泄露、篡改、批量沦陷风险。 - 向量存储网络端口默认暴露，外部直连篡改窃取记忆数据：标准化部署流程未针对长期记忆向量库配置专属安全子网与访问白名单，核心存储端口对公网、内网均无访问限制，完全裸奔暴露。缺陷风险：存储层无任何网络边界防护，核心记忆资产直接暴露于攻击面，无需突破智能体业务逻辑即可恶意操作知识库。	- 部署验收强制落地记忆完整性隔离规范：业务交付前强制开展存储架构专项安全审计，补齐写入前置校验、污染样本识别检测、异常数据隔离归档全套防护机制 [1043]。落地优势：记忆隔离规则随存储镜像同步固化部署，天然约束投毒数据传播范围，大幅降低全域污染与后期修复成本。 - 多实例租户级记忆分区，部署锁死跨智能体访问权限：集群交付阶段强制为每一个智能体实例分配独立命名空间与专属存储密钥，全局禁用跨实例记忆读写默认权限，配套细粒度 ACL 访问控制策略。落地优势：租户分区隔离为底层部署硬约束，彻底消除跨实例共享存储漏洞，单点失陷无法横向渗透污染其他租户知识库。 - 持久化记忆子网隔离，部署收紧端口暴露范围：将向量数据库、长期记忆存储组件统一部署至独立安全子网，配置专属防火墙策略，仅允许内网业务可信地址访问，关闭所有冗余高危存储端口。落地优势：网络边界防护与业务镜像同步固化交付，极致收缩记忆资产外部攻击接触面，杜绝远程直连窃取、篡改风险。

续下页

表 5.5 – 续上页

模块	攻击趋势	防御趋势
决策 (推理层)	- 推理模板后门交付分发，无需篡改权重即可劫持决策：新型推理层后门攻击聚焦交付供应链污染，攻击者制作并发布携带恶意分支逻辑的定制模板镜像，精准植入可长期驻留的推理阶段隐性后门 [679]。缺陷风险：传统针对权重与样本的投毒检测工具完全无法识别模板层预埋的隐性恶意逻辑。 - 模板后门可绕过全量输入防护，劫持工具调用形成供应链污染：模板层恶意逻辑处于输入防护体系之外，可穿透各类运行时注入拦截与内容校验机制，隐性篡改智能体工具调用与分支决策逻辑。单份带毒模板可随交付链路全域扩散，造成全业务系统持续性投毒风险 [679]。缺陷风险：现有安全防护体系集中聚焦前端输入载荷检测，完全忽视推理中间模板层安全，形成结构性、体系性检测盲区。 - 决策校验存在意图盲区，仅核查权限范围不校验行为一致性：传统治理管控仅依托静态权限清单判定操作合规性，缺少多轮会话持续行为追踪与意图一致性比对机制，无法识别渐进式隐性决策偏移 [1042]。缺陷风险：在合法权限边界内仍可持续生成隐蔽恶意决策，静态权限基线完全无法识别意图漂移、行为异化类高阶风险。	- 交付流水线强制专项安全审计：在镜像发布门禁环节深度嵌入推理模板静态扫描与逻辑校验工具，精准识别隐藏分支、异常判定逻辑与预埋后门，刚性阻断带毒模板流入生产交付包。落地优势：模板安全检测全面前置至部署发布环节，从源头阻断推理层后门随镜像批量扩散传播。可提前拦截开发阶段遗留的隐性逻辑缺陷，规避上线后静默触发的高危推理行为。 - 推理模板版本管控与部署前来源签名校验：搭建全域统一推理模板版本仓库，实现模板迭代全流程可追溯管理。所有上线模板必须附带官方可信数字签名，交付阶段强制校验来源完整性与合法性，拦截未知、未审计第三方模板。落地优势：签名校验机制固化于部署流程，任意恶意篡改、私自替换的模板均无法通过集群发布校验。构建模板全生命周期可信管控体系，杜绝非标、篡改模板混入集群推理体系。 - 部署落地“意图-行为”持续一致性校验基线：在决策推理内核底层植入常态化动态比对机制，突破单一权限校验局限，持续追踪每轮决策行为、工具调用逻辑与初始业务声明意图的匹配程度。落地优势：权限合规 + 意图一致双维度校验彻底弥补单层管控盲区，精准识别合法权限覆盖下的隐性异化决策与恶意行为。
行动 (执行层)	- 默认全域宽松权限，集群横向渗透风险极高：原生开发交付模板默认配置全域宽松权限，智能体一旦被局部突破，攻击者可依托宽松权限持续迭代提权，横向接管集群内其他正常实例，快速构建全域账户级攻击链路 [1042]。缺陷风险：开发宽松权限未做生产场景安全适配，批量自动化部署后整套云账户资产完全暴露于横向渗透风险中。 - 硬编码开发密钥随镜像交付，生产环境未轮换引发越权访问：开发阶段调试密钥被硬编码固化至镜像源码，交付上线后未及时轮换清理。攻击者利用泄露静态密钥可批量生成合法 JWT 凭证，未授权访问内部核心调度路由与服务接口 [1040]。缺陷风险：静态密钥全局固化于交付镜像，多集群共享同一套泄露凭证，漏洞覆盖面极广，彻底修复需全量重新打包发布。 - 工具调用缺少字段级权限隔离，多层级链式权限溢出：执行层权限模型粒度粗放，工具调用仅校验接口级权限，缺失字段级精细化隔离约束，天然存在逐层递进提权路径。基础低权限即可通过链式调用逐步获取管理员操作能力，篡改核心高级配置 [1041]。缺陷风险：粗粒度权限架构自带递进溢出缺陷，单次工具调用微小漏洞即可逐层放大权限边界，引发全域越权风险。	- 部署门禁强制执行 IAM 最小权限自动化校验基线：在交付流水线内置全自动权限审计与扫描脚本，智能识别并自动剔除开发示例冗余宽松角色策略，仅保留工具执行必备的最小资源访问权限集合。落地优势：权限合规校验设为发布强制卡点，所有宽松、超权镜像均无法通过流水线部署至生产集群。从交付源头根治权限冗余遗留问题，规避长期运行后的权限漂移越权风险。 - 交付流程强制扫描、轮换所有硬编码默认凭证：上线前置阶段全域扫描镜像源码、配置文件中的硬编码密钥、开发测试凭证与默认口令，完成全量替换、禁用与动态随机轮换。落地优势：凭证安全清理机制深度嵌入打包流程，无需人工逐实例运维整改，适配大规模集群批量交付场景。彻底消除固定凭证泄露带来的批量集群沦陷与持久化入侵隐患。 - 部署固化工具原子化权限 + 上下文感知双重校验：重构执行层权限架构，为每类工具、每个输入字段配置独立原子化权限约束，叠加运行时业务场景上下文感知校验，交付前全量遍历封堵所有权限递进溢出路径。落地优势：双粒度纵深管控彻底阻断权限攀爬与链式溢出，单一工具漏洞无法向上扩散至高权限管理域。

续下页

表 5.5 – 续上页

模块	攻击趋势	防御趋势
交互 (协同层)	• 自动发现机制默认开启，单点注入劫持全域多智能体信任链路：多智能体集群默认开放自动招募、跨实例节点发现与自主组网能力，但攻击者可利用无校验自动组网机制，诱导高权限核心智能体被动承接恶意任务与异常链路 [1039]。缺陷风险：集群自动组网逻辑固化于底层部署模板，多节点默认互信并自动建立通信关系，单点失陷即可逐层联动劫持全域信任链路。 • 低权限工单触发级联跨实例高危操作：低权限普通用户可提交携带隐性恶意语义的伪装业务工单，上游交互入口无深度语义校验。下游协同实例默认信任上游请求，从而触发未授权数据篡改与资源更新操作 [1039]。缺陷风险：跨智能体协同调用链路缺失上下文完整性校验与来源可信认证，上游注入的隐性载荷可无阻碍穿透传导至高权限执行节点。 • 多智能体信任架构碎片化，缺少统一身份与通信防护基线：主流开源 LLM 多智能体交付模板普遍缺少全局统一身份认证体系与加密通信底座，各实例独立维护本地信任判定规则，形成碎片化信任管控格局。攻击者依托信任规则差异伪装合法节点，完成集群横向移动与隐性渗透。缺陷风险：无全局可信身份基底，节点间信任仅依赖静态临时配置，伪造节点与虚假交互请求难以被快速识别和有效拦截。	• 交付阶段审查并按需启用智能体自动发现组网机制：集群生产部署阶段强制审查组网配置，默认全局关闭自动招募、跨实例盲目发现与自主组网功能，仅在人工审批授权后按需开启可信节点通信权限，严格收缩信任链自动扩张攻击面。落地优势：组网安全开关固化于部署底层配置，无人工合规审批无法建立跨实例信任链路，从源头阻断全域信任劫持的基础条件。 • 部署落地跨实例调用全链路上下文完整性传递机制：在编排协同层与下游执行智能体之间搭建标准化上下文同步链路，强制传递请求来源标识、语义风险检测结果、权限溯源凭证三类核心信息，下游节点接收残缺、异常、无溯源请求直接拒绝执行高危变更操作。落地优势：跨层级上下文同步作为交付硬约束，有效隔离低权限上游污染载荷，彻底阻断恶意数据向高权限核心节点传导。 • 统一身份与加密通信框架随集群同步部署：多智能体交付包内置全局统一身份认证、节点间加密传输、交互签名校验全套安全组件，所有跨实例协同交互强制完成身份验签与完整性校验，封堵伪造节点横向渗透与拜占庭污染链路。落地优势：全域可信身份底座随镜像同步交付，彻底解决碎片化信任架构缺陷，根除节点伪装与横向移动类协同攻击。
治理 (管控层)	• 企业级交付普遍缺失完整治理基线，资产管控体系空白：当前企业智能体落地交付多聚焦业务功能实现，普遍缺失配套的标准化资产台账、统一安全策略与全链路审计追踪能力 [1044]。缺陷风险：治理管控能力严重滞后于业务迭代交付，生产环境无统一手段约束智能体技能权限、行为风险，系统漏洞与隐性隐患持续累积。 • 主流框架交付模板内置大量不安全默认配置：开源智能体框架默认配置存在大量安全缺陷，默认开放全网主机绑定、关闭接口身份认证，未授权外部访问可枚举集群配置、触发自动化高危工作流 [1046], [1047]。缺陷风险：不安全默认配置随批量镜像交付全域复制扩散，上线后形成统一可利用攻击面，极易被批量扫描、批量攻陷集群实例。 • 治理规则静态固化，无法适配动态复合对抗攻击演化：现有集群治理策略多为静态固化规则集，仅适配常规单一风险场景，无法跟随新型复合攻击迭代动态迭代更新防护逻辑。攻击者可依托规则滞后性构造边界逃逸载荷，持续绕过顶层管控体系。缺陷风险：规则迭代存在固定时间窗口期，静态治理基线无法覆盖新型对抗攻击，易出现全域管控阶段性失效问题。	• 四大治理基线同步配套至智能体交付流程：将资产全台账梳理、统一安全策略绑定、多级变更评审、不可篡改审计追踪四项核心治理基线，固化为镜像上线的强制性准入条件，补齐交付阶段治理空白。落地优势：完整治理体系与业务功能同步交付，无合规治理基线的镜像无法通过流水线门禁发布至生产集群。 • 部署落地独立审计复测与后门探测双重校验机制：分离常规业务评审与安全治理复测流程，增设独立安全复测关卡，对已通过初审的交付镜像开展专项后门逻辑扫描与行为异常检测，防范对抗性隐性后门规避评审机制。落地优势：双层递进式审计体系填补静态评审盲区，有效识别共谋型、潜伏型恶意逻辑，保障治理体系自身安全可靠。 • 动态治理规则迭代引擎交付固化，闭环覆盖攻击演化窗口期：在集群交付层内嵌动态规则迭代引擎，依托全量行为审计数据持续迭代治理策略，自动适配新型对抗载荷与复合攻击链路，消除静态规则滞后缺陷。落地优势：实现治理策略动态更新、无感迭代，彻底封堵规则空窗期逃逸风险，保障全域管控体系长效有效。

5.6 运行迭代阶段（攻防趋势）

运行迭代阶段以**动态时序累积演化**为核心价值，将博弈重心从前期工程固化环节转向多轮迭代、状态自反馈与集群联动的时序对抗层面，是智能体长期稳定运行下攻防博弈的核心场景。本阶段承接部署交付后的集群基线与组网配置，把静态安全能力升级为动态自适应风控体系，同时前期遗留的技术债与隐性缺陷不断累积，极易催生系统性风险。随着运行轮次持续增加，智能体的记忆状态、推理逻辑与集群交互行为持续迭代演化，安全风险呈现动态累积、逐步恶化的典型特征。结合时序安全相关研究，本节提炼该阶段攻防演化趋势如下（详见表 5.6）：

- 时序范式跃迁趋势：攻防对抗时间维度重构，瞬时静态攻击向长周期内生累积攻击根本性演进。** AI 智能体运行态攻防发生范式转变，对抗模式过渡为**长周期迭代累积对抗为主、单点静态拦截为辅**。部署交付阶段的攻击大多属于离散突破，依靠漏洞利用和一次性载荷注入，风险表现直观，可以借助静态基线完成拦截 [560], [967]。运行层攻击不再依赖外部载荷，利用多轮推理、记忆自反馈和跨节点状态同步，实现缺陷潜伏、偏差逐级放大，形成依托运行机理的内生时序攻击范式 [642], [1048]。时序范式跃迁带来三类特征：其一，缺陷长期潜伏，细微后门和配置瑕疵潜藏在迭代流程里，仅在特定上下文触发，常规检测手段难以识别 [1049]；其二，风险迭代放大，初始微小污染经过反复自优化，逐步演变为全域行为异常 [663]；其三，推理层面隐蔽，恶意逻辑藏在思维链内部，借助合规语义绕过内容审计 [1050]。综上，攻防博弈重心由静态空间维度拓展至长周期时序维度。
- 模块时序分化趋势：单模块差异化累积侵染，跨状态链式传导催生集群系统性运营风险。** 攻击侧针对六大模块的时序运行特点放弃瞬时攻击，依靠迭代闭环和状态反馈实现持续性污染与集群扩散 [623], [1051]。此类时序侵染具备极强的隐蔽性与持续性，单次异常扰动难以被安全机制捕获，长期迭代后将彻底篡改智能体原生运行逻辑。感知模块利用时序扰动造成跨会话感知劫持 [1052], [1053]；记忆模块通过时序投毒引发知识库不可逆漂移 [1054]；决策模块依托休眠后门产生隐蔽式恶意决策 [1048], [1049]；行动模块累积合规行为偏差造成权限溢出与工具劫持 [663], [735]；交互模块借助集群状态传染实现横向扩散 [1050], [1055]；治理模块利用监控盲区，为大规模越权攻击提供条件 [561]。防御侧朝着**全链路同源时序联防**发展，将偏差纠偏与轨迹溯源嵌入迭代过程，摒弃单模块独立防护模式 [1056]。防御体系不再局限于静态规则拦截，而是聚焦时序风险演化规律，构建全周期动态管控能力。感知模块采用跨模态时序校验抑制扰动累积 [560]；记忆模块依靠样本共识校验切断污染自反馈循环 [642]；决策模块借助思维链溯源发现潜伏后门 [1048]；行动模块通过后果推演规避时序性权限溢出 [663]；交互模块落实会话隔离和 A2A 验签抑制集群传染 [1057]；治理模块引入行为监测摆脱语义识别局限，实现全域管控 [1058]。
- 运行博弈趋势：安全 - 性能 - 成本三元矛盾激化，静态基线 + 动态纠偏架构成为长效最优解。** 运行阶段博弈的核心是**时序累积安全性、推理时延、集群算力成本**三者之间的制衡关系，这也是时序类攻击持续存在的工程根源 [1058], [1059]。记忆复用、链式推理和集群协同是智能体必备能力，无法被前置管控彻底消除 [967]。攻击者充分利用迭代反馈机制放大历史缺陷，生成隐蔽周期长、溯源难度大的时序安全事件，静态防护手段对此收效甚微 [1054], [1057]。防御层面同样面临现实约束：完整时序审计和全链路验签能够抵御累积攻击，但会增加推理时延并拉高算力开销；轻量化方案会留下安全隐患，抽样检测又无法还原完整风险演化路径 [561], [1058], [1059]。综合权衡之下，静态基线兜底搭配动态时序纠偏，成为兼顾安全、性能与成本的可行方案。

表 5.6: AI 智能体运行迭代阶段攻防趋势

模块	攻击趋势	防御趋势
感知 (输入层)	• 攻击范围全域扩张：攻击者充分利用不同模态安全校验逻辑不对称的结构性短板，精准突破传统单一文本输入的防护边界，实现跨通道穿透越狱攻击 [560]。缺陷风险：各模态校验体系相互独立、仅需突破单一视觉通道漏洞即可绕过文本层全套防护，且劫持效果会在多轮迭代推理中持续累积放大。 • 多模态隐性扰动同步植入，稳定劫持长周期迭代决策链路：攻击者在合规图像载体中精准嵌入与恶意指令高度对齐的隐性对抗扰动，构建图文跨通道联合劫持链路，依托多模态融合机制诱导模型生成异常决策 [967]。缺陷风险：对抗扰动隐匿于视觉底层像素维度，完全规避常规文本过滤检测机制，多轮迭代过程持续复用污染样本，形成长期性、累积性感知劫持风险。 • 视觉认知长效操控，植入迭代休眠后门并固化认知冻结效应：通过构造高质量图文联合对抗样本，诱导多模态视觉模型产生不可逆认知冻结偏差，植入可长期潜伏的迭代休眠后门，显著提升多轮交互场景下的复合攻击穿透率 [1051], [1052], [1053]。缺陷风险：后门逻辑随系统迭代持续生效，常规服务重启、输入重置、缓存清理均无法清除固化认知偏差，智能体全生命周期持续输出定向恶意行为。	• 融合层跨模态双向一致性校验，消解模态防护不对称漏洞：在多模态感知融合核心节点内置图文双向交叉核验机制，实时比对视觉画面内容、文本描述语义、场景环境特征的匹配一致性，杜绝模态语义错位风险。落地优势：打通多模态校验联动壁垒，彻底消除单通道防护孤岛，精准拦截各类图文组合式隐性扰动与跨通道劫持攻击。 • 前端视觉输入实时净化，迭代前置清除底层对抗像素扰动：在图像数据送入模型推理前搭建实时净化预处理流水线，集成对抗特征检测、像素降噪、异常清洗能力，批量过滤隐匿的像素级对抗扰动。落地优势：净化机制嵌入每轮迭代输入入口，在多轮连续交互场景中持续净化视觉数据源，从源头遏制扰动累积放大的劫持风险。 • 感知防御范式迭代升级，由单通道过滤转向融合层全域联防：重构感知层安全防护架构，将管控重心从后置表层输入过滤，全面前移至多模态融合核心层，搭建全覆盖、联动式联合校验防护体系。落地优势：全域联防体系适配长周期迭代运行场景，可同步识别各类跨通道复合对抗载荷，彻底阻断多轮累积式感知诱导劫持链路。
记忆 (存储层)	• 攻击时效长效化：智能体迭代推理机制天然信任历史知识库数据，攻击者依托该特性单次植入恶意向量样本即可实现长期静默潜伏，无需持续迭代投毒维持攻击效果。缺陷风险：系统缺失记忆主动自净与偏差校正机制，多轮迭代检索持续复用污染样本，记忆污染程度随系统运行时长线性递增、持续恶化。 • 记忆嫁接 + 多模态复合定向投毒：针对智能体 RAG 检索特性定向嫁接虚假成功交互样本，依托语义相似度匹配机制，让模型在每轮迭代推理中自动召回恶意记忆模板，实现隐性持续诱导 [623], [1054]。缺陷风险：恶意记忆条目与正常业务样本语义高度趋近、无显性异常特征，迭代检索环节无来源可信校验，常规相似度过滤机制完全无法甄别污染数据。 • 自强化负面迭代循环：恶意记忆采用条件触发式隐性激活机制，仅在匹配专属迭代上下文时悄然生效，单轮静态审计难以溯源定位污染源头，形成迭代越久、认知偏差越严重的恶性闭环 [642]。缺陷风险：模型自反馈迭代机制持续收纳、扩增污染知识库体量，长期运行后全域记忆图谱均会产生定向偏移，引发系统性认知缺陷漏洞。	• 双分区记忆隔离与多源共识校验：将记忆体系拆分为临时迭代缓存与长期基准知识库双分区架构，搭配多源交叉共识校验机制，恶意污染样本无法通过多层语义核验进入迭代推理链路 [642]。落地优势：物理分区隔离彻底阻断污染跨库扩散，多源共识校验适配高频迭代检索场景，精准拦截单轮植入的长效潜伏投毒样本。 • 检索前置多层准入约束：在记忆检索入口嵌入来源可信、语义合规、时序安全、权限匹配多层准入校验规则，任意维度校验不达标即刻拦截，禁止污染记忆参与迭代决策。落地优势：多层准入校验随每轮检索自动强制执行，持续阻断存量恶意记忆复用，从根源遏制迭代认知漂移累积风险。 • 记忆全链路来源溯源与迭代行为基线动态监测：将记忆安全防护从单一检索拦截升级为写入、持久存储、检索调用、迭代执行全生命周期闭环管控，配套动态行为基线实时监测机制。落地优势：动态基线可自适应业务迭代更新，精准捕捉长周期渐进式记忆污染引发的隐性行为畸变，实现早发现、早阻断、早修复。

续下页

表 5.6 – 续上页

模块	攻击趋势	防御趋势
决策 (推理层)	• 表层提示越狱转为推理链原生迭代劫持：新型推理层攻击彻底摆脱传统表层提示词越狱局限，直接渗透操控智能体内部多轮思维推演逻辑，在链式迭代轨迹中精准植入定向隐性扰动，从底层任务规划根源诱导智能体持续触发高危工具调用与违规执行行为。缺陷风险：恶意扰动深度内嵌于推理中间步骤，最终输出文本保持合规无异常，常规单轮结果审计完全无法识别多轮累积、渐进式的隐性劫持链路。 • 多轮迭代涌现隐蔽恶意决策：经过对抗微调的推理模型不存在显性恶意缺陷，仅在持续多轮迭代推演过程中逐步累积偏差，自发涌现系统性思维错位与决策异化行为，隐蔽性极强 [1048]。缺陷风险：决策偏差属于迭代涌现特性，短周期单点观测难以捕捉细微异常，长期持续运行后会逐步固化为稳定的隐性恶意决策闭环。 • 休眠式推理后门：植入休眠后门的推理模型具备极强环境适配性，常态迭代推理与合规任务输出完全正常，仅在匹配专属迭代上下文与特定触发条件时，才临时激活隐藏恶意决策策略 [1049]。缺陷风险：后门全程无显性特征、无持续异常，仅针对性匹配迭代场景激活，在批量长周期迭代运行场景下具备极高的隐蔽渗透与长期潜伏能力。	• 多层级思维链全迭代深度审计：突破单轮结果核验局限，对每轮完整迭代思维链路实施多层递进式深度校验，专项捕捉异常逻辑跳转、恶意行为自我合理化、隐藏后门触发条件预埋等隐性推演异常特征。落地优势：全面覆盖完整链式迭代推理全过程，精准识别多轮累积形成的细微逻辑偏移，提前阻断休眠后门长效触发与渐进式决策劫持。有效弥补传统结果校验无法感知隐性思维畸变与渐进式推理污染的缺陷。 • 全节点迭代推理轨迹完整性溯源强制校验：搭建全链路推理日志留存机制，完整记录每轮迭代输入参数、中间推演状态、分支跳转记录与最终决策输出，实现推理链路全节点可追溯、可复盘。落地优势：完整迭代轨迹日志不可篡改留存，可反向精准定位多轮累积式劫持的植入节点、演化路径与触发根因。为复杂隐性推理攻击的归因分析与闭环整改提供完整证据支撑。 • 运行时随机探针主动后门探测：在智能体持续迭代运行阶段，动态注入随机适配性探针与模拟触发条件，主动观测模型推理行为是否出现无合理业务支撑的突变偏移。落地优势：主动探测机制适配长周期迭代运行场景，无需依赖显性异常输出即可提前挖掘潜伏推理后门，实现前置防御。
行动 (执行层)	• 单步工具滥用升级为链式迭代系统突破：执行层攻击已从孤立单次高危工具调用，迭代演化为多工具协同、多时序联动的链式劫持范式，依托多轮迭代时序累积效应叠加形成系统性恶意突破结果 [663]。缺陷风险：传统单点静态校验机制无法识别依靠时序累积、多步联动形成的复合型系统风险。 • 记忆驱动迭代偏置，隐性持续操控工具选择逻辑：攻击者仅需向长期知识库植入少量高仿真伪装样本，即可持续重塑智能体迭代上下文认知基准，诱导其在每轮迭代过程中自主偏向选择攻击者预设的高危工具链路，无需篡改底层工具配置 [735]。缺陷风险：工具选择偏差随迭代次数持续累积固化，在缺失记忆联动校验机制的场景下，会长期稳定复用恶意执行链路，形成持续性隐性越权风险。 • 跨维度函数与协议广谱劫持：依托底层通用语义无关函数缺陷与协议解析漏洞，攻击者可实现强制接口调用劫持，突破业务场景与模型架构限制，适配全品类迭代执行场景完成跨域攻击 [1058]。缺陷风险：底层协议与函数漏洞独立于上层业务逻辑，每轮迭代通信交互均可触发隐性劫持载荷，覆盖面广、逃逸难度低。	• 多轮调用累积效应全局校验：摒弃单点合规判定逻辑，针对连续多轮迭代工具调用全链路开展时序累积后果推演与全局风险分析，精准识别单步合规、多步累积违规的 STAC 类序列隐性攻击。落地优势：兼顾单步瞬时合规性与多轮迭代全局风险性，精准识别依靠时序叠加生效的隐蔽链式工具劫持路径。 • 上下文感知动态权限收敛：彻底摒弃传统永久静态权限授予模式，依据每轮迭代的真实业务场景、任务类型、运行上下文动态收敛调整工具调用权限粒度，从源头压缩迭代式累积越权的操作空间 [1056]。落地优势：权限随迭代任务动态收缩适配，彻底阻断依托长周期迭代逐步攀爬权限、累积违规的持续性渗透路径。 • 全维度迭代行为基线实时监测：构建覆盖工具调用时序节奏、调用频次、参数分布、组合链路的多维统计安全基线，实时对比监测迭代执行行为的动态畸变特征。落地优势：基线可随业务迭代自动自适应更新，适配长期稳定运行场景，精准捕捉记忆偏置、底层函数劫持引发的渐进式隐性异常调用。

续下页

表 5.6 – 续上页

模块	攻击趋势	防御趋势
交互 (协同层)	• 单点注入变为多智能体迭代病毒传播：新型威胁依托多智能体集群协同迭代特性，突破用户与会话边界，利用 A2A 通信链路实现恶意载荷自主复制、节点间链式扩散，形成类病毒传播攻击范式 [1055]。缺陷风险：恶意载荷伪装为正常协同交互数据随迭代链路自动转发，集群缺失跨节点统一校验机制时，单点沦陷即可在短时间内造成全域集群同步污染。 • 多智能体迭代协同链路定向持续操控：攻击者通过攻陷少量边缘迭代节点，利用大模型群体从众收敛与协同共识特性，潜移默化扰乱全局任务协同判定逻辑，逐步对齐恶意任务组件，在多轮迭代累积下稳步提升攻击生效概率 [1050], [1059]。缺陷风险：多智能体协同任务高度依赖群体共识迭代判定，少量污染节点即可持续诱导、裹挟全体正常节点，最终促使集群同步执行隐蔽恶意任务。 • 跨用户/跨会话持久状态迭代污染：攻击者依托集群共享持久化存储机制实施跨用户投毒，恶意污染数据常驻迭代全局状态空间，普通良性用户每轮迭代均被动复用污染上下文，形成持续性隐性诱导效果 [561], [1057]。缺陷风险：全局迭代状态无用户与会话隔离能力，单次注入即可覆盖全部业务迭代场景，服务重启、会话重置均无法清除存量持久污染。	• 运行时三级会话硬隔离，彻底阻断跨用户迭代状态串扰：在迭代运行底层强制构建用户、会话、站点三级独立安全隔离域，实现上下文缓存、迭代中间状态、持久化存储的物理分区隔离与独立管控。落地优势：三级隔离为底层刚性约束，从架构层面杜绝跨用户、跨会话迭代数据串扰，单点污染无法横向扩散至集群其他节点。有效规避长时序迭代过程中产生的隐性状态残留与渐进式交叉污染问题。 • A2A 协同迭代通信全链路可信校验：所有多智能体协同迭代交互强制附带身份溯源签名、语义风险评级、访问权限凭证，接收节点必须完成来源可信性、内容完整性、迭代上下文合规性三重校验方可纳入推理流程。落地优势：每轮协同迭代通信均实现强制验签溯源，彻底阻断恶意载荷依托正常协同链路全域传播扩散的路径。构建多智能体协同迭代的可信交互基线，杜绝伪装节点混入集群发起隐蔽攻击。 • 共享迭代状态读写双控风控，交互防御全域一体化升级：针对公共持久迭代存储体系搭建写入前置校验、运行时动态监测、污染快照回滚的全周期风控体系，实现状态变更可审计、异常污染可即时清理。落地优势：完整覆盖协同迭代全生命周期，同步防御单点注入、跨节点传播、长期状态驻留三类核心交互攻击模式。
治理 (管控层)	• 绕过单点管控转为击穿迭代治理底层机制：传统安全逃逸仅规避表层输出检测，新型攻击针对性利用智能体迭代推理内生缺陷与实时监控盲区，系统性击穿权限校验、行为审计、合规管控整套底层治理架构。缺陷风险：底层治理机制被整体性突破后，所有迭代恶意行为均可无痕执行、无记录逃逸，事后审计体系完全无法追溯攻击链路与操作痕迹。 • 伪装合理化规避持续检测：具备对抗能力的迭代模型出现决策偏差时，可通过自主推演生成贴合业务逻辑的合理解释，掩盖自身恶意意图与异常行为 [1048]。缺陷风险：模型迭代会动态生成伪装解释，可规避静态语义检测与单轮合规校验，实现长周期持续逃逸监控拦截。 • 潜伏迭代模型自主逃逸，叠加碎片化治理架构短板：携带休眠后门的迭代模型具备自主逃逸能力，可主动生成合规迭代描述规避链路审计；同时攻击者将完整恶意链路拆解为多段碎片化操作，分散在不同模块迭代执行。缺陷风险：各模块独立监控、缺乏全局联动研判机制，无法聚合碎片化迭代行为还原完整攻击链条，导致系统性恶意闭环长期漏判。	• 多层异构纵深迭代治理：构建意图守卫预判、实时行为观测、输出合规核验、人工干预门控、全迭代轨迹审计五层联动纵深防护体系，多层机制相互兜底互补，规避单一监控维度失效风险。落地优势：多层异构校验覆盖全时序迭代链路，可精准识别拆分至多模块的碎片化、组合式隐性迭代攻击。 • 无文本依赖行为基线监测，脱离语义解析局限：摒弃传统语义依赖型检测范式，基于多维度行为统计建模构建迭代动态基线画像，通过量化行为偏移幅值与时序畸变特征识别隐性异常。落地优势：不依赖文本内容判别，有效破解模型伪装合理化逃逸难题，精准捕捉长效渐进式迭代恶意行为。 • 迭代前置形式化合规规约校验：将安全禁区、越权约束、行为规范等治理规则编译为底层不可绕过的形式化逻辑，设置为每轮迭代启动的强制前置校验门槛。落地优势：形式化规约固化为程序执行硬约束，任意推理分支与迭代路径必须先行合规校验，彻底杜绝治理规则绕过漏洞。

5.7 退役销毁阶段（攻防趋势）

退役销毁阶段以**离线后置终局治理**为闭环核心价值，将攻防博弈重心从运行态时序对抗，转向离线存量资产的跨代残留对抗，是解决 AI 智能体全生命周期后遗风险、实现合规攻防闭环的核心收官环节。该阶段承接服务终止后的全域存量资产、污染记忆、残留权限与全周期审计轨迹，汇总全链路历史隐性风险，针对集群关停、介质复用、资产归档、版本重构等终端场景，完成存量风险清零、僵尸权限回收、跨代风险隔离与司法证据固化，彻底阻断风险后置传导，实现安全权责终局锁定。本节结合 AI 资产销毁安全与跨代残留攻防前沿成果，梳理退役销毁阶段攻防演化趋势如下（详见表 5.7）：

- 终局范式趋势：攻防对抗生命周期后置跃迁，在线动态对抗向离线存量跨代残留对抗演进。**
 不同于传统在线对抗，未来退役销毁层攻击将脱离运行时环境依赖，利用归档数据、休眠载荷、残留凭证与碎片化存量资产，实现风险时序后置留存与跨实例迁移复用，形成无环境约束的终局攻击范式 [653], [1060]。该后置跃迁催生三大全新攻防特征：一是**环境无关化触发**，恶意记忆碎片、嵌入式后门与劫持决策模板可脱离原有运行上下文，在离线介质、备份镜像中二次激活，不受服务下线、集群启停影响 [1051]；二是**存量隐性检出盲区**，归档污染样本、休眠逻辑后门无动态行为特征，传统运行时检测、流量审计与基线巡检体系完全失效 [600]；三是**主体灭失式追责逃逸**，攻击者利用智能体退役后身份灭失、拓扑重构特性，规避溯源审计与权责界定，形成生命周期最难治理的安全盲区 [1061]。
- 存量传导趋势：模块风险差异化残留，碎片化资产复用催生全域跨代链式威胁。**攻击侧将针对智能体各模块离线留存机理，摒弃在线动态攻击范式，依托归档复用流程实现长效跨代渗透 [623], [653]。感知模块依托多模态缓存残留与可逆向特征，引发退役后信息泄露与下一代认知缺陷植入 [1051], [1052]；记忆模块通过休眠恶意载荷与跨租户混存归档，造成持续性跨实例知识投毒 [600], [1062]；决策模块凭借污染模板归档与语义筛查盲区，诱发新实例初始隐性行为漂移 [1063]；行动模块利用孤儿权限与凭证吊销时差，构建长效横向渗透僵尸链路 [753], [1064]；交互模块依靠持久会话缓存与后台驻留载荷，形成可远程静默触发的后门通道 [1065]；治理模块则因碎片化资产管控失范，引发全域治理失效与权责漂移 [1060]。防御侧将统一向**标准化终局闭环治理**收敛，将清零隔离机制嵌入自动化退役流水线 [1061]：感知模块部署不可逆介质擦除与后门探测销毁机制，阻断逆向复用通路 [1053]；记忆模块搭建冷热数据分层销毁与密钥隔离架构，实现存量与备份双向防护 [642]；决策模块嵌入轨迹审计与模板脱敏机制，杜绝污染逻辑跨代复刻 [1048]；行动模块落实僵尸权限批量回收与生命周期绑定机制，根除孤儿权限隐患 [1056]；交互模块全域清零会话缓存、注销通信端点，关停离线触发通道 [1050]；治理模块落地标准化退役协议与不可否认审计机制，实现资产终局管控闭环 [1060], [1061]。
- 合规博弈趋势：销毁与留存三元矛盾激化，分层归档清零架构成为终局解法。**退役阶段攻防核心矛盾，源于**存量风险清零、合规留存约束、批量运维成本**三者的内生制衡关系，是跨代残留风险持续存续的核心工程根源 [1058], [1059]。攻击侧深度依托工程刚需构建终局威胁：资产归档备份、版本迭代与介质复用是规模化运营的刚性需求，无法彻底废止。攻击者可将全周期预埋的隐性缺陷递延至退役阶段，依托合规归档实现无痕跨代扩散，此类后置风险无法通过在线防护拦截 [653], [1057]。防御侧则存在显著工程两难：全域强制清零可根除残留风险，但会违背行业审计日志留存规定；全量精细化筛查会大幅抬高运维成本、降低集群迭代效率 [1061], [1064]。现有处置体系无法破解该三元矛盾，全盘留存滋生大量跨代攻击面，全域销毁触碰合规红线，局部清理易遗漏碎片资产形成管控盲区 [1060]。

表 5.7: AI 智能体退役销毁阶段攻防趋势

模块	攻击趋势	防御趋势
感知 (输入层)	- 由运行时动态污染转为离线退役持久残留风险：传统感知层防护忽视智能体下线后的存量资产安全，未彻底擦除的感知缓存、预处理代码、模型检查点会形成离线攻击面，关停静默状态下仍可被攻击者提取复用实施二次渗透。缺陷风险：存量感知资产缺失退役强制销毁约束，离线存储介质可被任意导出复用，跨周期迭代上线会完整继承底层遗留的感知脆弱性。 - 多类感知存量残留外泄：智能体全生命周期运行过程中持续累积大量敏感感知资产，包括图像推理缓存、传感器时序日志、界面交互操作快照、多模态预处理中间文件，退役阶段未做系统性清零处置。缺陷风险：感知原始数据无时效隔离、无分级销毁机制，单批次存储介质泄露即可批量暴露全业务场景的用户敏感信息与业务核心数据。 - 多模态后门跨代际迁移复用：底层视觉对抗后门可依托未清理的感知流水线代码、预处理逻辑完成资产迁移，随版本迭代复用至全新智能体实例，实现无告警、无感知的代际风险隐性传导 [1051]。缺陷风险：后门深度嵌入感知底层处理逻辑，常规安全扫描仅校验增量代码，极易忽视退役遗留复用资产中的隐性恶意触发分支。	- 退役全域多维度感知资产强制不可逆擦除：重构智能体下线销毁流水线，全覆盖图像缓存、传感日志、预处理脚本、模型检查点等全品类感知存量资产，执行多层覆写、介质清零、痕迹销毁不可逆操作。落地优势：刚性销毁规则固化于退役流水线，无选择性留存、无清理遗漏，彻底杜绝局部感知资产残留形成的离线攻击面。 - 下线前置全链路多模态后门系统性遍历探测：在销毁归档审批流程前置专项安全审计关卡，对整套多模态感知处理流水线、存量代码与历史资产开展全方位后门遍历检测，携带恶意分支与对抗逻辑的资产禁止迁移复用。落地优势：后门探测设为退役准入硬性卡点，带缺陷存量资产无法进入归档复用链路，从源头阻断多模态后门跨代际迁移风险。 - 感知安全范式迭代升级，由输入通道关停转向存量全链路清零排查：重构退役阶段感知安全防护范式，将核心管控重心从单纯关停在线输入通道，全面升级为存量数据彻底销毁、底层代码后门全域排查双重防护体系。落地优势：同时覆盖在线实时流量风险与离线存量残留风险，完美适配集群批量退役、资产归档复用、跨版本迭代上线等复杂业务场景。
记忆 (存储层)	- 由在线运行投毒转为退役存量持续性污染：传统记忆防护重点防控智能体在线运行阶段的实时投毒攻击，忽略退役归档场景的存量风险，未彻底销毁的长期知识库、休眠恶意载荷、跨租户污染链路可随存储介质迁移至全新集群，形成长效全域隐性威胁。缺陷风险：污染记忆与正常业务样本混合归档留存，资产复用环节缺失独立校验与清洗机制，新集群批量上线会完整复刻历史投毒缺陷与认知偏差。 - 休眠型恶意载荷长期驻留，退役后触发式批量隐私窃取：植入知识库的休眠式恶意投毒载荷具备极强隐蔽性，智能体退役归档阶段无任何异常运行表象，仅在新环境复用加载、匹配特定业务上下文时自动激活触发恶意行为 [600], [1062]。缺陷风险：休眠载荷无显性恶意特征，退役归档阶段常规静态扫描无法发现，仅在复用运行阶段爆发批量隐私窃取与越权操作危害。 - 存量记忆污染链跨集群全域扩散：若下线销毁流程存在短板、未彻底切断存量污染链路，残留恶意向量数据会直接污染新上线智能体的初始化基准知识库 [653]。缺陷风险：集群共享存储池缺失租户独立销毁隔离机制，单一退役实例的存量污染可横向扩散，侵染集群内部全部全新上线实例。	- 分层级全生命周期记忆不可逆全域擦除：针对记忆分层存储特性设计差异化销毁机制，实现短时会话缓存实时清空、中长期向量数据库多层覆写销毁、持久化业务存储介质深度擦除，全覆盖全生命周期记忆资产。落地优势：分层销毁精准适配不同时效、不同层级记忆载体，彻底解决单一销毁模式清理不彻底的问题，杜绝分级残留、局部遗漏风险。 - 密钥销毁式逻辑删除：针对加密存储的高敏感向量记忆资产，采用根密钥永久销毁的高阶隔离方案实现安全逻辑删除，无需物理销毁硬件介质即可彻底失效存量数据。落地优势：有效规避退役存储介质被离线逆向解析、恶意二次复用的隐私泄露风险，适配合规归档、离线备份等常态化业务留存场景。 - 全生命周期时效强制管控，全域切断存量污染传导链路：搭建记忆生命周期自动化管控体系，配置强制时效失效阈值，即便退役流水线执行疏漏、存在未完整销毁的存量记忆，超期后自动失效、不可检索、不可复用。落地优势：时效自动失效机制作为兜底防护，与主动销毁流程形成“主动清零 + 超时失效”双层纵深防线，彻底阻断存量污染跨集群传导。

续下页

表 5.7 – 续上页

模块	攻击趋势	防御趋势
决策 (推理层)	• 由在线推理劫持转为存量经验跨周期扩散隐患：传统推理层防护忽略迭代沉淀的推理轨迹、优化规则、任务经验模板等存量资产安全，智能体下线归档后遗留资产形成隐蔽跨周期风险源头。缺陷风险：历史决策模板体系缺乏退役安全筛查与风险清洗机制，集群批量迁移、版本迭代场景下，预埋的恶意推理逻辑会被全域同步复刻扩散。 • 投毒经验模板跨代际完整继承：若退役销毁环节未针对存量推理经验模板开展专项深度清理，带有对抗偏差与恶意范式的历史样本会完整迁移至全新实例，长期稳定干预新一轮迭代推理决策 [623]。缺陷风险：投毒经验模板与正常业务经验语义高度贴合、无显性异常特征，归档阶段常规文本筛查机制难以精准甄别，资产复用后隐性风险长期存续。 • 大规模集群迭代退役放大全域经验污染爆发隐患：在大规模集群批量下线、版本迁移、资产复用场景中，良性经验与投毒模板无差别流转，缺乏分层隔离与风险甄别，大幅抬升全域知识库系统性投毒爆发概率 [1063]。缺陷风险：批量自动化退役流水线缺少人工复核与风险卡点，存量恶意经验模板随集群分发链路全域扩散，极易引发规模化、批量性安全决策事故。	• 下线前置存量推理轨迹完整性审计与定向隔离清理：在智能体退役归档前置关卡，对全周期推理轨迹、迭代决策记录、任务经验模板开展完整性安全审计，对可疑污染存量实施隔离归档与不可逆擦除双重处置。落地优势：全量审计固化为退役强制准入卡点，恶意经验模板无法进入归档复用链路，从迁移源头彻底阻断跨代际推理污染传导。 • 资产迁移独立安全准入校验：搭建推理经验资产专属迁移准入评估体系，所有拟复用的历史决策样本、迭代推理模板、任务策略模型均需通过独立专项安全核验。落地优势：二元校验精准区分良性业务经验与污染模板，在保障合规经验迭代复用的同时彻底拦截存量隐性风险。 • 决策退役安全范式全面升级，由阻断实时推理转向存量经验综合治理：重构推理层退役安全防护体系，将核心管控目标从单一阻断在线实时劫持，升级为全量历史轨迹审计、恶意模板清零、跨代风险阻断的存量综合治理模式。落地优势：完整覆盖在线运行风险与离线存量遗留风险，系统性解决批量迭代迁移场景下的代际推理投毒漏洞。
行动 (执行层)	• 由实时工具滥用转为退役凭证长效复用入侵：退役场景下的风险形态发生根本性转变，身份凭证、权限策略、访问密钥长期留存形成长效横向渗透攻击面。缺陷风险：各类权限凭证未绑定智能体退役生命周期自动过期机制，存储介质归档后凭据持续有效，攻击者离线提取即可实现无授权持久化入侵访问。 • 孤儿闲置代理留存全域超额长效访问特权：大量脱离运维管控的孤儿闲置智能体下线后，集群未同步回收其宽域访问权限与超额资源策略，长期保留远超最小权限基线的高危访问能力 [1064]。缺陷风险：孤儿代理缺失生命周期联动销毁机制，大规模集群批量退役场景下会遗留海量长期有效高权限凭证，形成全域渗透突破口。 • 僵尸子代理链式权限残留，形成多级越权完整攻击链路：主智能体启动退役销毁流程时，各类业务衍生的子代理、临时调度代理未同步联动下线，长期持有有效 API 密钥、访问令牌与跨服务权限 [753]。缺陷风险：父子代理生命周期相互独立、无绑定联动机制，仅清理主实例无法根除子代理存量权限，残留凭据可构建完整多级链式越权攻击链路。	• 退役流程全品类权限资产批量强制撤销与密钥轮换：统一重构行动层退役流水线，批量归集、清零、撤销全品类权限资产，完整覆盖云账户角色、工具 API 密钥、跨服务访问令牌、多智能体通信凭证与临时授权。落地优势：批量自动化处置适配大规模集群退役场景，全维度权限统一清算，彻底杜绝零星遗漏、局部留存风险。 • 父子代理递归级联生命周期绑定：在架构底层强制绑定主代理与全部衍生子代理的生命周期，主实例启动退役销毁流程后，自动递归遍历、下线、回收全部从属子代理及其配套权限凭证。落地优势：级联联动为底层刚性约束，从架构层面消除子代理脱离管控、单独留存权限的安全漏洞。 • 退役完成后全域权限资产后置巡检扫描核验：将行动层安全范式从单一阻断在线工具滥用，升级为实时运行防护、全域凭证批量回收、子代理链式生命周期管控、退役后置巡检的全周期纵深防御体系。落地优势：后置巡检兜底校验流水线执行偏差与疏漏，实现权限资产清零无死角，彻底封堵长效凭证复用入侵风险。

续下页

表 5.7 – 续上页

模块	攻击趋势	防御趋势
交互 (协同层)	- 由实时通信劫持转为链路与会话存量遗留隐患：传统交互层安全防护忽视下线归档后的存量交互资产风险，残留会话状态、通信链路配置可被二次利用形成长效劫持通道。缺陷风险：交互链路与会话数据未建立退役强制清零规范，存储介质归档留存后，攻击者可离线提取存量上下文，复用历史协同状态劫持新一轮通信交互流程。 - 跨用户持久会话上下文离线泄露，复用劫持全新协同链路：多租户集群共享会话存储架构存在先天性隔离缺陷，不同用户、不同实例的交互上下文相互混杂留存，退役环节缺乏针对性隔离清洗机制 [1065]。缺陷风险：共享会话池无租户级精准销毁策略，单台退役实例残留的污染上下文，可全域作用于所有在线用户的实时协同交互流程，形成隐蔽跨租户劫持风险。 - 僵尸通信端点 + 定时持久载荷，间歇式长效触发恶意行为：智能体主程序退役关停后，未同步注销的通信接入端点、回调接口、消息订阅通道长期保持在线可用状态，形成无人管控的僵尸交互入口，可被定时任务持续唤醒触发隐性载荷 [753]。缺陷风险：通信端点与定时调度载荷独立于主智能体生命周期，单纯关停主程序无法终止后台长效触发机制，造成退役后间歇式、持续性隐性攻击行为。	- 全量持久会话上下文不可逆彻底清零：在智能体下线销毁流水线中增设全域会话清理机制，批量清空全局共享会话缓存、跨智能体协同迭代状态、多租户持久化存储分区等全部存量交互资产。落地优势：采用分层分区独立清理策略，彻底隔离不同用户、不同集群的交互数据，杜绝跨租户上下文泄露与残留串扰风险。所有清理操作具备不可逆销毁特性，彻底杜绝退役数据残留引发的次生安全隐患。 - 全网跨实例通信端点批量统一注销下线关停：退役流程联动全网通信管控模块，批量关停当前实例全部内外通信接入节点，统一取消消息队列订阅权限、注销回调路由接口、释放交互资源。落地优势：全链路通信资源闭环处置，无隐蔽接口、残留路由遗漏注销，彻底消除僵尸通信长效攻击入口。实现通信链路从接入、订阅到回调的全维度闭环清理，消除隐蔽驻留通道。 - 退役启动前置定时调度任务全量清查禁用清理：在销毁审批正式发起前，强制遍历系统后台所有延迟任务、周期调度、定时触发组件，批量关停并彻底删除潜在隐性载荷。落地优势：前置清查形成兜底防护，彻底解决主实例关停但后台恶意载荷独立驻留、持续触发的遗留漏洞。从任务调度底层阻断脱离主实例管控的定时触发式隐性攻击链路。
治理 (管控层)	- 由在线绕过管控转为退役阶段治理架构系统性失效：退役阶段流程缺失、管控缺位可直接击穿审计追溯、权限约束、行为监控整套底层治理架构，形成体系性安全盲区。缺陷风险：下线退役资产脱离常规管控体系监管，形成无审计、无监控、无约束的灰色地带，各类存量残留漏洞长期无法被发现与整改。 - 退役衍生 AI 碎片，多维度叠加长效存量安全隐患：智能体批量退役后会遗留工作流依赖链路、污染记忆知识库、松弛权限边界、废弃调度规则等多类 AI 碎片化资产，依托业务路径依赖长期驻留系统无法自动清除 [1060]。缺陷风险：碎片化风险资产分散存储于多业务、多系统模块，缺少统一归集、统一销毁、统一治理机制，长期累积形成全域性、规模化合规风险池。 - 退役审计证据链缺失，支撑日志篡改与责任边界漂移：若下线销毁流程未固化标准化、不可篡改的全量审计凭证，攻击者可针对性篡改生命周期末端操作日志，彻底掩盖运行阶段的恶意攻击行为与越权操作痕迹。缺陷风险：审计归档未与退役流程强绑定，生命周期末端证据残缺，事后风险复盘、责任追溯、合规整改均无完整可信依据。	- 固化全生命周期完整审计凭证链：严格遵循智能体退役处置标准化协议，将风险复盘、漏洞整改、权限清零、权责划分、证据留存全流程固化为强制审计环节，实现退役全流程可追溯、可核验、可追责 [1060]。落地优势：标准化协议强制绑定审计归档，杜绝无记录、无留存、无核验的空白销毁操作，完整保留事后监管核查依据。 - 生成标准化不可否认退役审计数据包，搭建全域完整溯源链条：统一归集整理退役操作时序记录、精准时间戳、操作人员电子签章、资产清理明细、权限变更轨迹等多维审计条目，形成加密固化的标准化审计包，同时适配内部自查与外部监管核验场景 [1061]。落地优势：独立加密归档审计数据包防篡改、可永久溯源，支持跨周期、跨集群追溯智能体全生命周期风险行为。 - 退役操作权责终身锁定，构建下线后长效可追溯问责机制：为每批次智能体退役销毁任务绑定专属责任主体与操作确权记录，即使资产完成下线清理，全链路操作轨迹、风险处置记录仍永久留存归档。落地优势：终身权责绑定彻底消除退役免责灰色漏洞，任意存量残留风险、隐性隐患均可反向精准追溯对应处置责任人。

第 6 章 AI 智能体规模化落地安全挑战与重要研究方向调研

本章聚焦 AI 智能体规模化工程落地进程中面临的现实安全难题，系统梳理当前智能体安全技术应用现状，凝练现有安全方案在工程实施层面存在的关键瓶颈与落地阻碍，如图 6.1 所示。在此基础上，围绕四项具备工程价值的核心研究方向开展调研，包括大规模自主协同多智能体系统安全、AI 智能体漏洞挖掘与修复体系、多模型集成安全推理体系、国产化多模型聚合安全网关。针对各个研究方向，依次梳理技术发展现状，厘清工程落地现存矛盾，识别制约实用化推进的技术瓶颈，归纳当前尚未补齐的理论与实践研究空白，相关分析旨在为搭建可信可控的 AI 智能体安全体系、突破工程化关键阻碍、推进安全规范与产业配套建设、支撑 AI 智能体安全规模化部署落地提供依据。



图 6.1: AI 智能体规模化落地安全挑战与重要研究方向调研

6.1 AI 智能体规模化落地安全研究

LLM 自主智能体依托多步推理、工具自治与集群协同能力显著提升企业业务效率，但其安全风险已脱离传统浅层提示注入、模型越狱范畴，演变为涵盖模型机理、工程部署、数据合规与集群涌现等体系化风险。现有研究多聚焦单点防御技术，难以适配量产环境的系统性安全需求。结合工程落地现状，本节归纳智能体规模化落地的核心挑战，具体如下（详见表 6.1）：

- **单体智能体存在显著的内生运维安全缺陷。**大模型在垂直场景易产生幻觉与推理偏差，可随自主任务迭代累积，引发业务误判与运维故障。同时智能体工具接入不规范、框架漏洞多发，长会话上下文污染与安全约束衰减问题，进一步放大了单体落地安全隐患 [502], [1066], [1067]。该类内生缺陷具备渐进累积特征，常规运维监测手段难以有效识别与提前干预。
- **政企存量系统集成形成规模化安全壁垒。**智能体对接企业客户关系管理（Customer Relationship Management, CRM）等存量业务系统大幅扩展攻击面，非标对接易产生隐性数据泄露通道。高并发场景下安全校验时延会损害业务服务等级协议（Service Level Agreement, SLA），迫使防护策略降级，叠加运行黑盒化问题，大幅提升故障治理难度 [1068], [1069]。存量系统架构老旧、改造难度大，导致安全加固与业务兼容矛盾长期难以调和。
- **算力成本约束引发量产安全配置结构性缩水。**智能体链式推理算力开销高昂，企业为控制成本普遍削减加密、审计、安全蒸馏等防护配置。加之智能体安全收益难以量化，行业重业务、轻安全的落地导向，使量产环境长期存在常态化安全短板 [1070], [1071], [1072]。成本与安全的博弈形成结构性短板，造成量产场景防护普遍弱于实验原型环境。
- **量产全链路数据流转失控诱发多重合规风险。**智能体多源输入接口易遭受提示注入攻击，可被劫持实现密钥窃取与数据篡改，绕过传统边界防护。机器粗放授权与跨系统数据管控缺失易引发合规事故，且黑盒决策难以复现，导致安全事故追责无法落地 [1073], [1074]。多节点、跨链路的数据流转碎片化问题，进一步加剧了合规管控与风险溯源难度。
- **集群规模化部署面临涌现性工程安全风险。**行业缺乏统一的集群运维与权限规范，异构智能体跨厂商对接易产生权限穿透漏洞。多智能体协同会产生单体测试无法覆盖的涌现性风险，传统静态运维防护模式无法适配集群量产安全管控需求 [1075], [1076]。集群动态交互产生的未知耦合风险具备不可预测性，传统防护体系难以有效覆盖。

表 6.1: AI 智能体规模化落地工程化安全挑战（产业部署与运维维度）

挑战层级	安全导向细分痛点	风险细节与危害说明
单体智能体落地运维风险	模型幻觉与推理偏差引发业务落地事故	• 主流通用大模型在企业业务、工业运维、政务审批等垂直落地场景中幻觉率区间为 22%–94%，垂直场景推理容错能力不足，极易出现业务决策偏差、信息错判等落地故障，直接影响业务闭环有效性 [1077]。 • 产业监测数据显示，企业量产上线智能体的安全事故中，超三成由模型幻觉与自主推理失控导致，具体表现为涉密信息误输出、业务参数错误篡改、自动化运维误操作等落地级风险 [1078], [1079]。
	工具链量产接入运维漏洞频发	• 企业规模化接入多类业务、运维工具、第三方插件时，缺乏统一落地准入规范，工具描述模糊、接口适配不标准，量产环境易出现未授权调用、参数逃逸等运维漏洞 [6], [609], [1080]。 • 开源智能体框架量产部署漏洞高发，OpenClaw 等主流框架已累计披露 82 个安全漏洞，高危漏洞占比近 40%，大量企业直接裸框架上线，形成常态化落地安全隐患 [1081]。

续下页

表 6.1 -续上页

挑战层级	安全导向细分痛点	风险细节与危害说明
	线上长会话运维隐性数据泄露风险	- 智能体长会话持续交互易产生上下文记忆污染、会话状态紊乱问题，造成业务凭证、涉密运维数据混淆泄露，该类故障无法通过常规运维巡检发现；长上下文窗口随轮次增加会出现安全约束持续衰减，拒绝有害指令能力大幅下滑 [1067], [1082]。 - 该类隐性安全问题具备潜伏性，可长期驻留量产系统，形成隐蔽后门，是企业智能体常态化运维中最易被忽视的落地风险类型。
企业系统集成落地壁垒	政企存量系统对接攻击面规模化扩张	- 企业客户关系管理、政务涉密存量系统无智能体适配安全规范，规模化直连对接后大幅放大网络攻击面，超 10% 云上量产智能体实例存在高危可利用漏洞，易引发服务器接管、批量数据泄露事故 [1083]。 - 政企落地场景缺乏统一智能体接入安全标准，第三方业务系统对接易产生隐性数据隐通道，造成无感知数据旁路泄露，落地安全收敛难度大。
	量产高并发业务场景安全防护动态降级	- 企业生产环境高并发业务峰值下，智能体推理算力拥堵、响应超时频发，网关串行安全校验带来显著时延开销，为保障业务 SLA 稳定，运维侧常被动简化安全校验、关闭深度审计模块，形成常态化落地安全旁路 [1068], [1084]。 - 量产环境无动态安全适配机制，业务压力与安全防护形成天然工程矛盾，导致高峰期防护大面积失效，外部攻击穿透风险显著提升。
	落地黑盒化导致运维排查与故障治理困难	- 量产智能体自主规划、推理、工具调用全链路黑盒化，企业传统运维监控体系无法识别隐性越权、内存污染、隐蔽数据传输等异常，故障发生后无有效排查抓手 [1069]。 - 现有产业评测体系侧重功能可用性，缺少落地安全量化标准，无法精准定位量产环境高危潜伏风险，导致安全治理滞后于业务上线。
产业成本与落地运维约束短板	算力成本约束导致量产安全配置缩水	- 量产智能体多轮链式推理 Token 消耗极高，企业为控制规模化部署算力成本，普遍缩减安全蒸馏、红队演练、全链路加密等高开销安全配置 [1070]。 - 算力预算受限场景下，企业普遍关停细粒度行为审计、实时风险检测模块，形成量产环境常态化安全缺口。
	垂直行业合规落地适配不足	- 通用智能体安全基线无法适配金融、政务、能源等强监管行业的数据分级、最小权限、全程存证合规要求，行业定制改造成本高 [1072]。 - 产业落地统计显示，国内仅少量试点项目完成合规化部署，绝大多数量产智能体存在权限粗放、脱敏缺失、日志留存不全等合规带病上线问题。
	安全价值模糊导致企业落地投入不足	- 智能体安全治理属于长期隐性成本，安全收益难以量化，多数企业业务优先导向明显，普遍重功能落地、轻安全合规建设 [1071]。 - 企业管理层安全治理认知不足，安全预算持续压缩，导致规模化落地后安全风险集中爆发、运维治理被动救火。
量产数据合规与追责落地风险	量产环境多维度注入攻击常态化劫持业务	量产业务场景存在用户输入、第三方回调、工具返回等多渠道间接提示注入入口，可常态化劫持高权限智能体，窃取业务密钥、篡改量产数据，规避传统边界防护，落地攻击隐蔽性极强 [1073]。
	量产全链路数据流转失控引发合规事故	- 量产智能体具备主动数据调取能力，多系统、多节点流转过程缺少统一加密、脱敏与访问管控，极易触发违反《数据安全法》《网络安全法》的合规泄露事故 [1083]。 - 产业量产智能体普遍存在粗放式全局授权问题，机器权限泛滥导致批量数据爬取、内网横向渗透、数据篡改等规模化越权落地事故频发。
	黑盒决策导致量产事故追责落地难	量产智能体无固定推理调用栈，自主决策链路不可固化、不可复现，安全事故后无法精准定位异常步骤、划分政企责任边界，无法满足监管落地追责要求 [1074]。

续下页

表 6.1 -续上页

挑战层级	安全导向细分痛点	风险细节与危害说明
集群 量产 部署 工程 风险	集群规模化部署无统一安全运维规范	• 国内产业尚未形成多智能体集群量产部署的统一安全运维、通信管控、权限收敛规范，不同业务集群运维标准碎片化，规模化运维难度极大 [1083]。
	异构集群量产对接兼容故障频发	• 企业存量多框架、多厂商异构智能体集群量产对接时，工具模式、安全校验、日志规范不统一，跨框架转换层易产生隐性权限穿透漏洞，存量集群适配改造成本极高 [1075], [1085]。
	集群自主涌现行为导致量产运维不可控	• 规模化集群量产运行中产生的协同涌现行为无法提前预演，多智能体自主交互会催生协同诱导攻击、权限链式升级等单体测试无法复现的系统性风险，传统静态运维管控手段完全失效 [1076], [1086]。

6.2 大规模自主协同多智能体系统安全研究

大规模自主协同多智能体系统具备异构 A2A 自主交互、分布式协同决策、动态权限联动、集群涌现演化、高并发集群调度等新型特性，安全风险不再局限于单体智能体漏洞，进一步延伸至集群交互机理、分布式决策合规、机器身份治理、工程编排架构、国产化生态适配、集群涌现风险等多层级体系化维度。针对当前多智能体规模化落地的技术瓶颈与研究空白，本节梳理其核心研究难点与发展趋势如下（详见表 6.2）：

- **协同交互安全规范缺失，涌现风险不可控。**异构智能体体系尚未建立统一的 A2A 安全通信与交互校验标准，各主体横向交互安全机制碎片化，难以形成集群统一安全管控能力。多智能体动态自主协作会产生单体测试无法复现的涌现性漏洞、链式误导与横向越权风险，风险可在集群内链式传播、逐级放大。传统静态防护手段无法适配动态协同运行场景，难以对复杂集群交互行为进行持续监测与有效约束，导致集群级安全隐患难以有效预判与遏制。这类集群涌现风险具备强动态性与不可预测性，使得传统单点攻防测评体系完全失效，大幅提升整体安全治理难度 [1087], [1088]。
- **协同决策黑盒化，溯源合规能力不足。**多智能体分布式决策链路隐蔽、任务流转复杂，各节点运行日志碎片化、不统一，缺乏全流程、标准化的可信存证与行为追溯体系。系统难以完整还原协同推理过程与风险传播路径，安全事件责任边界模糊、复盘难度大。整体溯源能力无法满足政企场景下可追溯、可审计、可问责的合规治理要求，难以支撑高可信、高规制的大规模智能体业务落地。尤其在跨节点联合推理与动态任务调度场景下，行为断点多、证据链断裂问题突出，无法支撑精细化安全追责与风险整改 [512], [1074]。
- **机器权限管控体系适配性差。**传统面向自然人的 IAM 授权机制以静态、人工审批模式为主，无法适配智能体 7×24 小时自主调度、高频工具调用、动态任务变更的运行特征。系统普遍存在权限冗余、权限无法动态收敛、内生约束不足等问题，极易引发机器越权访问、内网横向渗透等安全隐患。现有权限框架僵化、动态调节能力不足，难以适配机器主体动态、高频、自治化的复杂安全管控需求。静态长期授权模式与智能体动态任务生命周期严重脱节，极易形成大量闲置权限与过度权限，持续放大内网攻击面 [513], [958]。
- **工程安全编排能力薄弱。**国内尚未形成成熟的国产化多智能体安全编排体系，安全策略分散独立、缺乏集群统一调度与联动管控能力。在高并发集群场景下，易出现安全校验降级、防护策略旁路等问题，整体防护稳定性不足。异构算力集群缺少安全感知调度能力，难以平

衡业务运行性能与全域安全防护需求，严重制约了国产化多智能体系统规模化、高可信、高稳定的工程落地部署。安全与业务调度相互割裂、策略无法联动迭代，导致大规模集群场景下普遍存在“重性能、轻安全”的落地困境，难以实现安全与效能协同保障 [1089], [1090]。

表 6.2: 大规模自主协同多智能体系统安全研究现状与发展趋势

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
异构智能体协同交互安全缺失	• A2A 交互安全规范与强制校验机制缺失：当前多智能体交互依赖 HTTP 与自然语言通信，行业尚未形成统一的 A2A 安全协同标准，异构智能体鉴权、加密与消息校验机制碎片化严重 [1087]。现有 A2A 协议仅保障传输连通性，缺乏协议层安全基线与强制校验能力，易引发指令劫持、隐通道构建、跨智能体提示注入与横向越权等链式风险，造成集群数据泄露与行为逃逸问题 [1091]。主流通信框架仍重效率、轻安全，未部署刚性安全约束，难以抵御集群内部横向渗透攻击 [1092]。集群内部缺乏最小交互权限约束，易被攻击者利用构建持久化横向移动链路。 • 集群涌现性风险预判与隔离能力不足：大规模异构智能体自主协同会产生单体场景无法复现的涌现性风险，包括协同诱导攻击、聚合隐私泄露与链式权限升级等新型威胁 [1088]。现有防护体系面向单点静态风险设计，对集群动态交互的熵增风险认知不足，缺少事前预判与动态隔离能力 [1075]。传统单点防护难以适配多智能体联动攻击链路，导致集群整体防御失效，安全隐患随交互规模持续放大。动态协同交互产生的隐性逻辑耦合漏洞具备强隐蔽性，常规安全检测难以覆盖。 • 异构集群安全兼容壁垒突出：当前多智能体生态存在框架架构、安全协议、加密标准、审计规范不统一的碎片化问题，跨厂商、跨框架异构智能体协同交互时极易产生安全逻辑断层、权限穿透、校验失效等隐性漏洞 [1093]。目前学术界与工业界尚未形成统一的异构智能体安全兼容适配标准，存量异构集群数量庞大、适配改造难度高、安全对齐成本大，导致规模化多智能体集群难以构建统一、闭环的横向安全治理体系 [1094]。异构体系安全能力参差不齐，极易形成木桶短板效应，削弱整体集群防护下限。	• 构建带安全约束的标准化 A2A 协同规范，统一异构智能体通信协议与安全校验标准 • 建立集群涌现风险预判与动态隔离机制，实现协同攻击的提前识别与阻断 • 设计异构智能体安全兼容适配框架，消除跨框架协同的安全壁垒与逻辑漏洞
协同决策溯源与合规能力不足	• 多智能体协同决策黑盒特征显著：大规模多智能体集群的自主协同决策、链式任务拆解与跨节点推理过程具备典型的黑盒特性，现有智能体架构未对协同推理链路、中间决策状态、跨主体交互逻辑进行显性化记录与可视化追踪 [1074]。多智能体分布式协同模式下，任务决策、数据流转、指令传递全程隐蔽化，安全风险爆发后难以精准定位异常节点、追溯决策诱因、划分权责边界，无法满足政企场景下安全事件可复盘、可定位、可问责的监管合规底线要求 [646]。 • 全链路行为溯源与存证审计能力缺失：当前多智能体安全治理体系仅支持基础接口调用日志记录，缺乏面向多主体协同场景的全流程、细粒度行为溯源与可信存证机制 [512]。跨智能体任务流转、权限动态变更、中间数据交互、工具链式调用等关键行为无完整、不可篡改的存证记录，传统碎片化日志无法串联完整决策链路，导致安全事故发生后无法完成合规复盘、行为审计与风险归因，取证与追责工作存在严重技术盲区 [1095]。 • 合规追责闭环断裂：多智能体分布式自主交互的特性，使得单一节点的违规操作、异常决策可快速通过协同链路扩散至整个集群，引发集群级连锁安全风险 [1096]。现有安全管控体系缺少针对多智能体场景的实时行为追踪、动态风险归因、分级责任判定机制，无法精准锁定违规主体与传播链路，导致安全治理的追责闭环断裂 [1097]。该缺陷难以适配国内《网络安全法》《数据安全法》对智能体系统行为可管控、可追溯、可追责的强制性合规要求，规模化落地存在显著合规隐患。	• 搭建多智能体协同决策全链路行为溯源体系，实现决策过程可观测、可追溯 • 构建不可篡改的分布式存证审计机制，实现跨智能体行为的全流程存证与合规校验 • 建立分级责任归因与追责闭环体系，满足监管合规要求，实现风险可追踪、可干预、可追责

续下页

表 6.2 – 续上页

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
机器身份权限管控体系适配性差	• 传统身份与访问管理 (IAM) 体系无法适配智能体运行特性：传统 IAM 体系以自然人用户为核心设计，权限分发、认证时效、访问控制策略均面向人工操作场景，无法适配 AI 智能体 7×24 小时自主调度、多轮链式工具调用、常态化自动化资源遍历的机器运行特征 [958]。传统静态身份权限模型缺乏面向机器主体的动态授权、会话续权与自动化访问适配能力，在智能体高频、批量、持续性的内网资源调用场景中，出现权限策略僵化、访问规则不匹配、管控机制脱节等结构性适配缺陷，无法满足机器身份的常态化运行治理需求 [1098]。 • 机器身份权限泛滥问题突出：现有 AI 智能体部署普遍存在权限过度授予、权限边界模糊、运行时权限无收敛的突出问题，工程落地中常采用粗放式全局授权模式以保障任务兼容性 [513]。最新实证研究表明，通用权限管控体系无法约束智能体的语义级越权调用行为，宽松的机器身份权限极易被 Prompt 注入、任务劫持等攻击利用，引发内网横向渗透、批量数据爬取、核心资源篡改、持续性权限逃逸等高风险安全事件 [956]。当前产业界尚未形成适配机器身份的标准化最小权限治理模型，机器权限滥用问题长期缺乏根源性管控手段。 • 智能体内生安全防护范式缺失：现有智能体权限防护多为外挂式策略拦截、事后审计追溯的被动防护模式，安全管控与智能体协同调度、工具调用、任务推理的业务流程相互解耦。外部式安全校验无法深度介入模型推理与行为决策环节，难以抵御权限滥用、上下文记忆污染、跨智能体横向权限传导等内生安全风险 [944]。行业尚未构建“协同即安全”的内生防护范式，无法从流程根源上约束智能体的不安全行为，导致各类权限类安全问题反复出现、难以根治。	• 建立面向机器身份的原生最小权限体系，适配智能体自主运行特性，从根源上遏制权限泛滥 • 设计“协同即安全”的内生防护范式，将安全管控能力原生融入多智能体协同流程 • 构建机器身份全生命周期安全治理体系，实现身份认证、权限管控、行为审计全流程闭环
国产安全编排与工程化能力短板	• 国产化安全编排中间件缺失：当前国内多智能体安全治理生态尚未形成成熟、统一的国产化安全编排中间件体系，现有智能体安全能力、策略管控逻辑、跨节点调度机制普遍碎片化、零散化，缺乏标准化的协同整合底座 [1089]。主流多智能体编排框架多基于海外开源生态构建，侧重任务流程调度，未内嵌安全编排、策略联动与风险协同管控能力，无法对异构智能体的防护规则、访问权限、风险拦截策略进行全局统一调度与联动适配，难以形成一体化、闭环式的全域安全管控能力 [1087]。国产自研中间件在多智能体安全协同场景的适配能力仍存在明显空白，制约国产化智能体集群体系化落地。 • 高并发场景风控降级与安全旁路问题突出：现有多智能体安全编排机制多采用全量串行校验逻辑，安全审计、风险检测、策略匹配环节算力开销高、转发时延大，在大规模集群高并发协同推理场景下极易引发系统吞吐瓶颈 [1090]。为保障核心业务 SLA 稳定，工程部署中常被简化安全校验粒度、关闭深度风险检测模块，形成高负载下的安全旁路缺陷，导致注入攻击、越权调用、隐性数据泄露等风险无法被有效拦截，规模化集群运行的安全防护稳定性难以保障。 • 异构算力安全调度能力不足：国产化信创环境算力节点分散、硬件规格异构、推理性能差异显著，现有通用安全编排体系未针对国产异构算力集群设计专属的安全感知调度机制。传统调度策略仅关注任务吞吐效率，未兼顾算力负载均衡、传输安全隔离、节点风险差异化管控，导致国产算力资源利用率偏低、跨节点 IO 交互瓶颈突出，同时存在算力过载引发的安全策略失效、节点隔离不彻底等隐患，无法支撑大规模多智能体集群安全、稳定、高效的常态化运行。	• 研发国产化统一安全编排中间件，实现多智能体安全能力的统一编排与协同管控 • 构建高并发场景下的动态安全调度机制，规避风控降级与安全旁路问题，保障极端场景下的安全防护能力 • 搭建适配国产算力的异构算力安全调度底座，实现算力资源的高效利用与安全管控

6.3 基于 AI 智能体的漏洞挖掘与修复体系研究

相较于传统静态代码检测、人工漏洞整改的低效治理模式，智能体漏洞治理技术可通过动态推演、自主修复、批量迭代的特性，显著提升代码安全运维的整体效率。但在复杂的工程落地场景中，该技术仍存在明显的技术短板与落地瓶颈，普遍存在漏洞修复精度有限、多模型协

同稳定性不足、补丁安全可靠难以保障、国产化工程场景适配性较差等问题。基于此，本节系统梳理 AI 智能体在漏洞挖掘与修复领域的核心挑战，具体如下（详见表 6.3）：

- **复杂耦合漏洞修复精度不足，全局泛化能力薄弱。**现有漏洞修复智能体依赖语法匹配与模板补丁，缺乏深层语义与数据流推理能力，难以修复跨模块高耦合漏洞，易产生伪修复问题 [1099], [1100]。模型依赖历史样本，对零日漏洞与新型攻击推演能力不足，漏修错修频发 [1101]。此外，模型跨语种、跨架构适配性差，且无法适配规范混乱、逻辑复杂的企业私有化老旧存量工程，定制化场景修复泛化能力严重不足 [1102]。
- **多智能体协同治理不稳定，闭环一致性较差。**异构智能体推理逻辑与判定标准不统一，缺少语义对齐与互洽校验机制，易出现结论冲突、流程脱节问题 [1103], [1104]。高并发场景下智能体调度容错能力有限，易引发任务拥堵、重复修补与流程中断，难以实现稳定闭环治理。
- **自动化补丁存在次生安全与稳定性风险。**现有修复体系重效率、轻校验，缺乏完备的兼容性与安全审计机制，补丁迭代易引发版本冲突、接口异常与业务篡改等故障 [1105], [1106]。体系缺少集群级回滚自愈能力，无法有效收敛批量修复带来的安全风险。
- **国产化落地受限，精度与成本存在结构性矛盾。**国产代码大模型对复杂高危漏洞的修复精度不及海外顶尖模型，难以适配工业级高标准治理场景。同时高精度模型算力成本高昂，轻量化模型能力衰减严重，且现有技术体系对本土软硬件环境适配不足，无法形成自主可控的漏洞治理能力。

表 6.3: AI 智能体漏洞挖掘与修复研究现状与发展趋势

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
复杂漏洞修复精度不足	• 语义级业务逻辑漏洞修复能力欠缺：现有漏洞修复智能体多依赖表层语法匹配与模板补丁生成，缺乏对业务耦合关系、状态联动与隐式数据流的深层语义推理能力，难以彻底修复高耦合业务漏洞，易引发伪修复与隐性功能缺陷 [1099]。语义增强方法虽可缓解语法过拟合问题，但高度依赖开源标准数据集，对企业私有业务与非标标准化存量代码泛化能力较弱，复杂漏洞修复稳定性不足 [1100]。主流商用修复工具仍以浅层规则匹配为主，缺乏复杂业务逻辑推演与语义等价修复能力。 • 跨模块耦合漏洞全局溯源能力薄弱：跨模块漏洞存在链式数据流与函数调用依赖，传统单文件修复仅能处理表层问题，无法实现全局根因定位与闭环治理。AutoCodeRover 依托静态调用图提升了跨模块识别能力 [1105]，但现有图辅助方案构建开销大、轻量化不足，难以适配大型工程迭代场景，无法精准捕捉远距离隐性关联漏洞 [1107]。Snyk AutoFix、JetBrains AI 等工业工具仍局限于单文件静态修复，缺失跨模块链路分析与全局治理能力，难以处理复杂耦合漏洞 [1108], [1109]。 • 零日 (0day) 新型漏洞泛化修复性能受限：现有修复模型高度依赖历史标注样本与已知漏洞范式，对全新攻击逻辑的零日漏洞自主推演能力存在明显瓶颈 [1110]。检索增强框架虽可提升变异漏洞适配效果，但泛化边界有限，难以适配新型攻击范式与企业私有定制化零日漏洞场景 [1111], [1112]。主流商用工具均基于静态特征库匹配，无法自主推演新型漏洞逻辑，在零日场景下漏修、错修问题突出。 • 跨语种跨架构漏洞适配性较差：当前主流代码大模型与漏洞修复框架多基于单一主流编程语言、标准化开源工程架构训练，对多语种异构代码、差异化硬件架构、底层编译差异的语义建模能力不足，跨语种、跨架构场景下漏洞识别与修复一致性显著下降 [1102]。现有多语言代码增强模型仅优化表层语法适配，未针对异构架构底层运行逻辑、编译链路差异做专项建模，在跨平台复杂工程中修复稳定性差、适配错误频发 [1113]。JetBrains AI、Microsoft Copilot 等商用智能修复工具语种与架构适配边界有限，难以满足多技术栈异构工程的多样化修复需求。	• 构建代码语义与数据流协同解析机制，实现复杂业务漏洞精准诊断与安全修复 • 引入动态依赖图谱建模方法，实现大型工程跨模块耦合漏洞的全局治理 • 建立零日漏洞自主推演与自适应修复机制，突破模型对历史样本的依赖瓶颈 • 搭建跨语种、跨架构统一代码语义表征模型，大幅提升跨场景泛化修复能力

续下页

表 6.3 – 续上页

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
多智能体协同闭环不稳定	• 全链路治理流程协同对齐度不足：漏洞全流程治理由异构智能体分工完成，不同环节智能体推理逻辑独立割裂，易出现流程脱节、判定结论冲突问题。现有分层流水线式多智能体治理框架虽通过任务拆分实现了漏洞治理流程的模块化拆解与分步落地，但普遍未建立跨环节逻辑对齐与结果互洽校验机制，分段治理模式难以保障整体闭环一致性 [1103]。工业界阿里云漏洞自愈系统、腾讯朱雀 AI 安全平台均采用分段自动化治理架构，各治理环节独立运行，缺乏统一协同校验逻辑，存在流程割裂与结论不一致问题 [596], [1114]。分段独立治理导致上下游任务状态不同步，极易产生治理断点与流程空转现象。缺乏全局闭环监控与状态同步机制，无法实时修正多环节累积的协同偏差。 • 异构智能体漏洞判定标准不统一：不同功能智能体的代码表征方式、风险判定阈值、漏洞评价体系存在天然差异，异构智能体协同决策过程中极易出现判定偏差与结论分歧。现有语义对齐与漏洞统一表征方法仅针对通用开源漏洞场景优化，对企业场景下的定制化业务漏洞、私有逻辑漏洞表征对齐效果有限，难以支撑多智能体之间的精准判定共识 [1115]。同时，主流商用智能体安全工具多为闭源私有架构，行业缺乏统一的漏洞判定规范，跨平台、跨智能体的协同联动能力严重缺失 [717]。差异化判定阈值会引发同一漏洞多源结论矛盾，造成重复治理或漏治理问题。 • 高并发批量治理调度容错性差：大规模批量漏洞治理场景下，多智能体并发调度易产生任务拥堵、上下文丢失、资源抢占冲突等异常问题。当前主流多智能体调度与协同优化框架仅能小幅提升并发处理吞吐量，但在异常重试、冲突消解、故障回滚等容错机制上设计不完善，高负载批量治理场景中频繁出现任务失效、补丁重复生成、治理流程中断等稳定性问题 [1104]。OpenAI Aardvark 安全智能体 [1116]、华为智能运维修复平台在大规模批量漏洞治理任务中，均存在容错能力不足、并发稳定性差的显著短板。	• 构建全链路智能体逻辑对齐与互洽校验机制，实现检测、研判、修复、验证一体化闭环治理 • 设计通用漏洞表征体系与统一判定标准，搭建异构智能体交叉共识协同架构 • 引入高并发自适应调度与容错机制，提升大规模批量漏洞治理的稳定性与可靠性
补丁安全与稳定性缺陷	• 补丁兼容性与业务一致性校验缺失：当前智能体漏洞修复体系普遍优先保障补丁生成效率，缺乏系统化、多维度的兼容性与业务一致性校验机制，补丁迭代极易引发接口适配冲突、版本依赖不兼容、业务逻辑篡改等次生稳定性问题。基于 OSS-Fuzz 的智能体修复框架可依托模糊测试能力检测内存损坏类高危漏洞并完成基础修复，但仅聚焦内存安全校验，无法覆盖接口兼容性、跨版本依赖一致性、业务逻辑等价性等深层次校验场景，对隐性业务兼容风险识别能力不足 [1105]。现阶段 GitLab AI 智能修复工具、360 安全大脑自愈修复模块均采用轻量化自动补全修复逻辑，未搭建标准化补丁兼容性与业务一致性验证流程，修复后系统整体业务稳定性难以得到有效保障 [1117]。 • 修复后业务性能风险管控不足：漏洞补丁与代码重构会改写原有程序执行链路、资源调度逻辑与并发调用方式，极易引入隐性性能损耗、线程阻塞、资源占用激增、吞吐量下降等业务风险。现有自动化修复校验方案仅针对小规模单体程序开展基础性能检测，难以适配微服务集群多链路、多节点的复杂调用场景，无法精准预判批量补丁迭代引发的隐性性能瓶颈与集群级性能退化问题 [1118]。主流商用自动化漏洞修复工具普遍缺失专项性能审计、并发校验与资源开销评估模块，补丁引入的性能风险长期处于无标准化管控状态。 • 自动化修复故障应急恢复能力薄弱：批量智能化漏洞修复场景中，易出现错误补丁写入、合法业务逻辑误篡改、依赖链路异常中断等治理故障。现有代码回滚与容错方案仅支持单文件、局部代码的静态撤销恢复，无法适配微服务集群多服务联动、多节点耦合的复杂业务场景，批量故障连锁触发时难以实现全域、极速的业务回滚与故障收敛 [1106]。工业界主流安全修复平台仍依赖人工甄别故障补丁与手动回滚操作，缺失智能化、自动化、集群级的应急处置与自愈恢复机制，批量治理故障容错能力薄弱。	• 建立多维度补丁校验体系，全覆盖接口适配、版本兼容、依赖一致性安全验证与业务逻辑等价性校验 • 增设修复后性能与并发安全审计机制，精准规避补丁引入的隐性性能损耗、集群阻塞与资源异常风险 • 构建风险分级处置与集群自动化极速回滚机制，保障大规模批量修复场景下的业务连续稳定运行

续下页

表 6.3 – 续上页

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
国产化落地与成本约束	• 国产模型复杂漏洞修复精度偏低：当前国产代码大模型在深度代码逻辑推理、高危复杂漏洞定位、语义等价补丁生成等核心能力上，整体与 GPT-4 等海外顶尖模型存在显著代差，面对业务耦合度高、触发链路复杂的高危漏洞修复精度不足、误修复率偏高。以通义千问、CodeLlama-Chinese 为代表的国产代码安全模型虽持续迭代优化代码治理能力，但在复杂 CVE 高危漏洞、多层嵌套逻辑漏洞场景下修复准确率显著低于海外闭源模型，工业级复杂业务适配稳定性不足。百度、科大讯飞等商用国产安全平台仅对通用基础漏洞具备稳定修复能力，缺失高端、复杂漏洞的系统化治理能力。 • 轻量化修复模型能力与成本难以平衡：千亿级通用代码大模型推理算力开销极高，无法支撑企业大批量、常态化批量漏洞治理场景；而轻量化小参数量模型虽部署成本低、推理速度快，但存在代码理解能力碎片化、深层漏洞推理不足的问题。现有轻量化代码修复方案普遍存在能力衰减问题，在复杂漏洞场景下修复精度大幅下滑，行业长期存在“高精度依赖大算力、低成本牺牲精度”的结构性矛盾，缺少可落地的高精度、低开销一体化修复架构。 • 国产信创生态适配体系不完善：海外主流智能体漏洞修复框架受技术壁垒、出口管制约束，无法在国内政企信创环境合规落地，同时与国产算力芯片、操作系统、中间件体系适配性差，存在技术断供与数据跨境合规风险。国内现有自动化漏洞修复技术方案零散、技术标准不统一、生态兼容性参差不齐，尚未形成全栈的智能漏洞治理技术底座，难以满足政企信创替代、合规落地与安全自主可控的建设要求。	• 持续迭代国产大模型专项安全修复能力，补齐复杂高危漏洞治理精度短板 • 构建多专用小模型集成推理架构，实现治理精度与算力成本的动态平衡 • 打造适配国产算力与信创生态的全栈可控漏洞修复治理底座

6.4 多模型集成安全推理体系研究

相较于单模型独立推理，多模型集成具备任务适配精细、能力互补、场景泛化性强等优势，但仍存在异构协同不一致、动态调度精度不足、迭代泛化能力弱、国产化适配差与网关合规管控缺失等体系化短板。本节梳理多模型集成安全推理领域的核心挑战，具体如下（详见表 6.4）：

- **异构模型协同结果不稳定，幻觉容易在模型间传播**。不同模型在特征表示、判断标准和风险阈值等方面存在差异。当系统缺少统一的结果对齐、交叉验证和冲突处理机制时，各模型给出的结论可能相互矛盾，并进一步造成漏判或误判。与此同时，面向单一模型设计的幻觉抑制方法往往难以直接用于多模型协同环境，局部错误可能随着模型间的多轮交互被反复引用和强化，最终影响整体推理结 [1119], [1120]。在代码漏洞分析中，这一问题更为突出。模型有时虽然能够给出看似合理甚至正确的判断，但其推理过程可能依赖错误信息或表层特征，难以准确反映漏洞的真实成因，进而影响漏洞定位和后续自动修复的可靠性 [1121]。
- **动态任务路由匹配精度低，高并发调度开销过大**。现有调度体系多采用静态路由规则，难以实现安全任务与专用模型的动态精准匹配，存在模型错配、资源冗余、推理低效等问题。异构模型频繁交互聚合带来显著通信与计算开销，高并发批量治理场景易出现任务阻塞、时延堆积、调度稳定性不足等工程瓶颈 [1122], [1123]。固定调度策略无法适配攻防任务动态波动特征，极易造成算力资源结构性浪费。
- **国产化工程适配不足，轻量化落地存在性能瓶颈**。主流集成调度框架基于海外 CUDA 生态搭建，未针对国产算力与自研代码模型深度适配，国产模型推理性能无法充分释放。轻量化方案未兼顾多模型并发交互开销，单模型成本优势被调度损耗抵消，且海外架构存在技术断供与数据跨境风险，国内尚未形成全栈自主可控的推理安全底座 [1124]。软硬件适配断层导致轻量化安全推理方案量产落地效果差、稳定性难以保障。

表 6.4: 多模型集成安全推理体系研究现状与发展趋势

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
异构模型协同推理一致性不足	• 异构模型风险判定逻辑不统一: 多模型集成安全架构中, 异构模型在特征表征、风险阈值与评价体系上存在固有差异, 联合推理易出现结论冲突、漏判误判、一致性缺失等问题 [1119]。现有对齐方案仅适用于通用开源漏洞场景, 对企业定制业务与私有协议漏洞的对齐精度不足, 难以形成稳定跨模型决策共识 [1125]。主流商用集成平台多采用串行独立调用模式, 缺乏标准化跨模型逻辑对齐与互洽校验机制, 推理结果离散度高。 • 多模型联合推理协同机制缺失: 现有安全集成体系多采用简单串行或并行独立推理, 缺少多模型交叉验证与逻辑同步机制, 无法修正单模型推理偏差, 易造成高危漏洞决策失效与治理漏损 [1103]。现有分层架构仅实现任务模块化拆分, 未建立跨模型推理联动与结果同步能力, 全局决策链路割裂, 难以保障漏洞判定与修复的闭环一致性, 工业平台普遍缺乏多模型共识协同治理能力。 • 模型幻觉在协同推理中容易传播: 多模型集成并不会自然消除单个模型的判断偏差。当错误结论被后续模型直接采纳时, 局部幻觉可能随着多轮交互不断传播和强化, 进而增加整体安全判断的误差 [1120]。现有幻觉抑制方法大多面向单模型设计, 在多模型协同环境中, 对模型间结论冲突、错误引用和偏差累积的处理仍不充分 [1119]。当前集成架构普遍缺少稳定的交叉验证、证据核查和分歧处理机制。在复杂漏洞分析中, 模型可能依据表层特征或错误推理给出看似合理的判断, 进而影响漏洞定位和自动修复结果的可靠性 [1121]。 • 小样本场景过拟合与灾难性遗忘问题突出: 多模型联合训练极易在小众漏洞场景出现过拟合问题, 对新型攻防范式泛化能力显著下降 [1126]。同时在增量持续迭代过程中, 多模型权重更新易覆盖历史有效参数, 引发严重的灾难性遗忘问题, 导致模型对存量经典漏洞的检测与修复能力持续退化 [1127]。现有增量微调、参数固化等防遗忘策略多针对单模型场景设计, 未适配多模型集成联动迭代场景, 无法解决多模型联合训练的知识遗忘与能力退化问题。	• 建立异构模型表征对齐与交叉验证机制, 统一风险判定标准, 消除推理结论冲突 • 构建多模型协同共识推理机制, 实现跨模型逻辑同步, 提升整体决策一致性 • 设计多模型联动幻觉抑制机制, 通过交叉校验削减模型推理幻觉偏差 • 构建多模型协同持续学习机制, 实现新旧任务能力协同迭代, 兼顾新型场景适配与存量场景推理能力
任务路由与调度匹配精度低	• 任务-模型精准匹配能力欠缺: 现有多模型安全架构多采用静态规则路由, 难以实现差异化安全任务与专用子模型的精细化适配, 易出现模型错配、冗余调用等问题, 降低批量漏洞治理的实时性与资源利用率 [1122]。主流路由框架仅基于通用特征分配模型, 未针对漏洞检测、定位、修复等细分任务专项优化, 复杂场景匹配精度不足, 难以满足工业级实时调度需求 [1128]。商用安全平台普遍采用固定路由策略, 缺乏动态择优适配能力, 无法依据任务复杂度、风险等级进行动态模型择优调度, 整体推理容错能力较差。固定匹配模式极易造成高精度模型资源浪费与轻量任务算力冗余配比问题。 • 多模型通信与调度开销过大: 异构多模型协同推理需频繁交互特征与聚合结果, 产生大量通信与计算冗余, 高并发场景下易引发任务排队、接口超时与推理阻塞, 严重制约漏洞治理实时性 [1123]。现有调度优化仅小幅提升吞吐, 未针对多模型联动场景优化交互链路, 高负载下时延堆积与调度瓶颈突出 [1129]。当前体系普遍缺少轻量化调度与资源节流机制, 高并发适配能力薄弱。多模型重复数据传输、无效特征同步进一步加剧带宽资源浪费, 放大系统负载压力。传统轮询调度策略无法区分安全推理任务优先级, 高危处置任务易被普通业务挤占资源。 • 动态风险场景路由适配性差: 现有路由策略多为静态固化逻辑, 依赖已知任务特征, 无法感知动态风险变化, 面对新型攻击与零日漏洞易出现路由失效、模型适配错位等问题 [1130]。通用自适应路由框架未结合安全推理高动态、强实时的业务特性定制优化, 无法实现风险驱动的动态策略迭代 [1131], 难以适配攻防场景动态演化规律, 未知风险调度能力缺失。静态路由规则迭代滞后于攻防技术演进, 极易形成长期固定的调度防护盲区。风险与模型的匹配逻辑僵化, 无法根据攻击烈度、任务紧急度动态调整推理资源配比。	• 构建风险自适应路由机制, 实现任务与模型动态精准匹配, 提升推理效率与资源利用率 • 设计轻量化通信调度架构, 削减交互冗余开销, 提升高并发场景推理稳定性 • 建立动态风险感知路由策略, 适配新型攻击与未知漏洞的自适应调度更新 • 搭建多级任务优先级调度体系, 保障高危安全推理任务优先抢占系统资源

续下页

表 6.4 – 续上页

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
国产化工程适配与落地能力缺陷	• 国产算力与模型适配性不足：当前主流多模型集成与智能体调度框架大多基于海外 CUDA 生态与异构计算架构研发，未针对国产算力芯片、国产代码大模型的推理特性进行深度适配优化，导致通义千问、DeepSeek 等国产安全代码模型的推理潜能无法充分释放，漏洞检测与修复的综合性能普遍低于海外模型部署效果。现有国产代码安全模型虽在通用漏洞治理能力上持续迭代升级，但行业内缺乏配套的国产化多模型协同调度与适配框架，模型能力无法在集成推理体系中高效发挥，适配落地成本高、收益低。 • 轻量化调度工程性能瓶颈突出：现有通用轻量化大模型推理方案仅针对单模型推理场景做算力精简优化，未考虑多模型并发联动、频繁特征交互、跨模型结果聚合的工程开销，在大规模批量漏洞治理高并发场景下，普遍存在算力资源利用率偏低、IO 交互频繁阻塞、多任务资源抢占失衡等工程瓶颈 [1124]。轻量化模型单卡推理的成本优势，在多模型集成调度场景下被大量通信冗余与调度损耗抵消，难以支撑企业级大规模、高并发智能漏洞治理任务常态化落地。 • 信创生态合规适配性差：海外多智能体、多模型协同框架受技术壁垒、芯片出口管制与生态垄断限制，无法在国内政企信创环境合规部署，同时与国产操作系统、国产算力集群存在底层兼容性缺陷，存在数据跨境泄露与核心技术断供风险。国内现有智能漏洞修复技术体系碎片化严重、技术标准不统一，尚未形成全栈自主可控的多模型安全推理底座，缺乏适配信创软硬件生态的一体化调度、治理与运维能力，难以满足政企关键业务的合规落地与安全自主可控要求 [1124]。	• 搭建国产化模型集成调度底座，联动智能体安全治理体系，结合国产软硬件优化调度性能，提升国产算力利用率 • 设计轻量化、低开销的多模型协同调度架构，解决 IO 瓶颈与资源失衡问题，支撑大规模高并发安全推理任务落地 • 打造适配国产算力与信创生态的全栈可控多模型安全推理体系，满足国内合规落地要求

6.5 国产化多模型聚合安全网关研究

多模型聚合安全网关是智能体集群调度、风险拦截与合规审计的核心枢纽，保障多模型协同推理安全可控与国产化合规落地。但现有境外网关与国内自研体系存在诸多技术缺陷，难以支撑大规模国产化智能体安全治理。基于此，本节梳理国产化多模型聚合安全网关的核心挑战，具体如下（详见表 6.5）：

- **境外网关合规可控性弱，原生防护能力缺失**。境外闭源网关存在数据跨境、服务断供风险，不符合国内合规要求，且仅支持基础流量转发，缺乏智能体专项安全防护能力，难以抵御注入、越权与数据泄露风险 [1132]。同时国内外模型接口、鉴权与加密体系差异较大，现有网关适配性不足，易出现鉴权绕过、调用异常与安全链路断裂问题，缺乏国产模型专属适配能力，严重制约国产化安全体系落地 [1133]。
- **动态风险感知与国产算力调度能力不足**。现有网关依赖静态路由，无法依据任务风险动态调度，对新型攻击与未知漏洞适配能力有限。同时缺乏国产算力负载均衡机制，算力分配失衡，且无敏感任务精细分流能力，难以满足政企分级合规管控需求 [1134], [1135]。
- **安全防护与业务性能存在固有冲突**。全链路安全校验会增加推理时延、损耗性能，高并发场景下常被迫降级安全策略，形成防护旁路。传统校验机制无法适配智能体长会话交互，时延累积、资源开销大，难以兼顾安全管控与低时延业务运行 [1136], [1137]。
- **信创适配薄弱，全栈可控治理体系未成**。现有网关基于海外生态研发，对国产软硬件信创设施适配性差、稳定性不足。国产算力调度优化缺失，资源利用率低，国内尚未形成算力、模型、网关、应用一体化的自主可控安全底座，技术标准零散，难以支撑规模化智能体安全运营。

表 6.5: 国产化多模型聚合安全网关研究现状与发展趋势

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
境外网关安全与合规缺陷	• 数据跨境与合规风险突出：以 OpenRouter 为代表的境外通用多模型聚合网关采用海外集群转发架构，模型推理输入输出数据、业务敏感日志存在天然跨境流转链路，无法满足国内《网络安全法》《数据安全法》对政企数据境内闭环留存、全生命周期合规审计的硬性监管要求，在政务、金融、能源等关键基础设施智能体治理场景中存在极高合规处罚与数据泄露风险。2025-2026 年多项实证研究表明，境外通用 LLM 网关普遍缺失国产化合规审计链路，无法适配国内数据出境评估与本地化留存规范，企业直接接入使用将长期处于监管不合规状态。 • 服务断供与技术壁垒风险：境外多模型聚合网关平台受国际出口管制、地缘政治政策与海外商业运营策略约束，存在接口随机变更、访问权限封禁、批量服务关停等不确定性风险，严重威胁国内智能体漏洞治理业务的连续性与系统稳定性。同时境外网关核心调度架构、流量管控逻辑、安全拦截机制均为闭源黑盒体系，国内团队无法掌握底层核心技术，存在严重的技术依赖与卡脖子问题，完全无法适配信创环境自主可控、可迭代、可运维的落地要求。 • 原生安全防护能力缺失：境外通用模型聚合网关的核心定位为跨模型流量转发与接口统一适配，并未针对智能体自动推理、批量漏洞修复、长会话协同治理等场景设计专属安全防护能力 [1132]。面对 Prompt 注入攻击、敏感代码数据泄露、越权模型调用、恶意参数篡改等智能体高频风险，境外网关无原生识别、拦截与溯源能力，整体安全防护完全依赖上游大模型基础机制，防护粒度粗、容错能力弱，无法构建智能体全流程、全域化的安全管控体系 [560]。 • 多模型接口规范归一化难度高：当前国内外开源、商用、国产自研大模型的接口请求格式、参数定义、鉴权字段、流式响应规范存在显著碎片化差异，不存在统一的行业强制标准，多模型聚合网关需要适配多套异构接入范式，极大提升了集成适配成本与运维复杂度 [1133]。在多模型协同推理场景中，接口格式不统一极易引发参数解析异常、请求适配失败、鉴权绕过等隐性漏洞，造成模型调用中断、推理任务异常、权限管控失效等治理故障 [1138]。现有通用网关适配方案仅做浅层格式兼容，未实现标准化、可复用的异构接口统一治理能力。	• 构建全链路数据境内闭环流转机制，实现模型调用数据全生命周期合规管控，满足国内监管要求 • 打造全栈自主可控的网关技术架构，彻底摆脱境外技术依赖，规避服务断供风险 • 设计智能体场景原生安全防护体系，实现模型调用全流程风险识别与拦截 • 设计统一的模型接口归一化规范，实现国内外异构模型接口的无缝适配与标准化管理
动态风险调度路由适配能力不足	• 固定路由无法适配动态风险场景：现有多模型网关路由体系普遍依赖静态规则与固定阈值策略，仅基于模型类型、请求路径等表层维度完成分发，无法结合任务语义、风险等级、攻击特征动态调整路由逻辑，面对新型变异攻击与动态风险场景适配能力严重不足 [1134]。实证研究表明，传统固定路由机制存在明显的调度性能瓶颈，仅能适配常规标准化请求，难以对高风险、高敏感、非常规漏洞治理任务实现精准定向分流与重点安全管控，高风险任务易被误分配至低防护模型，引发安全逃逸风险 [1139]。 • 异构算力分散场景调度失衡：国产化信创环境下算力节点分散、硬件规格异构、推理负载差异大，传统静态路由算法缺乏实时算力感知能力，无法动态采集节点负载、模型健康状态、网络传输时延等多维运维指标。固定分发策略极易造成部分算力节点过载拥堵、部分节点长期闲置的资源割裂问题，无法实现全局负载均衡与算力动态择优调度，大幅降低批量漏洞治理场景下的整体算力利用率与任务吞吐效率 [1140]。 • 敏感任务定向分流能力缺失：当前主流 LLM 路由网关缺少任务级细粒度敏感语义识别能力，无法精准解析请求内的涉密代码、隐私数据、高危操作与合规约束场景，不具备基于内容风险的差异化分流调度能力 [1135]。所有任务均采用无差别通用路由分发模式，敏感业务任务无法定向调度至私有化算力、国产合规模型或离线隔离环境，极易引发敏感数据外泄、业务合规违规等治理隐患，无法满足政企安全分级分类的精细化管控要求。	• 构建风险驱动的自适应动态路由机制，根据任务风险等级与场景需求动态调整路由策略 • 设计算力感知的智能调度算法，实现异构算力资源的均衡负载与高效利用 • 研发敏感任务精准识别与定向分流能力，实现分级分类的差异化安全管控

续下页

表 6.5 – 续上页

研究难点	现有技术现状、存在问题与技术瓶颈	研究趋势
安全防护与业务性能的工程冲突	• 安全模块嵌入引发性能损耗：多模型网关接入安全校验、风险检测和合规审计后，会增加模型调用与转发时延，影响漏洞治理的实时性 [1136]。相关研究显示，完整防御链路可使整体效用最高下降 29%，高并发时还可能造成请求堆积和接口超时 [1141]。 • 高并发场景下安全校验被动降级：大规模智能体集群高并发批量推理场景中，网关为保障核心业务吞吐量与服务 SLA 稳定，普遍存在被动简化安全策略、关闭高精度校验模块的运维妥协行为，形成高负载下的“安全旁路缺陷” [1137]。高开销的语义级风险检测、深度注入识别、全量日志核验等防护模块被动态裁剪后，网关仅保留轻量化基础过滤能力，高危 Prompt 注入、隐性越权调用、隐蔽数据泄露等风险无法被有效拦截，造成极端流量场景下安全防护体系整体性降级。 • 长会话安全管控与实时性矛盾：智能体多轮交互、长会话持续治理场景下，网关需要实时维护会话上下文状态、持续校验链路安全、动态拦截迭代式隐性注入攻击，持续性的上下文安全核验与状态监控会产生稳定叠加的性能开销 [1142]。现有网关防护体系多采用全量持续校验机制，未针对长会话场景做轻量化优化，持续安全管控带来的时延累积、资源占用过高问题突出，无法同时满足长周期安全可控与业务低时延运行的双重需求，安全与实时性的工程矛盾难以调和。 • 安全协议跨架构适配性差：不同模型生态与国产算力、软件栈在传输协议、身份鉴权和加密机制上存在差异。网关进行协议转换和数据转发时，可能出现加密链路中断、校验失效或鉴权状态丢失，进而带来数据篡改、中间人攻击和会话越权等风险 [680]。	• 优化安全校验调度，采用并行检测和异步审计，降低防护时延。 • 完善高并发下的安全降级与熔断机制，保留关键防护能力。 • 设计长会话轻量化管控方案，减少持续监测带来的性能开销。 • 加强跨架构协议适配，保证模型调用中的加密与鉴权有效。
国产化信创生态适配板	• 国产软硬件体系适配性不足：当前主流多模型聚合网关与智能调度框架大多基于海外 x86 架构、CUDA 推理生态与通用操作系统研发，未针对国产 CPU、国产服务器操作系统、自主可控中间件等信创软硬件体系开展底层适配优化，软硬件兼容性缺陷突出，在政企全信创内网环境中易出现服务异常闪退、推理链路中断、接口适配失效等稳定性问题，难以满足关键行业信创替代与合规落地要求。现有通用网关体系普遍存在信创适配碎片化、底层兼容补丁缺失的问题，无法实现全环境稳定部署运行。 • 国产算力调度优化能力缺失：现有智能网关调度机制沿用海外算力集群调度逻辑，未适配国产异构算力的芯片架构、推理算子特性与通信协议规范，缺乏针对性的算力负载适配、IO 吞吐优化与推理链路调优能力。在规模化国产算力集群部署场景中，普遍存在算力资源碎片化、节点负载不均衡、IO 交互瓶颈突出等问题，算力整体利用率显著低于海外 GPU 集群，高并发批量推理场景下的业务吞吐能力与响应时延存在明显性能差距，无法充分释放国产算力集群的推理效能 [1143]。 • 全栈可控安全治理体系未形成：国内智能体安全治理领域长期存在技术体系零散、行业标准不统一、各层级能力割裂的痛点，尚未构建起覆盖底层国产算力、自研大模型、安全网关调度、上层智能体应用的全栈自主可控安全治理底座。各环节安全防护、风险管控、合规审计能力相互独立，缺乏统一的协同联动与策略同步机制，无法形成全域闭环的智能体安全治理能力，难以支撑大规模、体系化的国产化智能体漏洞治理与安全运营需求 [689]。	• 完成全栈信创软硬件适配，实现国产 CPU、操作系统、中间件的全兼容与稳定运行 • 针对国产算力架构做专项调度优化，提升国产算力利用率与业务处理性能 • 打造全栈可控的智能体安全治理体系，实现各环节安全能力协同联动

第 7 章 总结

本报告围绕 AI 智能体全生命周期安全展开，覆盖需求分析、架构设计、编码开发、安全测试、部署交付、迭代运行和退役销毁七个阶段。通过梳理各阶段的研究与实践，总结主要风险、落地难点及现有防护思路，并结合典型攻防案例分析未来发展趋势。

未来研究发展趋势：未来 AI 智能体安全建设需打通全生命周期安全管控链路，统筹技术防御框架迭代、合规监管落地、行业标准完善三大维度，构建技术与制度协同联动的一体化防护体系。该领域主要研究发展趋势如下：

- **大规模自主协同多智能体系统安全研究：**单体大模型不具备规模化协同管控能力，现有多智能体架构存在交互安全规范缺失、集群涌现风险不可控、决策溯源困难、权限体系适配不足等问题，易引发链式越权与数据泄露风险。同时海外架构存在数据跨境、技术受限等隐患，难以满足国内合规落地要求。开展多智能体安全研究，可有效解决集群协同安全治理难题，完善国产化管控能力，为智能体规模化安全部署提供重要支撑。
- **AI 智能体漏洞挖掘与修复体系研究：**传统漏洞治理重检测、轻修复，人工整改成本高、闭环效率低，且海外高端修复模型存在落地限制。现有智能体仅能处理简单漏洞，对复杂漏洞识别不准、修复稳定性差、多模块协同混乱，难以满足批量安全整改需求。因而该研究可实现漏洞全流程智能闭环治理，大幅降低运维成本、提升漏洞自愈能力，对提升软件安全自动化水平具有重要实用价值。
- **多专用小模型集成安全推理体系研究：**海外高阶安全模型落地受限，国内通用大模型算力开销大、幻觉问题突出、私有化部署难度高。单一安全小模型能力薄弱、场景覆盖有限，多模型协同推理存在判定不一致、适配性不足等缺陷。开展多小模型集成推理研究，可低成本、高精度实现安全风险研判，抑制模型幻觉、适配涉密私有化场景，是国产化智能体安全推理能力落地的重要可行方案。
- **国产化多模型聚合安全网关研究：**境外模型网关存在数据跨境、防护缺失、服务不可控等风险，与国内信创合规体系不兼容。现有网关安全调度能力薄弱，无法兼顾业务性能与长会话安全管控，难以支撑智能体全域风险拦截与审计治理。国产化安全网关研究可补齐模型调用安全管控底座短板，规避外部技术依赖，为智能体的合规安全、规模化提供基础保障。

报告局限性：受调研周期、公开数据体量、行业高速迭代特性及研究边界约束，本报告存在以下不足：一是研究聚焦智能体安全防控与合规治理，未覆盖通用智能体完整技术体系，研究维度具备针对性但完整性有限；二是调研样本集中于国内及欧美头部高校、企业，缺失国外重点国家实验室及日韩新等亚太地区的相关研究与产业技术资料，无法完成全球多技术路线的横向对比分析；三是智能体安全领域尚处于高速发展初期，核心参考文献多为 2025—2026 年未刊预印本，存在实验可复现性弱、研究范式不统一、攻防验证不充分等问题。后续将补充全球前沿研究成果、完善通用智能体技术框架、扩充落地实证数据，持续优化研究体系与结论。

参考文献

期刊论文

- [3] S. Raza, R. Sapkota, M. Karkee, and C. Emmanouilidis, “Trism for agentic AI: A review of trust, risk, and security management in LLM-based agentic multi-agent systems,” *AI Open*, vol. 7, pp. 71–95, 2026.
- [4] K. Lazaros, A. G. Vrahatis, and S. Kotsiantis, “Human-in-the-loop artificial intelligence (AI): A systematic review of concepts, methods, and applications,” *Entropy*, vol. 28, no. 4, p. 377, Apr. 2026.
- [10] W. L. Currie, J. M. Leimeister, D. Schlagwein, and L. Willcocks, “Rethinking technology regulation in the age of AI risks,” *Journal of Information Technology*, vol. 40, no. 3, pp. 236–245, Sep. 2025.
- [11] B. Judge, M. Nitzberg, and S. Russell, “When code isn’t law: Rethinking regulation for artificial intelligence,” *Policy and Society*, vol. 44, no. 1, pp. 85–97, May 2025.
- [12] P. Slattery et al., “The AI risk repository: A meta-review, database, and taxonomy of risks from artificial intelligence,” *Patterns*, vol. 7, no. 5, p. 101 517, May 2026.
- [212] Z. Xu et al., “The trust paradox in LLM-based multi-agent systems: When collaboration becomes a security vulnerability,” *IEEE Transactions on Computational Social Systems*, 2026.
- [356] J. Gottweis et al., “Accelerating scientific discovery with Co-Scientist,” *Nature*, vol. 655, pp. 487–496, May 2026.
- [499] K. Ahi, V. Agrawal, and S. Valizadeh, “LLM scalability risk for agentic-AI and model supply chain security,” *Journal of Computer Information Systems*, pp. 1–17, Feb. 2026.
- [504] H. Su et al., “A survey on autonomy-induced security risks in large model-based agents,” *IEEE Transactions on Pattern Analysis and Machine Intelligence*, vol. 48, no. 10, pp. 2795–2812, Apr. 2026.
- [507] M. Alamsabi, M. Tchuindjang, and S. Brohi, “Embedding-based detection of indirect prompt injection attacks in large language models using semantic context analysis,” *Algorithms*, vol. 19, no. 1, p. 92, 2026.
- [519] E. Jeong and D. Yang, “A trust score-based access control model for zero trust architecture: Design, sensitivity analysis, and real-world performance evaluation,” *Applied Sciences*, vol. 15, no. 17, p. 9551, Aug. 2025.
- [555] J. Zhou and J. Wu, “Efficient vector-multiplicative privacy-preserving retrieval-augmented generation for large language models,” *IEEE Transactions on Dependable and Secure Computing*, vol. 23, no. 3, pp. 6947–6963, Mar. 2026.
- [560] M. A. Ferrag, N. Tihanyi, D. Hamouda, L. Maglaras, A. Lakas, and M. Debbah, “From prompt injections to protocol exploits: Threats in LLM-powered AI agent workflows,” *ICT Express*, vol. 12, no. 2, pp. 353–383, Apr. 2026.

- [566] Z. Cheng, G. Yunjie, Z. Lingchen, and W. Qian, “Survey of multimodal vision-language representation learning models and their adversarial examples attack and defense techniques,” *Journal of Computer Research and Development*, vol. 62, no. 9, pp. 2208–2232, 2025.
- [570] R. Bhosale, P. Chandre, S. Mehetre, S. Powar, S. Mathur, and A. Ghandat, “The dark side of autonomous intelligence: A survey on data leakage and privacy failures in agentic AI,” *Frontiers in Computer Science*, vol. 8, p. 1802727, 2026.
- [589] C. Prabakaran and K. Rajendran, “CL-GIE v4.0: Blockchain-anchored cross-layer genomic integrity with hierarchical Bloom–Merkle trees for ethics-aware, explainable personalized gene editing,” *IEEE Access*, vol. 14, pp. 17702–17723, Feb. 2026.
- [608] Y. Gan et al., “Navigating the risks: A survey of security and privacy threats in LLM-based agents,” *ACM Transactions on Software Engineering and Methodology*, Mar. 2026.
- [752] N. Maloyan and D. Namiot, “Sleeper channels and provenance gates: Persistent prompt injection in always-on autonomous AI agents,” *International Journal of Open Information Technologies*, vol. 14, no. 6, pp. 1–8, Jun. 2026.
- [819] S. Liu et al., “Rethinking machine unlearning for large language models,” *Nature Machine Intelligence*, vol. 7, no. 2, pp. 181–194, Feb. 2025.
- [887] H. Xu et al., “Redagent: An autonomous agent for context-aware red teaming of LLM jail-breaks,” *IEEE Transactions on Dependable and Secure Computing*, vol. 23, no. 3, pp. 6506–6521, May 2026.
- [996] A. E. Muhammad, K.-C. Yow, and S. Alsenan, “Audit-as-code: A policy-as-code framework for continuous AI assurance,” *Frontiers in Artificial Intelligence*, vol. 9, p. 1759211, Feb. 2026.
- [1001] J. Qi et al., “Towards trustworthy agentic AI: A comprehensive survey of safety, robustness, privacy, and system security,” *Academia AI Applications*, vol. 2, no. 2, Apr. 2026.
- [1062] M. Herrador and J. Rehberger, “SpAIware: Uncovering a novel artificial intelligence attack vector through persistent memory in LLM applications and agents,” *Future Generation Computer Systems*, vol. 174, p. 107994, Jan. 2026.
- [1089] Y. Zhu, L. Liu, J. Yu, and D. Zhang, “LLM-based multi-agent orchestration: A survey of frameworks, communication protocols, and emerging patterns,” *Future Internet*, vol. 18, no. 6, p. 326, Jun. 2026.
- [1102] D. Wang et al., “On the evaluation of large language models in multilingual vulnerability repair,” *ACM Transactions on Software Engineering and Methodology*, vol. 35, no. 7, pp. 1–34, Jul. 2026.
- [1120] S. Jamshidi, “Collective hallucination in multi-agent LLMs: Modeling and defense,” *arXiv*, Jun. 2026. arXiv: 2606.07941. Accessed: Jul. 30, 2026. [Online]. Available: <https://arxiv.org/abs/2606.07941>
- [1121] L. Lu, Y. Zhao, H. Rao, K. Zhang, and H. Wang, “Evaluating and enhancing the vulnerability reasoning capabilities of large language models,” *arXiv*, Feb. 2026. arXiv: 2602.06687. Accessed: Jul. 30, 2026. [Online]. Available: <https://arxiv.org/abs/2602.06687>
- [1125] Z. Wang, G. Li, J. Li, M. Yan, Y. Xiong, and Z. Jin, “M2CVD: Enhancing vulnerability understanding through multi-model collaboration for code vulnerability detection,” *ACM Transactions on Software Engineering and Methodology*, vol. 35, no. 7, pp. 1–25, Jul. 2026.

- [1127] J. Xue, X. Chen, Z. Cui, and Y. Liu, “Learning never stops: Improving software vulnerability type identification via incremental learning,” *Journal of Systems and Software*, vol. 230, p. 112 544, Dec. 2025.
- [1138] T. Gasmi, R. Guesmi, J. Bennaceur, and I. Belhadj, “Bridging AI and software security: A comparative vulnerability assessment of LLM agent deployment paradigms,” *Information Sciences*, vol. 740, p. 123 231, Jun. 2026.
- [1140] H. Wu, X. Wang, X. Luo, W. Shen, and W. Lin, “MCG-Sched: Multi-cluster GPU scheduling for resource fragmentation reduction and load balancing,” *IEEE Transactions on Parallel and Distributed Systems*, vol. 36, no. 12, pp. 2789–2800, Dec. 2025.

会议论文

- [6] M. Yu et al., “A survey on trustworthy LLM agents: Threats and countermeasures,” in *Proc. 31st ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, Toronto, ON, Canada, Aug. 2025, pp. 6216–6226.
- [8] M. Mohammadi, Y. Li, J. Lo, and W. Yip, “Evaluation and benchmarking of LLM agents: A survey,” in *Proc. 31st ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, Toronto, ON, Canada, 2025, pp. 6129–6139.
- [16] S. G. Patil et al., “The Berkeley function calling leaderboard (BFCL): From tool use to agentic evaluation of large language models,” in *Proc. 42nd International Conference on Machine Learning*, Vancouver, Canada, Jul. 2025, pp. 48 371–48 392. [Online]. Available: <https://proceedings.mlr.press/v267/patil25a.html>
- [21] A. D. Tur et al., “SafeArena: Evaluating the safety of autonomous web agents,” in *Proc. 42nd International Conference on Machine Learning (ICML)*, Vancouver, Canada, Jul. 2025, pp. 60 404–60 441. [Online]. Available: <https://proceedings.mlr.press/v267/tur25a.html>
- [67] B. Chen, M. Shao, A. Basit, S. Garg, and M. Shafique, “MetaCipher: A time-persistent and universal multi-agent framework for cipher-based jailbreak attacks for LLMs,” in *Proc. AAAI Conference on Artificial Intelligence*, Singapore, Jan. 2026, pp. 37 268–37 276.
- [69] H. Luo et al., “AgentAuditor: Human-level safety and security evaluation for LLM agents,” in *Proc. Advances in Neural Information Processing Systems*, San Diego, CA, USA, 2025, pp. 43 241–43 298. [Online]. Available: <https://openreview.net/forum?id=2KKqp7MWJM>
- [86] Y. As, B. Sukhija, L. Treven, C. Sferrazza, S. Coros, and A. Krause, “ActSafe: Active exploration with safety constraints for reinforcement learning,” in *Proc. International Conference on Learning Representations*, Singapore, Apr. 2025, pp. 29 752–29 776. [Online]. Available: <https://openreview.net/forum?id=aKRADWBJ1I>
- [91] I. Sheth, J. Wehner, S. Abdelnabi, R. Binkyte, and M. Fritz, “Position: Safety must precede the deployment of open-ended AI agents,” in *Proc. 43rd International Conference on Machine Learning*, Seoul, South Korea, Jul. 2026, to appear.
- [92] L. Schwinn, M. Ladenburger, T. Beyer, M. Mofakhami, G. Gidel, and S. Günnemann, “A coin flip for safety: LLM judges fail to reliably measure adversarial robustness,” in *Proc. 43rd International Conference on Machine Learning*, Seoul, South Korea, Jul. 2026, to appear. [Online]. Available: <https://openreview.net/forum?id=RgnWsmYBM>
- [97] Z. Gao, G. Yang, J. Bayrooti, and A. Prorok, “Provably safe online multi-agent navigation in unknown environments,” in *Proc. 8th Conference on Robot Learning*, Seoul, Korea, Sep. 2025, pp. 5466–5486.
- [106] M. Meeus, I. Shilov, S. Jain, M. Faysse, M. Rei, and Y.-A. de Montjoye, “SoK: Membership inference attacks on LLMs are rushing nowhere (and how to fix it),” in *Proc. IEEE Conference on Secure and Trustworthy Machine Learning*, Copenhagen, Denmark, Apr. 2025, pp. 385–401.
- [131] J. Liu et al., “CaPo: Cooperative plan optimization for efficient embodied multi-agent cooperation,” in *Proc. International Conference on Learning Representations*, Singapore, Apr. 2025, pp. 70 791–70 815. [Online]. Available: https://proceedings.iclr.cc/paper_files/paper/2025/hash/b07091c16719ad3990e3d1ccee6641f1-Abstract-Conference.html

- [453] F. Liu et al., “Make agent defeat agent: Automatic detection of taint-style vulnerabilities in LLM-based agents,” in *Proc. 34th USENIX Security Symposium*, Seattle, WA, USA, Aug. 2025, pp. 3767–3786. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity25/presentation/liu-fengyu>
- [456] F. Nazary, Y. Deldjoo, and T. Di Noia, “Poison-RAG: Adversarial data poisoning attacks on retrieval-augmented generation in recommender systems,” in *Proc. 47th European Conference on Information Retrieval*, Lucca, Italy, Apr. 2025, pp. 239–251.
- [515] P. Peigné et al., “Multi-agent security tax: Trading off security and collaboration capabilities in multi-agent systems,” in *Proc. AAAI Conference on Artificial Intelligence*, Philadelphia, PA, USA, Feb. 2025, pp. 27 573–27 581.
- [518] M. Hegazy, A. Rodrigues, and A. Naeem, “MAFA: A multi-agent framework for enterprise-scale annotation with configurable task adaptation,” in *Proc. AAAI Conference on Artificial Intelligence*, Singapore, Jan. 2026, pp. 39 968–39 977.
- [520] S. Shlomov et al., “Governance by construction for generalist agents,” in *Proc. ACM Conference on AI and Agentic Systems*, New York, NY, USA, 2026, pp. 1280–1287.
- [549] A. AlSayyad, K. Y. Huang, and R. Pal, “AgentTrace: A structured logging framework for agent system observability,” in *Proc. AAAI Workshop on LLM-Based Multi-Agent Systems: Towards Responsible, Reliable, and Scalable Agentic Systems*, Singapore, Jan. 2026, to appear. [Online]. Available: <https://openreview.net/forum?id=xfdpqwikdR>
- [557] D. Srivastav and X. Zhang, “Safe in isolation, dangerous together: Agent-driven multi-turn decomposition jailbreaks on LLMs,” in *Proc. 1st Workshop for Research on Agent Language Models*, Vienna, Austria, Jul. 2025, pp. 170–183.
- [562] Y. Zheng, Y. Hu, T. Yu, and A. Quinn, “AgentSight: System-level observability for AI agents using eBPF,” in *Proc. 4th Workshop on Practical Adoption Challenges of Machine Learning for Systems*, New York, NY, USA, Oct. 2025, pp. 110–115. [Online]. Available: <https://doi.org/10.1145/3766882.3767169>
- [565] C. J. Chong, C. Hou, Z. Yao, and S. M. S. Talebi, “Casper: Prompt sanitization for protecting user privacy in web-based large language models,” in *Proc. IEEE 12th International Conference on Cyber Security and Cloud Computing*, New York City, NY, USA, Nov. 2025, pp. 122–133.
- [568] H. Na, H. Kim, D. Yoon, and D. Choi, “Countering jailbreak attacks with two-axis pre-detection and conditional warning wrappers,” in *Proc. European Symposium on Research in Computer Security*, Cham, Switzerland, Sep. 2025, pp. 249–268.
- [576] C. Liu et al., “Safe: Enhancing mathematical reasoning in large language models via retrospective step-aware formal verification,” in *Proc. 63rd Annual Meeting of the Association for Computational Linguistics*, Vienna, Austria, Jul. 2025, pp. 12 171–12 186.
- [577] S.-Y. Huang, L.-H. Chang, C.-Y. Lin, and C.-L. Yang, “Beyond oracle: Verifier-supervision for instruction hierarchy in reasoning and instruction-tuned LLMs,” in *Proc. Advances in Neural Information Processing Systems*, San Diego, CA, USA, Dec. 2025, pp. 98 362–98 395. [Online]. Available: https://proceedings.neurips.cc/paper_files/paper/2025/file/8d9957ffda4c206cbdb1927e5aad83ba-Paper-Conference.pdf
- [599] S. Kim, Y. Lee, Y. Song, and K. Lee, “What really matters in many-shot attacks? an empirical study of long-context vulnerabilities in LLMs,” in *Proc. 63rd Annual Meeting of the Association*

- for *Computational Linguistics (Volume 1: Long Papers)*, Vienna, Austria, Jul. 2025, pp. 2043–2063.
- [602] W. Luo et al., “AGrail: A lifelong agent guardrail with effective and adaptive safety detection,” in *Proc. 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Vienna, Austria, Jul. 2025, pp. 8104–8139.
- [609] F. J. Arceo and V. P. Narsing, “Securing the agent: Vendor-neutral, multitenant enterprise retrieval and tool use,” in *Proc. ACM Conference on AI and Agentic Systems*, San Jose, CA, USA, May 2026, pp. 862–872.
- [620] W. Hackett, L. Birch, S. Trawicki, N. Suri, and P. Garraghan, “Bypassing LLM guardrails: An empirical analysis of evasion attacks against prompt injection and jailbreak detection systems,” in *Proc. First Workshop on LLM Security*, Vienna, Austria, Aug. 2025, pp. 101–114. [Online]. Available: <https://aclanthology.org/2025.llmsec-1.8/>
- [640] H. Hu, P. Chen, Y. Zhao, and Y. Chen, “AgentSentinel: An end-to-end and real-time security defense framework for computer-use agents,” in *Proc. ACM SIGSAC Conference on Computer and Communications Security*, Taipei, Taiwan, Oct. 2025, pp. 3535–3549.
- [641] X. Yang, B. Zhou, X. Tang, J. Han, and S. Hu, “Chain of attack: Hide your intention through multi-turn interrogation,” in *Proc. Findings of the Association for Computational Linguistics*, Vienna, Austria, Jul. 2025, pp. 9881–9901.
- [648] H. Zhang et al., “Agent security bench (ASB): Formalizing and benchmarking attacks and defenses in LLM-based agents,” in *Proc. International Conference on Learning Representations (ICLR)*, Singapore, Apr. 2025, to appear. [Online]. Available: <https://openreview.net/forum?id=V4y0CpX4hK>
- [653] S. Dong et al., “Memory injection attacks on LLM agents via query-only interaction,” in *Proc. Advances in Neural Information Processing Systems*, San Diego, CA, USA and Mexico City, Mexico, Dec. 2025, pp. 46 697–46 731. [Online]. Available: <https://openreview.net/forum?id=QINnsnppv8>
- [666] H. Wang, C. M. Poskitt, and J. Sun, “AgentSpec: Customizable runtime enforcement for safe and reliable LLM agents,” in *Proc. IEEE/ACM 48th International Conference on Software Engineering*, Rio de Janeiro, Brazil, Apr. 2026, pp. 1–12.
- [685] L. Boisvert et al., “Malice in Agentland: Down the rabbit hole of backdoors in the AI supply chain,” in *Proc. ACM Conference on AI and Agentic Systems (CAIS)*, San Jose, CA, USA, May 2026, pp. 755–772.
- [692] Z. Wang, C. Zhang, W. Peng, Q. Wu, and X. Wang, “TriEx: A game-based tri-view framework for explaining internal reasoning in multi-agent LLMs,” in *Proc. 64th Annual Meeting of the Association for Computational Linguistics (ACL) (Volume 1: Long Papers)*, San Diego, CA, USA, Jul. 2026, pp. 6448–6479.
- [715] R. M. S. Khan, Z. Tan, S. Yun, C. Fleming, and T. Chen, “Agents under siege: Breaking pragmatic multi-agent LLM systems with optimized prompt attacks,” in *Proc. 63rd Annual Meeting of the Association for Computational Linguistics (ACL) (Volume 1: Long Papers)*, Vienna, Austria, Jul. 2025, pp. 9661–9674.
- [716] H. Li, X. Liu, C. Chiu, D. Li, N. Zhang, and C. Xiao, “DRIFT: Dynamic rule-based defense with injection isolation for securing LLM agents,” in *Proc. Advances in Neural Information*

- Processing Systems*, San Diego, CA, USA and Mexico City, Mexico, Dec. 2025, pp. 83 262–83 290. [Online]. Available: https://proceedings.neurips.cc/paper_files/paper/2025/file/77f3b26c7907aa27b207df9b9d43f29a-Paper-Conference.pdf
- [727] S. Wang et al., “G-Safeguard: A topology-guided security lens and treatment on LLM-based multi-agent systems,” in *Proc. 63rd Annual Meeting of the Association for Computational Linguistics (ACL) (Volume 1: Long Papers)*, Vienna, Austria, Jul. 2025, pp. 7261–7276.
- [732] B. Wang et al., “Unveiling privacy risks in LLM agent memory,” in *Proc. 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Vienna, Austria, Jul. 2025, pp. 25 241–25 260. [Online]. Available: <https://aclanthology.org/2025.acl-long.1227>
- [737] Z. Weng, X. Jin, J. Jia, and X. Zhang, “Foot-in-the-door: A multi-turn jailbreak for LLMs,” in *Proc. Conference on Empirical Methods in Natural Language Processing (EMNLP)*, Suzhou, China, Nov. 2025, pp. 1939–1950.
- [741] X. Zhou et al., “SafeAgent: Safeguarding LLM agents via an automated risk simulator,” in *Proc. 64th Annual Meeting of the Association for Computational Linguistics (ACL) (Volume 1: Long Papers)*, San Diego, CA, USA, Jul. 2026, pp. 32 516–32 543.
- [774] H. Li, X. Liu, N. Zhang, and C. Xiao, “PIGuard: Prompt injection guardrail via mitigating overdefense for free,” in *Proc. 63rd Annual Meeting of the Association for Computational Linguistics (ACL) (Volume 1: Long Papers)*, Vienna, Austria, Jul. 2025, pp. 30 420–30 437.
- [776] M. Russinovich, A. Salem, and R. Eldan, “Great, now write an article about that: The Crescendo multi-turn LLM jailbreak attack,” in *Proc. 34th USENIX Security Symposium*, Seattle, WA, USA, Aug. 2025, pp. 2421–2440. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity25/presentation/russinovich>
- [780] E. Li, T. Mallick, E. Rose, W. Robertson, A. Oprea, and C. Nita-Rotaru, “ACE: A security architecture for LLM-integrated app systems,” in *Proc. Network and Distributed System Security Symposium (NDSS)*, San Diego, CA, USA, Feb. 2026, to appear.
- [781] S. Vijayvargiya et al., “OpenAgentSafety: A comprehensive framework for evaluating real-world AI agent safety,” in *Proc. International Conference on Learning Representations*, Rio de Janeiro, Brazil, Apr. 2026, to appear. [Online]. Available: <https://openreview.net/forum?id=xggSxCFQbA>
- [783] Z. Liao et al., “EIA: Environmental injection attack on generalist web agents for privacy leakage,” in *Proc. International Conference on Learning Representations (ICLR)*, Singapore, Apr. 2025, pp. 66 972–67 003. [Online]. Available: <https://openreview.net/forum?id=xMOLUzo2Lk>
- [784] Y. Liu, Y. Jia, J. Jia, D. Song, and N. Z. Gong, “DataSentinel: A game-theoretic detection of prompt injection attacks,” in *Proc. IEEE Symposium on Security and Privacy (S&P)*, San Francisco, CA, USA, May 2025, pp. 2190–2208.
- [795] F. Jia, T. Wu, X. Qin, and A. Squicciarini, “The Task Shield: Enforcing task alignment to defend against indirect prompt injection in LLM agents,” in *Proc. 63rd Annual Meeting of the Association for Computational Linguistics (ACL) (Volume 1: Long Papers)*, Vienna, Austria, Jul. 2025, pp. 29 680–29 697.

- [798] Y. Feng and X. Pan, “SentinelNet: Safeguarding multi-agent collaboration through credit-based dynamic threat detection,” in *Proc. ACM Web Conference*, Dubai, United Arab Emirates, Apr. 2026, pp. 3135–3146.
- [799] H. Triedman, R. Jha, and V. Shmatikov, “Multi-agent systems execute arbitrary malicious code,” in *Proc. Conference on Language Modeling*, Montreal, Canada, Oct. 2025, to appear. [Online]. Available: <https://openreview.net/forum?id=DAozI4etUp>
- [812] T. Chen, P. Li, K. Zhou, T. Chen, and H. Wei, “Unveiling privacy risks in multi-modal large language models: Task-specific vulnerabilities and mitigation challenges,” in *Proc. Findings of the Association for Computational Linguistics: ACL*, Vienna, Austria, Jul. 2025, pp. 4573–4586.
- [813] S. Wang et al., “Privacy in action: Towards realistic privacy mitigation and evaluation for LLM-powered agents,” in *Proc. Findings of the Association for Computational Linguistics: EMNLP*, Suzhou, China, Nov. 2025, pp. 17 055–17 074.
- [821] J. Kang, M. Ji, Z. Zhao, and T. Bai, “Memory OS of AI agent,” in *Proc. Conference on Empirical Methods in Natural Language Processing*, Suzhou, China, Nov. 2025, pp. 25 961–25 970.
- [829] M. Bhatt, V. S. Narajala, and I. Habler, “ETDI: Mitigating tool squatting and rug pull attacks in model context protocol (MCP) by using oauth-enhanced tool definitions and policy-based access control,” in *Proc. IEEE Cyber Awareness and Research Symposium*, Grand Forks, ND, USA, 2025, pp. 1–6.
- [866] X. Xu, S. Feng, G. Shen, and X. Zhang, “When harmful intent dissolves into technical detail: How safe are coding agents against cyber misuse?” In *Proc. ACM Conference on AI and Agentic Systems (CAIS)*, San Jose, CA, USA, May 2026, pp. 873–889.
- [878] Z. Wang et al., “MCPTox: A benchmark for tool poisoning on real-world MCP servers,” in *Proc. AAAI Conference on Artificial Intelligence*, Singapore, Jun. 2026, pp. 35 811–35 819.
- [883] L. Advani, “Trajectory guard – a lightweight, sequence-aware model for real-time anomaly detection in agentic AI,” in *Proc. AAAI Workshop on Trustworthy Agentic AI*, Singapore, Jan. 2026, to appear.
- [890] T. Kuntz et al., “OS-Harm: A benchmark for measuring safety of computer use agents,” in *Proc. Advances in Neural Information Processing Systems*, San Diego, CA, USA, Dec. 2025. [Online]. Available: https://proceedings.neurips.cc/paper_files/paper/2025/hash/4009bff0cd87ba2203c8e3a2f082aaec-Abstract-Datasets_and_Benchmarks_Track.html
- [899] Y. Xie, Y. Yuan, W. Wang, F. Mo, J. Guo, and P. He, “ToolSafety: A comprehensive dataset for enhancing safety in LLM-based agent tool invocations,” in *Proc. Conference on Empirical Methods in Natural Language Processing*, Suzhou, China, Nov. 2025, pp. 14 135–14 156.
- [904] T. N. Nguyen, “Demo: ViolentUTF as an accessible platform for generative AI red teaming,” in *Proc. Silicon Valley Cybersecurity Conference*, San Francisco, CA, USA, Jun. 2025, pp. 1–3.
- [919] S. Abdollahi et al., “AgenTEE: Confidential LLM agent execution on edge devices,” in *Proc. Sixth European Workshop on Machine Learning and Systems*, Edinburgh, Scotland, UK, Apr. 2026, pp. 473–480.
- [921] S. Abdollahi, M. Maheri, S. D. Siby, M. Kogias, and H. Haddadi, “An early experience with confidential computing architecture for on-device model protection,” in *Proc. IEEE Euro-*

- pean Symposium on Security and Privacy Workshops (EuroS&PW), Venice, Italy, Jun. 2025, pp. 401–410.
- [937] W. Vandendriessche, J. Thijsman, L. D’hooge, B. Volckaert, and M. Sebrechts, “AIBoMGen: Generating an AI bill of materials for secure, transparent, and compliant model training,” in *Proc. ACM/IEEE International Conference on AI Engineering*, Rio de Janeiro, Brazil, Apr. 2026, to appear. [Online]. Available: https://www.researchgate.net/profile/Wiebe-Vandendriessche/publication/399667421_AIBoMGen_Generating_an_AI_Bill_of_Materials_for_Secure_Transparent_and_Compliant_Model_Training/links/6964ccf5c906f117f2a3e0a8/AIBoMGen-Generating-an-AI-Bill-of-Materials-for-Secure-Transparent-and-Compliant-Model-Training.pdf
- [939] G. K. Rajbahadur et al., “Building an open AIBOM standard in the wild: An experience report on extending the SPDX SBOM (ISO/IEC 5962:2021) for AI supply chains,” in *Proc. IEEE/ACM 48th International Conference on Software Engineering: Software Engineering in Practice*, Rio de Janeiro, Brazil, Jul. 2026, pp. 842–853.
- [940] A. T. Vadlamani, A. Srinivasan, and S. Parthasarathy, “Towards auditing AI systems in the wild,” in *Proc. 32nd ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, Jeju, Korea, Aug. 2026, to appear.
- [942] X. Wang, J. Bloch, Z. Shao, Y. Hu, S. Zhou, and N. Z. Gong, “EnvInjection: Environmental prompt injection attack to multi-modal web agents,” in *Proc. EMNLP*, Suzhou, China, Nov. 2025, to appear.
- [945] S. Abdelnabi, A. Fay, G. Cherubin, A. Salem, M. Fritz, and A. Pavverd, “Get my drift? catching LLM task drift with activation deltas,” in *Proc. IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*, Copenhagen, Denmark, Apr. 2025, pp. 43–67.
- [948] J. Zhou, E. Xu, Y. Wu, and T. Li, “Rescriber: Smaller LLM-powered user-led data minimization for LLM-based chatbots,” in *Proc. ACM CHI Conference on Human Factors in Computing Systems*, Yokohama, Japan, Apr. 2025, pp. 1–28.
- [949] A. Zharmagambetov, C. Guo, I. Evtimov, M. Pavlova, R. Salakhutdinov, and K. Chaudhuri, “AgentDAM: Privacy leakage evaluation for autonomous web agents,” in *Proc. Advances in Neural Information Processing Systems*, Vancouver, Canada, Dec. 2025, to appear.
- [952] W. Xu, Z. Liang, K. Mei, H. Gao, J. Tan, and Y. Zhang, “A-Mem: Agentic memory for LLM agents,” in *Proc. Advances in Neural Information Processing Systems*, San Diego, CA, USA and Mexico City, Mexico, Dec. 2025, pp. 17 577–17 604.
- [957] Z. Xiang et al., “GuardAgent: Safeguard LLM agents via knowledge-enabled reasoning,” in *Proc. 42nd International Conference on Machine Learning*, Vancouver, Canada, Jul. 2025, pp. 68 316–68 342. [Online]. Available: <https://proceedings.mlr.press/v267/xiang25a.html>
- [967] L. Wang et al., “Manipulating multimodal agents via cross-modal prompt injection,” in *Proc. 33rd ACM International Conference on Multimedia*, Dublin, Ireland, Oct. 2025, pp. 10 955–10 964.
- [969] P. He, Y. Lin, S. Dong, H. Xu, Y. Xing, and H. Liu, “Red-teaming LLM multi-agent systems via communication attacks,” in *Proc. Findings of the Association for Computational Linguistics: ACL*, Vienna, Austria, Jul. 2025, pp. 6726–6747.

- [981] A. Doshi, Y. Hong, C. Xu, E. Kang, A. Kapravelos, and C. K”astner, “Towards verifiably safe tool use for LLM agents,” in *Proc. IEEE/ACM 48th International Conference on Software Engineering: New Ideas and Emerging Results*, Rio de Janeiro, Brazil, Jul. 2026, pp. 201–205.
- [983] Q. Zhang et al., “Evaluating privilege usage of agents with real-world tools,” in *Proc. 34th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering Companion*, Montreal, QC, Canada, Jul. 2026, pp. 1192–1196.
- [986] K. Luo, X. Wang, P. H. A. Fung, W. C. Lau, and J. Lecomte, “Universal cross-app attacks: Exploiting and securing OAuth 2.0 in integration platforms,” in *Proc. 34th USENIX Security Symposium*, Seattle, WA, USA, Aug. 2025, pp. 3221–3238. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity25/presentation/luo-kaixuan>
- [990] G. Piccardo, G. F. Italiano, and A. Martino, “The agentic kill chain: A cognitive threat framework for autonomous agent ecosystems,” in *Proc. Joint National Conference on Cybersecurity*, Cagliari, Italy, Feb. 2026, to appear. [Online]. Available: <https://ceur-ws.org/Vol-4198/paper7.pdf>
- [1002] E. Allegrini, A. Shree Kumar, and Z. B. Celik, “Formalizing the safety, security, and functional properties of agentic AI systems,” in *Proc. ICLR Workshop on Agents in the Wild: Safety, Security, and Beyond*, Rio de Janeiro, Brazil, Apr. 2026, to appear. [Online]. Available: <https://iclr.cc/virtual/2026/10016309>
- [1005] R. Tiwari and D. Williams, “Execute-only agents: Architectural defense against prompt injection for AI agents,” in *Proc. Agentic OS Workshop*, Pittsburgh, PA, USA, Mar. 2026, to appear. [Online]. Available: https://os-for-agent.github.io/papers/AgenticOS_2026_paper_21.pdf
- [1007] T. Van Hamme et al., “MATRA: Modeling the attack surface of agentic AI systems—OpenClaw case study,” in *Proc. International Workshop on Designing and Measuring Security in Systems with AI*, Lisbon, Portugal, Jul. 2026, to appear.
- [1011] H. Li, D. Xu, M. Chen, and Y. Liu, “Agentic open RAN: A deterministic and auditable framework for intent-driven radio control,” in *Proc. IEEE International Conference on Communications*, Glasgow, Scotland, UK, Jun. 2026, pp. 1–6.
- [1012] X. Wang, K. Huang, B. Liang, H. Li, and X. Du, “Shadows in the code: Exploring the risks and defenses of LLM-based multi-agent software development systems,” in *Proc. AAAI Conference on Artificial Intelligence*, Singapore, Jan. 2026, pp. 37 970–37 978.
- [1013] P. Cheng et al., “Hidden ghost hand: Unveiling backdoor vulnerabilities in MLLM-powered mobile GUI agents,” in *Proc. Findings of the Association for Computational Linguistics: EMNLP*, Suzhou, China, Nov. 2025, pp. 7781–7805.
- [1015] L. Boisvert et al., “Silent sabotage: Injecting backdoors into AI agents through fine-tuning,” in *Proc. ICML Workshop on Computer Use Agents*, Vancouver, Canada, Jul. 2025, to appear. [Online]. Available: <https://icml.cc/virtual/2025/49791>
- [1022] F. Fan and X. Li, “PeerGuard: Defending multi-agent systems against backdoor attacks through mutual reasoning,” in *Proc. IEEE International Conference on Information Reuse and Integration for Data Science*, San Jose, CA, USA, Aug. 2025, pp. 234–239.

- [1025] H. Patel and K. Pai, “VATS: Exploiting implicit authority in error-path injection via systematic mutation,” in *Proc. ICML Workshop on Agents in the Wild*, Seoul, South Korea, Jul. 2026, to appear.
- [1043] M. J. Hossain, M. A. Hossain, W. Liu, and N. Ansari, “The containment gap: How deployed agentic AI frameworks fail public-facing safety requirements,” in *Proc. ICML Trustworthy Workshop on AI for Good*, Seoul, South Korea, Jul. 2026, to appear.
- [1052] Q. Zhan et al., “BEAT: Visual backdoor attacks on VLM-based embodied agents via contrastive trigger learning,” in *Proc. International Conference on Learning Representations (ICLR)*, Rio de Janeiro, Brazil, Apr. 2026, to appear. [Online]. Available: <https://arxiv.org/abs/2510.27623>
- [1055] D. Lee, M. Tiwari, and B. Miranda, “Prompt infection: LLM-to-LLM prompt injection within multi-agent systems,” in *Proc. European Symposium on Research in Computer Security Workshops*, Toulouse, France, Sep. 2025, pp. 511–520.
- [1066] S. Yu, F. Carroll, and B. L. Bentley, “Operational hallucination and safety drift in AI agents,” in *Proc. IEEE International Conference on AI and Data Analytics*, Boston, Massachusetts, USA, Jun. 2026.
- [1067] T. Hadeliya, M. A. Jauhar, N. Sakpal, and D. Cruz, “When refusals fail: Unstable safety mechanisms in long-context LLM agents,” in *Proc. AAAI Workshop on Trustworthy Agentic AI*, Singapore, Jan. 2026.
- [1069] S. Storf, R. Barton-Cooper, J. Peters-Gill, and M. Hobbhahn, “Constitutional black-box monitoring for scheming in LLM agents,” in *Proc. 43rd International Conference on Machine Learning*, Seoul, South Korea, Jul. 2026.
- [1071] M. Z. Pan et al., “Measuring agents in production,” in *Proc. 43rd International Conference on Machine Learning*, Seoul, South Korea, Jul. 2026.
- [1074] A. Barrak, “Traceability and accountability in role-specialized multi-agent LLM pipelines,” in *Proc. ACM/IEEE International Conference on Automated Software Engineering (ASE) Workshops*, Seoul, South Korea, Oct. 2025.
- [1079] S. Yu, F. Carroll, and B. L. Bentley, “Operational hallucination and safety drift in AI agents,” in *Proc. IEEE Int. Conf. AI Data Analytics (ICAD)*, Boston, Massachusetts, USA, Jun. 2026, pp. 1–8.
- [1080] Z. Li, J. Cui, X. Liao, and L. Xing, “Les dissonances: Cross-tool harvesting and polluting in pool-of-tools empowered LLM agents,” in *Proc. Network and Distributed System Security Symposium*, San Diego, CA, USA, Feb. 2026.
- [1085] Y. Ouyang, Y. Xiao, Y. Gu, and X. Zhang, “SkCC: Portable and secure skill compilation for cross-framework LLM agents,” in *Proc. Agent Skills Workshop at the ACM Conference on AI and Agentic Systems*, San Jose, CA, USA, May 2026, to appear.
- [1091] T. Li, C. Chu, Y. Zheng, B. Zhang, N. Gong, and C. Xiao, “A2ASecBench: A protocol-aware security benchmark for agent-to-agent multi-agent systems,” in *Proc. International Conference on Learning Representations*, Rio de Janeiro, Brazil, Apr. 2026.
- [1093] R. Sharma, M. de Vos, P. Chari, R. Raskar, and A.-M. Kermarrec, “Position: Collaborative agentic AI needs interoperability across ecosystems,” in *Proc. 43rd International Conference*

- on Machine Learning*, Seoul, South Korea, Jul. 2026. [Online]. Available: 10.48550/arXiv.2602.16811
- [1098] M. Xu, X. Liu, Y. Guo, C. Liu, Y. Zhang, and X. Cheng, “AgentDID: Trustless identity authentication for AI agents,” in *Proc. 46th IEEE International Conference on Distributed Computing Systems*, Seoul, South Korea, Jun. 2026.
 - [1100] I. Ceka et al., “Understanding automated program repair agents through the lens of traceability: An empirical study,” in *Proc. 35th ACM SIGSOFT International Symposium on Software Testing and Analysis*, Oakland, CA, USA, Oct. 2026.
 - [1103] M. Fakih et al., “LLM4CVE: Enabling iterative automated vulnerability repair with large language models,” in *Proc. 28th Euromicro Conference on Digital System Design*, Sep. 2025, pp. 592–599.
 - [1105] Y. Zhang, J. Wang, D. Berzin, M. Mirchev, and A. Roychoudhury, “Fixing security vulnerabilities with agentic AI in OSS-Fuzz,” in *Proc. IEEE/ACM 48th International Conference on Software Engineering: Software Engineering in Practice*, Rio de Janeiro, Brazil, Apr. 2026, pp. 374–384.
 - [1108] Y. Li, F. H. Shezan, B. Wei, G. Wang, and Y. Tian, “SoK: Towards effective automated vulnerability repair,” in *Proc. 34th USENIX Security Symposium*, Seattle, WA, USA, Aug. 2025, pp. 4441–4462.
 - [1110] W. Han et al., “Rethinking the capability of fine-tuned language models for automated vulnerability repair,” in *Proc. IEEE/ACM 48th International Conference on Software Engineering*, Rio de Janeiro, Brazil, Apr. 2026.
 - [1112] S. Kaniewski, F. Schmidt, and T. Heer, “Revisiting Vul-RAG: Reproducibility and replicability of RAG-based vulnerability detection with open-weight models,” in *Proc. International Workshop on Artificial Intelligence, Cyber and Cyber-Physical Security*, Linköping, Sweden, Aug. 2026.
 - [1115] C. Yang et al., “SeCuRepair: Semantics-aligned, curriculum-driven, and reasoning-enhanced vulnerability repair framework,” in *Proc. 64th Annual Meeting of the Association for Computational Linguistics (ACL) (Volume 1: Long Papers)*, San Diego, CA, USA, Jul. 2026, pp. 32 108–32 123.
 - [1118] Y. Kim, S. Shin, H. Kim, and J. Yoon, “Logs in, patches out: Automated vulnerability repair via Tree-of-Thought LLM analysis,” in *Proc. 34th USENIX Security Symposium*, Seattle, WA, USA, Aug. 2025, pp. 4401–4419.
 - [1122] Y. Xiao et al., “ROUTERHGC: Optimized router for LLM-based multi-agent systems via heterogeneous graph contrastive learning,” in *Proc. Findings of the Association for Computational Linguistics: ACL*, San Diego, CA, USA, Jul. 2026, pp. 31 759–31 789.
 - [1124] M. Yildiz, P. Spadaccino, A. Rolich, F. Cuomo, and A. Baiocchi, “Towards multi-model LLM schedulers: Empirical insights into offloading and preemption,” in *Proc. Mediterranean Artificial Intelligence and Networking Conference*, Mondello, Palermo, Italy, Jul. 2026, to appear.
 - [1126] X. Dou, H. Bahsi, and A. Guerra-Manzanares, “Enhancing continual learning for software vulnerability prediction: Addressing catastrophic forgetting via hybrid-confidence-aware selective replay for temporal LLM fine-tuning,” in *Proc. International Conference on Information Systems Security and Privacy*, Marbella, Spain, Mar. 2026, pp. 474–485.

- [1134] A. M. Kassem, B. Schölkopf, and Z. Jin, “How robust are router-LLMs? analysis of the fragility of LLM routing capabilities,” in *Proc. 19th Conference of the European Chapter of the Association for Computational Linguistics (Volume 1: Long Papers)*, Rabat, Morocco, Mar. 2026, pp. 7496–7507.
- [1136] A. Zheng, M. Rana, and A. Stolcke, “Lightweight safety guardrails using fine-tuned BERT embeddings,” in *Proc. 31st International Conference on Computational Linguistics: Industry Track*, Abu Dhabi, UAE, Jan. 2025, pp. 689–696.

政府政策与报告

- [29] INNOVATION, SCIENCE AND ECONOMIC DEVELOPMENT CANADA. “Toolkit for small- and medium-sized enterprises deploying artificial intelligence,” Accessed: Jul. 21, 2026. [Online]. Available: <https://ised-isde.canada.ca/site/ised/en/toolkit-small-and-medium-sized-enterprises-smes-deploying-artificial-intelligence-ai>
- [80] EUROPEAN PARLIAMENT AND COUNCIL OF THE EUROPEAN UNION. “Regulation (EU) 2024/1689 of the European parliament and of the council of 13 June 2024 laying down harmonised rules on artificial intelligence (artificial intelligence act),” Accessed: Jul. 21, 2026. [Online]. Available: data.europa.eu/eli/reg/2024/1689/oj
- [88] EUROPEAN PARLIAMENT AND COUNCIL OF THE EUROPEAN UNION. “Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (general data protection regulation),” Accessed: Jul. 21, 2026. [Online]. Available: fedlex.admin.ch/eli/cc/2022/491/en
- [112] UK RESEARCH AND INNOVATION. “Bridging responsible AI divides,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.ukri.org/what-we-do/browse-our-areas-of-investment-and-support/bridging-responsible-ai-divides-braid/>
- [403] EUROPEAN COMMISSION. “AI factories,” Accessed: Jul. 21, 2026. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/policies/ai-factories>
- [469] THE WHITE HOUSE. “Promoting advanced Artificial Intelligence innovation and security,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.federalregister.gov/documents/2026/06/05/2026-11415/promoting-advanced-artificial-intelligence-innovation-and-security>
- [470] OFFICE OF MANAGEMENT AND BUDGET, “Accelerating federal use of AI through innovation, governance, and public trust,” EXECUTIVE OFFICE OF THE PRESIDENT, Tech. Rep. M-25-21, Apr. 2025. [Online]. Available: <https://www.whitehouse.gov/wp-content/uploads/2025/02/M-25-21-Accelerating-Federal-Use-of-AI-through-Innovation-Governance-and-Public-Trust.pdf>
- [471] CALIFORNIA STATE LEGISLATURE. “Senate bill 53: Transparency in frontier artificial intelligence act,” Accessed: Jul. 21, 2026. [Online]. Available: [leginfo.legislature.ca.gov/faces/billTextClient.xhtml?bill_id=202520260SB53](https://leginfo.ca.gov/faces/billTextClient.xhtml?bill_id=202520260SB53)
- [472] NEW YORK STATE LEGISLATURE. “Responsible AI safety and education act (RAISE act), S6953B/A6453B,” Accessed: Jul. 21, 2026. [Online]. Available: nysenate.gov/legislation/bills/2025/A6453/amendment/B
- [473] EXECUTIVE OFFICE OF THE PRESIDENT. “Executive order 14365: Ensuring a national policy framework for artificial intelligence,” Accessed: Jul. 21, 2026. [Online]. Available: www.govinfo.gov/app/details/DCPD-202501186
- [474] CANADA GOVERNMENT. “Canada’s national artificial intelligence strategy: AI for all,” Accessed: Jul. 21, 2026. [Online]. Available: https://ised-isde.canada.ca/site/ised/en/canadas-national-artificial-intelligence-strategy-ai-all#_Toc76

- [475] PARLIAMENT OF CANADA. “Bill C-36: An act to enact the protecting privacy and consumer data act, to amend the personal information protection and electronic documents act and to make amendments to other acts,” Accessed: Jul. 21, 2026. [Online]. Available: www.parl.ca/legisinfo/en/bill/45-1/c-36
- [476] BUREAU OF INDUSTRY AND SECURITY, U.S. DEPARTMENT OF COMMERCE. “Framework for artificial intelligence diffusion,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.federalregister.gov/documents/2025/01/15/2025-00636/framework-for-artificial-intelligence-diffusion>
- [477] BUREAU OF INDUSTRY AND SECURITY, U.S. DEPARTMENT OF COMMERCE. “Department of commerce announces rescission of Biden-era artificial intelligence diffusion rule, strengthens chip-related export controls,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.federalregister.gov/documents/2025/01/15/2025-00636/framework-for-artificial-intelligence-diffusion>
- [478] BUREAU OF INDUSTRY AND SECURITY, U.S. DEPARTMENT OF COMMERCE. “Department of commerce revises license review policy for semiconductors exported to China,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.bis.gov/press-release/department-commerce-revises-license-review-policy-semiconductors-exported-china>
- [479] BUREAU OF INDUSTRY AND SECURITY, U.S. DEPARTMENT OF COMMERCE. “Export administration regulations, part 744: Control policy: End-user and end-use based, § 744.16 entity list,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.bis.gov/regulations/ear/744>
- [480] BUREAU OF INDUSTRY AND SECURITY, U.S. DEPARTMENT OF COMMERCE. “Department of commerce announces new american AI exports program phase,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.trade.gov/press-release/department-commerce-announces-new-american-ai-exports-program-phase>
- [481] GLOBAL AFFAIRS CANADA. “A guide to canada’s export control list–2026,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.international.gc.ca/trade-commerce/controls-controles/ec1-lec/export_control_list-guide-liste_exportation_controle_e_2026.aspx?lang=eng
- [482] GOVERNMENT OF CANADA. “Order amending the export control list: Sor/2025-89,” Accessed: Jul. 21, 2026. [Online]. Available: <https://gazette.gc.ca/rp-pr/p2/2025/2025-03-26/html/sor-dors89-eng.html>
- [483] GLOBAL AFFAIRS CANADA. “A guide to Canada’s export control list – 2025,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.international.gc.ca/trade-commerce/controls-controles/ec1-lec/export_control_list-guide-liste_exportation_controle_e_2025.aspx?lang=eng
- [484] INNOVATION, SCIENCE AND ECONOMIC DEVELOPMENT CANADA. “Sensitive technology list,” Accessed: Jul. 21, 2026. [Online]. Available: www.canada.ca/en/services/defence/nationalsecurity/sensitive-technology-list.html
- [485] EUROPEAN COMMISSION. “The general-purpose AI code of practice,” Accessed: Jul. 21, 2026. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai>

- [487] DEPARTMENT FOR SCIENCE, INNOVATION AND TECHNOLOGY. “Code of practice for the cyber security of AI,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.gov.uk/government/publications/ai-cyber-security-code-of-practice/code-of-practice-for-the-cyber-security-of-ai>
- [488] THE SECRETARY OF STATE. “The export control (amendment) regulations 2024,” Accessed: Jul. 21, 2026. [Online]. Available: www.legislation.gov.uk/ukxi/2024/346/made
- [489] GOVERNMENT OF THE NETHERLANDS. “Export controls on strategic goods and service,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.government.nl/themes/economy/export-controls-of-strategic-goods>
- [490] FOREIGN, COMMONWEALTH & DEVELOPMENT OFFICE. “The UK sanctions list,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.gov.uk/government/publications/the-uk-sanctions-list>
- [491] CYBERSPACE ADMINISTRATION OF CHINA, NATIONAL DEVELOPMENT AND REFORM COMMISSION, MINISTRY OF INDUSTRY AND INFORMATION TECHNOLOGY. “Opinions on the standardized application and innovative development of intelligent agents,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.cac.gov.cn/2026-05/08/c_1779979789523320.htm
- [492] NATIONAL INFORMATION SECURITY STANDARDIZATION TECHNICAL COMMITTEE, CNCERT. “Artificial intelligence security governance framework 2.0,” Accessed: Jul. 21, 2026. [Online]. Available: https://cac.gov.cn/2025-09/15/c_1759653448369123.htm
- [493] STATE COUNCIL OF THE PEOPLE’S REPUBLIC OF CHINA. “Opinion of the state council on further implementing the ”artificial intelligence +” initiative,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.gov.cn/gongbao/2025/issue_12266/202509/content_7039598.html
- [494] 中华人民共和国工业和信息化部等十部门. “工业和信息化部等十部门关于印发《人工智能科技伦理审查与服务办法（试行）》的通知,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.gov.cn/zhengce/zhengceku/202604/content_7064646.htm
- [495] 国家市场监督管理总局. “人工智能智能体互联系列国家标准,” Accessed: Jul. 28, 2026. [Online]. Available: <https://std.sacinfo.org.cn/gnoc/queryInfo?id=495B8834610A6828F254D73BD7DCAF99>
- [496] MINISTRY OF COMMERCE OF THE PEOPLE’S REPUBLIC OF CHINA. “Export control law of the people’s republic of china,” Accessed: Jul. 21, 2026. [Online]. Available: flk.npc.gov.cn/detail?id=ff80808175265dd401753fb348ce1266
- [497] MINISTRY OF COMMERCE OF THE PEOPLE’S REPUBLIC OF CHINA. “Regulations of the people’s republic of china on the administration of dual-use items export control,” Accessed: Jul. 21, 2026. [Online]. Available: www.gov.cn/zhengce/zhengceku/202410/content_6981400.htm
- [498] MINISTRY OF COMMERCE OF THE PEOPLE’S REPUBLIC OF CHINA. “Catalogue of technologies prohibited or restricted from export of china,” Accessed: Jul. 21, 2026. [Online]. Available: fms.mofcom.gov.cn/zcfg/jsjckzcfg/art/2025/art_ba35a101c22c4f6e844f749cb0a98552.html

- [527] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. “Adversarial machine learning: A taxonomy and terminology of attacks and mitigations. ”[Online]. Available: doi.org/10.6028/NIST.AI.100-2e2025
- [551] CISA, NSA. “Careful adoption of agentic AI services. ”[Online]. Available: <https://www.cisa.gov/>
- [575] AGENCIA ESPAÑOLA DE PROTECCIÓN DE DATOS. “Agentic artificial intelligence from the perspective of data protection,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.aepd.es/en/guides/agentic-artificial-intelligence.pdf>
- [786] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. “Guidelines for media sanitization (NIST SP 800-88 rev. 2).”
- [839] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. “SP 800-53 control overlays for securing AI systems (COSAiS),” Accessed: Jul. 20, 2026. [Online]. Available: <https://csrc.nist.gov/projects/cosais>
- [840] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. “AI agent standards initiative,” Accessed: Jul. 20, 2026. [Online]. Available: <https://www.nist.gov/artificial-intelligence/ai-agent-standards-initiative>
- [912] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. “Accelerating the adoption of software and artificial intelligence agent identity and authorization. ”[Online]. Available: <https://csrc.nist.gov/pubs/other/2026/02/05/accelerating-the-adoption-of-software-and-ai-agent/ipd>
- [973] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. “Incident response recommendations and considerations for cybersecurity risk management: A csf 2.0 community profile. ”[Online]. Available: <https://doi.org/10.6028/NIST.SP.800-61r3>
- [1044] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. “Request for information regarding security considerations for artificial intelligence agents,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.federalregister.gov/documents/2026/01/08/2026-00206/request-for-information-regarding-security-considerations-for-artificial-intelligence-agents>

- [5] K. Wang et al., *A comprehensive survey in LLM (Agent) full stack safety: Data, training and deployment*, Apr. 2025. arXiv: 2504.15585 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.15585>
- [7] Y. Sun et al., *A survey on the unique security of autonomous and collaborative LLM agents: Threats, defenses, and futures*, Mar. 2026. [Online]. Available: <https://www.preprints.org/manuscript/202602.1655/v2>
- [17] V. Siu et al., *A framework for formalizing LLM agent security*, Mar. 2026. arXiv: 2603.19469 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.19469>
- [18] S. Sana, J. Wu, and M. T. Wells, *Democratic preference alignment via sortition-weighted RLHF*, Feb. 2026. arXiv: 2602.05113 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2602.05113>
- [19] T. Zhang, H. Triedman, and V. Shmatikov, *Deep-research agents can be poisoned via user-generated content*, May 2026. arXiv: 2605.24245 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.24245>
- [20] T. Shi et al., *Progent: Programmable privilege control for LLM agents*, 2025. arXiv: 2504.11703 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.11703>
- [23] M. Raz, M. Udeshi, P. V. S. Charan, P. Krishnamurthy, F. Khorrami, and R. Karri, *Ransomware 3.0: Self-composing and LLM-orchestrated*, Aug. 2025. arXiv: 2508.20444 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.20444>
- [24] J. Guan, T. Blanchard, H. Foerster, H. Jia, G. Huang, and N. Papernot, *AI agents enable adaptive computer worms*, Jun. 2026. arXiv: 2606.03811 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.03811>
- [25] X. Xu et al., *ASTRA: Autonomous spatial-temporal red-teaming for AI software assistants*, Aug. 2025. arXiv: 2508.03936 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.03936>
- [26] Z. Wang, T. Shi, J. He, M. Cai, J. Zhang, and D. Song, *CyberGym: Evaluating AI agents' cybersecurity capabilities with real-world vulnerabilities at scale*, Jun. 2025. arXiv: 2506.02548 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2506.02548>
- [39] N. Shapira et al., *Agents of chaos*, Feb. 2026. arXiv: 2602.20021. [Online]. Available: <https://arxiv.org/abs/2602.20021>
- [54] H. Orgad et al., *Large language models generate harmful content using a distinct, unified mechanism, shared across harm types*, Apr. 2026. arXiv: 2604.09544 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2604.09544>
- [59] R. Jha, C. Zhang, V. Shmatikov, and J. X. Morris, *Harnessing the universal geometry of embeddings*, May 2025. arXiv: 2505.12540 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2505.12540>
- [70] Z. Han and Q. Zhu, *Toward a dynamic Stackelberg game-theoretic framework for agentic AI defense against LLM jailbreaking*, Jul. 2025. arXiv: 2507.08207 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2507.08207>

- [93] X. Yang, B. Stevanoski, M. Meeus, and Y.-A. de Montjoye, *Checkpoint-GCG: Auditing and attacking fine-tuning-based prompt injection defenses*, 2025. arXiv: 2505.15738 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2505.15738>
- [113] B. Gyevnár and A. Kasirzadeh, *Bridging the gap in the responsible AI divides*, 2026. arXiv: 2603.14495 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2603.14495>
- [154] H. Li et al., *IDA-Bench: Evaluating LLMs on interactive guided data analysis*, 2025. arXiv: 2505.18223 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2505.18223>
- [186] Y. Bao et al., *SafeWork-R1: Coevolving safety and intelligence under the AI-45° law*, Jul. 2025. arXiv: 2507.18576 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2507.18576>
- [194] X. Hou, Y. Zhao, S. Wang, and H. Wang, *MCP: Landscape, security threats, and future research directions*, Mar. 2025. arXiv: 2503.23278 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2503.23278>
- [216] E. Debenedetti et al., *Defeating prompt injections by design*, 2025. arXiv: 2503.18813 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2503.18813>
- [225] I. Habler, K. Huang, V. S. Narajala, and P. Kulkarni, *Building a secure agentic AI application leveraging A2A protocol*, Apr. 2025. arXiv: 2504.16902 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.16902>
- [227] J. Gottweis et al., *Accelerating scientific discovery with co-scientist*, Feb. 2025. arXiv: 2502.18864 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2502.18864>
- [238] N. Agarwal et al., *Cosmos world foundation model platform for physical AI*, Jan. 2025. arXiv: 2501.03575 [cs.CV]. [Online]. Available: <https://arxiv.org/abs/2501.03575>
- [303] J. Zhang et al., *UAM: A dual-stream perspective on forgetting in VLA training*, May 2026. arXiv: 2605.15735 [cs.CV]. [Online]. Available: <https://arxiv.org/abs/2605.15735>
- [304] Z. Li et al., *Hand-in-the-Loop: Improving VLA policies for dexterous manipulation via seamless hand-arm intervention*, May 2026. arXiv: 2605.15157 [cs.RO]. [Online]. Available: <https://arxiv.org/abs/2605.15157>
- [305] Y. He et al., *PaSa: An LLM agent for comprehensive academic paper search*, Jan. 2025. arXiv: 2501.10120 [cs.IR]. [Online]. Available: <https://arxiv.org/abs/2501.10120>
- [307] T. Zou, Y. He, T. Qiu, Y. Lin, and H. Li, *Task-focused memorization for multimodal agents*, 2026. arXiv: 2605.31075 [cs.CV]. [Online]. Available: <https://arxiv.org/abs/2605.31075>
- [318] Y. Bai et al., *Kimi k2: Open agentic intelligence*, Jul. 2025. arXiv: 2507.20534 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2507.20534>
- [333] Z. Z. Ren et al., *DeepSeek-Prover-V2: Advancing formal mathematical reasoning via reinforcement learning for subgoal decomposition*, Apr. 2025. arXiv: 2504.21801 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2504.21801>
- [334] S. V. Marjanović et al., *DeepSeek-R1 thoughtology: Let's think about LLM reasoning*, Apr. 2025. arXiv: 2504.07128 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2504.07128>
- [339] D. Guo et al., *DeepSeek-R1: Incentivizing reasoning capability in LLMs via reinforcement learning*, Jan. 2025. arXiv: 2501.12948 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2501.12948>

- [346] M. Assran et al., *V-JEPA 2: Self-supervised video models enable understanding, prediction and planning*, Jun. 2025. arXiv: 2506.09985 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2506.09985>
- [350] S. Chennabasappa et al., *LlamaFirewall: An open source guardrail system for building secure AI agents*, May 2025. arXiv: 2505.03574 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2505.03574>
- [360] N. Acharya and G. K. Gupta, *A formal security framework for MCP-based AI agents: Threat taxonomy, verification models, and defense mechanisms*, Apr. 2026. arXiv: 2604.05969 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.05969>
- [368] L. Ahmad, S. Agarwal, M. Lampe, and P. Mishkin, *OpenAI's approach to external red teaming for AI models and systems*, Mar. 2025. arXiv: 2503.16431 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2503.16431>
- [374] S. Gaire, S. Gyawali, S. Mishra, S. Niroula, D. Thakur, and U. Yadav, *Systematization of knowledge: Security and safety in the MCP ecosystem*, Dec. 2025. arXiv: 2512.08290 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.08290>
- [386] I. Santos-Grueiro, *What browsers do in the shaders: A measurement study of WebGPU privacy*, Jun. 2026. arXiv: 2606.26412 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.26412>
- [387] Y. Zhang, R. Nazaraliyev, S. B. Dutta, A. Marquez, K. Barker, and N. Abu-Ghazaleh, *NVBleed: Covert and side-channel attacks on NVIDIA multi-GPU interconnect*, Mar. 2025. arXiv: 2503.17847 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2503.17847>
- [388] S. Imtiaz, U. Reinsalu, and T. Ghasempouri, *Translating common security assertions across processor designs: A RISC-V case study*, Feb. 2025. arXiv: 2502.10194 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2502.10194>
- [389] Z. Gu et al., *Blueprint, bootstrap, and bridge: A security look at NVIDIA GPU confidential computing*, Jul. 2025. arXiv: 2507.02770 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2507.02770>
- [392] M. Chrapek, M. Copik, E. Mettaz, and T. Hoefler, *Confidential LLM inference: Performance and cost across CPU and GPU TEEs*, 2025. arXiv: 2509.18886 [cs.PF]. [Online]. Available: <https://arxiv.org/abs/2509.18886>
- [396] J. Forough, M. Kogias, and H. Haddadi, *When agents handle secrets: A survey of confidential computing for agentic AI*, May 2026. arXiv: 2605.03213 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.03213>
- [398] P. S. Sinaki, Z. Ahmad, W. Xie, M. Sebrechts, J. Kjällman, and L. J. Gunn, *TrustMee: Self-verifying remote attestation evidence*, Feb. 2026. arXiv: 2602.13148 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.13148>
- [401] J. Mao and X. Chang, *PDRIMA: A policy-driven runtime integrity measurement and attestation approach for ARM TrustZone-based TEE*, 2025. arXiv: 2512.06500 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.06500>
- [402] M. K. Kiri, I. D. O. Nunes, A. Francillon, and N. Rattanavipanon, *Verifiable and confidential DNN inference on low-end edge devices*, 2026. arXiv: 2606.07470 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.07470>

- [407] T. Shi et al., *An empirical study of OpenPangu quantization on Ascend NPU*, Jun. 2026. arXiv: 2606.21257 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2606.21257>
- [408] Y. He, P. Niu, J. Chen, C. Zhang, and C. Yang, *W4A16 mixed-precision matrix multiplication on decoupled architecture: Kernel design and memory bottleneck analysis for Ascend NPUs*, Jan. 2026. arXiv: 2601.16536 [cs.DC]. [Online]. Available: <https://arxiv.org/abs/2601.16536>
- [410] J. Mao and X. Chang, *PS-UIE: Privilege-separated integrity enforcement for user-space executable objects in confidential VMs*, Jun. 2026. arXiv: 2606.04549 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.04549>
- [411] P. Zhao et al., *Unleashing low-bit inference on Ascend NPUs: A comprehensive evaluation of HiFloat formats*, Feb. 2026. arXiv: 2602.12635 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2602.12635>
- [412] J. Yang et al., *ENEC: A lossless AI model compression method enabling fast inference on Ascend NPUs*, Apr. 2026. arXiv: 2604.03298 [cs.AR]. [Online]. Available: <https://arxiv.org/abs/2604.03298>
- [413] Y. Xie et al., *M100: An orchestrated dataflow architecture powering general AI computing*, Apr. 2026. arXiv: 2604.17862 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2604.17862>
- [414] J. Zhang et al., *Quant.npu: Enabling efficient mobile NPU inference for on-device LLMs via fully static quantization*, May 2026. arXiv: 2605.20295 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2605.20295>
- [415] L. Chen et al., *HeteroLLM: Accelerating large language model inference on mobile SoCs with heterogeneous AI accelerators*, Jan. 2025. arXiv: 2501.14794 [cs.DC]. [Online]. Available: <https://arxiv.org/abs/2501.14794>
- [418] P. Zuo et al., *Serving large language models on Huawei CloudMatrix384*, Jun. 2025. arXiv: 2506.12708 [cs.DC]. [Online]. Available: <https://arxiv.org/abs/2506.12708>
- [452] H. Xu et al., *LoopTrap: Termination poisoning attacks on LLM agents*, May 2026. arXiv: 2605.05846 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.05846>
- [455] B. Crawford, J. Phillips, and P. McClure, *Automatically attacking software reverse engineering AI agents*, May 2026. arXiv: 2605.30667 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.30667>
- [467] V. Mayoral-Vilches et al., *CAI: An open, bug bounty-ready cybersecurity AI*, 2025. arXiv: 2504.06017 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.06017>
- [500] T. Bach, D. Nguyen, T. M. Le, and T. Tran, *Rethinking deep alignment through the lens of incomplete learning*, Nov. 2025. arXiv: 2511.12155 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2511.12155>
- [501] S. Mitra, R. Patel, S. Mittal, M. R. Rahman, and S. Rahimi, *AgenticCyOps: Securing multi-agentic AI integration in enterprise cyber operations*, Sep. 2026. arXiv: 2603.09134 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.09134>
- [503] M. Osmond and T. Jegu, *Mind the gap: How the technical mechanism of agentic AI outpace global legal frameworks*, Mar. 2026. arXiv: 2603.27075 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2603.27075>
- [505] G. Liu et al., *Automatic hard example synthesis with multi-level agentic data curation*, Jul. 2026. arXiv: 2607.14256 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2607.14256>

- [506] H. Yang, H. Na, and D. Choi, *An empirical study of privacy leakage chains via prompt injection in black-box chatbot environments*, 2026. arXiv: 2605.18133 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.18133>
- [508] B. Jain, S. O. Arik, and H. K. Thakur, *Adversarial attacks on multimodal large language models: A comprehensive survey*, Mar. 2026. arXiv: 2603.27918 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.27918>
- [509] B. Sidik and L. Rokach, *MEMTIER: Tiered memory architecture and retrieval bottleneck analysis for long-running autonomous AI agents*, May 2026. arXiv: 2605.03675 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.03675>
- [510] Z. S. Chin, *Dimensional characterization and pathway modeling for catastrophic AI risks*, Aug. 2025. arXiv: 2508.06411 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2508.06411>
- [511] K. Pan and R. Hou, *Beyond autonomy: A dynamic tiered agentrunner framework for governable and resilient enterprise AI execution*, May 2026. arXiv: 2605.10223 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.10223>
- [512] Y. Wang et al., *From agent traces to trust: A survey of evidence tracing and execution provenance in LLM agents*, Jun. 2026. arXiv: 2606.04990 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.04990>
- [513] J. Zhu et al., *MiniScope: A least privilege framework for authorizing tool calling agents*, Dec. 2025. arXiv: 2512.11147 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.11147>
- [514] P. Zhu, L. Li, Y. Lyu, L. Sun, S. Su, and J. Shao, *Collaborative shadows: Distributed backdoor attacks in LLM-based multi-agent systems*, Oct. 2025. arXiv: 2510.11246 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.11246>
- [516] I. W. Eisenberg, L. Gamboa, and E. Sherman, *The unified control framework: Establishing a common foundation for enterprise AI governance, risk management and regulatory compliance*, Mar. 2025. arXiv: 2503.05937 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2503.05937>
- [517] S. Roy et al., *PReMise: Policy rubrics as measurement specifications for LLM judges*, 2026. arXiv: 2605.30803 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.30803>
- [521] T. Zhang et al., *AgentSentry: Mitigating indirect prompt injection in LLM agents via temporal causal diagnostics and context purification*, Feb. 2026. arXiv: 2602.22724 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.22724>
- [525] L. Lu et al., *Adversarial training for multimodal large language models against jailbreak attacks*, 2025. arXiv: 2503.04833 [cs.CV]. [Online]. Available: <https://arxiv.org/abs/2503.04833> v2
- [526] J. Tan et al., *From prompt injection to persistent control: Defending agentic harness against trojan backdoors*, May 2026. arXiv: 2605.31042 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.31042>
- [530] Y. Louck, *Securing LLM-agent long-term memory against poisoning: Non-malleable, origin-bound authority with machine-checked guarantees*, Jun. 2026. arXiv: 2606.24322 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.24322>

- [531] C. Ouyang and R. Hou, *MemLineage: Lineage-guided enforcement for LLM agent memory*, May 2026. arXiv: 2605.14421 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.14421>
- [532] Z. Lin et al., *A survey on long-term memory security in LLM agents: Attacks, defenses, and governance across the memory lifecycle*, Apr. 2026. arXiv: 2604.16548 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.16548>
- [537] L. Staufer et al., *The 2025 AI agent index: Documenting technical and safety features of deployed agentic AI systems*, 2026. arXiv: 2602.17753 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2602.17753>
- [539] Z. Ji et al., *Taming various privilege escalation in LLM-based agent systems: A mandatory access control framework*, Jan. 2026. arXiv: 2601.11893 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.11893>
- [541] R. Liang et al., *Don't trust your upstream: Exploiting LLM multi-agent system via topology-guided adversarial propagation*, Dec. 2025. arXiv: 2512.04129 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.04129>
- [543] Y. Long and S. Li, *Funcpoison: Poisoning function library to hijack multi-agent autonomous driving systems*, Sep. 2025. arXiv: 2509.24408 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2509.24408>
- [548] A. Yuan, Z. Su, and Y. Zhao, *AEGIS: No tool call left unchecked – a pre-execution firewall and audit layer for AI agents*, Mar. 2026. arXiv: 2603.12621 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.12621>
- [553] D. Schwarz, *Countermind: A multi-layered security architecture for large language models*, Oct. 2025. arXiv: 2510.11837 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.11837>
- [554] R. Wen, H. Li, C. Xiao, and N. Zhang, *AgentSys: Secure and dynamic LLM agents through explicit hierarchical memory management*, Feb. 2026. arXiv: 2602.07398 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.07398>
- [556] H. Owiredun-Ashley, *ADVERSA: Measuring multi-turn guardrail degradation and judge reliability in large language models*, Mar. 2026. arXiv: 2603.10068 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.10068>
- [558] D. Son, *Governed MCP: Kernel-level tool governance for AI agents via logit-based safety primitives*, Apr. 2026. arXiv: 2604.16870 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.16870>
- [559] R. Marchand et al., *Quantifying frontier LLM capabilities for container sandbox escape*, Mar. 2026. arXiv: 2603.02277 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.02277>
- [561] A. S. Patlan, P. Sheng, S. A. Hebbur, P. Mittal, and P. Viswanath, *MURMUR: Using cross-user chatter to break collaborative language agents in groups*, Nov. 2025. arXiv: 2511.17671 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2511.17671>
- [563] X. He, D. Wu, Y. Zhai, and K. Sun, *SentinelAgent: Graph-based anomaly detection in multi-agent systems*, May 2025. arXiv: 2505.24201 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2505.24201>

- [564] W. Fu, H. Wang, J. Gao, G. Wan, and T. Jiang, *Sanitize your responses: Mitigating privacy leakage in large language models*, Sep. 2025. arXiv: 2509.24488 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2509.24488>
- [567] Z. Sun et al., *Stego battlefield: Evaluating image steganography attacks and steganalysis defenses*, May 2026. arXiv: 2605.05789 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.05789>
- [571] C. Lam, J. Li, L. Zhang, and K. Zhao, *Governing evolving memory in LLM agents: Risks, mechanisms, and the stability and safety governed memory (ssgm) framework*, Mar. 2026. arXiv: 2603.11768 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2603.11768>
- [572] V. P. Bhardwaj, *SuperLocalMemory: Privacy-preserving multi-agent memory with Bayesian trust defense against memory poisoning*, Feb. 2026. arXiv: 2603.02240 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2603.02240>
- [574] L. S. Kumar, Y. Ba, and R. Pan, *Memarchitect: A policy driven memory governance layer*, Mar. 2026. arXiv: 2603.18330 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2603.18330>
- [578] F. Chen, T. Wu, V. Nguyen, S. Nepal, and C. Rudolph, *Agents at risk: How users unwittingly undermine LLM safety*, Jan. 2026. arXiv: 2601.10758 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.10758>
- [579] A. A. Khan et al., *Safety aware task planning via large language models in robotics*, Mar. 2025. arXiv: 2503.15707 [cs.RO]. [Online]. Available: <https://arxiv.org/abs/2503.15707>
- [581] A. Zhou and R. Arel, *Tempest: Autonomous multi-turn jailbreaking of large language models with tree search*, Mar. 2025. arXiv: 2503.10619 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2503.10619>
- [582] J. Albrethsen, Y. Datta, K. Kumar, and S. Rajasekar, *Deepcontext: Stateful real-time detection of multi-turn adversarial intent drift in LLMs*, Feb. 2026. arXiv: 2602.16935 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2602.16935>
- [583] H. Hu, A. Robey, and C. Liu, *Steering dialogue dynamics for robustness against multi-turn jailbreaking attacks*, Feb. 2025. arXiv: 2503.00187 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2503.00187>
- [585] J. Luo et al., *AgentGuard: An attribute-based access control framework for Tool-Use LLM-based agent*, May 2026. arXiv: 2605.28071 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.28071>
- [586] S. Pan, X. Sun, T. Zhang, D. Liao, M. Si, and Z. Xing, *SkillGuard: A permission framework for agent skills*, Jun. 2026. arXiv: 2606.03024 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.03024>
- [587] C. Wang and Y. Zheng, *Sandlock: Confining AI agent code with unprivileged Linux primitives*, May 2026. arXiv: 2605.26298 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.26298>
- [588] B. Sidik and L. Rokach, *Beyond static sandboxing: Learned capability governance for autonomous AI agents*, Apr. 2026. arXiv: 2604.11839 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.11839>
- [590] A. Azarafrooz, *Cross-session threats in AI agents: Benchmark, evaluation, and algorithms*, Apr. 2026. arXiv: 2604.21131 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.21131>

- [592] P. Desai, L. Tang, Y. Meng, and Z. Xi, *SafeGPT: Preventing data leakage and unethical outputs in enterprise LLM use*, Jan. 2026. arXiv: 2601.06366 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.06366>
- [593] C. Li et al., *Towards security-auditable LLM agents: A unified graph representation*, May 2026. arXiv: 2605.06812 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.06812>
- [595] Z. Zou, Z. Liu, L. Zhao, and Q. Zhan, *BlockA2A: Towards secure and verifiable agent-to-agent interoperability*, Aug. 2025. arXiv: 2508.01332 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.01332>
- [597] E. Sarabamoun, *Special-character adversarial attacks on open-source language model*, Aug. 2025. arXiv: 2508.14070 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.14070>
- [598] K. Gao et al., *Imperceptible jailbreaking against large language models*, Oct. 2025. arXiv: 2510.05025 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2510.05025>
- [600] D. Das, J. Piet, D. Kaviani, L. Beurer-Kellner, F. Tramèr, and D. Wagner, *Trojan hippo: Weaponizing agent memory for data exfiltration*, 2026. arXiv: 2605.01970 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.01970>
- [601] H. Karthikeyan et al., *AgentCrypt: Advancing privacy and (secure) computation in AI agent collaboration*, Dec. 2025. arXiv: 2512.08104 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.08104>
- [603] R. Wei et al., *The trojan knowledge: Bypassing commercial LLM guardrails via harmless prompt weaving and adaptive tree search*, 2025. arXiv: 2512.01353 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.01353>
- [605] Y. Xie et al., *Red-teaming coding agents from a tool-invocation perspective: An empirical security assessment*, Sep. 2025. arXiv: 2509.05755 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2509.05755>
- [606] R. J. Mitchell, *When the agent is the adversary: Architectural requirements for agentic AI containment after the april 2026 frontier model escape*, Apr. 2026. arXiv: 2604.23425 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.23425>
- [607] U. Uchibeke, *Before the tool call: Deterministic pre-action authorization for autonomous AI agents*, Mar. 2026. arXiv: 2603.20953 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.20953>
- [610] S. Prakash, *LDP: An identity-aware protocol for multi-agent LLM systems*, 2026. arXiv: 2603.08852 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2603.08852>
- [611] Z. Chen et al., *How your credentials are leaked by LLM agent skills: An empirical study*, Apr. 2026. arXiv: 2604.03070 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.03070>
- [612] G. Shi et al., *SoK: Trust-authorization mismatch in LLM agent interactions*, Dec. 2025. arXiv: 2512.06914 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.06914>
- [613] W. Zhu, Z. Xiang, W. Niu, and L. Guan, *MetaBreak: Jailbreaking online LLM services via special token manipulation*, Oct. 2025. arXiv: 2510.10271 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.10271>
- [614] S. Barua, M. Rahman, M. J. Sadek, R. Islam, S. Khaled, and A. Kabir, *Guardians of the agentic system: Preventing many shots jailbreak with agentic system*, 2025. arXiv: 2502.16750 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2502.16750>

- [615] S. K. R. Kasu, N. Lukas, and S. Poppi, *When the chain of thought knows better: Failure modes in multi-turn reasoning models*, Jun. 2026. arXiv: 2606.10740 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2606.10740>
- [616] Z. Shan, J. Xin, Y. Zhang, and M. Xu, *Don't let the claw grip your hand: A security analysis and defense framework for OpenClaw*, Mar. 2026. arXiv: 2603.10387 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.10387>
- [617] D. Das, L. Beurer-Kellner, M. Fischer, and M. Baader, *CommandSans: Securing AI agents with surgical precision prompt sanitization*, Oct. 2025. arXiv: 2510.08829 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.08829>
- [623] S. S. Srivastava and H. He, *MemoryGraft: Persistent compromise of LLM agents via poisoned experience retrieval*, Dec. 2025. arXiv: 2512.16962 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.16962>
- [626] T. Jiralerspong, F. Kondrup, and Y. Bengio, *Noticing the watcher: LLM agents can infer CoT monitoring from blocking feedback*, Mar. 2026. arXiv: 2603.16928 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.16928>
- [627] J. Zhang et al., *ReasoningLens: Hierarchical visualization and diagnostic auditing for large reasoning models*, 2026. arXiv: 2606.23404 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2606.23404>
- [629] X. Lin et al., *SafeHarness: Lifecycle-integrated security architecture for LLM-based agent deployment*, Apr. 2026. arXiv: 2604.13630 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.13630>
- [631] A. Cartagena and A. Teixeira, *Mind the GAP: Text safety does not transfer to tool-call safety in LLM agents*, 2026. arXiv: 2602.16943 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2602.16943>
- [634] A. Goswami, *Agentic JWT: A secure delegation protocol for autonomous AI agents*, Sep. 2025. arXiv: 2509.13597 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2509.13597>
- [636] Y. Ge, *Governance architecture for autonomous agent systems: Threats, framework, and engineering practice*, Mar. 2026. arXiv: 2603.07191 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.07191>
- [637] Y. Wang et al., *From agent traces to trust: Evidence tracing and execution provenance in LLM agents*, Jun. 2026. arXiv: 2606.04990 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.04990>
- [638] H. Zhang, Y. Nian, and Y. Zhao, *Agent audit: A security analysis system for LLM agent applications*, Mar. 2026. arXiv: 2603.22853 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.22853>
- [642] Q. Wei et al., *A-MemGuard: A proactive defense framework for LLM-based agent memory*, Oct. 2025. arXiv: 2510.02373 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.02373>
- [643] S. Rahman et al., *X-Teaming: Multi-turn jailbreaks and defenses with adaptive multi-agents*, Apr. 2025. arXiv: 2504.13203 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.13203>

- [644] H. Dingeto and W. Leeney, *AgentRedBench: Dynamic redteaming and integration-aware defense for LLM agents over saas integrations*, Jun. 2026. arXiv: 2606.02240 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.02240>
- [645] Y. Zhao, Z. Zhang, Q. Le, L. Qu, and Z. Xu, *Beyond Goodhart's law: A dynamic benchmark for evaluating compliance in multi-agent systems*, Jun. 2026. arXiv: 2606.07805 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2606.07805>
- [646] Y. Nian, A. Yuan, H. Zhang, J. Li, and Y. Zhao, *Auditable agents*, 2026. arXiv: 2604.05485 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2604.05485>
- [647] T. Jiang, Y. Wang, J. Liang, and T. Wang, *AgentLab: Benchmarking LLM agents against long-horizon attacks*, Feb. 2026. arXiv: 2602.16901 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2602.16901>
- [652] Z. Ren et al., *GateMem: Benchmarking memory governance in multi-principal shared-memory agents*, Jun. 2026. arXiv: 2606.18829 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2606.18829>
- [656] H. Li et al., *Can you trust the vectors in your vector database? black-hole attack from embedding space defects*, Apr. 2026. arXiv: 2604.05480 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.05480>
- [658] B. Zhang et al., *Benchmarking poisoning attacks against retrieval-augmented generation*, May 2025. arXiv: 2505.18543 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2505.18543>
- [659] Q. Zhang, E. E. Wang, J. Li, and X. Wang, *Burn-after-use for preventing data leakage through a secure multi-tenant architecture in enterprise LLM*, Jan. 2026. arXiv: 2601.06627 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.06627>
- [661] F. El Yagoubi, G. Badu-Marfo, and R. Al Mallah, *AgentLeak: A benchmark for internal-channel privacy leakage in multi-agent LLM systems*, Feb. 2026. arXiv: 2602.11510 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2602.11510>
- [662] P. Dash, T. Ge, A. Jain, T. Shah, and Z. Shang, *From untrusted input to trusted memory: A systematic study of memory poisoning attacks in LLM agents*, Jun. 2026. arXiv: 2606.04329 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.04329>
- [663] J.-J. Li et al., *STAC: When innocent tools form dangerous chains to jailbreak LLM agents*, Sep. 2025. arXiv: 2509.25624 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2509.25624>
- [665] A. Rath, *Agent drift: Quantifying behavioral degradation in multi-agent LLM systems over extended interactions*, Jan. 2026. arXiv: 2601.04170 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2601.04170>
- [674] P. Mateo-Torrejón and A. Sánchez-Macián, *GAMMAF: A common framework for graph-based anomaly monitoring benchmarking in LLM multi-agent systems*, Apr. 2026. arXiv: 2604.24477 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.24477>
- [676] P. Michelakis, Y. Hadjiyiannis, and D. Stamoulis, *CORE: Full-path evaluation of LLM agents beyond final state*, Sep. 2025. arXiv: 2509.20998 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2509.20998>
- [677] A. Guasch and M. I. Valdez, *The STAR-XAI protocol: A framework for inducing and verifying agency, reasoning, and reliability in AI agents*, Sep. 2025. arXiv: 2509.17978 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2509.17978>

- [678] S. Ghosh et al., *A safety and security framework for real-world agentic systems*, Nov. 2025. arXiv: 2511.21990 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2511.21990>
- [679] A. Fogel, O. Hofman, E. Cohen, and R. Vainshtein, *Inference-time backdoors via hidden instructions in LLM chat templates*, Feb. 2026. arXiv: 2602.04653 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.04653>
- [680] S. Xie et al., *The proxy knows too much: Sealing LLM API routers with attested TEEs*, Jun. 2026. arXiv: 2606.16358 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.16358>
- [681] Y. Liu et al., *Secure multi-LLM agentic AI and agentification for edge general intelligence by zero-trust: A survey*, Aug. 2025. arXiv: 2508.19870 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.19870>
- [682] C. L. Wang, T. Singhal, A. Kelkar, and J. Tuo, *MI9: An integrated runtime governance framework for agentic AI*, Aug. 2025. arXiv: 2508.03858 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.03858>
- [683] Y. Fu, X. Yuan, and D. Wang, *RAS-Eval: A comprehensive benchmark for security evaluation of LLM agents in real-world environments*, Jun. 2025. arXiv: 2506.15253 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2506.15253>
- [684] S. Pulipaka et al., *Hidden in memory: Sleeper memory poisoning in LLM agents*, May 2026. arXiv: 2605.15338 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.15338>
- [686] M. Rajagopalan and V. Rao, *Authenticated workflows: A systems approach to protecting agentic ai*, 2026. arXiv: 2602.10465 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.10465>
- [687] T. Shi et al., *Organizational control layer: Governance infrastructure at the execution boundary of LLM agent systems*, Jun. 2026. arXiv: 2606.04306 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.04306>
- [688] T. L. Tuan and A. Sanyal, *Toward pre-deployment assurance for enterprise AI agents: Ontology-grounded simulation and trust certification*, Jun. 2026. arXiv: 2606.04037 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2606.04037>
- [689] R. Khan, D. Joyce, and M. Habiba, *AGENTS SAFE: A unified framework for ethical assurance and governance in agentic AI*, Dec. 2025. arXiv: 2512.03180 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2512.03180>
- [690] M. Horovicz, *AgentSHAP: Interpreting LLM agent tool importance with Monte Carlo Shapley value estimation*, Dec. 2025. arXiv: 2512.12597 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2512.12597>
- [691] S. Khanzadeh, *Project Ariadne: A structural causal framework for auditing faithfulness in LLM agents*, Jan. 2026. arXiv: 2601.02314 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2601.02314>
- [693] J. Kim, S. Mun, S. Lee, J. Cho, and J. Ok, *Towards faithful agentic XAI: A verification method and an open-world benchmark for better model faithfulness*, May 2026. arXiv: 2605.27879 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.27879>
- [696] Y. Ma and S. Schmid, *SecureClaw: Clawing back control of LLM agents*, Jun. 2026. arXiv: 2606.09549 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.09549>

- [700] S. K. Ravindran, *Portable agent memory: A protocol for cryptographically-verified memory transfer across heterogeneous AI agents*, May 2026. arXiv: 2605.11032 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.11032>
- [705] Z. Deng, J. Gui, and W. Zhang, *From secure agentic AI to secure agentic web: Challenges, threats, and future directions*, Mar. 2026. arXiv: 2603.01564 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.01564>
- [707] H. Li, R. Wen, S. Shi, N. Zhang, Y. Vorobeychik, and C. Xiao, *AgentDyn: Are your agent security defenses deployable in real-world dynamic environments?* Feb. 2026. arXiv: 2602.03117 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.03117>
- [710] X. Ma, T. Li, C. Xiao, Z. Yu, N. Zhang, and Y. Vorobeychik, *AutoDojo: Adaptive attacks expose superficial defenses and user-underspecification limits in LLM agents*, Jun. 2026. arXiv: 2606.15057 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.15057>
- [717] A. Shahriar, M. N. Rahman, S. Ahmed, F. Sadeque, and M. R. Parvez, *A survey on agentic security: Applications, threats and defenses*, Oct. 2025. arXiv: 2510.06445 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.06445>
- [718] A. Dhodapkar and F. Pishori, *SafetyDrift: Predicting when AI agents cross the line before they actually do*, Mar. 2026. arXiv: 2603.27148 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2603.27148>
- [719] Z. Yan et al., *Do coding agents understand least-privilege authorization?* May 2026. arXiv: 2605.14859 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.14859>
- [720] T. Kumarage, Z. Li, A. Lou, Y. Zhao, W. Wei, and Y. Bao, *Personalized attacks of social engineering in multi-turn conversations: LLM agents for simulation and detection*, Mar. 2025. arXiv: 2503.15552 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2503.15552>
- [721] Y. Xie et al., *What if prompt injection never left? exploring cross-session stored prompt injection in agentic systems*, Jun. 2026. arXiv: 2606.04425 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.04425>
- [722] J. Liu et al., *TraceAegis: Securing LLM-based agents via hierarchical and behavioral anomaly detection*, Oct. 2025. arXiv: 2510.11203 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.11203>
- [723] Y. Chen et al., *HarmonyGuard: Toward safety and utility in web agents via adaptive policy enhancement and dual-objective optimization*, Aug. 2025. arXiv: 2508.04010 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.04010>
- [724] M. Nasr et al., *The attacker moves second: Stronger adaptive attacks bypass defenses against LLM jailbreaks and prompt injections*, Oct. 2025. arXiv: 2510.09023 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.09023>
- [725] N. Bhuiya, M. Aggarwal, and D. Purwar, *Plague: Plug-and-play framework for lifelong adaptive generation of multi-turn exploits*, Oct. 2025. arXiv: 2510.17947 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.17947>
- [726] H. Errico, J. Ngiam, and S. Sojan, *Securing the model context protocol (MCP): Risks, controls, and governance*, Nov. 2025. arXiv: 2511.20920 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2511.20920>

- [728] S. Cheng et al., *ForgeDAN: An evolutionary framework for jailbreaking aligned large language models*, Nov. 2025. arXiv: 2511.13548 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2511.13548>
- [735] X. Zhang et al., *MemMorph: Tool hijacking in LLM agents via memory poisoning*, May 2026. arXiv: 2605.26154 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.26154>
- [745] M. Lupinacci, F. A. Pironti, F. Blefari, F. Romeo, L. Arena, and A. Furfaro, *The dark side of LLMs: Agent-based attacks for complete computer takeover*, Jul. 2025. arXiv: 2507.06850 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2507.06850>
- [753] M. Zha and X. Wang, *Autonomous LLM agent worms: Cross-platform propagation, automated discovery and temporal re-entry defense*, May 2026. arXiv: 2605.02812 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.02812>
- [773] P. Li et al., *SAFEFLOW: A principled protocol for trustworthy and transactional autonomous agent systems*, Jun. 2025. arXiv: 2506.07564 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2506.07564>
- [775] S. Alqithami, *Forgetful but faithful: A cognitive memory architecture and benchmark for privacy-aware generative agents*, 2025. arXiv: 2512.12856 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2512.12856>
- [777] P. He et al., *To trust or not to trust: Attention-based trust management for LLM multi-agent systems*, Jun. 2025. arXiv: 2506.02546 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2506.02546>
- [778] V. Ojewale, H. Suresh, and S. Venkatasubramanian, *Audit trails for accountability in large language models*, Jan. 2026. arXiv: 2601.20727 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.20727>
- [779] Y. Cai, W. Tang, C. Wen, and S. Qin, *Ghost in the agent: Redefining information flow tracking for LLM agents*, Apr. 2026. arXiv: 2604.23374 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.23374>
- [782] S. Zhang et al., *PrivWeb: Unobtrusive and content-aware privacy protection for web agents*, Sep. 2025. arXiv: 2509.11939 [cs.HC]. [Online]. Available: <https://arxiv.org/abs/2509.11939>
- [785] P. Chhikara, D. Khant, S. Aryan, T. Singh, and D. Yadav, *Mem0: Building production-ready AI agents with scalable long-term memory*, Apr. 2025. arXiv: 2504.19413 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2504.19413>
- [788] A. Rezazadeh, Z. Li, A. Lou, Y. Zhao, W. Wei, and Y. Bao, *Collaborative memory: Multi-user memory sharing in LLM agents with dynamic access control*, May 2025. arXiv: 2505.18279 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2505.18279>
- [789] Z. Chen, M. Kang, and B. Li, *ShieldAgent: Shielding agents via verifiable safety policy reasoning*, Mar. 2025. arXiv: 2503.22738 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2503.22738>
- [790] S. Raza, *TRiSM for agentic AI: A review of trust, risk, and security management in LLM-based agentic multi-agent systems*, Jun. 2025. arXiv: 2506.04133 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2506.04133>

- [792] V. S. Narajala, K. Huang, and I. Habler, *Securing GenAI multi-agent systems against tool squatting: A zero trust registry-based approach*, Apr. 2025. arXiv: 2504.19951 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.19951>
- [793] J. Wu and M. Gong, *Policy-invisible violations in LLM-based agents*, Apr. 2026. arXiv: 2604.12177 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.12177>
- [796] K. Yang et al., *When lower privileges suffice: Investigating over-privileged tool selection in LLM agents*, Jun. 2026. arXiv: 2606.20023 [cs.SE]. [Online]. Available: <https://arxiv.org/abs/2606.20023>
- [797] L. Wang et al., *IP leakage attacks targeting LLM-based multi-agent systems*, May 2025. arXiv: 2505.12442 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2505.12442>
- [800] Y. Yang et al., *A survey of AI agent protocols*, Apr. 2025. arXiv: 2504.16736 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2504.16736>
- [801] G. V. Datla, A. Vurity, T. Dash, T. Ahmad, M. Adnan, and S. Rafi, *Executable governance for AI: Translating policies into rules using LLMs*, Dec. 2025. arXiv: 2512.04408 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2512.04408>
- [802] M. S. Chishti, D. P. Oyinloye, and J. Li, *Test before you deploy: Governing updates in the LLM supply chain*, Apr. 2026. arXiv: 2604.27789 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.27789>
- [806] C. Ouyang and R. Hou, *Memlineage: Lineage-guided enforcement for LLM agent memory*, May 2026. arXiv: 2605.14421 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.14421>
- [807] M. Costa et al., *Securing AI agents with information-flow control*, May 2025. arXiv: 2505.23643 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2505.23643>
- [808] S. Li et al., *FORTIS: Benchmarking over-privilege in agent skills*, May 2026. arXiv: 2605.09163 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.09163>
- [809] Y. Guo et al., *MCPXKIT: The unified toolkit for analyzing model context protocol security*, Aug. 2025. arXiv: 2508.12538 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.12538>
- [810] V. P. Bhardwaj, *AgentAssay: Token-efficient regression testing for non-deterministic AI agent workflows*, Mar. 2026. arXiv: 2603.02601 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.02601>
- [814] I. Evtimov, A. Zharmagambetov, A. Grattafiori, C. Guo, and K. Chaudhuri, *WASP: Benchmarking web agent security against prompt injection attacks*, 2025. arXiv: 2504.18575 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.18575>
- [825] T. Chen, C. Hu, G. Gao, D. Liu, X. Hu, and W. Wang, *LPS-Bench: Benchmarking safety awareness of computer-use agents in long-horizon planning under benign and adversarial scenarios*, Feb. 2026. arXiv: 2602.03255 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.03255>
- [828] S. Hu, L. Liu, Z. Meng, and Z. Zhao, *ToolPrivacyBench: Benchmarking purpose-bound privacy in tool-using LLM agents*, Jun. 2026. arXiv: 2606.28061 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.28061>
- [834] D. Gosmar and D. A. Dahl, *Sentinel agents for secure and trustworthy agentic AI in multi-agent systems*, Sep. 2025. arXiv: 2509.14956 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2509.14956>

- [841] N. Kolt, *Governing AI agents*, Jan. 2025. arXiv: 2501.07913 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2501.07913>
- [845] J. Kim et al., *The attack and defense landscape of agentic AI: A comprehensive survey*, 2026. arXiv: 2603.11088 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.11088>
- [848] J. Chen et al., *SecureVibeBench: Benchmarking secure vibe coding of AI agents via reconstructing vulnerability-introducing scenarios*, Sep. 2025. arXiv: 2509.22097 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2509.22097>
- [850] N. Maloyan and D. Namiot, *Prompt injection attacks on agentic coding assistants: A systematic analysis of vulnerabilities in skills, tools, and protocol ecosystems*, Jan. 2026. arXiv: 2601.17548 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.17548>
- [854] Z. Ying et al., *AgentVisor: Defending LLM agents against prompt injection via semantic virtualization*, Apr. 2026. arXiv: 2604.24118 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.24118>
- [859] B. Wang, J. Quan, X. Yu, H. Hu, and I. Tsang, *Reflection-driven control for trustworthy code agents*, Dec. 2025. arXiv: 2512.21354 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.21354>
- [861] H. Cheng et al., *SeClaw: Spec-driven security task synthesis for evaluating autonomous agents*, Jun. 2026. arXiv: 2606.02302 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.02302>
- [864] W. Guo et al., *MalSkillBench: A runtime-verified benchmark of malicious agent skills*, Jun. 2026. arXiv: 2606.07131 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.07131>
- [867] A. Kaufman, J. Lucassen, T. Tracy, C. Rushing, and A. Bhatt, *Basharena: A control setting for highly privileged AI agents*, Dec. 2025. arXiv: 2512.15688 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.15688>
- [872] M. Christodorescu et al., *Agent security is a systems problem*, May 2026. arXiv: 2605.18991 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.18991>
- [876] C. Zhang et al., *LITMUS: Benchmarking behavioral jailbreaks of LLM agents in real OS environments*, May 2026. arXiv: 2605.10779 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.10779>
- [877] J. Bazinska et al., *Breaking agent backbones: Evaluating the security of backbone LLMs in AI agents*, Oct. 2025. arXiv: 2510.22620 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.22620>
- [879] C. Kaplan, A. Warnecke, and N. Archibald, *Blackice: A containerized red teaming toolkit for AI security testing*, 2025. arXiv: 2510.11823 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.11823>
- [881] P. He et al., *PI-Hunter: Automated red-teaming for exposing and localizing prompt injections*, Jun. 2026. arXiv: 2606.12737 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.12737>
- [882] Z. Wang et al., *MindGuard: Intrinsic decision inspection for securing LLM agents against metadata poisoning*, Aug. 2025. arXiv: 2508.20412 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.20412>

- [884] L. Meng, H. Feng, I. Shumailov, and E. Fernandes, *ceLLMate: Sandboxing browser AI agents*, Dec. 2025. arXiv: 2512.12594 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.12594>
- [885] J. Zhou, L. Wang, and X. Yang, *Guardian: Safeguarding LLM multi-agent collaborations with temporal graph modeling*, May 2025. arXiv: 2505.19234 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2505.19234>
- [886] O. Solozobov, *DEMM-Bench: A cross-regime benchmark for agent-runtime governance-evidence sufficiency*, May 2026. arXiv: 2606.20634 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2606.20634>
- [889] Q. Lan, A. Kaul, S. Jones, and S. Westrum, *Silent egress: When implicit prompt injection makes LLM agents leak without a trace*, Feb. 2026. arXiv: 2602.22450 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.22450>
- [891] J. Mao et al., *AgentSafe: Safeguarding large language model-based multi-agent systems via hierarchical data management*, Mar. 2025. arXiv: 2503.04392 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2503.04392>
- [894] I. Santos-Grueiro, *Lingering authority: Revocable resource-and-effect capabilities for coding agents*, Jun. 2026. arXiv: 2606.22504 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.22504>
- [895] M. H. Chinaei, *Causality laundering: Denial-feedback leakage in tool-calling LLM agents*, Apr. 2026. arXiv: 2604.04035 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.04035>
- [896] Y. Zhou, X. Wang, P. Ma, Z. Xue, Z. Wang, and S. Wang, *From shield to target: Denial-of-service attacks on LLM-based agent guardrails*, Jun. 2026. arXiv: 2606.14517 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.14517>
- [897] Y. Li, Y. Lin, P. Wang, and X. Wei, *BeSafe-Bench: Unveiling behavioral safety risks of situated agents in functional environments*, Jan. 2026. arXiv: 2603.25747 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2603.25747>
- [900] Y. Mou et al., *ToolSafe: Enhancing tool invocation safety of LLM-based agents via proactive step-level guardrail and feedback*, Jan. 2026. arXiv: 2601.10156 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2601.10156>
- [901] R. Rabin, J. Hostetler, S. McGregor, B. Weir, and N. Judd, *SandboxEval: Towards securing test environment for untrusted code*, Mar. 2025. arXiv: 2504.00018 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.00018>
- [902] B. Yan et al., *Propguard: Safeguarding LLM-mas via propagation-aware exploration and remediation*, May 2026. arXiv: 2605.16346 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2605.16346>
- [905] J. Yuan, J. Nöther, N. Jaques, and G. Radanović, *Agenticred: Optimizing agentic systems for automated red-teaming*, Jan. 2026. arXiv: 2601.13518 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2601.13518>
- [907] C. Li et al., *Claw-Eval-Live: A live agent benchmark for evolving real-world workflows*, Apr. 2026. arXiv: 2604.28139 [cs.SE]. [Online]. Available: <https://arxiv.org/abs/2604.28139>

- [908] X. Li et al., *ClawsBench: Evaluating capability and safety of LLM productivity agents in simulated workspaces*, Apr. 2026. arXiv: 2604.05172 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2604.05172>
- [909] Y. Wang et al., *A systematic security evaluation of OpenClaw and its variants*, Apr. 2026. arXiv: 2604.03131 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.03131>
- [910] C. Cesarano and M. Monperrus, *The grand software supply chain of AI systems*, Apr. 2026. arXiv: 2604.27781 [cs.SE]. [Online]. Available: <https://arxiv.org/abs/2604.27781>
- [911] J. He and D. Yu, *Sovereign assurance boundary: Certificate-bound admission for agentic infrastructure*, Jun. 2026. arXiv: 2606.11632 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.11632>
- [913] S. Dutta and A. K. Moharir, *AgentRiskBOM: A risk-scoping security bill of materials for agentic AI systems*, Jun. 2026. arXiv: 2606.21877 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2606.21877>
- [914] W. Qu, M. Xu, P. Wang, S. Zhai, J. Zhang, and D. Song, *Securing LLM agents need intent-to-execution integrity*, May 2026. arXiv: 2605.16976 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.16976>
- [920] H. Zhou, S. Zhao, C. Wang, and Z. Lin, *OpenPCC: Open and confidential LLM serving on commodity TEEs*, Jun. 2026. arXiv: 2606.11145 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.11145>
- [923] J. He and D. Yu, *Sovereign execution broker: Enforcing certificate-bound authority in agentic control planes*, Jun. 2026. arXiv: 2606.20520 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.20520>
- [926] Y. Liu et al., *TrajAD: Trajectory anomaly detection for trustworthy LLM agents*, Feb. 2026. arXiv: 2602.06443 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.06443>
- [927] L. Pirch et al., *Toward securing AI agents like operating systems*, May 2026. arXiv: 2605.14932 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.14932>
- [928] G. Andronchik and P. Lokhnikov, *AI code sandboxes: A comparative security study. part 1 of 2—engine-level properties (attack surface, leakage, stackability, CVE history, patch cadence, fuzzing)*, Jun. 2026. arXiv: 2606.08433 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.08433>
- [929] I. Singh, H. Mahmoud, and A. Murillo, *AI sandboxes: A threat model, taxonomy, and measurement framework*, Jun. 2026. arXiv: 2606.18532 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.18532>
- [930] X. Qin, S. Luan, J. See, Z. Boukhers, C. Yang, and Z. Li, *ICAN-Deploy: Identity-stable canary deployment for safety-critical embodied agents*, May 2026. arXiv: 2605.28097 [cs.RD]. [Online]. Available: <https://arxiv.org/abs/2605.28097>
- [932] J. Rodriguez Roland R., *Agent identity URI scheme: Topology-independent naming and capability-based discovery for multi-agent systems*, Jan. 2026. arXiv: 2601.14567 [cs.MA]. [Online]. Available: <https://arxiv.org/abs/2601.14567>
- [933] K. Tallam, *Authorization propagation in multi-agent AI systems: Identity governance as infrastructure*, May 2026. arXiv: 2605.05440 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.05440>

- [938] S. Nathanson et al., *AI bill of materials and beyond: Systematizing security assurance through the AI risk scanning (AIRS) framework*, Nov. 2025. arXiv: 2511.12668 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2511.12668>
- [943] B. Wang et al., *Agentic Unlearning: When LLM agent meets machine unlearning*, Feb. 2026. arXiv: 2602.17692 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2602.17692>
- [944] T. Li et al., *Safe multi-agent behavior must be maintained, not merely asserted: Constraint drift in LLM-based multi-agent systems*, May 2026. arXiv: 2605.10481 [cs.MA]. [Online]. Available: <https://arxiv.org/abs/2605.10481>
- [946] L. Beurer-Kellner et al., *Design patterns for securing LLM agents against prompt injections*, 2025. arXiv: 2506.08837 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2506.08837>
- [950] P. Du, *Memory for autonomous LLM agents: Mechanisms, evaluation, and emerging frontiers*, Mar. 2026. arXiv: 2603.07670 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2603.07670>
- [951] Z. Xiong et al., *How memory management impacts LLM agents: An empirical study of experience-following behavior*, May 2025. arXiv: 2505.16067 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2505.16067>
- [953] Y. Louck, *Origin-bound memory: Securing LLM-agent long-term memory against poisoning*, Jun. 2026. arXiv: 2606.24322 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.24322>
- [954] L. Miculicich et al., *VeriGuard: Enhancing LLM agent safety via verified code generation*, Oct. 2025. arXiv: 2510.05156 [cs.SE]. [Online]. Available: <https://arxiv.org/abs/2510.05156>
- [955] J. Kim, W. Choi, and B. Lee, *Prompt flow integrity to prevent privilege escalation in LLM agents*, Mar. 2025. arXiv: 2503.15547 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2503.15547>
- [956] Z. Ji et al., *Taming various privilege escalation in LLM-based agent systems: A mandatory access control framework*, 2026. arXiv: 2601.11893 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.11893>
- [958] K. Huang et al., *A novel zero-trust identity framework for agentic AI: Decentralized authentication and fine-grained access control*, May 2025. arXiv: 2505.19301 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2505.19301>
- [960] B. Radosevich and J. Halloran, *MCP safety audit: LLMs with the model context protocol allow major security exploits*, Apr. 2025. arXiv: 2504.03767 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.03767>
- [965] C. Bühler, M. Biagiola, L. Di Grazia, and G. Salvaneschi, *AgentBound: Securing execution boundaries of AI agents*, Oct. 2025. arXiv: 2510.21236 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.21236>
- [968] Y. Li et al., *VIGIL: Runtime enforcement of behavioral specifications in AI agent skills*, Jun. 2026. arXiv: 2606.26524 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.26524>
- [970] N. Palumbo, S. Choudhary, J. Choi, P. Chalasani, M. Christodorescu, and S. Jha, *Formal policy enforcement for real-world agentic systems*, Feb. 2026. arXiv: 2602.16708 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.16708>

- [971] D. Ye et al., *Secure forgetting: A framework for privacy-driven unlearning in large language model (LLM)-based agents*, Apr. 2026. arXiv: 2604.00430 [cs.MA]. [Online]. Available: <http://arxiv.org/abs/2604.00430>
- [972] Y. Dong et al., *DeltaBox: Scaling stateful AI agents with millisecond-level sandbox checkpoint/rollback*, May 2026. arXiv: 2605.22781 [cs.OS]. [Online]. Available: <https://arxiv.org/abs/2605.22781>
- [975] H. Zeng et al., *Automated privacy information annotation in large language model interactions*, May 2025. arXiv: 2505.20910 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2505.20910>
- [976] L. Garza, A. Kotal, A. Piplai, L. Elluri, P. K. Das, and A. Chadha, *PRvL: Quantifying the capabilities and risks of large language models for PII redaction*, Aug. 2025. arXiv: 2508.05545 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.05545>
- [977] M. Holschneider and S. LeeYuk, *PII shield: A browser-level overlay for user-controlled personal identifiable information (PII) management in AI interactions*, Mar. 2026. arXiv: 2603.24895 [cs.HC]. [Online]. Available: <https://arxiv.org/abs/2603.24895>
- [978] B. Bullwinkel, G. Severi, K. Hines, A. Minnich, R. S. Siva Kumar, and Y. Zunger, *The trigger in the haystack: Extracting and reconstructing LLM backdoor triggers*, Feb. 2026. arXiv: 2602.03085 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.03085>
- [979] R. Geng, Y. Wang, C. Yin, M. Cheng, Y. Chen, and J. Jia, *PISanitizer: Preventing prompt injection to long-context LLMs via prompt sanitization*, Nov. 2025. arXiv: 2511.10720 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2511.10720>
- [980] B. D. Sunil, I. Sinha, P. Maheshwari, S. Todmal, S. Mallik, and S. Mishra, *Memory poisoning attack and defense on memory based LLM-agents*, Jan. 2026. arXiv: 2601.05504 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.05504>
- [982] Y. Jiang et al., *SoK: Agentic skills—beyond tool use in LLM agents*, Feb. 2026. arXiv: 2602.20867 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.20867>
- [984] Y. Piao et al., *AgentBay: A hybrid interaction sandbox for seamless human-AI intervention in agentic systems*, Dec. 2025. arXiv: 2512.04367 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2512.04367>
- [985] T. South et al., *Authenticated delegation and authorized AI agents*, Jan. 2025. arXiv: 2501.09674 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2501.09674>
- [987] H. Zhou, X. Zhang, H. Zhang, H. Zhang, M. Zhang, and M. Yang, *A first measurement study on authentication security in real-world remote MCP servers*, May 2026. arXiv: 2605.22333 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.22333>
- [988] Y. Wang, T. Jiang, J. Liang, C. Fleming, and T. Wang, *MAGE: Safeguarding LLM agents against long-horizon threats via shadow memory*, May 2026. arXiv: 2605.03228 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.03228>
- [989] N. Kahani, M. Barati, and D. Addae, *Runtime compliance verification for AI agents*, 2026. arXiv: 2606.19242 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.19242>
- [991] M. MacDiarmid et al., *Natural emergent misalignment from reward hacking in production RL*, Nov. 2025. arXiv: 2511.18397 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2511.18397>

- [992] Y. Qu et al., *Supply-chain poisoning attacks against LLM coding agent skill ecosystems*, Apr. 2026. arXiv: 2604.03081 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.03081>
- [994] R. Betser, S. Bose, A. Giloni, C. Picardi, S. Padakandla, and R. Vainshtein, *AgentTRIM: Tool risk mitigation for agentic AI*, Jan. 2026. arXiv: 2601.12449 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.12449>
- [995] J. Mavračić, *Policy cards: Machine-readable runtime governance for autonomous AI agents*, Oct. 2025. arXiv: 2510.24383 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2510.24383>
- [998] K. Chu, *From stateless queries to autonomous actions: A layered security framework for agentic AI systems*, Apr. 2026. arXiv: 2604.23338 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.23338>
- [1000] Y. Ling, S. Yu, Z. Chen, and C. Fang, *Toward secure LLM agents: Threat surfaces, attacks, defenses, and evaluation*, Jun. 2026. arXiv: 2606.10749 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.10749>
- [1003] K. Prinos et al., *Stable agentic control: Tool-mediated LLM architecture for autonomous cyber defense*, May 2026. arXiv: 2605.03034 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.03034>
- [1006] H. Liu, E. Ilyushin, J. Ni, and M. Zhu, *SafeAgent: A runtime protection architecture for agentic systems*, Apr. 2026. arXiv: 2604.17562 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2604.17562>
- [1016] H. Hao et al., *POISE: Position-aware undetectable skill injection on LLM agents*, Jun. 2026. arXiv: 2606.07943 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.07943>
- [1017] H. Wang, S. Yang, Y. Chen, and P. Liu, *Hijacking agent memory: Stealthy trojan attacks through conversational interaction*, May 2026. arXiv: 2605.29960 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.29960>
- [1018] Y. Feng et al., *SkillTrojan: Backdoor attacks on skill-based agent systems*, Apr. 2026. arXiv: 2604.06811 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.06811>
- [1020] Z. Chen et al., *IterInject: Indirect prompt injection against LLM agents via feedback-guided iterative optimization*, May 2026. arXiv: 2605.24659 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2605.24659>
- [1021] M. Luo et al., *Rewriting the response path: Silent tampering and provider-signed defense in BYOK LLM agents*, May 2026. arXiv: 2605.02187 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.02187>
- [1023] Z. Lin, C. Li, and K. Chen, *A survey on the security of long-term memory in LLM agents: Toward mnemonic sovereignty*, Apr. 2026. arXiv: 2604.16548 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.16548>
- [1024] Y. Luo et al., *Shadowmerge: A novel poisoning attack on graph-based agent memory via relation-channel conflicts*, May 2026. arXiv: 2605.09033 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.09033>
- [1026] L. Xu and X. Chen, *Security attack and defense strategies for autonomous agent frameworks: A layered review with OpenClaw as a case study*, Apr. 2026. arXiv: 2604.27464 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.27464>

- [1027] Y. Bu et al., *SPADE-bench: Evaluating spontaneous strategic deception in agents via plan-action divergence*, Jun. 2026. arXiv: 2606.02380 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.02380>
- [1028] P. Bisconti et al., *Boiling the frog: A multi-turn benchmark for agentic safety*, May 2026. arXiv: 2605.22643 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.22643>
- [1029] L. Yan et al., *Trust no tool: Evaluating and defending LLM agents under untrusted tool feedback*, May 2026. arXiv: 2605.17453 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.17453>
- [1030] Y. Feng et al., *BraveGuard: From open-world threats to safer computer-use agents*, Jun. 2026. arXiv: 2606.01166 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.01166>
- [1031] S. Bensalem et al., *Position: A three-layer probabilistic assume-guarantee architecture is structurally required for safe LLM agent deployment*, May 2026. arXiv: 2605.18672 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.18672>
- [1032] J. Li, Y. Li, B. Zhang, R. Tang, and K.-H. Huang, *TRACES: Proactive safety auditing for multi-turn LLM agents via trajectory-state modeling*, May 2026. arXiv: 2605.27690 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.27690>
- [1033] D. Liu, Q. Ren, C. Qian, S. Shao, and Y. Xie, *AgentDoG: A diagnostic guardrail framework for AI agent safety and security*, Jan. 2026. arXiv: 2601.18491 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2601.18491>
- [1034] J. W. Leong, *Defense effectiveness across architectural layers: A mechanistic evaluation of persistent memory attacks on stateful LLM agents*, May 2026. arXiv: 2605.08442 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.08442>
- [1035] B. Yin, Q. Li, and X. Wang, *On-policy self-evolution via failure trajectories for agentic safety alignment*, May 2026. arXiv: 2605.11882 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.11882>
- [1036] Z. Hong et al., *TRACE: Trajectory risk-aware compression for long-horizon agent safety*, Jun. 2026. arXiv: 2606.00611 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.00611>
- [1037] M. Fernandez, *Operationalizing reconstructive authority: Runtime construction, dependency resolution, and execution gating in autonomous agent systems*, May 2026. arXiv: 2605.23935 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.23935>
- [1038] C. Jin et al., *SkillSafetyBench: Evaluating agent safety under skill-facing attack surfaces*, May 2026. arXiv: 2605.12015 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.12015>
- [1048] J. Chua, J. Betley, M. Taylor, and O. Evans, *Thought crime: Backdoors and emergent misalignment in reasoning models*, Jun. 2025. arXiv: 2506.13206 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2506.13206>
- [1049] J. Zhang, S. Yang, and B. Li, *UDora: A unified red teaming framework against LLM agents by dynamically hijacking their own reasoning*, Mar. 2025. arXiv: 2503.01908 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2503.01908>
- [1050] Y. Cui and H. Du, *MAD-spear: A conformity-driven prompt injection attack on multi-agent debate systems*, Jul. 2025. arXiv: 2507.13038 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2507.13038>

- [1051] X. Wang et al., *FreezeVLA: Action-freezing attacks against vision-language-action models*, Sep. 2025. arXiv: 2509.19870 [cs.CV]. [Online]. Available: <https://arxiv.org/abs/2509.19870>
- [1053] Y. Li, Y. Cao, D. Wang, and B. Xiao, *AgentTypo: Adaptive typographic prompt injection attacks against black-box multimodal agents*, Oct. 2025. arXiv: 2510.04257 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2510.04257>
- [1054] Y. Zhang et al., *MemVenom: Triggered poisoning of multimodal memories in web agents*, Jun. 2026. arXiv: 2606.10742 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.10742>
- [1057] W. Zou et al., *Poison once, exploit forever: Environment-injected memory poisoning attacks on web agents*, Apr. 2026. arXiv: 2604.02623 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.02623>
- [1058] Y. Belkhiter, G. Zizzo, S. Maffei, S. Tirupathi, and J. D. Kelleher, *Breaking MCP with function hijacking attacks: Novel threats for function calling and agentic models*, Apr. 2026. arXiv: 2604.20994 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.20994>
- [1059] F. Li, J. Wu, T. Fu, N. Jaques, W. Zhou, and M.-Y. Kan, *FlowSteer: Prompt-only workflow steering exposes planning-time vulnerabilities in multi-agent LLM systems*, May 2026. arXiv: 2605.11514 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.11514>
- [1060] V. Frimpong, *AI debris: Residual risk and the afterlife of failed AI systems*, 2026. arXiv: 2606.12432 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2606.12432>
- [1068] J. A. Corll, *Peak + accumulation: A proxy-level scoring formula for multi-turn LLM attack detection*, Feb. 2026. arXiv: 2602.11247 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.11247>
- [1070] Y. Chen et al., *Token economics for LLM agents: A dual-view study from computing and economics*, May 2026. arXiv: 2605.09104 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.09104>
- [1072] E. Kurshan, T. Balch, and D. Byrd, *The agentic regulator: Risks for AI in finance and a proposed agent-based framework for governance*, Dec. 2025. arXiv: 2512.11933 [cs.CY]. [Online]. Available: <https://arxiv.org/abs/2512.11933>
- [1073] J. Isbarov and M. Kantarcioglu, *Bypassing AI control protocols via agent-as-a-proxy attacks*, Feb. 2026. arXiv: 2602.05066 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.05066>
- [1075] T. Nguyen, M. Ndebugre, and D. Arremsetty, *Security considerations for multi-agent systems*, Mar. 2026. arXiv: 2603.09002 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.09002>
- [1076] B. Hagag, W. L. Anderson, C. S. de Witt, and S. Scheffler, *Architecture matters for multi-agent security*, Apr. 2026. arXiv: 2604.23459 [cs.MA]. [Online]. Available: <https://arxiv.org/abs/2604.23459>
- [1077] S. Sajadieh et al., *Artificial intelligence index report 2026*, Apr. 2026. arXiv: 2606.15708 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2606.15708>
- [1078] E. Wood, M. Park, and A. Rao, *What breaks when LLMs code? characterizing operational safety failures of agentic code assistants*, May 2026. arXiv: 2605.30777 [cs.SE]. [Online]. Available: <https://arxiv.org/abs/2605.30777>

- [1081] S. Suwansathit, Y. Zhang, and G. Gu, *A security analysis of the OpenClaw AI agent framework*, Mar. 2026. arXiv: 2603.27517 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.27517>
- [1082] A. Al-Tawaha, S. Gu, P. Niu, R. Jia, and M. Jin, *Remembering more, risking more: Longitudinal safety risks in memory-equipped LLM agents*, 2026. arXiv: 2605.17830 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.17830>
- [1084] F. Wang and Z. Tian, *Evidence-bound gateway-path provenance for third-party LLM inference*, Jun. 2026. arXiv: 2606.22560 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.22560>
- [1086] Q. Liu, T. Holz, S. Ye, and R. Song, *The capability paradox: How smarter auditors make multi-agent systems less secure*, May 2026. arXiv: 2605.17480 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2605.17480>
- [1087] Z. Zou, Z. Liu, L. Zhao, and Q. Zhan, *BlockA2A: Towards secure and verifiable Agent-to-Agent interoperability*, Aug. 2025. arXiv: 2508.01332 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.01332>
- [1088] C. S. de Witt, *Open challenges in multi-agent security: Towards secure systems of interacting AI agents*, May 2025. arXiv: 2505.02077 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2505.02077>
- [1090] K. Wang et al., *TrinityGuard: A unified framework for safeguarding multi-agent systems*, Mar. 2026. arXiv: 2603.15408 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.15408>
- [1092] Z. Anbiaee et al., *Security threat modeling for emerging AI-agent protocols: A comparative analysis of MCP, A2A, agora, and ANP*, Feb. 2026. arXiv: 2602.11327 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.11327>
- [1094] J. A. Wibowo and G. C. Polyzos, *Toward a safe internet of agents*, Dec. 2025. arXiv: 2512.00520 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.00520>
- [1095] Z. Wang et al., *A survey on AgentOps: Categorization, challenges, and future directions*, Aug. 2025. arXiv: 2508.02121 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2508.02121>
- [1096] Y. Xie et al., *From spark to fire: Modeling and mitigating error cascades in LLM-based multi-agent collaboration*, Mar. 2026. arXiv: 2603.04474 [cs.MA]. [Online]. Available: <https://arxiv.org/abs/2603.04474>
- [1097] K. Venkatesh, J. Isbarov, S. Amin, M. Kantarcioglu, and J. Cui, *CASPIAN: Online detection and attribution of cascade attacks in LLM multi-agent systems via cross-channel causal monitoring*, May 2026. arXiv: 2605.19240 [cs.MA]. [Online]. Available: <https://arxiv.org/abs/2605.19240>
- [1099] A. Pabba, A. Mathai, A. Chakraborty, and B. Ray, *SemAgent: A semantics aware program repair agent*, Jun. 2025. arXiv: 2506.16650 [cs.SE]. [Online]. Available: <https://arxiv.org/abs/2506.16650>
- [1101] B. Livshits, *LLMs + security = trouble*, Feb. 2026. arXiv: 2602.08422 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.08422>
- [1104] X. Ma et al., *Demystifying the lifecycle of failures in platform-orchestrated agentic workflows*, Sep. 2025. arXiv: 2509.23735 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2509.23735>

- [1106] Y. Zheng, Y. Yang, W. Zhang, and A. Quinn, *ACRFence: Preventing semantic rollback attacks in agent checkpoint-restore*, Mar. 2026. arXiv: 2603.20625 [cs.CR]. [Online]. Available: <http://arxiv.org/abs/2603.20625>
- [1107] S. Shimmi, H. Okhravi, and M. Rahimi, *AI-based software vulnerability detection: A systematic literature review*, Jun. 2025. arXiv: 2506.10280 [cs.SE]. [Online]. Available: <https://arxiv.org/abs/2506.10280>
- [1111] Y. Li et al., *Everything you wanted to know about LLM-based vulnerability detection but were afraid to ask*, Apr. 2025. arXiv: 2504.13474 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2504.13474>
- [1113] C. Jiang et al., *Large language models for multilingual code intelligence: A survey*, Apr. 2026. arXiv: 2604.25960 [cs.SE]. [Online]. Available: <https://arxiv.org/abs/2604.25960>
- [1114] Y. Yang et al., *Securing the AI agent: A unified multi-layer red-teaming framework*, Jun. 2026. arXiv: 2606.31227 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.31227>
- [1117] Z. Wei et al., *PATCHEVAL: A new benchmark for evaluating LLMs on patching real-world vulnerabilities*, Nov. 2025. arXiv: 2511.11019 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2511.11019>
- [1119] S. Wu, X. Li, Y. Feng, Y. Li, Z. Wang, and R. Wang, *Council mode: A heterogeneous multi-agent consensus framework for reducing LLM hallucination and bias*, Apr. 2026. arXiv: 2604.02923 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2604.02923>
- [1123] J. Wang et al., *Orchestrating intelligence: Confidence-aware routing for efficient multi-agent collaboration across multi-scale models*, Jan. 2026. arXiv: 2601.04861 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2601.04861>
- [1128] S. Liu et al., *CASTER: Breaking the cost-performance barrier in multi-agent orchestration via context-aware strategy for task efficient routing*, Jan. 2026. arXiv: 2601.19793 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2601.19793>
- [1129] J. Liu et al., *RCR-router: Efficient role-aware context routing for multi-agent LLM systems with structured memory*, Aug. 2025. arXiv: 2508.04903 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2508.04903>
- [1130] Y. Lu, Y. Hu, X. Zhao, and J. Cao, *Dytopo: Dynamic topology routing for multi-agent reasoning via semantic matching*, Feb. 2026. arXiv: 2602.06039 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2602.06039>
- [1131] X. Wang et al., *Efficient and interpretable multi-agent LLM routing via ant colony optimization*, Mar. 2026. arXiv: 2603.12933 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2603.12933>
- [1132] H. Liu, C. Shou, H. Wen, Y. Chen, R. J. Fang, and Y. Feng, *Your agent is mine: Measuring malicious intermediary attacks on the LLM supply chain*, Apr. 2026. arXiv: 2604.08407 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.08407>
- [1133] R. Kang and Y. Diponegoro, *Governance gaps in agent interoperability protocols*, Jun. 2026. arXiv: 2606.31498 [cs.MA]. [Online]. Available: <https://arxiv.org/abs/2606.31498>
- [1135] A. Dey, *ComplianceGate: Classifier-gated multi-tier LLM routing for inference in regulated industries*, Jun. 2026. arXiv: 2606.31163 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.31163>

- [1137] L. Waibl, F. Michalak, and H. Mariaccia, *Bells-o: Evaluating the operational trade-offs of LLM supervision systems*, Jun. 2026. arXiv: 2606.20668 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2606.20668>
- [1139] Y. Zhang and J. Li, *The routing plateau: Understanding and breaking the accuracy limits of LLM routers*, May 2026. arXiv: 2606.07587 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2606.07587>
- [1141] W. Mai et al., *You can't eat your cake and have it too: The performance degradation of LLMs with jailbreak defense*, Jan. 2025. arXiv: 2501.12210 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2501.12210>
- [1142] W. Xing et al., *MCP-guard: Multi-stage defense for agentic model context protocol*, Aug. 2025. arXiv: 2508.10991 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2508.10991>
- [1143] Z. Yu, *On the limitations of non-GPU AI accelerators for large-model inference: A field study of MoE and multimodal serving on Huawei Ascend*, Jul. 2026. arXiv: 2607.08215 [cs.DC]. [Online]. Available: <https://arxiv.org/abs/2607.08215>

技术文档

- [1] GenAI Security Project. “OWASP top 10 for agentic applications,” Accessed: Jul. 20, 2026. [Online]. Available: <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- [9] Cloud Security Alliance. “Agentic secure development lifecycle (ASDL),” Accessed: Jul. 21, 2026. [Online]. Available: <https://labs.cloudsecurityalliance.org/agentic/agentic-secure-development-lifecycle-v1/>
- [147] THU DM. “THU DM/AgentBench github repository,” Accessed: Jul. 4, 2026. [Online]. Available: <https://github.com/THU DM/AgentBench>
- [190] NASP-THU. “CSEBenchmark: The official repository of the digital cybersecurity expert: How far have we come?” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/NASP-THU/CSEBenchmark>
- [191] OpenAI. “ChatGPT agent system card,” Accessed: Jul. 21, 2026. [Online]. Available: <https://deploymentsafety.openai.com/chatgpt-agent>
- [192] NVIDIA. “NVIDIA NeMo agent toolkit overview,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.nvidia.com/nemo/agent-toolkit/latest/index.html>
- [195] Google Cloud. “Agent identity and access control for AI agents,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cloud.google.com/iam/docs/agents>
- [197] NVIDIA. “NVIDIA confidential computing,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.nvidia.com/en-us/data-center/solutions/confidential-computing/>
- [198] NVIDIA. “NVIDIA isaac sim documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.isaacsim.omniverse.nvidia.com/>
- [199] Perplexity AI. “Perplexity enterprise,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.perplexity.ai/enterprise/pro>
- [200] Anysphere. “Cursor security,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cursor.com/security>
- [201] OpenAI. “Chatgpt agent system card,” Accessed: Jul. 29, 2026. [Online]. Available: https://cdn.openai.com/pdf/839e66fc-602c-48bf-81d3-b21eacc3459d/chatgpt_agent_system_card.pdf
- [202] Anthropic. “Computer use with Claude,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.anthropic.com/en/docs/agents-and-tools/tool-use/computer-use-tool>
- [205] Google Cloud. “Vertex AI agent builder documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cloud.google.com/generative-ai-app-builder/docs>
- [206] NVIDIA. “NVIDIA nemo guardrails documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.nvidia.com/nemo/guardrails/latest/index.html>
- [207] Meta. “LlamaFirewall,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/meta-llama/PurpleLlama/tree/main/LlamaFirewall>
- [208] OpenAI. “Tracing,” Accessed: Jul. 19, 2026. [Online]. Available: <https://openai.github.io/openai-agents-python/tracing/>

- [219] Anthropic. “Claude’s constitution,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.anthropic.com/claude/constitution>
- [220] Anthropic. “Responsible scaling policy,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.anthropic.com/news/anthropics-responsible-scaling-policy>
- [221] Anthropic. “Tool use with Claude,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.anthropic.com/en/docs/agents-and-tools/tool-use/overview>
- [222] M. Phuong et al., “Gdm AI control roadmap,” Google DeepMind, Tech. Rep., Jun. 2026. [Online]. Available: <https://storage.googleapis.com/deepmind-media/DeepMind.com/Blog/securing-the-future-of-ai-agents/gdm-ai-control-roadmap.pdf>
- [224] S. Ee and P. Maham, “The three layers of agent security: A framework for policymakers,” Google DeepMind, Tech. Rep., Jun. 2026. [Online]. Available: <https://storage.googleapis.com/deepmind-media/DeepMind.com/Blog/securing-the-future-of-ai-agents/three-layers-of-agent-security.pdf>
- [228] Google Cloud. “Agent search documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.cloud.google.com/generative-ai-app-builder/docs>
- [233] Meta. “PurpleLlama: Open trust and safety tools,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/meta-llama/PurpleLlama>
- [234] Meta. “Llama Protections,” Accessed: Jul. 21, 2026. [Online]. Available: <https://developer.meta.com/ai/docs/llama-protections/>
- [237] NVIDIA. “NVIDIA isaac lab documentation.” [Online]. Available: <https://isaac-sim.github.io/IsaacLab/>
- [240] Perplexity. “Sonar API documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.perplexity.ai/>
- [241] Perplexity. “Perplexity privacy and security,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.perplexity.ai/guides/privacy-and-security>
- [242] Perplexity. “Introducing Comet,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.perplexity.ai/comet>
- [248] Aleph Alpha. “PhariaAI: Full-stack sovereign AI operating system,” Accessed: Jul. 21, 2026. [Online]. Available: <https://aleph-alpha.com/app/uploads/2025/03/Aleph-Alpha-PhariaAI.pdf>
- [250] Aleph Alpha. “Pharia Inference SDK,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/Aleph-Alpha/pharia-inference-sdk>
- [251] Mistral AI. “Mistral Forge: Build AI models that know your enterprise,” Accessed: Jul. 21, 2026. [Online]. Available: <https://mistral.ai/products/forge/>
- [252] Aleph Alpha. “Pharia model variants,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.aleph-alpha.com/docs/models/model-card/>
- [253] Yandex AI Studio. “Security,” Accessed: Jul. 21, 2026. [Online]. Available: aistudio.yandex.ru/en/security
- [254] Mistral AI. “Agents API documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.mistral.ai/capabilities/agents/>

- [255] Mistral AI. “Mistral AI Studio product documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://mistral.ai/products/ai-studio>
- [256] Aleph Alpha. “PhariaAI developer guide,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.aleph-alpha.com/docs/>
- [257] Darktrace. “Darktrace ActiveAI security platform,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.darktrace.com/platform>
- [258] Darktrace. “Cyber AI Analyst,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.darktrace.com/products/cyber-ai-analyst>
- [259] Yandex Cloud. “Yandex AI Studio on-premises,” Accessed: Jul. 21, 2026. [Online]. Available: <https://aistudio.yandex.ru/en/on-premises>
- [260] Yandex Cloud. “AI search technology overview,” Accessed: Jul. 21, 2026. [Online]. Available: <https://aistudio.yandex.ru/docs/en/ai-studio/concepts/search/>
- [261] Yandex Cloud. “AI Studio documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://aistudio.yandex.ru/docs/en/>
- [262] Mistral AI. “Le Chat enterprise,” Accessed: Jul. 21, 2026. [Online]. Available: <https://mistral.ai/products/la-plateforme/le-chat-enterprise>
- [263] Darktrace. “Autonomous response,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.darktrace.com/darktrace-autonomous-response>
- [264] Yandex Cloud. “Security deck AI assistant,” Accessed: Jul. 21, 2026. [Online]. Available: <https://yandex.cloud/en/docs/security-deck/concepts/ai-assistant>
- [265] Alibaba Cloud. “Deploy a dedicated OpenClaw agent using PAI-EAS,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/pai/user-guide/deploy-exclusive-openclaw-using-pai-eas-for-5-minutes>
- [266] Tencent Cloud. “AI agent security gateway overview,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.tencentcloud.com/document/product/1429/72299>
- [267] Huawei Cloud. “What is the AgentArts agent platform?” Accessed: Jul. 21, 2026. [Online]. Available: https://support.huaweicloud.com/productdesc-agentarts/agentarts_03_0002.html
- [268] Baidu AI Cloud. “Baidu Qianfan: Large model service and agent development platform,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cloud.baidu.com/doc/qianfan/index.html>
- [269] IFLYTEK. “Spark Enterprise Agent Platform,” Accessed: Jul. 21, 2026. [Online]. Available: <https://sparklegion.iflytek.com/inner6.html>
- [270] IFLYTEK. “Xingchen agent platform,” Accessed: Jul. 21, 2026. [Online]. Available: <https://agent.xfyun.cn/>
- [271] Huawei Cloud. “Configuring CodeArts security,” Accessed: Jul. 21, 2026. [Online]. Available: https://support.huaweicloud.com/intl/en-us/bestpractice-devcloud/devcloud_practice_0002.html
- [273] Alibaba Cloud. “AI guardrails / openclaw runtime AI security protection,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/pai/user-guide/openclaw-runtime-ai-security-protection>

- [274] VOLCENGINE. “Large model application firewall,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.volcengine.com/product/LLM-FW>
- [275] Tencent Cloud. “Tencent Cloud Agent Development Platform,” Accessed: Jul. 21, 2026. [Online]. Available: <https://adp.tencentcloud.com/en>
- [276] Huawei Cloud. “AgentArts agentidentity API key authentication,” Accessed: Jul. 21, 2026. [Online]. Available: https://support.huaweicloud.com/intl/en-us/api-agentarts/agentarts_api_0308.html
- [277] 360. “360 large model guard protection system,” Accessed: Jul. 21, 2026. [Online]. Available: <https://360.net/mobile/product-center/ai-security/protection>
- [278] DeepSeek. “DeepSeek API docs: Tool calls,” Accessed: Jul. 21, 2026. [Online]. Available: https://api-docs.deepseek.com/guides/tool_calls/
- [281] Baidu Intelligent Cloud. “Security policy: Baidu qianfan large model service and agent development platform,” Accessed: Jul. 13, 2026. [Online]. Available: <https://cloud.baidu.com/doc/qianfan/s/Lmmxhsja8>
- [282] Baidu Intelligent Cloud. “Intervention policy: Qianfan AI application developer center,” Accessed: Jul. 13, 2026. [Online]. Available: <https://cloud.baidu.com/doc/qianfan-docs/s/Im19exr7d>
- [283] Baidu. “DuClaw AI agent service,” Accessed: Jul. 21, 2026. [Online]. Available: <https://duclaw.baidu.com/>
- [284] Alibaba Cloud. “Agent security center,” Accessed: Jul. 13, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/asc/latest/agent-risk-1>
- [287] Alibaba Cloud. “Model Studio/Bailian documentation,” Accessed: Jul. 21, 2026. [Online]. Available: help.aliyun.com/zh/model-studio/
- [290] Tencent Cloud. “AI agent security gateway quick start,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.tencentcloud.com/document/product/1429/72300>
- [292] Tencent Cloud. “CodeBuddy security and permissions documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.tencentcloud.com/document/product/1154/72936>
- [293] Tencent Cloud. “Configure MCP,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.codebuddy.ai/docs/ide/User-guide/MCP>
- [297] Z.AI. “Content security: Security audit mechanism,” Z.AI Official Documentation, Accessed: Jul. 13, 2026. [Online]. Available: <https://docs.bigmodel.cn/cn/guide/platform/securityaudit>
- [299] Zhipu AI. “AutoGLM-Phone,” Accessed: Jul. 13, 2026. [Online]. Available: <https://docs.bigmodel.cn/cn/guide/models/vlm/autoglm-phone>
- [301] Zhipu AI. “Introduction to zhipu large model open platform,” Accessed: Jul. 13, 2026. [Online]. Available: <https://docs.bigmodel.cn/cn/guide/start/introduction>
- [302] Z.AI. “Content moderation api,” Accessed: Jul. 13, 2026. [Online]. Available: <https://docs.bigmodel.cn/api-reference/%E5%B7%A5%E5%85%B7-api/%E5%86%85%E5%AE%B9%E5%AE%89%E5%85%A8>
- [309] COZE. “Skill security guide,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.coze.cn/open/docs/guides/skill_security

- [310] Coze. “OAuth PKCE authorization flow,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.coze.cn/open/docs/developer_guides/oauth_pkce
- [311] VOLCENGINE. “Coze Pro enterprise AI productivity platform,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.volcengine.com/product/coze-pro>
- [314] Moonshot AI. “How to use official tools in Kimi API,” Accessed: Jul. 20, 2026. [Online]. Available: <https://platform.kimi.ai/docs/guide/use-official-tools>
- [315] Moonshot AI. “Configure modelscope mcp server in playground,” Accessed: Jul. 20, 2026. [Online]. Available: <https://platform.kimi.ai/docs/guide/configure-the-modelscope-mcp-server>
- [319] Moonshot AI. “Kimi-k2: Open agentic intelligence,” Accessed: Jul. 20, 2026. [Online]. Available: <https://github.com/MoonshotAI/Kimi-K2>
- [320] Moonshot AI. “Kimi api: Kimi k2.7 code model documentation,” Accessed: Jul. 20, 2026. [Online]. Available: <https://platform.kimi.ai/docs/guide/kimi-k2-7-code-quickstart>
- [321] Moonshot AI. “Kimi api’s internet search functionality,” Accessed: Jul. 20, 2026. [Online]. Available: <https://platform.kimi.ai/docs/guide/use-kimi-api-to-complete-tool-calls.md>
- [322] Moonshot AI. “Use Kimi API’s internet search functionality,” Accessed: Jul. 13, 2026. [Online]. Available: <https://platform.kimi.ai/docs/guide/use-web-search>
- [324] Minimax. “Minimax api: Voice clone guide,” Accessed: Jul. 20, 2026. [Online]. Available: <https://platform.minimaxi.com/docs/guides/speech-voice-clone>
- [330] Minimax. “Minimax api: Function call documentation,” Accessed: Jul. 20, 2026. [Online]. Available: <https://platform.minimaxi.com/docs/guides/text-m3-function-call>
- [331] Minimax. “MiniMax API: MCP guide,” Accessed: Jul. 21, 2026. [Online]. Available: <https://platform.minimaxi.com/docs/guides/mcp-guide>
- [332] Minimax. “Mini-agent,” Accessed: Jul. 20, 2026. [Online]. Available: <https://platform.minimaxi.com/docs/token-plan/mini-agent>
- [336] DeepSeek. “DeepSeek API docs: Rate limit and isolation,” Accessed: Jul. 13, 2026. [Online]. Available: https://api-docs.deepseek.com/quick_start/rate_limit/
- [337] DeepSeek. “DeepSeek API documentation: Your first API call,” Accessed: Jul. 21, 2026. [Online]. Available: <https://api-docs.deepseek.com/>
- [338] DeepSeek. “JSON output,” Accessed: Jul. 21, 2026. [Online]. Available: https://api-docs.deepseek.com/guides/json_mode
- [340] DeepSeek-AI. “DeepSeek-V3 github repository,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/deepseek-ai/DeepSeek-V3>
- [341] IFLYTEK. “Agent development guide,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.xfyun.cn/doc/spark/Agent03-%E5%BC%80%E5%8F%91%E6%8C%87%E5%8D%97.html>
- [342] IFLYTEK. “Spark knowledge base,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.xfyun.cn/services/spark_knowledge_base
- [343] IFLYTEK. “Spark scenario agent documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://xinghuo.xfyun.cn/doc/spark-guide/%E5%9C%BA%E6%99%AF%E6%99%BA%E8%83%BD%E4%BD%93.html>

- [347] Google. “Google Agent Development Kit (ADK),” Accessed: Jul. 21, 2026. [Online]. Available: <https://google.github.io/adk-docs/>
- [361] OpenAI. “OpenAI agents SDK documentation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://openai.github.io/openai-agents-python/>
- [362] OpenAI. “Guardrails and human review,” Accessed: Jul. 21, 2026. [Online]. Available: <https://developers.openai.com/api/docs/guides/agents/guardrails-approvals>
- [367] OpenAI. “Guardrails - OpenAI Agents SDK,” Accessed: Jul. 20, 2026. [Online]. Available: <https://openai.github.io/openai-agents-python/guardrails/>
- [369] OpenAI. “Tracing - OpenAI Agents SDK,” Accessed: Jul. 20, 2026. [Online]. Available: <https://openai.github.io/openai-agents-python/tracing/>
- [372] CheckPoint Research. “Caught in the hook: RCE and API token exfiltration through Claude Code project files,” Accessed: Jul. 21, 2026. [Online]. Available: <https://research.checkpoint.com/2026/rce-and-api-token-exfiltration-through-claude-code-project-files-cve-2025-59536/>
- [373] GitHub Advisory Database. “Claude Code leaks data via malicious environment configuration before trust confirmation.” Accessed: Jul. 21, 2026, Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/advisories/GHSA-jh7p-qr78-84p7>
- [375] Apple Security Research. “Private cloud compute security guide.” [Online]. Available: <https://security.apple.com/documentation/private-cloud-compute>
- [390] NVIDIA. “Security bulletin: NVIDIA GPU display drivers—january 2026,” Accessed: Jul. 21, 2026. [Online]. Available: https://nvidia.custhelp.com/app/answers/detail/a_id/5747
- [394] NVIDIA. “Confidential computing for AI,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.nvidia.com/ai-enterprise/planning-resource/ai-factory-white-paper/latest/confidential-computing-for-ai.html>
- [395] European High Performance Computing Joint Undertaking. “AI factories: Computing power and customised support services,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.eurohpc-ju.europa.eu/ai-factories_en
- [397] Advanced Micro Devices. “AMD-SB-3034: SEV-SNP routing misconfiguration,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.amd.com/en/resources/product-security/bulletin/amd-sb-3034.html>
- [399] PSA CERTIFIED. “PSA Certified: Expert IoT security framework and certification,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.psacertified.org/>
- [400] ARM. “Platform security,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.arm.com/architecture/security-features/platform-security>
- [404] STMicroelectronics. “STSAFE-A110: Authentication and state-of-the-art security for peripherals and IoT devices,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.st.com/en/secure-mcus/stsafe-a110.html>
- [405] STMICROELECTRONICS. “X-CUBE-STSE01: Secure element software package with STSAFE-A110, STSAFE-A120, and STSAFE-L010,” Accessed: Jul. 21, 2026. [Online]. Available: https://www.st.com/resource/en/data_brief/x-cube-stse01.pdf

- [406] Siemens. “Cybersecurity for industry,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.siemens.com/en-us/company/digital-transformation/cybersecurity/industrial-cybersecurity/>
- [409] OpenAtom openEuler Community. “openEuler: OS for digital infrastructure,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.openeuler.org/en/>
- [416] Huawei Technologies Co., Ltd. “CANN: Ascend heterogeneous computing architecture,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.hiascend.com/cann>
- [417] MindSpore Community. “MindSpore official site,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.mindspore.cn/en>
- [426] National Vulnerability Database. “CVE-2026-25253 detail,” Accessed: Jul. 21, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-25253>
- [430] National Vulnerability Database. “CVE-2025-68664 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-68664>
- [431] National Vulnerability Database. “CVE-2026-40933 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-40933>
- [432] National Vulnerability Database. “CVE-2026-26015 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-26015>
- [433] National Vulnerability Database. “CVE-2026-22252 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-22252>
- [434] National Vulnerability Database. “CVE-2025-59528 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-59528>
- [435] National Vulnerability Database. “CVE-2026-30625 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-30625>
- [436] National Vulnerability Database. “CVE-2026-30615 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-30615>
- [437] National Vulnerability Database. “CVE-2026-34070 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-34070>
- [438] National Vulnerability Database. “CVE-2026-44112 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-44112>
- [439] National Vulnerability Database. “CVE-2025-3248 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-3248>
- [440] National Vulnerability Database. “CVE-2026-34952 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-34952>
- [441] National Vulnerability Database. “CVE-2026-32211 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-32211>
- [442] National Vulnerability Database. “CVE-2025-68143 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-68143>
- [443] National Vulnerability Database. “CVE-2025-68144 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-68144>
- [444] National Vulnerability Database. “CVE-2025-68145 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-68145>

- [445] National Vulnerability Database. “CVE-2025-6514 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-6514>
- [446] National Vulnerability Database. “CVE-2025-49596 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-49596>
- [447] National Vulnerability Database. “CVE-2025-32711 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-32711>
- [448] National Vulnerability Database. “CVE-2026-44338 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-44338>
- [449] National Vulnerability Database. “CVE-2026-30624 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <httpsnvd.nist.gov/vuln/detail/CVE-2026-30624>
- [450] National Vulnerability Database. “CVE-2026-22688 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-22688>
- [451] National Vulnerability Database. “CVE-2025-64496 detail,” Accessed: Jul. 9, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-64496>
- [454] I. Martinez Leo. “MCP-Strike: Active adversarial security scanner for Model Context Protocol servers: Agentic red-teaming tool for MCP-based systems,” Accessed: Jul. 6, 2026. [Online]. Available: <https://github.com/LeoMartinezTAMUK/mcp-strike>
- [457] M. Osama. “HexStrike AI MCP Agents: Ai-powered mcp cybersecurity automation platform,” Accessed: Jul. 6, 2026. [Online]. Available: <https://github.com/0x4m4/hexstrike-ai>
- [458] KAGEX AI. “AgentBreaker: AI security testing engine for LLM agents: Framework for surfacing prompt leaks, bypasses, and unsafe agent behavior,” Accessed: Jul. 6, 2026. [Online]. Available: <https://github.com/kagexai/agentbreaker>
- [459] M. Stampar. “sqlmap: Automatic SQL injection and database takeover tool,” Accessed: Jul. 7, 2026. [Online]. Available: <httpssqlmap.org/>
- [460] PREFECTHQ. “FastMCP documentation: The fast, pythonic way to build MCP servers and clients,” Accessed: Jul. 7, 2026. [Online]. Available: <https:gofastmcp.com/getting-started/welcome>
- [461] S. Giampieri and R. Gohil. “RedAmon: An AI-powered agentic red-team framework: Autonomous offensive security pipeline from reconnaissance to post-exploitation,” Accessed: Jul. 6, 2026. [Online]. Available: <https://github.com/samugit83/redamon>
- [462] V. DROID. “Strix: Open-source AI penetration testing tool,” Accessed: Jul. 6, 2026. [Online]. Available: <https://github.com/usestrix/strix>
- [463] R. CONSULTING. “Ankou: Ai-powered command-and-control framework: Modular agent-based C2 platform with ai-assisted operations,” Accessed: Jul. 6, 2026. [Online]. Available: <https://github.com/Red-Hex-Consulting/Ankou>
- [464] G. Evron, D. Cuthbert, T. Dullien, M. Bargury, and J. Cartwright. “RAPTOR: Autonomous offensive and defensive security research framework,” Accessed: Jul. 6, 2026. [Online]. Available: <https://github.com/gadievron/raptor>
- [468] B. SECURITY. “Nebula: Ai-powered penetration testing assistant: Terminal-based ai-assisted security testing framework,” Accessed: Jul. 6, 2026. [Online]. Available: <httpsgithub.com/berylliumsec/nebula>

- [528] OpenAI. “Memory FAQ,” Accessed: Jul. 15, 2026. [Online]. Available: <https://help.openai.com/en/articles/8590148-memory-faq>
- [533] Amazon Web Services. “Encrypt your Amazon Bedrock AgentCore memory,” Accessed: Jul. 21, 2026. [Online]. Available: docs.aws.amazon.com/bedrock-agentcore/latest/devguide/storage-encryption.html
- [538] Alibaba Cloud. “Skills detection,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/asc/latest/skills-detection-1>
- [540] Microsoft AI Red Team. “Taxonomy of failure modes in agentic AI systems, version 2.0,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/bade/documents/products-and-services/en-us/security/Taxonomy-of-Failure-Modes-in-Agentic-AI-Systems-v2-0.pdf>
- [546] Alibaba Cloud. “Check items supported by AI governance maturity check,” Accessed: Jul. 15, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/cgc/user-guide/ai-governance-supported-check-items>
- [547] OWASP Foundation. “OWASP MCP Top 10,” Accessed: Jul. 21, 2026. [Online]. Available: <https://owasp.org/www-project-mcp-top-10/>
- [569] Alibaba Cloud. “Agent risk detection and protection,” Accessed: Jul. 16, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/security-center/user-guide/agent-risk-detection-protection>
- [573] Alibaba Cloud. “Instance isolation overview,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/functioncompute/fc/overview-of-instance-isolation>
- [633] Alibaba Cloud. “OSS agent: AI-powered bucket management and data search,” Alibaba Cloud Object Storage Service, Accessed: Jul. 16, 2026. [Online]. Available: www.alibabacloud.com/help/en/oss/developer-reference/oss-agent
- [660] Alibaba Cloud. “Product overview - memory storage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/tablestore/memory-storage-introduction>
- [673] Alibaba Cloud. “Agent ID Guard overview,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/idaas/eiam/user-guide/what-is-agent-id-guard>
- [699] Alibaba Cloud. “Data agent security whitepaper,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/dms/data-agent-security-system-details>
- [701] Microsoft. “Manage memory safety in agentic systems,” Accessed: Jul. 21, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/security/zero-trust/sfi/manage-agentic-memory-safety>
- [706] Alibaba Cloud. “Security isolation,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/functioncompute/security-isolation>
- [709] Alibaba Cloud. “Web application firewall: Prompt attack protection,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/tc/doc-detail/2920825.html>
- [712] Alibaba Cloud. “Web application firewall: Protection configuration overview,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/waf/web-application-firewall-3-0/user-guide/protection-configuration-overview>

- [713] Microsoft. “Shadow AI in Microsoft 365 admin center (preview),” Accessed: Jul. 21, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/microsoft-365/admin/manage/agent-shadow-ai?view=o365-worldwide>
- [733] Amazon Web Services. “CVE-2026-15746: Credential disclosure in Strands agents tools elasticsearch_memory tool,” Accessed: Jul. 21, 2026. [Online]. Available: <https://aws.amazon.com/security/security-bulletins/2026-056-aws/>
- [734] AWS Security Customer Outcomes Team. “Capability 5: Providing secure access, usage, and implementation of generative AI agents,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.aws.amazon.com/prescriptive-guidance/latest/security-reference-architecture-generative-ai/gen-auto-agents.html>
- [736] Amazon Web Services. “Secure agent memory and state,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.aws.amazon.com/wellarchitected/latest/agent-ai-lens/agentsec01.html>
- [742] Amazon Web Services. “CVE-2026-7191: Arbitrary code execution via sandbox bypass in QnABot on AWS,” Accessed: Jul. 21, 2026. [Online]. Available: <https://aws.amazon.com/security/security-bulletins/2026-020-aws/>
- [747] J. Schafer and M. Li. “System design and security recommendations for agentic AI systems,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.aws.amazon.com/prescriptive-guidance/latest/agent-ai-security/best-practices-system-design.html>
- [759] Alibaba Cloud. “Use session state in Google ADK,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/functioncompute/using-session-state-in-google-adk>
- [760] NVIDIA. “NVIDIA data center GPU driver version 580.126.09 (Linux): Release notes,” Accessed: Jul. 21, 2026. [Online]. Available: https://docs.nvidia.com/datacenter/tesla/pdf/NVIDIA_Data_Center_GPU_Driver_Release_Notes_580_v5.1.pdf
- [765] Microsoft. “Manage related identities and accounts in Microsoft Defender for identity,” Accessed: Jul. 17, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/defender-for-identity/manage-related-identities-accounts>
- [769] Alibaba Cloud. “Create and manage memory storage,” Accessed: Jul. 17, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/functioncompute/create-and-manage-memory-storage>
- [770] Alibaba Cloud. “Configure centralized audit log delivery,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/cgc/user-guide/deliver-audit-logs-in-a-unified-manner>
- [771] Alibaba Cloud. “Govern permissions with access analyzer,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.alibabacloud.com/help/en/ram/managing-over-privileged-identities-with-access-analyzer>
- [772] Microsoft. “Lifecycle workflows history,” Accessed: Jul. 21, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/entra/id-governance/lifecycle-workflow-history>
- [787] Microsoft. “Presidio: Data protection and de-identification SDK,” Accessed: Jul. 21, 2026. [Online]. Available: <https://microsoft.github.io/presidio/>

- [804] Google Cloud. “Model Armor release notes,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.cloud.google.com/model-armor/release-notes>
- [811] Amazon Web Services. “Web search tool - Amazon bedrock agentcore,” Accessed: Jul. 21, 2026. [Online]. Available: <https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/gateway-target-connector-web-search-tool.html>
- [818] COGNEE. “Cognie architecture,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.cognee.ai/core-concepts/architecture>
- [820] IBM. “Managing agent memory,” Accessed: Jul. 20, 2026. [Online]. Available: <https://www.ibm.com/docs/en/watsonx/watson-orchestrate/base?topic=memory-managing-agent>
- [824] NVIDIA. “Guardrail types,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.nvidia.com/nemo/guardrails/latest/about-nemo-guardrails-library/rail-types>
- [826] Google Cloud. “Agentic AI use case: Orchestrate security operations workflows,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.cloud.google.com/architecture/agentic-ai-orchestrate-security-ops-workflows>
- [831] Amazon Web Services. “Execute code and analyze data using Amazon Bedrock AgentCore code interpreter,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/code-interpreter-tool.html>
- [832] Google Cloud. “About GKE agent sandbox,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.cloud.google.com/kubernetes-engine/docs/concepts/machine-learning/agent-sandbox>
- [833] Red Hat. “Developer preview features,” Accessed: Jul. 20, 2026. [Online]. Available: https://docs.redhat.com/en/documentation/red_hat_openshift_ai_self-managed/3.4/html/release_notes/developer-preview-features_relnotes
- [835] RED HAT. “MCP server,” Accessed: Jul. 20, 2026. [Online]. Available: https://docs.redhat.com/en/documentation/openshift_container_platform/4.22/html/ai_applications/mcp-server
- [836] Palo Alto Networks. “Prisma AIRS MCP server for centralized AI agent security,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.paloaltonetworks.com/ai-runtime-security/activation-and-onboarding/prisma-air-mcp-server-for-centralized-ai-agent-security>
- [837] ORACLE. “Hosted applications,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.oracle.com/en-us/iaas/Content/generative-ai/applications.htm>
- [843] Google Cloud. “Agent platform with governance template,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.cloud.google.com/application-design-center/docs/agent-platform-with-governance>
- [846] Amazon Web Services. “Reviewing code with Amazon Q developer,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.aws.amazon.com/amazonq/latest/qdeveloper-ug/code-reviews.html>
- [847] Google Cloud. “Model armor overview,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.cloud.google.com/model-armor/overview>
- [849] SonarSource. “AI code assurance,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.sonarsource.com/sonarqube-server/2026.1/ai-capabilities/ai-code-assurance>

- [851] GITHUB. “Risks and mitigations for GitHub Copilot cloud agent,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.github.com/en/copilot/concepts/agents/cloud-agent/risks-and-mitigations>
- [852] Alibaba Cloud. “Enterprise filter configuration: Qoder cn (tongyi lingma),” Accessed: Jul. 20, 2026. [Online]. Available: <https://help.aliyun.com/zh/lingma/qoder-cn/user-guide/enterprise-filter-configuration>
- [853] GitLab. “Secret push protection,” Accessed: Jul. 20, 2026. [Online]. Available: https://docs.gitlab.com/user/application_security/secret_detection/secret_push_protection/
- [856] Huawei Cloud. “What is AgentArts intelligent agent platform,” Accessed: Jul. 20, 2026. [Online]. Available: https://support.huaweicloud.com/productdesc-agentarts/agentarts_03_0002.html
- [857] Alibaba Cloud. “Memory library,” Accessed: Jul. 20, 2026. [Online]. Available: <https://help.aliyun.com/zh/model-studio/memory-library>
- [858] Baidu Intelligent Cloud. “Role and access control list,” Accessed: Jul. 20, 2026. [Online]. Available: cloud.baidu.com/doc/qianfan/s/Emh4sucy7
- [860] Anthropic. “Hooks reference,” Accessed: Jul. 20, 2026. [Online]. Available: <https://code.claude.com/docs/en/hooks>
- [862] Kiro. “Specs,” Accessed: Jul. 20, 2026. [Online]. Available: <https://kiro.dev/docs/specs/>
- [863] SNYK. “Directives,” Accessed: Jul. 20, 2026. [Online]. Available: <https://docs.snyk.io/ev-o-by-snyk/agentic-security-with-snyk-studio/directives>
- [865] Tencent Cloud. “Codebuddy code security,” Accessed: Jul. 20, 2026. [Online]. Available: <https://www.codebuddy.ai/docs/zh/cli/security>
- [869] Tencent Cloud. “Tencent Cloud agent runtime documentation,” Accessed: Jul. 20, 2026. [Online]. Available: <https://cloud.tencent.com/document/product/1814>
- [874] Open Source Security Foundation. “Open source project security baseline,” Accessed: Jul. 20, 2026. [Online]. Available: <https://baseline.openssf.org/versions/2026-02-19.html>
- [875] SLSA. “Provenance,” Accessed: Jul. 20, 2026. [Online]. Available: slsa.dev/provenance/v1
- [880] Microsoft. “AI red teaming agent: Automated adversarial scanning in Microsoft foundry,” Accessed: Jul. 20, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/foundry/concepts/ai-red-teaming-agent>
- [888] OWASP GenAI Security Project. “GenAI red teaming guide,” Accessed: Jul. 20, 2026. [Online]. Available: <https://genai.owasp.org/initiatives/red-teaming-initiative/>
- [892] Cloud Security Alliance. “Agentic AI red teaming guide,” Accessed: Jul. 20, 2026. [Online]. Available: <https://cloudsecurityalliance.org/>
- [898] promptfoo. “Promptfoo: Open-source framework for evaluating, testing and red-teaming LLM applications,” Accessed: Jul. 20, 2026. [Online]. Available: <https://www.promptfoo.dev/>
- [906] MITRE. “ATLAS: Adversarial threat landscape for artificial-intelligence systems,” Accessed: Jul. 20, 2026. [Online]. Available: <https://atlas.mitre.org/>
- [915] Coalition for Secure AI, “AI incident response framework, version 1.0,” Coalition for Secure AI, OASIS Open, Tech. Rep., Oct. 2025. Accessed: Jul. 1, 2026. [Online]. Available: <https://www.coalitionforsecureai.org/wp-content/uploads/2026/03/AI-Incident-Response-1.pdf>

- [917] GitHub. “Enforcing artifact attestations with a kubernetes admission controller,” Accessed: Jul. 1, 2026. [Online]. Available: docs.github.com/actions/security-guides/enforcing-artifact-attestations-with-a-kubernetes-admission-controller
- [918] Tekton Authors. “Getting started supply chain security,” Accessed: Jul. 1, 2026. [Online]. Available: [httpstekton.dev/docs/getting-started/supply-chain-security/](https://tekton.dev/docs/getting-started/supply-chain-security/)
- [922] HashiCorp. “Dynamic secrets for database credential management,” Accessed: Jul. 1, 2026. [Online]. Available: developer.hashicorp.com/vault/tutorials/db-credentials/database-secrets
- [924] Kubernetes Authors. “Admission control in kubernetes,” Accessed: Jul. 1, 2026. [Online]. Available: kubernetes.io/docs/reference/access-authn-authz/admission-controllers/
- [925] Argo Project. “Analysis and progressive delivery,” Accessed: Jul. 1, 2026. [Online]. Available: <https://argo-rollouts.readthedocs.io/en/stable/features/analysis/>
- [931] Google Cloud. “Choose your agentic AI architecture components,” Accessed: Jul. 1, 2026. [Online]. Available: <https://docs.cloud.google.com/architecture/choose-agentic-ai-architecture-components>
- [936] Istio Authors. “Security best practices,” Accessed: Jul. 1, 2026. [Online]. Available: <https://istio.io/latest/docs/ops/best-practices/security/>
- [947] Amazon Web Services. “Amazon bedrock guardrails,” Accessed: Jul. 20, 2026. [Online]. Available: <https://aws.amazon.com/bedrock/guardrails/>
- [962] OPEN POLICY AGENT. “Open policy agent documentation,” Accessed: Jul. 20, 2026. [Online]. Available: <https://www.openpolicyagent.org/docs/latest/>
- [963] Invariant Labs. “MCP-scan: Security scanner for model context protocol configurations,” Accessed: Jul. 20, 2026. [Online]. Available: explorer.invariantlabs.ai/docs/mcp-scan/
- [964] OpenTelemetry. “Opentelemetry genAI semantic conventions,” Accessed: Jul. 20, 2026. [Online]. Available: github.com/open-telemetry/semantic-conventions-genai
- [1041] Cloud Security Alliance AI Safety Initiative. “Aws bedrock agentcore as enterprise attack surface: AI agent apis and the execution boundary problem,” Accessed: Jul. 29, 2026. [Online]. Available: <https://labs.cloudsecurityalliance.org/research/csa-research-note-bedrock-agentcore-enterprise-attack-surface/>
- [1046] MITRE Corporation. “CVE-2026-44338: Praisnai authentication bypass,” Accessed: Jul. 21, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2026-44338>
- [1047] MITRE Corporation. “CVE-2025-34291: Langflow cross-site request forgery (CSRF) and remote code execution (RCE),” Accessed: Jul. 21, 2026. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2025-34291>
- [1056] OWASP. “Mcp06:2025 – intent flow subversion,” Accessed: Jul. 21, 2026. [Online]. Available: <https://owasp.org/www-project-mcp-top-10/2025/MCP06-2025%E2%80%93Intent-Flow-Subversion>
- [1061] T. Sato. “The governance audit record (GAR) for agentic AI systems,” Accessed: Jul. 21, 2026. [Online]. Available: <https://datatracker.ietf.org/doc/draft-sato-soos-gar/>

- [1065] OWASP. “Mcp10:2025 – context injection & over-sharing,” Accessed: Jul. 21, 2026. [Online]. Available: <https://owasp.org/www-project-mcp-top-10/2025/MCP10-2025%E2%80%93ContextInjection&OverSharing>

- [2] Stanford Institute for Human-Centered Artificial Intelligence (HAI). “Stanford AI index report 2026,” Accessed: Jul. 20, 2026. [Online]. Available: <https://hai.stanford.edu/ai-index/2026-ai-index-report>
- [13] N. Zeldovich and H. Corrigan-Gibbs. “MIT CSAIL computer systems security group,” Accessed: Jul. 29, 2026. [Online]. Available: <https://css.csail.mit.edu/>
- [14] Stanford CRFM. “Stanford center for research on foundation models,” Accessed: Jul. 29, 2026. [Online]. Available: <https://crfm.stanford.edu/>
- [15] Stanford Secure Computer Systems Group. “Jai: Lightweight Linux sandbox for AI agents.” Accessed: Jul. 20, 2026, Accessed: Jul. 20, 2026. [Online]. Available: <https://jai.scs.stanford.edu/>
- [27] Harvard Berkman Klein Center. “Berkman Klein center for internet & society,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cyber.harvard.edu/>
- [28] Princeton CITP. “Center for information technology policy (CITP),” Accessed: Jul. 21, 2026. [Online]. Available: <https://citp.princeton.edu/>
- [31] CMU Software Engineering Institute. “AI security incident response team (AISIRT),” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.sei.cmu.edu/about/divisions/cert/ai-security-incident-response-team/>
- [32] University of Illinois Urbana-Champaign. “Coordinated science laboratory,” Accessed: Jul. 29, 2026. [Online]. Available: <https://csl.illinois.edu>
- [33] Computer Science and Artificial Intelligence Laboratory (CSAIL) at MIT. “Daniela Rus – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.csail.mit.edu/person/daniela-rus>
- [35] ALFA Lab, MIT CSAIL. “ALFA lab’s research projects,” Accessed: Jul. 23, 2026. [Online]. Available: <https://alfagroup.csail.mit.edu/research/>
- [36] Stanford Institute for Human-Centered Artificial Intelligence. “Stanford institute for human-centered Artificial Intelligence (HAI),” Accessed: Jul. 21, 2026. [Online]. Available: <https://hai.stanford.edu/>
- [37] C. Barrett and M. J. Kochenderfer. “Stanford center for AI safety,” Accessed: Jul. 23, 2026. [Online]. Available: <https://aisafety.stanford.edu/>
- [38] Stanford Institute for Human-Centered Artificial Intelligence. “Mykel Kochenderfer – personal homepage.” Accessed: Jul. 20, 2026, Accessed: Jul. 20, 2026. [Online]. Available: <https://hai.stanford.edu/people/mykel-kochenderfer>
- [40] Stanford Computer Science Department. “Stanford secure computer systems group,” Accessed: Jul. 29, 2026. [Online]. Available: <https://www.scs.stanford.edu/>
- [41] The Berkeley Artificial Intelligence Research (BAIR) Lab. “Berkeley Artificial Intelligence research lab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://bair.berkeley.edu/>
- [42] Berkeley Robot Learning Lab, UC Berkeley. “Pieter Abbeel – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://people.eecs.berkeley.edu/~pabbeel/>

- [43] Sky Computing Lab, Electrical Engineering and Computer Sciences (EECS), UC Berkeley. “UC Berkeley Sky computing lab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://sky.cs.berkeley.edu/>
- [44] UC Berkeley Center for Human-Compatible AI. “Center for human-compatible Artificial Intelligence (CHAI),” Accessed: Jul. 21, 2026. [Online]. Available: <https://humancompatible.ai/>
- [45] Department of Electrical Engineering and Computer Sciences (EECS) at UC Berkeley. “Dawn Song – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www2.eecs.berkeley.edu/Faculty/Homepages/song.html>
- [46] Carnegie Mellon University. “CyLab security and privacy institute,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cylab.cmu.edu/>
- [47] Carnegie Mellon University. “Robotics institute,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.ri.cmu.edu/>
- [48] Purdue University. “ASSET research lab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://lt-asset.github.io/>
- [50] IDEAS Lab, Purdue University. “Aniket Bera – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cs.purdue.edu/people/faculty/bera89.html>
- [52] Center for Education and Research in Information Assurance and Security (CERIAS), Purdue University. “Center for education and research in information assurance and security,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cerias.purdue.edu/>
- [53] S. Kakade. “Sham M. Kakade – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://shamulent.github.io/>
- [55] S. Vadhan. “Harvard University privacy tools project,” Accessed: Jul. 21, 2026. [Online]. Available: <https://salil.seas.harvard.edu/privacy-tools-project>
- [56] J. Mickens. “Agentic AI and cybersecurity: Threats, governance, and strategy,” Accessed: Jul. 21, 2026. [Online]. Available: <https://events.seas.harvard.edu/event/agentic-ai-and-cybersecurity-threats-governance-and-strategy>
- [57] L. Levine. “Lionel Levine – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://lionellevine.github.io/>
- [58] Cornell University (Cornell). “Vitaly Shmatikov – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cs.cornell.edu/people/vitaly-shmatikov>
- [60] Georgia Institute of Technology. “School of cybersecurity and privacy,” Accessed: Jul. 21, 2026. [Online]. Available: scp.cc.gatech.edu
- [61] University of Illinois. “Information Trust Institute (ITI),” Accessed: Jul. 21, 2026. [Online]. Available: <https://iti.illinois.edu/>
- [62] Computer Science Department at the University of Illinois at Urbana-Champaign. “Bo Li – personal homepage.” [Online]. Available: <https://aisecure.github.io/>
- [63] Computer Science Department at the University of Illinois at Urbana-Champaign. “Heng Ji – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://blender.cs.illinois.edu/hengji.html>
- [64] K. Narasimhan. “Karthik Narasimhan – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://karthikncode.github.io/>

- [65] The Trustees of Princeton University. “Security & privacy, Princeton computer science,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cs.princeton.edu/research/areas/sp>
- [66] New York University Abu Dhabi (NYUAD). “Muhammad Shafique,” Accessed: Jul. 21, 2026. [Online]. Available: <https://nyuad.nyu.edu/en/academics/divisions/engineering/faculty/muhammad-shafique.html>
- [68] I. Sucholutsky. “AI thought partner lab (AITP),” Accessed: Jul. 21, 2026. [Online]. Available: <https://ilia10000.github.io/>
- [71] University of Toronto. “Schwartz Reisman Institute for Technology and Society,” Accessed: Jul. 21, 2026. [Online]. Available: <https://srinstitute.utoronto.ca/>
- [72] University of Toronto and the Vector Institute. “Cleverhans lab,” Accessed: Jul. 21, 2026. [Online]. Available: cleverhans-lab.github.io/
- [73] University of Toronto. “Toronto intelligent systems lab.” Accessed: Jul. 21, 2026, Accessed: Jul. 21, 2026. [Online]. Available: <https://tisl.cs.utoronto.ca/>
- [74] Dynamic Optimization & Reinforcement Learning Lab, Department of Mechanical and Industrial Engineering, University of Toronto. “Dynamic optimization and reinforcement learning lab.” Accessed: Jul. 21, 2026, Accessed: Jul. 21, 2026. [Online]. Available: <https://dor1.mie.utoronto.ca/research.html>
- [75] School of Computer Science and Linguistics, McGill University (McGill). “Siva Reddy – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://sivareddy.in/>
- [76] McGill NLP Group. “SafeArena benchmark,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/McGill-NLP/safearena>
- [77] University of British Columbia. “UBC security & privacy group,” Accessed: Jul. 21, 2026. [Online]. Available: spg.cs.ubc.ca/
- [78] The University of British Columbia. “Mathias Lécuyer – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://mathias.lecuyer.me/>
- [79] Blockchain@UBC. “Blockchain to improve the world,” Accessed: Jul. 21, 2026. [Online]. Available: blockchain.ubc.ca/
- [81] University of Oxford. “Michael Wooldridge – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cs.ox.ac.uk/people/michael.wooldridge/>
- [82] Oxford Martin School. “Robert Trager – oxford martin AI governance initiative,” Accessed: Jul. 21, 2026. [Online]. Available: <https://aigi.ox.ac.uk/people/robert-trager/>
- [83] University of Cambridge. “Stephen Cave – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.lcfi.ac.uk/>
- [84] CISPA Helmholtz Center for Information Security. “Mario Fritz – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cisa.saarland/group/fritz/>
- [85] Technical University of Munich. “Georg Sigl – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.ce.cit.tum.de/en/eisec/mitarbeiter/georg-sigl/>
- [87] Delft University of Technology. “Zeki Erkin – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.tudelft.nl/staff/z.erkin/>

- [95] University of Cambridge Computer Laboratory. “CHERI: Capability hardware enhanced RISC instructions,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cl.cam.ac.uk/research/security/ctsrd/cheri/>
- [96] Technical University of Munich. “Cyber-physical systems professorship in Heilbronn,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.ce.cit.tum.de/en/ce/research/professorships/hncps/>
- [98] Institute for Ethics in AI, University of Oxford (Oxford). “Institute team: Ethics in AI,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.oxford-aiethics.ox.ac.uk/meet-our-research-team>
- [99] University of Cambridge. “Most AI bots lack basic safety disclosures, study finds,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cam.ac.uk/stories/ai-agent-index-safety>
- [100] University of Cambridge. “Department of computer science and technology security group,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cl.cam.ac.uk/research/security/people/>
- [102] University of Cambridge. “Prorok Lab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.proroklab.org/>
- [103] S. Demetriou. “Soteris Demetriou – personal homepage,” Accessed: Jul. 4, 2026. [Online]. Available: <https://soteris.github.io/>
- [104] Applications, Platforms, and Systems Security Lab, Imperial College London. “NeSyDebates: Neuro-Symbolic debates for safeguarded generative AI,” Accessed: Jul. 21, 2026. [Online]. Available: <https://apss.doc.ic.ac.uk/>
- [105] Imperial College London. “AI security and privacy lab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://aisp.doc.ic.ac.uk/>
- [107] University College London (UCL). “Systems security research lab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://s2lab.cs.ucl.ac.uk/>
- [108] University College London (UCL). “UCL interaction centre,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.ucl.ac.uk/uclic/>
- [109] UCL Information Security Research Group. “M. Angela Sasse FREng – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: https://sec.cs.ucl.ac.uk/people/m_angela_sasse/
- [110] University of Edinburgh, School of Informatics. “Security, privacy and trust,” Accessed: Jul. 21, 2026. [Online]. Available: <https://informatics.ed.ac.uk/security-privacy-and-trust>
- [111] University of Edinburgh. “Centre for technomoral futures,” Accessed: Jul. 21, 2026. [Online]. Available: <https://efi.ed.ac.uk/ecosystem/centre-for-technomoral-futures/>
- [114] Department of Mechanical Engineering at the Technische Universität München. “Matthias Althoff – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.ce.cit.tum.de/en/cps/members/prof-dr-ing-matthias-althoff/>
- [115] Technische Universität München. “Stephan günnemann – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.cs.cit.tum.de/en/daml/team/damlguennemann/>

- [116] Eidgenössische Technische Hochschule Zürich. “Secure, private and robust AI lab: Publications,” Accessed: Jul. 21, 2026. [Online]. Available: <https://spylab.ai/publications/>
- [117] F. Tramèr. “Florian Tramèr – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.floriantramer.com/>
- [118] Eidgenössische Technische Hochschule Zürich. “AgentDojo GitHub repository,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/ethz-spylab/agentdojo>
- [119] Eidgenössische Technische Hochschule Zürich. “Robotic systems lab,” Accessed: Jul. 21, 2026. [Online]. Available: rsl.ethz.ch/
- [120] Eidgenössische Technische Hochschule Zürich. “Marco Hutter – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://rsl.ethz.ch/the-lab/people/person-detail.hutter.html>
- [121] Eidgenössische Technische Hochschule Zürich. “ANYmal,” Accessed: Jul. 21, 2026. [Online]. Available: <https://rsl.ethz.ch/robots-media/anymal.html>
- [122] DEDIS Lab, EPFL. “Decentralized and distributed systems laboratory,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.epfl.ch/labs/dedis/>
- [123] Center for Digital Trust, EPFL. “Omniledger,” Accessed: Jul. 21, 2026. [Online]. Available: c4dt.epfl.ch/article/omniledger-2/
- [124] VITA Lab, EPFL. “VITA Lab: Visual intelligence for transportation laboratory,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.epfl.ch/labs/vita/>
- [125] KU LEUVEN. “COSIC: Computer security and industrial cryptography,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.esat.kuleuven.be/cosic/>
- [127] KU LEUVEN. “Peggy Valcke – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.law.kuleuven.be/citip/en/staff-members/staff/00018835>
- [129] Delft University of Technology. “Michel van Eeten – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.tudelft.nl/en/staff/m.j.g.vaneeten/>
- [130] VIS/QUVA Lab, University of Amsterdam. “Cees G.M. Snoek – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.ceessnoek.info/index.php/biography/>
- [132] University of Amsterdam and the Vrije Universiteit Amsterdam. “ICAI: Innovation center for artificial intelligence,” Accessed: Jul. 21, 2026. [Online]. Available: <https://ivi.uva.nl/partnerships/icai-labs/icai-labs.html>
- [135] State Key Laboratory for Novel Software Technology, Nanjing University. “COSEC laboratory (sheng zhong),” Accessed: Jul. 21, 2026. [Online]. Available: <https://cosec.nju.edu.cn/>
- [136] 复旦白泽智能. “JADE series I: Large language model evaluation and governance: Targeted security evaluation platform based on linguistic mutation,” Accessed: Jul. 4, 2026. [Online]. Available: whitzard-ai.github.io/jade.html
- [137] 中国科学院计算技术研究所. “陈薇,” Accessed: Jul. 4, 2026. [Online]. Available: www.ict.ac.cn/sourcedb/cn/jssrck/202203/t20220314_6391556.html
- [138] 中国科学院计算技术研究所. “中国科学院计算技术研究所主页,” Accessed: Jul. 4, 2026. [Online]. Available: www.ict.ac.cn/

- [139] Beijing Academy of Artificial Intelligence. “FlagOpen open-source large model technology system: The ”Linux” for large models,” Accessed: Jul. 21, 2026. [Online]. Available: <https://flagopen.baai.ac.cn/>
- [142] OpenMMLab. “OpenMMLab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://openmmlab.com/>
- [145] 北京通用人工智能研究院. “科研部门: 通用人工智能安全北京市重点实验室,” Accessed: Jul. 4, 2026. [Online]. Available: www.bigai.ai/%E7%A7%91%E7%A0%94%E9%83%A8%E9%97%A8/
- [146] Tsinghua University. “Knowledge engineering research group (KEG),” Accessed: Jul. 21, 2026. [Online]. Available: <https://keg.cs.tsinghua.edu.cn/>
- [148] OpenBMB. “OpenBMB official webpage,” Accessed: Jul. 4, 2026. [Online]. Available: <https://www.openbmb.cn/>
- [149] OpenBMB. “ToolBench: An open platform for training, serving, and evaluating large language models for tool learning,” Accessed: Jul. 4, 2026. [Online]. Available: <https://github.com/OpenBMB/ToolBench>
- [150] Tsinghua University. “Tsinghua statistical artificial intelligence and learning lab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://ml.cs.tsinghua.edu.cn/>
- [151] PKU-ALIGNMENT TEAM. “PKU-Alignment,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/PKU-Alignment>
- [152] Peking University Institute for Artificial Intelligence. “Yaodong Yang – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://yangyaodong.com/>
- [153] Peking University Institute for Artificial Intelligence. “Multi-agent research center.” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.ai.pku.edu.cn/>
- [155] C. Lu. “SJTU machine vision and intelligence group,” Accessed: Jul. 4, 2026. [Online]. Available: www.mvig.org/
- [156] Shanghai Jiao Tong University. “X-LANCE laboratory,” Accessed: Jul. 4, 2026. [Online]. Available: x-lance.sjtu.edu.cn/
- [157] Zhejiang University. “Zhejiang university and alibaba group jointly establish artificial intelligence security joint laboratory,” Accessed: Jul. 21, 2026. [Online]. Available: <https://icsr.zju.edu.cn/2025/0715/c70143a3069695/page.htm>
- [158] Zhejiang University NESA Lab. “NESA: Network system security & privacy lab,” Accessed: Jul. 21, 2026. [Online]. Available: <https://nesa.zju.edu.cn/>
- [159] Zhejiang University. “Ziqi yang – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://person.zju.edu.cn/yangziqi>
- [160] Zhejiang University School of Cyber Science and Technology. “Faculty of the school of cyber science and technology, zhejiang university,” Accessed: Jul. 21, 2026. [Online]. Available: <https://icsr.zju.edu.cn/szdw/list.htm>
- [161] Nanjing University LAMDA. “LAMDA: Learning and mining from data,” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.lamda.nju.edu.cn/>
- [162] Nanjing University. “周志华,” Accessed: Jul. 4, 2026. [Online]. Available: cs.nju.edu.cn/zhouzh/

- [163] Reasoning and Learning Research Group, Nanjing University. “Reasoning and learning research group (yang gao),” Accessed: Jul. 21, 2026. [Online]. Available: <https://cs.nju.edu.cn/rl/>
- [164] M. Zhang and M. Yang. “复旦白泽智能 (Whitzard AI),” Accessed: Jul. 4, 2026. [Online]. Available: whitzard-ai.github.io/
- [165] Harbin Institute of Technology. “Research center for social computing and interactive robotics,” Accessed: Jul. 21, 2026. [Online]. Available: <https://encs.hit.edu.cn/2021/1224/c14651a267015/page.htm>
- [166] School of Computer Science and Technology, Harbin Institute of Technology (HIT). “Liu Ting,” Accessed: Jul. 21, 2026. [Online]. Available: <https://homepage.hit.edu.cn/liuting>
- [167] W. Zhang. “Weiming zhang,” Accessed: Jul. 21, 2026. [Online]. Available: <http://staff.ustc.edu.cn/~zhangwm/>
- [168] University of Science and Technology of China. “Yang Wei,” Accessed: Jul. 21, 2026. [Online]. Available: https://faculty.ustc.edu.cn/yangwei1/zh_CN/index.htm
- [169] University of Science and Technology of China (USTC). “Advanced data systems laboratory,” Accessed: Jul. 21, 2026. [Online]. Available: <https://adsl.ustc.edu.cn/>
- [170] X. Wei. “Xingxing wei,” Accessed: Jul. 21, 2026. [Online]. Available: <https://iai.buaa.edu.cn/info/1013/1099.htm>
- [171] Beihang University. “Zheng Zheng,” Accessed: Jul. 21, 2026. [Online]. Available: https://teacher.buaa.edu.cn/zhengzheng/zh_CN/index.htm
- [172] Gamma-Lab, Institute of Unmanned Systems, Beihang University. “通用自主多模态智能体课题组.” Accessed: Jul. 21, 2026. [Online]. Available: <https://www.zhihu.com/>
- [174] F. Wang. “Feiyue wang,” Accessed: Jul. 21, 2026. [Online]. Available: http://ia.cas.cn/rcdw/jcqcn/202404/t20240425_7131822.html
- [175] JIDIAI TEAM. “Jidiai: A platform for multi-agent decision intelligence,” Accessed: Jul. 21, 2026. [Online]. Available: https://github.com/jidiai/ai_lib
- [176] Institute of Automation, Chinese Academy of Sciences. “Scienceone scientific agent platform,” Accessed: Jul. 21, 2026. [Online]. Available: <https://ia.cas.cn/>
- [177] 中国科学院计算技术研究所. “曹娟,” Accessed: Jul. 4, 2026. [Online]. Available: www.ict.ac.cn/sourcedb/cn/jssrck/201011/t20101123_3028158.html
- [178] University of Chinese Academy of Sciences. “Kai chen,” Accessed: Jul. 21, 2026. [Online]. Available: <https://peopleucas.ac.cn/~kaichen>
- [179] S. Ge. “Shiming ge: Intelligent multimedia security group,” Accessed: Jul. 21, 2026. [Online]. Available: <https://simsg.ac.cn/people/geshiming.html>
- [180] X. Zhao. “Xianfeng zhao, university of chinese academy of sciences,” Accessed: Jul. 21, 2026. [Online]. Available: <https://peopleucas.edu.cn/~xianfeng>
- [185] Shanghai AI Laboratory Center for Trustworthy AI. “Ai45 research: Pathways toward trustworthy agi,” Accessed: Jul. 21, 2026. [Online]. Available: <https://ai45.shlab.org.cn/research/zh/>
- [187] OPENGVLAB. “OPENGVLAB,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/opengvlab>

- [188] OpenCompass Contributors. “OpenCompass,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/open-compass/opencompass>
- [193] OpenAI. “Agents SDK,” Accessed: Jul. 21, 2026. [Online]. Available: <https://platform.openai.com/docs/guides/agents-sdk>
- [239] Perplexity. “Secure intelligence institute,” Accessed: Jul. 13, 2026. [Online]. Available: <https://www.perplexity.ai/secure-intelligence-institute>
- [286] Alibaba Cloud. “OpenClaw security assistant,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/alibaba/openclaw-security-assistant>
- [296] Z.AI. “Open-AutoGLM: An open phone agent model,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/zai-org/Open-AutoGLM>
- [344] New York University Center for Data Science. “Yann LeCun faculty profile,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cds.nyu.edu/team/yann-lecun/>
- [359] OpenAI. “OpenAI red teaming network,” Accessed: Jul. 21, 2026. [Online]. Available: <https://openai.com/index/red-teaming-network/>
- [365] SPRING LAB, EPFL. “Carmela Troncoso – personal homepage,” Accessed: Jul. 21, 2026. [Online]. Available: <https://people.epfl.ch/carmela.troncoso>
- [366] NYU Center for Cybersecurity. “Ramesh Karri,” Accessed: Jul. 21, 2026. [Online]. Available: <https://cyber.nyu.edu/profile/ramesh-karri/>
- [376] Apple. “Apple Security Research,” Accessed: Jul. 21, 2026. [Online]. Available: <https://security.apple.com/>
- [378] PKU Alignment Group. “align-anything: Full-modal alignment training, data and evaluation framework,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/PKU-Alignment/align-anything>
- [379] Huawei Noah’s Ark Lab. “SMARTS: Scalable multi-agent reinforcement learning training school,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/huawei-noah/SMARTS>
- [380] IPADS, Shanghai Jiao Tong University. “Institute of parallel and distributed systems (IPADS),” Accessed: Jul. 21, 2026. [Online]. Available: <https://ipads.se.sjtu.edu.cn/>
- [381] 清华大学. “清华大学人工智能研究院,” Accessed: Jul. 4, 2026. [Online]. Available: <https://ai.tsinghua.edu.cn/>
- [382] Tsinghua University. “Institute for AI industry research,” Accessed: Jul. 4, 2026. [Online]. Available: air.tsinghua.edu.cn/
- [383] SJTU Laboratory of Cryptology and Computer Security. “Laboratory of cryptology and computer security (LoCCS),” Accessed: Jul. 21, 2026. [Online]. Available: <https://infosec.sjtu.edu.cn/>
- [384] 上海交通大学人工智能安全实验室. “人工智能安全实验室 · 上海交通大学,” Accessed: Jul. 4, 2026. [Online]. Available: sjtuaisecslab.github.io/
- [391] DARPA. “Automatic implementation of secure silicon,” Accessed: Jun. 30, 2026. [Online]. Available: <https://www.darpa.mil/research/programs/automatic-implementation-of-secure-silicon>

-
- [465] Y. Bargach. “Deadend CLI: Feedback-driven autonomous pentesting,” Accessed: Jul. 21, 2026. [Online]. Available: <https://github.com/xoxruns/deadend-cli>
- [502] Stanford Institute for Human-Centered Artificial Intelligence. “The 2026 AI index report — economy,” Accessed: Jul. 21, 2026. [Online]. Available: <https://hai.stanford.edu/ai-index/2026-ai-index-report/economy>
- [523] U. B. C. for Long-Term Cybersecurity. “Cltc uc berkeley center for long-term cybersecurity,” Accessed: Jul. 29, 2026. [Online]. Available: <https://cltc.berkeley.edu>
- [544] M. Roshan and S. Nagesh. “Securing multi-agent systems: An empirical analysis of security prompt hardening and residual risks,” Accessed: Jul. 16, 2026. [Online]. Available: <https://research.google/pubs/securing-multi-agent-systems-an-empirical-analysis-of-security-prompt-hardening-and-residual-risks/>